

システムログ管理ガイドライン （AWS環境版） 保険編

開発ベンダー向け 実装・運用要求事項

Log Management Guidelines on AWS — Insurance Edition (J-SOX and Industry Regulations)

本書について

本書は、日本の主要10業種シリーズの一冊であり、J-SOX対応 システムログ管理ガイドライン（AWS環境版）Ver.1.2 を基に、保険の法令・政府のガイドラインの調査結果（基準日 2026-10-06）を反映した業種編である。財務報告に関連するシステムや業種の法令が記録の保存を求めるシステムを AWS 上に構築・運用する際に、開発ベンダーが設計・実装・引継ぎすべきシステムログ管理の要求事項を定める。

目次

本書のポイント（要約）	6
本書が求めること	6
最初に発注者と確認すべき事項	7
0 はじめに	9
0.1 本書の目的	9
0.2 対象読者と前提知識	9
0.3 適用範囲	10
0.4 本書の位置づけ	11
0.5 責任分担	11
0.6 要求レベルの表記	14
0.7 本書の構成	14
0.8 用語の使い分け	15
0.9 改訂履歴	16
0.10 保険編について	17
1 J-SOXとIT統制の基礎 — なぜログが必要か	19
1.1 J-SOXの概要	19
1.2 内部統制の基本的要素と「ITへの対応」	20
1.3 IT統制の三層	21
1.4 IT全般統制の4領域 ITGC-A～D	22
1.5 IT業務処理統制とアプリケーションログ	24
1.6 2023年改訂のポイント	25
1.7 整備状況評価と運用状況評価 — ログが「運用の証拠」となる仕組み	26
1.8 監査人が典型的に求める証拠	29
1.9 開発ベンダーにとっての意味	31
1.10 保険の法令・ガイドラインとログ	33
2 ログ管理要求事項（LR-01～LR-14）	38
2.0 本章の読み方	38
2.1 LR-01 対象範囲の特定と網羅性	39
2.2 LR-02 記録項目（5W1H）	41
2.3 LR-03 時刻同期とタイムスタンプ	42
2.4 LR-04 改ざん防止と完全性の保証	43

2.5 LR-05 保存期間とライフサイクル	47
2.6 LR-06 ログへのアクセス制御と職務分掌	50
2.7 LR-07 暗号化と機微情報の保護	51
2.8 LR-08 監視とアラート	52
2.9 LR-09 定期レビューと証跡化	54
2.10 LR-10 検索・抽出（監査対応）	56
2.11 LR-11 バックアップ・可用性・欠損検知	57
2.12 LR-12 ログ設定の変更管理	58
2.13 LR-13 外部委託と責任分界	60
2.14 LR-14 文書化（ログ設計書・運用手順書）	61
2.15 要求事項とAWSサービスの対応	62
3 ログ種別と取得対象マトリクス（L-01～L-14）	64
3.1 マトリクスの見方	64
3.2 ログ種別マトリクス	66
3.3 各ログ種別の詳細	68
3.4 対象システムへの当てはめ	78
3.5 保険のシステムへの当てはめ	80
4 AWSサービス対応詳細（1） — 基盤ログの取得・保全	83
4.1 AWS CloudTrail	83
4.2 AWS Config	89
4.3 Amazon CloudWatch Logs	95
4.4 Amazon S3（ログアーカイブ）	100
4.5 AWS KMS	106
5 AWSサービス対応詳細（2） — 認証・操作・データ・ネットワーク・検知・分析	111
5.1 AWS IAM／AWS IAM Identity Center／ルートユーザー	111
5.2 AWS Systems Manager Session Manager と OSログ	114
5.3 Amazon RDS／Amazon Aurora／Amazon DynamoDB の監査ログ	119
5.4 ネットワーク・エッジログ（VPC Flow Logs、ELB、AWS WAF、Amazon CloudFront、API Gateway）	124
5.5 セキュリティ検知（Amazon GuardDuty、AWS Security Hub、Amazon Detective、Amazon Inspector、Amazon Security Lake）	127
5.6 通知・自動化（Amazon EventBridge、Amazon SNS、AWS Lambda、Amazon Data Firehose）	130
5.7 分析・抽出（Amazon Athena、AWS CloudTrail Lake、Amazon OpenSearch Service、Amazon Quick）	131
5.8 AWS Backup（ジョブ履歴、Backup Vault Lock、Backup Audit Manager）	133

5.9 CI/CD・IaC（AWS CodePipeline／CodeBuild／CodeDeploy、AWS CloudFormation、承認と本番反映の証跡）	135
5.10 AWS Organizations／AWS Control Tower	137
5.11 AWS Artifact と責任共有モデル	139
5.12 Amazon Time Sync Service	141
6 リファレンスアーキテクチャ	143
6.1 設計原則	143
6.2 標準構成（マルチアカウント）	145
6.3 ログフロー一覧	147
6.4 単一アカウント構成の場合（小規模案件向け）	150
6.5 ログアーカイブアカウントの設計詳細	152
6.6 監査人アクセスの設計	157
6.7 設計書に含めるべき図・表	158
7 保存期間とライフサイクル設計	161
7.1 基本方針	161
7.2 参照する法令・基準の年限	163
7.3 推奨保存期間	165
7.4 AWS 上の階層化実装	169
7.5 保存期限到来後の削除手続	174
7.6 保存期間変更の統制	175
7.7 コストとの両立	177
7.8 保険の保存期間	178
8 改ざん防止と完全性の実装	185
8.1 脅威モデル	185
8.2 多層防御の全体像	187
8.3 CloudTrail ログファイル整合性検証	189
8.4 S3 Object Lock による WORM 化	190
8.5 削除・停止・設定変更の予防	192
8.6 発見統制	202
8.7 完全性テスト	205
8.8 証跡として提出するもの	207
9 監視・アラートと定期レビュー運用	209
9.1 監視設計の考え方	209
9.2 アラートカタログ	212
9.3 実装パターン	217

9.4 レビューカタログ	221
9.5 レビュー記録の必須項目	226
9.6 例外・逸脱の取り扱い	228
9.7 運用引継ぎ時に開発ベンダーが提供するもの	230
10 職務分掌とログへのアクセス制御	231
10.1 職務分掌の原則	231
10.2 役割と権限マトリクス	233
10.3 AWS での実装	234
10.4 開発ベンダー・運用ベンダー要員のアクセス管理	239
10.5 特権ID管理の統制フロー	242
10.6 アクセス権棚卸の証跡	243
10.7 提出する設計書・証跡	245
11 開発ベンダーの実装責任と成果物	247
11.1 フェーズ別の実施事項	247
11.2 成果物一覧	248
11.3 ログ設計書の必須記載事項	250
11.4 実装ガイドーアプリケーション業務ログ（L-07）の実装規約	251
11.5 テスト観点	254
11.6 設定証跡の取得方法	259
11.7 受入チェックリスト	263
11.8 運用引継ぎと保守中の責任	265
12 監査対応ー証跡の抽出と提出	267
12.1 監査の流れとタイミング	267
12.2 典型的な依頼と対応するログ	269
12.3 抽出手順	272
12.4 抽出結果の完全性と提出パッケージ	283
12.5 監査人への直接アクセス提供	287
12.6 回答期限の目安と体制	288
12.7 よくある指摘と予防	290
12.8 保険での監査・検査対応の留意点	293
13 導入ロードマップと移行時の留意点	295
13.1 段階的導入	295
13.2 オンプレミスからの移行時の留意点	297
13.3 既存AWS環境への適用時の留意点	300
13.4 よくある不備と予防策	303

13.5 発注者との合意事項チェックリスト 306

付録	309
付録A 用語集	310
付録B 参考文献	313
付録C 設定パラメーター一覧	319
付録D 様式（レビュー記録・証跡提出記録）	328
付録E 要求事項一覧（LR-01～LR-14 サマリー）	333
付録F ログ種別一覧（L-01～L-14 サマリー）	335
付録G 保険の法令・ガイドライン調査	336

本書のポイント（要約）

本書が求めること

- 財務報告に関連するシステムの操作・変更・アクセスを、全アカウント・全リージョンで漏れなく、個人を特定できる形で記録する（LR-01～LR-03）。
- ログは保存専用のログアーカイブアカウントに集約し、S3 Object Lock（コンプライアンスモード）と SSE-KMS により、誰も改ざん・削除できない状態で保管する（LR-04、LR-07、第6章・第8章）。全体の構成は図6-1 に示す。
- 保存期間は J-SOX では定められていないため、第7章の基準（検索可能な期間は15か月以上、区分 (2) の監査ログは事業年度末から10年、区分 (3) の記録は 7.8 に示す期間と起算点）をもとに発注者が決定する（LR-05）。
- ログを削除・変更できる者を作らない。開発者・運用者とログ管理者を分離し、監査人には読み取り専用で提供する（LR-06、第10章）。
- ログの停止・削除・権限変更は即時に検知し、特権操作・アクセス権・変更は定期的にレビューして記録を残す（LR-08、LR-09、第9章）。
- 監査人の依頼に対し、期間・主体・対象で抽出し、抽出結果の完全性を示して提出できるようにする（LR-10、第12章）。

表S-1 ログ管理要求事項と主な AWS サービス（表2-1 の主たる実装手段）

ID	要求事項	主な AWS サービス	本文
LR-01	対象範囲の特定と網羅性	CloudTrail、Config、Organizations／Control Tower	2.1
LR-02	記録項目（5W1H）	CloudTrail、CloudWatch Logs、IAM／IAM Identity Center、Session Manager、RDS／Aurora	2.2
LR-03	時刻同期とタイムスタンプ	Amazon Time Sync Service（5.12）	2.3
LR-04	改ざん防止と完全性の保証	CloudTrail、S3（Object Lock）、Organizations／Control Tower	2.4
LR-05	保存期間とライフサイクル	CloudWatch Logs、S3（Object Lock）	2.5
LR-06	ログへのアクセス制御と職務分掌	S3（Object Lock）、KMS、IAM／IAM Identity Center、Session Manager、Organizations／Control Tower	2.6
LR-07	暗号化と機微情報の保護	CloudWatch Logs、S3（Object Lock）、KMS、RDS／Aurora	2.7
LR-08	監視とアラート	CloudTrail、CloudWatch Logs、EventBridge／SNS、GuardDuty／Security Hub CSPM	2.8
LR-09	定期レビューと証跡化	CloudTrail、Config、IAM／IAM Identity Center、Athena／CloudTrail Lake、GuardDuty／Security Hub CSPM	2.9
LR-10	検索・抽出（監査対応）	CloudTrail、Config、CloudWatch Logs、Athena／CloudTrail Lake	2.10
LR-11	バックアップ・可用性・欠損検知	Config、CloudWatch Logs、S3（Object Lock）	2.11
LR-12	ログ設定の変更管理	CloudTrail、Config、Organizations／Control Tower	2.12
LR-13	外部委託と責任分界	Organizations／Control Tower、Artifact	2.13
LR-14	文書化（ログ設計書・運用手順書）	－（ログ設計書等の成果物。第11章）	2.14

最初に発注者と確認すべき事項

- 対象範囲：財務報告に関連するシステム、区分 (3) の記録を扱うシステム、AWS アカウント、リージョン、および対象外とするものとその理由（0.3、LR-01）
- 保存年限：ログ種別ごとの区分（7.1.3）、検索可能期間とアーカイブ期間、最終的な保存年限と起算点（第7章、7.8、LR-05）
- アカウント構成：マルチアカウント構成（標準）か単一アカウント構成か、ログアーカイブアカウントの所有・運用主体（第6章）
- 役割の割り当て：ログ管理者（R-5）の所属と、開発者・運用者との分離の方法（第10章、LR-06）
- 監査人への提供方式：読み取り専用ロールを直接付与するか、ログ管理者が抽出して提出するか（第12章、LR-10）

- 監視体制：アラートの通知先、対応時間帯、エスカレーションの基準（第9章、LR-08）

0

はじめに

0.1 本書の目的

発注者は、金融商品取引法に基づく内部統制報告制度（以下「J-SOX」）の適用対象である上場企業である。同制度では、経営者が財務報告に係る内部統制の有効性を自ら評価して内部統制報告書を作成し、有価証券報告書と併せて内閣総理大臣に提出する。金融商品取引所に上場されている有価証券の発行会社等が提出する内部統制報告書は、その者と特別の利害関係のない公認会計士又は監査法人の監査証明を受けなければならないとされており（一定の要件を満たす新規上場会社等に対する例外規定がある）、発注者はこの監査証明を受ける立場にある。発注者は、財務報告に関連する業務システムを AWS 上に構築・運用しており、その開発を受託する開発ベンダーには、統制の有効性を事後に検証できる状態でシステムを引き渡す責務が生じる。

企業会計審議会が公表した『財務報告に係る内部統制の評価及び監査に関する実施基準』（以下「実施基準」。書誌事項は付録 B に示す）は、「IT に係る全般統制」（以下「IT 全般統制」）の具体例として、システムの開発、保守に係る管理、システムの運用・管理、内外からのアクセス管理などシステムの安全性の確保、外部委託に関する契約の管理の 4 領域を挙げている（Ⅰ.2(6)②〔IT の統制〕ロ a.）。経営者は、IT 全般統制と IT 業務処理統制の両者を評価する必要があるとされている（Ⅱ.3(3)⑤イ）。また実施基準は、「システムの仕様によっては、IT を利用して実施した手続や情報の変更等が適切に記録されないことがあり、そのような場合には、事後の検証が困難となる」との問題が生じうる」として、内部統制の整備及び運用に当たり適切な事後の検証方法を予め検討しておく必要があるとしている（Ⅰ.2(6)〔IT の利用〕）。システムログは、この「事後の検証」を成立させる一次証跡である。

実施基準は、運用状況の評価に関連文書の閲覧、担当者への質問、業務の観察、内部統制の実施記録の検証、自己点検の状況の検討等により行うとしており（Ⅱ.3(3)④イ）、ログはこのうち「内部統制の実施記録」に当たる中核的な証跡である。また実施基準は、電子記録について変更の痕跡が残り難い場合には、内部統制の無効化が生じてもその発見が遅れることがある点に留意することが重要であるとしている（Ⅱ.3(3)⑤ニ b）。ログが取得されていない、保存されていない、又は改ざん可能な状態にある統制は、事後の検証を他の証拠で代替せざるを得ず、有効性の立証が著しく困難となる。

本書は、この状況を踏まえ、開発ベンダーが実装し発注者・運用ベンダーへ引き継ぐべきログ管理の要求事項を、J-SOX の統制要件と AWS の各サービスに対応付けて示すものである。具体的には、(1) 何を記録するか（ログ種別 L-01～L-14）、(2) どの水準で記録・保全・監視するか（ログ管理要求事項 LR-01～LR-14）、(3) どの AWS サービスをどう設定して実現するか、(4) 何を成果物・証跡として残すか、の 4 点を規定する。本書が **必須** と示す事項を満たさない実装は、機能要件を満たしていても受入の対象とならない（0.6 に定める代替実装として発注者の承認を得た場合を除く）。推奨事項を省略する場合及び任意事項の採否は、0.6 に定める記録・承認の手続に従う。

0.2 対象読者と前提知識

本書の対象読者は、発注者から財務報告に関連するシステムの開発を受託する開発ベンダーの設計者、構築者、及び運用設計者である。加えて、運用を受託する運用ベンダーの運用設計者も、第 9 章、第 10 章、第 12 章の読者

に含まれる。

読者は AWS の基礎知識（アカウントとリージョンの概念、AWS IAM による権限付与、VPC とサブネット、Amazon S3、Amazon EC2 及びマネージドサービスの一般的な利用方法）を有していることを前提とする。一方、J-SOX や内部統制に関する知識は前提としない。制度上の最小限の背景は第 1 章に集約し、第 2 章以降は実装に必要な形へ翻訳して記述する。会計監査や内部統制評価の実務そのものを解説する文書ではない。

0.3 適用範囲

本書は、発注者の財務報告に関連するシステム、すなわち会計、販売、購買、在庫、給与、固定資産等の業務システムと、それらを支える基盤を対象とする。実施基準は「IT に係る全般統制は、通常、業務を管理するシステムを支援する IT 基盤（ハードウェア、ソフトウェア、ネットワーク等）を単位として構築することになる」としており（1.2(6)②〔IT の統制〕ロ a.）、本書もこの考え方に従い、業務システム単体ではなく基盤を含めた範囲を対象とする。

具体的な対象は次のとおりである。

- 業務システムのアプリケーション層（取引の登録・更新・承認、締め処理、帳票出力を含む）
- それらを稼働させる基盤層（AWS アカウント、OS、ミドルウェア、コンテナ実行環境、Amazon RDS / Amazon Aurora 等のデータベース、ネットワーク）
- 認証基盤（AWS IAM Identity Center、業務システムの利用者認証、特権アクセスの経路）
- データ連携基盤（業務システム間、及び外部システムとのインターフェース）
- 上記に変更を加える経路（CI/CD パイプライン、IaC の適用、手動運用作業の経路）
- ログの取得・配信・保全・分析に用いる基盤（ログ集約先アカウント、AWS Organizations の管理アカウント、セキュリティ検知・分析用アカウント、ログ配信先バケット・暗号鍵・組織ポリシーを含む）。これらは業務データを保持しない場合であっても、証跡の完全性を左右するため対象に含まれる（L-14、LR-06、LR-12、第 6 章）

一方、次のようなものは原則として本書の対象外である。

- 財務報告の数値に影響しない社内情報共有・社内広報用途のシステム
- 本番データを保持せず本番環境へ到達する経路を持たない開発・検証専用環境
- 財務報告に用いない参考分析・マーケティング分析用途のデータ利用

ただし、開発・検証環境であっても本番環境への変更経路（デプロイ権限、共有の IaC リポジトリ、共通の認証基盤）を持つ場合は、変更管理と権限管理の観点で対象に含まれる。本書の対象外に該当すると考えられるシステム・環境については、その判断根拠を設計書に記載したうえで発注者（R-2 システム所管。役割 ID は 0.5 節の表 0-1 で定義する）へ照会し、その確認結果を記録すること（**必須**）。

対象システムの範囲の最終決定は、発注者が行う内部統制の評価範囲の決定に従う（評価範囲の決定は発注者 内部統制担当（R-1）が行う）。開発ベンダーの判断のみで対象外として実装から除外しないこと（**必須**）。

業種編では、上記に加え、区分 (3) の記録（7.1.3）を保持・処理するシステムも本書の対象とする。財務報告の数値に影響しないシステムであっても、区分 (3) の記録を扱う場合は、上記の対象外の例に当たらない（0.10、7.8）。

0.4 本書の位置づけ

本書は、発注者の内部統制方針及び情報セキュリティポリシー（以下「発注者の確定文書」）を、AWS 環境におけるログ管理の技術要求へ具体化した下位文書である。個別の契約仕様書・提案依頼書との関係では、契約仕様書が優先し、本書はその技術的な補完として位置づけられる。

文書間の優先順位は、発注者の確定文書、契約仕様書、本書、提案依頼書の順とする。本書の記述がこれらと矛盾する場合は上位の文書に従うこと（**必須**）。発注者の確定文書と契約仕様書が矛盾する場合は、実装を進める前に発注者（R-2 システム所管。0.5 節の表0-1）へ照会し、解釈の確定を記録に残すこと（**必須**）。

本書は要求水準の基準線であり、上限ではない。本書に定めのない事項や、より高い水準の統制を開発ベンダーの判断で実装することは妨げないが、その場合も本書の必須事項を満たしていることが受入の条件となる。

● 注意

J-SOX の基準及び実施基準は、ログの保存年限、取得すべきログの一覧、使用すべき製品やサービスを規定していない。本書が示す保存期間の参照値は、会社法・法人税法等の他法令や公的機関のガイドラインを根拠とする実務上の目安であり、制度上の義務ではない（本書における「**推奨**」は 0.6 に定める要求レベルを指す語であり、これらの参照値とは区別する）。最終的な保存期間の決定は発注者が行う（第 7 章を参照）。同様に、本書が挙げる AWS サービスの構成は要求水準を満たす一つの実装例であり、同等以上の水準を満たす代替構成を否定するものではない。代替構成を採る場合は、要求事項ごとの充足根拠を設計書に記載すること（**必須**）。

0.5 責任分担

AWS の利用においては、責任共有モデル（Shared Responsibility Model）に基づき、AWS と利用者の責任が分界される。AWS はクラウド「の」セキュリティ（Security of the Cloud）、すなわち AWS クラウドで提供されるすべてのサービスを稼働させる基盤（施設、ハードウェア、ネットワーク、基盤ソフトウェア）の保護に責任を負う。利用者はクラウド「内」のセキュリティ（Security in the Cloud）に責任を負い、その範囲は選択するサービスにより変動する。Amazon EC2 のような IaaS では、ゲスト OS のパッチ適用、導入したアプリケーション、セキュリティグループの設定が利用者の責任に含まれる。Amazon S3 のような抽象化されたサービスでは、AWS が基盤・OS・プラットフォーム層を運用し、利用者はデータの分類・暗号化・アクセス管理に責任を負う。Amazon RDS・Amazon Aurora のようなマネージドデータベースでは、AWS が OS 及びデータベースエンジンの導入基盤を運用する一方、利用者はネットワークアクセス制御（セキュリティグループ）、パラメータグループ、データベースエンジンのアカウント管理、及び監査ログの有効化・出力設定に責任を負う（L-06、第 5 章）。統制は、物理・環境統制のように AWS から継承するもの（継承コントロール）、パッチ管理・構成管理・教育のように双方が担うもの（共有コントロール）、及び利用者固有のものに区分される。

ログ管理は、そのほぼ全体が利用者側の責任範囲に属する。AWS のサービスを利用していることは、財務報告に必要なログが自動的に取得・保全されていることを意味しない。

● 注意

AWS の既定状態は、本書が求める証跡水準（事後の検証を成立させる水準）を満たすように設定されていない。代表例を次に挙げる。

- AWS CloudTrail のイベント履歴は、リージョンごと・単一アカウントの過去 90 日間の管理イベントのみを保持し、組織全体の集約は提供しない。データイベント（Amazon S3 のオブジェクト操作等）・Insights イベント・ネットワークアクティビティイベントはイベント履歴に表示されず、証跡（trail）を作成した場合でもデータイベントは既定で無効のままである（有効化には追加設定と追加料金を要する）。なお、AWS CloudTrail Lake のイベントデータストアは 2026 年 5 月 31 日以降は新規顧客に開放されていないため、既存利用のない環境では選択肢とならない（第 4 章）。
- AWS Config は、自ら作成するカスタマー管理設定レコーダー（customer managed configuration recorder。アカウント・リージョンあたり 1 つ）と配信チャンネル（同じくアカウント・リージョンあたり 1 つ、AWS Config の利用に必須）を作成しない限り、財務報告に関連するシステムの構成変更履歴を記録しない。これとは別に、他の AWS サービスが自動作成するサービスにリンクされた設定レコーダー（service-linked configuration recorder）が常時記録を行っている場合があるが、記録対象と記録スコープが当該サービス側で固定され、スコープが INTERNAL の場合は配信チャンネルに設定項目が配信されない。したがって、これを財務報告に関連するシステムの構成変更履歴の取得根拠としないこと（**必須**）。
- Amazon CloudWatch Logs のロググループは、保持期間を設定しない限りログデータを無期限に保持する。

これらはいずれも開発ベンダーが明示的に設計・設定すべき事項であり、「マネージドサービスだからログは残っている」という前提で設計してはならない。各サービスの既定値・上限・記録スコープは変更され得るため、設計時点の公式ドキュメントで最新の仕様を確認したうえで、既定値に依存した設計としないこと（**必須**）。

本書における当事者と責務の対応を表 0-1 に示す。役割 ID（R-1～R-6）は本表で定義し、第 10 章の職務分掌設計及び第 12 章の抽出権限設計で用いる。呼称の使い分けは 0.8 節を参照。

表0-1 当事者と責務の分担

当事者	役割 ID	主な責務	本書での扱い
AWS（クラウドサービス事業者）	—	クラウド「の」セキュリティ。施設・ハードウェア・基盤ソフトウェア及びマネージドサービス自体の運用。統制状況は第三者保証報告書として提供	本書の要求事項の名宛人ではない。報告書の入手と評価は発注者が行う
発注者 内部統制担当	R-1	評価範囲の決定、統制の設計方針の承認、統制の評価と是正、監査人への対応	本書の発行者。受入判定の主体
発注者 システム所管（システムオーナー）	R-2	対象システムの統制オーナー。ログ要件の承認、保存期間の決定、外部委託の管理	要求の確定・変更承認の窓口
開発ベンダー 開発者	R-3	ログ機能の設計・実装・テスト、ログ設計書と運用手順書の作成、運用引継ぎ	本書の主たる名宛人（貴社）
運用者（運用ベンダー含む）	R-4	ログ取得の継続運用、監視とアラートへの一次対応、定期レビューの実施と記録	引継ぎ先。手順書と証跡様式の受領者
ログ管理者（開発・運用から独立）	R-5	ログ基盤の保全、ログへのアクセス権管理、完全性検証、ログ設定変更の管理	開発及び運用のいずれからでも独立した役割として設置すること（ 必須 ）。権限設計は第 10 章に定める）
監査人（内部監査・外部監査、読み取り専用）	R-6	ログを証跡として閲覧・抽出し、統制の有効性を検証	ログデータに対して読み取り専用となる抽出経路を用意すること（ 必須 ）。クエリ結果の出力先など、抽出に付随して必要となる書き込み権限の範囲は第 12 章に定める）

本書における照会・承認の窓口は、原則としてシステム所管（R-2）とし、評価範囲の決定及び受入判定は内部統制担当（R-1）が行う。R-2 を経由した照会・承認の結果は、いずれも設計書に記録すること（**必須**）。

AWS 側の統制については、発注者が AWS Artifact から第三者保証報告書を取得し、報告書の名称、対象期間、対象サービス・対象リージョンが評価対象範囲と整合しているかを確認する。開発ベンダーは、確認結果（対象範囲に含まれないサービス・リージョンの有無）の共有を受け、設計上の前提として設計書に記録すること（**必須**）。AWS Artifact の機密指定文書は、利用条件により共有先が自社内・規制当局・監査人に限定されている。したがって、発注者が取得した文書をそのまま開発ベンダーへ提供することはできず、開発ベンダーも自ら取得した文書を発注者の評価証跡として配布・第三者提供しないこと（**必須**）。開発ベンダーは発注者の確認結果のみを受領し、原本の開示の要否は発注者が判断する。NDA を要しない公開版の要約報告書（SOC 3）も公表されているが、これは SOC 2 報告書の公開要約であり、財務報告に係る内部統制を対象とする SOC 1 報告書の代替とはならない。開示制約により SOC 1 / SOC 2 報告書そのものを共有できない場合の補足資料として位置づけられる。

● 監査の視点

実施基準は「委託業務に関しては、委託者が責任を有しており、委託業務に係る内部統制についても評価の範囲に含まれる」としている（II.2(1)②イ）。2023年4月7日に公表された改訂実施基準では、評価対象となる委託業務の例に「情報システムの開発・運用・保守などITに関する業務を外部の専門会社に委託する場合」が明示され、あわせてITの委託業務に係る統制の重要性の高まりと、クラウドやリモートアクセスの活用に伴うセキュリティ確保の重要性が記載された。改訂基準及び改訂実施基準は、2024（令和6）年4月1日以後開始する事業年度における評価及び監査から適用されている。実施基準は、委託業務が企業の重要な業務プロセスの一部を構成している場合には、経営者が受託会社の内部統制の有効性を評価しなければならないとしている（II.2(1)②イ）。したがって、開発ベンダー及び運用ベンダーの作業そのもの（誰がいつ本番環境に接続し、何を変更したか）も、発注者の評価範囲の決定によっては評価対象となり得る。貴社要員のアクセス記録・作業記録が取得・保全されていることは、貴社自身の説明責任にも直結する。

0.6 要求レベルの表記

本書の要求事項には、**必須**／**推奨**／**任意**のいずれかの要求レベルを付す。定義と受入判定との関係を表0-2に示す。

表0-2 要求レベルの定義と受入判定との関係

表記	定義	受入判定における扱い
必須	発注者が受入条件とする事項	未充足の場合は受入不可。代替実装により同等の統制目的を達成する場合も、充足根拠を設計書に記載し、発注者（R-2）の承認を得ること
推奨	合理的な理由なく省略しない事項	省略する場合は、理由、リスク評価、代替統制を設計書に記録し、発注者（R-2）の承認を得ること。無記録の省略は必須未充足と同様に扱う
任意	発注者と協議して採否を決める事項	協議の結果と採否を設計書に記録すること。採否そのものは受入の可否を左右しない

要求事項の文は「～すること」で終え、要求レベルを併記する。本章では、文末に括弧書きで要求レベルを示す。要求レベルの表示を伴わない記述は、背景説明、解説、又は参考情報であり、それ自体は受入判定の対象としない。

第0章は本書の読み方を定める章であるが、本章に置いた手続的指示（適用範囲の照会と確認結果の記録、対象外判断を開発ベンダー単独で行わないこと、文書間の優先順位の遵守、文書間矛盾の照会と解釈の記録、代替構成の充足根拠の記載、既定値に依存しない設計、サービスにリンクされた設定レコーダーを構成変更履歴の取得根拠としないこと、AWS Artifactの機密指定文書の取扱い、AWS側統制の確認結果の記録、照会・承認結果の記録、ログ管理者の独立設置、監査人向け抽出経路の用意、参照表記の統一、受入前の自己点検、参照版数の明記）にも要求レベルを付し、受入判定の対象とする。表0-2に定める推奨事項の省略記録及び任意事項の協議・採否の記録も、同様に受入判定の対象とする。これらは第2章の対応する要求事項（LR-06、LR-13、LR-14等）並びに第10章、第11章及び第12章の設計要求と重複して規定されるものであり、いずれか一方を満たせば足りるという趣旨ではない。要求事項の一覧は付録Eに集約する。

0.7 本書の構成

本書は0章から13章及び付録で構成する。各章の内容を表0-3に示す。

表0-3 本書の構成

章	内容
0 はじめに	本書の目的、適用範囲、責任分担、要求レベルの表記、用語と固定 ID の体系
1 J-SOXとIT統制の基礎 — なぜログが必要か	制度の枠組み、IT 全般統制の 4 領域（ITGC-A～D）、ログが統制の証跡となる場面
2 ログ管理要求事項（LR-01～LR-14）	本書の中核。要求事項ごとの要求水準、要求レベル、及び残すべき証跡
3 ログ種別と取得対象マトリクス（L-01～L-14）	ログ種別の定義と、システム区分ごとの取得要否・取得元の対応表
4 AWSサービス対応詳細（1）— 基盤ログの取得・保全（CloudTrail、Config、CloudWatch Logs、S3、KMS）	基盤ログの取得・配信・暗号化・保全に関する設定要求と、設定値の証跡化
5 AWSサービス対応詳細（2）— 認証・操作・データ・ネットワーク・検知・分析	認証基盤、サーバ操作、データベース、ネットワーク、セキュリティ検知、分析基盤の設定要求
6 リファレンスアーキテクチャ	マルチアカウント構成、ログ集約先アカウント、配信経路と暗号化の設計
7 保存期間とライフサイクル設計	保存期間の根拠と決定手順、ストレージクラスの階層化、コストと統制の両立
8 改ざん防止と完全性の実装	書き込み後変更不可の実装、ログファイル整合性検証、削除・停止の防止
9 監視・アラートと定期レビュー運用	検知すべき事象、通知経路とその生存確認、定期レビューの手順と証跡化
10 職務分掌とログへのアクセス制御	R-1～R-6 に対応する権限設計、特権アクセスの統制、ログ基盤へのアクセス制御
11 開発ベンダーの実装責任と成果物（ログ設計書の必須記載事項、テスト観点、受入チェックリストを含む）	納品すべき成果物の一覧、自己点検の方法、運用引継ぎの範囲
12 監査対応 — 証跡の抽出と提出	監査人の依頼類型ごとの抽出手順、抽出結果の提出形式と再現性の確保
13 導入ロードマップと移行時の留意点	段階的導入の順序、既存環境からの移行、期中移行時の証跡の連続性

付録は次のとおりである。付録 A 用語集、付録 B 参考文献、付録 C 設定パラメータ一覧、付録 D 様式、付録 E 要求事項一覧（LR-01～LR-14 と要求レベルの一覧）、付録 F ログ種別一覧（L-01～L-14 の定義と取得元の一覧）、付録 G 保険の法令・ガイドライン調査（業種別調査の該当部分の全文）。

実装を担当する読者は、第 2 章で要求水準を把握したうえで、第 3 章で自システムの取得対象を特定し、第 4 章・第 5 章で設定内容へ落とし込む順序で読み進めるとよい。受入前には第 11 章のチェックリストにより自己点検を行うこと（**必須**）。

0.8 用語の使い分け

本書では当事者を次のように呼び分ける。「発注者」は本書を発行し受入判定を行う上場企業である。「開発ベンダー」は本書の名宛人であり、文脈により「貴社」と表記する。「運用ベンダー」は運用を受託する事業者を指

し、開発ベンダーと同一事業者である場合も、役割としては区別する。「監査人」は内部監査部門及び外部監査を担う公認会計士・監査法人を総称し、本書では読み取り専用の利用者として扱う。「ログ管理者」は開発と運用のいずれからも独立してログ基盤を管理する役割を指す。

● 補足

本書における役割は、組織や人ではなく責務の単位である。小規模な体制で一人が複数の役割を兼ねる場合であっても、ログ管理者（R-5）を開発者（R-3）又は運用者（R-4）と同一人物が兼務すると、自らの操作記録を自ら管理できる状態となる。発注者は、この状態を代替統制のない限り認めない。兼務が避けられない場合の代替統制は第 10 章に定める。

本書は、参照の一貫性を保つため 4 系統の固定 ID を用いる。他章・他文書からの参照は、章番号（第 N 章）、節番号（N.M 節）、表番号（表 N-M）、及びこれらの固定 ID によって行うこと（**必須**）。体系の概要を表 0-4 に示す。

表 0-4 固定 ID の体系

記号体系	対象	件数	主な参照先
ITGC-A～ITGC-D	実施基準が例示する IT 全般統制の 4 領域	4	第 1 章、第 2 章（各要求事項が対応する領域の明示）
LR-01～LR-14	本書が定めるログ管理要求事項	14	第 2 章（定義）、第 4 章～第 12 章（実装・成果物・監査対応）、付録 E
L-01～L-14	ログ種別	14	第 3 章（定義とマトリクス）、第 4 章・第 5 章、付録 F
R-1～R-6	役割	6	0.5 節（表 0-1 で定義）、第 10 章（権限設計）、第 12 章（抽出権限）

IT 全般統制の 4 領域は、実施基準の例示に対応し、本書では次の名称で参照する。ITGC-A システムの開発、保守に係る管理。ITGC-B システムの運用・管理。ITGC-C 内外からのアクセス管理などシステムの安全性の確保。ITGC-D 外部委託に関する契約の管理。第 2 章の各要求事項には、対応する ITGC 領域を併記し、どの統制目的を満たすための要求であるかを明示する。

なお、実施基準は IT の統制目標として、準拠性、信頼性、可用性、機密性を挙げ、信頼性を構成する概念として正当性（取引が組織の意思・意図に沿って承認され、行われること）、完全性（記録した取引に漏れ、重複がないこと）、正確性（発生した取引が財務や科目分類などの主要なデータ項目に正しく記録されること）を定義している（1.2(6)②〔IT の統制〕イ）。本書でこれらの語を用いる場合は、この定義に従う。

0.9 改訂履歴

本書の改訂は発注者が行う。開発ベンダーは、参照した版数を設計書及び受入資料に明記すること（**必須**）。

表0-5 改訂履歴

版数	発行日	改訂内容
1.0	2026-09-12	初版発行
1.1	2026-09-12	検証指摘（表現・体裁）の反映、表の見切れとコード例・表のページまたぎの解消、文字サイズの適正化
1.2	2026-09-12	Amazon RDS for Db2 の監査ログ（Db2 監査ログ記録）に関する要求事項・設定値・構成・監視・証跡を追記。付録F の本文参照の節番号を訂正
業種編 1.0	2026-10-09	版 1.2 を基に、保険の法令・ガイドラインの調査結果（基準日 2026-10-06）を反映した業種編を作成。保存期間の推奨（2.5、第 7 章）を業種別調査のログの 3 区分に合わせて改め、要約、0.3、図6-1、13.5、付録 E をこれに合わせて。7.3 に区分 (3) の実装上の要求を加え、0.10、1.10、2.5.5、3.5、7.1.3、7.8、12.8、付録 G を追加

0.10 保険編について

本書は、版 1.2 を基に、保険の法令・政府のガイドラインの調査結果（業種別調査。基準日 2026-10-06）を反映した業種編である。財務報告に関連するシステムに加え、保険の法令が記録の保存を求めるシステムも対象とする。

対象とする事業者は、保険業法に基づく保険会社（生命保険会社・損害保険会社。株式会社と相互会社がある。外国保険会社等、少額短期保険業者を含む）、保険募集人（生命保険募集人・損害保険代理店・少額短期保険募集人）、保険仲立人、および金融サービス提供法に基づき保険媒介業務を行う金融サービス仲介業者である。保険募集人のうち規模の大きい「特定保険募集人」「特定大規模乗合保険募集人」には、追加の義務がある（付録 G の § 6.1）。これに当たらない一般の保険募集人には、保険業法上の帳簿書類の保存義務はない（付録 G の IN4）。少額短期保険業者に固有の帳簿書類の保存規定は、業種別調査が検索した範囲では見つかっていないが、準用規定の網羅的な確認はしていない（付録 G の § 6.7 の 5）。

版 1.2 は、上場企業の財務報告に係る内部統制（J-SOX）を前提としている。内部統制報告書の提出義務を負うのは、有価証券報告書の提出会社のうち一定の会社であり、自社が該当するかは確認が必要である（付録 G の J6）。一方、保険業法などの業種の法令は、付録 G の § 6.1 に示す事業者に適用され、その適用は J-SOX の適用範囲に限られない。保険業法は、監査ログの保存年数を直接定めていない。保存期間を定めるのは帳簿書類・記録であり、その一部は保険契約の消滅（保険期間の終了）を起算点とする。この点が保険業の特徴である（付録 G の § 6.1）。

版 1.2 から改めたのは、保存期間の推奨である。2.5（LR-05）、7.3、表7-2 を業種別調査のログの 3 区分に合わせて改め、3 区分を説明する 7.1.3 を追加した。あわせて、要約、0.3（適用範囲）、図6-1、13.5、付録 E を 3 区分に合わせて、7.3 に区分 (3) の実装上の要求を加えた。保険に固有の内容は、次の節に示す。

- 1.10 保険の法令・ガイドラインとログ（表1-4）
- 2.5.5 保険での適用
- 3.5 保険のシステムへの当てはめ（表3-3）
- 7.8 保険の保存期間（表7-5、表7-6）
- 12.8 保険での監査・検査対応の留意点
- 付録 G 保険の法令・ガイドライン調査（業種別調査の該当部分の全文）

保険に固有の記述の根拠は、「(付録 G の IN3)」のように、付録 G の行番号で示す。付録 G の「§」の番号は業種別調査の番号であり、本書の章・節の番号とは別である。ほかの業種の行（例：SC13）は、その業種編の付録 G に収録している。

● 注意

業種別調査は法的助言ではない。最終的な決定には、法務部門と監査部門（内部統制）の確認が必要である（付録 G の冒頭）。特に、区分 (2) の「事業年度末から10年」は、株式会社である保険会社では会社法432条2項（J1）、相互会社では保険業法54条の2第2項（IN1）に準じて扱う解釈であり、監査ログを明記した法定の期間ではない（要法務確認。付録 G の § 1.1、IN1）。

1

J-SOXとIT統制の基礎 — なぜログが必要か

本章は、開発ベンダーが本書の要求事項（LR-01～LR-14）を「なぜそこまで求められるのか」を理解した上で設計できるよう、制度上の根拠を整理する。結論を先に述べると、J-SOX の下でログが必要なのは、セキュリティ対策として望ましいからではなく、**統制が評価対象期間を通じて実際に運用されていたことを、後日、第三者が検証できる形で示す中心的な記録**が求められるためである。ログが無い、欠損している、または改ざん可能である場合、統制そのものは存在していても「運用されていたことを証明できない」状態となり、内部統制の不備として扱われ得る。

1.1 J-SOXの概要

1.1.1 法的根拠と対象

J-SOX とは、金融商品取引法（以下「金商法」）に基づく**内部統制報告制度**の通称である。法令上「J-SOX」という語は用いられない。制度の骨格は次の三層で構成される。

- **金商法 第24条の4の4 第1項:** 有価証券報告書の提出義務を負う会社のうち政令で定めるものは、「事業年度ごとに、当該会社の属する企業集団及び当該会社に係る財務計算に関する書類その他の情報の適正性を確保するために必要なものとして内閣府令で定める体制について、内閣府令で定めるところにより評価した報告書」（＝**内部統制報告書**）を、有価証券報告書と併せて内閣総理大臣に提出しなければならない。同条第2項により、提出義務のない有価証券報告書提出会社も任意に提出できる。
- **金商法施行令 第4条の2の7 第1項:** 上記「政令で定めるもの」は、株券・優先出資証券等の発行者である。実務上は上場会社を対象となる。
- **内部統制府令（財務計算に関する書類その他の情報の適正性を確保するための体制に関する内閣府令、平成19年内閣府令第62号）第3条:** 評価対象となる「体制」とは「当該会社における財務報告が法令等に従って適正に作成されるための体制」をいう。

本書の発注者は上記の対象会社であり、貴社が受託して構築するシステムが財務報告に関連する場合、そのシステムは発注者の評価範囲に含まれ得る。ただし最終的な評価範囲は、財務報告に対する金額的及び質的影響の重要性を考慮して発注者が決定する（実施基準 II.2(2)）。

1.1.2 経営者評価と監査人監査

制度は二段構えである。第一に**経営者**が自社の財務報告に係る内部統制の有効性を評価し、その結果を内部統制報告書に記載する。第二に、内部統制監査を行う**監査人**（この場面では公認会計士または監査法人）が、その内部統制報告書の適正性について監査証明を行う。根拠は金商法 第193条の2 第2項であり、金融商品取引所に上場されている有価証券の発行会社等が第24条の4の4に基づき提出する内部統制報告書には、「その者と特別の利害関係のない公認会計士又は監査法人」の監査証明を受けなければならないと定める。ただし同項ただし書第4号により、資本の額等が内閣府令で定める基準に達しない上場会社等が、上場会社等に初めて該当した日等から「三年を経過

する日までの間に内部統制報告書を提出する場合」は監査証明を要しない。なお、金商法上の内部統制監査を行うのは公認会計士または監査法人であるが、本書では内部監査部門を含む総称として「監査人」を用いる。

評価および監査の具体的な基準は法令本体には書かれていない。内部統制府令第1条第1項は「この府令において定めのない事項については、一般に公正妥当と認められる財務報告に係る内部統制の評価の基準に従うものとする」と定め、同条第5項が、企業会計審議会により公表された「**財務報告に係る内部統制の評価及び監査に関する基準**」（企業会計審議会の公表文書としての正式名称は「財務報告に係る内部統制の評価及び監査の基準」）が、第1項に規定する評価の基準および第4項に規定する監査に関する基準に該当すると規定する。本書では以下、これを「**基準**」と呼ぶ。企業会計審議会は、この基準とあわせて、その適用にあたっての実務上の指針となる**実施基準**（以下「**実施基準**」）を公表しており、2023年4月7日の改訂も基準と実施基準の双方を対象としている。したがって本書が制度上の根拠として参照するのは、金商法・内部統制府令と、この基準・実施基準である。加えて、実務上の具体化にあたっては経済産業省が公表するIT統制関連のガイダンスを補足的に参照する。

● 補足

J-SOXの目的は**財務報告の信頼性**に限定される。実施基準は「財務報告の信頼性以外の他の目的を達成するためのITの統制の整備及び運用を直接的に求めるものではない」としている。情報セキュリティ全般の対策とJ-SOX対応は目的が異なるため、本書の要求事項は財務報告に関連するシステムに対する要求として読むこと。ただし後述1.6のとおり、2023年改訂によりサイバーリスクを踏まえたセキュリティの確保が「ITへの対応」の一部として明記されており、両者は実務上ほぼ分離できない。

1.2 内部統制の基本的要素と「ITへの対応」

基準は、内部統制の基本的要素として「統制環境、リスクの評価と対応、統制活動、情報と伝達、モニタリング（監視活動）及びIT（情報技術）への対応の6つ」を挙げる。このうち第6の要素である「ITへの対応」が、開発ベンダーの業務に直接関わる。

基準1.2(6)は「ITへの対応とは、組織目標を達成するために予め適切な方針及び手続を定め、それを踏まえて、業務の実施において組織の内外のITに対し適時かつ適切に対応することをいう」と定義し、「ITへの対応は、IT環境への対応とITの利用及び統制からなる」とする。

1.2.1 IT環境への対応

基準1.2(6)①は「IT環境とは、組織が活動する上で必然的に関わる内外のITの利用状況のことであり、社会及び市場におけるITの浸透度、組織が行う取引等におけるITの利用状況、及び組織が選択的に依拠している一連の情報システムの状況等をいう」と定義する。実施基準は考慮すべき事項として、社会及び市場におけるITの浸透度、組織が行う取引等におけるITの利用状況、組織が選択的に依拠している一連の情報システムの状況、ITを利用した情報システムの安定度、**ITに係る外部委託の状況**の5点を挙げる。最後の項目は、開発ベンダーへの委託そのものが発注者の評価対象要素であることを意味する。

1.2.2 ITの利用及び統制 — 本書の出発点

実施基準1.2(6)②〔ITの利用〕には、本書全体の出発点となる記述がある。

● 補足

実施基準 1.2(6)②〔ITの利用〕：「システムの仕様によっては、ITを利用して実施した手続や情報の変更等が適切に記録されないことがあり、そのような場合には、事後の検証が困難となるとの問題が生じる。したがって、内部統制の整備及び運用に当たっては、ITを利用した情報システムの特性を十分に理解し、予め計画的に準備を進めるとともに、適切な事後の検証方法等について検討しておく必要がある。」

「適切に記録されない」「事後の検証が困難」「予め計画的に準備」という3つの表現が、本書のログ要求の根拠である。事後の検証に耐える記録は、システムが稼働してから追加できるとは限らない（1.9.3 参照）。したがってログ設計は要件定義・設計フェーズの成果物として扱う。

同じく実施基準 1.2(6)②〔ITの利用〕は、統制活動が自動化されている場合について「プログラムの不正な改ざんや不正な使用等があった場合に、プログラムに精通した者しか対応できず、不正等の適時の発見が困難になる」といった問題点も考えられ、適切なアクセス管理等の措置を講じておくことにつき留意する必要がある」とする。自動化された処理ほど、アクセス管理とその記録が重要になるという構造である。

1.2.3 ITの統制目標

実施基準 1.2(6)②〔ITの統制〕は、ITの統制目標の例として準拠性・信頼性・可用性・機密性を挙げる。このうち**信頼性**は「情報が組織の意思・意図に沿って承認され、漏れなく正確に記録・処理されること」とされ、次の3要素に分解される。本書 1.5 節および第2章の記録項目要求（LR-02）は、この3要素を証明するための項目定義である。

- **正当性**：「取引が組織の意思・意図にそって承認され、行われること」
- **完全性**：「記録した取引に漏れ、重複がないこと」
- **正確性**：「発生した取引が財務や科目分類などの主要なデータ項目に正しく記録されること」

1.3 IT統制の三層

IT統制は、対象範囲の広さに応じて三層で語られる。実施基準が明示的に定義しているのはIT全般統制（IT General Controls）とIT業務処理統制（IT Application Controls）の二層である。「IT全社統制」は経済産業省「システム管理基準 追補版（財務報告に係るIT統制ガイダンス）」（2024年（令和6年）12月25日改訂）が用いる用語であり、金融庁の基準・実施基準の本文には同名の定義を確認できない。本書では実務上の整理として三層を用いるが、根拠の出所が異なる点に留意すること。

表1-1 IT統制の三層とログの関与

層	定義（出所）	統制の例	ログの関与
IT全社統制	「企業集団全体（連結対象企業を含む）を対象としたITに係る内部統制のことであり、企業集団全体のITを健全に維持、監督するために構築するもの」（経済産業省「システム管理基準 追補版」）。	IT基本方針・情報セキュリティ方針、IT組織体制と職務分掌の定め、外部委託方針、システム化計画の承認体制	ログ管理方針そのもの（対象・記録項目・保存期間・レビュー・責任者）の文書化が証跡となる。開発ベンダーはログ設計書（LR-14）で発注者の方針に適合していることを示す。
IT全般統制（ITGC）	「業務処理統制が有効に機能する環境を保証するための統制活動を意味しており、通常、複数の業務処理統制に関係する方針と手続」（実施基準Ⅰ.2(6)②〔ITの統制〕ロ a.）。「通常、業務を管理するシステムを支援するIT基盤（ハードウェア、ソフトウェア、ネットワーク等）を単位として構築する」。	ITGC-A～Dの4領域（1.4節、表1-2）。AWS環境ではアカウント・VPC・共通基盤サービス群が評価単位となり得る。	基盤・運用側のログが中心。L-01～L-06、L-08～L-14（L-07のうちエラー・例外処理の記録はITGC-Bの証跡としても用いる。表1-2参照）。統制の運用証跡の大半がここに集中する。
IT業務処理統制（ITAC）	「業務を管理するシステムにおいて、承認された業務が全て正確に処理、記録されることを確保するために業務プロセスに組み込まれたITに係る内部統制」（実施基準 同ロ b.）。「ITに係る業務処理統制の評価は、基本的には個々のシステム毎に行う必要がある」（Ⅱ.3(3)⑤ハ）。	入力情報の完全性・正確性・正当性を確保する統制、例外処理（エラー）の修正と再処理、マスタ・データの維持管理、システムの利用に関する認証・操作範囲の限定	アプリケーションが自ら出力するログが中心。L-07を核とし、L-08・L-09が処理の完全性を補完する。加えて認証・権限（L-04）とDB監査（L-06）が補完する。

三層は独立ではない。実施基準Ⅱ.3(3)⑤ニ c. は、自動化された内部統制について「評価された時点から内部統制が変更されていないこと、障害・エラー等の不具合が発生していないこと、及び関連する全般統制の整備及び運用の状況を確認及び評価した結果、全般統制が有効に機能していると判断できる場合には、その結果を記録することで、当該評価結果を継続して利用することができる」とする。すなわち**ITGCが有効であることが、ITACの評価を軽くする前提条件**であり、その「変更されていないこと」「不具合が発生していないこと」を示すのが変更・デプロイログ（L-10）、構成変更履歴（L-03）、エラー・例外処理ログ（L-07）である。

1.4 IT全般統制の4領域 ITGC-A～D

実施基準Ⅰ.2(6)②〔ITの統制〕ロ a. は、IT全般統制の具体例として次の4項目を挙げる。本書ではこれをITGC-A～Dとして固定IDを付し、以降の全章で参照する。

- **ITGC-A** システムの開発、保守に係る管理
- **ITGC-B** システムの運用・管理
- **ITGC-C** 内外からのアクセス管理などシステムの安全性の確保
- **ITGC-D** 外部委託に関する契約の管理

同 a. は続けて「① システムの開発又は変更の際して、当該システムの開発又は変更が既存のシステムと整合性を保っていることを十分に検討するとともに、**開発・変更の過程等の記録を適切に保存する** ② プログラムの不正な使用、改ざん等を防止するために、システムへのアクセス管理に関して適切な対策を講じる」ことが重要であるとする。①が記録保存の直接の要求、②がアクセス管理の要求である。

表1-2 IT全般統制の4領域とログ

領域	統制の例	ログが証拠となる場面	対応するログ種別
ITGC-A システムの開発、保守に係る管理	変更依頼の承認、導入前テストの実施と承認、開発環境と本番環境の分離、本番リリース権限の限定、緊急変更の事後承認、開発・変更過程の記録の保存	変更依頼から本番反映までの一連の突合（誰が依頼し、誰が承認し、誰がテストし、誰がいつ本番に反映したか）。開発者と本番リリース実施者が分離されていること。承認されていない変更が本番に入っていないこと。	L-10（変更・デプロイログ）、L-03（構成変更履歴）、L-01（クラウド基盤API操作ログ）、L-04（認証・認可ログ）
ITGC-B システムの運用・管理	ジョブ・バッチのスケジュール実行と結果確認、異常終了時の対応、バックアップの取得と復旧手順、障害の把握・分析・解決、データ連携の完全性確認	ジョブが計画どおり実行され、異常終了に対して承認された対応が取られたこと。バックアップが所定の頻度で成功していること。障害発生から復旧までの経緯。連携データに漏れ・重複がないこと。	L-08（ジョブ・バッチ実行ログ）、L-09（データ連携ログ）、L-13（バックアップ・リストアログ）、L-11（ネットワーク・通信ログ）、L-07（アプリケーション業務ログのうちエラー・例外処理）
ITGC-C 内外からのアクセス管理などシステムの安全性の確保	認証とアクセス制御の存在、権限の申請・承認・付与の分離、特権IDの利用申請と最小化、退職・異動時の即時削除、ID・権限の定期棚卸、アクセス違反のモニタリング	「全ての担当者の認証及びアクセス制御機能が存在し、アクセスが記録されている」（経済産業省「システム管理基準 追補版」）ことの確認。特権IDの利用実績と申請・承認記録との突合。退職者のアクセス権が即座に削除されたこと。本番データへの直接アクセス・直接修正の有無。	L-04、L-05（サーバ操作ログ）、L-06（データベース監査ログ）、L-02（データアクセスログ）、L-01、L-14（ログ基盤自身の監査ログ）
ITGC-D 外部委託に関する契約の管理	委託契約におけるセキュリティ要件・報告義務・監査権の定め、委託先要員のID管理と棚卸報告、責任分界の明確化、受託会社の内部統制に関する報告書の入手と検討	委託先要員が誰でもどの権限を持つのかの一覧と棚卸結果。委託先要員による本番環境の操作記録。責任分界に基づき、どのログを誰が取得・保管・提出するか取決めと実績。なお委託契約書・棚卸報告・受託会社の保証報告書はシステム外の文書として別途必要となる。	L-04、L-05、L-01、L-14

ITGC-D については、実施基準 II.2(1)② が「委託業務に関しては、委託者が責任を有しており、委託業務に係る内部統制についても評価の範囲に含まれる」と定める。委託したことで発注者の責任が消えるわけではなく、当該委託業務が発注者の重要な業務プロセスの一部を構成し、財務報告への影響が重要である場合には、貴社の内部統制が発注者の評価対象に取り込まれる。評価の手段として実施基準は、サンプリングによる検証と、受託会社が実施している内部統制の評価結果を記載した報告書等の入手・検討を挙げる。なお金融庁「内部統制報告制度に関するQ & A」問24 は、保証業務実務指針3402 に基づく報告書が「必ず」必要になるわけではないとしている。責任分界とログの提供義務は第2章 LR-13 および第11章で具体化する。

● 監査の視点

監査人は「ログを取得しているか」ではなく「ログが証拠として使えるか」を見る。経済産業省「システム管理基準 追補版」が示す評価手続の例は、(1)「企業に、一定の操作を禁止する方針があり、この方針に沿ってログが保存されていることを確かめる」、(2)「ログの記録や保管に際して、改ざんや削除ができないかについて確かめる」、(3)「モニタリング対象として選んだログが、全ての期間で収集されていることを確かめる」、(4)「ログは、証拠として利用できるか確かめる」である。つまり、**方針との対応・改ざん耐性・期間の網羅性・可読性と抽出可能性**の4点が問われる。ログファイルが存在するだけでは(2)～(4)を満たさない。

1.5 IT業務処理統制とアプリケーションログ

IT業務処理統制は、実施基準 II.3(3)⑤ニ b. において次の観点で評価される。これらはそのままアプリケーションのログ要件に翻訳できる。

- 入力情報の完全性、正確性、正当性等が確保されているか。
- エラーデータの修正と再処理の機能が確保されているか。
- マスタ・データの正確性が確保されているか。
- システムの利用に関する認証・操作範囲の限定など適切なアクセス管理がなされているか。

統制そのものが自動化されている場合でも、「その統制が期間を通じて意図どおり働いていた」ことは自動的に証明されない。2023年改訂で実施基準 ⑤ニ b. に追加された次の記述は、この点を明示している。

● 注意

実施基準 II.3(3)⑤ニ b. (2023年改訂で追加)：「自動化されたITに係る業務処理統制であっても過信せずに、内部統制の無効化のリスクを完全に防ぐことは困難であるという視点を持つことが重要である。また、**電子記録について変更の痕跡が残りにくい場合には、内部統制の無効化が生じてその発見が遅れることがある点についても留意することが重要である。**」

「変更の痕跡が残りにくい」設計は、それ自体が指摘対象となる。UPDATE で上書きして変更前の値を残さない実装、論理削除フラグのみで削除者・削除日時を記録しない実装、管理画面からの直接データ修正に監査証跡を残さない実装が典型例である。

1.5.1 アプリケーション層で取得するログ（L-07・L-09）に求める記録

開発ベンダーは、担当システムの IT業務処理統制ごとに、次の記録を実装すること。特記のない項目は L-07（アプリケーション業務ログ）として実装する。記録項目の共通要件（5W1H）は第2章 LR-02 に、時刻の扱いは LR-03 に従う。

- **必須** **承認操作**: 承認・差戻し・取消のそれぞれについて、実施者の識別子、実施日時、対象取引の識別子、承認前後のステータス、承認階層・権限区分を記録すること。
- **推奨** **承認権限判定の根拠**: 承認権限の判定に用いた権限マスタのバージョン、または判定結果を記録すること。
- **必須** **マスタ・データ変更**: 取引先マスタ、勘定科目マスタ、単価・料率マスタ、承認権限マスタ等、財務報告に影響するマスタの追加・変更・削除について、実施者、日時、対象キー、**変更前後の値**、適用開始日を記録すること。変更後の値のみの記録は「変更の痕跡」として不十分である。
- **必須** **例外処理（エラー）と再処理**: 業務エラーの発生（対象、エラー種別、発生日時）、その修正内容（修正前後の値、修正者、承認者）、再処理の実行結果を一連で追跡できる識別子を付して記録すること。
- **必須** **締め後・確定後のデータ修正**: 会計期間の締め後、または承認済み取引に対する修正は、通常の更新と区別できる区分を付して記録すること。監査人が特に着目する領域である。
- **必須** **インターフェース送受信**: L-09（データ連携ログ）として、連携単位ごとに、送信側・受信側それぞれの件数と主要金額の合計、連携日時、連携ジョブ識別子、突合結果（一致・不一致）を記録すること。完全性（漏れ・重複がないこと）の証明に用いる。
- **推奨** **自動計算・自動仕訳のロジック識別**: 自動仕訳や自動計算を行った場合、適用したルール・レート of 識別子とバージョンを記録すること。過年度評価結果の継続利用（実施基準 II.3(3)⑤ニ c.）にあたり「評価された時点から変更されていないこと」を示す材料となる。

- **推奨** **参照系の記録**: 個人データ・給与データ等の機微な情報の参照は、参照者・日時・参照範囲を記録すること。記録内容に機微情報そのものを含めない扱いは LR-07 に従う。
- **任意** **画面操作単位のトレース**: 業務トレーサビリティ強化のための画面遷移・操作ログは、量とコストの影響が大きいため、対象範囲を発注者と協議して決めること。

● 補足

ITGC が有効であれば ITAC の評価が必ず有効になる、という関係は成立しない。2023年改訂で実施基準 II.3(3)⑤イ に「ITに係る全般統制が有効に機能していると評価されたとしても、それだけでITに係る業務処理統制も有効に機能しているという結論に至らない点について留意することが必要である」が追加されている。基盤側のログ（L-01～L-06）を整備しても、アプリケーション業務ログ（L-07～L-09）の不足を代替できない。

1.6 2023年改訂のポイント

基準および実施基準は2023年（令和5年）4月7日に改訂され、**2024年（令和6年）4月1日以後開始する事業年度における財務報告に係る内部統制の評価及び監査から適用**されている。改訂の経緯として、制度が「平成20（2008）年4月1日以後開始する事業年度に適用されて以来、15年余りが経過」し、「経営者による内部統制の評価範囲の外で開示すべき重要な不備が明らかになる事例や内部統制の有効性の評価が訂正される際に十分な理由の開示がない事例が一定程度見受けられ」たことが挙げられている。IT に関係する改訂点は次のとおりである。

1.6.1 クラウド・外部委託・サイバーセキュリティの明記

実施基準 I.2(6) に次の記述が追加された。本書が AWS 環境版として書かれている直接の根拠である。

● 補足

実施基準 I.2(6)（2023年改訂で追加）：「また、情報システムの開発・運用・保守などITに関する業務の全て又は一部を、外部組織に委託するケースもあり、かかるITの委託業務に係る統制の重要性が増している。さらに、クラウドやリモートアクセス等の様々な技術を活用するに当たっては、サイバーリスクの高まり等を踏まえ、情報システムに係るセキュリティの確保が重要である。」

あわせて、基準 I.2(6) の「ITへの対応」の定義に「適時かつ」が追加され、「業務の実施において組織の内外のITに対し適時かつ適切に対応すること」となった。検知と対応の適時性が要素として明示された形であり、本書の監視・アラート要求（LR-08）の背景となる。

1.6.2 IT委託業務が評価範囲であることの明示

実施基準 II.2(1)②イ の委託業務の例に「情報システムの開発・運用・保守などITに関する業務を外部の専門会社に委託する場合」が明記された。金融庁「内部統制報告制度に関するQ & A」問22 も、評価対象となる委託業務に情報システムの開発・運用・保守等を含むとしている。開発ベンダー・運用ベンダーの統制が発注者の評価対象になることが、改訂により一層明確になっている。

1.6.3 ITを利用した内部統制の評価方法に関する改訂

- ITGC の有効性は ITAC の有効性を意味しない（II.3(3)⑤イ に追加）。1.5 節の補足を参照。

- **ITGCの運用評価を複数会計期間に一度とする取扱いについて**、⑤ニ a. の注に「経営者において、IT環境の変化を踏まえて慎重に判断され、必要に応じて監査人と協議して行われるべきものであり、**特定の年数を機械的に適用すべきものではない**ことに留意する」が追加された。前年度に評価したから今年度は評価しない、という運用は前提にできない。開発ベンダーは、毎期の評価に耐えるログを継続的に出し続ける前提で設計すること。
- **自動化されたITACの過信の戒めと、変更の痕跡が残り難い場合の留意**（⑤ニ b. に追加）。1.5 節の注意を参照。
- 「情報と伝達」の要素についても、大量の情報を扱う状況等において、情報の信頼性を確保するうえで情報システムが有効に機能することの重要性が記載された。

● 補足

改訂にあたり、実施基準は「組織に新たなITシステムの導入を要求したり、既存のITシステムの更新を強いるものではない」旨の記述を維持している。本書の要求事項も、特定の製品・サービスの新規導入を目的とするものではなく、財務報告に関連するシステムについて事後の検証が可能な記録を確保することを目的とする。要求レベルが **推奨** の事項は、省略する合理的理由を示したうえで発注者と協議し代替手段を採用することができる。**任意** の事項は、発注者との協議により採否を決める。

1.7 整備状況評価と運用状況評価 — ログが「運用の証拠」となる仕組み

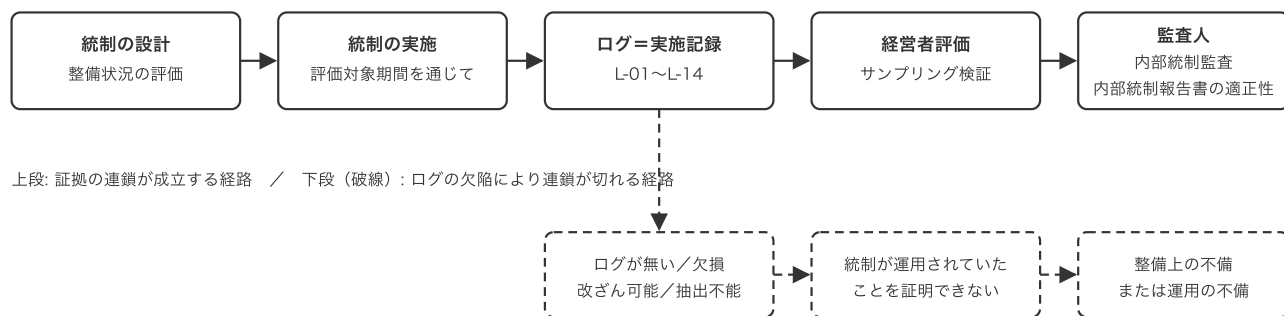
1.7.1 二種類の評価

経営者の評価は、整備状況の評価と運用状況の評価に分かれる。

- **整備状況の評価**（実施基準 II.3(3)③）：統制上の要点が適切に整備されているかを「関連文書の閲覧、従業員等への質問、観察等を通じて」判断する。留意点として「適切な職務の分掌が導入されているか」「内部統制によって発見された不正又は誤謬に適時に対処する手続が設定されているか」が挙げられる。ここで用いられるのは**設計に関する文書**であり、本書ではログ設計書・運用手順書（LR-14）がこれに当たる。
- **運用状況の評価**（同 ④イ）：「経営者は、関連文書の閲覧、当該内部統制に関係する適切な担当者への質問、業務の観察、**内部統制の実施記録の検証**、各現場における内部統制の運用状況に関する自己点検の状況の検討等により、業務プロセスに係る内部統制の運用状況を確認する」。同 ④ロ は「運用状況の評価の実施に際して、経営者は、原則としてサンプリングにより十分かつ適切な証拠を入手する」とする。

ログが制度上どこに位置づくかは、この「**内部統制の実施記録**」という語に尽きる。設計が正しいこと（整備）は文書で示せるが、その設計どおりに運用されたこと（運用）を示す中核となるのが実施記録である。ただし上記の引用のとおり、運用状況の確認は実施記録の検証だけで行われるのではなく、担当者への質問、業務の観察、自己点検の状況の検討等が併用される。人手による統制であれば承認印のある伝票やチェックリストが実施記録に当たり、IT を利用した統制ではログがこれに当たる。この証拠の連鎖と、ログの欠陥により連鎖が切れる経路を図1-1に示す。

図1-1 統制の実施からログ・評価・監査に至る証拠の連鎖



1.7.2 評価期間と期末日

実施基準 II.3(3)④ハは「評価時点（期末日）における内部統制の有効性を判断するには、適切な時期に運用状況の評価を実施することが必要となる」とし、運用状況の評価を期中に実施した場合、期末日までに内部統制に重要な変更があったときは、(a) 重要な変更の内容の把握・整理、(b) 変更後の内部統制の整備状況の有効性の評価、(c) 変更後の内部統制の運用状況の有効性の評価という追加手続の実施を検討するとする。監査人側も、経営者の評価の実施から期末日までの期間に重要な変更があった場合、経営者が追加手続を実施しているか確認する(III.4(2)①ロ b.)。

実務ではこの期中評価から期末日までの追加検証を「ロールフォワード」と呼ぶことがあるが、この語は基準・実施基準および経済産業省の追補版のいずれにも用いられていない。本書では上記 II.3(3)④ハの手続を指す実務上の呼称として扱う。

また実施基準 II.3(5)②は「内部統制の評価時点は期末日であり、**期末日後に実施した是正措置は、期末日における財務報告に係る内部統制の評価には影響しない。**ただし、経営者は、内部統制報告書の提出日までに実施した是正措置がある場合は、その内容を内部統制報告書に付記事項として記載できる」とする。期末を過ぎてからログ設定を修正しても、当期の評価は救われない。この一文が、ログを本番稼働前に確定させなければならない実務上の理由である。

1.7.3 期末日後の証拠保持

評価記録の保存について、実施基準 II.3(7)は「経営者は、財務報告に係る内部統制の有効性の評価手続及びその評価結果、並びに発見した不備及びその是正措置に関して、記録し保存しなければならない」とし、「記録・保存に当たっては、**後日、第三者による検証が可能となるよう、関連する証拠書類を適切に保存する必要がある**」とする。保存期間については同②が「諸法令との関係を考慮して、企業において適切に判断されることとなるが、金融商品取引法上は、有価証券報告書及びその添付書類の縦覧期間（5年）を勘案して、それと同程度の期間、適切な範囲及び方法（磁気媒体、紙又はフィルム等のほか必要に応じて適時に可視化することができる方法）により保存することが考えられる」とする。縦覧期間5年の根拠は金商法 第25条第1項（有価証券報告書及びその添付書類等5年、内部統制報告書及びその添付書類等5年）である。

ここで示されている5年は**評価記録**に関する目安であり、J-SOXの基準・実施基準はログそのものの保存年限を規定していない。ログの保存期間は、会社法・法人税法等の他法令や情報セキュリティ上の要請を踏まえて発注者が決定する。開発ベンダーはその決定を保存期間・ライフサイクル要求（LR-05）として実装する。詳細と推奨値の根拠は第7章に示す。

- **必須** 評価対象期間（原則として期首から期末日まで）の全期間について、対象ログを取得・保持すること（LR-01、LR-05）。期間の一部が欠けている場合、その期間の運用状況を裏付ける証拠が不足するため、質問・

観察・自己点検等による代替手続や、代替的・補完的な他の内部統制による検討（実施基準 II.3(4)③）が必要となり、それらによっても確認できない場合は不備として扱われ得る。このうち**欠損なく取得すること**を受入条件とする対象は、配信の完全性を検証できる手段（ダイジェストによる整合性検証、配信エラー状態の取得、件数・シーケンスの突合等）が提供されるログ種別とする。

- **必須** ベストエフォート配信で完全性が保証されないログ種別（Amazon S3 サーバーアクセスログ、VPC Flow Logs の一部レコード等）については、(a) 完全性が保証されない旨とその根拠をログ設計書（LR-14）に明記し、(b) 統制の主証拠には、同一操作を記録し配信の完全性を検証できるログ種別（例: L-02 のうち AWS CloudTrail データイベント。Amazon S3 サーバーアクセスログも同じ L-02 に属するが、完全性の検証可能性が異なる点に注意）を用いること。ただし、認証に失敗したリクエストや、ライフサイクルによる移行・有効期限切れ・復元など、AWS CloudTrail が記録せずサーバーアクセスログでしか捕捉できない事象については、当該ログを唯一の記録源として用いてよい。その場合は、完全性が保証されない旨と代替手段が存在しない理由をログ設計書（LR-14）に記載し、発注者の承認を得ること。該当するログ種別と根拠は第4章・第5章で確認すること。
- **必須** 期末日後、経営者評価および内部統制監査が完了するまでの期間もログを保持すること。保持階層を、(a) 即時照会可能な階層と (b) 復元手続を経て抽出可能なアーカイブ階層に区分する場合は、復元手順および想定復元所要時間（ストレージクラス別）をログ設計書（LR-14）に明記し、監査期間中に復元が間に合う期限管理を行うこと。アーカイブ階層を用いる場合、整合性検証の手段を失わないよう、配信先と同一の保管場所を維持したままストレージクラスを移行する方式を原則とすること。別の保管場所へ移送する場合は、移送後も完全性を検証できる手段を確保し、その方式をログ設計書（LR-14）に記載すること（第7章・第8章）。
- 保持期限の基準日（決算日、経営者評価完了予定日、内部統制監査完了予定日）は発注者が提示する。 **必須** 開発ベンダーは、発注者が提示した基準日に基づき保持期限を設定し、ログ設計書（LR-14）に記載すること。具体的な設定値は第7章に従う。
- **必須** ログの欠損が発生した場合に、欠損の発生および期間を機械的に検知し記録できること（LR-11）。原因の特定と記録は、検知を起点とする運用手順（LR-11、第9章）に基づく調査結果として残すこと。この要求は、取得元が欠損検知手段（配信エラー状態、件数・シーケンスの突合等）を提供するログ種別に適用する。原因が取得元から開示されないログ種別（VPC Flow Logs の log-status に SKIPDATA が記録される場合等）については、原因を特定できない旨をログ設計書（LR-14）に記載すれば足りる。欠損を検知できない設計は、網羅性を主張できない。

1.7.4 サンプリング — 実務慣行であり法令要件ではない

運用状況の評価は原則としてサンプリングによる。ここで実務上よく引用される件数には次の出所があるが、いずれも**例示または実務上の目安であり、法令が定める要件ではない**。開発ベンダーは特定の件数を前提に設計するのではなく、母集団全体から任意の期間・任意の対象を抽出できる検索性（LR-10）を確保することで対応する。

- 実施基準 III.4(2)①ロ a.（監査人の手続の例示）：「例えば、日常反復継続する取引について、統計上の二項分布を前提とすると、90%の信頼度を得るには、評価対象となる統制上の要点ごとに少なくとも 25 件のサンプルが必要になる」。文脈上「例えば」で始まる例示である。
- 経済産業省「システム管理基準 追補版」付録のサンプル件数の例: 1日につき多数 25件、日次 25件、週次 5件、月次 2件、四半期次 2件、年次 1件（いずれも許容逸脱件数 0）。同資料は「1日につき多数及び日次の場合以外は、統計的方法によるものではない」と注記する。
- 実施基準 II.3(3)④ニ a.（経営者側）：「IT を利用した内部統制は一貫した処理を反復継続するため、その整備状況が有効であると評価された場合には、IT に係る全般統制の有効性を前提に、人手による内部統制よりも、例えばサンプル件数を減らし、サンプルの対象期間を短くするなど、一般に運用状況の評価作業を減らすことができる」。

● 監査の視点

最後の項目は、開発ベンダーにとって重要な含意を持つ。**ITGCが有効であることが確認できれば、評価作業そのものが軽くなる**。逆に、ログが不十分でITGCの有効性を確認できない場合、監査人は代替手続として個々の取引をより多く検証することになり、発注者の評価工数と監査報酬が増加する。ログ設計の巧拙は、発注者にとって毎期発生するコストの差として現れる。

実務上、監査人は「対象期間の母集団リストの提出」を先に求め、そこからサンプルを指定する。したがって必要なのは個別ログの提示能力だけでなく、**期間を指定して母集団を漏れなく一覧化する能力**である。第12章の証跡抽出手順は、この母集団抽出を起点に構成している。

1.8 監査人が典型的に求める証跡

表1-3は、内部統制監査および経営者評価の場面で依頼されることの多い証跡と、それに対応するログ種別・要求事項の対応を示す。個々の証跡のAWS上での取得方法は第4章・第5章、抽出手順は第12章に示す。なお最終行のログ設計書・運用手順書はログ種別ではなく文書であり、その必須記載事項・テスト観点・受入確認は第11章に示す。

表1-3 典型的に依頼される証拠とログ種別・要求事項の対応

依頼される証拠	対応するログ種別	関連する要求事項
特権ID・管理者権限の使用履歴（誰が、いつ、何を実施したか）と、利用申請・承認記録との突合	L-04、L-05、L-01	LR-02、LR-06、LR-08、LR-09
アクセス権の付与・変更・削除の記録と、その承認記録との突合（申請者と承認者の分離を含む）	L-04、L-01、L-03	LR-02、LR-06、LR-09
退職者・異動者のアカウントが、社内規程に定める期限内（原則として即時）に削除・無効化されたことの記録	L-04、L-01	LR-02、LR-09
ID・権限の定期棚卸の実施結果と、実際のシステム設定との一致	L-04、L-03	LR-09、LR-10
本番環境へのプログラム変更・リリースの一覧と、変更依頼・承認・テスト記録との突合	L-10、L-03、L-01	LR-02、LR-10、LR-12
承認されていない変更が本番環境に反映されていないこと（IaC 適用差分・構成ドリフトを含む）	L-10、L-03	LR-01、LR-12
ジョブ・バッチが計画どおり実行され、異常終了に対して承認された対応が取られたことの記録	L-08、L-07	LR-08、LR-11
バックアップの取得結果と、復旧テストの実施記録	L-13	LR-11
本番データベースへの直接アクセス・直接更新の有無と、実施した場合の承認記録	L-06、L-05、L-02	LR-02、LR-04、LR-06
マスタ・データ変更の一覧（変更前後の値、実施者、承認者）	L-07、L-06	LR-02、LR-09
システム間インターフェースの送受信件数・金額の整合、および不整合発生時の対応記録	L-09、L-07	LR-02、LR-11
締め後・確定後の取引データ修正の一覧と承認記録	L-07、L-06	LR-02、LR-10
ログレビューの実施記録と、責任者による承認の記録	L-02・L-01（ログ保管先への参照記録） および運用記録（システム外）	LR-09、LR-14
ログの取得設定が対象期間中に変更・停止・削除されていないこと、または変更が承認されていること	L-14、L-01、L-03	LR-04、LR-12
ログが改ざんされておらず、対象期間に欠損がないことの証明	L-01（整合性検証）、L-14	LR-04、LR-05、LR-11
セキュリティ検知事象の発生状況と、検知後の対応記録	L-12、L-11	LR-08、LR-09
外部委託先要員のID一覧・棚卸報告と、委託先要員による本番環境の操作記録	L-04、L-05、L-01	LR-06、LR-13
ログ設計書・運用手順書、および設計と実装の一致を確認したテスト記録	－（文書）	LR-14

● 注意

表1-3の「ログレビューの実施記録」および「変更依頼・承認記録」は、システムのログだけでは充足しない。ログを見たこと・承認したことの記録は、ログの外側にある運用記録（チケット、レビュー記録、承認記録）である。両者を結び付ける識別子が無い場合、監査人は数百件のログと数百件のチケットを人手で突き合わせることになり、突合不能と判断されると統制の運用を確認できない。

必須 開発ベンダーは、システムのログと運用記録を、(a) 運用記録側に AWS 側の識別子（イベントID、セッション識別子、ジョブ実行ID等）を記録する、または (b) AWS 側のログに運用記録の識別子（変更管理チケット番号、申請番号等）を載せられる項目がある場合はそれを用いる、のいずれかで相互に突合できるようにすること。AWS CloudTrail をはじめ、サービス自身が生成するログの多くは、イベント本文に任意のフィールドを追加することができない。(b) を採る場合は、ロールセッション名や sts:SourceIdentity のように、あらかじめ用意された項目に識別子を載せる方式に限られる。採用する受け渡し方式は第5章・第10章の定めに従い、ログ設計書（LR-14）に明記すること。

任意 どの変更管理ツールを用いるかは発注者と協議して決めること。

1.9 開発ベンダーにとっての意味

1.9.1 「不備」と「開示すべき重要な不備」

実施基準 II.1② イ は不備を次のように定義する。「内部統制の不備は、内部統制が存在しない、又は規定されている内部統制では内部統制の目的を十分に果たすことができない等の**整備上の不備**と、整備段階で意図したように内部統制が運用されていない、又は運用上の誤りが多い、あるいは内部統制を実施する者が統制内容や目的を正しく理解していない等の**運用の不備**からなる。」

このうち一定の重要性を持つものが「開示すべき重要な不備」である。内部統制府令第2条第10号は「財務報告に重要な影響を及ぼす可能性が高い財務報告に係る内部統制の不備」と定義し、実施基準はこれを「一定の金額を上回る虚偽記載、又は質的に重要な虚偽記載をもたらす可能性が高いもの」とする。金額的重要性の判断については「例えば、連結税引前利益については、おおむねその5%程度とすることが考えられる」との注記がある。開示すべき重要な不備が期末日時点で存在する場合、その旨が内部統制報告書に記載され、公表される。

ログの欠陥は、この定義に照らして次のように位置づけられる。

- **ログを取得する機能・設定が存在しない** → 記録が残らない設計であり、統制の目的（事後の検証）を果たせない。**整備上の不備**に該当し得る。
- **設定はあるが期間の一部が欠損している** → 整備段階で意図したように運用されていない。**運用の不備**に該当し得る。
- **記録項目が不足して誰が実施したか特定できない** → 規定されている記録では事後の検証という目的を十分に果たすことができない。**整備上の不備**に該当し得る。
- **ログが運用者自身によって削除・改変可能である** → 記録の信頼性が担保されず、証跡として利用できない。整備上・運用の双方の不備となり得る。

1.9.2 ITGC の不備は「直ちに」開示すべき重要な不備ではない — が、影響は残る

実施基準 II.3(4)③ は「ITに係る全般統制に不備がある場合には、代替的又は補完的な他の内部統制により、財務報告の信頼性という目的が達成されているかを検討する。ITに係る全般統制の不備は、財務報告の重要な事項に虚偽記載が発生するリスクに直接に繋がるものではないため、**直ちに開示すべき重要な不備と評価されるもので**

はない。しかし…その有効な運用を継続的に維持することができない可能性があり、虚偽記載が発生するリスクが高まることとなる」とする。金融庁「内部統制報告制度に関するQ & A」問14も同様である。

したがって、ログの不足が直ちに公表事案となるわけではない。しかし影響は確実に発生する。第一に、代替的・補完的統制の検討と追加手続が必要になり、発注者と監査人の工数が増える。第二に、ITGCの有効性を前提としたサンプル件数の削減（1.7.4）が使えなくなる。第三に、実施基準 II.3(3)⑤ニ c. による過年度の評価結果の継続利用ができず、自動化された統制であっても每期あらためて評価が必要となる。第四に、是正は期末日を過ぎてからでは当期の評価に反映されない（1.7.2）。これらはすべて発注者の継続的なコストであり、受入判定と保守フェーズの評価に反映される。

● 監査の視点

監査の現場で最も扱いにくいのは「ログはあるが、証跡として使えない」状態である。典型的には次の5つの形で現れる。いずれも「取得はしている」状態であるため設計時に見落とされやすい。

- (1) **実施者が特定できない**: 共有ID・共有ロールで操作しており、ログには共有IDしか残っていない。誰が実施したかを特定できず、職務分掌の遵守を確認できない。
- (2) **期間が欠けている**: 設定変更やサービス移行の前後でログの形式・保存先が変わり、突合できない期間がある。
- (3) **時刻が突合できない**: 複数システムのログでタイムゾーン表記が異なり、あるいは時刻同期がされておらず、事象の前後関係を確定できない。
- (4) **抽出できない**: 保管はされているが、期間・利用者・操作種別で絞り込む手段がなく、母集団の一覧を作れない。
- (5) **削除・改変が可能**: ログの保管先に対して、操作を行う本人が削除権限を持っている。

第2章の LR-02（記録項目）、LR-03（時刻同期とタイムスタンプ）、LR-04（改ざん防止と完全性の保証）、LR-06（ログへのアクセス制御と職務分掌）、LR-10（検索・抽出）、LR-11（バックアップ・可用性・欠損検知）は、これら5つの失敗形態に個別に対応する要求事項である。

1.9.3 設計段階から組み込むこと

ログ要件を後から追加できない理由は、制度側と技術側の双方にある。制度側の理由は1.7.2で述べた「期末日後の是正措置は当期の評価に影響しない」である。技術側の理由は、AWSのログの多くが**既定では長期保存の設定がされておらず、有効化していない期間は遡って取得できない**ことにある。有効化していない期間のログは、後から生成することができない。各サービスの既定の記録範囲・参照可能期間および長期保存に必要な設定は第4章・第5章で確認すること。例外として、クラウド基盤API操作ログ（L-01）の管理イベントは既定で記録され、AWS CloudTrailの証跡（trail）を作成しなくても直近90日分をイベント履歴として参照・取得できるが、単一アカウント・単一リージョン、管理イベントのみ（データイベントを含まない）等の制約があり、継続的な監査証跡の代替にはならない（第4章参照）。なお本書では、AWS CloudTrailのtrailを指す場合に限り「証跡（trail）」と表記し、単に「証跡」と記す場合は監査証跡（evidence）を指す。設計初期に決定を要する代表的な項目を挙げる。

- **必須** ログに関する要求事項（LR-01～LR-14）を、システム要件定義書に機能要件・非機能要件として明記し、設計レビューおよびテストの対象とすること。ログを「運用フェーズで整えるもの」として設計対象から外さないこと。
- **必須** 遡及取得ができない設定（データアクセスログの取得範囲、DB監査ログの取得イベント、サーバ操作ログの記録方式、機微情報のマスキング適用範囲など）を、本番稼働前に発注者と合意し、ログ設計書（LR-14）に記載すること。ログ保管先の改ざん防止設定は稼働後にも有効化できるが、有効化前に生成されたログ

の完全性は遡って保証できず、既定の保持設定は原則として新規オブジェクトにのみ適用されるため、同様に本番稼働前に決定すること。

- **必須** 利用者を一意に識別できる認証方式を設計すること。共有ID・共有ロールの利用が避けられない場合は、実際の操作者を追跡できる仕組み（個人識別子のセッションへの引き渡し等）を併せて設計すること（第5章、第10章）。
- **必須** ログの保管先へのアクセス権限を、開発者・運用者から分離する構成を設計時点で決めること。稼働後の権限分離は、既存ログの信頼性を遡って回復しない（第10章）。
- **推奨** 受入テストの一部として、統制ごとに「監査人からこの証跡を求められたら、どの手順で抽出できるか」を実演し、その結果を記録すること。即時照会可能な期間については所要時間を、アーカイブ済みの期間については復元手順と想定復元所要時間を実演し記録すること（第11章、第12章）。
- **推奨** 既存システムからの移行を伴う場合、移行前システムのログの保存・参照可能性、および移行前後で利用者識別子が変わる場合の対応表を、移行計画に含めること（第13章）。

本書の以降の構成は次のとおりである。第2章で要求事項 LR-01～LR-14 を定義し、第3章で取得対象ログ L-01～L-14 のマトリクスを示す。第4章・第5章で AWS サービスごとの実装、第6章でリファレンスアーキテクチャ、第7章から第10章で保存期間・改ざん防止・監視とレビュー・職務分掌を扱う。開発ベンダーの成果物と受入チェックリストは第11章、監査対応時の証跡抽出は第12章、導入と移行の進め方は第13章に示す。

1.10 保険の法令・ガイドラインとログ

保険でシステムの記録・ログが問題になる場面は、①保険契約の管理（契約の締結から消滅まで数十年に及ぶ終身保険などの長期契約）、②保険募集（意向把握・意向確認、説明の記録、書面の電磁的交付）、③募集人・仲立人の帳簿書類、④変額保険などの特別勘定の経理、⑤苦情処理・利益相反管理の記録、⑥顧客情報（機微情報を含む）へのアクセス管理とインターネット取引の不正検知である（付録 G の § 6.1）。

保険業法は、監査ログの保存年数を直接定めていない。保険の法令が保存期間を定めるのは帳簿書類・記録であり、その一部は保険契約の消滅を起算点とする（付録 G の § 6.1）。金融分野のガイドラインは、ログの取得・点検を求めるが、年数は示していない（付録 G の § 1.1）。

保険の法令・ガイドラインとログ・記録との関わりを表1-4 に示す。「関わり」の欄の直接・間接・対象外は、業種別調査の区分である。直接は、条文がログ・アクセス記録・操作履歴などを明記して保存を求めるもの、間接は、帳簿書類・記録を電磁的記録で保存する場合のデータ・訂正削除の履歴・システム要件として関わるもの、対象外は、紛らわしいが監査ログには適用されないものである（付録 G の § 2）。保険の法令の行には、直接に当たるものはない。

表1-4 保険の法令・ガイドラインとログ・記録の関わり

行番号	法令・ガイドライン	ログ・記録への関わり	本書で扱う箇所
IN1	保険業法54条の2第2項（198条で外国相互会社に準用）	間接。相互会社の会計帳簿と、その事業に関する重要な資料（会計帳簿の閉鎖の時から10年）。会社法432条2項（J1）と同じ内容を、株式会社でない相互会社について定めた規定である。監査ログを明記していないが、J1と同様に「重要な資料に準じて扱う」という解釈で、相互会社の区分(2)の根拠になる（要法務確認）	2.5.5、 7.8.1
IN2	保険業法54条の3第4項	間接。相互会社の計算書類・附属明細書（計算書類を作成した時から10年）。会計データの出力物であり、区分(2)を10年とする補強材料	7.8.1
IN3	保険業法13条	対象外。株式会社である保険会社について、会社法432条1項などの「法務省令」を「内閣府令」と読み替えるだけで、保存期間を定めていない。株式会社である保険会社の会計帳簿の保存期間は、保険業法ではなく会社法432条2項（J1）による	2.5.5、 7.8.5
IN4	保険業法303条、同法施行規則236条の2・237条の2（罰則：法320条3号）	間接。特定保険募集人と保険仲立人の、事務所ごとの業務に関する帳簿書類。電磁的記録で作成・保存する場合の、データと訂正削除の履歴として関わる。特定保険募集人は、所属保険会社等の数が15以上、または2以上の所属保険会社等から受けた手数料等の総額が10億円以上の募集人である。これに当たらない一般の保険募集人には、保険業法上の帳簿書類の保存義務はない	3.5、 7.8.4、 12.8
IN5	保険業法施行規則237条1項	間接。特定保険募集人の、保険契約ごとの帳簿書類（保険契約の締結の日から5年）。起算点が契約の消滅ではなく締結の日であり、長期契約では契約の存続中に保存期間が満了しうる	3.5、 7.8.1、 7.8.2
IN6	保険業法施行規則237条2項	間接。保険仲立人の、保険契約ごとの帳簿書類（保険契約が消滅した日から5年）。契約期間に連動し、終身保険などでは保存の終了日が作成から数十年後になる	3.5、 7.8.1、 7.8.2
IN7	保険業法施行規則227条の4第2項3号	間接（システム要件）。保険仲立人が書面の交付に代えて閲覧の方法で提供した記載事項を、保険契約が消滅した日以後5年（期間中に苦情の申出があれば、期間の終了日と苦情の解決日の遅い方まで）、「消去し又は改変することができないもの」として保持する。対象は交付した書面の電子データであり、ログではない。顧客の消去の指図などの場合は消去できる	3.5、 7.8.1～ 7.8.3
IN8	保険業法施行規則234条の6第2項3号	間接（システム要件）。特定保険契約（変額保険など）について、書面に代えて閲覧の方法で提供した記載事項（特定投資家制度の申出・承諾に関する書面に限る）を、記載事項に掲げられた取引を最後に行った日以後5年（苦情の申出があれば、期間の終了日と苦情の解決日の遅い方まで）、消去・改変できない状態で保持する。対象は提供した書面の電子データであり、ログではない	3.5、 7.8.1～ 7.8.3
IN9	保険業法施行規則75条の2第3項（外国保険会社等は154条の2に同旨）	間接。変額保険などの特別勘定（特定特別勘定）の帳簿書類。 ①特定特別勘定元帳は10年（「保険年度の終了の日又は保険期間の終了の日」から。読み方は解釈）、②特定特別勘定に係る総勘定元帳は5年（作成の日から）、③業務の委託契約書は5年（委託契約の終了の日から）。①は契約期間に連動しうる	3.5、 7.8.1、 7.8.2

行番号	法令・ガイドライン	ログ・記録への関わり	本書で扱う箇所
IN10	保険業法施行規則52条の22第4項	間接。保険金信託業務を行う生命保険会社等の帳簿書類。①信託勘定元帳は10年（信託財産の計算期間の終了の日または信託行為によって設定された期間の終了の日から）、②総勘定元帳は5年（作成の日から）、③委託契約書は5年（委託契約の終了の日から）。①は信託期間に連動する	3.5、 7.8.1
IN11	保険業法施行規則53条の14第2項（外国保険会社等は133条の4、保険持株会社は210条の6の6に同旨）	間接。利益相反管理の記録（記録の作成の日から5年）。利益相反管理システムで記録を作成・保存する場合のデータ	3.5、 7.8.1
IN12	保険業法施行規則53条の14の2第2項（外国損害保険会社等は133条の5に同旨）	間接。損害保険会社が、兼業特定保険募集人との関係で講じる、保険金支払業務の公正確保の措置・監視に係る記録（記録の作成の日から5年）	3.5、 7.8.1
IN13	保険業法294条の4第3号、同法施行規則227条の19第2項	間接。特定大規模乗合損害保険代理店の、保険募集の業務に係る苦情処理の記録（記録の作成の日から5年）	3.5、 7.8.1
IN14	保険業法施行規則227条の20第2項	間接。兼業特定保険募集人である特定大規模乗合損害保険代理店の、保険金の支払の請求に関する業務の特定・監視・体制整備の記録（記録の作成の日から5年）	3.5、 7.8.1
IN15	保険業法施行令40条、同法施行規則215条の4第1項3号口	間接。特定大規模乗合生命保険募集人の、苦情処理の記録（記録の作成の日から5年）	3.5、 7.8.1
IN16	保険業法施行規則53条の8（保険会社）・227条の9（保険募集人・保険仲立人）	間接。個人である顧客に関する情報の安全管理措置。期間の定めはない。監督指針を通じて、実務指針（ING8）のアクセス記録の義務が、保険会社・保険募集人・保険仲立人のいずれにも求められる	3.5
IN17	保険業法294条の2（意向把握・確認義務）、同法施行規則53条の7・227条の7（社内規則等）	対象外。意向把握・確認の実施を義務づけるが、その記録の作成・保存や保存期間は定めていない	3.5、 7.8.4
IN18	金融サービスの提供及び利用環境の整備等に関する法律33条、金融サービス仲介業者等に関する内閣府令138条1項2号・139条2項	間接。金融サービス仲介業者の、保険媒介業務に係る記録（保険契約が消滅した日から5年）。保険業法以外で保険契約の情報の保存を定める法令であり、契約期間に連動する	3.5、 7.8.1、 7.8.2
IN19	保険法95条	対象外（保存義務ではない）。保険給付・保険料の返還・保険料積立金の払戻しの請求権の消滅時効（3年）と、保険料請求権の消滅時効（1年）。保険金請求の紛争に備える期間の参考にとどまる	3.5、 7.8.4
IN20	保険業法施行規則239条の10第2項・239条の13第1項（法308条の11・308条の13第9項）	対象外。指定紛争解決機関の苦情処理手続・紛争解決手続の記録であり、義務を負うのは指定紛争解決機関（ADR機関）で、保険会社・募集人ではない	—
ING1	金融庁「保険会社向けの総合的な監督指針」（令和8年10月版）II-3-13-2-1-2(4)（システムリスク管理態勢・情報セキュリティ管理）	ガイドライン（法的拘束力なし）。ログの取得・保存を明記する（直接）。不正アクセス・情報漏えいを牽制・防止する仕組みとして「アクセス記録の保存、検証」を挙げ、重要情報の洗い出しの対象に障害解析用データや取引ログも含める。年数は示していない	3.5、 7.8.1、 12.8
ING2	同監督指針II-3-13-2-2-2(2)（インターネット取引・セキュリティの確保）	ガイドライン（法的拘束力なし）。不正アクセス検知と「事後検証に資するログイン・取引時の情報の保存」を求める。年数の記載はない	3.5、 7.8.1

行番号	法令・ガイドライン	ログ・記録への関わり	本書で扱う箇所
ING3	同監督指針Ⅱ-4-2-2(3)④ア・イ(ア)(キ)（意向把握・確認義務に係る体制整備）	ガイドライン（法的拘束力なし）。意向把握に用いた帳票等を「保存するなどの措置」、意向確認書を「事後的に確認できる方法により保存」することを求めるが、保存期間は示していない。業種別調査は、募集支援システムの記録として区分(3)の対象とする	3.5、 7.8.4
ING4	同監督指針Ⅱ-4-2-6-3(5)（銀行等の保険募集指針）	ガイドライン（法的拘束力なし）。銀行等が保険募集を行う場合の、説明に係る記録等の保存期間を「保険期間が終了するまで」とする。銀行等の窓口販売に限った記述だが、募集時の記録の保存期間を契約期間に連動させた、唯一の公式の記述である	3.5、 7.8.1、 7.8.4
ING5	同監督指針Ⅱ-4-4-2-1(4)（高齢者に対する保険募集）	ガイドライン（法的拘束力なし）。保険募集内容の記録（録音・報告書への記録など）の記録・保存を、適切な取組みの例として挙げる。年数の記載はなく、録音データなどの保存期間は各社で定める	3.5、 7.8.4
ING6	同監督指針Ⅱ-4-2-15-5(1)①・(4)（兼業特定保険募集人である特定大規模乗合損害保険代理店）	ガイドライン（法的拘束力なし）。IN14の具体化。自動車の修理見積額の適切性に係る証拠などを、IN14に基づき保存する（＝5年）	3.5
ING7	同監督指針Ⅱ-4-2-10（帳簿書類）	ガイドライン（法的拘束力なし）。特定保険募集人の帳簿書類の作成・保存の方法を、社内規則等に具体的に定めることを求める。期間はIN5による	3.5
ING8	個人情報保護委員会・金融庁「金融分野における個人情報保護に関するガイドラインの安全管理措置等についての実務指針」（令和6年3月改正、同年4月1日適用。告示）5-5・5-6・5-7、7-2-2⑤⑥	ガイドライン（法的拘束力なし）。ログの取得・保存を明記する（直接）。アクセスや操作を「記録するとともに、当該記録の分析・保存を行わなければならない」とし、不正が疑われる異常な記録の存否の定期的な確認も求める。年数は示していない	3.5、 7.8.1、 12.8
ING9	金融庁「金融分野におけるサイバーセキュリティに関するガイドライン」（令和6年10月4日制定、令和7年7月4日改正）2.3.4.2①②（ログ管理）、2.3.1④（認証・アクセス管理）	ガイドライン（法的拘束力なし）。保険会社・少額短期保険業者・金融サービス仲介業者を対象に含む。ログの取得・監視・保存の手続を策定し、その手続に「保存期間」「ログの改ざん防止」などを含めることを求める。年数は示していない	3.5、 7.8.1、 7.8.5
ING10	個人情報保護委員会・金融庁「金融分野における個人情報保護に関するガイドライン」（令和6年3月改正、同年4月1日適用）第7条	ガイドライン（法的拘束力なし）。保険契約者等の個人データの保存期間を利用目的に応じて定め、経過した個人データを消去することを求める。上限側の制約	2.5.5、 7.8.3
ING11	保険会社向けの総合的な監督指針Ⅱ-3-13-2-1-2(6)ア(オ)	ガイドライン（法的拘束力なし）。システムの開発や変更の記録について、保存期間を定めて保管することを求める。年数は示していない	3.5、 7.8.1

表1-4の「法令・ガイドライン」の欄は、付録Gの§6.2・§6.3の記載のとおりである。保存対象・期間・起算点の全体は、付録Gに示す。

● 補足

政府のガイドラインは、原則として法的拘束力がない（付録 G の § 2）。実務指針（ING8）は告示の形式で公表されているが、業種別調査はガイドラインの表に載せている（付録 G の ING8）。金融分野の個人情報ガイドライン7条（ING10）の「こととする」は、個人情報保護法22条（努力義務）より強い書き方であり、業種別調査は、金融分野に固有の上限側の制約として扱っている（付録 G の § 6.4）。

全業種に共通する法令のうち、株式会社である保険会社の会計帳簿には、会社法432条2項（J1）が適用される（付録 G の IN3）。犯罪収益移転防止法の特定事業者には保険会社・少額短期保険業者が含まれ、確認記録・取引記録の保存（7年）が適用される（付録 G の CM8～CM10）。業種別調査は、これらを全業種に共通する法令として § 3 で扱っている（付録 G の § 6.8）。保険募集人・保険仲立人・金融サービス仲介業者が特定事業者に当たるかは、業種別調査に記載がないため、自社が特定事業者に当たるか、どの業務が特定業務に当たるかを確認する（付録 G の CF7）。

2

ログ管理要求事項（LR-01～LR-14）

本章は、発注者が開発ベンダーに求めるログ管理の要求事項を LR-01 から LR-14 まで定義する。第1章で述べたとおり、財務報告に係る内部統制において「IT を利用して実施した手続や情報の変更等が適切に記録されない」状態は事後の検証を困難にし、内部統制の無効化が生じてその発見を遅らせる。ログは、その事後検証を成立させるための基礎資料である。

2.0 本章の読み方

2.1 から 2.14 までの各項は、次の四つの見出しで構成する。

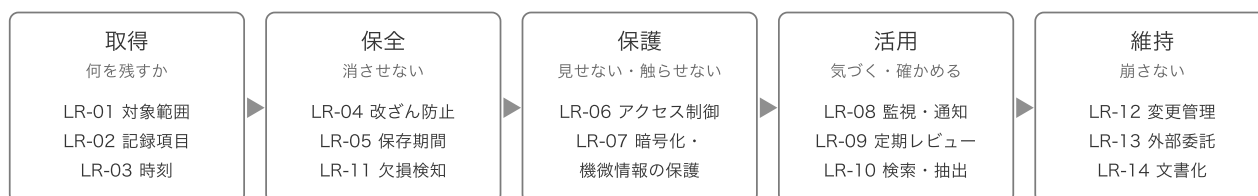
- **目的と統制上の意味** — その要求事項が何のために存在し、IT 全般統制のどの領域（ITGC-A～ITGC-D）に対応するか。
- **要求事項** — 開発ベンダーが設計・構築・運用設計で満たすべき事項。各項目に要求レベルを付す。
- **監査で求められる証跡** — 監査人（R-6）が整備状況及び運用状況の有効性を確かめるために提示を求める記録。開発ベンダーは、これらが検収時点で存在し、かつ運用開始後も継続して生成される状態を作ること。
- **対応するAWSサービス** — 主たる実装手段。個別の設定手順・パラメータは第4章および第5章で扱う。

要求レベルの意味は次のとおりである。**必須** は発注者が受入条件とする事項であり、未充足は検収不合格の対象となる。**推奨** は合理的理由なく省略しない事項であり、省略する場合は理由と代替統制を文書に記録して発注者の承認を得ること。**任意** は発注者と協議して採否を決める事項である。

「証跡」の語は二つの意味で用いる。本書では、AWS CloudTrail の記録単位を指す場合は「証跡（trail）」、監査上の証拠記録を指す場合は「証跡」と表記する。また、各項の「監査で求められる証跡」には、推奨事項を採用した場合に限り必要となるものを含む。該当する記録にはその旨を括弧書きで示す。

LR-01 から LR-14 は、ログのライフサイクル上の五つの段階に整理できる（図2-1）。個々の要求事項は独立して成立するものではなく、たとえば LR-04（改ざん防止）は LR-06（アクセス制御）と LR-12（設定の変更管理）が伴って初めて統制として機能する。

図2-1 ログ管理要求事項の全体像



● 補足

本章は「何を満たすか」を定める。「どのサービスで、どう設定するか」は第4章（基盤ログの取得・保全）および第5章（認証・操作・データ・ネットワーク・検知・分析）、「何を成果物として提出するか」は第11章、「監査人にどう提出するか」は第12章で扱う。ログ種別 L-01～L-14 の定義と取得対象の割り当ては第3章による。

2.1 LR-01 対象範囲の特定と網羅性

2.1.1 目的と統制上の意味

財務報告に関連するシステムの操作・変更・アクセスのうち、記録されていないものがあれば、その範囲について監査人は有効性を確かめる手段を失う。実施基準は IT の統制目標として信頼性（正当性・完全性・正確性）を挙げ、完全性を「記録した取引に漏れ、重複がないこと」と定義している。ログの網羅性はこの完全性の前提であり、ITGC-B（システムの運用・管理）および ITGC-C（内外からのアクセス管理などシステムの安全性の確保）に対応する。取得範囲が不明確なまま構築されたログ基盤は、後から範囲を証明できないため、設計段階で範囲を確定し文書化することが不可欠である。

2.1.2 要求事項

- **ログ取得対象一覧の作成** **必須** — 対象アカウント、リージョン、AWSサービス、リソース、ログ種別（L-01～L-14）、取得可否、保存先、保持期間、所管（R-2～R-5）を一つの一覧にまとめること。各行に、当該システムが支える業務プロセス・勘定科目との対応を併記すること。
- **全リージョン記録** **必須** — AWS CloudTrail の証跡（trail）はマルチリージョン証跡とすること。IAM、AWS STS、Amazon CloudFront のグローバルサービスイベントは 2021年11月22日以降 us-east-1 に記録されるため、マルチリージョン証跡で `IncludeGlobalServiceEvents` を有効にすること。使用しないリージョンについては、遮断する統制（サービスコントロールポリシー等）を設けるか、記録対象として明示すること。
- **全アカウント記録** **必須** — AWS Organizations の組織の証跡を用いること。組織の証跡はメンバーアカウント側で削除・停止・設定変更ができない。オプトインリージョンは各メンバーアカウントで有効化されて初めて記録対象となるため、有効化状況を一覧に記録すること。
- **新規リソースの自動包含** **必須** — AWS Config の設定レコーダーは、サポートされる全リソースタイプを記録する構成とすること。記録対象外としたリソースタイプは、作成・削除のみが捕捉され構成の詳細が残らないため、対象外とする理由を記録すること。
- **新規アカウントの自動包含** **必須** — アカウント払い出し手順への、組織の証跡の適用、AWS Config レコーダーおよび配信チャネルの構成、ログ保護ポリシーの適用の確認の組み込み案を開発ベンダーが提示し、手順の改定は発注者が行う。開発ベンダーは、手作業での個別設定に依存しない設計とし、適用結果の確認記録を取得すること。
- **横断参照の構成** **推奨** — AWS Config のアグリゲータを用い、複数アカウント・複数リージョンの構成とコンプライアンス状態を読み取り専用で一元参照できるようにすること。
- **グローバルリソースの記録先の明示** **必須** — AWS Config のグローバル IAM リソース（ユーザー、グループ、ロール、カスタマー管理ポリシー）は、2022年2月以前に AWS Config が提供されていたリージョンでのみ記録できる。重複した設定項目を避けるため記録は一つのリージョンに限定し、そのリージョンを一覧に明記すること。

- **対象外の明示 必須** — 技術的に取得できないログ、および取得しないと判断したログを、理由・影響・代替統制とともに一覧に明記し、発注者の承認を得ること。
- **棚卸の実施 必須** — ログ取得対象一覧と実機の設定を定期的に突合し、差異を是正すること。頻度は 2.9 の定めによる。

● 注意

取得範囲には、AWS の仕様上の穴が存在する。代表例として次を挙げる。いずれも「取得している」と誤認したまま設計を進めると、監査時に網羅性を証明できない。

- AWS Systems Manager Session Manager は、ポートフォワーディング経由および SSH 経由のセッションのログを取得できない。SSH またはポートフォワーディングを利用しない場合は `AWS-StartSSHSession` 等のセッションドキュメントの利用を IAM で拒否し、業務上利用が避けられない場合は利用時の申請・承認と事後レビューを代替統制として定めること（→ 2.6）。
- Amazon S3 サーバーアクセスログはベストエフォート配信であり、完全性・適時性が保証されない。一方 CloudTrail は、資格情報が無効で認証に失敗したリクエストのログを配信しない（認可失敗 = AccessDenied と匿名リクエストは記録する）ほか、ライフサイクルによる移行・有効期限・復元も記録しない。いずれか一方では網羅できないため、配信の完全性を要する記録には CloudTrail データイベントを用いたうえで、認証失敗およびライフサイクル操作の記録が必要な場合はサーバーアクセスログを併用すること（→ 2.2、L-02）。
- VPC フローログは、Amazon DNS サーバー宛の通信、インスタンスメタデータおよび時刻同期サービス宛のリンクローカル通信などを記録しない。
- CloudTrail データイベントは既定では記録されない（本項の必須項目「ログ取得対象一覧の作成」で取得可否を明示的に判断すること。設定手順は第4章による）。

業種編では、ログ取得対象一覧の対象に、区分 (3) の記録を扱うシステムを含める (0.3)。

2.1.3 監査で求められる証跡

- ログ取得対象一覧（版数・作成者・承認者・承認日を含む）。
- 全アカウント・全リージョンの証跡設定と配信状態の実機出力（`describe-trails`、`get-trail-status` の結果）。
- AWS Config の設定レコーダーおよび配信チャネルの設定一覧、アグリゲータの構成。
- 新規アカウント払い出し時のログ設定確認記録（対象アカウント、実施日、確認者）。
- 対象外一覧と、その代替統制および発注者の承認記録。

2.1.4 対応するAWSサービス

AWS Organizations および AWS Control Tower が組織単位での一括適用と新規アカウントへの自動適用を担う。AWS CloudTrail の組織の証跡が API 操作の網羅的記録を、AWS Config の全リソースタイプ記録とアグリゲータが構成情報の網羅的記録を担う。Amazon CloudWatch Logs、AWS Systems Manager Session Manager、Amazon RDS／Amazon Aurora は、それ自体が網羅性を担保する手段ではないが、取得対象として一覧に登載すべきログ源であり、その取得可否の判断が LR-01 の対象となる。詳細は第4章（CloudTrail、Config に関する節）および第5章による。

2.2 LR-02 記録項目（5W1H）

2.2.1 目的と統制上の意味

ログは「いつ・誰が・どこから・何に対して・何をして・結果どうなったか」が特定できて初めて証跡となる。日本公認会計士協会の監査基準報告書315 実務ガイダンス第1号（2021年8月6日公表、2022年10月13日改正）は、特権 ID の代表的なリスクとして「特権 ID が共有されており、誰が使用して会計データを修正したかを特定することが困難なリスク」を挙げている。主体を個人まで特定できない記録は、統制の運用状況を裏付ける証拠として不十分である。ITGC-C および ITGC-B に対応する。

2.2.2 要求事項

- 時刻 必須** — 協定世界時（UTC）を基準として記録し、タイムゾーンを明示すること。AWS CloudTrail の `eventTime` は UTC、Amazon CloudWatch Logs のイベントタイムスタンプは 1970年1月1日 UTC からのミリ秒である。詳細は 2.3 による。
- 主体 必須** — 個人を特定できる識別子を記録すること。CloudTrail では IAM ユーザーの ARN、ロール引き受け時は `userIdentity.sessionContext.sessionIssuer`、個人識別子は `userIdentity.sessionContext.sourceIdentity`（AssumeRole 呼び出し時のリクエストパラメータ `SourceIdentity` / CLI の `--source-identity` で渡した値。付与には `sts:SetSourceIdentity` 権限が必要であり、条件キー `sts:SourceIdentity` はロール信頼ポリシー等で許容値を強制するために用いる）または `userIdentity.principalId` に含まれるロールセッション名（リクエストパラメータ `RoleSessionName` で渡した値。条件キー `sts:RoleSessionName` は同様に値を要求・限定するために用いる）が該当する。条件キーは値を設定するものではなく設定された値を強制・制約するものであるため、呼び出し側がパラメータを渡す設計と、条件キーによる強制的双方を要求事項に含めること。AWS IAM Identity Center 経由では `userIdentity.onBehalfOf.userId` と `userIdentity.onBehalfOf.identityStoreArn` が該当する。ログに現れる項目名と IAM ポリシーの条件キー名は別物であるため、ログ設計書の項目定義には実ログに現れる項目名を記載すること。ロール引き受け後の操作には、元の IAM ユーザー名は記録されず、ロール ID とロールセッション名のみが残るため、セッション属性による個人特定の手当てを設計すること。
- 発信元 必須** — 送信元 IP アドレス、ユーザーエージェント、VPC エンドポイント経由の場合はエンドポイント識別子を記録すること。
- 対象 必須** — 操作対象のリソース ARN。データベース監査ログではスキーマ・テーブル・オブジェクト、業務ログでは伝票番号・勘定科目・対象期間など、業務上の識別子を記録すること。
- 操作内容 必須** — API 名、SQL の種別、画面上の操作名など、実行された行為を一意に示す値を記録すること。
- 結果 必須** — 成功・失敗の別と、失敗時のエラーコード・エラーメッセージを記録すること。アクセス拒否および認証失敗は、成功と同等に記録対象とすること。
- 関連ID 推奨** — リクエスト単位の識別子（CloudTrail の `requestID` / `eventID` に相当するもの）をアプリケーション側でも発行し、フロントエンドからバックエンド、データベースまで伝播させて各ログに出力すること。IAM Identity Center のサインインイベントは `AuthWorkflowID` で一連の認証を関連できる。
- 構造化形式 必須** — JSON など機械可読な構造化形式で出力し、項目名・型・値域を定義すること。自由記述文のみのログは、項目単位での確実な抽出ができず、抽出結果が抽出条件に該当するすべてであることを示せない（→ 2.10）ため不可とする。
- 個人情報の最小化 必須** — 記録目的に不要な個人情報を出力しないこと。機微情報の取り扱い は 2.7 による。

● 監査の視点

監査人は「特権 ID の利用について、誰が・いつ・何を行ったかを事後に追跡できるか」を確認する。共有 ID を用いる場合であっても、実際の操作者を個人まで特定できる仕組み（ID 連携、セッションへの個人識別子の付与、利用申請記録との突合）が設計されているかが論点となる。設計書には、共有 ID から個人を特定する経路を図または表で示すこと。

2.2.3 監査で求められる証跡

- ログ設計書の記録項目定義（ログ種別ごとの項目名・型・意味・値の例）。
- 実ログのサンプル抜粋（機微情報をマスクしたもの）と、上記定義との一致の確認記録。
- 業務ログのサンプルと、業務システム上の伝票・承認記録との突合結果。
- 共有 ID を用いる場合、個人を特定できることを示す設計記述と実ログでの確認結果。

2.2.4 対応するAWSサービス

AWS CloudTrail の `userIdentity` 構造が主体・セッションの識別を担い、AWS IAM Identity Center が個人単位の認証と識別子の付与を担う。アプリケーション業務ログ（L-07）は Amazon CloudWatch Logs へ構造化形式で出力する。詳細は第5章の認証に関する節による。

2.3 LR-03 時刻同期とタイムスタンプ

2.3.1 目的と統制上の意味

複数のログを突き合わせて一連の事象を再構成するには、各ログの時刻が同一の基準に揃っている必要がある。JPCERT/CC の報告書「高度サイバー攻撃への対処におけるログの活用と分析方法」は、複数機器のログからタイムラインを作成する際にタイムが正しく設定されていないと事象の流れを把握できないとして NTP の活用を求めている。内閣サイバーセキュリティセンターの政府機関等の対策基準策定のためのガイドライン（令和7年度版）も、時刻設定が可能な機器について基準となる時刻への同期とログへの時刻情報の記録を求めている。ITGC-B に対応する。

2.3.2 要求事項

- **UTC統一** **必須** — ログの保存時刻は UTC に統一すること。AWS のマネージドサービスが出力するログは UTC であり、アプリケーション・OS・データベースの出力もこれに揃えること。
- **表示時のJST換算** **必須** — 監査人・発注者への提出物では日本標準時（JST、UTC+9）を併記するか、換算基準を明記すること。抽出条件に用いた時刻が UTC と JST のいずれであるかを、抽出結果に必ず記載すること（→ 2.10）。
- **EC2・コンテナの時刻同期** **必須** — Amazon Time Sync Service（IPv4 169.254.169.123、Nitro 世代のインスタンスでは IPv6 fd00:ec2::123）に同期すること。chrony を用いる場合、当該サーバー行を他の `server` / `pool` 行より前に記述すること。
- **AWS外の機器の同期** **推奨** — オンプレミス機器や外部連携先の機器も、パブリック NTP（`time.aws.com`）等により同一の時刻源へ同期すること。同期できない機器がある場合は、ログ突合時の時刻誤差の扱いを手順書に定めること。
- **うるう秒の扱い** **推奨** — Amazon Time Sync Service のローカル NTP およびパブリック NTP はうるう秒をスミアするが、PTP ハードウェアクロックはスミアせず UTC 標準どおり挿入する。両者を同一ホストで併用

しないこと。

- **遅延到着と欠損の区別** **必須** — ログの到着には遅延がある。CloudTrail は通常 API 呼び出しから平均約5分以内に配信されるが保証はなく、Amazon S3 ユーザーガイドのログ比較表では S3 への配信の速さを、データイベントが5分ごと、管理イベントが15分ごととしている。VPC フローログの最大集約間隔は既定10分である。これらはいずれも目安であり、実際の到着時刻は環境によって変動する。「イベント発生時刻から一定時間内に到着しなかったこと」をもって直ちに欠損と判定しないよう、ログ種別ごとの到着締切は本番同等環境での実測に基づいて定義し、締切を超えたものを欠損として扱う判定基準とともに文書化すること（→ 2.11）。
- **同期状態の監視** **推奨** — 時刻同期デーモンの同期状態を定期取得し、同期喪失を検知できるようにすること。

```
# /etc/chrony.conf - Amazon Time Sync Service (他の server / pool 行より前に記述する)
server 169.254.169.123 prefer iburst minpoll 4 maxpoll 4
```

2.3.3 監査で求められる証跡

- 時刻同期の設定内容（chrony 設定の抜粋、Windows の時刻設定）と、対象ホスト一覧。
- 同期状態の定期取得記録、または同期喪失時のアラート設定と発報実績（推奨事項「同期状態の監視」を採用した場合）。
- UTC/JST の表記規約が記載された文書箇所と、実際の提出物での適用例。
- ログ種別ごとの到着締切の定義（実測値とその測定記録を含む）と、遅延到着の発生実績。

2.3.4 対応するAWSサービス

Amazon Time Sync Service が EC2 インスタンスおよび EC2 上のコンテナの時刻源となる。CloudTrail、CloudWatch Logs をはじめとする AWS のログ出力は UTC を用いる。詳細は第5章による。

2.4 LR-04 改ざん防止と完全性の保証

2.4.1 目的と統制上の意味

ログが後から書き換え・削除できる状態では、証跡としての価値がない。経済産業省のシステム管理基準 追補版（財務報告に係るIT統制ガイダンス、2024年12月25日）は、統制の評価手続の例として「ログの記録や保管に際して、改ざんや削除ができないかについて確かめる」ことを挙げ、インシデント記録について「ログを安全な環境（改ざん、滅失、意図しない暗号化などが行われない環境）に、あらかじめ定められた期間保存されるようにする」ことを求めている。ITGC-C および ITGC-B に対応する。

2.4.2 要求事項

- **ログアーカイブ用の独立アカウント** **必須** — 本番運用アカウントおよび開発アカウントから分離した専用アカウントにログを集約すること。当該アカウントは保管を目的とし、分析処理を実行しない構成とすること。
- **バージョニング** **必須** — ログ保管用 Amazon S3 バケットでバージョニングを有効にすること。
- **WORM保管** **必須** — ただし後掲の例外を除き、S3 Object Lock を有効にすること。財務報告に関連するログにはコンプライアンスモードを適用する。コンプライアンスモードでは、ルートユーザーを含むいかなるユーザーもオブジェクトを上書き・削除できず、モードの変更も保持期間の短縮もできない。Object Lock の有効化に加えて、バケットの既定保持設定（コンプライアンスモードおよび 2.5 で決定した保持期間）を構成する

こと。バケットの既定保持設定は、設定後に配信される新規オブジェクトに適用されるため、証跡の作成およびログ配信の開始前に構成すること。有効化前に存在した既存オブジェクトには既定保持が適用されないため、保護が必要な場合は S3 バッチオペレーションで保持設定を適用すること。ガバナンスモードを採用する場合は、`s3:BypassGovernanceRetention` 権限を誰にも付与しない設計と、その権限が付与されていないことの定期確認を併せて実施すること。

- WORM保管の例外（AWS Config および S3 サーバーアクセスログの配信先）** **必須** — AWS Config の配信チャンネル先バケット、および S3 サーバーアクセスログの配信先バケットは、Object Lock を有効にしたバケット（サーバーアクセスログは Object Lock 有効バケット全般、AWS Config は既定の保持設定を有効化したバケット）にできないため前項の対象外とし、当該バケットの改ざん防止方式（バージョニング、削除拒否ポリシー、レプリケーション等）を別途設計して発注者の承認を得ること。なお S3 サーバーアクセスログは Amazon CloudWatch Logs を配信先とする方式も選択できるため、採否を検討すること。
- ログファイル整合性検証の有効化** **必須** — CloudTrail のログファイル整合性検証を有効にすること。有効にすると、各ログファイルのハッシュ（SHA-256）を含むダイジェストファイルが1時間ごとに配信され、ダイジェストは直前のダイジェストの署名（SHA-256 with RSA）を含む連鎖構造となる。
- 整合性検証の定期実行** **必須** — 有効化は検証そのものを行わない。aws cloudtrail validate-logs を定期的に行い、結果を証跡として保存すること。検証対象はダイジェストから参照されるファイルに限られ、配信元の場所から移動されたファイルは検証できないため、検証はログを移動させずに実施すること。
- 削除・停止を拒否するポリシー** **必須** — サービスコントロールポリシーおよびバケットポリシーにより、ログの停止・削除・保護解除に相当する操作を拒否すること。S3 バケットポリシーで削除を拒否する場合、`s3:DeleteObject`、`s3:DeleteObjectVersion` に加えて `s3:PutLifecycleConfiguration` を拒否対象に含めること。ライフサイクル設定による削除・移行はバケットポリシーでは防げない。
- 組織横断の拒否が及ばない範囲の手当て** **必須** — サービスコントロールポリシーは AWS Organizations の管理アカウントおよびサービスリンクロールには適用されない。管理アカウントについては、ルートアクセスの集中管理、IAM の権限境界、当該アカウントで実行できる操作の限定等による統制の設計案を開発ベンダーが提示し、適用は発注者システム所管（R-2）が行うものとする。設計内容は文書化して発注者の承認を得ること。
- ロググループの削除保護** **推奨** — CloudWatch Logs のロググループに削除保護を設定すること。
- 改ざん・停止試行の検知** **必須** — 拒否された操作を含め、ログ設定の変更・停止・削除の試行を検知し通知すること（ログ種別 L-14、→ 2.8）。
- MFA Delete** **任意** — Object Lock を採用しない領域における代替手段。有効化できるのはバケット所有者（ルートユーザー）のみで、コンソールからは設定できず、ライフサイクル設定と併用できない点に留意すること。


```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyLogPlatformResourceTampering",
      "Effect": "Deny",
      "Action": [
        "cloudtrail:StopLogging",
        "cloudtrail:DeleteTrail",
        "cloudtrail:UpdateTrail",
        "cloudtrail:PutEventSelectors",
        "logs:DeleteLogGroup",
        "logs:PutRetentionPolicy",
        "s3:DeleteBucket",
        "s3:DeleteObject",
        "s3:DeleteObjectVersion",
        "s3:PutLifecycleConfiguration",
        "s3:PutBucketPolicy",
        "s3:DeleteBucketPolicy",
        "s3:PutEncryptionConfiguration",
        "s3:PutBucketVersioning",
        "kms:ScheduleKeyDeletion",
        "kms:DisableKey"
      ],
      "Resource": [
        "arn:aws:cloudtrail:*:*:trail/example-org-trail",
        "arn:aws:logs:*:*:log-group:/example/log-platform/*",
        "arn:aws:s3:::example-log-archive-bucket",
        "arn:aws:s3:::example-log-archive-bucket/*",
        "arn:aws:kms:*:111122223333:key/example-log-key-id"
      ],
      "Condition": {
        "ArnNotLike": {
          "aws:PrincipalARN": "arn:aws:iam::111122223333:role/LogPlatformAdminRole"
        }
      }
    },
    {
      "Sid": "DenyConfigRecorderTampering",
      "Effect": "Deny",
      "Action": [
        "config:StopConfigurationRecorder",
        "config:DeleteConfigurationRecorder",
        "config:PutConfigurationRecorder",
        "config:DeleteDeliveryChannel",
        "config:PutDeliveryChannel",
        "config:PutRetentionConfiguration"
      ],
      "Resource": "*",
      "Condition": {
        "ArnNotLike": {
          "aws:PrincipalARN": "arn:aws:iam::111122223333:role/LogPlatformAdminRole"
        }
      }
    }
  ]
}

```

本サンプルは骨子であり、対象リソースと除外ロールは環境に合わせて設計すること。設計上の要点は次のとおりである。

- 第1のステートメントはログ基盤のリソース（証跡、ログ基盤のロググループ、ログ保管バケット、ログ用 KMS キー）に対象を限定している。Resource を * とすると、業務アプリケーション側のロググループの保持期間設定など正当な運用まで停止するため、対象 ARN は必ずログ基盤のリソースに限定すること。
- 第2のステートメントの AWS Config の設定レコーダー・配信チャネルの操作は、対象リソースを ARN で特定できないため組織横断の拒否として分離している。
- 第2のステートメントは AWS Config の設定レコーダーおよび配信チャネルの操作を組織横断で拒否するため、2.1.2 の必須事項「新規アカウントの自動包含」を実行するアカウント払い出し／ベースライン適用の実行ロール（AWS Control Tower の実行ロール等、サービスリンクロールに該当しないもの）も除外対象に含めること。除外しない場合、新規メンバーアカウントで AWS Config レコーダーおよび配信チャネルを構成できず、LR-01 の網羅性要求を満たせない。除外する場合は当該ロールの引き受け権限を限定し、その利用を L-14 として記録・レビュー対象とすること。
- 除外するロールは、ログアーカイブ用アカウントの特定ロールにアカウント ID まで含めて限定すること。アカウント ID をワイルドカードにすると、任意のメンバーアカウントで同名ロールを作成して拒否を回避できる。あわせて、当該ロールの作成・変更・引き受けの権限も別途制限すること。
- サービスコントロールポリシーは組織の管理アカウントおよびサービスリンクロールには適用されないため、管理アカウントは前掲の必須項目に従って別途統制すること。
- 同様の拒否をバケットポリシー等のリソースポリシーで表現する場合は、対象となるプリンシパルの範囲が変わる。組織外のプリンシパルが拒否対象から外れないよう、aws:PrincipalOrgID、aws:PrincipalAccount 等の条件を用いて対象範囲を明示的に設計すること。サービスコントロールポリシーは組織内のプリンシパルにのみ適用されるため、これらの条件は本サンプルには含めていない。

● 注意

S3 Object Lock には不可逆な性質と配信先としての制約がある。設計段階で次を確認すること。

- Object Lock はバージョニング有効バケットでのみ動作し、有効化後は Object Lock の無効化もバージョニングの停止もできない。
- Object Lock を有効にしたバケットは、S3 サーバーアクセスログの配信先にできない。当該バケットの保護方式は別途設計すること（2.4.2 の必須項目「WORM保管の例外」による）。
- AWS Config は、既定の保持設定を有効化した Object Lock バケットへの配信をサポートしない。AWS Config の配信先は別バケットとし、当該バケットの保護方式を別途設計すること（2.4.2 の必須項目「WORM保管の例外」による）。
- CloudTrail の証跡ログの保管先として S3 Object Lock を用いることは、AWS Security Reference Architecture において CloudTrail ログオブジェクトの完全性を保護する二つの選択肢の一つ（もう一つはログファイル整合性検証）として位置づけられている。ただし Object Lock の既定保持設定は配信後の新規オブジェクトに適用されるため、証跡の作成前にバケットの Object Lock 設定および既定保持設定を完了させること。検収時には配信テスト（証跡作成後、既定保持期間を設定したバケットにログファイルとダイジェストファイルが所定時間内に配置されること、および validate-logs が成功すること）を実施し、結果と実施日を記録すること。
- コンプライアンスモードでは保持期限前に削除できないため、保持期間の設定誤りは訂正できない。保持期間は 2.5 に基づき発注者が決定した値を適用すること。

2.4.3 監査で求められる証跡

- ログ保管用バケットの Object Lock 設定（モード・既定保持期間）、バージョニング設定、パブリックアクセスブロック設定の実機出力。

- 適用しているサービスコントロールポリシーの本文と、適用先の組織単位。管理アカウントに対する代替統制の設計記述と設定の実機出力。
- `validate-logs` の実行記録（実施日、対象証跡、対象期間、結果）。
- AWS Config ルール（`cloud-trail-log-file-validation-enabled`、`cloud-trail-encryption-enabled`、`s3-bucket-versioning-enabled`、`s3-bucket-default-lock-enabled` 等）の評価結果。
- ログ停止・削除の試行を検知した記録と、その対応記録。

2.4.4 対応するAWSサービス

Amazon S3（Object Lock、バージョニング、バケットポリシー）が保管の不変性を担い、AWS CloudTrail のログファイル整合性検証が改変検知を担う。AWS Organizations のサービスコントロールポリシーが停止・削除操作を組織横断で拒否し、AWS Config が設定状態を継続評価する。詳細は第4章および第8章による。

2.5 LR-05 保存期間とライフサイクル

2.5.1 目的と統制上の意味

保存期間は、監査対応上の必要期間、法令上の記録保存義務、セキュリティインシデント調査上の必要期間、および保管コストの均衡で決まる。期間が短ければ過年度の検証ができず、長すぎれば不要な情報保有と費用を招く。ITGC-B に対応する。

● 注意

財務報告に係る内部統制の評価及び監査に関する基準およびその実施基準は、**ログの保存年限を規定していない**。実施基準が期間に言及しているのは内部統制の評価記録についてであり、「金融商品取引法上は、有価証券報告書及びその添付書類の縦覧期間（5年）を勘案して、それと同程度の期間」保存することが考えられるとされている。なお、この5年は内部統制の評価記録に係る期間であってログの保存年限ではない。ログの保存期間は、監査対応上の必要期間に加えて会社法・法人税法等の記録保存義務を勘案して定める必要があるため、次項では別途の推奨値を示す。したがって本節に示す年数はいずれも推奨値であり、**最終的な保存期間は発注者が決定する**。ただし、業種編では、法令が保存期間を定める記録（区分(3)。7.8）について、その期間と起算点を下回らないことを必須とする。開発ベンダーは、発注者が決定した値を設定として実装し、その根拠を文書に記録すること。

2.5.2 要求事項

- **保存期間の決定と根拠の記録** **必須** — ログ種別（L-01～L-14）ごとに、検索可能な状態での保持期間とアーカイブでの保持期間を定め、根拠（法令、監査要求、セキュリティ要求、業務要求）とともに文書化し、発注者の承認を得ること。
- **検索可能状態で1年以上** **推奨** — 内閣サイバーセキュリティセンターの政府機関等向けガイドライン、総務省の地方公共団体向けガイドライン、JPCERT/CC の報告書は、いずれもログを1年以上保存することが望ましいとしている。ただしこれらは政府機関等・地方公共団体を対象とする基準、またはサイバー攻撃への対処という観点からの参考値であり、上場企業の財務報告に係る内部統制を直接規律するものではない。AWS Well-Architected フレームワーク セキュリティの柱 SEC04-BP01（サービスとアプリケーションのログ記録を設定する）も、一般に3か月から1年分を即時照会可能とし、最長7年保持する例を示している。開発ベンダーは、これらを踏まえて検索可能な状態での保持期間を1年以上とする設計案を提示し、発注者の決定値がこれを下回る場合は、理由と代替統制を記録して発注者の承認を得ること。

- 監査ログは事業年度末から10年** **推奨** — 本書が付録 G に収録した業種別の法令調査（以下「業種別調査」）は、ログを (1) 運用ログ、(2) 監査ログ、(3) 業種固有の記録とその変更履歴 の 3 区分に分け（7.1.3）、区分 (2) の保存期間を、全業種に共通する下限の目安として「事業年度末から10年」としている。これは会社法第432条第2項（会計帳簿およびその事業に関する重要な資料。会計帳簿の閉鎖の時から10年）に準じて扱う解釈であり、監査ログを明記した法定の期間ではない。法人税法施行規則第59条第1項の7年（帳簿書類）は、この期間に含まれる。ただし、欠損金額が生じた事業年度の帳簿書類（同規則第26条の3第1項。起算日から10年）は、起算日が事業年度終了の日の翌日から2月を経過した日であるため、区分 (2) より約2か月以上長くなりうる（付録 G の § 3.5）。開発ベンダーは、区分 (2) に当たるログ種別（表7-2）の保存期間を事業年度末から10年とする設計案を既定案として提示し、発注者が法務部門の確認を経て決定した値と、その根拠を記録すること。ログの作成日を起点とする日数で設定する場合は、4,018日（11年）とする。11年の日数はうるう日の数によって 4,017日または 4,018日となり、4,018日を使えば不足しない。
- 業種固有の記録は業種の法令の期間** **必須** — 区分 (3) の記録（その業種の法令が保存を求める記録と、その記録を扱うシステムの変更履歴・操作履歴）は、7.8 に示す業種の法令の期間と起算点を下回らないこと。区分 (3) の記録に対する登録・変更・削除・閲覧の操作ログは区分 (2) にも当たるため、区分 (2) の期間とその記録の法定保存期間のうち、遅く満了する方まで保存すること。期間は年数ではなく満了日で比べること。
- 上限側の制約の確認** **必須** — 保存期間を長くするほど、個人情報保護法第22条（利用する必要がなくなった個人データの遅滞ない消去の努力義務）などの制約との調整が必要になる。7.8 と付録 G に示す上限側の制約を確認し、保存期間を延ばす場合も短くする場合も、その判断と根拠をログ設計書に記録すること。
- 既定値に依存しない明示設定** **必須** — 次の既定値をそのまま用いず、決定した保持期間を明示的に設定すること。
 - Amazon CloudWatch Logs のロググループは既定でログデータを無期限に保持する。保持期間は所定の有効値（1、3、5、7、14、30、60、90、120、150、180、365、400、545、731、1096、1827、2192、2557、2922、3288、3653 日）からのみ選択できる。
 - AWS Config の設定項目の保持期間は既定7年（2,557日）で、30日から2,557日の範囲で設定できる。
 - AWS Control Tower を利用する場合、ログ保管バケットの既定の保持期間は標準のアカウントログが1年、アクセスログが10年であり、最長15年まで設定できる。
- ライフサイクルによる階層化** **推奨** — S3 のライフサイクルルールにより、検索可能期間経過後に低頻度アクセス層およびアーカイブ層へ移行させること。各ストレージクラスには最小保存期間（S3 Standard-IA は30日、S3 Glacier Instant Retrieval および S3 Glacier Flexible Retrieval は90日、S3 Glacier Deep Archive は180日）があり、128 KB 未満のオブジェクトは既定でどのストレージクラスにも移行されない。多数の小さなログファイルをそのまま移行しても効果が出にくいいため、集約してから移行する設計を検討すること。
- 取り出し時間の織り込み** **必須** — アーカイブ層からの取り出しには時間を要する（S3 Glacier Flexible Retrieval は Standard で3～5時間、Bulk で5～12時間、S3 Glacier Deep Archive は Standard で12時間以内、Bulk で48時間以内）。監査依頼への応答期限（→ 2.10）と整合する階層化とすること。
- 削除の実行可能性の確認** **必須** — CloudWatch Logs では保持期限到達後の実際の削除に通常最大72時間を要する。Object Lock コンプライアンスモードでは保持期限前の削除ができない。保存期間の終了に伴う削除がいつ、どのように行われるかを手順書に記載すること。

保存期間の設計、ストレージクラスの選定、コストの見積りは第7章で詳述する。

2.5.3 監査で求められる証跡

- ログ種別ごとの保存期間定義とその根拠、発注者の承認記録。
- 実機の設定値（ロググループの保持期間、S3 ライフサイクルルール、Object Lock の既定保持設定、AWS Config の保持期間）の出力。

- 保持期間の設定が定義と一致していることの確認記録（定期実施分を含む）。

2.5.4 対応するAWSサービス

Amazon S3 のライフサイクルと Object Lock、Amazon CloudWatch Logs の保持期間設定、AWS Config の設定項目保持期間が実装手段となる。詳細は第7章による。

2.5.5 保険での適用

LR-05 を保険に当てはめた要点を示す。期間・起算点・根拠の詳細は 7.8 に示す。

区分 (2) の監査ログは、事業年度末から10年とする。株式会社である保険会社には、会社法432条2項（J1）が適用される。保険業法13条は会社法の規定の読替えだけで、保存期間を定めていない（付録 G の IN3）。相互会社は会社法432条の対象外だが、保険業法54条の2が同じ「帳簿閉鎖の時から10年」を定めるため、株式会社・相互会社とも区分 (2) は同じになる（付録 G の § 6.5、IN1）。いずれも監査ログを明記していないため、準じて扱う解釈である（要法務確認）。外国相互会社には IN1 が準用される（付録 G の IN1）。それ以外の外国保険会社等と少額短期保険業者の区分 (2) の根拠は、業種別調査に記載がない。保険業法は、監査ログについて共通の下限より長い期間を定めていない（付録 G の § 6.5）。

区分 (3) の代表例は、保険仲立人の帳簿・電磁的交付書面・金融サービス仲介業者の記録（保険契約の消滅日から5年）、変額保険の特別勘定元帳（保守的な読みで保険期間の終了日から10年）、苦情処理・利益相反管理などの記録（作成日から5年）である（付録 G の § 6.5）。保険会社自身の契約記録・募集記録（意向把握記録など）には法定の保存期間がないが、業種別調査は「消滅+5年」に揃えることを推奨している（付録 G の § 6.5、INF4）。保険会社の契約データについては、区分 (2) の10年と遅く満了する方まで保存する案である（付録 G の INF7）。起算点が契約の消滅である期間は、終身保険などの長期契約では、保存の終了日が作成から数十年後になる（付録 G の § 6.5）。

区分 (1) の運用ログは、業種固有の追加がなく1年とする。ただし、インターネット取引の認証ログは「事後検証に資する」保存が求められるため、不正検知・顧客通知に使うものは区分 (2) とするかを検討する（付録 G の § 6.5、ING2）。

上限側では、金融分野の個人情報ガイドライン7条が、保険契約者等の個人データについて保存期間を定め、経過したものは消去することとしている。契約データを「無期限に保存」とする設計は、これと整合しない（付録 G の § 6.4、ING10）。

- **必須** 区分 (2) の根拠を、保険会社の会社形態に合わせてログ設計書に記載すること。株式会社は J1、相互会社は IN1（・IN2）とし、保険業法13条を保存期間の根拠として書かないこと（付録 G の § 6.5、IN3）。
- **必須** 区分 (3) の記録は、7.8 に示す期間と起算点を下回らないこと。起算点が契約の消滅などの事象の日である記録は、作成日起点の固定日数だけで管理しないこと（付録 G の INF1）。
- **推奨** 契約者向け Web サービスの認証ログのうち、不正検知・顧客通知に使うものを区分 (1) と区分 (2) のどちらで扱うかを決め、理由とともに記録すること（付録 G の § 6.5、ING2）。
- **必須** 個人データを含むログ・契約データの保存期間を、利用目的に応じて規程に定めること（付録 G の ING10、§ 6.4）。

保険での要求事項の全体は 7.8.5 に示す。

2.6 LR-06 ログへのアクセス制御と職務分掌

2.6.1 目的と統制上の意味

ログを取得しても、記録される側がログを操作できるのであれば統制として成立しない。システム管理基準は IT 部門における職務の分離を求め、追補版は特権について「運用基準があり、特権の付与に際して、最小限にとどめている」こと、アクセス権の申請と承認について「同一人物が両方の行為を実施していないこと」を確かめる評価手続を示している。ITGC-C に対応する。

2.6.2 要求事項

- **最小権限 必須** — ログの参照・設定変更・削除の各権限を分離し、業務上必要な範囲に限定すること。ログアーカイブアカウントへの書き込みは、ログ配信を行う AWS サービスのプリンシパルに限定すること。
- **ログ管理者の独立 必須** — ログ管理者（R-5）を開発者（R-3）および運用者（R-4）から独立させること。ログ基盤の設定変更権限は R-5 に限定し、兼務が避けられない場合は代替統制（相互監視、変更の事後承認）を設けて発注者の承認を得ること。R-5 自身が実施した設定変更の承認およびそのレビュー結果の承認は、R-5 から分離すること（→ 2.9、2.12）。
- **削除権限の付与 必須** — 運用者・開発者に、ログの削除・停止に相当する権限（`s3:DeleteObject`、`s3:DeleteObjectVersion`、`logs:DeleteLogGroup`、`cloudtrail:DeleteTrail`、`cloudtrail:StopLogging`、AWS Config の停止・削除系操作）を付与しないこと。個別の IAM ポリシーだけでなく、組織レベルでも拒否すること（→ 2.4）。
- **監査人の読み取り専用アクセス 必須** — 監査人（R-6）に対して読み取り専用のロールまたは権限セットを用意すること。付与は期間を限定し、付与・失効の記録を残すこと。
- **監査機能を無効化する権限の限定 必須** — CloudTrail の全操作を許可する AWS マネージドポリシー（`AWSCloudTrail_FullAccess`）は監査機能を無効化・再設定できるため、付与対象を最小限にし、付与者の一覧を維持すること。
- **多要素認証 必須** — コンソールを利用する全ユーザーに多要素認証を要求すること。ルートユーザーの多要素認証については、AWS が定める要件と自社のアカウント種別（スタンドアロン、組織の管理アカウント、メンバーアカウント）への適用状況を設計時点で確認し、有効化すること。ルートユーザーは日常作業に使用せず、AWS Organizations の集中的なルートアクセス管理によりメンバーアカウントのルート認証情報を保持しない構成を検討すること。
- **共有ID禁止 必須** — 人が用いる認証は個人単位とし、AWS IAM Identity Center と外部 ID プロバイダの連携を基本とすること。運用上やむを得ず共有される認証情報については、操作者を個人まで特定できる仕組みを併設すること（→ 2.2）。
- **特権操作の経路の限定と記録 必須** — サーバーへの対話的アクセスは AWS Systems Manager Session Manager に限定し、セッションログを取得すること。ログを取得できない経路（SSH、ポートフォワーディング）は IAM で拒否するか、利用時の申請・承認・事後レビューを代替統制として定めること。
- **アクセス権の定期棚卸 必須** — 利用者・権限・多要素認証の有効性・最終利用日を定期的に棚卸すること（→ 2.9）。異動者・退職者の権限は速やかに削除し、その記録を残すこと。
- **ログ基盤へのアクセス自体の記録 必須** — ログの参照・抽出・エクスポート操作が記録され、レビュー対象に含まれること（ログ種別 L-14）。

2.6.3 監査で求められる証拠

- 役割（R-1～R-6）と権限の対応表、およびそれに対応する IAM ロール・権限セットの定義。

- 権限の実機一覧（IAM 認証情報レポート、IAM Identity Center の割り当て一覧）と、承認済みの権限台帳との突合結果。
- 適用中のサービスコントロールポリシー本文。
- 監査人用アカウント・ロールの発行および失効の記録。
- 多要素認証の有効状況、ルートユーザーの利用実績（原則として利用がないこと）。
- ログアーカイブアカウントへのアクセス記録。

2.6.4 対応するAWSサービス

AWS IAM および AWS IAM Identity Center が認証と権限付与を、AWS Organizations のサービスコントロールポリシーが組織横断の禁止を担う。S3 バケットポリシーと AWS KMS のキーポリシーがログ本体への到達を二重に制御し、AWS Systems Manager Session Manager が特権操作の経路と記録を担う。詳細は第5章および第10章による。

2.7 LR-07 暗号化と機微情報の保護

2.7.1 目的と統制上の意味

ログは操作の内容を含むため、それ自体が保護対象の情報資産となる。実施基準は IT の統制目標に機密性を含めており、内部統制の評価記録についても第三者による検証が可能な形で適切な保存を求めている。一方で、ログに認証情報や特定個人情報が入ると、ログの保管・共有そのものが情報漏えいリスクとなる。ITGC-C に対応する。

2.7.2 要求事項

- **保存時暗号化 必須** — ログ保管用 S3 バケットおよびロググループを、AWS KMS のカスタマー管理キーによるサーバー側暗号化（SSE-KMS）で保護すること。ログの読み取りには S3 の読み取り権限と KMS の復号権限の双方が必要となるため、キーポリシーで復号可能な主体を限定すること。KMS キーポリシーは各キーにちょうど一つであり、キーポリシーが許可しない限り IAM ポリシーでは許可できない。
- **キー管理 必須** — 自動ローテーションを有効にすること（既定の間隔は365日、90日から2,560日の範囲で設定できる）。キーを削除するとそのキーで暗号化したデータは復号できなくなるため、ログ用キーは削除ではなく無効化を原則とし、削除予約（待機期間は7日から30日、既定30日）を検知・是正の対象とすること（→ 2.8）。CloudTrail 用の KMS キーは配信先 S3 バケットと同じリージョンに作成すること。CloudWatch Logs で使用できるのは対称キーのみであり、既存ロググループへのキー関連付けはコンソールから行えない。
- **転送時暗号化 必須** — ログの転送を TLS で保護すること。S3 バケットポリシーで `aws:SecureTransport` が `false` のリクエストを拒否すること。
- **機微情報のログ出力禁止 必須** — パスワード、アクセストークン、API キー、クレジットカード番号、個人番号（マイナンバー）等をログに出力しないこと。例外処理でのリクエストボディの全量出力、スタックトレースへのパラメータ埋め込みが典型的な混入経路であるため、設計時に出力箇所を洗い出すこと。
- **マスキング 必須** — Amazon CloudWatch Logs のデータ保護ポリシーにより、認証情報・金融情報・個人情報等をマネージドデータ識別子でマスクすること。ポリシーはアカウントレベルとロググループレベルの双方に設定できる。**ポリシー設定前に取り込まれたイベントはマスクされないため**、ログ出力の開始前にポリシーを適用すること。非マスク表示に必要な `logs:Unmask` 権限の付与は最小限とし、使用実績をレビュー対象に含めること。

- **データベースの監査ログ 必須** — Aurora MySQL の高度な監査で `QUERY` を有効にするとクエリが平文で記録されるため、記録するイベント種別の選定と閲覧権限の限定を設計に含めること。PostgreSQL では pgAudit を用いること（平文パスワード等を秘匿する）。ネイティブの `log_statement` は既定値の `none` を維持することが推奨される。RDS for Db2 では、`EXECUTE` カテゴリの設定値に `WITH` を付すとホスト変数・パラメータマーカーへの入力値も記録されるため、既定の `WITHOUT` を基本とすること（5.3.2）。
- **運用操作での混入防止 必須** — AWS Systems Manager Run Command のパラメータに平文の機密情報を含めないこと（CloudTrail に平文で残る）。Session Manager での対話的なパスワード入力は、端末のエコーを停止する方法を運用手順に定めること。
- **混入時の対応手順 必須** — 機微情報がログに混入した場合の検知・影響評価・封じ込め・報告の手順を定めること。WORM 保管されたログは削除できないため、アクセス制限と鍵管理による封じ込め、および該当認証情報の無効化・再発行を対応の中心に据えること。

2.7.3 監査で求められる証拠

- 暗号化設定（バケットおよびロググループの暗号化方式、使用キーの ARN、キーポリシー本文）。
- TLS を強制するバケットポリシーの本文。
- データ保護ポリシーの定義内容と、検出件数を示すメトリクスの推移。
- `logs:Unmask` 権限の保持者一覧と使用記録。
- マスキング適用前後のログサンプル（提出用に加工したもの）。
- 機微情報混入時の対応手順書と、発生した場合の対応記録。

2.7.4 対応するAWSサービス

AWS KMS が鍵管理を、Amazon S3 と Amazon CloudWatch Logs が保存時暗号化を担う。CloudWatch Logs のデータ保護ポリシーがマスキングを、Amazon RDS／Amazon Aurora の監査機能が DB 層での秘匿を担う。詳細は第4章（KMS に関する節）および第5章による。

2.8 LR-08 監視とアラート

2.8.1 目的と統制上の意味

ログの取得は、それだけでは記録にとどまる。追補版は、アクセス権限の設定を予防的統制、アクセス違反のモニタリングを発見的統制と位置づけ、両者の組み合わせによってプログラムとデータの改ざんが防止されるとしている。特に統制自体を無効化しうる操作（ログの停止、権限の変更、鍵の削除）は、事後のレビューではなくリアルタイムの検知が必要である。ITGC-C および ITGC-B に対応する。

2.8.2 要求事項

- **リアルタイム検知対象 必須** — 少なくとも次の事象を検知し通知すること。
 - ルートユーザーによる操作、および特権セッション（ルートとしてのセッション開始を含む）の開始。
 - 多要素認証を伴わないコンソールサインイン、およびコンソール認証失敗の連続発生。ただし AWS IAM Identity Center 経由のサインインは `ConsoleLogin` ではなく `UserAuthentication` 等のイベントとして記録され、多要素認証の有無は `additionalEventData.CredentialType` の値（`PASSWORD`、`TOTP`、`WEBAUTHN`、`EXTERNAL_IDP` 等）で判定するため、IAM ユーザー向けのパターンとは別に検知条件を設計すること（→ 2.6）。

- IAM のポリシー・ユーザー・アクセスキーの変更、IAM Identity Center の権限セット・割り当ての変更。
- CloudTrail の証跡の作成・変更・削除、ログ記録の開始・停止、イベントセレクトタの変更。
- AWS Config の設定レコーダーの停止・削除、配信チャンネルの変更・削除。
- AWS KMS のカスタマー管理キーの無効化および削除予約。
- ログ保管用 S3 バケットのポリシー・暗号化設定・ライフサイクル設定・レプリケーション設定の変更。
- サーバーへの対話的セッションの開始（Session Manager のセッション開始）。
- ログ配信の停止および取り込み量の急減（→ 2.11）。
- **実装方式 必須** — CloudTrail のイベントを Amazon CloudWatch Logs に送出し、メトリクスフィルターと CloudWatch アラームで検知するか、Amazon EventBridge のルールで検知すること。メトリクスフィルターは作成後に取り込まれたデータのみを対象とし遡及しないこと、Standard ログクラスでのみ利用できること、ロググループあたり100個の上限があることに留意すること。ただしログ配信の停止および取り込み量の急減は、個々のイベントの内容ではなく流量の異常であり、メトリクスフィルターでも EventBridge のルールでも検知できない。これらは CloudWatch Logs が標準で発行する `IncomingBytes` / `IncomingLogEvents` 等のメトリクスに対するアラーム、または S3 への到着オブジェクト数の監視で実装すること。
- **ベンチマーク準拠時のパターン 推奨** — CIS AWS Foundations Benchmark への準拠を求められる場合は、AWS Security Hub CSPM（クラウドセキュリティ態勢管理の機能。従来の AWS Security Hub にあたるものであり、2025年12月に一般提供された新しい AWS Security Hub とは別のサービスであるため、設計時に対象を確認すること）が示すとおりのメトリクスフィルターパターンを用いること。追加の語句を含めると不合格と判定される。ただし、CIS が定めるコンソールサインインに関するパターン（CloudWatch.3）は `$.userIdentity.type = "IAMUser"` を条件に含むため、IAM ユーザーのサインインのみを対象とする。IAM Identity Center 経由のサインインは当該パターンでは検知できないため、前掲の必須検知対象を満たすには別途の検知条件が必要である（→ 2.6）。なお、CloudWatch 系のコントロールのうち v1.4.0 で自動評価されるのは CloudWatch.1 および CloudWatch.4～CloudWatch.14 であり、CloudWatch.2（未承認の API 呼び出し）および CloudWatch.3（多要素認証を伴わないコンソールサインイン）が自動評価されるのは v1.2.0 のみである。v3.0.0 および v5.0.0 では CloudWatch 系のコントロールはすべて手動チェック扱いとなる。採用する版によって自動評価の可否が変わるため、本項の必須検知対象のうち自動評価されないものは、メトリクスフィルターまたは EventBridge ルールとして自ら実装することを前提に設計し、採用する版を発注者と確認すること。
- **通知先の管理 必須** — Amazon SNS のトピックとサブスクリプションを一覧管理し、個人のメールアドレス単独ではなくグループ配信または運用ツールへの連携を用いること。未確認のサブスクリプションは48時間で削除され、バウンスが発生すると一定期間配信が抑止されるため、サブスクリプションの状態を定期的に確認すること。配信解除操作に認証を要求する設定を検討すること。
- **対応手順と時限 必須** — 検知事象ごとに重大度を区分し、一次対応の時限、エスカレーション先、記録方法を定め、発注者の承認を得ること。時限の具体値は発注者と合意して定めること。
- **検知の疎通テスト 必須** — 検収時および設定変更時に、本番同等環境で実際に対象事象が発生させ、検知・通知が機能することを確認し、発生時刻・検知時刻・通知到達時刻を記録すること。
- **セキュリティ検知サービスの連携 推奨** — Amazon GuardDuty および AWS Security Hub CSPM の検出結果を EventBridge 経由で通知経路に統合すること。GuardDuty の検出結果は90日で保持期限を迎えるため、S3 へのエクスポートを設定すること。

```
# ルートユーザーの使用
{$.userIdentity.type="Root" && $.userIdentity.invokedBy NOT EXISTS && $.eventType != "AwsServiceEvent"}}

# CloudTrail 設定変更
{($.eventName=CreateTrail) || ($.eventName=UpdateTrail) || ($.eventName=DeleteTrail) ||
 ($.eventName=StartLogging) || ($.eventName=StopLogging)}
```

```
# コンソール認証失敗
{($.eventName=ConsoleLogin) && ($.errorMessage="Failed authentication")}
```

```
# カスタマー管理キーの無効化・削除予約
{($.eventSource=kms.amazonaws.com) && (($.eventName=DisableKey) || ($.eventName=ScheduleKeyDeletion))}
```

```
# AWS Config 設定変更
{($.eventSource=config.amazonaws.com) && (($.eventName=StopConfigurationRecorder) ||
 ($.eventName=DeleteDeliveryChannel) || ($.eventName=PutDeliveryChannel) ||
 ($.eventName=PutConfigurationRecorder))}
```

2.8.3 監査で求められる証跡

- 検知対象一覧と、それに対応するメトリクスフィルター定義または EventBridge ルール定義。ログ配信の停止・取り込み量の急減については、対象メトリクスとアラーム定義。
- CloudWatch アラームの設定内容（しきい値、評価期間、アクション）。
- SNS トピックとサブスクリプションの一覧および確認状態。
- 疎通テストの記録（実施日、発生させた事象、検知時刻、通知到達の確認）。
- 期間中の発報実績と、各発報に対する対応記録（対応者、対応内容、完了日）。

2.8.4 対応するAWSサービス

Amazon CloudWatch（メトリクスフィルター、アラーム）と Amazon EventBridge が検知を、Amazon SNS が通知を担う。Amazon GuardDuty と AWS Security Hub CSPM が脅威・設定逸脱の検知を補完し、AWS Config ルールが設定状態の継続評価を担う。詳細は第5章の検知に関する節および第9章による。

2.9 LR-09 定期レビューと証跡化

2.9.1 目的と統制上の意味

実施基準は、内部統制の運用状況の評価にあたり「内部統制の実施記録の検証」を手段の一つとして挙げている。ログは、この実施記録に相当する。ただし、ログが存在するだけでは統制が運用されている証拠にならず、定められた頻度でレビューが行われ、その結果が責任者に承認され、例外が是正されていることまでを記録として残す必要がある。ITGC-A、ITGC-B、ITGC-C に対応する。

2.9.2 要求事項

- レビュー対象と頻度の設定** **必須** — 次を目安として対象と頻度を設定し、発注者の承認を得ること。最終的な頻度は発注者が決定する。
 - 特権操作の実施記録（L-01、L-04、L-05） — 週次または月次。
 - アクセス権の棚卸（利用者、権限、多要素認証の有効性、最終利用日） — 四半期。
 - 変更・デプロイ（L-10）と、変更申請・承認記録との突合 — リリース毎。
 - ジョブ・バッチ（L-08）およびデータ連携（L-09）の異常終了と件数整合 — 日次。

- セキュリティ検知（L-12）－ 日次。
- ログ基盤自身の設定変更（L-14）および欠損検知の結果－ 月次。
- ログ取得対象一覧（LR-01）の棚卸－ 四半期。
- **レビュー記録の必須項目** **必須**－ 対象期間、対象ログ種別と保存先、抽出条件、母集団件数、確認件数（サンプリングの場合は抽出方法）、実施者、実施日、確認結果、検出した例外、是正内容と期限、承認者と承認日を記録すること。
- **職務分掌** **必須**－ レビュー実施者は、対象となる操作の実施者と別の者とする。レビュー結果は責任者（R-2 または R-5）が承認すること。ただし R-5 による承認が使えるのは、開発者（R-3）または運用者（R-4）が実施した操作に係るレビューに限る。ログ基盤自身の設定変更（L-14）に係るレビューについては、設定変更の実施者・承認者である R-5 を承認者から除外し、発注者システム所管（R-2）または発注者内部統制担当（R-1）が承認すること。
- **例外の追跡と是正** **必須**－ 検出した例外を一覧管理し、是正完了まで追跡すること。未是正の例外は期限と担当を明示し、期末までの状況を発注者に報告すること。
- **記録の保存** **必須**－ レビュー記録自体も証拠として保存すること。実施基準は評価の記録・保存について、後日第三者による検証が可能となるよう関連する証拠書類を適切に保存する必要があるとしている。保存期間は 2.5 に準じる。
- **サンプリングの取扱い** **推奨**－ 全件確認が困難な場合はサンプリングを用いること。実施基準は、日常反復継続する取引について統計上の二項分布を前提とすると90%の信頼度を得るには統制上の要点ごとに少なくとも25件のサンプルが必要になる、という例示を示している。なお、この25件は監査人が自ら行う試査に関する例示であり、かつ予想逸脱が0件であることを前提とした件数である。レビューで逸脱を発見した場合は、サンプル件数の拡大または追加手続の実施を検討すること。経済産業省のシステム管理基準 追補版（2024年12月25日）も頻度別のサンプル件数の例（1日につき多数および日次は25件、週次は5件、月次・四半期次は2件、年次は1件、いずれも許容逸脱件数0）を示している。これらはいずれも例示であり法令の要件ではない。採用する場合は発注者および監査人と合意すること。
- **抽出の自動化** **推奨**－ レビュー対象の抽出をクエリとして定型化し、クエリ本文をリポジトリで版管理すること。ただし抽出の自動化は、人による判断と責任者による承認を代替しない。

● 監査の視点

監査人が確認するのは、ログの存在ではなくレビューが実際に行われたことである。典型的な確認事項は、レビュー実施者が対象操作の実施者と分離されていること、責任者の承認が記録されていること、検出された例外が是正まで追跡されていること、そしてレビュー対象期間に欠落がないこと（対象として選んだログが全期間について収集されていること）である。レビュー記録の様式は付録Dに定める。

2.9.3 監査で求められる証拠

- レビュー手順書（対象、頻度、抽出条件、判定基準、承認経路）。
- 期間中のレビュー記録一式（実施漏れがないこと、承認が揃っていることが確認できる形）。
- 抽出に用いたクエリ本文と、その実行結果。
- 例外一覧と是正記録。
- アクセス権棚卸の結果（実機一覧、台帳、差異と是正）。

2.9.4 対応するAWSサービス

Amazon Athena および Amazon CloudWatch Logs Insights がレビュー対象の抽出を担う。AWS Config がリソース構成と権限設定の一覧化を、IAM 認証情報レポート（4時間に1回生成できる CSV）および IAM Access Analyzer の未使用アクセス分析（追跡期間は1日から365日で設定）がアクセス権棚卸を支援する。詳細は第9章による。

2.10 LR-10 検索・抽出（監査対応）

2.10.1 目的と統制上の意味

監査人からの依頼は、通常「特定期間の特定の操作について、該当するすべての記録を示すこと」という形で行われる。求められるのは、抽出できることに加えて、抽出結果が当該条件に該当するすべてであることを示せることである。ITGC-B に対応する。

2.10.2 要求事項

- **検索基盤の構築 必須** — S3 に保管したログを Amazon Athena で抽出できる状態にすること（パーティション射影を用いてパーティションの手動追加を不要とする構成を推奨する）。直近期間の照会には Amazon CloudWatch Logs Insights を併用してよい。
- **新規構成での前提条件 必須** — AWS CloudTrail Lake は2026年5月31日以降、新規の利用者に開放されない。新規に構築するシステムでは、CloudTrail Lake を前提とした抽出設計を採らないこと。既存環境で利用中の場合、AWS は既存顧客の継続利用を認めているが、本書が想定する保存期間（→ 2.5）にわたる可用性を前提とするため、継続利用の可否および移行の要否・時期を発注者と確認すること。
- **抽出軸 必須** — 期間、主体（ユーザー・ロール・セッション）、発信元、対象（リソース、テーブル、伝票）、操作、結果の各軸で抽出できること。
- **抽出結果の完全性の示し方 必須** — 抽出結果には次を添付すること。対象ログ種別と保存先、対象期間（UTC と JST の別を明記）、抽出条件（実行したクエリ本文そのもの）、抽出件数、母集団の範囲、実施者、実施日時、抽出ファイルのハッシュ値（SHA-256）。
- **応答期限 必須** — 監査人からの依頼に対する標準応答期限を発注者と合意すること。アーカイブ層からの取り出し時間（→ 2.5）を織り込み、期限内に応答できない階層に置くログについては、取り出し所要時間をあらかじめ明示すること。
- **抽出の再現性 推奨** — 定型的な監査依頼に対応するクエリをクエリ集として整備し、版管理すること。
- **抽出作業自体の記録 必須** — 誰がいつ何を抽出したかがログに残ること（L-14）。抽出結果ファイルの受け渡し経路と保管場所を定めること。
- **抽出リハーサル 必須** — 検収時に、代表的な監査依頼を想定した抽出を実施し、所要時間・件数・出力形式を記録すること。

```
-- ルートユーザーによる操作（パーティション射影列 timestamp で期間を限定する）
-- 除外条件は 2.8.2 のメトリクスフィルター例と同一の母集団を指すよう揃えている
SELECT eventtime, eventsource, eventname, sourceipaddress,
       useridentity.sessioncontext.attributes.mfaauthenticated
FROM cloudtrail_logs_pp
WHERE "timestamp" BETWEEN '2026/04/01' AND '2026/06/30'
      AND useridentity.type = 'Root'
      AND useridentity.invokedby IS NULL
      AND eventtype <> 'AwsServiceEvent'
ORDER BY eventtime;
```



```
# 抽出対象期間のログファイル整合性の検証（時刻は UTC。組織の証跡では --account-id が必要）
aws cloudtrail validate-logs --region ap-northeast-1 \
  --trail-arn arn:aws:cloudtrail:ap-northeast-1:111122223333:trail/example-org-trail \
  --account-id 111122223333 \
  --start-time 2026-04-01T00:00:00Z --end-time 2026-06-30T23:59:59Z
```

組織の証跡では、検証対象がアカウントごとに分かれて保管されるため、対象となるメンバーアカウントごとに `--account-id` の値を変えて実行し、それぞれの結果を記録すること。

● 補足

抽出結果の完全性は、抽出処理の正しさだけでは示せない。対象期間のログが欠損なく保管されていること（→ 2.11）と、保管中に改変されていないこと（→ 2.4）が併せて示されて初めて成立する。監査提出時は、抽出結果と同じ期間について整合性検証の結果を添えることが実務上有効である。証跡の提出手順は第12章で詳述する。

2.10.3 監査で求められる証跡

- 抽出手順書と定型クエリ集。
- 抽出リハーサルの記録（依頼想定、条件、所要時間、件数）。
- 実際の抽出依頼と回答の記録（依頼日、依頼内容、回答日、抽出条件、件数、ハッシュ値）。
- 抽出対象期間の整合性検証結果（組織の証跡では対象アカウントごとの実行結果）。

2.10.4 対応するAWSサービス

Amazon Athena が S3 上のログに対する SQL 抽出を、Amazon CloudWatch Logs Insights が直近ログの照会を担う。AWS Config の高度なクエリと構成履歴の取得が構成情報の抽出を、AWS CloudTrail の整合性検証コマンドが完全性の裏付けを担う。詳細は第5章の分析に関する節および第12章による。

2.11 LR-11 バックアップ・可用性・欠損検知

2.11.1 目的と統制上の意味

ログが取得されていない期間があると、その期間について統制の有効性を示せない。実施基準は、監査人が確認すべき事項として、システムの運用・管理について、障害等によるデータ消失に備えた保存と迅速な復旧のための対策を挙げている。追補版も、モニタリング対象として選んだログが全期間について収集されていることを確かめる評価手続を示している。ITGC-B に対応する。

2.11.2 要求事項

- 配信状態の監視** **必須** — CloudTrail の配信状態（配信エラーの有無）、AWS Config の設定レコーダーの稼働状態と配信結果を定期的に確認し、異常を検知すること。組織の証跡は、バケットポリシーの誤りなどリソース検証に失敗した場合でもメンバーアカウントに作成されるため、証跡が存在することをもって配信できている証拠としないこと。
- ログ量の急減検知** **必須** — ロググループへの取り込み量（`IncomingBytes` / `IncomingLogEvents` 等）、および S3 への到着オブジェクト数を日次で監視し、平常値からの急減を検知して通知すること（→ 2.8）。
- 到着件数の照合** **推奨** — ログ種別ごとに、当日到着すべき件数（またはファイル数）と実際の到着を日次で照合し、結果を記録すること。

- 設定不備の継続検知** **必須** — AWS Config ルールにより、ログ設定の不備を継続的に評価すること。適用するルールの例として、`multi-region-cloudtrail-enabled`、`cloud-trail-log-file-validation-enabled`、`cloud-trail-encryption-enabled`、`cloud-trail-cloud-watch-logs-enabled`、`cloudtrail-s3-dataevents-enabled`、`s3-bucket-versioning-enabled`、`s3-bucket-default-lock-enabled`、`cloudwatch-log-group-encrypted`、`vpc-flow-logs-enabled`、`rds-logging-enabled` がある。なお `multi-region-cloudtrail-enabled` は、管理イベントの除外設定が空でない場合も非準拠と判定される。
- クロスリージョン複製** **推奨** — 重要なログについて S3 のレプリケーションを構成すること。ライブレプリケーションの対象は設定後の新規・更新オブジェクトのみであり、既存オブジェクトの複製にはバッチ処理が必要である点に留意すること。ログ保管バケットで S3 Object Lock を有効にしている場合、レプリケーション構成には複製元・複製先双方の要件が伴うため、採用前に Amazon S3 のレプリケーション要件を確認し、複製先バケットの Object Lock 構成とあわせて設計すること。
- ログ基盤設定のバックアップ** **推奨** — ログ基盤の構成をコードとして保持し（→ 2.12）、リポジトリのバックアップを確保すること。AWS Backup を用いる場合、そのバックアップ・リストアの記録（L-13）自体もログ取得対象に含めること。
- 復元手順とテスト** **必須** — アーカイブ層からの取り出しおよびログ基盤の再構築の手順を文書化し、発注者と合意した頻度（少なくとも年1回）でテストを実施して、所要時間と結果を記録すること。
- 配信経路の設計** **推奨** — CloudWatch Logs から S3 への定期エクスポートは継続的なアーカイブ用途には推奨されないため、長期保管はサブスクリプション（Amazon Data Firehose 経由等）で設計すること。

2.11.3 監査で求められる証拠

- 配信状態およびログ量の監視設定と、期間中の検知実績。
- 日次の到着件数照合記録（推奨事項「到着件数の照合」を採用した場合）。
- AWS Config ルールの評価結果と、非準拠となった項目の是正記録。
- 復元テストの記録（実施日、対象、所要時間、結果、判明した課題と対応）。
- レプリケーション設定と複製状況（推奨事項「クロスリージョン複製」を採用した場合）。

2.11.4 対応するAWSサービス

AWS CloudTrail の配信状態確認と AWS Config ルールが欠損・不備の検知を、Amazon CloudWatch のアラームが急減検知を担う。Amazon S3 のレプリケーション、Amazon Data Firehose、AWS Backup が保全と復元を支える。詳細は第4章および第9章による。

2.12 LR-12 ログ設定の変更管理

2.12.1 目的と統制上の意味

ログ設定は統制そのものであり、無断の変更は統制の無効化を意味する。実施基準は、システムの開発・変更について「その過程が適切に記録及び保存される」ことを求めている。ログ基盤の変更も、業務システムの変更と同等の変更管理プロセスに載せる必要がある。ITGC-A に対応する。

2.12.2 要求事項

- IaCによる管理** **必須** — 証拠、設定レコーダーと配信チャンネル、ロググループと保持期間、バケットポリシー、ライフサイクルルール、Object Lock 設定、サービスコントロールポリシー、メトリクスフィルターと

アラーム、通知先をコードとして管理し、パイプライン経由で適用すること。コンソールまたは CLI からの直接変更を運用手順に含めないこと。

- **変更管理プロセス 必須** — 申請、影響評価（どの要求事項に影響するか）、承認、適用、事後確認の各段階を記録すること。承認はログ管理者（R-5）および発注者システム所管（R-2）が行うこと。ただし申請者が R-5 である場合の承認は R-2 が行い、実施者と承認者を分離すること。
- **ドリフト検知 必須** — AWS Config ルールによりログ設定の逸脱を継続評価すること（適用するルールの例は 2.11 を参照。ログ設定の変更管理では特に `multi-region-cloudtrail-enabled`、`cloud-trail-log-file-validation-enabled`、`s3-bucket-default-lock-enabled`、`cloudwatch-log-group-encrypted` の非準拠を変更管理プロセスの逸脱として扱うこと）。設定レコーダー自体の停止・削除等は、リソースタイプ `AWS::Config::ConfigurationRecorder` により追加料金なしで追跡できる。IaC 側のドリフト検出機能も併用すること。
- **設定変更自体の記録 必須** — ログ設定の変更・削除・停止の試行が CloudTrail に記録され（L-14）、月次のレビュー対象に含まれること（→ 2.9）。承認記録と実際の変更イベントを突合できること。ただし RDS for Db2 のデータベースごとの監査ポリシーの設定・変更・無効化はデータベース内のストアードプロシージャで行われ、CloudTrail には記録されない。5.3.2 に定める代替手段（AUDIT カテゴリによる記録と設定状態の定期確認）で補うこと。
- **緊急変更 必須** — 緊急時に事前承認を得られない場合の手順（事後承認の期限、承認者、記録内容）を定めること。
- **禁止事項の明示 必須** — ログの停止・削除・保持期間の短縮を伴う変更は原則として禁止し、やむを得ない場合は発注者の事前承認と代替統制を要件とすること。

● 注意

AWS Config のマネージドルール `cw-loggroup-retention-period-check` は、保持期間が「無期限（Never expire）」のロググループを準拠と判定する。CloudWatch Logs の保持期間は既定で無期限であるため、このルールの準拠判定をもって「保持期間が方針どおりに設定されている」証拠とすることはできない。保持期間については、実際の設定値の一覧を別途取得し、2.5 で定めた値と突合すること。

2.12.3 監査で求められる証拠

- IaC リポジトリのコミット履歴とコードレビュー記録。
- 変更申請・承認の記録と、パイプラインの適用結果。申請者が R-5 である変更については、R-2 による承認記録。
- AWS Config ルールの評価結果、ドリフト検知の実績と是正記録。
- 期間中のログ設定変更イベント一覧と、承認記録との突合結果。
- 緊急変更が発生した場合の事後承認記録。

2.12.4 対応するAWSサービス

IaC（AWS CloudFormation 等）とデプロイパイプラインが変更の適用経路を、AWS Config ルールとドリフト検出が逸脱の検知を、AWS CloudTrail が変更事実の記録を担う。詳細は第5章および第9章による。

2.13 LR-13 外部委託と責任分界

2.13.1 目的と統制上の意味

実施基準は、委託業務について「委託者が責任を有しており、委託業務に係る内部統制についても評価の範囲に含まれる」としており、2023年の改訂で委託業務の例に「情報システムの開発・運用・保守などITに関する業務を外部の専門会社に委託する場合」が明示された。同改訂では、クラウドやリモートアクセス等の技術を活用するにあたりサイバーリスクの高まりを踏まえた情報システムのセキュリティ確保が重要である旨も追加されている。ITGC-D に対応する。

2.13.2 要求事項

- 責任共有モデルの文書化** **必須** — AWS が担う「クラウドのセキュリティ」(Security of the Cloud) と、利用者が担う「クラウド内のセキュリティ」(Security in the Cloud) の区分を前提に、ログ種別 L-01～L-14 ごとに、AWS・発注者 (R-1、R-2)・開発ベンダー (R-3)・運用ベンダー (R-4)・ログ管理者 (R-5) の責任範囲を表で明示すること。
- SOC報告書の入手経路の明確化** **必須** — AWS のコンプライアンス報告書は AWS Artifact から入手する。入手および監査人への提供は**発注者が行う**ものとし、開発ベンダーは Artifact の文書を再配布しないこと。Artifact の文書には利用条件と透かしが付され、共有が許されるのは自社内、規制当局、監査人に限られる。財務報告に係る内部統制の評価には基本的に SOC 1 報告書（財務報告に限定した内部統制を対象とし、保証業務実務指針3402 に該当するもの）を用いる。委託先のセキュリティ等の状況の理解には SOC 2 報告書を併せて入手することが有用である。いずれも対象期間、評価範囲が発注者の決算期および利用範囲を覆っているかの確認は発注者および監査人が行う。
- 受託会社の報告書の種別** **推奨** — 受託会社の内部統制に関する保証報告書には、基準日現在のデザインの適切性を対象とするタイプ1の報告書と、特定期間にわたる記述の適正性・デザインの適切性・運用の有効性および運用評価手続とその結果を含むタイプ2の報告書がある。運用状況の評価に用いるにはタイプ2の報告書が必要となる点を、発注者との協議事項として提示すること。なお、受託会社の評価結果の報告について必ずしも保証業務実務指針に基づく報告書が必要になるわけではないとされているが、どの証拠をもって足りるとするかは発注者および監査人が判断する事項であり、開発ベンダーが独自に判断しないこと。
- ベンダー要員のアクセスもログ対象** **必須** — 開発ベンダー・運用ベンダーの要員に発行する ID は個人単位で識別でき、その操作が L-01、L-04、L-05 に記録されること。ID と権限は定期的に棚卸し、結果を発注者に報告すること。
- アクセス条件の限定** **推奨** — 保守用アクセスについて、接続経路、利用可能時間帯、対象リソース（タグ条件等）を限定し、条件を文書化すること。
- 再委託の管理** **必須** — 再委託の有無、範囲、要員数をあらかじめ発注者に届け出て承認を得ること。再委託先の要員にも本ガイドラインと同等のログ要求を適用すること。受託会社の報告書において再受託会社を範囲から除く方式が採られている場合でも、再受託会社の内部統制の有効性を監視する受託会社側の内部統制は範囲に含まれる点に留意すること。
- 委託契約への監査協力条項** **必須** — 監査人および発注者内部監査部門による監査の受入れ、ログ・証拠の提出、要員へのヒアリング協力、記録の保存期間、契約終了時の証拠の引渡しと消去を契約に含めること。
- 契約終了時の引継ぎ** **必須** — 保管中のログ、設定情報、抽出手順、定型クエリを発注者または後継ベンダーへ引き渡し、引渡し内容を記録すること。
- 運用状況の定期報告** **推奨** — ログ取得状況、欠損の有無、レビュー結果、例外と是正状況を月次で発注者に報告すること。

● 監査の視点

受託会社の報告書を利用する場合、監査人は当該報告書が十分な証拠を提供しているかを検討する。実務上の論点は、報告書の対象期間が発注者の評価対象期間を覆っているか、報告書の対象範囲に当該システムで利用しているサービス・リージョンが含まれているか、報告書が前提とする委託会社側の統制（利用者側で実施すべき統制）が実際に整備・運用されているか、である。開発ベンダーは、利用しているAWSサービスとリージョンの一覧を提示できるようにしておくこと。

2.13.3 監査で求められる証跡

- ・ 責任分界表（ログ種別 × 関係者）。
- ・ 委託契約書の該当条項（監査協力、再委託、記録保存、契約終了時の取扱い）。
- ・ ベンダー要員の ID 一覧と棚卸記録、発注者への報告記録。
- ・ 再委託の届出・承認記録。
- ・ 利用中の AWS サービスおよびリージョンの一覧。
- ・ 月次の運用報告。

2.13.4 対応するAWSサービス

AWS Artifact がコンプライアンス報告書の入手経路（発注者が実施）となる。AWS Organizations によるアカウント分離、AWS IAM Identity Center による要員単位の認証、AWS Systems Manager Session Manager による保守作業の記録、AWS CloudTrail による操作記録が、委託先アクセスの統制手段となる。詳細は第5章および第10章による。

2.14 LR-14 文書化（ログ設計書・運用手順書）

2.14.1 目的と統制上の意味

統制は、整備状況と運用状況の双方が評価される。整備状況の評価は関連文書の閲覧、質問、観察等を通じて行われるため、設計が文書化されていなければ整備状況を示せない。また実施基準は、システムの変更に際して変更前の内部統制の整備状況に係る記録が更新されていることを留意点として挙げている。文書と実装の乖離は、それ自体が不備となりうる。ITGC-A、ITGC-B、ITGC-C、ITGC-D に対応する。

2.14.2 要求事項

- ・ **ログ設計書** **必須** — 少なくとも次を記載すること。詳細な様式と記載粒度は第11章による。
 - 適用範囲とシステム構成（対象アカウント、リージョン、ネットワーク構成、主要リソース）。
 - 財務報告関連システムとの対応（業務プロセス、勘定科目、関連するIT業務処理統制）。
 - ログ取得対象一覧（L-01～L-14の取得可否、対象外の理由と代替統制） — LR-01。
 - ログ種別ごとの記録項目定義と実ログのサンプル — LR-02。
 - 時刻同期方式と時刻表記規約、遅延到着の判定基準 — LR-03。
 - 改ざん防止方式（WORM構成、整合性検証の運用） — LR-04。
 - 保存先、保持期間、ライフサイクル、削除の実行方法 — LR-05。
 - アクセス制御と職務分掌（R-1～R-6 と権限の対応表） — LR-06。
 - 暗号化・鍵管理・マスキング方式と機微情報の取扱い — LR-07。

- 監視・アラート定義、通知先、重大度区分と対応時限 — LR-08。
- 検索・抽出方式と定型クエリ — LR-10。
- 欠損検知方式と復元手順 — LR-11。
- 責任分界 — LR-13。
- 設定パラメーター一覧（付録Cの様式による）。
- 前提条件、制約事項、残存リスクと発注者による受容の記録。

なお LR-09（定期レビュー）および LR-12（ログ設定の変更管理）はログ設計書の記載事項に含めず、それぞれ次項のレビュー手順書、および運用手順書・変更管理記録で扱う。

- **運用手順書 必須** — 日次・週次・月次・四半期の作業内容と実施者、アラート発報時および欠損検知時の対応、緊急連絡先、エスカレーション経路を記載すること。ログ設定の変更管理（LR-12）の手順と記録様式もここに含めること。
- **レビュー手順書 必須** — LR-09 の対象・頻度・抽出条件・判定基準・記録様式・承認経路を記載すること。
- **監査対応手順書 必須** — LR-10 の依頼受付から提出までの流れ、完全性の示し方、提出物の管理方法を記載すること。
- **設定パラメーター一覧 必須** — 実機の設定値を一覧化し、実機からの出力と一致することを確認して記録すること。
- **証跡の保存場所の一覧 必須** — 各証跡の保存先、命名規則、保存期間、アクセス権を一覧化すること。
- **改版管理 必須** — 版数、改訂日、改訂内容、承認者を管理すること。実装が変わる場合は、同一の作業単位で文書を更新すること。
- **引渡し 必須** — 検収時に発注者へ文書一式を引き渡し、運用ベンダーへの引継ぎを実施して記録を残すこと。
- **日本語による記述 推奨** — 発注者および監査人が読解できるよう日本語で記述すること。AWS のサービス名、API 名、設定値等の識別子は原表記のままとしてよい。

2.14.3 監査で求められる証跡

- 承認済みのログ設計書、運用手順書、レビュー手順書、監査対応手順書。
- 設定パラメーター一覧と、実機出力との突合記録。
- 改版履歴（実装変更と文書更新の時期が対応していること）。
- 発注者への引渡し記録および運用ベンダーへの引継ぎ記録。

2.14.4 対応するAWSサービス

本要求事項に直接対応する AWS サービスはない。ただし設定パラメーター一覧の裏付けとして、証跡・設定レコーダー・ロググループ・バケット設定等の実機出力を取得し、文書と併せて保存すること。成果物の構成と受入チェックリストは第11章による。

2.15 要求事項とAWSサービスの対応

表2-1 に、LR-01～LR-14 と主要な AWS サービスの対応を示す。行を要求事項（LR-01～LR-14）、列を主要な14サービスとし、各セルに ●（主たる実装手段）、○（補助的手段）、—（直接の対応がない）のいずれかを示す。行は図2-1 の五段階（取得・保全・保護・活用・維持）の順に並べ、各行が属する段階を第2列に示す。列とするサービスは、AWS CloudTrail、AWS Config、Amazon CloudWatch Logs、Amazon S3（Object Lock）、AWS

KMS、AWS IAM および AWS IAM Identity Center、AWS Systems Manager Session Manager、Amazon RDS および Amazon Aurora、Amazon EventBridge および Amazon SNS、Amazon Athena および AWS CloudTrail Lake、Amazon GuardDuty および AWS Security Hub CSPM、AWS Organizations および AWS Control Tower、AWS Backup、AWS Artifact の14である（列見出しでは接頭辞の AWS／Amazon を省略する）。個別の設定手順は第4章および第5章による。

表2-1 要求事項と主要AWSサービスの対応（●＝主たる実装手段、○＝補助的手段、－＝直接の対応なし）

要求事項	段階	CloudTrail	Config	CloudWatch Logs	S3 (Object Lock)	KMS	IAM \ IAM Identity Center	Session Manager	RDS \ Aurora	EventBridge \ SNS	Athena \ CloudTrail Lake	GuardDuty \ Security Hub CSPM	Organizations \ Control Tower	Backup	Artifact
LR-01 対象範囲	取得	●	●	○	○	－	－	○	○	－	－	○	●	○	－
LR-02 記録項目	取得	●	－	●	－	－	●	●	●	－	－	－	－	－	－
LR-03 時刻同期	取得	－	－	－	－	－	－	－	－	－	－	－	－	－	－
LR-04 改ざん防止	保全	●	○	○	●	○	－	－	－	－	－	－	●	－	－
LR-05 保存期間	保全	○	○	●	●	－	－	－	○	－	－	－	○	－	－
LR-11 欠損検知	保全	○	●	●	●	－	－	－	－	○	○	○	－	○	－
LR-06 アクセス制御	保護	○	○	○	●	●	●	●	－	－	－	－	●	－	－
LR-07 暗号化・機微情報	保護	－	－	●	●	●	－	○	●	－	－	－	－	－	－
LR-08 監視・アラート	活用	●	○	●	－	○	○	○	－	●	－	●	○	－	－
LR-09 定期レビュー	活用	●	●	○	－	－	●	○	○	○	●	●	－	○	－
LR-10 検索・抽出	活用	●	●	●	○	－	○	－	－	－	●	－	－	－	－
LR-12 変更管理	維持	●	●	○	○	○	－	－	○	○	－	○	●	－	－
LR-13 外部委託	維持	○	－	－	－	－	○	○	－	－	－	－	●	－	●
LR-14 文書化	維持	－	－	－	－	－	－	－	－	－	－	－	－	－	－

● 補足

表2-1 の列に含まれないサービス、および表だけでは読み取れない事項を補足する。LR-03（時刻同期）の主たる実装手段は Amazon Time Sync Service であり、これは表2-1 の列とした14サービスに含まれないため、同行は全列を「－」としている。表2-1 の各サービスは UTC で時刻を記録することにより LR-03 に寄与するが、これは時刻同期の実装手段ではないため表では扱わない（→ 2.3.4）。同様に、LR-11 の長期保管経路として用いる Amazon Data Firehose、および LR-12 の IaC による適用経路となる AWS CloudFormation 等も表2-1 の列に含まれない。これらは各節の「対応するAWSサービス」および第4章・第5章による。LR-14（文書化）は成果物に関する要求であり、主たる実装手段となるサービスがないため全列を「－」としているが、設定パラメーター一覧の裏付けとして各サービスの実機出力を用いる（→ 2.14.4）。また AWS CloudTrail Lake は2026年5月31日以降、新規の利用者に開放されないため、新規構築では Amazon Athena による抽出を基本とすること（→ 2.10）。

3

ログ種別と取得対象マトリクス（L-01～L-14）

第2章の要求事項（LR-01～LR-14）が「ログに何を満たさせるか」を定めるのに対し、本章は「何をログとして取得するか」を定める。財務報告に関連するシステムで取得すべきログを 14 種別（L-01～L-14）に整理し、種別ごとに統制目的、AWS 上の発生源、有効化方法、保存先、要求レベルを示す。開発ベンダーは本章を起点に対象システムのログ設計書（第11章）を作成すること。

3.1 マトリクスの見方

表3-1 の各列は次の意味である。

- **内容**：当該種別が記録する事象。財務報告に関連しない事象まで広げる必要はないが、対象システムの構成要素に発生する事象は漏れなく含めること。
- **主な統制目的**：IT全般統制の領域（ITGC-A～D）またはIT業務処理統制のいずれに資するか。1つのログが複数の統制目的に用いられる場合がある。なお ITGC-D（外部委託に関する契約の管理）は、ログの種別ではなく委託契約の管理に係る統制であるため、表3-1 には現れない。運用ベンダー等への委託に係る要求は LR-13 が定める。委託先に付与するログへのアクセス権限と職務分掌は第10章による。
- **AWS上の発生源**：ログを生成するサービスまたはコンポーネント。
- **取得・有効化方法**：既定で取得されるか、明示的な有効化が必要かを含む設定の要点。詳細は第4章および第5章に示す。
- **推奨保存先**：一次保存先。保存期間とライフサイクルは第7章、改ざん防止の実装は第8章による。
- **要求レベル**：**必須** は発注者が受入条件とする事項、**推奨** は合理的理由なく省略しない事項、**任意** は発注者と協議のうえ採否を決める事項である。

要求レベルはシステム単位ではなく「システム構成要素 × ログ種別」の単位で適用する。当該システムに存在しない構成要素に対応する種別（例：データベースを持たないシステムにおける L-06）は対象外として差し支えないが、対象外とする理由を 3.4 節の対応表に記載し、発注者（R-2 システム所管）の確認を得ること。取得可能であるにもかかわらずコスト・工数を理由に取得しない場合は、対象外ではなく未充足として扱い、代替統制または是正計画を提示すること。レイヤと種別の対応の概観を図3-1 に示す。

財務報告に関連するシステムの構成レイヤとログ種別の対応

業務アプリケーション層	L-07 / L-08 / L-09	L-14 ログ基盤自身の 監査ログ (全レイヤを横断)
データストア層	L-02 / L-06 / L-13	
実行環境・OS 層	L-05	
ネットワーク・境界層	L-11	
クラウド基盤・ID 層	L-01 / L-03 / L-04 / L-12	
CI/CD・変更管理	L-10	

L-14 は他の全種別の設定・保存先そのものを対象とし、ログが取得され続けていることを裏付ける。
本図は代表的な配置であり、実際の対応は 3.4 の対応表で判定すること。

図3-1 ログ種別のレイヤ構成

● 監査の視点

IT全般統制の評価単位はIT基盤を単位として識別され、IT業務処理統制の評価は基本的に個々のシステムごとに行われる。監査人はまず「対象システムに関係するITの範囲」を把握し、そのうえで統制上の要点ごとに証跡を求める。本章の対応表は、この範囲把握に開発ベンダー側から回答するための一次資料となる。範囲が示せない場合、取得しているログの量にかかわらず網羅性（LR-01）を立証できない。

3.2 ログ種別マトリクス

表3-1 ログ種別マトリクス（L-01～L-14）

ID・名称	内容	主な統制目的	AWS上の発生源	取得・有効化方法	推奨保存先	要求レベル
L-01 クラウド基盤 API操作ログ	コンソール・CLI・SDKによるAWS API操作（管理イベント）	ITGC-B、 ITGC-C	AWS CloudTrail	組織証跡をマルチリージョンで作成。Read/Write 両方、整合性検証、SSE-KMS	ログアーカイブ 用 S3 + Amazon CloudWatch Logs	必須
L-02 データアクセスログ	財務データ実体（S3 オブジェクト等）への読取・書込・削除	ITGC-C、IT 業務処理統制	CloudTrail データイベント、S3 サーバーアクセスログ	既定は無効。高度なイベントセレクトで対象リソースを指定。S3 側でアクセスログを有効化	ログアーカイブ 用 S3（S3 サー バーアクセスロ グの宛先は 3.3.2 参照）	必須 （財務 データ格 納領域） 推奨 （その他）
L-03 構成変更履歴	AWS リソース設定の時点記録と変更差分	ITGC-A、 ITGC-B	AWS Config	全リージョンでレコーダーを有効化（Continuous）。グローバル IAM リソースは1リージョンのみ	Config データス トア + 配信先 S3	必須
L-04 認証・認可ログ	サインイン、ロール引受、権限付与・変更、業務利用者の認証	ITGC-C	CloudTrail（signin/sts/iam/sso）、アプリケーション	AWS 側は L-01 に包含。業務利用者の認証は開発ベンダーが実装	L-01 と同じ、ア プリ分は CloudWatch Logs → S3	必須
L-05 サーバ操作ログ	サーバへの対話操作（入力と出力）、OS 認証・特権操作	ITGC-B、 ITGC-C	AWS Systems Manager Session Manager、OS 監査ログ	セッション設定で S3/CloudWatch Logs 出力を指定。OS ログは CloudWatch エージェント	S3、 CloudWatch Logs → S3	必須 （本番 サーバ）
L-06 データベース監査ログ	DB 接続、DDL/DCL/DML、アプリ外からの直接データ修正	IT業務 処理統 制、 ITGC-C	Amazon RDS/Amazon Aurora 監査ログ（Database Activity Streams は任意）	パラメータグループ/オプショングループで有効化し、インスタンス外へ出力（3.3.6 参照）	CloudWatch Logs → S3（SQL Server・Db2 は S3 に直接出力）	必須 （財務 データ保 持 DB）
L-07 アプリケーション業務ログ	財務データの登録・更新・削除・承認・取消、マスタ変更、権限変更、エラー	IT業務 処理統 制	アプリケーション（開発ベンダー実装）	構造化ログを CloudWatch Logs へ出力。機微項目はマスク	CloudWatch Logs → S3	必須

ID・名称	内容	主な統制目的	AWS上の発生源	取得・有効化方法	推奨保存先	要求レベル
L-08 ジョブ・バッチ実行ログ	起動契機、開始・終了、成否、処理件数、再実行	ITGC-B、IT業務処理統制	Amazon EventBridge Scheduler、AWS Step Functions、AWS Batch、AWS Glue、実行基盤（コンテナ／サーバ／cron）	実行ログを CloudWatch Logs へ。状態変化を EventBridge → Amazon SNS	CloudWatch Logs → S3	必須
L-09 データ連携ログ	インターフェース送受信、件数・金額の整合、エラーと再処理	IT業務処理統制	連携アプリケーション、連携基盤	送信側・受信側の双方でコントロールトータルを出力	CloudWatch Logs → S3	必須 (連携がある場合)
L-10 変更・デプロイログ	ビルド、承認、本番反映、IaC 適用、構成のドリフト	ITGC-A	CI/CD サービス、AWS CloudFormation、CloudTrail	承認アクションとパイプライン実行、スタックイベント、ドリフト検出を記録	CloudWatch Logs → S3、変更管理記録	必須
L-11 ネットワーク・通信ログ	VPC 内通信の許可・拒否、HTTP アクセス、DNS クエリ	ITGC-C	VPC Flow Logs、Elastic Load Balancing、AWS WAF、Amazon CloudFront、Amazon Route 53 Resolver クエリログ	各リソースで個別に有効化（既定は無効）	ログアーカイブ用 S3	必須 (公開経路のアクセスログ) 推奨 (フローログ)
L-12 セキュリティ検知ログ	脅威検出結果、セキュリティ基準への準拠状況	ITGC-B、ITGC-C	Amazon GuardDuty、AWS Security Hub CSPM	組織単位で全リージョン有効化。検出結果を S3 へエクスポート	検出結果エクスポート先 S3	必須
L-13 バックアップ・コピー・復旧の実施結果、復旧ポイントの削除	バックアップ・コピー・復旧の実施結果、復旧ポイントの削除	ITGC-B	AWS Backup、CloudTrail	レポートプランで S3 配信。サービスイベントを CloudTrail で記録	レポート配信先 S3、L-01	必須
L-14 ログ基盤自身の監査ログ	ログ設定の変更・停止・削除、およびその拒否された試行	ITGC-B、ITGC-C	CloudTrail (cloudtrail/s3/kms/config/logs)、AWS Config	メトリクスフィルターとアラーム、Config ルール、ログバケットのデータイベント（当該証跡自身の配信先バケットは対象から除くか、証跡の RecursiveLogging を無効化する）	L-01 と同じ + 通知履歴	必須

● 補足

「ログアーカイブ用 S3」は、運用アカウントから独立したログ集約専用アカウントの S3 バケットを指す。アカウント分離を含む標準構成は第6章に、そのバケットに求めるバージョンニング・S3 Object Lock・SSE-KMS の設定は第8章に示す。「CloudWatch Logs → S3」は、CloudWatch Logs を一次保存先とし、サブスクリプションフィルターと Amazon Data Firehose で S3 へ継続的に転送する構成を指す。CloudWatch Logs から S3 への定期エクスポートは、継続的なアーカイブ手段としては推奨されない。なお、S3 サーバーアクセスログの CloudWatch Logs 配信は、配信先として Amazon S3 または Amazon Data Firehose を直接指定する機構であり、本書で「CloudWatch Logs → S3」と表記する構成とは別である。

3.3 各ログ種別の詳細

以下、種別ごとに概要、取得対象の具体例、必須記録項目、AWS 上の実現方法、取得漏れの典型例を示す。「必須記録項目」は、第2章の LR-02（記録項目（5W1H））が定める記録項目を種別ごとに具体化したものであり、これを満たさない実装は当該種別を取得したものみなさない。記録項目の一般的な定義は LR-02 によるものとし、本章では言い換えを行わない。

3.3.1 L-01 クラウド基盤API操作ログ（AWS CloudTrail 管理イベント）

AWS 環境に対するあらゆる操作の基点となるログであり、他の全種別の前提となる。財務報告に関連するシステムが稼働する全アカウント・全リージョンを対象とすること。

取得対象の例：IAM ユーザー・ロール・ポリシーの作成と変更、S3 バケットとバケットポリシーの操作、RDS インスタンスとパラメータグループの変更、Amazon EC2（以下 EC2）・Amazon ECS（以下 ECS）の起動と停止、KMS キーの操作、CloudTrail・AWS Config 自身の設定変更。

必須記録項目：発生時刻（UTC）、操作主体（userIdentity）、送信元 IP、ユーザーエージェント、リージョン、イベント名とイベントソース、リクエストパラメータ、結果（errorCode/errorMessage の有無）、イベント ID。

AWS上の実現方法：

- AWS Organizations の管理アカウントまたは委任管理者で組織の証跡を作成し、メンバーアカウントに一律適用すること。メンバーアカウントは組織の証跡を削除・停止・変更できない。
- マルチリージョン証跡とし、グローバルサービスイベントを含める設定を有効にすること。IAM・AWS STS・CloudFront のイベントは us-east-1 に記録される。
- ログファイル整合性検証を有効化し、SSE-KMS で暗号化すること（第8章）。CloudWatch Logs への配信を併せて設定し、L-14 の監視に用いること。
- 管理イベントの最初のコピーは追加料金なしで記録できる。同一リージョンで管理イベントを重複記録する2本目以降の証跡は課金対象となるため、証跡の本数は用途を明確にして設計すること。証跡数はリージョンあたり5本で、引き上げできない。

● 注意

- コンソールの「イベント履歴」は過去90日の管理イベントのみを対象とし、単一アカウント・単一リージョンに限られる。これを証跡の代替とみなさないこと。
- 管理イベントの除外設定（ExcludeManagementEventSources）で AWS KMS 等を除外すると、除外中のイベントは事後に回復できない。除外する場合は理由をログ設計書に記載し、発注者の承認を得ること。なお、L-14 で使用するマルチリージョン証跡のマネージドルールは、除外設定が空でない場合を非準拠と評価する。除外を採用する場合は、当該ルールの評価結果の取扱い（例外承認の記録、または代替の検出手段）を併せて設計書に記載すること。
- 組織の証跡は、S3 バケットポリシーや SNS トピックポリシーの不備、CloudWatch Logs への配信不可、KMS キーによる暗号化権限の不足といったリソース検証に失敗した場合でも、メンバーアカウント側に作成される（この場合ログは配信されない）。構築後に `aws cloudtrail get-trail-status` で配信エラーの有無を確認し、結果を証跡として残すこと。
- 新たに有効化したオプトインリージョンや、後から組織に追加したアカウントの記録開始状況を確認していない例が多い。

3.3.2 L-02 データアクセスログ（CloudTrail データイベント、S3サーバーアクセスログ）

L-01 が記録するのはリソースに対する管理操作であり、リソース内のデータそのものへのアクセスは記録されない。財務データの実体に誰が触れたかを示すのが本種別である。

取得対象の例：会計データを格納する S3 バケットのオブジェクト取得・保存・削除、証憑ファイルの持ち出し、連携ファイル授受用バケットへのアクセス、財務データを保持する Amazon DynamoDB（以下 DynamoDB）テーブルの項目操作。

必須記録項目：発生時刻、操作主体、送信元 IP、対象リソース（バケット名とオブジェクトキー等）、操作種別（読取・書込・削除）、結果。

AWS上の実現方法：CloudTrail のデータイベントは既定で無効であり、追加料金が発生する。高度なイベントセレクトで対象リソースをバケットまたはプレフィックス単位に限定し、財務データ格納領域に絞って有効化すること。セレクトの条件にワイルドカードは使えないため、前方一致・後方一致の演算子を用いること。S3 サーバーアクセスログは、認証に失敗したアクセスやライフサイクルによる移行・失効を記録できるため、CloudTrail データイベントの補完として併用すること。

● 注意

- 「CloudTrail を有効化した」という報告のみで、データイベントが未設定のまま受け入れられる例が最も多い。有効化の対象リソース一覧をログ設計書に明記すること。
- ライフサイクル設定による削除・移行は CloudTrail のオブジェクトレベルのログには記録されない。ライフサイクルによる消失と人為的削除を区別するには S3 サーバーアクセスログが必要である。
- S3 サーバーアクセスログはベストエフォート配信で、完全性・適時性が保証されない。単独では改ざん・欠落の立証に用いないこと。また S3 バケットを宛先とする場合は同一リージョン・同一アカウントで SSE-S3 に限られ、S3 Object Lock を有効にしたバケットは宛先にできない。したがってログ集約アカウントへ集約する場合は、いったん同一アカウント内のバケットへ配信したうえでレプリケーション等の転送方式を別途設計するか、S3 サーバーアクセスログの宛先として CloudWatch Logs を選択すること（CloudWatch Logs 宛先はクロスアカウント・クロスリージョンの配信および KMS 暗号化に対応する）。

3.3.3 L-03 構成変更履歴（AWS Config）

CloudTrail が「誰がどの API を呼んだか」を記録するのに対し、AWS Config は「リソースが結果としてどの状態にあったか」を時点で記録する。変更前後の状態比較と、期末時点の設定状態の立証に用いる。

取得対象の例：セキュリティグループの許可範囲、IAM ロールにアタッチされたポリシー、S3 バケットの暗号化・公開ブロック設定、RDS のパラメータ、CloudTrail 証跡自身の設定。

必須記録項目：記録時刻、リソース種別と識別子、リージョン、設定内容、前回からの差分、関連リソース、ルール評価結果（準拠・非準拠）。

AWS上の実現方法：顧客管理の設定レコーダー（customer managed configuration recorder）はアカウント・リージョンあたり1つで、配信チャネルも1つである。これとは別に、AWS のサービスが自動的に作成するサービスリンク設定レコーダーが存在する場合があります、その記録範囲は当該サービスが決定し直接変更できない。財務報告に関連するリソースが存在する全リージョンで有効化し、記録頻度は変更の都度記録する継続記録（Continuous）を既定とすること。グローバルの IAM リソースは重複を避けるため1リージョンでのみ記録すること。設定項目の保持期間は既定 2,557日（7年）で、30日から 2,557日の範囲で設定できる。設定履歴ファイルはリソース種別ごとに6時間ごとに S3 へ配信される。

● 注意

- グローバルの IAM リソースを記録できるリージョンには制約があり、2022年2月以降に AWS Config が提供開始されたリージョンでは記録できない。記録リージョンを決めた根拠を残すこと。
- 記録対象に含めていないリソース種別は作成と削除しか捕捉されず、設定内容は残らない。「全リソースを記録」以外の設定にする場合は、除外したリソース種別と理由を記載すること。
- 既定の保持設定を有効にした S3 Object Lock バケットは AWS Config の配信先としてサポートされない。第8章の改ざん防止設計と配信先設定の整合を確認すること。
- Config 側の保持期間（既定7年）と配信先 S3 のライフサイクル設定が不一致のまま放置される例がある。第7章の保存期間設計と突き合わせること。

3.3.4 L-04 認証・認可ログ

誰がシステムに入り、どの権限を得たかを示すログである。AWS 環境への管理者アクセスと、業務アプリケーションへの利用者アクセスの双方を対象とする。

取得対象の例：マネジメントコンソールへのサインイン（成功・失敗）、多要素認証の使用有無、ロールの引受、IAM Identity Center での認証と権限セットの割当変更、業務アプリケーションへのログイン・ログアウト・ロック、権限の付与と剥奪。

必須記録項目：発生時刻、認証主体の識別子、送信元 IP、認証手段（多要素認証の有無）、認証結果、引き受けたロールまたは権限、割当変更の場合は対象者・付与内容・実施者。

AWS上の実現方法：AWS 側の認証イベントは L-01 の証跡に含まれる。コンソールのサインインは ConsoleLogin イベントとして記録され、多要素認証の使用有無は additionalEventData に含まれる。IAM Identity Center は認証の各段階（資格情報の要求・検証・認証完了）をイベントとして記録し、一連の試行は AuthWorkflowID で関連できる。ロールを共有して運用する場合は、ロール引受時に sts:SourceIdentity またはセッション名を設定し、個人を特定できるようにすること。業務利用者の認証ログは開発ベンダーが実装し、L-07 と同じ関連 ID 体系で出力すること。

● 注意

- AWS のログには業務アプリケーションの利用者認証は残らない。アプリケーション側の認証ログの実装漏れは、アクセス管理（ITGC-C）の統制不備に直結する。
- 共有ロールのみで運用すると、以後の操作はロールの識別子でしか記録されず、行為者を特定できない。個人と AWS 上の識別子の対応表を第11章のログ設計書に含めること。
- クロスアカウントでロールの引受が拒否された場合、引受先アカウント側には記録されない。呼び出し元アカウント側での記録の有無は対象 API ごとに公式ドキュメントで確認し、記録されない場合の代替の検知手段（引受先の信頼ポリシー変更の検知等）を設計書に記載すること。
- サインイン時にユーザー名欄へ誤って資格情報を入力した場合、当該値はマスクされて記録される。マスクされたイベントを「不明な操作」として放置しないこと。

3.3.5 L-05 サーバ操作ログ（Session Manager セッションログ、OS 監査ログ）

アプリケーションを経由せずサーバ上で行われた操作を記録する。データベースの直接操作やファイルの差し替えなど、業務処理統制を迂回しうる操作の抑止と事後検証に用いる。

取得対象の例：本番サーバへの対話的接続とその入力コマンド・出力、OS への昇格操作、OS 利用者アカウントの追加・削除、ログイン成功と失敗、設定ファイルの変更。

必須記録項目：セッション ID、接続した主体、接続先ノード、開始・終了時刻、入力コマンドと出力、接続および OS 認証の結果（成功・失敗）。

AWS上の実現方法：AWS Systems Manager Session Manager のセッション設定で、S3 または CloudWatch Logs への出力を明示的に設定すること。CloudWatch Logs を出力先とする場合、ストリーミング（Stream session logs）方式は対話的コマンドをサポートしないため、必須記録項目の「入力コマンドと出力」を満たすには S3 出力、またはセッション終了時にログをアップロードする方式を選択すること。Windows ノードで PowerShell Transcription ポリシーが設定されている場合、ストリーミングは利用できない。選択した方式と、それが必須記録項目を満たす根拠をログ設計書に記載すること。出力先を設定しない限りセッションの入出力は保存されない。暗号化されたバケット・ロググループのみを許可する設定を選択すること。OS 側の監査ログは CloudWatch エージェントで収集し、Linux は監査ログや認証ログのファイル、Windows はセキュリティイベントログを対象とすること。セッションログおよび OS 監査ログの保存先は、記録項目ではなく保管設計に属する事項として、ログ設計書に記載すること。

● 注意

- ポートフォワーディングまたは SSH を経由するセッションはログを記録できない。SSH セッション用ドキュメントの利用を IAM ポリシーで拒否し、拒否していることを設定証跡として残すこと。
- Linux/macOS では screen ユーティリティが存在しないとログが切り詰められることがある。対象 AMI での導入状況を確認すること。
- セッション履歴は、セッションログを有効化した場合に過去30日分の接続明細のレポートを取得できるとされており、長期保存の手段にはならない。保持期間は設計時に公式ドキュメントで確認し、S3 または CloudWatch Logs への出力を必須とすること。
- パスワード等をコマンドラインから入力するとログに記録される。入力時にエコーを抑止する運用手順を運用ベンダーに引き渡すこと。

3.3.6 L-06 データベース監査ログ（RDS／Aurora 監査ログ、Database Activity Streams）

アプリケーションを経由しない直接のデータ操作を記録する。締め処理後のデータ修正など、内部統制を無効化する操作の検出に不可欠である。

取得対象の例：DB への接続と切断（成功・失敗）、GRANT／REVOKE 等の権限操作、CREATE／ALTER 等の定義変更、INSERT／UPDATE／DELETE の実行、管理用アカウントによる操作。

必須記録項目：発生時刻、接続元ホストと DB ユーザー、接続 ID、操作種別、対象データベース・オブジェクト、実行された文、結果コード。

AWS上の実現方法：Aurora MySQL は DB クラスターパラメータで監査を有効化し、記録するイベント種別（接続、クエリ、DDL、DML、DCL 等）を指定すること。RDS for MySQL はオプショングループに監査プラグインを追加して有効化すること。PostgreSQL 系は pgAudit 拡張を用い、共有プリロードライブラリへの追加と再起動、拡張の作成、記録対象の指定を行うこと。RDS for SQL Server は SQL Server Audit をオプショングループで追加し、監査（audit）と監査仕様を作成したうえで S3（および任意で CloudWatch Logs）へ出力すること。RDS for Oracle は `audit_trail` パラメータ（既定 `none`）を `os`、`db [, extended]`、`xml [, extended]` のいずれかに設定して監査を有効化し、`audit` ログ種別を CloudWatch Logs へ発行すること。RDS for Db2 はオプショングループに `DB2_AUDIT` オプションを追加して出力先の S3 バケットと IAM ロールを指定し、データベースごとに監査ポリシー（`rdsadmin.configure_db_audit`）を設定すること。RDS for Db2 の監査ログは S3 にのみ出力され、CloudWatch Logs には発行できない。いずれのエンジンでも、統合監査を用いる場合を含め監査ポリシーの作成・維持は利用者側の責任であり、既定では監査は行われない。また、いずれのエンジンでもインスタンス上のファイルはローテーションで失われるため、インスタンス外への出力（RDS for SQL Server は S3 への出力と必要に応じた CloudWatch Logs への転送、RDS for Db2 は S3 への出力、その他のエンジンは CloudWatch Logs への発行）を設定すること。より高い保証が必要な場合は、Database Activity Streams に対応するエンジン（Aurora MySQL、Aurora PostgreSQL、RDS for Oracle、RDS for SQL Server。対応バージョンは公式ドキュメントで確認すること）では、その採用を発注者と協議すること（**任意**）。RDS for Db2 は対応していないため、5.3.2 に定める監査ポリシーの設定と一次保全用バケットの保護で要求を満たすこと。

● 注意

- ロググループの保持期間が未設定のまま「無期限」となり、第7章の保存期間設計と一致していない例がある。発行先ロググループの保持期間を明示的に設定すること。
- Aurora には特定のクエリだけを除外するフィルタがなく、参照系を除きたい場合は DML 全体を除外することになる。除外設定は監査証拠の欠落に直結するため、除外内容を発注者の承認事項とすること。
- 管理用アカウントによる定期的なヘルスチェックがログを肥大化させる場合がある。除外ユーザーの設定を検討し、除外した利用者と理由を記載すること。
- ネイティブのステートメントログ機能を安易に有効化すると平文の資格情報が記録されるおそれがある。監査目的では監査プラグインまたは拡張機能を用いること。
- RDS for Db2 では、カテゴリ `ALL` を指定しても SQL 文の実行（`EXECUTE`）は記録されない。更新系 DML を記録するには `EXECUTE` を個別に設定すること。また監査ポリシーはデータベースごとに設定するため、データベースの追加時に未設定のまま残らないようにすること（5.3.2）。

3.3.7 L-07 アプリケーション業務ログ

IT業務処理統制の中心となるログであり、開発ベンダーの実装責任が最も大きい種別である。財務データの登録・更新・削除・承認・取消、マスタ変更、権限変更、エラーおよび例外処理を対象とする。

取得対象の例：仕訳・伝票の起票と更新、取消・赤伝処理、承認と差戻し、取引先・勘定科目・単価等のマスタ変更、利用者への業務権限の付与と剥奪、入力チェックエラーとその再処理、締め処理の実行。

必須記録項目：以下をすべて出力すること。

- ・ 操作者 ID（業務利用者の識別子。代行入力の場合は代行者と被代行者の双方）
- ・ 操作日時（UTC を基準とし、表示上の時差を明示）
- ・ 対象キー（伝票番号、マスタコード等、対象レコードを一意に特定できる値）
- ・ 変更前後の値または変更差分（新規登録は登録値、削除は削除前の値）
- ・ 承認者（承認・差戻しの操作では承認者 ID と承認日時）
- ・ 相関 ID（画面操作から API、バッチ、DB 操作までを一意に追跡する識別子）
- ・ 処理結果（正常・エラー、エラーコードと例外の内容）

AWS上の実現方法：構造化された JSON 形式で標準出力またはエージェント経由により CloudWatch Logs へ出力し、ロググループを業務単位で分離すること。機微情報は CloudWatch Logs のデータ保護ポリシーでマスクし、マスク解除の権限を限定すること。長期保存は第7章に従い S3 へ転送すること。出力例を次に示す。

```
{
  "timestamp": "2026-09-08T02:15:33.412Z",
  "correlationId": "b1f2c3d4-5e6f-4a7b-8c9d-0e1f2a3b4c5d",
  "eventType": "JOURNAL_UPDATE",
  "operatorId": "u-102934",
  "approverId": "u-100021",
  "targetKey": "JV-2026-000841",
  "before": { "amount": 1200000, "accountCode": "5110" },
  "after": { "amount": 1250000, "accountCode": "5110" },
  "result": "SUCCESS"
}
```

● 注意

- ・ 「更新した」事実のみを記録し、変更前後の値を残さない実装は、事後の検証ができず統制の証跡として成立しない。
- ・ 相関 ID を持たないと、アプリケーションのログと L-06 の DB 監査ログ、L-01 の基盤ログを突合できず、直接データ修正の有無を否定できない。
- ・ データ保護ポリシーによるマスクは、ポリシー設定前に取り込まれたログには適用されない。マスク設計は本番稼働前に完了させること。
- ・ 承認操作を画面遷移だけで完結させ、承認者をログに残していない例がある。承認は必ずログに残すこと。

3.3.8 L-08 ジョブ・バッチ実行ログ

定時処理・定期処理の実行結果を記録する。財務報告に関連するジョブが計画どおり実行され、異常終了に対処されたことを示す。

取得対象の例：Amazon EventBridge Scheduler、AWS Step Functions、AWS Batch、AWS Glue、OS の cron 等により起動される日次・月次の集計処理、外部連携ジョブ、締め処理、再実行。

必須記録項目：ジョブ ID とジョブ名、起動契機（定時起動・手動起動・再実行の別）、実行主体、開始・終了時刻、終了コード、処理件数（入力・出力・スキップ）、エラー内容、再実行時は元の実行 ID。

AWS上の実現方法：実行基盤の標準出力を CloudWatch Logs へ集約し、成否と処理件数はアプリケーション側で明示的に出力すること。EventBridge でジョブの状態変化を捕捉し、失敗を Amazon SNS で通知すること（第9章）。未実行はイベントが発生しないため EventBridge では検知できず、実行完了ログの不在を監視する仕組み（想定実行時刻を過ぎても完了ログが到着しないことのアラーム化等）を別途設けること。EventBridge Scheduler は少なくとも1回の配信を保証する方式であり重複起動が起こりうるため、冪等性キーと重複検知の結果もログに残すこと。利用する各サービスの実行履歴の保持期間とログ出力先の既定値は、公式ドキュメントで確認のうえログ設計書に記載すること。

● 注意

- コンソール上の実行履歴に依存する設計は、保持期間の経過とともに証跡が失われる。履歴は必ずログとして保存先に転送すること。
- 異常終了は記録されるが「起動しなかった」ことは記録されない。未実行の検知は、実行完了ログの不在を監視する仕組みで補うこと。
- 処理件数を記録していないと、ジョブが正常終了しても対象データが欠落していないことを示せない。

3.3.9 L-09 データ連携ログ（インターフェース送受信・件数整合）

システム間で受け渡されたデータが、漏れも重複もなく処理されたことを示すログである。入力情報の完全性・正確性を確保する統制、および例外処理の修正と再処理に直接対応する。

取得対象の例：販売管理システムから会計システムへの日次売上連携、経費精算データの取込、外部サービスとの API 連携、ファイル授受による連携、取込エラーデータの修正と再取込。

必須記録項目：インターフェース ID、方向（送信・受信）、対象期間または対象キー範囲、送信件数、受信件数、正常処理件数、エラー件数、金額等のコントロールトータル、突合結果（一致・不一致）、相関 ID、再処理の場合は実施者・承認者・対象件数。

AWS上の実現方法：送信側・受信側の双方でコントロールトータルを出力し、突合結果を1レコードとして記録すること。連携ファイルを S3 経由で受け渡す場合は、ファイル実体へのアクセスを L-02 のデータイベントで併せて記録すること。出力例を次に示す。

```
{
  "timestamp": "2026-09-08T17:05:00.000Z",
  "interfaceId": "IF-SALES-TO-GL-D",
  "direction": "RECEIVE",
  "targetDate": "2026-09-07",
  "sentCount": 15234, "receivedCount": 15234, "successCount": 15230, "errorCount": 4,
  "controlTotal": { "amount": 482913500 },
  "reconciliation": "MATCHED",
  "correlationId": "if-20260908-0001"
}
```

● 注意

- 送信側のログしか残さない設計では、受信側での取りこぼしを検出できない。双方向で記録すること。
- 件数のみを記録し金額のコントロールトータルを残していないと、件数が一致したまま金額が誤るケースを検出できない。
- エラーデータの再処理を運用担当者の手作業に委ね、実施者・承認者・対象件数を記録していない例が多い。再処理は必ず記録対象とすること。

3.3.10 L-10 変更・デプロイログ（CI/CD、IaC 適用）

本番環境に何がいつ反映されたかを記録し、変更管理（ITGC-A）における承認記録との対応づけを可能にする。監査人は変更依頼または変更されたプログラムを起点にサンプリングし、承認から本番反映までを追跡する。

取得対象の例：ソースコードの変更、ビルドとテストの実行結果、パイプラインの手動承認アクション、本番環境へのデプロイ、IaC テンプレートの適用とスタック更新、緊急対応時の手動変更。

必須記録項目：変更依頼番号、変更内容（コミット識別子、テンプレートのバージョン）、承認者と承認日時、実行者、本番反映日時、パイプライン実行 ID またはスタック更新 ID、実行結果、切り戻しの有無。

AWS上の実現方法：パイプラインの状態変化を Amazon EventBridge で捕捉し、通知と記録を行うこと。手動承認アクションには承認者と要約コメントを残す運用とし、承認待ちのまま一定期間（採用する CI/CD サービスの既定では数日程度の場合がある）を経過するとアクションが失敗扱いとなるため、採用サービスのタイムアウト仕様を公式ドキュメントで確認し、運用設計に織り込むこと。ビルドログは CloudWatch Logs、デプロイエージェントのログは CloudWatch エージェントで集約すること。AWS CloudFormation を用いる場合はスタックイベントを保全し、ドリフト検出を定期実行して手動変更の有無を確認すること。パイプラインの実行履歴の保持期間、および承認結果が記録される API 名は、公式ドキュメントで確認のうえ設計書に記載すること。

● 注意

- 承認記録が変更管理ツール側にしかなく、本番反映（パイプライン実行 ID 等）と紐づいていないと、承認済みの変更のみが反映されたことを示せない。対応づけの項目を設計時に定めること。
- コンソールからの直接変更は CloudTrail（L-01）にしか残らず、変更管理記録と対応しない。AWS Config（L-03）のドリフト検出と併せて検知する設計とすること。
- ビルドサービスの S3 へのログ出力は既定で無効な場合がある。デプロイエージェントのログはローテーションにより短期間で削除されるため、集約設定が必須である。

3.3.11 L-11 ネットワーク・通信ログ

不正アクセスの検知と事後追跡に用いる。財務報告の正確性に直接対応するものではないが、システムの安全性の確保（ITGC-C）を裏付ける。

取得対象の例：VPC 内の通信の許可・拒否、ロードバランサへの HTTP リクエスト、WAF による遮断、CDN 経由のアクセス、DNS クエリ。

必須記録項目：発生時刻、送信元・宛先アドレスとポート、プロトコル、通信量、許可または拒否の別、HTTP アクセスではリクエスト内容・応答コード・利用者エージェント、DNS クエリではクエリ名・レコードタイプ・応答コードおよび応答データ。

AWS上の実現方法：VPC Flow Logs は VPC・サブネット・ENI の単位で作成し、集約間隔と記録フィールドを指定すること。既定のフィールドに加え、必要に応じて VPC ID・サブネット ID・インスタンス ID 等を含むカスタム形式を用いることができる（**任意**）。採否は発注者と協議すること）。Elastic Load Balancing のアクセスログは既定で無効のため明示的に有効化すること。AWS WAF のログを S3 または CloudWatch Logs に出力する場合、バケット名およびロググループ名に所定の接頭辞が必要である。S3 を宛先とする場合、既定では Web ACL を管理するアカウントのバケットが前提であり、別アカウントのログ集約用バケットへ出力するにはバケット所有者側で配信用のバケットポリシーを手動で付与する必要がある。DNS クエリは VPC Flow Logs には記録されないため、VPC 単位で Amazon Route 53 Resolver クエリログの記録を作成し、CloudWatch Logs または S3 を出力先に指定すること。

● 注意

- VPC Flow Logs には記録されない通信がある（Amazon DNS サーバー宛、インスタンスメタデータ宛、時刻同期サービス宛、DHCP 等）。記録がないことを「通信がない」と読み替えないこと。
- フローログは作成後に記録形式・集約間隔を変更できず、削除して再作成する必要がある。設計段階でフィールドを確定させること。
- ネットワークロードバランサのアクセスログは TLS リスナーがある場合に限り、TLS 接続の情報のみが記録される。TCP/UDP リスナーのみで構成する場合はアクセスログ自体が生成されないため、当該経路については VPC Flow Logs（該当 ENI 単位）とバックエンドのアプリケーションアクセスログの組合せを代替統制として設計し、その構成と根拠をログ設計書に記載して発注者（R-2 システム所管）の確認を得ること。
- フローログはリアルタイムのストリームではなく、配信に遅延がある（CloudWatch Logs 宛で約5分、S3 宛で約10分、いずれもベストエフォート）。秒単位の即時検知が必要な要件は、フローログでも L-12 でも満たせないため（GuardDuty はフローログ等を分析源とする下流のサービスであり、新規検出結果の配信も生成から約5分後である）、要件そのものを発注者と再確認すること。

3.3.12 L-12 セキュリティ検知ログ（GuardDuty、Security Hub CSPM）

他のログを分析源とする検知の結果を記録する。実施基準は、クラウドやリモートアクセス等の技術の活用に当たり、サイバーリスクの高まり等を踏まえた情報システムに係るセキュリティの確保が重要である旨を述べている。ただし実施基準は、新たなITシステムの導入を要求するものではなく、また財務報告の信頼性以外の目的のためのIT統制を直接的に求めるものでもない。これを踏まえ、本書では発注者の受入条件として、財務報告に関連するシステムにおける検知の有効化とその結果の保全を必須とする。

取得対象の例：認証情報の異常な利用、想定外の地域からの API 呼び出し、マルウェア検知、セキュリティ基準からの逸脱（暗号化されていないログバケット、無効化された証跡等）。

必須記録項目：検出日時、検出種別と重大度、対象アカウント・リージョン・リソース、検出根拠、対応状況（確認者、対応内容、完了日時）。対応状況は運用記録として第9章の定期レビュー証跡に含める。

AWS上の実現方法：Amazon GuardDuty は AWS Organizations 経由で全アカウント・全リージョンに有効化し、新規アカウントの自動有効化を設定すること。AWS Security Hub CSPM（セキュリティ標準に基づく設定評価を行うサービス）は AWS Config の記録を前提とするため、L-03 の設定と併せて設計すること。同サービスは名称・機能範囲の変更があるため、設計時点の名称と対応する標準を公式ドキュメントで確認すること。検出結果は Amazon EventBridge 経由で通知し（第9章）、S3 へのエクスポートを設定して保全すること。

● 注意

- GuardDuty の検出結果は90日で保持期限を迎える。S3 へのエクスポートを設定していないと、期末監査の時点で期初の検出結果が参照できない。
- エクスポート設定はリージョンごとに必要であり、アーカイブ済みの検出結果は出力されない。エクスポート先の S3 バケットと KMS キーは同一リージョンに存在する必要がある。商用リージョンからオプトインリージョンへのエクスポート、およびオプトインリージョン間のエクスポートはできない。オプトインリージョンを利用する場合は集約先バケットの配置を設計時に確認すること。
- 採用するセキュリティ基準のバージョンによって、自動評価されるコントロールの範囲が異なる。採用バージョンと、自動評価されない項目を手動確認とする運用を設計書に記載すること。

3.3.13 L-13 バックアップ・リストアログ（AWS Backup）

データ消失に備えた保全と迅速な復旧の対策が実施されていることを示すログである。実施基準は、システムを構成する重要なデータやソフトウェアについて、障害や故障等によるデータ消失等に備え、その内容を保存し、迅速な復旧を図るための対策が取られていることを、ITGC-Bの運用管理に関する留意点として挙げている。本書では、その対策が実効的であることを示すため、バックアップの実施結果に加え復旧テストの結果を記録することを求める。

取得対象の例：バックアップジョブの開始・完了・失敗、復旧ポイントの作成、別リージョン・別アカウントへのコピー、リストアの実行、復旧ポイントの削除、保管庫の設定変更。

必須記録項目：ジョブ ID、対象リソース、開始・終了時刻、結果、復旧ポイントの識別子と保持期限、失敗時の原因と再実行結果、リストアの場合は実施者・目的・所要時間・検証結果。

AWS上の実現方法：AWS Backup のジョブは CloudTrail にサービスイベントとして記録される。加えてレポートプランを設定し、ジョブレポート（直近24時間に完了したジョブおよび実行中のジョブが対象）とコンプライアンスレポートを S3 へ日次配信して長期の証跡とすること。ジョブレポートは対象期間が直近24時間に限られ、配信が欠落した日の実績を事後に再生成できないため、配信の成否自体を監視対象に含めること。保管庫には保持期間の下限・上限を設定すること。改ざん防止の実装は第8章による。

● 注意

- ジョブ一覧を返す API は直近30日を対象とするため、コンソールや API の照会結果だけでは通期の実施証跡にならない。
- レポートの配信先は同一アカウント内の S3 に限られる。ログ集約アカウントへ集める場合は転送方式を別途設計すること。
- バックアップの成功記録のみを残し、リストアが実際に可能であることを検証していない例が多い。復旧テストの計画と結果を記録すること。
- 復旧ポイントの削除イベントを監視対象に含めていないと、証跡の消失に気づけない。

3.3.14 L-14 ログ基盤自身の監査ログ

ログが取得され続けていることを裏付ける最上位の統制である。L-01～L-13 がどれほど整備されていても、その設定を変更・停止・削除できる者が記録されなければ、ログ全体の信頼性を主張できない。

取得対象の例：

- CloudTrail 自身：証跡の作成・更新・削除、記録の開始と停止、イベントセレクタの変更
- S3 ログバケット：バケットポリシー・ライフサイクル・暗号化・バージョンニング設定の変更、バケットおよびオブジェクトの削除
- AWS KMS：ログ暗号化キーの無効化、削除の予約、キーポリシーの変更
- AWS Config：レコーダーの停止・削除、配信チャネルの削除、保持設定の変更
- CloudWatch Logs：ロググループの削除、保持期間の短縮、サブスクリプションの削除
- 上記に対する拒否された試行（権限不足によりアクセスが拒否されたイベント）

必須記録項目：発生時刻、操作主体、対象のログ資産、操作種別、結果（成功・拒否）、検知の有無と通知先、対応記録。

AWS上の実現方法：これらのイベントはいずれも L-01 の管理イベントとして記録されるため、追加取得ではなく検知の実装が本質である。CloudTrail を CloudWatch Logs へ配信し、メトリクスフィルターとアラームを設定して通知すること（第9章）。CloudTrail の設定変更を検知するフィルターパターンの例を次に示す。

```
{ ($.eventName=CreateTrail) || ($.eventName=UpdateTrail) || ($.eventName=DeleteTrail) ||
  ($.eventName=StartLogging) || ($.eventName=StopLogging) }
```

併せて AWS Config のマネージドルール（マルチリージョン証跡の有効化、ログファイル整合性検証の有効化、証跡の暗号化、CloudWatch Logs 連携）で継続的に準拠状況を評価すること。ログ集約先アカウントに対する操作も同様に記録・検知の対象とすること。予防面では、組織のポリシーによりログ資産に対する変更操作を限定的な役割以外から拒否する設計を第10章で扱う。ログ資産に対する操作権限を運用ベンダーへ委託する場合は、委託範囲・許可される操作・記録の確認責任を LR-13 に従って責任分界表に定め、委託先の操作が本種別で記録されることを確認すること。

● 注意

- ログバケットに対するオブジェクトレベルの操作は、データイベント（L-02）を有効化しないと記録されない。ただし、当該証跡自身がログファイルを配信しているバケットをそのままデータイベント対象に指定すると、ログ配信による PutObject がデータイベントとして記録され、それがさらにイベントを生む再帰的ログ（recursive logging）となる。対象とする場合は、監査対象のログ資産（例：他サービスのログ配信先バケット、証跡とは別のバケット）に限定するか、証跡の RecursiveLogging を無効化して CloudTrail の配信操作に起因するイベントを抑止すること。
- 拒否された試行を監視対象に含めていない設計が多い。成功したイベントだけでなく、権限不足で拒否されたイベントも検知対象とすること。ただし、クロスアカウントの操作では記録されるアカウントが限られる場合があるため、対象 API ごとに公式ドキュメントで確認すること。
- ロググループの削除や保持期間の短縮は、証跡を失わせる操作でありながら監視対象から漏れやすい。削除保護の設定可否を含めて設計すること。
- アラートの通知先が失効していると検知は機能しない。通知経路の生存確認を定期レビュー（第9章）に含めること。

3.4 対象システムへの当てはめ

開発ベンダーは、ログ設計書（第11章）において「システム構成要素 × L-xx」の対応表を作成すること。構成要素は、システム構成図・ネットワーク構成図に現れるすべての要素（アカウント、VPC、コンピュート、データストア、認証基盤、連携基盤、CI/CD、ログ基盤）を列挙し、L-01～L-14 のそれぞれについて取得の要否を判定する。対象外とする場合は、該当する構成要素が存在しない、または当該事象が発生しないという事実に基づく理由を記載すること。これに加え、同一の事象が他のログ種別で記録され、その記録項目が LR-02 を満たす場合は、代替する種別を明記したうえで対象外と判定してよい。この第3の類型は、事象の記録自体が別の種別で確保されていることを前提とする点で、取得可能な事象を取得しないままにする未充足（3.1 節）とは異なる。代替種別を示せない場合は対象外ではなく未充足として扱うこと。「対象外」の記載がない空欄は、判定漏れとして扱う。

表3-2 「システム構成要素 × ログ種別」対応表の記載例（抜粋）

構成要素	具体例	該当するログ種別	対象外とする種別と理由
認証基盤	AWS IAM Identity Center、業務アプリの利用者認証	L-01、L-04、L-14	L-06：データベースを保持しない構成要素であるため
業務アプリケーション	コンテナ上で稼働する会計 API・画面	L-07、L-09、L-11	L-05：対話的接続を許可しない設計のため。ただし例外的に接続を許可する場合は L-05 を適用する
会計データベース	Amazon Aurora（財務データを保持）	L-06、L-13	L-02：当該データストアへのデータアクセスは代替種別 L-06 で記録し、LR-02 の記録項目を満たすため（RDS Data API を使用する場合は CloudTrail データイベントの対象とする）。L-08：当該要素上でジョブを起動しないため
バッチ基盤	スケジューラおよび集計処理	L-05、L-08、L-09	（本表は抜粋。実際の対応表では L-01～L-14 の全種別について該当または対象外を記載する）
CI/CD 基盤	パイプライン、IaC テンプレート	L-01、L-10	L-06、L-09：財務データを扱わないため
ログ基盤	ログ集約アカウント、ログ用 S3、暗号化キー	L-01、L-02、L-14	（本表は抜粋。実際の対応表では L-01～L-14 の全種別について該当または対象外を記載する）

表3-2 は記載の粒度を示す抜粋であり、紙面の都合により構成要素ごとに一部の種別のみを示している。実際の対応表は、構成要素ごとに L-01～L-14 の全種別について該当・対象外のいずれかを必ず記載し、空欄を残さないこと。対象外の種別が存在しない場合も「該当なし」とは記載せず、全種別を判定済みであることが分かる表記とすること。

対応表の作成にあたっては、次の点を満たすこと。

- 対応表は、要求レベルの判定単位（3.1 節）と一致させ、**必須** と判定した組合せについては第4章・第5章の設定要件を満たす設定内容を併記すること。
- 対象外の判定は開発ベンダー単独では確定させず、発注者（R-2 システム所管および R-1 内部統制担当）の確認結果を記録すること。
- システム構成の変更（構成要素の追加、サービスの置換、連携先の追加）が生じた場合は、同じ単位で対応表を更新し、ログ設定の変更管理（LR-12）の手続に従うこと。構成が変わったにもかかわらず対応表が更新されていない状態は、それ自体が統制の不備となる。
- 対応表と実際の設定が一致していることを、設定内容の出力（AWS Config の照会結果、CLI による設定の取得等）により示すこと。設計書上の記載のみでは、取得されていることの証跡にならない。

● 監査の視点

評価および監査においては、モニタリングの対象として選んだログが評価対象期間の全期間にわたって収集されていたことが確かめられる。また実施基準は、期中に運用状況の評価を実施した場合、期末日までに重要な変更があったときは追加手続の実施を検討することを求めている。したがって対応表は、期末時点の設定を示すだけでは足りず、期首から期末までの間に構成要素と取得範囲がどう変化したかを追跡できる形で維持する必要がある。構成要素の追加日、ログ取得の開始日、設定変更の日付を対応表に併記しておく、期中の取得漏れの有無を効率的に説明できる。

本章で定めた取得対象に対し、記録項目・時刻・改ざん防止・保存期間・アクセス制御・監視・レビュー・抽出の各要求は第2章の LR-01～LR-14 が定める。AWS サービスごとの具体的な設定は第4章および第5章、全体構成は第6章、保存期間の設計は第7章、改ざん防止の実装は第8章、監視とレビュー運用は第9章、職務分掌とアクセス制御は第10章に示す。

3.5 保険のシステムへの当てはめ

付録 G の § 6.1 が挙げる、記録・ログが問題になる場面を、ログ種別（L-01～L-14）とログの 3 区分（7.1.3）に対応させた例を表3-3 に示す。区分は、7.1.3 の定義と付録 G の § 6.5 の推奨案による。業種固有の記録への登録・変更・削除・閲覧の操作ログは区分 (2) にも当たるため、区分 (2) の期間と記録の保存期間のうち、遅く満了する方まで保存する（付録 G の § 2、§ 6.5）。

表3-3 保険のシステム・記録とログ種別・区分の対応（例）

システム・記録	主なログ種別（L-xx）	区分	根拠の行番号	設計上の注意
契約管理システムの保険契約のデータ（申込書、保険証券の控えなど）とその変更履歴	L-06、L-07	(3)（推奨案は消滅＋5年）。(2)の10年も満たすかは法務部門と決める（推奨案は遅く満了する方まで）	INF7、INF1、§ 6.5	保険会社の契約データの保存期間を、保険業法令は直接定めていない（変額保険の特別勘定を除く）。会社法432条（J1）の「事業に関する重要な資料」に当たるかは解釈である。変更履歴・操作履歴を契約IDに紐づけて管理できることが、消滅日を起点とする管理の前提になる
募集支援システムの記録（意向把握の帳票、意向確認書面、説明の記録、高齢者募集の録音など）	L-02、L-07	(3)（推奨案は消滅＋5年）。操作ログは(2)と(3)の遅く満了する方	IN17、ING3、ING4、ING5、IN19、INF4	法令上の保存期間はない。監督指針は、銀行等の募集時の記録を「保険期間が終了するまで」としている（ING4）。「保険期間の終了まで」や、保険法95条（3年。IN19）に余裕を持たせた期間とする選択肢もあり、法務・コンプライアンス部門が決める（INF4）
閲覧の方法で交付・提供した書面の電子データ（電磁的交付書面）	L-02、L-07（データへの操作ログ）	(3)（データ）。操作ログは(2)と(3)の遅く満了する方	IN7、IN8、INF6	データ自体はログではない。保存期間中は「消去し又は改変することができないもの」とし、苦情の申出があれば解決日まで延びる。起算点は、IN7が保険契約が消滅した日、IN8が記載事項に掲げられた取引を最後に行った日である。顧客の指図による消去を認める必要がある。消去の指図の記録を(2)として残すかは判断事項である（INF6）
代理店システム・保険仲立人のシステムの帳簿書類、金融サービス仲介業者の保険媒介業務の記録	L-06、L-07	(3)（帳簿・記録）。操作ログは(2)と(3)の遅く満了する方	IN4、IN5、IN6、IN18、ING7、INF5	特定保険募集人は締結の日から5年、保険仲立人・金融サービス仲介業者は消滅した日から5年と、起算点が異なる。一般の保険募集人には帳簿の保存義務自体がない。複数の種類の事業者で共用する場合は、最も長い「消滅＋5年」に揃えるのが安全である（INF5）
変額保険などの特別勘定（特定特別勘定）の経理システム	L-06、L-07、L-08	(3)（帳簿）。操作ログは(2)と(3)の遅く満了する方	IN9、INF3	特定特別勘定元帳は、法務部門の確認までは保守的に「保険期間の終了日から10年」とする（解釈。INF3）。変額終身保険では作成から数十年後まで保存が必要になる。総勘定元帳は作成の日から5年、委託契約書は委託契約の終了の日から5年である
保険金信託業務の信託勘定系システム（保険金信託業務を行う生命保険会社のみ）	L-06、L-07	(3)（帳簿）。操作ログは(2)と(3)の遅く満了する方	IN10、INF3	信託勘定元帳は信託期間に連動する。起算点の「又は」の構文は、特定特別勘定元帳と同じ論点である（INF3）
苦情管理・利益相反管理のシステム、保険金支払システム・代理店管理システム（兼業代理店に関する記録）	L-06、L-07	(3)（記録。作成日から5年）。操作ログは(2)	IN11～IN15、ING6	記録の期間（作成の日から5年）は共通の下限より短い。区分(2)に当たる操作ログは区分(2)の期間とする

システム・記録	主なログ種別 (L-xx)	区分	根拠の行番号	設計上の注意
顧客情報へのアクセス記録	L-02、L-04、L-06、L-07	(2)	IN16、ING1、ING8、ING9	監督指針・実務指針はアクセス記録の取得・保存を明記するが、年数はないため、期間は共通の下限による（§ 6.5）。ログに病歴などの機微情報を含めると業務上必要な範囲を超える利用になりうるため、マスキングを検討する（§ 6.4）
契約者向け Web サービスの認証ログ（ログイン・取引時の情報）	L-04、L-07	(1)。不正検知・顧客通知に使うものは (2) とするかを検討	ING2、§ 6.5	監督指針は「事後検証に資する」ログイン・取引時の情報の保存を求めるが、年数の記載はない
システムの開発や変更の記録	L-10	(2)（本書の 7.3）	ING11	監督指針は、保存期間を定めて保管することを求めるが、年数は示していない。業種別調査は区分 (1) の理由の欄でこの行に触れている。本書は 7.3 で L-10 を区分 (2) に含めている
取引時確認（本人確認）の記録（全業種に共通する法令）	L-07	(3)（確認記録）。操作ログは (2) と (3) の遅く満了する方	CM8、CM10、CF7	確認記録は7年で、起算点は取引終了日である。長期の顧客関係では、作成から10年を超えて保存が必要になりうる。特定事業者の一覧に含まれるのは保険会社・少額短期保険業者であり、それ以外の事業者は該当性を確認する（CF7）

表3-3 の行番号は付録 G の行番号である。「区分」の欄のうち、行番号が示す推奨案・判断事項をログ種別に割り当てた部分は、本書の当てはめである。ネットワーク・通信ログ（L-11）とセキュリティ検知ログ（L-12）は、7.3 のとおり区分 (1) として扱う。ログ基盤自身の監査ログ（L-14）は、表7-2 のとおり保護対象ログの最長年限以上とする。区分 (3) の記録への操作ログを、契約の消滅を起算点とする期間まで保存する場合は、表7-2 の定めにより、L-14 もその満了日を下回らないようにする。

- **必須** 3.4 の対応表に、構成要素ごとの区分と起算点を記載すること。区分 (3) に当たるログ種別は、表3-3 を参考に、対象の記録の名称と根拠の行番号（付録 G）を併記すること。
- **必須** 対象システムの利用者が、保険会社（株式会社・相互会社）、特定保険募集人、一般の保険募集人、保険仲立人、金融サービス仲介業者のどれに当たるかを確認し、対応表に記載すること（付録 G の INF5）。
- **必須** 契約に連動する記録とその変更履歴・操作履歴は、契約 ID に紐づけて管理できるようにすること（付録 G の INF1）。

4

AWSサービス対応詳細（1） — 基盤ログの取得・保全

本章は、AWS環境における財務報告関連システムのログ基盤を構成する5つのサービス — AWS CloudTrail、AWS Config、Amazon CloudWatch Logs、Amazon S3、AWS KMS — について、開発ベンダーが実装すべき設定内容と、発注者に提出する設定証跡を定める。これらは L-01（クラウド基盤API操作ログ）、L-02（データアクセスログ）、L-03（構成変更履歴）、L-14（ログ基盤自身の監査ログ）の取得源であると同時に、第5章で扱う L-04～L-13 のすべてのログを受け取り、保全する土台でもある。したがって本章の要求を満たさないまま第5章の個別ログを取得しても、LR-04（改ざん防止と完全性の保証）および LR-05（保存期間とライフサイクル）は成立しない。

本章は「何を、どのサービスで、どう設定し、何を証跡として残すか」に限定する。保存期間の具体値は第7章、改ざん防止の全体設計は第8章、アラート閾値と定期レビュー運用は第9章、ログへのアクセス制御と職務分掌は第10章、アカウント構成は第6章で定める。本章の設定パラメータ表は、それらの章が決定を下すための AWS 側の制約（指定できる値、上限、不可逆な設定）を提供する位置づけである。なお、本章で扱う5サービスはいずれもAWSが提供する外部サービスであり、AWS へ委託している部分は、発注者による外部委託に関する契約の管理（ITGC-D）および LR-13（外部委託と責任分界）の対象である。委託業務に係る内部統制についても発注者の評価範囲に含まれるため、AWS側の統制の確認方法と発注者・開発ベンダー・AWSの責任分界は第2章 LR-13 による。受託会社側の統制の確認方法は発注者が判断する事項であり、特定の様式の保証報告書によることが一律に求められるものではない。

● 補足

本章に記載する AWS の仕様（既定値、上限、モード、選択肢）は、実装時点の公式ドキュメントで再確認すること。特に料金体系、リージョン対応、サービスの提供形態は変更されやすい。設計書には「確認日」と参照した公式ドキュメントの版を記録すること。

用語の区別: 本章では、AWS CloudTrail の設定単位を「証跡（Trail）」と表記し、監査人や発注者に提出する記録を「設定証跡」「運用証跡」と表記して区別する。

4.1 AWS CloudTrail

4.1.1 役割と対応する要求事項

AWS CloudTrail は、AWSアカウント内で行われたAPI操作の記録であり、本ガイドラインにおける最上位のログ源である。誰が（userIdentity）、いつ（eventTime）、どこから（sourceIPAddress）、何に対して（eventSource/resources）、何をしたか（eventName）を記録し、LR-02（記録項目・5W1H）の中核を担う。

- **取得するログ種別:** L-01（管理イベント）、L-02（データイベント）、L-04の一部（コンソールログイン、AssumeRole、IAM操作）、L-14（証跡自身の設定変更・停止・削除）

- **対応する要求事項:** LR-01（対象範囲の特定と網羅性）、LR-02（記録項目）、LR-03（時刻同期とタイムスタンプ。eventTime はUTCで記録される）、LR-04（ログファイル整合性検証）、LR-05（S3ライフサイクルによる保存期間管理）、LR-08（CloudWatch Logs 連携によるアラート）、LR-10（Amazon Athena による検索・抽出）、LR-11（配信の遅延と欠損検知）、LR-12（ログ設定の変更管理）、LR-13（AWS側の統制と責任分界）、LR-14（ログ設計書への記載）
- **対応するIT全般統制の領域:** ITGC-C（内外からのアクセス管理などシステムの安全性の確保）を主とし、ITGC-A（システムの開発、保守に係る管理）およびITGC-B（システムの運用・管理）の実施記録を裏づける（AWS側の統制の扱いは章冒頭の記載と第2章 LR-13 による）

4.1.2 設定要件

- **必須** イベント履歴（Event history）をログの長期保管手段としないこと。イベント履歴は過去90日間の管理イベントをリージョン単位で閲覧・検索できる機能であり、データイベント・Insightsイベント・ネットワークアクティビティイベントは表示されず、組織単位の集約もできず、属性フィルタは1つと時間範囲のみ、1ファイルあたり最大200,000イベントのダウンロードに制限される。90日を超える継続記録には証跡（Trail）を作成すること。
- **必須** 証跡はAWS Organizations の**組織の証跡**として、管理アカウントまたは委任管理者が作成すること。メンバーアカウントには同名の証跡コピーが作成され、メンバーアカウントは閲覧のみ可能で、削除・ログ停止・設定変更ができない。組織にアカウントが追加されると自動的に記録が開始される。
- **必須** マルチリージョン証跡とし、`IncludeGlobalServiceEvents` を true に設定すること。IAM・STS・CloudFront のグローバルサービスイベントは2021年11月22日以降 us-east-1 に記録されるため、単一リージョン証跡ではこれらを取りこぼす。
- **必須** 管理イベントは読み取り（Read）と書き込み（Write）の**両方**を記録すること。表現はイベントセレクトタの方式によって異なり、基本イベントセレクトタでは `ReadWriteType` を `All` とし、高度なイベントセレクトタでは `readOnly` フィールドセレクトタを設定しない。
- **必須** 管理イベントソースを除外しないこと。基本イベントセレクトタでは `ExcludeManagementEventSources` を空とし、高度なイベントセレクトタでは `eventSource` に `NotEquals` 条件（`kms.amazonaws.com / rdsdata.amazonaws.com`）を設定しない。除外設定中に発生したイベントは事後に回復できない。なお、Configルール `multi-region-cloudtrail-enabled` は基本イベントセレクトタの `ExcludeManagementEventSources` を評価するため、高度なイベントセレクトタのみで構成する場合の評価結果を構築時に確認すること。
- **必須** データイベント（LR-02）を明示的に有効化すること。既定では記録されない。財務報告に関連するデータを保持する Amazon S3 バケット、Amazon DynamoDB テーブル、AWS Lambda 関数は必須対象とする。コストを考慮して対象を限定する場合は、高度なイベントセレクトタで `resources.ARN` を `StartsWith` 等により限定し、対象外としたリソースと理由をログ設計書（LR-14）に記載すること。ワイルドカード `*` は使用できない。
- **推奨** Insights イベントを有効化すること。APIコールレートの逸脱検出には書き込み管理イベントが、APIエラーレートの逸脱検出には読み取りまたは書き込み管理イベントが必要である。証跡ではS3の `/CloudTrail-Insight` フォルダに配信され、初回有効化後の配信開始まで最大36時間を要する。追加料金が発生する。
- **任意** ネットワークアクティビティイベント（VPCエンドポイント経由のAPI呼び出し記録）の採否を発注者と協議すること。既定では無効で追加料金が発生する。対象サービスは一般提供開始（2025年2月）後も順次拡大しているため、採否を協議する際は、実装時点の公式ドキュメントで対象サービス（eventSource）と料金を確認すること。

- **必須** S3の配信先はログアーカイブアカウントの専用バケット（4.4節、第6章）とし、SSE-KMS（顧客管理キー）で暗号化すること。KMSキーは配信先S3バケットと**同一リージョン**に作成する必要がある。
- **必須** ログファイル整合性検証を有効化すること。有効化すると各ログファイルのSHA-256ハッシュを含むダイジェストファイルが1時間ごとに CloudTrail-Digest フォルダへ配信され、各ダイジェストは直前のダイジェストの署名を含む連鎖構造となる。署名はSHA-256 with RSA である。
- **必須** 有効化に加え、aws cloudtrail validate-logs を定期的に行い、結果を運用証跡として保存すること（LR-04、LR-09）。有効化しただけでは検証は行われない。実行周期は発注者と合意し、運用手順書に記載すること。
- **必須** CloudWatch Logs への配信を有効化すること（LR-08）。ロググループは証跡と同一アカウント内に必要で、専用のIAMロールを要する。マルチリージョン証跡は全リージョンのイベントを1つのロググループへ送る。
- **必須** StopLogging、DeleteTrail、UpdateTrail、PutEventSelectors を検知対象とすること（L-14）。検知の実装は4.3.2のメトリクスフィルターおよび第9章による。予防的統制としてのAWS Organizationsのサービスコントロールポリシー（SCP）は第10章による。
- **必須** AWSマネージドポリシー AWSCloudTrail_FullAccess の付与先を最小限にすること。同ポリシーの保持者は監査機能を無効化・再設定できる。
- **推奨** 証跡・イベントセクタ・バケットポリシー・キーポリシーはすべて IaC（Infrastructure as Code）で定義し、コンソールでの手動作成を行わないこと。設定変更の申請・承認・適用の追跡（ITGC-A）を成立させるためである。
- **必須** AWS CloudTrail Lake は、発注者が既存利用者でない場合は新規に採用できない。既存利用者である場合も、CloudTrail Lake に依存する構成を新規に採用しないこと（4.1.3 および表4-1参照）。

4.1.3 設計上の注意点

二系統配信の役割分担。 CloudTrail の配信先は、長期保全のためのS3と、検知のためのCloudWatch Logs の2系統に分ける。両者は保存期間・アクセス権・使用目的が異なるため、同一視して片方だけを構成してはならない。

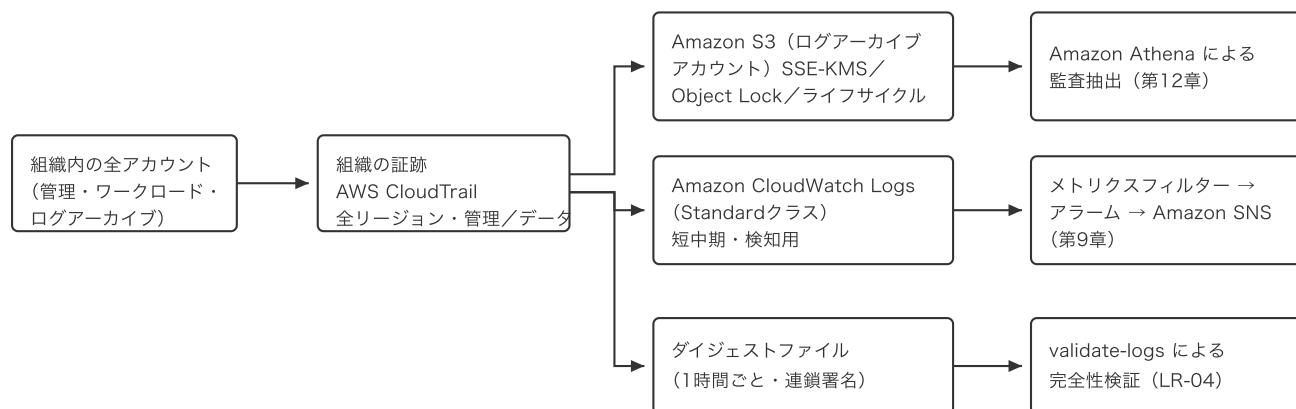


図4-1 CloudTrailの二系統配信（S3＝長期保全、CloudWatch Logs＝検知）と整合性検証

「誰が」を個人まで特定できること。 `userIdentity` は、IAMロールを引き受けた操作ではロールARNとロールセッション名として記録されるため、共有IAMユーザーや個人を識別できないセッション名を使用すると、操作者を個人まで特定できない。AWS IAM Identity Center 等のフェデレーションを用い、ロールセッション名に個人識別子が入る設計とすること。共有IDによる操作は、ログのみでは実施者を個人まで特定できないため、操作内容の文書化と管理者承認、相互監視、事後のログモニタリング等の補完統制を併せて整備しない限り、運用証跡として十分とはいえない（L-04、第10章と整合させること）。

長期保管・検索方式の選択。 本ガイドラインは、S3への長期保全と Amazon Athena による抽出を基本構成とする。AWS CloudTrail Lake は2026年5月31日以降、新規顧客への提供が行われない（既存顧客は継続利用可能で、組織イベントデータストアであれば新規メンバーアカウントも取り込まれる）。発注者が既存利用者でない限り新規採用はできず、既存利用者であっても Lake は重要なバグ修正とセキュリティ更新のみを受けるため、本ガイドラインでは Lake に依存しない構成を基本とする。

表4-1 CloudTrailログの長期保管・検索方式の比較

方式	保持期間の決め方	検索手段	本書での位置づけ
証跡 → Amazon S3 + Amazon Athena	S3ライフサイクルで任意に設計（第7章）	SQL（パーティション射影を推奨）	必須 基本構成。長期保全と監査抽出の正
証跡 → Amazon CloudWatch Logs	retentionInDays の列挙値から選択	メトリクスフィルター、Logs Insights	必須 検知・直近調査用。長期保管の主要手段としない
AWS CloudTrail Lake	1年延長可能保持: 既定366日／最大3,653日。7年保持: 既定・最大とも2,557日	SQL（SELECT 構文のサブセット）	2026年5月31日以降、新規顧客への提供が行われない（既存顧客は継続利用可能）。本書では Lake に依存しない構成を基本とする

組織の証跡に固有の落とし穴。 組織の証跡は、バケットポリシーの誤りなどリソース検証に失敗した場合でもメンバーアカウントに作成される。作成されたことをもって配信されていると判断してはならない。構築時および定期レビュー時に `get-trail-status` で配信エラーの有無を確認すること。また、管理アカウントが管理アカウントでなくなると組織の証跡は非組織証跡となる。この事象に備え、バケットポリシーには組織ID配下と管理アカウントID配下の双方への書き込み許可が必要である（4.4.2）。組織から除外されたアカウントの除外前のログはバケットに残る。

重複記録と課金。 同一リージョンで管理イベントを重複して記録する2本目以降の証跡は課金対象となる（組織の証跡とメンバーアカウント独自の証跡が併存する場合を含む）。既存アカウントを組織に取り込む際は、既存証跡の要否を整理し、統合または削除の判断と理由を記録すること。証跡のクォータはリージョンあたり5で、引き上げできない。

配信の遅延と欠損検知。 ログファイルは約5分ごとに複数回発行され、通常はAPI呼び出しから平均約5分以内に配信されるが、配信時間は保証されない。S3のログ比較では、データイベントは5分ごと、管理イベントは15分ごとの配信と説明されている。LR-11（バックアップ・可用性・欠損検知）に対しては、リアルタイム性ではなく「日次でオブジェクトが到着していること」を確認する監視として設計すること。

整合性検証の制約。 `validate-logs` は、CloudTrail が配信した元の場所から移動していないファイルのみを検証できる。ローカルにダウンロードしたファイルは検証できず、ダイジェストに参照されないファイルは検証対象外となる。`--region` の指定が必要で、組織の証跡では `--account-id` が必須である。監査人へ提出するのは「バケット上のファイルを対象に検証した結果」であり、抽出済みファイルの検証結果ではないことに留意すること。

● 注意

CloudTrail のログ配信先バケットに S3 Object Lock（コンプライアンスモード）を適用することは、AWS が公表するログ保全のプラクティスとして案内されている。ただし既定の保持期間の値は事後に変更・短縮ができないため、本番適用前に検証環境で配信テストを行い、配信成功と保持期限の付与を証跡として残すこと（4.4.2、4.4.3参照）。

● 監査の視点

監査人は「評価対象期間を通じてログが欠落なく取得されていたこと」を確かめる。証跡が現在有効であることの証明だけでは足りない。評価対象期間（評価時点は期末日。対象期間は発注者が監査人と協議して定める）について、証跡の作成日時、`IsLogging` の状態、配信エラーの発生有無、整合性検証の実行結果、および期間中に `UpdateTrail` / `PutEventSelectors` が実行されていないこと（実行されていた場合はその承認記録）をセットで提示できるよう設計すること。なお、期中に運用状況の評価を実施した場合、期末日までの重要な変更については追加手続が検討される（実施基準Ⅱ.3(3)④ハ）。

4.1.4 設定パラメータ

表4-2 AWS CloudTrail 設定パラメータ

パラメータ	推奨値	レベル	備考
証跡の種別	組織の証跡	必須	管理アカウントまたは委任管理者が作成。メンバーは停止・削除・変更不可
IsMultiRegionTrail	true	必須	コンソールで作成する証跡はすべてマルチリージョン
IncludeGlobalServiceEvents	true	必須	IAM・STS・CloudFront は us-east-1 に記録
管理イベントの記録範囲	読み取り・書き込みの両方	必須	基本セクタでは ReadWriteType: All、高度なイベントセクタでは readOnly フィールドセクタを設定しない
管理イベントソースの除外	除外しない	必須	基本セクタでは ExcludeManagementEventSources を空、高度なイベントセクタでは eventSource の NotEquals 条件を設定しない。multi-region-cloudtrail-enabled は基本セクタの同項目を評価する
データイベント	財務報告関連のS3バケット・DynamoDBテーブル・Lambda関数を対象に有効化	必須	既定は無効・追加料金。高度なイベントセクタで範囲を限定
イベントセクタの方式	高度なイベントセクタ	推奨	基本と高度は併用不可（高度を適用すると基本は上書き）。方式により上記2項目の表現が変わる
Insights イベント	APIコールレートおよびAPIエラーレート	推奨	追加料金。初回配信開始まで最大36時間
ネットワークアクティビティイベント	発注者と協議のうえ決定	任意	既定無効・追加料金
S3配信先	ログアーカイブアカウントの専用バケット	必須	Requester Pays バケットは使用不可
S3配信の暗号化	SSE-KMS（ログ用顧客管理キー）	必須	キーは配信先バケットと同一リージョン
LogFileValidationEnabled	true	必須	ダイジェストは1時間ごとに別フォルダへ配信
CloudWatch Logs 配信	有効（Standardクラスのロググループ）	必須	CloudTrailは256KBを超えるイベントをCloudWatch Logs／EventBridgeへ送信しない（CloudWatch Logs自体のイベントサイズ上限1,024 KBとは別の制限。4.3.3参照）
証跡の本数	用途別に最小限	推奨	リージョンあたり5（引き上げ不可）。重複記録は課金対象

4.1.5 提出する設定証跡

次のコマンドの標準出力を証跡とし（describe-trails・get-trail-status・get-event-selectors・get-insight-selectors はJSON、validate-logs はテキスト形式）、それぞれに取得日時、実行者、対象アカウントID、対象リージョンを付して提出すること。加えて、証跡をIaCで定義している場合は、そのファイルのパスと

レビュー済みコミットIDを記載すること。IaCを用いない場合は、コンソール操作の申請・承認記録を証跡として提出すること。

```
# 証跡の定義（シャドウトレイルを含む）
aws cloudtrail describe-trails --include-shadow-trails --region <region>

# 記録状態と配信エラーの有無（IsLogging / LatestDeliveryError /
# LatestDeliveryTime / LatestDigestDeliveryError を確認）
aws cloudtrail get-trail-status --name <trail-arn> --region <region>

# 管理イベント・データイベントのセレクト定義
aws cloudtrail get-event-selectors --trail-name <trail-arn> --region <region>
aws cloudtrail get-insight-selectors --trail-name <trail-arn> --region <region>

# ログファイル整合性検証（時刻はUTC。組織の証跡は --account-id が必須）
aws cloudtrail validate-logs \
  --trail-arn <trail-arn> \
  --start-time 2026-04-01T00:00:00Z \
  --end-time 2026-06-30T23:59:59Z \
  --account-id <member-account-id> \
  --region <region> --verbose
```

- マネジメントコンソールの証跡詳細画面（証跡名、マルチリージョン、組織の証跡、ログファイル検証、S3バケット、KMSキー、CloudWatch Logs のロググループが1画面で確認できるもの）
- データイベント対象リソースの一覧と、対象外としたリソースおよびその理由（ログ設計書の該当節）
- 整合性検証の実行記録（実行日時、対象期間、対象アカウント、結果件数、**INVALID** が出た場合の調査記録）

4.2 AWS Config

4.2.1 役割と対応する要求事項

AWS Config は、AWSリソースの構成を設定項目（Configuration Item、CI）として時系列に記録し、「変更の前後で構成がどう変わったか」を提供する。「誰が・いつ・どのAPIで変更したか」は CloudTrail が記録するため、変更管理（ITGC-A）の証跡は**両者の突合**によって成立する。承認記録そのものはAWS外の変更管理プロセス（第5章 L-10、第11章）に依存する。

- **取得するログ種別:** L-03（構成変更履歴）、L-14（Configレコーダー・配信チャンネル自身の変更）
- **対応する要求事項:** LR-01（記録対象リソースの網羅性）、LR-05（CI保持期間）、LR-09（Configルール評価結果を定期レビューの入力とする）、LR-10（高度なクエリによる抽出）、LR-12（ログ設定の逸脱検知）、LR-13（AWS側の統制と責任分界）
- **対応するIT全般統制の領域:** ITGC-A、ITGC-B、ITGC-C（AWS 側の統制の扱いは章冒頭の記載と第2章 LR-13 による）

4.2.2 設定要件

- **必須** 全アカウント・使用する全リージョンで設定レコーダーを有効化すること。顧客管理レコーダーはアカウント・リージョンあたり1つである。
- **必須** 記録対象は全サポートリソースタイプとすること。記録対象外のリソースは作成・削除のみが捕捉され構成の詳細が残らないため、財務報告に関連するリソースを対象外にしてはならない。

- 必須** グローバルIAMリソース（AWS::IAM::Group / Policy / Role / User）は、重複するCIの生成を避けるため1つのリージョンでのみ記録すること。ただしグローバルIAMリソースを記録できるのは、2022年2月以前にAWS Config が提供されていたリージョンに限られる。2022年2月以降に対応が追加されたグローバルリソースはホームリージョンでのみ記録される。記録リージョンをログ設計書に明記すること。
- 必須** 記録頻度は Continuous（変更のたびに記録）を既定とすること。Daily は24時間の時点で最新状態が前回と異なる場合にのみCIを生成するため、期中の中間状態を追えない。Daily を採用する場合は対象リソースと理由を記録し、発注者の承認を得ること。
- 必須** 配信チャンネル（アカウント・リージョンあたり1つ、必須）のS3配信先をログアーカイブアカウントのバケットとすること。既定の暗号化はSSE-S3であるため、KMSキーを明示的に指定すること。
- 必須** 設定スナップショットの配信頻度 `deliveryFrequency` を明示的に設定すること。これはAWS側で必須とされる項目ではないが、本ガイドラインでは受入条件として明示設定を求める。有効値は `One_Hour` / `Three_Hours` / `Six_Hours` / `Twelve_Hours` / `TwentyFour_Hours` であり、値は第7章の保存期間設計および第9章のレビュー周期と整合させて発注者と協議のうえ決定すること。設定履歴ファイルはリソースタイプごとに6時間ごとにS3へ配信され、変更がなければ配信されない。
- 必須** CIの保持期間を明示設定すること。設定可能範囲は30日～2,557日、既定は2,557日（7年）である。第7章で定める保存期間に一致させること。この保持期間はAWS Config 自身のデータストアに対するものであり、S3およびSNSに配信されたデータの保持は別管理である。記録中のリソースの現在の状態は保持期限に関係なく削除されない。
- 必須** 表4-4のうち **必須** と表記したマネージドルールを全アカウント・全使用リージョンに展開すること。
推奨 と表記したものは合理的理由なく省略しないこと。適用対象を限定するルールは、備考欄に示す範囲および限定方法に従うこと。
- 推奨** ルールの展開はコンフォーマンスパックによること。Operational Best Practices for Logging、Security Best Practices for AWS CloudTrail、Operational Best Practices for Amazon S3 等のサンプルテンプレートを基に、発注者承認版のパックを作成すること。サンプルテンプレートは特定の規制への準拠を保証しない旨が明記されている点に留意すること。
- 推奨** 組織全体のアグリゲータを作成し、レビュー・監査用アカウントから参照できるようにすること。アグリゲータは読み取り専用ビューで追加料金はなく、AWS Organizations をソースとする場合は各アカウントの承認を要しない。ルールの配布やスナップショットの送信はできない。
- 必須** レコーダーの停止・削除、配信チャンネルの変更を検知すること（L-14）。リソースタイプ `AWS::Config::ConfigurationRecorder` を記録することでレコーダー自身の変更を追跡でき、追加料金は発生しない。あわせて4.3.2のメトリクスフィルターを設定すること。

4.2.3 設計上の注意点

Object Lock との非互換。 AWS Config は、既定の保持設定を有効化した Object Lock バケットを配信チャンネルの宛先としてサポートしない。したがって Config 用の配信先バケットは、CloudTrail 用バケットと分離し、既定保持期間を設定しない構成とすること。改ざん防止は、Object Lock を有効化したうえで既定保持を用いず、オブジェクト単位の保持期間またはリーガルホールドを付与する方式で代替する案を発注者と協議すること。ただしこの代替案は公式ドキュメントに構成例が示されたパターンではないため、構築時に検証し、検証結果を証拠として残すこと（4.4.3参照）。

サービスリンク設定レコーダーの併存。 2024年11月27日以降、AWS Config はサービスリンク設定レコーダーをサポートする。これらは常時記録で直接変更できない。顧客管理レコーダーとの併存状況をログ設計書に記載し、どちらがどのリソースを記録しているかを明確にすること。

高度なクエリの制約。 高度なクエリは SQL の `SELECT` のサブセットであり、`JOIN`、`DISTINCT`、`HAVING`、`UNION` は使用できない。削除済みリソースおよび記録対象外リソースはクエリできず、`SELECT *` は上位のスカラー属性のみを返す。監査用の抽出では `get-resource-config-history` と併用すること（第12章）。

コストの見積り。 記録頻度の選択はコストに影響するが、単価は継続記録CIより定期記録CIのほうが高い（取得時点のバージニア北部の価格ページで、継続記録CIが\$0.003、定期記録CIが\$0.012）。したがって「コスト削減のためDaily」という判断は成立しない場合がある。生成されるCI数を含めて試算し、実装時点の価格ページで単価を確認すること。

● 監査の視点

変更管理の運用評価では、基本的に、変更依頼どおりにリソースが変更されたかについて承認及び導入前の試験が適切に行われているかが確認される（実施基準III.4(2)②ロa）。その際、監査人は変更依頼又は変更されたリソースのいずれかからサンプルを抽出し、それがどのような手続で依頼・承認されたものかを確認する（双方が必ず求められるものではなく、状況に応じて適切な手続が選択される）。AWS Config の構成履歴は「何がいつ変わったか」を、CloudTrail は「誰がどのAPIで変えたか」を提供するが、「承認されていたか」はAWS外の記録との突合でしか示せない。開発ベンダーは、Config／CloudTrailの記録と変更管理チケットを対応づける鍵（変更ID、リクエストID、コミットID等をタグや実行パラメータに持たせる等）を設計段階で定義すること。この鍵はいずれの抽出方向にも対応できる必要がある。

4.2.4 設定パラメータ

表4-3 AWS Config 設定パラメータ

パラメータ	推奨値	レベル	備考
設定レコーダー	全アカウント・全使用リージョンで有効	必須	顧客管理レコーダーはアカウント・リージョンあたり1つ
記録対象リソースタイプ	全サポートリソースタイプ	必須	対象外リソースは作成・削除のみ捕捉
グローバルIAMリソースの記録	1リージョンのみで記録	必須	記録可能なリージョンに制限あり。記録リージョンを設計書に明記
AWS::Config::ConfigurationRecorder の記録	有効	必須	レコーダー自身の停止・削除を追跡。追加料金なし
記録頻度	Continuous	必須	Daily 採用時は対象と理由を記録し発注者承認を得る
配信チャネル (S3)	ログアーカイブアカウントのConfig専用バケット	必須	既定保持設定つき Object Lock バケットは使用不可
配信チャネルの暗号化	SSE-KMS（ログ用顧客管理キー）	必須	既定は SSE-S3
deliveryFrequency	明示設定（値は第7章の保存期間設計および第9章のレビュー周期と整合させる）	必須	AWS側では配信チャネルの必須項目ではないが、本書では受入条件として明示設定を求める。定期ルールは deliveryFrequency と MaximumExecutionFrequency の短いほうで実行
CI保持期間	第7章で定める保存期間に一致させる	必須	30～2,557日（既定2,557日）。S3・SNS側の保持は別管理
アグリゲータ	組織全体を対象に作成	推奨	読み取り専用、追加料金なし。ルール配布は不可
コンフォーマンスパック	発注者承認版を作成し全アカウントへ展開	推奨	サンプルは特定の規制準拠を保証しない
SNSトピック（設定ストリーム）	設定変更通知を有効化	任意	通知量が多いため、通知先と絞り込み方針を第9章と整合させる

表4-4に、ログ統制上、開発ベンダーが展開すべきAWS Configマネージドルールを示す。ルール名は識別名（コンソール表示名）であり、ルール識別子とは異なる場合がある（例: multi-region-cloudtrail-enabled の識別子は MULTI_REGION_CLOUD_TRAIL_ENABLED）。

表4-4 ログ統制上展開するAWS Configマネージドルール

ルール名	目的（対応する要求事項）	レベル	備考
cloudtrail-enabled	証跡が存在すること（LR-01）	必須	定期トリガー
multi-region-cloudtrail-enabled	全リージョン記録・管理イベント設定・除外なしの担保（LR-01、LR-12）	必須	基本イベントセクタの ExcludeManagementEventSources を評価する。高度なイベントセクタのみで構成する場合の評価結果を構築時に確認すること
cloud-trail-log-file-validation-enabled	ログファイル整合性検証の有効化（LR-04）	必須	有効化の確認のみ。検証の実行は 4.1.2 による
cloud-trail-encryption-enabled	証跡のSSE-KMS暗号化（LR-07）	必須	キーは配信先バケットと同一リージョン
cloud-trail-cloud-watch-logs-enabled	アラート基盤への配信（LR-08）	必須	検知システムの構成漏れを検出する
cloudtrail-s3-dataevents-enabled	S3データイベントの取得（L-02）	必須	S3BucketNames パラメータに、データイベント取得対象と定めた財務報告関連バケットのみをカンマ区切りで指定すること。未指定の場合はアカウント内の全S3バケットが評価対象となり、4.1.2 で認めるスコープ限定と矛盾する。定期トリガーで評価され、データイベント設定の変更を検知する
s3-bucket-versioning-enabled	アーカイブバケットのバージョンニング（LR-04）	必須	Object Lock の前提条件
s3-bucket-ssl-requests-only	TLS強制（LR-07）	必須	バケットポリシーの Deny 文と対応
s3-default-encryption-kms	既定暗号化のSSE-KMS化（LR-07）	必須	適用対象は CloudTrail用、AWS Config用、CloudWatch Logs（Amazon Data Firehose 経由）用のアーカイブバケット。サーバーアクセスログ用バケットは S3 の仕様上 SSE-S3 のみが利用可能であるため適用対象外とする（4.4.3）。本ルールにはバケット名で対象を絞るパラメータがなく全 AWS::S3::Bucket を評価するため、ルールのスコープ（リソースIDまたはタグキー）で対象を限定するか、対象外バケットの NON_COMPLIANT を例外として記録・承認すること
s3-bucket-public-read-prohibited / s3-bucket-public-write-prohibited	ログの公開防止（LR-06）	必須	アカウントレベルのパブリックアクセスブロックと併用

ルール名	目的（対応する要求事項）	レベル	備考
cloudwatch-log-group-encrypted	ロググループのKMS暗号化（LR-07）	必須	対称キーのみ対応
cw-loggroup-retention-period-check	ロググループ保持期間の下限確認（LR-05）	必須	MinRetentionTime に指定できる値は retentionInDays の列挙値と一致せず、1, 3, 5, 7, 14, 30, 60, 90, 120, 150, 180, 365, 400, 545, 731, 1827, 3653 に限られる（2192・2557・2922・3288等は指定できない）。保存期間を2557日とする場合、本ルールでは下限を1827日として評価し、2557日の設定確認は describe-log-groups による定期棚卸で補うこと
cmk-backing-key-rotation-enabled	ログ用CMKの自動ローテーション（LR-07）	必須	対象は対称暗号化キー
kms-cmk-not-scheduled-for-deletion	ログ用CMKの削除予約の検出（LR-04）	必須	4.5.2の検知と併用する
s3-bucket-default-lock-enabled	Object Lock 既定保持の設定確認（LR-04）	必須 （適用対象のバケットに限る）	適用対象は CloudTrail用および CloudWatch Logs（Amazon Data Firehose 経由）用アーカイブバケットとし、いずれも 4.1.3・4.4.3の配信検証の完了をもって適用する（4.4.2）。AWS Config用バケットとサーバーアクセスログ用バケットは 4.4.3のとおりサービス側の制約により適用対象外とする。本ルールにはバケット名を絞るパラメータがなく（任意パラメータは mode のみ）、設定変更トリガーで全 AWS::S3::Bucket を評価するため、AWS Config ルールのスコープ（リソースIDまたはタグキー）で対象バケットを限定するか、mode パラメータに COMPLIANCE を指定したうえで対象外バケットの NON_COMPLIANT を例外として記録・承認すること
s3-bucket-logging-enabled	アーカイブバケットへのアクセス記録（L-14）	必須	ライフサイクルによる削除・移行はCloudTrailのオブジェクトレベルログに記録されないため、LR-05の運用証跡としてアーカイブバケットのサーバーアクセスログ取得が必須である（4.4.3）
vpc-flow-logs-enabled / rds-logging-enabled / guardduty-enabled / centralized / securityhub-enabled	第5章で定める L-06・L-11・L-12 の取得確認（展開範囲は第5章の要求による）	推奨	最終的な要求レベルと対象範囲は第5章による（本表では表4-4の展開対象に含めることを示す）

● 注意

cw-loggroup-retention-period-check は、保持期間が「Never expire（無期限）」のロググループを COMPLIANT と判定する（既定の MinRetentionTime は365日）。したがって、このルールだけでは「保持期間が未設定のロググループ」を検出できない。無期限保持の検出は、describe-log-groups の出力に retentionInDays が存在しないロググループを抽出する定期棚卸で補うこと（4.3.3、第9章）。

4.2.5 提出する設定証跡

```
# レコーダーと記録状態
aws configservice describe-configuration-recorders --region <region>
aws configservice describe-configuration-recorder-status --region <region>

# 配信チャネルと配信状態（S3バケット・KMSキー・配信頻度）
aws configservice describe-delivery-channels --region <region>
aws configservice describe-delivery-channel-status --region <region>

# 設定項目の保持期間
aws configservice describe-retention-configurations --region <region>

# アグリゲータ、ルール、コンフォーマンスパックの適用状況
aws configservice describe-configuration-aggregators --region <region>
aws configservice describe-config-rules --region <region>
aws configservice describe-compliance-by-config-rule --region <region>
aws configservice describe-conformance-pack-status --region <region>

# 個別リソースの構成履歴（監査抽出のサンプル）
aws configservice get-resource-config-history \
  --resource-type AWS::S3::Bucket --resource-id <bucket-name> --region <region>
```

- グローバルIAMリソースを記録するリージョンの指定と、その理由を記載したログ設計書の該当節
- コンフォーマンスパックのテンプレート（laCファイル）と、発注者の承認記録
- 適用対象を限定したルール（cloudtrail-s3-dataevents-enabled、s3-bucket-default-lock-enabled等）のパラメータおよびスコープ設定と、限定した理由
- ルール評価結果のうち NON_COMPLIANT となった項目の一覧と是正記録（LR-09、第9章）

4.3 Amazon CloudWatch Logs

4.3.1 役割と対応する要求事項

Amazon CloudWatch Logs は、本ガイドラインにおいて2つの役割を持つ。第一に、AWSの各サービスおよびアプリケーションが出力するログの受け口であり、第5章で扱う L-04～L-09、L-13 の多くがここに集約される。第二に、メトリクスフィルタとアラームによる検知基盤（LR-08）である。長期保管の主体はS3であり、CloudWatch Logs は「検知と直近の調査のための短中期保持」と位置づける。

- **取得・受領するログ種別:** L-01（検知用のコピー）、L-04～L-09、L-13の受け皿、L-14（ロググループ設定の変更）
- **対応する要求事項:** LR-02、LR-05（保持期間の明示設定）、LR-06（ロググループ単位のアクセス制御）、LR-07（KMS暗号化・データ保護ポリシー）、LR-08（メトリクスフィルタとアラーム）、LR-10（Logs Insights）、LR-11（欠損検知）、LR-12（ログ設定の変更管理）、LR-13（AWS側の統制と責任分界）
- **対応するIT全般統制の領域:** ITGC-B、ITGC-C（AWS 側の統制の扱いは章冒頭の記載と第2章 LR-13 による）

4.3.2 設定要件

- **必須** ロググループの命名規則を定め、ログ設計書に記載すること。AWSサービスが名称を自動生成するもの（例: RDS のログ発行先）や、名称に接頭辞の制約があるもの（第5章参照）はそれに従い、開発ベンダーが作成するロググループは「システムID／環境／コンポーネント／ログ種別」のように、対象システムと環境が名称だけで識別できる規則とすること。

- **必須** すべてのロググループに保持期間を明示的に設定すること。**既定ではログデータは無期限に保持される。** `retentionInDays` は任意の日数を指定できず、次の列挙値から選択する: 1, 3, 5, 7, 14, 30, 60, 90, 120, 150, 180, 365, 400, 545, 731, 1096, 1827, 2192, 2557, 2922, 3288, 3653。第7章で定める保存期間に最も近い値（下回らない値）を選択すること。
- **必須** ログ用の顧客管理KMSキーでロググループを暗号化すること。CloudWatch Logs は対称キーのみをサポートし、関連付けはロググループ単位である。既存ロググループへの関連付けはコンソールから実施できないためCLI/APIで行う。反映まで最大5分を要する。
- **必須** ログクラスを設計時に決定すること。**作成後にクラスを変更できない。** CloudTrail の配信先など、メトリクスフィルターまたはサブスクリプションフィルターを設定するロググループは Standard クラスとすること（表4-5）。
- **必須** ログ基盤自身の重要操作（L-14）に対してメトリクスフィルターとアラームを設定すること。メトリクスフィルターは**作成後に取り込まれたデータのみを対象とし、遡及しない。** ロググループあたり100個までである。AWS Security Hub CSPM が提供するセキュリティ標準のコントロール（コントロールID CloudWatch.5 / .7 / .8 / .9）に適合させる場合、フィルターパターンに追加のフィールドや語句を加えるとコントロール判定に失敗するため、採用する標準の公式表記を、空白を含めて一字一句そのまま転記し、転記元の版と取得日を設計書に記録すること。本章の対象サービスに関係する主なパターンを次に示す。

```
# CloudTrail の設定変更 (CloudWatch.5)
{($.eventName=CreateTrail) || ($.eventName=UpdateTrail) || ($.eventName=DeleteTrail) ||
 ($.eventName=StartLogging) || ($.eventName=StopLogging)}
```

```
# AWS Config の設定変更 (CloudWatch.9)
{($.eventSource=config.amazonaws.com) && (($.eventName=StopConfigurationRecorder) ||
 ($.eventName=DeleteDeliveryChannel) || ($.eventName=PutDeliveryChannel) ||
 ($.eventName=PutConfigurationRecorder))}
```

```
# CMK の無効化・削除予約 (CloudWatch.7)
{($.eventSource=kms.amazonaws.com) && (($.eventName=DisableKey) || ($.eventName=ScheduleKeyDeletion))}
```

```
# S3 バケットポリシー等の変更 (CloudWatch.8)
{($.eventSource=s3.amazonaws.com) && (($.eventName=PutBucketAcl) || ($.eventName=PutBucketPolicy) ||
 ($.eventName=PutBucketCors) || ($.eventName=PutBucketLifecycle) || ($.eventName=PutBucketReplication) ||
 ($.eventName=DeleteBucketPolicy) || ($.eventName=DeleteBucketCors) || ($.eventName=DeleteBucketLifecycle)
 || ($.eventName=DeleteBucketReplication))}
```

で始まる行は説明のための注記であり、実際のフィルターパターンには含めないこと。

上記のコントロール準拠パターン（CloudWatch.5）には `PutEventSelectors` が含まれない。4.1.2 が必須とする証跡の設定変更検知を満たすため、コントロール判定用のメトリクスフィルターには一切手を加えず、次のような発注者独自のメトリクスフィルターを**別に**追加すること。

```
# 証跡 (Trail) のイベントセレクト変更 (発注者独自のパターン)
{($.eventSource=cloudtrail.amazonaws.com) && (($.eventName=PutEventSelectors) ||
 ($.eventName=PutInsightSelectors))}
```

- **必須** 長期保管は、サブスクリプションフィルターから Amazon Data Firehose を経由してS3へ配信する構成とすること。S3エクスポート機能は継続的なアーカイブ用途には推奨されておらず、ログデータがエクスポート可能になるまで最大12時間、タスクは24時間でタイムアウトし、同時実行タスクはアカウントあたり1つ、ファイル内の時系列順も保証されない。サブスクリプションフィルターはロググループあたり最大5、アカウントレベルはリージョンあたり1つで、再試行可能なエラーは最大24時間再試行される。

- **推奨** データ保護ポリシーを設定し、認証情報・個人情報等をマスクすること（LR-07）。アカウントレベルとロググループレベルの双方を設定でき、両方が適用される。**ポリシー設定前に取り込まれたイベントはマスクされない。** マスク解除には `logs:Unmask` 権限が必要であり、付与先を限定すること（第10章）。ポリシーの上限は30,720文字である。
- **推奨** 監査対象のロググループに削除保護を設定すること。既定では無効である。
- **推奨** クロスアカウント観測性により、モニタリングアカウントから各アカウントのロググループを横断的に照会できるようにすること（第6章）。ログ・メトリクスの共有に追加料金はかからない。
- **必須** ロググループの削除、保持期間の変更、暗号化設定の変更を検知対象とすること（L-14）。予防的統制としてのSCPIは第10章による。

保持期間および削除保護は次のコマンドで設定する。`put-log-group-deletion-protection` が受け取るパラメータは `--log-group-identifier` であり `--log-group-name` ではない。解除は `--no-deletion-protection-enabled` による。

```
# 保持期間の設定（列挙値のみ指定可）
aws logs put-retention-policy --log-group-name <name> --retention-in-days 2557 --region <region>

# 削除保護の有効化
aws logs put-log-group-deletion-protection --log-group-identifier <name> \
  --deletion-protection-enabled --region <region>
```

● 注意

AWS Security Hub CSPM が提供するセキュリティ標準のうち、本章が用いるメトリクスフィルター系コントロール（CloudWatch.5／.7／.8／.9）が自動チェックされるのは同標準の v1.2.0 および v1.4.0 であり、v3.0.0 および v5.0.0 では「手動チェック」として扱われる（CloudWatch.2／.3 は v1.4.0 でも手動チェックである）。採用する標準のバージョンによって自動評価の可否が変わるが、**これらのメトリクスフィルターは発注者の要求事項であり、Security Hub CSPM の判定結果にかかわらず実装すること。**

4.3.3 設計上の注意点

ログクラスの選択は不可逆である。 Standard と Infrequent Access（IA）の料金差は取り込み単価のみで、保存料金と Logs Insights のスキャン料金は同額である。IA ではメトリクスフィルター、サブスクリプションフィルター、Live Tail、異常検知、`GetLogEvents`／`FilterLogEvents` が使用できない。すなわち IA のロググループは、本ガイドラインが必須とするサブスクリプションフィルター経由の長期保管も、アラームの発報もできない（S3エクスポート機能自体は IA でも利用できるが、4.3.2 のとおり継続的なアーカイブ手段としては採用しない）。検知対象・転送対象のロググループは必ず Standard とすること。

表4-5 CloudWatch Logs のログクラスの使い分け

項目	Standard	Infrequent Access
想定用途	検知対象ログ、S3へ転送するログ	事後調査のみを想定するログ
メトリクスフィルター	可	不可
サブスクリプションフィルター（S3転送）	可	不可
S3エクスポート	可（本書では継続的なアーカイブ手段として使用しない）	可（同左）
Logs Insights	可	可（ <code>pattern</code> / <code>diff</code> / <code>unmask</code> を除く）
KMS暗号化・データ保護ポリシー	可	可
作成後のクラス変更	不可	不可

保持期間の設定漏れは検出されにくい。 既定が無期限であること、`cw-loggroup-retention-period-check` が「Never expire」を COMPLIANT と判定すること、および同ルール `MinRetentionTime` に指定できる値が `retentionInDays` の列挙値と一致しないこと（表4-4備考）により、保持期間未設定のロググループは統制の網を抜けやすい。`describe-log-groups` の出力から `retentionInDays` を持たないロググループを抽出する棚卸を定期レビュー（LR-09）の手順に組み込むこと。なお、保持期限に到達したデータの削除には通常最大72時間を要する（削除待ちデータは課金対象外）。

投入時刻の制約。 イベントの最大サイズは1,024 KB、1回のバッチは1 MBまたは10,000イベントが上限である。**14日より古いイベントおよび2時間より未来のイベントは拒否される。** バッチ処理の遅延投入やタイムスタンプの誤りにより、ログが欠落する可能性がある。第5章の L-08（ジョブ・バッチ実行ログ）およびアプリケーションログの設計では、この制約を前提に投入経路を設計し、拒否件数を監視すること（LR-11）。

Logs Insights の結果は保全されない。 クエリ結果は7日間しか保持されず、クエリは60分でタイムアウトする。対象は2018年11月5日以降のデータである。監査人への提出物とする場合は、結果をCSV等に出力して保全すること（第12章）。

集約は遡及しない。 CloudWatch Logs のクロスアカウント・クロスリージョンのログ集約機能（AWS Organizations を前提とする）は、集約ルールの作成後に発生した新規ログのみを複製する。既存ログは複製されないため、集約構成の変更時期を記録し、期首から期末までの網羅性を別途説明できるようにすること。

4.3.4 設定パラメータ

表4-6 Amazon CloudWatch Logs 設定パラメータ

パラメータ	推奨値	レベル	備考
ロググループ命名	命名規則を定義し設計書に記載	必須	サービスが名称を強制する場合はそれに従う
retentionInDays	第7章で定める保存期間を下回らない列挙値（例: 1827／2557／3653）	必須	既定は無期限。任意の日数は指定できない
kmsKeyId	ログ用顧客管理キー	必須	対称キーのみ。既存ロググループはCLI/APIで関連付け
logGroupClass	検知・転送対象は Standard	必須	作成後に変更できない
削除保護	有効	推奨	既定は無効。設定は <code>--log-group-identifier</code> を用いる。有効時の削除は <code>ValidationException</code> となる
メトリクスフィルター	4.3.2 のパターンを公式表記のまま設定	必須	遡及しない。ロググループあたり100個まで。コントロール判定用パターンに追加のフィールドや語句を加えないこと
サブスクリプションフィルター	Amazon Data Firehose 経由で S3へ配信	必須	ロググループあたり5、アカウントレベルはリージョンあたり1
S3エクスポート	継続的なアーカイブ手段として使用しない	必須	臨時の抽出用途に限る。IAクラスでも利用可能
データ保護ポリシー	アカウントレベルとロググループレベルの併用	推奨	設定前のイベントはマスクされない。上限30,720文字
クロスアカウント観測性	モニタリングアカウントに集約	推奨	共有に追加料金なし

4.3.5 提出する設定証跡

```
# ロググループ一覧 (retentionInDays / kmsKeyId / logGroupClass /
# 削除保護の状態を確認)
aws logs describe-log-groups --region <region>

# メトリクスフィルターとサブスクリプションフィルター
aws logs describe-metric-filters --log-group-name <name> --region <region>
aws logs describe-subscription-filters --log-group-name <name> --region <region>

# アラーム定義
aws cloudwatch describe-alarms --region <region>
```

- 保持期間未設定（`retentionInDays` が存在しない）のロググループが0件であることを示す棚卸結果
- データ保護ポリシーの定義内容（IaCファイル）と、`logs:Unmask` 権限の付与先一覧（第10章と整合させること）
- メトリクスフィルターとアラームの対応表（フィルター名、パターン、メトリクス、閾値、通知先。閾値と通知運用は第9章）。コントロール判定用パターンと発注者独自パターンを区別して記載すること

4.4 Amazon S3（ログアーカイブ）

4.4.1 役割と対応する要求事項

Amazon S3 は、すべてのログの最終的な保全先である。LR-04（改ざん防止と完全性の保証）と LR-05（保存期間とライフサイクル）は、主としてS3のバージョニング、Object Lock、ライフサイクル、バケットポリシー、暗号化の組み合わせで実現する。

- **保全するログ種別:** L-01～L-13の長期保管先、L-14（アーカイブバケット自身へのアクセスと設定変更）
- **対応する要求事項:** LR-04、LR-05、LR-06、LR-07、LR-10、LR-11、LR-12、LR-13（AWS側の統制と責任分界）、LR-14
- **対応するIT全般統制の領域:** ITGC-B、ITGC-C（AWS 側の統制の扱いは章冒頭の記載と第2章 LR-13 による）

4.4.2 設定要件

- **必須** ログアーカイブ専用アカウントに配置すること（第6章）。同アカウントでは分析ワークロードを実行せず、保存先に徹すること。書き込みはログ配信元のサービスプリンシパルに、読み取りはログ管理者（R-5）および監査人（R-6）に限定すること（第10章）。
- **必須** ログ配信元サービスごとにバケットを分割すること。Object Lock の適用可否と暗号化の要件がサービスごとに異なるためである（4.4.3）。少なくとも CloudTrail用、AWS Config用、CloudWatch Logs（Firehose経由）用、サーバーアクセスログ用を分けること。
- **必須** バージョニングを有効化すること。Object Lock はバージョニングが有効なバケットでのみ動作する。**有効化後は未バージョニング状態に戻せず、「停止」しかできない。**
- **必須** Object Lock を有効化し、モードは**コンプライアンスモード**とすること。ガバナンスモードは `s3:BypassGovernanceRetention` 権限と `x-amz-bypass-governance-retention: true` ヘッダーにより上書きでき、S3コンソールは既定でこのヘッダーを付与するため、WORM（Write Once Read Many）としての証明力が弱い。本ガイドラインではガバナンスモードを採用しない。ただしサーバーアクセスログ用バケットは、Object Lock を有効化したバケットを配信先にできないため対象外とし、代替の改ざん防止策（アクセス制御、バージョニング、クロスリージョンレプリケーション等）を発注者と協議して決定すること。
- **必須** 既定の保持期間（Retain Until Date の基礎となる既定値）を、第7章で定める保存期間に一致させること。適用範囲はバケット種別ごとに異なり、CloudTrail用および CloudWatch Logs（Amazon Data Firehose 経由）用のアーカイブバケットに必須とする。ただしこれらのバケットへの適用は、4.1.3 および 4.4.3 に定める配信検証（配信成功と保持期限の付与の確認）を経てから行うこと。検証の結果、既定保持を設定した状態では配信が継続できないと判明したバケットは、既定保持を設定せず、4.4.3 の代替方式（配信後のオブジェクトに保持期間またはリーガルホールドを付与する方式）に切り替え、検証結果と判断理由を証跡として残して発注者の承認を得ること。既定保持は設定後に配置されたオブジェクトにのみ適用されるため、設定までの間に配信されたオブジェクトには S3 Batch Operations で保持期間を個別に付与し、その実施記録を残すこと。AWS Config用バケットはサービス側の制約により既定保持を設定せず、サーバーアクセスログ用バケットは Object Lock 自体を適用しない。既定保持を設定できないバケットについては、4.4.3 の方針に従い代替手段を発注者と協議し、決定と検証結果を記録すること。
- **推奨** 調査・係争時にリーガルホールドを付与する手順を運用手順書に定めること。リーガルホールドは保持期限とは独立に、期限なしで `s3:PutObjectLegalHold` 権限者が付け外しできる。
- **必須** パブリックアクセスブロックの4設定（`BlockPublicAcls`、`IgnorePublicAcls`、`BlockPublicPolicy`、`RestrictPublicBuckets`）をすべて有効化すること。アカウントレベルでも設定すること。

- 必須** 既定暗号化を SSE-KMS（ログ用顧客管理キー）とし、バケットポリシーで指定キー以外の書き込みおよび SSE-KMS を指定しない書き込みを拒否すること。ただしサーバーアクセスログ用バケットは、S3の仕様上 SSE-S3 のみが利用可能であるため対象外とし、その旨をログ設計書に記載すること。SSE-KMS による保護を要する場合は、サーバーアクセスログの配信先として Amazon CloudWatch Logs を選択する構成を代替経路として検討すること（4.4.3）。
- 必須** バケットポリシーで、TLSの強制、SSE-KMS（特定キー）の強制、削除およびライフサイクル変更の拒否、配信元サービスへの必要最小限の許可を定めること。削除の拒否には `s3:DeleteObject`、`s3:DeleteObjectVersion`、`s3:PutLifecycleConfiguration` の3アクションが必要である。
- 必須** ライフサイクルによる階層化を第7章の設計に従って構成すること。128 KB未満のオブジェクトは既定でどのストレージクラスにも移行されない。
- 推奨** MFA Delete を採用せず、Object Lock で改ざん防止を実現すること。**MFA Delete はライフサイクル設定と併用できず**、有効化できるのはバケット所有者（ルートユーザー）のみで、コンソールからは設定できない。階層化を行うアーカイブバケットとは両立しない。
- 推奨** クロスリージョンレプリケーションを構成すること（LR-11）。ライブレプリケーションは設定後の新規・更新オブジェクトのみを対象とし、既存オブジェクトには S3 Batch Replication が必要である。S3 Replication Time Control（S3 RTC）は、アップロードされたオブジェクトの大半を数秒で、99.9%を15分以内に複製する（SLA が付随し、S3 Replication metrics とイベント通知で遅延を検知できる）。S3 RTC を使用しない場合の複製時間は保証されないため、複製完了はレプリケーションステータスと S3 Replication metrics で監視すること。数値と SLA の適用条件は実装時点の公式ドキュメントで確認すること。複製元が Object Lock を有効化したバケットである場合の要件（複製先バケットの Object Lock 有効化、必要な権限、保持設定の複製）も公式ドキュメントで確認し、複製先に保持設定が付与されることを構築時に検証して証跡を残すこと。
- 推奨** S3 Inventory による棚卸を日次または週次で構成すること。出力フィールドに暗号化状態、Object Lock の保持期限・モード・リーガルホールド、レプリケーション状態、チェックサムを含めること。初回配信まで最大48時間を要し、結果は結果整合性である。
- 必須** アーカイブバケット自身へのアクセスを記録すること（L-14）。CloudTrail のデータイベントとサーバーアクセスログは記録内容が異なるため、両者の役割を設計書に明記すること（4.4.3）。

CloudTrail 用バケットのポリシーの骨子を次に示す。AWS Config 用バケットには、サービスプリンシパル `config.amazonaws.com` に対する `s3:GetBucketAcl`、`s3:ListBucket`、および配信先プレフィックス（`AWSLogs/<アカウントID>/Config/*`）への `s3:PutObject`（条件 `s3:x-amz-acl = bucket-owner-full-control` と `aws:SourceAccount`）を許可するステートメントを別途設けること（**必須**）。実際のポリシーは発注者のアカウント構成に合わせて作成し、適用前に IAM ポリシーシミュレータ等で検証すること。組織の証跡では、管理アカウントID配下と組織ID配下の双方への書き込み許可が必要である。公式例は書き込み許可を2ステートメントに分けた3ステートメント構成であり、管理アカウントID配下のステートメントは、組織の証跡が単一アカウントの証跡に変更された場合の配信を担保する。


```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AWSCloudTrailAclCheck",
      "Effect": "Allow",
      "Principal": { "Service": "cloudtrail.amazonaws.com" },
      "Action": "s3:GetBucketAcl",
      "Resource": "arn:aws:s3:::<log-archive-bucket>",
      "Condition": { "StringEquals": {
        "aws:SourceArn": "arn:aws:cloudtrail:<region>:<mgmt-account-id>:trail/<trail-name>" } }
    },
    {
      "Sid": "AWSCloudTrailWrite20150319",
      "Effect": "Allow",
      "Principal": { "Service": "cloudtrail.amazonaws.com" },
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::<log-archive-bucket>/AWSLogs/<mgmt-account-id>/*",
      "Condition": { "StringEquals": {
        "s3:x-amz-acl": "bucket-owner-full-control",
        "aws:SourceArn": "arn:aws:cloudtrail:<region>:<mgmt-account-id>:trail/<trail-name>" } }
    },
    {
      "Sid": "AWSCloudTrailOrganizationWrite",
      "Effect": "Allow",
      "Principal": { "Service": "cloudtrail.amazonaws.com" },
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::<log-archive-bucket>/AWSLogs/<o-orgid>/*",
      "Condition": { "StringEquals": {
        "s3:x-amz-acl": "bucket-owner-full-control",
        "aws:SourceArn": "arn:aws:cloudtrail:<region>:<mgmt-account-id>:trail/<trail-name>" } }
    },
    {
      "Sid": "DenyInsecureTransport",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:*",
      "Resource": [ "arn:aws:s3:::<log-archive-bucket>",
        "arn:aws:s3:::<log-archive-bucket>/*" ],
      "Condition": { "Bool": { "aws:SecureTransport": "false" } }
    },
    {
      "Sid": "DenyUnencryptedObjectUploads",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::<log-archive-bucket>/*",
      "Condition": { "Null": {
        "s3:x-amz-server-side-encryption-aws-kms-key-id": "true" } }
    },
    {
      "Sid": "DenyWrongEncryptionKey",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::<log-archive-bucket>/*",
      "Condition": { "ArnNotEqualsIfExists": {
        "s3:x-amz-server-side-encryption-aws-kms-key-id": "<log-cmk-arn>" } }
    },
    {
      "Sid": "DenyDeleteAndLifecycleChange",
      "Effect": "Deny",
      "Principal": "*",

```

```

    "Action": [ "s3:DeleteObject", "s3:DeleteObjectVersion",
                "s3:PutLifecycleConfiguration" ],
    "Resource": [ "arn:aws:s3:::<log-archive-bucket>",
                  "arn:aws:s3:::<log-archive-bucket>/*" ],
    "Condition": { "ArnNotLike": {
                    "aws:PrincipalArn": "arn:aws:iam::<log-archive-account-id>:role/<log-admin-role>" } }
  }
}
}

```

バケットポリシー適用後の配信確認（必須）。 `DenyUnencryptedObjectUploads` と `DenyWrongEncryptionKey` の2ステートメントは、配信元サービスが暗号化ヘッダーを付与しない経路では配信失敗を招きうるため、バケットの既定暗号化との組み合わせを構築時に検証すること。またAWSは、サービス間の呼び出しでは `aws:SourceIp` / `aws:SourceVpc` / `aws:SourceVpcArn` / `aws:SourceVpce` といったネットワーク関連の条件キーの認可コンテキストが削除される場合があり、Deny文でこれらを用いるとAWSサービスプリンシパルが意図せず遮断されうると注意喚起している（この場合は `aws:PrincipalIsAWSService` を `false` とする条件を併記して除外する）。`DenyInsecureTransport` は `aws:SecureTransport` のみを用いる公式例と同じ形である。したがってバケットポリシー適用後は、CloudTrail・AWS Config 等からの実配信が継続していることを `get-trail-status` および配信オブジェクトの到着によって確認し、その結果を証跡として残すこと。

4.4.3 設計上の注意点

Object Lock の適用可否は配信元サービスごとに異なる。 これは本章で最も設計判断を要する箇所であり、バケットを分割する理由でもある。

- **AWS Config:** 既定の保持設定を有効化した Object Lock バケットへの配信は**サポートされない**と明記されている。Config用バケットには既定保持を設定しないこと。
- **AWS CloudTrail:** ログ配信先バケットに Object Lock（コンプライアンスモード）を適用することは、AWS が公表するログ保全のプラクティスとして案内されている。ただし既定の保持期間の値は事後に変更・短縮ができないため、本番適用前に検証環境で配信テストを行い、配信成功と保持期限の付与を証跡として残すこと。
- **Amazon Data Firehose（CloudWatch Logs からのS3への長期転送）:** 既定保持を有効化した Object Lock バケットへの配信可否を実装時点の公式ドキュメントで確認し、構築時に配信テストで検証すること。検証結果（配信成功と保持期限の付与）を証跡として残すこと。
- **Amazon CloudWatch Logs のS3エクスポート:** 保持期間つき Object Lock バケットへのエクスポートに対応すると明記されている（ただしDSSE-KMSは非対応）。本ガイドラインでは継続的なアーカイブ手段として採用しない（4.3.2）が、臨時抽出時の参考として記載する。
- **S3サーバーアクセスログ:** Object Lock 有効バケットを配信先にできない。サーバーアクセスログ用バケットは別に用意すること。

既定保持を設定できないバケットの改ざん防止については、Object Lock を有効化したうえで既定保持を用いず、配信後のオブジェクトに対して保持期間またはリーガルホールドを付与する方式（既存オブジェクトへの保持適用はS3 Batch Operations で実施できる）が考えられる。ただしこれは公式ドキュメントに構成例が示された標準パターンではなく、本ガイドライン上の設計案である。採否は発注者と協議し、採用する場合は検証環境で動作確認したうえで、検証記録を設計書に添付すること。

● 注意

コンプライアンスモードの Object Lock は、保持期限までルートユーザーを含むいかなる利用者也オブジェクトを上書き・削除できず、モードの変更も保持期間の短縮もできない。期限前に削除する唯一の方法は AWS アカウントの削除である。また、Object Lock は有効化後に無効化できず、バージョンングの停止もできない。**保持期間の設定誤りは事後に是正できない**。本番適用の前に、検証環境で短い保持期間を用いて動作と解除不能性を確認し、既定保持期間の値については発注者の書面による承認を得ること。

バケットポリシーではライフサイクルによる削除を防げない。 ライフサイクルによる有効期限切れや移行は、バケットポリシーで阻止できない。したがって `s3:PutLifecycleConfiguration` を明示的に拒否し、ライフサイクル設定自体を変更させないことが統制上の要点となる。あわせて Object Lock により、ライフサイクルの誤設定があっても保持期限内のオブジェクトが削除されないようにすること。なお、レプリケーションのステータスが `PENDING` または `FAILED` のオブジェクトは、有効期限切れと移行がブロックされる。

ライフサイクルによる削除はCloudTrailに記録されない。 ライフサイクル操作は CloudTrail のオブジェクトレベルのログに記録されず、S3 サーバーアクセスログ（`S3.EXPIRE.OBJECT`、`S3.TRANSITION_GDA.OBJECT` 等）でのみ確認できる。すなわち「保存期間の満了によって削除されたこと」を示す証跡は、サーバーアクセスログを取得していなければ提示できない。LR-05 の運用証跡として、アーカイブバケットのサーバーアクセスログを取得すること。

CloudTrail データイベントとサーバーアクセスログの使い分け。 CloudTrail のデータイベントは整合性検証が可能でプレフィックス単位に有効化でき、JSON 形式で配信されるが、**認証失敗は記録されない**。サーバーアクセスログは**認証失敗を記録し**、ライフサイクルの移行・期限切れ・復元も記録するが、整合性検証の仕組みがなく、ベストエフォート配信のため完全性・適時性は保証されない（欠落・遅延・重複がありうる）。両者は代替関係ではなく補完関係にある。配信先の選択にも制約があり、S3 バケットを宛先とするサーバーアクセスログは同一リージョン・同一アカウントかつ SSE-S3 のみである。一方、Amazon CloudWatch Logs を宛先とする場合はクロスアカウント・クロスリージョンの配信と AWS KMS による暗号化に対応するため、SSE-KMS 要求を満たす代替経路となりうる。いずれを採用するかを設計書に明記すること。

ストレージクラスの最小保存期間は取り出し要件と衝突しうる。 表4-7に、階層化設計にあたって考慮すべき制約を示す。監査人からの証跡提出依頼に対する応答期限（第12章）と取り出し時間を照合し、階層化の段数と移行時期を決定すること。

表4-7 ストレージクラスの最小保存期間と取り出し時間

ストレージクラス	最小保存期間	取り出し	ログアーカイブでの位置づけ
S3 Standard	なし	即時	直近期間。Athena での日常的な検索対象
S3 Standard-IA	30日	即時	当期中の再照会が想定される期間
S3 Glacier Instant Retrieval	90日	ミリ秒	即時性を保ったまま長期保管する場合
S3 Glacier Flexible Retrieval	90日	Expedited 1～5分／Standard 3～5時間／Bulk 5～12時間	過年度分の長期保管。復元操作が必要
S3 Glacier Deep Archive	180日	Standard 12時間以内／Bulk 48時間以内（Expedited 不可）	最長期保管。提出期限との整合を必ず確認する

最小保存期間に満たないうちに次のクラスへ移行すると残期間分が課金され、1つのライフサイクルルール内で最小保存期間を下回る連鎖移行は定義できない。また S3 Glacier Flexible Retrieval ではオブジェクトごとに40 KBのメタデータが加算されるため、小さなログオブジェクトが大量に存在する構成では、階層化してもコストが期待どおり下がらない場合がある。S3 One Zone-IA は単一アベイラビリティゾーンに保存されるため、ログアーカイブ用途では採用しないこと。

4.4.4 設定パラメータ

表4-8 ログアーカイブバケット 設定パラメータ

パラメータ	推奨値	レベル	備考
配置アカウント	ログアーカイブ専用アカウント	必須	分析ワークロードを同居させない（第6章）
バケット分割	ログ配信元サービス単位	必須	Object Lock の適用可否と暗号化要件が異なるため
バージョニング	有効	必須	未バージョニングに戻せない
Object Lock	有効・コンプライアンスモード	必須	有効化後に無効化不可。サーバーアクセスログ用バケットには適用不可（4.4.2のとおり代替策を協議）
既定保持期間	第7章で定める保存期間（適用対象はCloudTrail用およびCloudWatch Logs（Firehose経由）用バケット）	必須	AWS Config用バケットはサービス制約により設定しない。設定できないバケットは代替手段を協議し検証記録を残す
リーガルホールド	付与・解除手順を整備	推奨	保持期限とは独立。期限なし
パブリックアクセスブロック	4設定すべて有効	必須	アカウントレベルでも設定
既定暗号化	SSE-KMS（ログ用顧客管理キー）	必須	バケットポリシーで指定キー以外およびSSE-KMS未指定を拒否。サーバーアクセスログ用バケットはS3の仕様上 SSE-S3 のみのため対象外
バケットポリシー	TLS強制・SSE-KMS強制・削除／ライフサイクル変更拒否・配信元許可	必須	削除拒否は3アクションを指定。組織の証跡では管理アカウントID配下と組織ID配下の双方に書き込みを許可
ライフサイクル	第7章の設計に従う階層化	必須	128 KB未満は既定で移行対象外
MFA Delete	採用しない（Object Lockで代替）	推奨	ライフサイクル設定と併用不可
クロスリージョンレプリケーション	有効	推奨	既存オブジェクトはBatch Replication が必要
S3 Inventory	日次または週次	推奨	暗号化状態・Object Lock保持期限を出力対象に含める
アクセス記録	CloudTrailデータイベント+サーバーアクセスログ	必須	ライフサイクル削除はサーバーアクセスログでのみ確認可能

4.4.5 提出する設定証跡

```
aws s3api get-bucket-versioning --bucket <log-archive-bucket>
aws s3api get-object-lock-configuration --bucket <log-archive-bucket>
aws s3api get-bucket-encryption --bucket <log-archive-bucket>
aws s3api get-bucket-policy --bucket <log-archive-bucket>
aws s3api get-public-access-block --bucket <log-archive-bucket>
aws s3api get-bucket-lifecycle-configuration --bucket <log-archive-bucket>
aws s3api get-bucket-replication --bucket <log-archive-bucket>
aws s3api get-bucket-logging --bucket <log-archive-bucket>
aws s3api list-bucket-inventory-configurations --bucket <log-archive-bucket>

# 個別オブジェクトの保持状態（Object Lock が機能していることの確認）
aws s3api get-object-retention --bucket <log-archive-bucket> --key <object-key>
```

- バケット一覧と、各バケットの配信元サービス・Object Lock適用状況・既定保持期間・暗号化方式（SSE-KMS／SSE-S3）の対応表
- Object Lock の動作検証記録（検証環境で保持期限内のオブジェクト削除が拒否されたことを示す出力）
- 既定保持を有効化したバケットに対する配信テストの記録（配信成功と保持期限の付与を示す出力。CloudTrail用および Firehose経由バケット）
- バケットポリシー適用後に配信が継続していることを示す記録（`get-trail-status` の出力と配信オブジェクトの到着確認）
- S3 Inventory レポートの1世代（暗号化状態・Object Lock保持期限を含むもの）
- アカウントレベルのパブリックアクセスブロック設定

4.5 AWS KMS

4.5.1 役割と対応する要求事項

AWS KMS は、ログの機密性（LR-07）を担保すると同時に、S3の読み取り権限とキーポリシーによる復号権限の二重の制御によって、ログへのアクセス制御（LR-06）と持ち出し防止を実現する。同時に、キーの不適切な削除はログを永久に復号不能にするため、ログ基盤における最大の可用性リスク（LR-11）でもある。

- **対応する要求事項:** LR-04、LR-06、LR-07、LR-11、LR-12、LR-13（AWS側の統制と責任分界）
- **関連するログ種別:** L-14（キーの無効化・削除予約・キーポリシー変更）。AWS KMS のすべての操作は管理イベントとして CloudTrail に記録される
- **対応するIT全般統制の領域:** ITGC-C（AWS 側の統制の扱いは章冒頭の記載と第2章 LR-13 による）

4.5.2 設定要件

- **必須** ログ用の顧客管理キー（CMK）を業務データ用のキーと分離し、ログアーカイブアカウントに作成すること。CloudTrail用のキーは、配信先S3バケットと同一リージョンに作成する必要がある。
- **推奨** 用途別（CloudTrail用、Config・S3アーカイブ用、CloudWatch Logs用）にキーを分離すること。キーポリシーの誤りやキー障害の影響範囲を限定でき、復号権限を用途ごとに分けられる。キーの本数はコストに影響するため、分離方針は発注者と合意すること。
- **必須** キーポリシーを表4-9に従って設定すること。キーポリシーはキーごとにちょうど1つで、リージョナルなりソースである。ルートユーザーやキーの作成者であっても、キーポリシー等で明示的に許可されない限り

権限を持たない。またキーポリシーがIAMポリシーによる許可を有効化しない限り、IAMポリシー側で許可を与えることはできない（拒否は可能）。

- **必須** 自動ローテーションを有効化すること。既定は365日で、90～2,560日の範囲でカスタマイズできる。対象はAWS_KMSをオリジンとする対称暗号化キーである。旧キーマテリアルは保持されるため、既存データの再暗号化は不要である。ローテーションはRotateKey イベントとしてCloudTrailに記録される。
- **必須** キー削除はScheduleKeyDeletion 呼び出し時に待機期間（PendingWindowInDays、7～30日・既定30日）を指定する。既定の30日より短い値を指定しないこと。待機期間はキーに事前設定できる属性ではないため、短縮を防ぐ予防的統制として、キーポリシーまたはSCPでkms:ScheduleKeyDeletionPendingWindowInDays 条件キーにより下限を強制すること（第10章）。実際の削除は指定した待機期間よりさらに最大24時間長くなる場合がある。
- **必須** ScheduleKeyDeletion および DisableKey を検知対象とすること（4.3.2のCloudWatch.7相当のパターン）。加えて、CloudTrail 経由のCloudWatch Logsで「pending deletion」を含むエラーメッセージを検知するメトリクスフィルターを併用すること。検知後はCancelKeyDeletionにより取り消せるため、検知から取消判断までの手順と責任者を運用手順書に定めること。
- **必須** ログの読み取り・復号を許可するプリンシパル（ログ管理者R-5、監査人R-6）をキーポリシーに明記し、開発者（R-3）および運用者（R-4）に既定で復号権限を与えないこと（第10章）。
- **任意** マルチリージョンキーの採否を発注者と協議すること。レプリケーション先リージョンでの復号に有用だが、単一リージョンキーからの変換はできず、各レプリカは独立したリソースでキーポリシーも独立している。
- **必須** cmk-backing-key-rotation-enabled および kms-cmk-not-scheduled-for-deletion を必須Configルールに含めること（表4-4）。

表4-9 ログ用CMKのキーポリシー要件

対象	許可するプリンシパル	主なアクションと条件
AWS CloudTrail (証跡の暗号化)	cloudtrail. amazonaws.com	kms:GenerateDataKey* (条件: kms:EncryptionContext:aws:cloudtrail:arn を証跡ARNのパターンに限定、aws:SourceArn)、kms:DescribeKey。S3 Bucket Keyを使用するバケットではkms:Decrypt も必要
CloudTrailログの読み取り者	ログ管理者・監査人の ロール	kms:Decrypt (条件: Null: kms:EncryptionContext:aws:cloudtrail:arn = false)
Amazon CloudWatch Logs	logs.<region>. amazonaws.com	kms:Encrypt / kms:Decrypt / kms:ReEncrypt* / kms:GenerateDataKey* / kms:Describe* (条件: kms:EncryptionContext:aws:logs:arn でロググループARNに限定)。呼び出し側にはkms:ViaService 条件付きの権限を付与する
Amazon S3 (ログ アーカイブ)	配信元サービスおよび 読み取り者	データキーの生成と復号。バケットポリシーで指定キー以外の書き込みを拒否し、キーポリシーと二重に制御する
AWS Config (配信 チャンネル)	サービスプリンシパル config.amazonaws. com	kms:Decrypt / kms:GenerateDataKey* を許可し、aws:SourceAccount / aws:SourceArn (またはkms:ViaService によるS3限定) で呼び出し元を限定する。実装時点の公式ドキュメントで最新の要件を確認のうえ確定すること
Amazon Data Firehose (S3への 長期転送)	配信ストリームに付与 するIAMロール	kms:GenerateDataKey / kms:Decrypt を許可し、kms:ViaService をs3.<region>.amazonaws.com に、kms:EncryptionContext:aws:s3:arn を配信先バケットに限定する。実装時点の公式ドキュメントで最新の要件を確認のうえ確定すること

4.5.3 設計上の注意点

● 注意

KMSキーを削除すると、そのキーで暗号化されたデータは復号できず、**回復できない**。ログアーカイブに用いるキーは、保存期間が満了するまで削除も無効化もしない運用とすること（待機期間中は暗号化操作ができず、ローテーションも行われない）。キー削除を防ぐ予防的統制（SCPおよびキーポリシーによる `kms:ScheduleKeyDeletion`・`kms:DisableKey` の制限、および `kms:ScheduleKeyDeletionPendingWindowInDays` による待機期間の下限強制）は第10章に、検知は第9章に定める。削除ではなく無効化を検討すべき場面でも、ログ用キーについては無効化中でも復号できない点に留意すること。

キーの不備はログの欠損として現れる。 キーが無効化されている、またはキーポリシーに誤りがある場合、CloudTrail はログを配信できない。この事象は「暗号化が失敗した」ではなく「ログが届かない」形で現れるため、`get-trail-status` の配信エラーと、S3へのオブジェクト到着監視（LR-11）の両方で検知できるようにすること。

KMS操作の記録は CloudTrail の設定に依存する。 AWS KMS のすべての操作は管理イベントとして記録されるが、基本イベントセクタの `ExcludeManagementEventSources` に `kms.amazonaws.com` を設定する、または高度なイベントセクタで `eventSource` に同値の `NotEquals` 条件を設定すると記録されなくなる（4.1.2）。KMS の `Encrypt` / `Decrypt` / `GenerateDataKey` は KMS イベント量の99%超を占め読み取りイベントとして記録される一方、`DisableKey` / `ScheduleKeyDeletion` 等は書き込みイベントとして記録される。イベント量の削減を目的にKMSを除外する提案を行う場合は、L-14 の検知が成立しなくなることを明示し、発注者の承認と代替統制を得ること。

関連付け解除後も暗号化は残る。 CloudWatch Logs では、KMSキーの関連付けを解除しても既存データはそのキーで暗号化されたままである。キーを無効化すると過去データが読めなくなるため、キーのライフサイクルは「ロググループの保持期間より長いこと」を条件として設計すること。

マルチリージョンキーの運用。 マルチリージョンキーはグローバルなリソースではなく、各レプリカが独立したリソースであり、キーポリシーも独立している。採用する場合は、レプリカ側のキーポリシーを含めて IaC で管理し、片側だけが変更される状態を防ぐこと。

コスト。 顧客管理キーは月額課金とリクエスト課金があり、ローテーションの実施によって加算が生じる（取得時点の価格ページでは1回目・2回目のローテーションで各\$1/月が加算され、それ以上は加算されない）。用途別にキーを分離する方針はコストに直結するため、実装時点の価格ページで確認したうえで試算を提示すること。

4.5.4 設定パラメータ

表4-10 AWS KMS 設定パラメータ

パラメータ	推奨値	レベル	備考
キーの種類	対称暗号化の顧客管理キー	必須	CloudWatch Logs は対称キーのみ対応
キーの分離	ログ用と業務用を分離。さらに用途別に分離	推奨	影響範囲の限定と復号権限の分離のため
配置	ログアーカイブアカウント。 CloudTrail用は配信先バケットと同一リージョン	必須	キーポリシーはリージョナル
キーポリシー	表4-9のとおり	必須	キーごとにちょうど1つ。ルートユーザーも明示許可が必要
自動ローテーション	有効（既定365日）	必須	90～2,560日でカスタマイズ可。旧キーマテリアルは保持される
削除待機期間 （ScheduleKeyDeletion のリクエスト時パラメータ）	30日を下回らないこと	必須	キー属性ではないため、kms:ScheduleKeyDeletionPendingWindowInDays 条件キーによる強制とCloudTrail検知で担保する。指定範囲は7～30日・既定30日。実際はさらに最大24時間長くなる場合がある
削除予約・無効化の検知	メトリクスフィルターとアラーム	必須	4.3.2 のCloudWatch.7相当パターン+「pending deletion」検知
キーエイリアス	用途が識別できる命名規則	推奨	キーポリシーレビュー時の識別性を確保する
マルチリージョンキー	発注者と協議のうえ決定	任意	単一リージョンキーからの変換は不可
Configルール	cmk-backing-key-rotation-enabled / kms-cmk-not-scheduled-for-deletion	必須	表4-4に含める

4.5.5 提出する設定証跡

```
aws kms describe-key --key-id <key-id> --region <region>
aws kms get-key-policy --key-id <key-id> --policy-name default --region <region>
aws kms get-key-rotation-status --key-id <key-id> --region <region>
aws kms list-aliases --region <region>
```

- ログ用キーの一覧（キーID、エイリアス、用途、配置アカウント・リージョン、対応するログ種別の対応表）
- キーポリシーで復号を許可されているプリンシパルの一覧。第10章の職務分掌の設計と一致していること
- kms:ScheduleKeyDeletionPendingWindowInDays 条件キーによる待機期間の下限強制を定めたキーポリシーまたはSCPの定義。待機期間はキー属性ではないため describe-key の出力には現れず、この定義をもって証跡とする
- 削除予約・無効化に対するアラーム定義と、検知時の対応手順（運用手順書の該当節）

● 監査の視点

ログが暗号化されていること自体は、監査人にとっての関心事の一部にすぎない。より重視されるのは「誰がログを復号でき、その権限が承認されたものか」である。S3の読み取り権限とKMSの復号権限は独立しているため、いずれか一方のみを提示しても復号可能者の一覧にはならない。開発ベンダーは、バケットポリシー・IAMポリシー・キーポリシーを突き合わせた「復号可能なプリンシパルの一覧」を成果物として提出できるようにすること（第10章、第11章）。

● 補足

本章で構成した基盤ログは、第5章で扱う認証・操作・データベース・ネットワーク・検知系のログを受け取ることで完成する。本章の設定を先に確定させ、第5章の各ログの配信先・暗号化キー・保持期間を本章で定めたバケットおよびロググループに割り当てること。全体構成は第6章に示す。

5

AWSサービス対応詳細（2） — 認証・操作・データ・ネットワーク・検知・分析

第4章で基盤ログの取得と保全（AWS CloudTrail、AWS Config、Amazon CloudWatch Logs、Amazon S3、AWS KMS）を定めた。本章は、その基盤の上に載る個別領域——認証・認可、サーバ操作、データベース、ネットワーク、セキュリティ検知、通知、分析、バックアップ、CI/CD、マルチアカウント統制、責任共有、時刻同期——について、開発ベンダーが設計・構築・テストに落とし込める粒度で要求事項を示す。

各節は原則として「役割と対応する要求事項」「設定要件」「設計上の注意点」「提出する設定証跡」の4区分で構成する（5.9 のみソースリポジトリの取り扱いを加える）。「設定要件」は要求レベル（必須・推奨・任意）を付した遵守事項を示し、「設計上の注意点」は設計判断の前提となる解説を示す。「提出する設定証跡」は、当該設定が有効に構成されていることを示す成果物を指す。監査人へのログ本体の抽出・提出手続は第12章、保存期間の決定は第7章、改ざん防止の実装は第8章、監視のしきい値と定期レビューの運用は第9章、権限設計と職務分掌は第10章、成果物の書式は第11章に定める。

5.1 AWS IAM／AWS IAM Identity Center／ルートユーザー

5.1.1 役割と対応する要求事項

本節は L-04（認証・認可ログ）の主たる取得元を扱う。IT全般統制としては ITGC-C（内外からのアクセス管理などシステムの安全性の確保）に対応し、要求事項 LR-01（対象範囲の特定と網羅性）、LR-02（記録項目）、LR-06（ログへのアクセス制御と職務分掌）、LR-08（監視とアラート）、LR-10（検索・抽出）、LR-14（文書化）に該当する。

財務報告に係る内部統制の実務では、特権IDの使用状況を事後にモニタリングできることが着眼点とされる（日本公認会計士協会 監査基準報告書315 実務ガイダンス第1号および経済産業省「システム管理基準 追補版」による。基準・実施基準の本文に特権IDの定義および保存・モニタリングの明文規定はない）。特権IDとは、マスタ情報やパラメータ設定値の変更、会計データの作成・変更・削除、およびそれらの権限設定が可能な、操作に制限を受けない識別子を指す。共有IDを用いる場合であっても、実際に操作した個人を特定できることが評価上の要点となる。AWS環境では、この「個人の特定」を IAM の識別子設計と CloudTrail の `userIdentity` の構造によって担保する。

5.1.2 設定要件

- **必須** 人による AWS マネジメントコンソールおよび CLI へのアクセスは、AWS IAM Identity Center または外部IdPフェデレーションを経由する設計とし、恒久的な IAM ユーザーと長期アクセスキーを新規に発行しないこと。やむを得ず IAM ユーザーを用いる場合は、対象・理由・棚卸方法をログ設計書（LR-14）に記載すること。
- **必須** CloudTrail 管理イベント（第4章）において、`ConsoleLogin`、`AssumeRole`、`AssumeRoleWithSAML`、`AssumeRoleWithWebIdentity`、`GetFederationToken`、`GetSessionToken` が記録

されることを構築後に確認すること。IAM・AWS STS・Amazon CloudFront のグローバルサービスイベントは us-east-1 に記録されるため、マルチリージョン証跡を用いるか、us-east-1 を記録対象に含めること。

- 必須** AWS CLI/API から直接ロールを引き受けて業務操作を行う経路（開発ベンダー・運用ベンダーの保守作業等）では、操作者個人を特定できるよう送信元アイデンティティ（source identity）を用いること。ロールの信頼ポリシーで `sts:AssumeRole`（フェデレーションの場合は `sts:AssumeRoleWithSAML` 等）と併せて `sts:SetSourceIdentity` を許可し、`sts:SourceIdentity` 条件キーで受け入れる値を限定すること。IdP（外部IdPフェデレーション）に接続されたロールについては、信頼ポリシーに `sts:SetSourceIdentity` の許可がないと `AssumeRole*` 操作自体が失敗する。IdPを経由しない直接の `AssumeRole` では、許可がない場合に失敗するのは送信元アイデンティティを渡したときである。引き受ける側のアイデンティティベースポリシーにも `sts:SetSourceIdentity` を付与すること。ロールチェーンおよびクロスアカウントで引き受ける場合は、呼び出し元のアクセス許可ポリシーと引受先ロールの信頼ポリシーの双方に `sts:SetSourceIdentity` が必要である。設定後の操作では `aws:SourceIdentity` 条件キーが利用でき、CloudTrail には `requestParameters.sourceIdentity` および `userIdentity.sessionContext.sourceIdentity` として記録される。
- 必須** 送信元アイデンティティを要求するロールは、マネジメントコンソールのロール切り替えでは引き受けられない。したがって当該ロールを用いる経路は CLI/API に限定する設計とし、コンソール経由の操作については IAM Identity Center 経由とすること。IAM Identity Center 経由の個人特定は二段構えとする。(a) サインイン、AWS アクセスポータルの利用、MFA デバイス管理など IAM Identity Center 自身が発行するイベント（`userIdentity` の type は `IdentityCenterUser` または `Unknown`）では、`onBehalfOf.userId` および `onBehalfOf.identityStoreArn` により利用者を特定すること。これらのイベントでは `userIdentity` の `userName` / `principalId` を利用できないため、Identity Store の `DescribeUser` による利用者の解決手順を運用手順書に定めること。(b) 権限セットを引き受けた後のメンバーアカウント内の操作は `userIdentity` type `AssumedRole` として記録され `onBehalfOf` を含まないため、権限セットに対応するロール（`AWSReservedSSO_` で始まるロール）とロールセッション名により特定すること。(a) と (b) を突合できるように、Identity Store 上の利用者と `userId`・ロールセッション名の対応表を整備すること。
- 必須** AWS CLI/API からロールを引き受ける経路では、`AssumeRole` の `RoleSessionName` パラメータに個人を識別できる値を設定すること。信頼ポリシーの `sts:RoleSessionName` 条件キーにより、受け入れるセッション名の形式を強制すること。AWS IAM Identity Center 経由の経路ではセッション名はサービスが生成するため、本節に定める `onBehalfOf.userId` と Identity Store の対応表（およびロールセッション名との突合）をもって個人特定の手段とすること。
- 必須** IAM Identity Center を利用する場合、`sso.amazonaws.com`、`identitystore.amazonaws.com`、`sso-directory.amazonaws.com`、`sso-oauth.amazonaws.com`、`identitystore-scim.amazonaws.com`、`signin.amazon.com` を発生源とするイベントが証跡に含まれることを確認すること。サインインは `CredentialChallenge`、`CredentialVerification`、`UserAuthentication` の各イベントとして記録され、`AuthWorkflowID` により一連の認証として相関できる。
- 必須** 権限の付与・変更・削除にあたる操作（`CreatePermissionSet`、`CreateAccountAssignment`、`DeleteAccountAssignment`、`ProvisionPermissionSet`、`AttachManagedPolicyToPermissionSet`、`PutInlinePolicyToPermissionSet`、および IAM のポリシー変更API）を LR-08 の監視対象に含める設計とすること。検知の実装は 5.5 および 5.6 による。
- 必須** IAM Identity Center の CloudTrail イベントがどのリージョンに記録されるかを公式ドキュメントで確認し、確認結果と、それに基づく証跡の記録対象リージョンの設計をログ設計書に記載すること。記録先リージョンを取り違えると LR-01 の網羅性が損なわれる。
- 必須** 発注者側（R-1 内部統制担当、R-2 システム所管）が保有する前提——ルートユーザーの MFA 登録状況、AWS Organizations における集中ルートアクセス管理の適用有無——を着手時に確認し、確認結果と、そ

れを前提とした設計上の扱いをログ設計書に記載すること。ルートユーザーの設定変更そのものは貴社の作業範囲ではない。

- **推奨** IAM Access Analyzer の未使用アクセス分析を有効化すること。追跡期間は 1～365 日の範囲で設定でき、90 日などの値を発注者と合意すること。追跡期間はアナライザー作成時の必須入力であり既定値は定義されていないため、採用値とその根拠をログ設計書に記載すること。
- **推奨** IAM 認証情報レポート（4時間に1回生成される CSV）を、アクセス権棚卸（R-2 が実施）の基礎資料として定期取得する手順を運用設計に含めること。
- **推奨** 開発ベンダー要員および運用ベンダー要員に付与するロールには、アクセス許可の境界（permissions boundary）を設定し、最大権限を明示的に制限すること。
- **任意** ロール引き受け時のセッションタグ（sts:TagSession を信頼ポリシーで許可し、AssumeRole の Tags で付与）を用いて、案件番号や作業区分を証跡に残すこと。CloudTrail の requestParameters.principalTags で確認できる。

5.1.3 設計上の注意点

- ロールを引き受けた後の操作は、ロールの識別子で記録され、引き受けた個人の情報を含まない。送信元アイデンティティを設定していない場合、特権IDの使用者を CloudTrail だけでは特定できず、LR-02（5W1H のうち「誰が」）を満たさない。
- コンソールサインインでユーザー名を誤入力した場合、当該値は HIDDEN_DUE_TO_SECURITY_REASONS としてマスクされる。認証失敗の分析は、この挙動を前提とした解釈が必要である。
- クロスアカウントのロール引き受けが拒否された場合、その記録はターゲットアカウント側には残らない。委託先からのアクセス拒否を検知したい場合は、呼び出し元アカウントの証跡が必要である。
- IAM の最終アクセス情報（サービス単位・アクション単位）は拒否された試行も含むため、実際に成功した操作の判断根拠としては CloudTrail が正となる。また対象アクションと開始時期がサービスにより異なる。
- IAM 認証情報レポートは、パスワード、利用者ごとの最初の2つのアクセスキー、MFA、X.509 証明書のみを対象とし、サービス固有の認証情報や3つ目以降のキーを含まない。棚卸の網羅性を主張する際は、この範囲の限定が前提となる。

5.1.4 提出する設定証跡

- 証跡のイベントセクタ設定（aws cloudtrail get-event-selectors の出力）と、認証系イベントが記録対象であることの説明。
- IAM Identity Center の割当一覧の取得手順（list-instances → list-permission-sets-provisioned-to-account → list-account-assignments、および identitystore list-users / list-groups / list-group-memberships）と、構築時点の取得結果。
- ロールの信頼ポリシー（sts:SetSourceIdentity の許可と sts:SourceIdentity 条件キーによる値の限定を含む）、引き受ける側のアイデンティティベースポリシー、および実際に sourceIdentity が記録されたテストイベントの抜粋。
- IAM Identity Center 経由の操作について、(a) IAM Identity Center 発行イベント（onBehalfOf を含む）と (b) 権限セット引き受け後の操作イベント（AssumedRole ・ロールセッション名）の双方のテストイベント抜粋、および両者を突合した対応表。
- IAM Identity Center の CloudTrail イベント記録先リージョンの確認結果と、証跡の記録対象リージョンとの突合結果。
- AWS Config ルール iam-root-access-key-check、root-account-mfa-enabled、mfa-enabled-for-iam-console-access、iam-user-mfa-enabled の評価結果。

- 利用者識別子の対応表（IAM/Identity Center 上の識別子と、業務上の利用者区分・所属・役割 R-1～R-6 の対応）。

5.2 AWS Systems Manager Session Manager と OS ログ

5.2.1 役割と対応する要求事項

本節は L-05（サーバ操作ログ）を扱う。ITGC-C（アクセス管理・安全性の確保）および ITGC-B（システムの運用・管理）に対応し、LR-01、LR-02、LR-04（改ざん防止）、LR-06、LR-07（暗号化と機微情報の保護）、LR-08、LR-14 に該当する。OS レベルの特権操作は、アプリケーションの統制を迂回してデータを直接変更しうる経路であり、その記録は特権ID統制の中核となる。

5.2.2 設定要件

- **必須** 本番環境における対話的な OS 操作は AWS Systems Manager Session Manager 経由に限定し、SSH（22番）および RDP（3389番）による直接接続の経路を設計上持たないこと。踏み台サーバを用いる場合も同様とする。
- **必須** セッションログを Amazon S3 または Amazon CloudWatch Logs に出力する設定を、Session Manager のセッション設定に対して明示的に行うこと。既定では設定しない限りセッションログは保存されない。
- **必須** SSH セッション（AWS-StartSSHSession）およびポートフォワーディング（AWS-StartPortForwardingSession、AWS-StartPortForwardingSessionToRemoteHost）を IAM ポリシーまたは SCP で原則として拒否すること。これらの経路はセッションログを取得できない。例外的に許容する場合は、ログを取得できない経路が存在するという事実と、それに対する代替統制（接続元の限定、時間帯の限定、二人作業、事前承認と事後報告）を発注者と合意し、対象・理由・代替統制をログ設計書に記載すること。合意のないまま許容してはならない。公式に示されている拒否の記述例は SSH のみを対象とするため、ポートフォワーディングの各ドキュメントを明示的に追加した記述例は次のとおりである。

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": "ssm:StartSession",
      "Resource": [
        "arn:aws:ssm:*:*:document/AWS-StartSSHSession",
        "arn:aws:ssm:*:*:document/AWS-StartPortForwardingSession",
        "arn:aws:ssm:*:*:document/AWS-StartPortForwardingSessionToRemoteHost"
      ]
    }
  ]
}
```

- **必須** S3 へ出力する場合は「暗号化された S3 バケットのみを許可」、CloudWatch Logs へ出力する場合は「暗号化されたロググループのみを許可」を有効にすること。顧客管理の KMS キーを用いる場合、対象ノードのインスタンスプロファイルに当該キーの利用権限を明示的に付与すること。
- **必須** Linux/macOS の対象ノードに screen ユーティリティが導入されていることを構築時に確認すること。導入されていない場合、セッションログが切り詰められる可能性がある。

- **必須** OS の監査ログを Amazon CloudWatch エージェントで収集すること。Linux は `logs.logs_collected.files.collect_list` に `/var/log/audit/audit.log` および `/var/log/secure` 等を指定し、Windows は `logs.logs_collected.windows_events.collect_list` に `event_name` として「Security」を、`event_ids` として認証成功・失敗に対応する ID（4624、4625 等）を指定すること。ロググループ名と `log_stream_name`（`{instance_id}` 等の変数を利用）の命名規約をログ設計書に定めること。
- **必須** AWS Systems Manager Run Command および Automation のパラメータに、パスワードその他の機微情報を平文で渡さないこと。パラメータは CloudTrail に平文で記録される（LR-07）。
- **必須** 対話セッション中にパスワード等を入力する必要がある場合、Linux では `stty -echo; read passwd; stty echo;`、Windows では `$Passwd = Read-Host -AsSecureString` のように、ログへの記録を回避する入力手順を運用手順書に定めること。
- **必須** Session Manager のセッション開始・再開・終了が CloudTrail 管理イベント（`StartSession`、`ResumeSession`、`TerminateSession`）として記録されることを構築後に確認し、記録されたイベントの抜粋を 5.2.4 の提出証跡に含めること。`exit` のようにセッション内で完結し API 呼び出しを伴わない操作は CloudTrail および Amazon EventBridge では捕捉されないため、セッション内の操作記録はセッションログ（S3/CloudWatch Logs）で担保する設計とすること。
- **推奨** Run Command の出力を S3 または CloudWatch Logs へ送信すること。既定では先頭 24,000 文字のみが返されるため、全量の保全にはこの設定が必要である。CloudWatch Logs の既定のロググループ名は `/aws/ssm/<ドキュメント名>`、ストリーム名は `<コマンドID>/<インスタンスID>/<プラグインID>/stdout|stderr` である。
- **推奨** 対称 KMS キーによるセッションデータ自体の暗号化を有効化すること（`Standard_Stream`、`InteractiveCommands`、`NonInteractiveCommands` に対応、SSM Agent 2.3.539.0 以上）。有効化後はセッション開始者と対象ノードの双方に鍵の利用権限が必要となる。
- **任意** `ssm:resourceTag/<キー>` および `ssm:SessionDocumentAccessCheck` の条件キーを用いて、接続可能な対象ノードとセッションドキュメントを限定すること。

● 注意

ポートフォワーディング経由および SSH 経由の Session Manager セッションは、仕様上ログを取得できない。SSH は TLS トンネル内で暗号化され、Session Manager は単なるトンネルとして動作するためである。したがって、これらの経路を拒否せずに残すことは、サーバ操作の記録に構造的な欠落を作ることを意味する。要求事項の本文（5.2.2）は、この経路を原則として拒否し、例外を認める場合の条件を定めている。

5.2.3 設計上の注意点

- `aws ssm describe-sessions --state History` は Session Manager 経由で開始された接続のみを返し、RDP や SSH など他の手段による接続を列挙しない。接続経路を Session Manager に一本化しない限り、この一覧を「サーバ操作の網羅的な記録」として提示することはできない（LR-01）。
- CloudWatch Logs への継続ストリーミングは対話コマンドには対応しない。Windows では PowerShell 5.1 以上が必要で、PowerShell Transcription のポリシーが設定されている場合はストリーミングできない。Windows Server 2012 以前ではログ形式が最適でない場合がある。
- セッション履歴のレポートは過去30日分、Run Command の履歴は最大30日である。保存期間要件（第7章）は、セッションログの出力先である S3 または CloudWatch Logs 側で満たす必要がある。Automation の実行履歴の保持期間は公式ドキュメントに明示がないため、採用時に確認を要する事項である。
- AWS Systems Manager Change Manager は 2025年11月7日以降、新規顧客に開放されない。承認フローの基盤として新規に採用できるサービスではない（承認の設計は 5.9 による）。

5.2.4 提出する設定証跡

- セッション設定ドキュメント（`SSM-SessionManagerRunShell`）の内容と、出力先・暗号化設定の画面または CLI 出力。
- SSH／ポートフォワーディングを拒否する IAM ポリシーまたは SCP の本文と、実際に拒否されることを確認した試験結果。例外を許容する場合は、発注者との合意記録と代替統制の記述。
- `StartSession`／`ResumeSession`／`TerminateSession` が記録されたイベントの抜粋。
- CloudWatch エージェント設定ファイル（収集対象ファイル、Windows イベント、ロググループ名を含む）。
- テストセッションのログ出力の抜粋（機微情報を含まないことの確認結果を添える）。
- 対象ノード一覧と、`screen` 導入状況および SSM Agent バージョンの確認結果。

5.2.5 CloudWatch エージェントの設定例

OS の監査ログ（L-05）と、サーバー上のファイルに出力するアプリケーション業務ログ（L-07）を収集する Amazon CloudWatch エージェントの設定例を示す。例は本番環境の Linux（Amazon Linux）と Windows Server を想定したものである。ロググループ名は第4章の命名規則（システムID／環境／コンポーネント／ログ種別）に従い、システムID `acct01`（会計システムを想定した架空の値）で記載している。ファイルパス、ロググループ名、イベントIDは対象システムに合わせてログ設計書で確定すること。

前提となる設計

- **必須** 収集先のロググループはエージェントに自動作成させず、IaC で事前に作成すること。作成時に、保持期間（第7章）、AWS KMS キー（LR-07）、ロググループクラス（Standard。メトリクスフィルターによるアラートを使うため）を設定する。エージェントが作成したロググループは、保持期間が「失効しない」になり、KMS キーも関連付けられない。
- **必須** 設定ファイルに `retention_in_days` を記載しないこと。既存のロググループにこの値を設定すると、指定した日数より前に発行されたログが削除される。保持期間の変更は、ログ管理者（R-5）の承認を経た IaC 変更に限る（LR-05、LR-12、第8章）。
- **必須** エージェントを実行するインスタンスロールに `logs:PutRetentionPolicy` と `logs:DeleteLogGroup` を付与しないこと。AWS 管理ポリシー（`CloudWatchAgentServerPolicy`）を用いる場合も、含まれる権限を確認すること。
- **必須** OS の時刻は Amazon Time Sync Service に同期させ、タイムゾーンは UTC とすること（LR-03）。設定例の `timezone` は、`timestamp_format` を指定した場合にのみ有効である。
- **必須** 設定ファイルは AWS Systems Manager Parameter Store で管理し（パラメータ名は `AmazonCloudWatch-` で始める）、変更は変更管理（LR-12）を経て Run Command で配布すること。

Linux の設定例（`/var/log/audit/audit.log` と `/var/log/secure` は root だけが読み取れるため、エージェントは root で実行する）


```

{
  "agent": {
    "run_as_user": "root",
    "logfile": "/opt/aws/amazon-cloudwatch-agent/logs/amazon-cloudwatch-agent.log"
  },
  "logs": {
    "force_flush_interval": 5,
    "logs_collected": {
      "files": {
        "collect_list": [
          {
            "file_path": "/var/log/audit/audit.log",
            "log_group_name": "/acct01/prod/os/linux-audit",
            "log_stream_name": "{instance_id}",
            "log_group_class": "STANDARD"
          },
          {
            "file_path": "/var/log/secure",
            "log_group_name": "/acct01/prod/os/linux-secure",
            "log_stream_name": "{instance_id}",
            "timestamp_format": "%b %d %H:%M:%S",
            "timezone": "UTC",
            "log_group_class": "STANDARD"
          },
          {
            "file_path": "/opt/acct01/logs/audit/*.json",
            "log_group_name": "/acct01/prod/app/audit",
            "log_stream_name": "{instance_id}",
            "log_group_class": "STANDARD"
          }
        ]
      }
    }
  }
}

```

Windows Server の設定例（Security ログは財務報告に関係する主要なイベントIDに絞り込んだ例）

```

{
  "logs": {
    "logs_collected": {
      "windows_events": {
        "collect_list": [
          {
            "event_name": "Security",
            "event_ids": [4624, 4625, 4634, 4648, 4672, 4720, 4722, 4724,
                          4725, 4726, 4728, 4732, 4738, 4740, 4756, 1102],
            "event_format": "xml",
            "log_group_name": "/acct01/prod/os/windows-security",
            "log_stream_name": "{instance_id}"
          },
          {
            "event_name": "System",
            "event_levels": ["WARNING", "ERROR", "CRITICAL"],
            "event_format": "xml",
            "log_group_name": "/acct01/prod/os/windows-system",
            "log_stream_name": "{instance_id}"
          }
        ]
      }
    }
  }
}

```

表5-1 Windows Security ログの収集対象イベントID（設定例）

イベントID	内容	統制上の用途
4624／4625／4634	ログオン成功／失敗／ログオフ	認証の記録、不正ログオン試行の検知（L-04、L-05）
4648／4672	明示的な資格情報によるログオン／特別な権限の割り当て	特権の利用記録（第10章の特権ID管理）
4720／4722／4724／4725／4726／4738	アカウントの作成／有効化／パスワードリセット／無効化／削除／変更	アクセス権の付与・変更・削除の証跡（ITGC-C）
4728／4732／4756	セキュリティグループへのメンバー追加	権限昇格の検知
4740	アカウントのロックアウト	認証失敗の多発の検知
1102	監査ログの消去	ログの改ざん・消去試行の検知（LR-04）

- **必須** `event_ids` で収集対象を絞り込む場合は、対象IDを発注者と合意し、ログ設計書に記載すること。Security ログに監査イベントが出力されるよう、監査ポリシー（ログオン、アカウント管理、特権の使用）をOS側で有効にすること。
- **推奨** Linux では、`auditd` の監査ルール（特権コマンドの実行、`/etc/sudoers` など認証設定ファイルの変更）をOS側で設定し、収集される内容をログ設計書に記載すること。

● 注意

Amazon Linux 2023 は既定で `rsyslog` を導入しておらず、`/var/log/secure` が生成されない。採用するOSのバージョンで収集対象ファイルが実在することを構築時に確認し、存在しない場合は `rsyslog` を導入するなどして認証ログをファイルに出力させること。

配布と確認

```
# Parameter Store の設定を読み込んでエージェントを起動する (Linux)
sudo /opt/aws/amazon-cloudwatch-agent/bin/amazon-cloudwatch-agent-ctl \
  -a fetch-config -m ec2 -s -c ssm:AmazonCloudWatch-acct01-prod-linux

# 稼働状態の確認（出力を設定証跡として保存する）
sudo /opt/aws/amazon-cloudwatch-agent/bin/amazon-cloudwatch-agent-ctl -a status

# ロググループの保持期間・KMS キー・クラスが IaC の定義と一致することの確認
aws logs describe-log-groups --log-group-name-prefix /acct01/prod/ \
  --query 'logGroups[][logGroupName,retentionInDays,kmsKeyId,logGroupClass]' \
  --output table
```

- **必須** エージェントの停止や送信失敗を検知するため、各ロググループの取り込み件数（IncomingLogEvents メトリクス）の急減をアラートの対象とすること（LR-11、第9章）。
- **必須** Parameter Store の設定値とバージョン履歴、および上記コマンドの出力を、5.2.4 の設定証跡として提出すること。

5.3 Amazon RDS／Amazon Aurora／Amazon DynamoDB の監査ログ

5.3.1 役割と対応する要求事項

本節は L-06（データベース監査ログ）を扱う。ただし Amazon DynamoDB のデータプレーン操作は CloudTrail データイベントで取得するため、ログ種別としては L-02（データアクセスログ）にも該当する。第3章のマトリクスおよび 5.11 の責任分界表では L-02 の行に記載すること。ITGC-C および ITGC-B に対応するとともに、IT業務処理統制を補完する位置づけを持つ。すなわち、アプリケーションの承認フローを経由せずにデータベースへ直接接続してデータを変更する経路が存在する場合、その操作を記録できるかどうか、業務処理統制の有効性を支える前提となる。要求事項は LR-01、LR-02、LR-04、LR-05（保存期間とライフサイクル）、LR-06、LR-07、LR-08、LR-12（ログ設定の変更管理）に該当する。

● 監査の視点

実施基準は経営者評価において、「自動化された IT に係る業務処理統制であっても過信せずに、内部統制の無効化のリスクを完全に防ぐことは困難であるという視点を持つことが重要である」としている（2023年改訂で追加）。監査人も、この前提を踏まえて経営者の評価を検証する。典型的な着眼点は、決算締切後に会計データを直接修正するなど、統制を迂回した更新が行われていないかである。データベース監査ログは、この問いに答えるための一次証跡となる。したがって、少なくとも「誰が」「いつ」「どの接続元から」「どのオブジェクトに対し」「どの種類の更新を行ったか」を再構成できる記録項目（LR-02）を確保する必要がある。

5.3.2 設定要件

- **必須** 財務報告に関連するデータを保持するデータベースについて、少なくとも接続（成功・失敗）、DDL、DCL、および更新系 DML を監査対象とすること。エンジン別の方式は表5-2 による。
- **必須** 監査ログを Amazon CloudWatch Logs に発行すること（RDS for Db2 を除く。RDS for Db2 の監査ログは CloudWatch Logs に発行できないため、後述の RDS for Db2 の項により Amazon S3 へ出力する）。Amazon RDS はホスト上のログファイルへの直接アクセスを提供しないため、インスタンス外への発行が保全の前提となる。ロググループは `/aws/rds/instance/<インスタンス名>/<ログ種別>`（クラスターの場合は `/aws/rds/cluster/<クラスター名>/<ログ種別>`）に自動作成される。

- **必須** 発行先ロググループの保持期間を明示的に設定すること。既定では保持期間が設定されず「Never Expire」となる。設定値の決定は第7章による。
- **必須** Amazon DynamoDB を業務データの格納に用いる場合、CloudTrail のデータイベント（リソースタイプ `AWS::DynamoDB::Table`、ストリームを利用する場合は `AWS::DynamoDB::Stream`）を有効化すること。データプレーンの操作は既定では記録されない。
- **必須** データベース監査の設定変更（パラメータグループ、オプショングループ、クラスターパラメータグループの変更）は CloudTrail 管理イベントとして記録される。これらを LR-12（ログ設定の変更管理）の監視対象に含めること。RDS for Db2 の `DB2_AUDIT` オプションの追加・削除・設定変更（出力先バケットの変更を含む）もオプショングループの変更として記録されるが、データベースごとの監査ポリシーの設定・変更・無効化は記録されない（後述）。
- **必須** オプショングループへのプラグイン追加・削除は、停止や再起動を伴う可能性がある。本番適用はメンテナンスウィンドウで行い、適用手順と結果を変更管理の記録に含めること。
- **必須** Amazon Aurora PostgreSQL および RDS for PostgreSQL では、ネイティブの `log_statement` を既定値 `none` のまま維持し、監査は pgAudit で行うこと。`none` 以外の値はパスワードを含むステートメントが記録されるおそれがある（LR-07）。
- **必須** データベース監査ログのタイムスタンプが、形式にタイムゾーン表記を含まない場合がある（例：`YYYYMMDD HH:MI:SS`）。当該ログの時刻が UTC かインスタンスのタイムゾーン設定に従うかを公式ドキュメントで確認し、確認結果と、5.12 で定める時刻表記の規約との突合方法をログ設計書に明記すること。
- **必須** RDS for Db2 では、カスタムオプショングループに `DB2_AUDIT` オプションを追加し、オプション設定 `IAM_ROLE_ARN`（出力先バケットへの書き込みを許可した IAM ロール）と `S3_BUCKET_ARN`（出力先バケット）を指定すること。オプションの追加に DB インスタンスの再起動は要しない。出力先バケットは DB インスタンスと同一リージョンに置き、バケットの所有者と IAM ロールの所有者を同一とする必要がある（RDS はバケットと DB インスタンスが同一アカウントの所有であることを確認する）。このため、ログアーカイブアカウントのバケットを直接の出力先にはできない。ワークロードアカウントに一次保全用バケットを置き、ログアーカイブアカウントの logs バケットへ S3 レプリケーションで複製すること（6.2・表6-3。S3 サーバーアクセスログと同じ構成）。
- **必須** RDS for Db2 の一次保全用バケットには、バージョニング、パブリックアクセスブロック、TLS 強制を適用し、オブジェクトの削除と、ライフサイクル設定・バケットポリシー・レプリケーション設定の変更をバケットポリシーと SCP で拒否すること（ログ管理者ロールおよび IaC パイプラインの実行ロールのみ除外）。Object Lock を有効化する場合、RDS からのアップロードと複製が成功することを構築時に実機で確認すること。Object Lock を適用できない場合は、上記を代替統制とし、複製完了までの無保護時間を残存リスクとして発注者の承認を得ること。出力先を SSE-KMS で暗号化する場合、IAM ロールのポリシーとキーポリシーの双方で当該ロールに `kms:GenerateDataKey` と `kms:Decrypt` を許可すること。
- **必須** RDS for Db2 では、`DB2_AUDIT` オプションを追加したうえで、データベースごとに監査ポリシーを設定することで当該データベースの監査が有効になる。マスターユーザーで `rdsadmin` データベースに接続し、財務報告に関連するデータを保持する各データベースについて `rdsadmin.configure_db_audit` を実行すること。DB インスタンスにデータベースを追加する場合に備え、データベース作成手順に監査ポリシーの設定を組み込むこと。
- **必須** RDS for Db2 の監査カテゴリ `ALL` は `AUDIT`・`CHECKING`・`OBJMAINT`・`SECMAINT`・`SYSADMIN`・`VALIDATE` を対象とし、`CONTEXT`・`EXECUTE`・`ERROR` を含まない。本項冒頭の監査対象のうち、接続（成功・失敗）は `VALIDATE`（利用者の認証）、DDL は `OBJMAINT`（オブジェクトの作成・削除等）、DCL は `SECMAINT`（権限の付与・取消等）で記録されるが、更新系 DML を含む SQL 文の実行内容（文のテキスト）は `EXECUTE` で記録される。`ALL` を `BOTH`（成功と失敗）で設定したうえで、`EXECUTE` を個別に設定すること（表5-2）。

- 必須** RDS for Db2 のデータベースごとの監査ポリシーの設定・変更・無効化（`rdsadmin.disable_db_audit`）は、マスターユーザーがデータベース接続上でストアードプロシージャを実行して行う。AWS の API 操作ではないため CloudTrail には記録されない。このため、(1) 実行するスクリプトと実行記録を LR-12 の変更管理の対象とし、(2) 監査設定の変更と監査ログへのアクセスを記録する AUDIT カテゴリを監査ポリシーに含め（ALL に含まれる）、(3) `rdsadmin.get_task_status` による設定状態の確認を月次のレビュー（表9-2 の RV-10）に含め、(4) マスターユーザーを特権IDとして管理すること（第10章）。
- 推奨** 参照系（SELECT）を監査対象に含めるか否かを発注者と協議して決定すること。Aurora MySQL では SELECT のみを除外する仕組みがなく、除外するには DML 全体を除外する必要がある。一方、RDS for MySQL では `SERVER_AUDIT_EVENTS` に `QUERY_DML_NO_SELECT` を指定することで SELECT を除いた更新系 DML のみを記録できる（RDS for MariaDB での可否は確認すること）。RDS for Db2 の `EXECUTE` カテゴリには参照系のみを除外する設定がなく、SQL 文の実行を記録すると参照系も記録される。監査範囲はログ量とコストを直接左右する。
- 推奨** ヘルスチェック等により高頻度で接続する管理用アカウント（`rdsadmin` 等）を除外設定の対象とすること。除外した場合は、除外した識別子と理由をログ設計書に記載すること。RDS for Db2 の `rdsadmin.configure_db_audit` には利用者単位で対象を指定するパラメータがない（データベース単位で設定する）。
- 推奨** RDS for Db2 の `EXECUTE` は、設定値に `WITH` を付すとホスト変数・パラメータマーカーへの入力値も記録する（既定は `WITHOUT`）。機微情報が記録されうるため `WITHOUT` を基本とし、`WITH` とする場合は LR-07 に照らして記録範囲と閲覧権限を発注者と協議すること。
- 推奨** RDS for Db2 の `ERROR` カテゴリを `AUDIT` に設定すること。既定の `NORMAL` では監査機能自身が生成したエラーは無視され、実行した操作に関するエラーの `SQLCODE` のみが記録される。監査ログ欠落の原因特定（LR-11）に用いる。
- 推奨** RDS for Db2 で CloudWatch Logs に発行できるのは診断ログ（`diag.log`）と通知ログ（`notify.log`）であり（ロググループは `/aws/rds/instance/<インスタンス名>/diagnostic` と `/aws/rds/instance/<インスタンス名>/notify`）、監査ログの代替にはならない。障害調査に備えて発行し、保持期間を明示的に設定すること。
- 任意** Database Activity Streams を採用すること。データベース管理者が収集・伝送・保存・処理の過程に関与できない構成であり、職務分掌（LR-06）の観点で有利である。ただし Amazon Kinesis Data Streams の料金が発生し、KMS による暗号化が必須となる。RDS for Db2 は Database Activity Streams に対応していない。

表5-2 エンジン別のデータベース監査ログ方式

エンジン	監査方式	有効化に用いる設定	主な既定値	出力先	主な制約
Aurora MySQL	高度な監査 (Advanced Auditing)	クラスターパラメータ <code>server_audit_logging</code> を ON、 <code>server_audit_events</code> に <code>CONNECT</code> ／ <code>QUERY</code> ／ <code>QUERY_DCL</code> ／ <code>QUERY_DDL</code> ／ <code>QUERY_DML</code> ／ <code>TABLE</code> を大文字カンマ区切りで指定。対象利用者は <code>server_audit_incl_users</code> / <code>server_audit_excl_users</code>	<code>server_audit_logging</code> は OFF、 <code>server_audit_events</code> は空、対象利用者の指定なし (全利用者)	インスタンスのローカル (<code>audit/audit.log</code> *)。CloudWatch Logs へはログ種別 <code>audit</code> を発行設定	SELECT のみの除外は不可。ローカルは4ファイルに分散し1ファイル最大100MB (変更不可)。エントリは時系列順ではなく timestamp でのソートが必要
RDS for MySQL・RDS for MariaDB	MariaDB Audit Plugin (オプショングループ)	(以下は RDS for MySQL 向けドキュメントの記載) オプション <code>MARIADB_AUDIT_PLUGIN</code> を追加し、 <code>SERVER_AUDIT_EVENTS</code> (有効値: <code>CONNECT</code> ／ <code>QUERY</code> ／ <code>QUERY_DDL</code> ／ <code>QUERY_DML</code> ／ <code>QUERY_DML_NO_SELECT</code> ／ <code>QUERY_DCL</code> 。 <code>QUERY_DML_NO_SELECT</code> は <code>QUERY_DML</code> から <code>SELECT</code> を除いたもの)、 <code>SERVER_AUDIT_INCL_USERS</code> / <code>SERVER_AUDIT_EXCL_USERS</code> 、 <code>SERVER_AUDIT_FILE_ROTATE_SIZE</code> 、 <code>SERVER_AUDIT_FILE_ROTATIONS</code> 、 <code>SERVER_AUDIT_QUERY_LOG_LIMIT</code> を設定	(以下は RDS for MySQL 向けドキュメントの記載) <code>SERVER_AUDIT_EVENTS</code> は <code>CONNECT,QUERY</code> ／ローテーションサイズ 1,000,000 バイト／世代数 9 / <code>SERVER_AUDIT_QUERY_LOG_LIMIT</code> 1024	<code>/rdsdbdata/log/audit/</code> (パス固定)。CloudWatch Logs へはログ種別 <code>audit</code> を発行設定	MySQL では <code>TABLE</code> イベント非対応。 <code>SERVER_AUDIT_LOGGING</code> は ON のみで無効化できず、停止にはプラグイン削除 (自動再起動) が必要。RDS for MariaDB については設定値・既定値・有効イベント (<code>QUERY_DML_NO_SELECT</code> と <code>TABLE</code> の可否を含む)・対応バージョンを RDS for MariaDB 向けの公式ドキュメントで確認すること
Aurora PostgreSQL・RDS for PostgreSQL	pgAudit 拡張	<code>shared_preload_libraries</code> に <code>pgaudit</code> を追加 (pending-reboot) →再起動→ <code>CREATE EXTENSION pgaudit</code> ; → <code>pgaudit.log</code> を設定→再起動。オブジェクト監査は <code>pgaudit.role</code>	<code>pgaudit.log</code> は <code>none</code> (記録しない)。 <code>pgaudit.role</code> の許容値は <code>rds_pgaudit</code> のみ	データベースログ。CloudWatch Logs へはログ種別 <code>postgresql</code> 等を発行設定	導入時に再起動が2回必要。設定には <code>rds_superuser</code> 権限が必要。ストレージ消費の監視が必要

エンジン	監査方式	有効化に用いる設定	主な既定値	出力先	主な制約
RDS for Db2	Db2 監査ログ記録（オプショングループの DB2_AUDIT と、データベースごとの監査ポリシー）	オプション DB2_AUDIT を追加し、IAM_ROLE_ARN と S3_BUCKET_ARN を設定（再起動不要）→マスターユーザーで rdsadmin データベースに接続し、データベースごとに rdsadmin.configure_db_audit('<DB名>', '<カテゴリ>', '<設定値>', ?) を実行。カテゴリは ALL（AUDIT／CHECKING／OBJMAINT／SECMAINT／SYSADMIN／VALIDATE）、CONTEXT、EXECUTE、ERROR。設定値は BOTH／SUCCESS／FAILURE／NONE（EXECUTE はこれに WITH／WITHOUT を付す。ERROR は AUDIT／NORMAL）。設定状態は rdsadmin.get_task_status で確認	オプション未追加・監査ポリシー未設定では記録しない。EXECUTE は入力値を記録しない（WITHOUT）、ERROR は NORMAL	S3_BUCKET_ARN で指定した S3 バケット（DB インスタンスと同一アカウント・同一リージョン）の db2-audit-logs/<リソースID>/<日時（UTC）>/（データベース単位は末尾に <DB名>/）。CloudWatch Logs へは発行できない	ALL は CONTEXT・EXECUTE・ERROR を含まない。参照系のみ除外、利用者単位の対象指定はできない。監査ポリシーの変更・無効化は CloudTrail に記録されない。S3 への反映は完了したログファイル単位（有効化後は少なくとも1時間待つよう案内されている）。Database Activity Streams は非対応
DynamoDB	CloudTrail データイベント（L-02 に該当）	証跡（trail）の基本イベントセクタでデータリソースタイプ AWS::DynamoDB::Table を指定するか、高度なイベントセクタで resources.type に AWS::DynamoDB::Table（必要に応じ AWS::DynamoDB::Stream）を指定。イベントデータストア（AWS CloudTrail Lake）は高度なイベントセクタのみに対応するが、5.7.2 により新規設計では用いない	データイベントは記録しない（追加料金あり）	CloudTrail の送信先（S3／CloudWatch Logs）	Time to Live のデータプレーン操作は記録されない。Streams の GetRecords はサービス起因の呼び出しにより件数が増大しうる

5.3.3 設計上の注意点

- Database Activity Streams を採用する場合、Aurora MySQL では同期モードを利用できず非同期モードのみとなる。RDS（非 Aurora）では Amazon RDS for Oracle と RDS for SQL Server が対象で、常に非同期である（RDS for Db2、RDS for MySQL、RDS for MariaDB、RDS for PostgreSQL は対象外）。リードレプリカと Oracle の CDB は対象外である。Aurora PostgreSQL ではメジャーバージョンアップ前に停止が必要である。
- DynamoDB のデータイベントは件数課金である。サービス起因の呼び出しを含めるか否かで費用が大きく変わるため、記録範囲は発注者との合意事項となる。
- 監査ログの有効化は、監査対象の操作が実際に記録されることをもって完了とする。設定値の投入のみでは設定完了とはいえない（第11章のテスト観点）。
- RDS for Db2 の監査ログは完了したログファイル単位で S3 にアップロードされる。公式ドキュメントは、有効化後、S3 で監査データを確認できるまで少なくとも1時間待つよう案内している。到着までの遅延を構築時に実測してログ設計書に記載し、リアルタイム検知を前提とした設計にしないこと（A-22・A-23 の実装は第9章による）。

- RDS for Db2 の監査ログファイルの形式（Athena で直接検索できるか、`db2audit extract` 等による変換を要するか）を構築時に実ファイルで確認し、検索・抽出の手順（LR-10）をログ設計書に記載すること。変換を要する場合は、変換の手順と、変換前後の件数照合など変換結果の完全性を確認する方法も記載すること。
- S3 レプリケーションは複製元と同じオブジェクトキーで複製するため、logs バケット内の RDS for Db2 の監査ログは `db2-audit-logs/<DB インスタンスのリソース ID>/...` のパスとなり、アカウント ID・リージョンを含まない。リソース ID とアカウント・リージョン・インスタンス名との対応表をログ設計書に記載すること（6.5.1）。

5.3.4 提出する設定証跡

- パラメータグループ、クラスターパラメータグループ、オプショングループの設定値一覧（既定値からの差分を明示）。
- CloudWatch Logs への発行設定（`EnableLogTypes` の内容）と、発行先ロググループの保持期間設定。
- AWS Config ルール `rds-logging-enabled` の評価結果。
- DynamoDB を利用する場合、CloudTrail のイベントセクタ設定内容（`aws cloudtrail get-event-selectors` の出力。基本イベントセクタ／高度なイベントセクタのいずれで構成したかを明示すること）。
- データベース監査ログの時刻系の確認結果と、5.12 の時刻表記規約との突合結果。
- RDS for Db2 を利用する場合、`DB2_AUDIT` オプションの設定内容（`aws rds describe-option-groups` の出力）、データベースごとの監査ポリシーの設定状態（`rdsadmin.get_task_status` の出力）、一次保全用バケットのバケットポリシー・バージョニング・Object Lock・レプリケーション設定、および logs バケットに複製された監査ログの抜粋。なお AWS Config ルール `rds-logging-enabled` は RDS のログ（ログ種別）の有効化を評価するルールであり、`DB2_AUDIT` オプションやデータベースごとの監査ポリシーの状態を評価する旨は公式ドキュメントに記載されていない。これらは上記の出力で確認すること。
- テストで実行した DDL・更新系 DML・接続失敗が、監査ログに期待どおり記録されたことを示す抜粋（利用者・時刻・接続元・対象オブジェクト・操作種別が確認できること）。

5.4 ネットワーク・エッジログ（VPC Flow Logs、ELB、AWS WAF、Amazon CloudFront、API Gateway）

5.4.1 役割と対応する要求事項

本節は L-11（ネットワーク・通信ログ）を扱う。財務報告に係る内部統制における位置づけは、**主に ITGC-C（内外部からのアクセス管理などシステムの安全性の確保）の補助証跡**である。ネットワークログは、取引が承認されたこと（正当性）、記録に漏れ・重複がないこと（完全性）、金額や科目が正しく記録されたこと（正確性）を直接立証するものではない。その用途は、不正アクセスや侵害の疑いが生じた際の調査、アクセス経路が設計どおりであることの確認、および他のログ種別と突合するための補完情報の提供にある。

したがって本節の要求レベルは推奨および任意にとどめ、必須要件は置かない。対応する要求事項は LR-01、LR-05、LR-08、LR-10 である。

● 補足

ネットワークログを財務報告統制の必須要件としないことは、取得しなくてよいという意味ではない。発注者のセキュリティ方針や他の規程により取得が求められる場合があり、また侵害調査の起点として実務上の価値が高い。本ガイドラインでは「財務報告に係る内部統制の受入条件」としては必須としない、という限定である。採否と保存期間は発注者と協議して決定すること。

5.4.2 設定要件

各ログの位置づけ・送信先・要求レベル・主な制約は表5-3 に整理する。

- **推奨** 財務報告に関連するシステムを収容する VPC について VPC Flow Logs を有効化すること。最大集約間隔は既定10分で、作成時に1分を選択できる。記録形式は既定のフィールド構成に加え、`vpc-id`、`subnet-id`、`instance-id`、`flow-direction` 等を含むカスタム形式を検討すること。
- **推奨** Application Load Balancer のアクセスログを有効化すること。既定では無効である。Network Load Balancer のアクセスログは TLS リスナーがある場合にのみ作成され、TLS リクエストの情報のみを含む点に留意すること。
- **推奨** AWS WAF を利用する場合、そのログを有効化すること。CloudWatch Logs のロググループ名および S3 バケット名は `aws-waf-logs-` で始まる必要がある。ロググループは Web ACL と同一リージョン・同一アカウントで構成すること。
- **推奨** Amazon API Gateway（REST API）のアクセスログを有効化し、`$context.requestId` または `$context.extendedRequestId` を必ず出力項目に含めること。これによりアプリケーション業務ログ（L-07）との突合が可能になる。実行ログのレベルは ERROR または INFO とすること。
- **推奨** 取得することとしたネットワーク・エッジログについて、網羅性の限界（5.4.3 に示す記録対象外の通信、およびベストエフォート配信であること）を LR-01 の記述に含めること。
- **任意** Amazon CloudFront の標準ログを有効化すること。新規構築では、配信先とフィールドを選択できる新しい形式を用いること。
- **任意** Amazon Route 53 Resolver のクエリログを有効化すること。
- **任意** ネットワーク・エッジログの送信先を、基盤ログと同じログアーカイブアカウント（5.10）に集約すること。

表5-3 ネットワーク・エッジログの位置づけと主な制約

ログ	主な内容・用途	送信先	要求レベル	主な制約
VPC Flow Logs	ネットワークフローの受理・拒否。アクセス経路の妥当性確認と侵害調査	CloudWatch Logs／S3／Amazon Data Firehose	推奨	リアルタイムストリームではない。作成後に構成・記録形式を変更できず、削除して再作成が必要。特定の通信は記録されない
ELB アクセスログ	リクエスト単位の到達記録。障害調査と利用状況の確認	S3（CloudWatch Logs 経由の配信にも対応）	推奨	ベストエフォート配信。ノードごとに5分間隔で発行。新フィールドは末尾に追加される
AWS WAF ログ	検査結果と適用ルール。攻撃遮断の記録	CloudWatch Logs／S3／Amazon Data Firehose	推奨	ロググループ名・バケット名の接頭辞が固定。S3 は5分間隔配信
API Gateway ログ	API 呼び出しの記録。業務ログとの突合	CloudWatch Logs	推奨	リクエスト識別子の出力設定が必要。データトレースは機微情報を記録しうするため本番では用いない
CloudFront 標準ログ	エッジでの配信記録	CloudWatch Logs／S3／Amazon Data Firehose	任意	旧来の形式は S3 バケットの ACL 有効化を要する。1ディストリビューションにつき配信元は1つ
Route 53 Resolver クエリログ	DNS 問い合わせと応答	CloudWatch Logs／S3／Amazon Data Firehose	任意	キャッシュから応答されたクエリは記録されない

5.4.3 設計上の注意点

- VPC Flow Logs は、Amazon が提供する DNS サーバへの通信、169.254.169.254（インスタンスメタデータ）、169.254.169.123（時刻同期）、DHCP、ARP など一部の通信を記録しない。ネットワークログは「通信の完全な記録」ではなく、網羅性に構造的な限界がある。
- ELB のアクセスログはベストエフォート配信であり、欠落・遅延・重複が生じうる。件数の完全一致を前提とした統制（例: 件数照合）の根拠には用いられない。
- ログの解析処理を作り込む場合、将来のフィールド追加に耐える実装（列数を固定しない、末尾の追加を許容する）が前提となる。
- ネットワーク・エッジログは量が大きく、保存期間の設定がコストに直結する。保存期間とストレージクラス的设计は第7章による。
- ELB および CloudFront は CloudWatch Logs を介した配信に対応している。対応状況と設定方法は変更されるため、採用時点の公式ドキュメントの確認を要する。

5.4.4 提出する設定証跡

5.4.2 で取得することとしたログについて、次を提出すること。

- ネットワーク・エッジログの有効化状態一覧（サービス、リソース識別子、送信先、記録形式、集約間隔）。取得しないこととしたログがある場合は、その旨と理由。
- AWS Config ルール `vpc-flow-logs-enabled` の評価結果。
- 送信先バケットおよびロググループの命名規約への適合確認結果。
- 各ログのサンプルレコード1件とフィールド定義（解析基盤への取り込み仕様を含む）。

5.5 セキュリティ検知（Amazon GuardDuty、AWS Security Hub、Amazon Detective、Amazon Inspector、Amazon Security Lake）

5.5.1 役割と対応する要求事項

本節は L-12（セキュリティ検知ログ）を扱う。本書で **AWS Security Hub CSPM** と表記するものは、セキュリティ標準に基づくコントロール評価を行う機能を指し、固定ID L-12 にいう「Security Hub」はこれを指す。以後、本書の要求事項・証跡における表記は AWS Security Hub CSPM に統一する。ITGC-C に対応し、LR-08（監視とアラート）、LR-09（定期レビューと証跡化）、LR-11（バックアップ・可用性・欠損検知）、LR-12（ログ設定の変更管理）に該当する。これらのサービスは発見的統制であり、アクセス制御や SCP といった予防的統制の代替とはならない。両者を組み合わせて設計すること。

また、内部統制報告制度の改訂において、クラウドやリモートアクセス等の技術を活用するにあたりサイバーリスクの高まりを踏まえた情報システムのセキュリティ確保が重要である旨が明記されている。セキュリティ検知の構成は、この要請に対する実装の一部として位置づけられる。

5.5.2 設定要件

- **必須** Amazon GuardDuty を、財務報告に関連するシステムが稼働するすべてのリージョンで有効化すること。AWS Organizations を利用する場合、委任管理者はリージョンごとに指定する必要がある、かつ全リージョンで同一のアカウントを指定する必要がある。
- **必須** GuardDuty の検出結果を Amazon S3 へエクスポートする設定を行うこと。検出結果の保持は90日であり、それを超える保全にはエクスポートが必要である。エクスポートには KMS による暗号化が必須で、バケットと KMS キーは同一リージョンに置く。出力パスは `/AWSLogs/<アカウントID>/GuardDuty/<リージョン>` であり、フォルダは事前に作成しておく必要がある。
- **必須** エクスポート設定はリージョンごとに必要である。有効化した全リージョンについて設定漏れがないことを確認すること。
- **必須** AWS Security Hub CSPM を有効化し、AWS Config によるリソース記録（第4章）が前提であることを設計に反映すること。CIS AWS Foundations Benchmark のチェックを完全に成立させるには、対応するすべてのリージョンで有効化する必要がある。
- **必須** 採用する CIS AWS Foundations Benchmark のバージョンを発注者と合意し、記録すること。バージョンにより自動チェックの範囲が異なる。CIS の監視項目と本ガイドラインの固定ID の対応は表5-4 による。
- **必須** CloudWatch メトリクスフィルターによる監視項目を実装する場合、CIS が規定するフィルターパターンと完全に一致させること。フィールドや語句を追加すると評価が不合格となる。代表的なパターンは次のとおりである。

```

CloudWatch.1（ルートユーザーの使用）
{$.userIdentity.type="Root" && $.userIdentity.invokedBy NOT EXISTS && $.eventType != "AwsServiceEvent"}}

CloudWatch.5（CloudTrail 設定の変更）
{($.eventName=CreateTrail) || ($.eventName=UpdateTrail) || ($.eventName=DeleteTrail) ||
 ($.eventName=StartLogging) || ($.eventName=StopLogging)}

CloudWatch.6（コンソール認証の失敗）
{($.eventName=ConsoleLogin) && ($.errorMessage="Failed authentication")}}

CloudWatch.7（カスタマーマネージドキーの無効化・削除予約）
{($.eventSource=kms.amazonaws.com) && (($.eventName=DisableKey) || ($.eventName=ScheduleKeyDeletion))}

CloudWatch.9（AWS Config 設定の変更）
{($.eventSource=config.amazonaws.com) && (($.eventName=StopConfigurationRecorder) ||
 ($.eventName=DeleteDeliveryChannel) || ($.eventName=PutDeliveryChannel) ||
 ($.eventName=PutConfigurationRecorder))}

```

- **推奨** Security Hub CSPM のクロスリージョン集約（集約リージョン）を構成し、検出結果を1か所で参照できるようにすること。
- **推奨** Amazon Inspector を有効化し、EC2、コンテナイメージ、関数の脆弱性検出結果を Security Hub CSPM に集約すること。
- **任意** Amazon Detective を有効化すること。CloudTrail、VPC フローログ、GuardDuty の検出結果から行動グラフを生成し、最大1年分の履歴イベントデータを参照できる。
- **任意** Amazon Security Lake を採用し、取り込んだログを Apache Parquet と OCSF に正規化して保持すること。採用する場合の委任管理者はログアーカイブアカウントとすることが推奨されている。

表5-4 CIS の監視項目と本ガイドラインの固定IDの対応

コントロール	検知対象	根拠となるログ種別	関連する要求事項	自動チェックの対象となるバージョン
CloudWatch.1	ルートユーザーの使用	L-04	LR-06、LR-08	v1.2.0、v1.4.0
CloudWatch.2	未認可の API 呼び出し	L-01	LR-08	v1.2.0 のみ（v1.4.0 以降は manual check）
CloudWatch.3	MFA なしのコンソールサインイン	L-04	LR-06、LR-08	v1.2.0 のみ（v1.4.0 以降は manual check）
CloudWatch.4	IAM ポリシーの変更	L-01、L-04	LR-06、LR-08	v1.2.0、v1.4.0
CloudWatch.5	CloudTrail 設定の変更	L-14	LR-04、LR-12	v1.2.0、v1.4.0
CloudWatch.6	コンソール認証の失敗	L-04	LR-08	v1.2.0、v1.4.0
CloudWatch.7	カスタマーマネージドキーの無効化・削除予約	L-01、L-14	LR-04、LR-07	v1.2.0、v1.4.0
CloudWatch.8	S3 バケットポリシーの変更	L-01、L-14	LR-04、LR-06	v1.2.0、v1.4.0
CloudWatch.9	AWS Config 設定の変更	L-03、L-14	LR-12	v1.2.0、v1.4.0
CloudWatch.10～14	セキュリティグループ、ネットワークACL、ゲートウェイ、ルートテーブル、VPC の変更	L-01、L-11	LR-08	v1.2.0、v1.4.0

● 注意

CIS AWS Foundations Benchmark の「モニタリング」に相当する CloudWatch.1～14 のコントロールは、採用するバージョンにより自動チェックの可否が異なる。v1.2.0 では CloudWatch.1～14 の全14項目が自動チェックの対象である。v1.4.0 では CloudWatch.2（未認可の API 呼び出し）および CloudWatch.3（MFA なしのコンソールサインイン）が「Not supported – manual check」となり、残る12項目のみが自動チェックの対象である。v3.0.0 および v5.0.0 では CloudWatch.1～14 のすべてが「Not supported – manual check」として扱われる。すなわち、新しいバージョンを採用するほど、これらの監視項目について Security Hub CSPM による自動的な合否判定が得られなくなる。自動チェックの対象外となる項目については、採用バージョンにかかわらず、開発ベンダーは対応するメトリクスフィルターとアラームを自ら設計・実装し、その設定内容と稼働確認の結果を代替的な証拠として提出すること。採用バージョンは発注者との合意事項である。

5.5.3 設計上の注意点

- Security Hub CSPM の評価は AWS Config によるリソース記録に依存する。設定レコーダーが停止されると評価結果が得られなくなるため、レコーダーの停止・削除を LR-12 の監視対象および 5.10 の予防的統制の対象に含める必要がある。
- GuardDuty の初回有効化時には、一部の保護プランを除いて全保護プランが自動的に有効化され、無料トライアル期間が設定される。トライアル終了後の費用影響は発注者との事前合意事項となる。
- 新規の検出結果は約5分以内に Amazon EventBridge へ配信されるが、更新された検出結果の配信頻度は既定で6時間である。適時性を要する統制では配信頻度の設定が前提条件となる。
- アーカイブ済みの検出結果は S3 へエクスポートされない。抑制ルールでアーカイブする運用を採る場合、抑制対象が証拠から欠落するため、抑制条件の文書化が必要である。
- AWS Organizations の変更を検知するメトリクスフィルターについては、Security Hub CSPM のコントロールとして提供されておらず、公式のパターン文字列も確認できない。必要とする場合は自組織で定義し、設計レビューで妥当性を確認する必要がある。
- 露出可視化の機能はリスク分析の用途に適するが、統制の有効性を示す証拠としてはコントロール評価結果を用いること。

5.5.4 提出する設定証拠

- GuardDuty の有効化リージョン一覧、委任管理者の設定、および検出結果エクスポート先の設定内容。
- Security Hub CSPM の有効化状態、有効な標準とそのバージョン（標準の ARN を含む）、および構築時点のコントロール評価結果。
- 実装したメトリクスフィルターとアラームの定義（フィルターパターン文字列を含む）、および通知経路（5.6）との対応。
- 採用した CIS バージョンと、自動チェック対象外となる項目に対する代替実装の一覧。
- AWS Config ルール `guardduty-enabled-centralized`、`securityhub-enabled` の評価結果。

5.6 通知・自動化（Amazon EventBridge、Amazon SNS、AWS Lambda、Amazon Data Firehose）

5.6.1 役割と対応する要求事項

本節は、検知した事象を担当者へ確実に届けるための経路と、ログを外部へ転送するための経路の設定要件を扱う。ITGC-B に対応し、LR-04（改ざん防止と完全性の保証）、LR-08（監視とアラート）、LR-11（可用性・欠損検知）および LR-12（ログ設定の変更管理）に該当する。ログ種別としては、L-14（ログ基盤自身の監査ログ）を含む各種ログの検知結果を通知し、またログを外部基盤へ転送するための経路にあたる。通知経路の設定変更自体も L-14 の記録対象となる。アラートのしきい値、エスカレーション先、レビューの頻度と記録様式は第9章に定める。

5.6.2 設定要件

- 必須** CloudTrail から CloudWatch Logs への連携（第4章）を前提として、メトリクスフィルター、CloudWatch アラーム、Amazon SNS トピックからなる通知経路を構成すること。
- 必須** SNS のサブスクリプションが「確認済み」の状態であることを構築完了時に確認し、記録すること。未確認のサブスクリプションは48時間で削除される。
- 必須** 通知経路の生存確認（テスト通知を送出し、受信を確認する手続）を定期的実施する手順を運用設計に含めること。実施頻度と記録様式は第9章による。メールのバウンスが発生すると7日間配信が抑止される。また、メールまたは email-json のエンドポイントで毎秒10メッセージの上限を超えると、サブスクリプションが自動停止して確認待ち（PendingConfirmation）状態に戻る。この状態は30日間維持され、再確認しない場合に削除される（未確認サブスクリプションが48時間で削除される扱いとは別である）。
- 必須** メトリクスフィルターは作成後に取り込まれたログデータのみを対象とし、過去のデータに遡って適用されない。各フィルターの作成日時をログ設計書に記録し、監視が開始された時点を明示できるようにすること（第9章の運用状況評価で参照される）。
- 必須** アラームの対象とするロググループは、Standard のログクラスで作成すること。Infrequent Access クラスはメトリクスフィルターおよびサブスクリプションフィルターに対応せず、作成後にクラスを変更できない。
- 必須** 通知経路の設定変更（トピックのサブスクリプション追加・削除、アラームの無効化）自体を監視対象に含めること。監視を止める操作が検知されない構成は、LR-04 および LR-12 の趣旨に反する。
- 推奨** 通知の宛先は、個人のメールアドレスではなく共有メールボックスまたは配信リストとし、担当者の異動・退職により経路が失効しない構成とすること。
- 推奨** メール以外の経路（チャットツール連携、インシデント管理ツール連携）を併用し、単一経路の失効で検知が途切れない構成とすること。
- 推奨** CloudTrail 経由の API イベントを Amazon EventBridge で処理する場合、detail-type に AWS API Call via CloudTrail を指定すること。読み取り専用の管理イベントを受信するには、ルールごとのオプション設定（CLI または CloudFormation でのみ設定可能）が必要である。
- 推奨** ログをログ管理製品や SIEM 製品へ転送する場合、CloudWatch Logs のサブスクリプションフィルターから Amazon Data Firehose を経由する構成とすること。送出データは base64 エンコードのうえ gzip 圧縮される。サブスクリプションフィルターにはロググループ単位のものアカウント単位のものがあり、ロググループ単位は1ロググループあたり最大5つ、アカウント単位はアカウント・リージョンあたり1つである。
- 推奨** 通知や転送の処理に AWS Lambda を用いる場合、当該関数の実行ログを CloudWatch Logs に保存し、失敗を検知できるようにすること（LR-11）。

- **任意** 定期的な確認処理を Amazon EventBridge Scheduler で実行すること。

5.6.3 設計上の注意点

- CloudTrail は 256 KB を超えるイベントを CloudWatch Logs および EventBridge へ送らない。大きなイベントに依存した検知は成立しない。
- CloudTrail から CloudWatch Logs への配信は、API 呼び出しから平均で約5分を要し、時間は保証されない。秒単位の即時性を前提とした統制設計は成り立たない。
- サブスクリプションフィルター経由の配信は少なくとも1回の配信であり、重複が生じうる。転送先での重複排除が前提となる。
- 自動修復（AWS Systems Manager Automation による修復等）を導入する場合、修復処理そのものが本番環境に対する変更であり、ITGC-A の変更管理および LR-12 の対象となる。無条件の自動修復は、変更の承認記録を欠いた本番変更となりうるため、適用範囲は発注者との合意事項である。

5.6.4 提出する設定証跡

- メトリクスフィルター、CloudWatch アラーム、SNS トピック、サブスクリプションの一覧（サブスクリプションの状態列を含む）と、各フィルターの作成日時。
- テスト通知の送出および受信の記録（送出日時、宛先区分、受信確認者）。
- EventBridge ルールの定義（イベントパターン、ターゲット）。
- サブスクリプションフィルターの設定内容と転送先の識別情報（認証情報は含めないこと）。
- 通知経路の生存確認手順（運用手順書の該当部）。

5.7 分析・抽出（Amazon Athena、AWS CloudTrail Lake、Amazon OpenSearch Service、Amazon Quick）

5.7.1 役割と対応する要求事項

本節は、保全したログから必要な範囲を抽出するための分析基盤の選定と設定を扱う。ITGC-B に対応し、LR-07（暗号化と機微情報の保護）、LR-09（定期レビューと証跡化）および LR-10（検索・抽出）に該当する。監査人への提出手続、抽出条件の記録様式、抽出結果の完全性の説明方法は第12章に定める。本節は、その手続を実行可能にする基盤側の要件に限る。

5.7.2 設定要件

- **必須** 監査人または発注者からの依頼に対し、対象期間・対象アカウント・対象操作・対象利用者を指定して抽出できる分析経路を、少なくとも1つ構築すること。基本構成は、S3 に保全した証跡を Amazon Athena で照会する方式とすること。
- **必須** Athena のテーブル定義ではパーティション射影を用い、日付による絞り込みができる構成とすること。組織証跡を対象とする場合、アカウント識別子とリージョンを含むパスに対応した定義が必要となる。使用する構文は公式ドキュメントで検証すること。CloudTrail の証跡を対象とする場合の基本形は次のとおりである。

組織の証跡では S3 のパスに組織 ID の階層が入り（AWSLogs/<組織ID>/<アカウントID>/CloudTrail/<リージョン>/）、`storage.location.template` とパーティション列（アカウント識別子・リージョン）をこれに合わせて定義する必要がある。単一アカウント向けの下記基本形をそのまま適用しないこと。


```

PARTITIONED BY (`timestamp` string)
TBLPROPERTIES (
  'projection.enabled'='true',
  'projection.timestamp.type'='date',
  'projection.timestamp.format'='yyyy/MM/dd',
  'projection.timestamp.interval'='1',
  'projection.timestamp.interval.unit'='DAYS',
  'projection.timestamp.range'='<運用開始日>,NOW',
  'storage.location.template'=
    's3://<バケット名>/AWSLogs/<アカウントID>/CloudTrail/<リージョン>/${timestamp}')

```

- **必須** Athena のクエリ結果出力先バケットを、ログアーカイブ用バケットとは分離して用意し、そのアクセス制御と保持期間を定めること。抽出結果には機微な情報が含まれる（LR-07）。
- **必須** 分析・照会ログアーカイブアカウントとは別のアカウント（監査／セキュリティツール用アカウント）から行い、ログアーカイブアカウントで分析ワークロードを実行しない構成とすること（5.10、第10章）。
- **必須** AWS CloudTrail Lake は 2026年5月31日以降、新規顧客に開放されない。新規設計において CloudTrail Lake を前提とした構成としないこと。発注者に既存の利用がある場合に限り、既存のイベントデータストアの取り扱いと移行方針を発注者と合意し、記録すること。
- **推奨** 直近期間の照会には Amazon CloudWatch Logs Insights を用いること。対象は 2018年11月5日以降のデータで、クエリは60分でタイムアウトし、結果は7日間保持される。長期・大量のデータは S3 と Athena で照会する、という二層構成とすること。
- **推奨** 代表的な抽出条件（特権IDの使用、権限の付与・削除、ログ設定の変更、ジョブの異常終了、データの直接更新）についてクエリを事前に用意し、ログ設計書または運用手順書に登録すること。
- **任意** Amazon OpenSearch Service、またはログ管理製品／SIEM 製品を併用すること。採用する場合、当該基盤への転送経路（5.6）と、転送先での保持期間・アクセス制御を設計に含めること。
- **任意** レビュー結果の可視化に Amazon Quick（BI 機能は Amazon Quick Sight。従来の Amazon QuickSight から改称され、既存の API・SDK・統合はそのまま利用できる）を用いること。提供条件と利用可否を採用時点の公式ドキュメントで確認し、確認結果をログ設計書に記載すること。

● 注意

証跡の自動収集や検索を特定サービスに依存させる設計は、提供形態の変更により将来の監査対応が成り立たなくなるおそれがある。本ガイドライン作成時点で、AWS CloudTrail Lake は 2026年5月31日以降、AWS Audit Manager は 2026年4月30日以降、いずれも新規の利用開始ができないとされている。新規設計では、証跡の保全を S3（ライフサイクルと Object Lock）に、照会を Athena または CloudWatch に置く構成を基軸とし、これらのサービスを前提とした自動化を組み込まないこと。

5.7.3 設計上の注意点

- Athena はスキャンしたデータ量に応じて課金される。抽出クエリを日付パーティションで絞り込む設計は、コスト面での前提条件であり、手順書への明記が必要である。
- SSE-KMS で暗号化されたログを読むには、S3 の読み取り権限と KMS の復号権限の両方が必要である。監査人に読み取り専用ロール（R-6）を提供する場合、両方の権限設計が必要となる（第10章）。
- CloudWatch Logs から S3 への定期エクスポートは、継続的なアーカイブの手段としては推奨されていない。エクスポート可能になるまで最大12時間を要し、タスクは24時間でタイムアウトし、同時に実行できるタスクはアカウントあたり1つで、ファイル内の時系列順は保証されない。長期保全にはサブスクリプション経由の転送が適する。

- AWS Config の高度なクエリは SQL のサブセットであり、`JOIN`、`DISTINCT`、`HAVING`、`UNION` に対応しない。削除済みリソースおよび記録対象外のリソースは照会できない。構成の履歴が必要な場合は `get-resource-config-history` の併用が必要である。
- CloudTrail Lake から CloudWatch Logs へ履歴をインポートする場合、2023年より前のデータは移行されない。既存利用がある発注者では、この期間のデータの扱いが論点となる。
- CloudTrail、CloudWatch Logs など AWS サービスが出力するログの時刻は原則として協定世界時（UTC）で記録される。ただしデータベース監査ログのようにタイムゾーン表記を含まない形式のログは、時刻系を個別に確認する必要がある（5.3.2）。日本標準時への変換規約は 5.12 および第12章による。

5.7.4 提出する設定証跡

- Athena のテーブル定義（DDL）とワークグループの設定（クエリ結果出力先、暗号化設定）。
- 事前登録した代表クエリの一覧と、構築時に実行した結果（1件以上）。
- 分析基盤に対する照会権限を持つロールの一覧と、ログアーカイブアカウントとの分離を示す構成図または権限設計書。
- CloudTrail Lake の利用有無と、利用がある場合の取り扱い方針の記録。
- 抽出結果出力先バケットのアクセス制御と保持期間の設定。
- Amazon Quick を採用する場合、提供条件・利用可否の確認結果。

5.8 AWS Backup（ジョブ履歴、Backup Vault Lock、Backup Audit Manager）

5.8.1 役割と対応する要求事項

本節は L-13（バックアップ・リストアログ）を扱う。ITGC-B（システムの運用・管理）に対応し、LR-08、LR-09、LR-11、LR-12 に該当する。監査人は、重要なデータやソフトウェアについて、障害や故障等によるデータ消失に備えて内容が保存され、迅速な復旧を図るための対策が取られていることを確認する。ここで必要となるのは、バックアップが計画どおりに実行されたことの記録と、復旧が可能であることの確認結果である。

5.8.2 設定要件

- **必須** 財務報告に関連するシステムのバックアップを AWS Backup のバックアップ計画で管理し、ジョブの成否を LR-08 の監視対象に含めること。異常終了時の通知経路は 5.6 による。
- **必須** バックアップジョブ、リストアジョブ、コピージョブの実行記録が CloudTrail に保全されることを確認すること。AWS Backup は API 呼び出しに加え、`BackupJobStarted` / `BackupJobCompleted`、`RestoreStarted` / `RestoreCompleted`、`CopyJobStarted` / `CopyJobCompleted`、`BackupDeleted`、`RecoveryPointCreated` 等をサービスイベントとして記録する。
- **必須** AWS Backup のジョブ一覧 API が返す期間は限られる（直近30日とされる。正確な期間は公式ドキュメントで確認すること）。保存期間要件（第7章）を満たす長期の証跡は、CloudTrail の記録または Backup Audit Manager のレポートで保全すること。
- **必須** 復旧ポイントを削除する操作（`DeleteRecoveryPoint`）およびバックアップ計画・ポリシー設定の変更を、LR-12 の監視対象に含めること。
- **必須** （Backup Vault Lock の Compliance モードを採用する場合）保持期間の誤設定が猶予期間経過後に取り消せなくなるため、設定値について発注者（R-2）の承認を得たうえで適用し、承認記録を残すこと。

- **必須** （Backup Audit Manager を利用する場合）AWS Config によるリソース記録が前提であること、およびレポートが24時間ごとに S3 へ配信され、クロスアカウントでの配信ができないことを踏まえて配信先アカウントを設計すること。
- **推奨** Backup Vault Lock を適用すること。Governance モードは十分な IAM 権限を持つ利用者が解除できる。Compliance モードは猶予期間の経過後、いかなる利用者も AWS も変更・削除できない。設定値は `ChangeableForDays`（Compliance モードのみ、3～36,500日、最短3日）、`MinRetentionDays`（最短1日）、`MaxRetentionDays`（最長36,500日）である。
- **推奨** Backup Audit Manager のフレームワークを構成し、レポートプランで定期レポートを取得すること。利用できるコントロールには、バックアップ計画への包含、最小頻度と最小保持（既定は1日／35日）、手動削除の防止、暗号化、最小保持期間の設定、クロスリージョン／クロスアカウントのコピー、Vault Lock の適用、最終復旧ポイントの作成、復旧時間の目標充足がある。コントロールはアカウント・リージョンあたり最大50、レポートプランはアカウントあたり最大20である。
- **推奨** 復旧試験（リストア）を実施し、結果を証跡化すること。実施頻度と範囲は発注者と合意すること（第9章）。
- **任意** 論理的にエアギャップされたボールドを採用すること。常に Compliance モードの Vault Lock が適用され、既定では AWS 所有のキーで暗号化され、AWS Backup のサービス所有アカウントに保存される。他アカウントへの共有と復元には所定の共有手続が必要となる。

5.8.3 設計上の注意点

- Backup Vault Lock はバックアップデータの改ざん・削除を防ぐ仕組みであり、ログ自体の改ざん防止（第8章）とは別の要件である。両者は混同されやすいが、片方のみでは双方の要件を満たさない。
- バックアップの取得が成功したことは、復旧が可能であることを意味しない。復旧可能性は復旧試験によってのみ確認できるため、取得成功率のみでは証跡として不十分である。
- Compliance モードのボールドは、AWS アカウントを閉鎖した場合でも所定の期間の経過後に内容が削除される。長期保全の設計では、この点が保存期間の設計（第7章）の前提となる。
- バックアップの対象範囲は、財務報告に関連するデータおよびそれを処理するソフトウェアを網羅する必要がある。対象外としたリソースがある場合、その理由の記載が求められる。

5.8.4 提出する設定証跡

- バックアップ計画（対象リソース、頻度、保持期間、コピー先）とボールドの設定。
- Vault Lock の設定内容（`DescribeBackupVault` の `Locked` および `LockDate` を含む）と、Compliance モード採用時の発注者承認記録。
- Backup Audit Manager のフレームワーク定義、レポートプラン定義、および直近のレポート。
- ジョブ成否の監視設定と通知経路（5.6 との対応）。
- 復旧試験の実施計画と、実施済みの場合はその結果記録。

5.9 CI/CD・IaC（AWS CodePipeline／CodeBuild／CodeDeploy、AWS CloudFormation、承認と本番反映の証跡）

5.9.1 役割と対応する要求事項

本節は L-10（変更・デプロイログ）を扱う。IT全般統制としては ITGC-A（システムの開発、保守に係る管理）に対応し、LR-02、LR-04、LR-09、LR-12、LR-14 に該当する。

システムの開発・変更については、承認、導入前の試験、および開発・変更の過程の記録が適切に保存されていることが評価の着眼点となる。変更の場合には、変更前のシステムに関する内部統制の整備状況に係る記録が更新されていることも留意点に含まれる。具体的な評価手続と参照すべき基準・実施基準および Q & A の該当箇所は、発注者の内部統制担当（R-1）および監査人と確認すること。

変更管理の評価においては、変更依頼または変更されたプログラム等からサンプリングし、それがどのような手続で依頼・承認されたものであるかを確認する方法が考えられるとされている。ただし金融庁「内部統制報告制度に関する Q & A」（問78）は、この確認について「必ず双方が求められるのではなく、状況に応じて適切な手続を実施する必要がある」としている。もっとも、監査人がいずれの母集団からサンプリングしても対応できるようにするため、本ガイドラインでは、本番反映されたものから遡って承認記録に到達できること、および承認記録から本番反映の事実には到達できることの双方を、発注者の受入条件として求める。

財務諸表監査の枠組みにおいても、IT全般統制の理解にあたって、プログラムの変更と本番環境への移行に対するアクセス権の分離が着眼点として挙げられている。以下の要求事項はこれを実装に落としたものである。

5.9.2 設定要件

- **必須** 本番環境への反映について、**承認者と実施者を分離すること**。変更を起票し実装した者が、その変更の本番反映を単独で承認し実行できない構成とすること。実装は、IAM による権限分離とパイプラインの承認アクションの組合せによる。
- **必須** **本番反映の記録**として、変更単位で次を追跡できるようにすること。(a) 変更内容の識別子（コミット識別子、テンプレートのバージョン）、(b) 承認者と承認日時、(c) 実施者と実施日時、(d) 反映対象の環境とアカウント、(e) 結果（成功・失敗・切り戻し）。これらを相互に参照できる形でログ設計書に定義すること。
- **必須** パイプラインの手動承認アクションを本番ステージの前に配置すること。承認・却下の記録に用いる CloudTrail イベント名を公式ドキュメントで確認し、確認したイベント名と、実際に記録されたイベントの抜粋をログ設計書および 5.9.5 の提出証跡に含めること。承認・却下がないまま7日が経過すると当該アクションは失敗として扱われるため、承認期限に関する運用ルールを定めること。
- **必須** 承認者ロールとデプロイ実行ロールを分離し、承認者にパイプラインの実行権限を付与しないこと。詳細な権限設計は第10章による。
- **必須** 開発環境・検証環境と本番環境で同一のロールやアカウントを共用しないこと。共用は、開発担当者が誤って本番環境に変更を適用する事故の典型的な原因である。
- **必須** 本番環境の構成を IaC（AWS CloudFormation 等）で管理し、コンソールや CLI からの直接変更を行わない運用とすること。緊急時等でやむを得ず直接変更を行う場合の事前承認と事後記録の手順を、運用手順書に定めること。
- **必須** CloudFormation のドリフト検出を定期的に行い、結果を証跡化すること。同一の操作に対するス tack イベントには同じクライアントリクエストトークンが付与されるため、これを用いて変更単位での突合ができるようにすること。

- **必須** AWS CodeBuild のビルドログを CloudWatch Logs に保存すること（既定で有効）。S3 へのログ出力は既定で無効であるため、必要に応じて有効化すること。既定のロググループ名の規約を公式ドキュメントで確認し、確認結果と実際に生成されたロググループ名をログ設計書および 5.9.5 の提出証跡に含めること。
- **必須** 導入前の試験の結果（自動テストの実行結果）を成果物として保全すること。テストが実行されたことの記録がなければ、導入前の試験が適切に行われていることを示せない。
- **必須** パイプライン定義、パイプラインのサービスロール、承認ステージの構成に対する変更を、LR-12 の監視対象に含めること。承認ステージを削除する変更が検知されない構成は、承認統制そのものを無効化しうる。
- **推奨** AWS CodeDeploy のエージェントログを CloudWatch エージェントで集約すること。エージェントはログを日次または一定サイズでローテーションし、7日で削除するため、対象ノード上の保持だけでは保存期間要件を満たさない。なお CodeDeploy のログは EC2／オンプレミス向けのデプロイのみが対象である。
- **推奨** パイプラインの実行履歴の保持期間（12か月とされる）は公式ドキュメントで確認し、第7章で定める保存期間を満たさない場合は、EventBridge によるイベント転送等により別途保全すること。

5.9.3 ソースリポジトリの一般的な取り扱い

ソースリポジトリの製品選定は発注者の環境に依存するため、本ガイドラインでは特定の製品を指定しない。開発ベンダーは、採用するリポジトリについて次を満たす構成とすること。

- **必須** 本番環境に反映されたコミットを一意に特定でき、当該コミットに対するレビューおよび承認の記録が保存されること。
- **必須** 保護対象ブランチに対する履歴の書き換え（強制プッシュ）と、レビューを経ない直接コミットを禁止する設定を行うこと。
- **必須** リポジトリの認証記録および権限の付与・変更・削除の記録が取得できること。取得できない場合は、その事実と代替統制（権限一覧の定期取得と棚卸等）をログ設計書に記載すること。
- **必須** AWS 外のサービスを利用する場合、責任分界と、保証報告書等の入手方針を発注者と合意すること（5.11、LR-13）。
- **推奨** リポジトリの権限一覧を定期的に出力し、棚卸の証跡として保全すること。特に開発ベンダー要員および運用ベンダー要員の権限は、契約終了時の速やかな削除が監査上の着眼点となる。

5.9.4 設計上の注意点

- 承認記録の正本を AWS 内（パイプラインの承認アクション）に置くか、AWS 外の変更管理システムに置くかは、発注者との合意事項である。いずれの場合も、承認記録と本番反映記録を相互に参照できる識別子（変更管理番号等）が必要である。承認記録の保存期間は第7章による。
- ドリフト検出は、テンプレートやパラメータで明示的に設定したプロパティのみを対象とする。KMSKeyId は対象外であり、ネストされたスタックは個別に実行する必要がある。したがって、ドリフト検出の結果のみでは「構成が完全に一致している」ことの根拠にはならない。
- パイプラインのサービスロールが広範な権限を持つ場合、承認者と実施者の分離が実質的に無効化される。サービスロールの権限は反映対象に必要な最小限とする必要がある。
- ビルド環境から本番環境の認証情報にアクセスできる場合、パイプラインを経由しない反映が可能になる。ビルド環境の権限と本番環境の権限の分離が前提となる。
- 本番環境用アカウントへのアクセス経路は、パイプラインのデプロイロール以外に残さない設計とすることが望ましい。緊急対応等で人による直接アクセス経路を残す場合は、5.1 に定める送信元アイデンティティによる個人特定を前提とし、対象ロールと利用条件をログ設計書に記載する。

5.9.5 提出する設定証跡

- パイプライン定義（ステージ構成、承認アクションの位置、通知先）。
- 承認・却下に対応する CloudTrail イベント名の確認結果と、記録されたイベントの抜粋。
- 承認者ロールと実行ロールの IAM ポリシー、および両者が同一の要員に付与されていないことを示す権限割当一覧。
- 開発・検証環境と本番環境でロールおよびアカウントが分離されていることを示す一覧。
- 代表的な変更1件についての一気通貫の証跡（起票 → レビュー → 承認 → ビルド・テスト結果 → 本番反映 → ドリフト検出結果）。
- ドリフト検出の実行設定（スケジュール、対象スタック）と直近の実行結果。
- CodeBuild のログ設定（既定ロググループ名の確認結果と実際のロググループ名を含む）と、CodeDeploy を利用する場合のエージェントログ集約設定。
- ソースリポジトリの保護設定（強制プッシュ禁止、レビュー必須）と権限一覧の取得手順。

5.10 AWS Organizations／AWS Control Tower

5.10.1 役割と対応する要求事項

本節は、複数アカウント環境におけるログの網羅性（L-01、L-14）と保全の基盤を扱う。ITGC-C と ITGC-B を横断し、LR-01、LR-04、LR-06、LR-12、LR-13 に該当する。

AWS Organizations の管理アカウント、AWS Control Tower のランディングゾーン、ログアーカイブアカウント、監査アカウント、SCP（サービスコントロールポリシー）および RCP（リソースコントロールポリシー）は、通常、発注者（R-1 内部統制担当、R-2 システム所管）が保有・管理する。開発ベンダーはこれらを新規に構成する立場にないことが多いため、本節の要求事項は「前提条件の確認と設計への反映」を貴社の責務とし、統制そのものの適用主体は発注者側とする形で整理する。

5.10.2 設定要件

- **必須** 着手時に、AWS Organizations および AWS Control Tower の利用有無、ログアーカイブアカウントと監査アカウントの存在、適用されている SCP／RCP の内容、ログの送信先バケットと KMS キーを確認し、ログ設計書に記載すること。前提が未整備の場合は、貴社が実装できる範囲と、発注者側で整備が必要な範囲を分けて提示すること。
- **必須** 本書で必須または推奨として取得を求めるログの保全先を、ワークロードが稼働するアカウントとは分離されたログアーカイブアカウントとすること（ネットワーク・エッジログの集約可否は 5.4 による）。ワークロードアカウントの管理者がログを削除・変更できない構成であることを、設計書で説明できるようにすること（第8章、第10章）。
- **必須** 検知と分析は監査アカウント（セキュリティツール用アカウント）側から行い、ログアーカイブアカウントでは分析ワークロードを実行しないこと。ログアーカイブアカウントは保管のためのアカウントとして扱うこと。
- **必須** 新規に追加されるアカウントが自動的に記録対象に含まれる構成（組織の証跡）であることを確認すること。既に独自の証跡を持つアカウントを組織に登録すると、同一リージョンでの重複記録により課金が発生しうするため、登録前に既存証跡の要否を確認すること。
- **必須** 有効化されていないオプトインリージョンは記録対象にならない。利用するリージョンの一覧と、各メンバーアカウントでの有効化状況を確認し、記録すること。

- **必須** AWS Control Tower を利用する場合、ログ保持期間の既定値（標準的なアカウントログは1年、アクセスログは10年。日または年単位で最長15年まで設定可能）を、第7章で定める保存期間に合わせて明示的に設定すること。既定値のまま放置しないこと。
- **推奨** ログの停止・削除を防ぐ予防的統制が適用されていることを確認すること。AWS Control Tower の必須コントロールの内容はランディングゾーンのバージョンにより異なる。Landing Zone 4.0 未満では次の操作が拒否される（いずれも `AWSControlTowerExecution` ロールを `ArnNotLike` で除外する形で定義されている）。

```
CloudTrail    : cloudtrail:DeleteTrail, cloudtrail:PutEventSelectors,
               cloudtrail:StopLogging, cloudtrail:UpdateTrail
AWS Config    : config:DeleteConfigurationRecorder, config:DeleteDeliveryChannel,
               config:DeleteRetentionConfiguration, config:PutConfigurationRecorder,
               config:PutDeliveryChannel, config:PutRetentionConfiguration,
               config:StopConfigurationRecorder
CloudWatch Logs : logs:DeleteLogGroup, logs:PutRetentionPolicy
ログアーカイブバケット : s3:DeleteBucket, s3:PutBucketPolicy, s3:DeleteBucketPolicy,
                        s3:PutLifecycleConfiguration, s3:PutEncryptionConfiguration,
                        s3:PutBucketLogging
```

Landing Zone 4.0 以降では、CloudTrail 系コントロールは組織証跡化に伴い展開されなくなり、S3 ログアーカイブバケット系の個別コントロール（暗号化・ロギング・バケットポリシー・ライフサイクル・削除）は `aws-controltower-access-logs-*` / `aws-controltower-cloudtrail-*` / `aws-controltower-logs-*` を対象とする単一の統合コントロール（Sid: CTS3PV8、NotAction による許可列挙方式）に置き換えられている。なお S3 バケット系のコントロールは、全 OU ではなく Security OU に適用される点にも留意する。CloudWatch Logs（`logs:DeleteLogGroup` / `logs:PutRetentionPolicy`）と AWS Config の各コントロールは引き続き全 OU に適用される。着手時にランディングゾーンのバージョンを確認し、実際に適用されているコントロール一覧を証跡として取得すること。

- **推奨** Amazon GuardDuty や AWS Security Hub CSPM の無効化に該当する API（例: `guardduty:DeleteDetector`、`guardduty:UpdateDetector`、`securityhub:DisableSecurityHub`）を拒否リスト型の SCP で明示的に拒否すること。対象 API は採用時点の公式ドキュメントで確認し、確認結果と SCP 本文をログ設計書に記載すること。
- **推奨** KMS キーの削除予約（`kms:ScheduleKeyDeletion`）を拒否する統制については、AWS 公式の単体の記述例が確認できないため、上記の公式コントロールを参考に組織で定義し、設計レビューで妥当性を確認すること。ログ用バケットのライフサイクル設定については、上記の `s3:PutLifecycleConfiguration` を拒否する公式コントロールが AWS Control Tower に存在するため、その適用状況を確認し、Control Tower 非利用時は同等の SCP を定義すること。
- **任意** RCP により、組織外のプリンシパルからログ用リソースへアクセスできないよう制限すること。

5.10.3 設計上の注意点

- SCP は権限を付与するものではなく、最大権限を定義するものである。管理アカウントおよびサービスにリンクされたロールには影響しない。`FullAWSAccess` を削除するとすべてのアクションが失敗する。
- 組織の証跡はメンバーアカウントから削除・停止・設定変更できないが、バケットポリシーの誤り等により検証に失敗した場合でもメンバーアカウントには作成される。配信が実際に行われていることの確認は別途必要である（第4章）。
- 管理アカウントが管理アカウントでなくなった場合、組織の証跡は組織の証跡ではなくなる。組織構成の変更は、ログの網羅性に直接影響する変更として LR-12 の対象となる。

- アカウントが組織から除外されても、除外前に作成されたログはバケットに残る。ランディングゾーンの更新に伴いアカウント単位の証跡が削除される場合も、既存のログファイルは S3 に残る。移行時の証跡の連続性は第13章による。
- 委任管理者の指定方法はサービスごとに異なる。GuardDuty はリージョンごとに指定し、かつ全リージョンで同一のアカウントである必要がある。委任管理者の設計を1つの方式で統一できるとは限らない。
- 最小権限の観点から、管理アカウントを各セキュリティサービスの委任管理者とすることは推奨されていない。

5.10.4 提出する設定証跡

- OU 構成とアカウント一覧（用途、所有者、本ガイドラインにおける役割 R-1～R-6 との対応）。
- 適用されている SCP/RCP の本文と適用先 OU の一覧。
- AWS Control Tower を利用する場合、ランディングゾーンのバージョンと、実際に適用されている必須コントロールの一覧。
- 組織の証跡の設定内容（対象リージョン、S3 送信先、CloudWatch Logs 連携の有無）。
- ログ保持期間の設定値（AWS Control Tower 利用時は標準ログ・アクセスログの双方）。
- 有効化されているリージョンの一覧と、記録対象リージョンとの突合結果。

5.11 AWS Artifact と責任共有モデル

5.11.1 役割と対応する要求事項

本節は ITGC-D（外部委託に関する契約の管理）および LR-13（外部委託と責任分界）に対応する。実施基準は、委託業務に関しては委託者が責任を有しており、委託業務に係る内部統制も評価の範囲に含まれること、委託業務が企業の重要な業務プロセスの一部を構成している場合には、受託会社の業務に関する内部統制の有効性を評価しなければならないことを定めている。2023年の改訂では、情報システムの開発・運用・保守などITに関する業務を外部の専門会社に委託する場合が、委託業務の例として明示された。改訂基準は2024年4月1日以後開始する事業年度から適用されている。

AWS 環境では、統制の責任が AWS、発注者、開発ベンダー、運用ベンダーの間で分割される。責任共有モデルにおいて、AWS はハードウェア、ソフトウェア、ネットワーク、施設といった「クラウドのセキュリティ」に責任を負い、利用者はゲスト OS のパッチ適用、アプリケーション、アクセス制御の設定、データの管理と暗号化といった「クラウドにおけるセキュリティ」に責任を負う。物理的・環境的な統制は継承され、パッチ管理・構成管理・意識向上と教育は共有される統制として位置づけられる。

5.11.2 設定要件

- **必須** 本ガイドラインの対象範囲について、AWS が責任を負う範囲、発注者が責任を負う範囲、貴社が責任を負う範囲、運用ベンダーが責任を負う範囲を区分した**責任分界表**を作成し、成果物として提出すること（第11章）。なお責任分界表が区分するのは取得・保全・監視等の実装および運用の分担であり、財務報告に係る内部統制の評価および報告の責任が発注者に帰属することを変更するものではない。
- **必須** 責任分界表は、行をログ種別 L-01～L-14、列を取得設定・保全・監視・レビュー・証跡提出とし、各セルに責任を負う役割を R-1～R-6 で記載すること。AWS が責任を負う範囲は「AWS」と記載すること。いずれの列についても空欄を残さないこと。

- **必須** AWS の SOC 1 報告書は AWS 側の統制環境に関する情報を提供するものであり、**発注者のアカウントにおける設定と運用が有効であることの証跡にはならない**。この区別をログ設計書に明記し、発注者・監査人との認識齟齬が生じないようにすること。
- **必須** AWS Artifact からのレポート取得は、原則として発注者（R-1）が自社のアカウントで行うこと。機密（confidential）と表示された文書は、自社内、規制当局、監査人に限って共有が許されており、顧客への提供やウェブサイトへの掲載は認められていない。個別のレポートの共有可否は、ダウンロードした文書の表紙に記載された利用条件で確認すること。各文書には一意の透かしが付与される。**貴社が自社のアカウントで取得した文書を発注者へ転送する運用は配布条件に抵触するおそれがあるため、行わないこと**。貴社の責務は、取得経路の設計と利用条件への適合を確認することに限る。
- **必須** 保証報告書を委託業務の評価に用いる場合、対象期間、評価範囲、対象システムが発注者の会計期間と評価範囲に整合しているかを確認する必要があることを、発注者に情報提供すること。対象期間や評価範囲が一致しないまま利用すると、評価の空白期間や対象外の領域が生じる。
- **推奨** 受託会社の内部統制の評価方法には、質問書や確認書の送付、直接の往査、保証報告書の入手といった複数の方法があり、保証業務実務指針に基づく報告書の入手が必ず必要になるわけではないことを、発注者への情報提供に含めること。最終的な評価方法の選択は発注者と監査人の判断による。
- **推奨** 貴社および運用ベンダーが提供する役務についても、発注者が評価できるよう、統制の記述、実施記録、独立した確認の有無を整理して提供すること。
- **推奨** 委託契約に、要員の ID と権限の管理、定期的な棚卸とその結果の報告、ログの提出義務、監査への協力義務を含めることを発注者へ提案すること。契約条項の決定は発注者の判断による。
- **任意** 財務報告に限定しない領域（セキュリティ、可用性、処理の完全性、機密性、プライバシー）について発注者が委託先の状況を理解する必要がある場合、SOC 2 に相当する報告書の入手を検討することを情報提供すること。

● 監査の視点

クラウドサービスの利用では、委託先の内部統制がブラックボックスになりやすく、監査権の確保または保証報告書の入手により内部統制の状況を確認することが重要とされている。監査人が確認するのは、(1) 受託会社が実施している内部統制と、受託会社が提供する業務に対して発注者が実施している内部統制の双方を理解しているか、(2) 発注者が行った検証の状況、(3) 報告書等を入手している場合、それが十分な証拠を提供しているかである。開発ベンダーは、(1) のうち「発注者が実施すべき統制」の内容を設計段階で具体的に示すこと——たとえば「ログの定期レビューは R-5（開発・運用から独立したログ管理者）が実施し、その記録を保存する」といった形で——が、発注者の評価作業を成立させる前提となる。なお R-5 をいずれの当事者に置くかは本ガイドラインでは固定しておらず、5.11.2 の責任分界表において発注者と合意する。ただし R-5 は開発（R-3）および運用（R-4）から独立していることが要件であり、これらと同一の当事者に兼務させないこと。

5.11.3 設計上の注意点

- AWS の SOC 1 報告書は四半期ごとに発行され、月次のブリッジレターが併せて提供される。取得には秘密保持の条件が伴う。取得と管理は発注者の責任範囲である。
- Artifact の文書のダウンロード後の保護は利用者の責任である。貴社が発注者の環境で取得作業を代行する場合、取得した文書の取り扱いは事前の合意事項となる。
- 委託先の位置づけ（企業集団内か外部委託か）および受託会社の内部統制の評価方法は、発注者と監査人の判断による。金融庁「内部統制報告制度に関する Q & A」（問23）は、連結財務諸表を構成する子会社や関連会社への委託について、実施基準という外部に委託した業務ではなく、企業集団内部における本来の業務として

評価の範囲に含まれるとしている。貴社の役割は事実関係の整理と情報提供に留まり、位置づけそのものの判断は発注者の領分である。

- 責任分界表は一度作成して終わりではなく、利用サービスの追加・変更に伴い更新が必要である。更新の契機と手順を運用手順書に定める必要がある。

5.11.4 提出する設定証跡

- 責任分界表（様式は 5.11.2 による）。
- 利用する AWS サービスの一覧と、それぞれについて発注者が設定責任を負う項目の一覧。
- 貴社および運用ベンダーが提供する役務に関する統制の記述（統制の目的、実施者、実施頻度、記録の所在）。
- AWS Artifact の取得経路と取得主体に関する取り決めの記録。

5.12 Amazon Time Sync Service

5.12.1 役割と対応する要求事項

本節は LR-03（時刻同期とタイムスタンプ）に対応する。ITGC-B に位置づけられるが、実質的にはすべてのログ種類の前提となる要件である。複数の機器やサービスのログを突き合わせて事象の時系列を再構成するには、各ログの時刻が共通の時刻源に同期している必要がある。時刻が同期していない場合、LR-03 のみならず、LR-09（定期レビュー）および LR-10（検索・抽出）の前提が成立しない。

5.12.2 設定要件

- 必須** Amazon EC2 インスタンスの時刻を Amazon Time Sync Service に同期すること。ローカルの NTP エンドポイントは IPv4 が 169.254.169.123、IPv6 が fd00:ec2::123（Nitro ベースのインスタンスのみ）である。IPv4 と IPv6 を併用する必要はない。
- 必須** chrony を用いる場合、次の設定行を他の server 行および pool 行より前に記述すること。

```
server 169.254.169.123 prefer iburst minpoll 4 maxpoll 4
```

- 必須** Amazon Linux 2023 および近年の Amazon Linux 2、2018年8月以降の Windows AMI は既定で設定済みであるが、AMI のカスタマイズや構成管理により設定が上書きされていないことを、構築時および定期的に確認すること。
- 必須** AWS 外の機器（オンプレミスのサーバ、ネットワーク機器）についても、同一の時刻源に同期すること。パブリックの NTP エンドポイントとして time.aws.com を利用できる。
- 必須** ログの時刻表記に関する規約をログ設計書に定めること。AWS の各サービスのログは原則として協定世界時（UTC）で記録される（例外は 5.3.2 による）。CloudTrail の `eventTime` は API エンドポイントを提供するホストの時刻に基づく UTC であり、2014-07-16T15:49:27Z の形式で記録される。CloudWatch Logs のイベントのタイムスタンプは 1970年1月1日 UTC からのミリ秒である。証跡の提出にあたり日本標準時へ変換する場合は、変換規則と変換前後の対応を明示すること（第12章）。
- 必須** 証跡として出力する際に、どの時刻系で出力したかを必ず併記すること。ログを解析する基盤やダッシュボードで表示タイムゾーンを切り替えられる場合、表示上の切替結果をそのまま証跡とすると、時刻の解釈が一意に定まらない。

- **必須** うるう秒の扱いを統一すること。ローカルの NTP およびパブリックの NTP ではうるう秒がスミアされる一方、PTP ハードウェアクロックはスミアせず UTC の標準どおりにうるう秒を挿入する。同一システム内でこれらを併用しないこと。
- **必須** 時刻同期の失敗を検知できるようにすること。OS の同期状態を監視項目に含め、同期が失われた場合に通知される構成とすること（5.6）。
- **必須** 同期が失われていた期間があった場合、その期間のログの突合可能性について発注者へ報告すること。
- **推奨** タイムゾーン表記を含まない形式で出力されるログ（データベース監査ログ等）については、そのログの時刻がどの時刻系に基づくかを確認し、ログ設計書に記載すること（5.3）。
- **任意** マイクロ秒精度の時刻が必要な場合、PTP ハードウェアクロックを利用すること。Linux のみが対象で、所定のバージョン以上の ENA ドライバと専用の配置グループが必要であり、対応するリージョンとインスタンスファミリーが限定される。

5.12.3 設計上の注意点

- リンクローカルアドレス宛のパケットには合計 1,024 パケット/秒の上限がある。時刻同期以外の用途（インスタンスメタデータへのアクセス等）と合算される点に留意する。
- 時刻同期に用いる通信は VPC Flow Logs に記録されない（5.4）。同期の状況を Flow Logs で確認することはできないため、OS 側の同期状態の監視が必要となる。
- 時刻同期は、統制の一部というより、すべての証跡の証拠力を支える基礎条件である。同期が失われていた期間のログは、他のログとの突合可能性そのものが損なわれる。

5.12.4 提出する設定証跡

- chrony（Linux）または w32tm（Windows）の設定ファイルの内容と、同期状態を確認したコマンドの出力。
- AWS 外の機器を含む場合、その時刻源の設定内容。
- ログ設計書における時刻表記規約の該当部（記録時の時刻系、提出時の変換規則、証跡出力時の時刻系の併記方法、タイムゾーン表記を含まないログの扱い）。
- 時刻同期の監視設定と、通知経路との対応。

6

リファレンスアーキテクチャ

本章は、第2章の要求事項（LR-01～LR-14）を AWS 上で満たす標準構成を示す。開発ベンダーは本章を出発点に案件固有の設計へ具体化し、6.7 節の図・表を設計書として提出すること。**必須** 標準構成から逸脱する場合は、同等の統制をどの仕組みで担保するかを設計書に明記し、発注者（R-1・R-2）の承認を得ること。

6.1 設計原則

設計判断に迷った場合は次の 5 原則に照らして判断する。各原則は複数の要求事項を横断する。

6.1.1 分離 — ログアーカイブアカウントの独立

必須 ログの長期保全先は、ワークロード（本番・検証）とも運用ツールとも異なる専用の AWS アカウント（以下「ログアーカイブアカウント」）に置くこと。同アカウントは保存専用とし、分析基盤・業務アプリケーション・運用ツールを同居させない。書き込みは AWS サービスプリンシパルと配信用ロールに限定し、開発者（R-3）・運用者（R-4）は同アカウントへの権限セットやロールを一切持たないこと。アカウント境界で分けるのは、「運用者が自らの操作記録を削除・改変できない」状態（LR-06、第10章）を、IAM ポリシーの正しさだけに依存せず構成そのもので示すためであり、ITGC-C の評価で有力な証拠となる。

必須 R-5 の所属（発注者側か運用ベンダー側か）を設計書に明記し、R-4 と同一の要員が兼務しないこと。

推奨 R-5 は R-4 と異なる組織（原則として発注者側）とすること。例外として運用ベンダー要員が R-5 を担う場合は、発注者（R-1）の承認を得たうえで、アカウント分離のみでは職務分掌を示せないため、当該統制を発注者が評価する委託業務として位置づけ、評価手段（受託側報告書の入手等）を責任分界表（6.7）に記載すること。

6.1.2 不変性 — WORM

必須 保全用 Amazon S3 バケットには S3 Object Lock を有効化し、保持期間を LR-05 で発注者が決定した保存期間以上に設定すること（LR-04・LR-05、第7章・第8章）。ただしサービス側の制約により Object Lock または既定保持を適用できない配信先については、表6-3 に例外と代替統制（バージョニング、削除拒否のバケットポリシー、SCP、別バケットへの複製）を明記し、発注者の承認を得ること。具体的には、既定保持を有効化した Object Lock バケットを配信先にできない AWS Config の配信チャネルと、Object Lock 有効バケットを宛先にできないサーバーアクセスログが該当し、6.5.1 および表6-3 に示す代替統制で保護すること。**推奨** 保持モードはコンプライアンスモードとする（単一アカウント構成では代替統制が限られるため **必須**。6.4.2 参照）。同モードではルートユーザーを含むいかなる利用者也期限前の上書き・削除・保持期間短縮ができず、期限前に削除する唯一の方法はアカウントの削除である。ガバナンスモードを採る場合は `s3:BypassGovernanceRetention` の保有者をログ管理者（R-5）に限定し、選択理由を設計書に記録すること。**必須** AWS CloudTrail の証跡ではログファイル整合性検証を有効化すること（LR-04、第8章）。1 時間ごとにダイジェストファイル（SHA-256 ハッシュ、SHA-256 with RSA 署名、前ダイジェストとの連鎖）が配信され、`aws cloudtrail validate-logs` で改変・削除を検出できる。

● 注意

Object Lock はバージョニング有効バケットでのみ動作し、一度有効化するとバケットの Object Lock 無効化もバージョニングの停止もできない。保持期間の短縮はコンプライアンスモードでは不可であり、ガバナンスモードでも `s3:BypassGovernanceRetention` を持つ主体に限られる。延長は両モードで可能である。既定保持を過大に設定した場合の保存コストは取り消せない。既定保持期間は発注者の決定を文書で得てから設定し、設定値を設計書に転記すること。

6.1.3 網羅性 — 組織単位の自動包含

必須 ログ収集の有効化はアカウントごとの個別設定ではなく AWS Organizations の組織単位で行い、新規アカウントが自動的に対象へ含まれる方式を採用すること。CloudTrail は組織の証跡（マルチリージョン、グローバルサービスイベントを含む）、AWS Config は AWS Control Tower のランディングゾーンまたは AWS Systems Manager Quick Setup（もしくは AWS CloudFormation StackSets）による組織単位の設定レコーダー・配信チャネル展開、Amazon GuardDuty と AWS Security Hub CSPM は委任管理者による自動有効化（新規アカウントを含む設定）を用いる。組織の証跡は追加されたアカウントで自動的に記録が始まり、メンバーアカウント側から削除・停止・変更できない。AWS Config のアグリゲータは記録済みデータの読み取り専用ビューであり、メンバーアカウントの記録を有効化する機能はない。アグリゲータの設定だけでは新規アカウントの構成履歴は取得できないため、**必須** レコーダーと配信チャネルの展開手段を別に設計し、レコーダーの削除は `AWS::Config::ConfigurationRecorder` のドリフト検知で、記録の停止は CloudTrail の `StopConfigurationRecorder` イベントで監視すること（ドリフト検知は記録の停止を捕捉しない）。IAM・STS・CloudFront のグローバルサービスイベントは us-east-1 に記録される。us-east-1 以外の単一リージョン証跡ではこれらを取りこぼすため、マルチリージョン証跡とし、`IncludeGlobalServiceEvents` が true であることを確認すること。またオプトインリージョンは各メンバーアカウントで有効化されて初めて対象になるため、リージョンの有効化状況を LR-01 の対象範囲台帳に含めること。

6.1.4 一元化 — 集約と検索

必須 保全（ログアーカイブアカウントの S3）と分析（セキュリティアカウントの Amazon Athena 等）を分けた二層構成とし、全アカウント・全リージョンのログを単一の検索基盤から横断検索できること。Athena のテーブル定義にはパーティション射影を用い、日付のパーティションを手動追加なしに検索対象へ含める。ただしアカウント ID・リージョンのパーティションは enum 型となり値の静的な列挙が必要であるため、組織にアカウントが追加された際にテーブルプロパティを更新する手順を運用手順書に定め、更新を LR-12 の変更管理対象とすること。enum の値数は数十程度が上限の目安であり（テーブルメタデータの上限に依存する）、これを超える規模ではアカウント ID をパーティション列にしない設計、または injected 型の採用を検討すること。ただし injected 型は列ごとに WHERE 句での値の指定が必須であり、指定のないクエリは失敗するため、アカウントを横断した検索（本節冒頭の要求）と両立するかを確認すること。直近の調査と検知は Amazon CloudWatch Logs、それ以前の期間の検索・抽出は S3 上のアーカイブに対して行うなど、費用と応答性で照会先を分ける設計とし、どの期間をどこで照会するかを設計書に明記すること（LR-10、第12章）。

● 補足

AWS CloudTrail Lake は 2026 年 5 月 31 日以降、新規顧客には開放されない。既に利用している場合を除き、証跡（Trail）+ S3 + Athena を標準とし、CloudTrail Lake を前提とした設計を行わないこと。既存利用がある場合も、2023 年より前のイベントは Amazon CloudWatch ヘインポートできないため、移行計画を設計書に含めること。

6.1.5 最小権限

必須 ログ基盤への権限は、組織境界（SCP・RCP）、リソース境界（バケットポリシー・AWS KMS キーポリシー）、アイデンティティ境界（IAM ポリシー・権限セット）の三層で制限し、いずれか一層の設定誤りだけでは削除・停止が成立しない構成とすること。**必須** 証跡・Config・ロググループ・アーカイブバケット・暗号化キーを変更できる主体（AWS`CloudTrail_FullAccess` 相当の権限を含む）を一覧化し、変更は IaC パイプライン経由に限定すること（LR-12）。読み取り専用ロールと変更ロールを分け、調査・監査対応には読み取り専用ロールのみを用いること。**必須** Organizations のルートアクセス集中管理を有効化し、メンバーアカウントのルート認証情報を削除すること。ルート認証情報を保持する管理アカウント（および Organizations 外の単独アカウント）については、ルートユーザーに MFA を設定し、使用時に R-2 へ通知すること（本書の要求事項。AWS 側の強制適用の範囲と時期は公式ドキュメントで確認すること）。

6.2 標準構成（マルチアカウント）

標準構成は次の 4 種類のアカウントで構成する。AWS Control Tower を用いる場合、Security OU に作成される Log Archive アカウントと Audit アカウントが、それぞれログアーカイブアカウントとセキュリティ（監査）アカウントに対応する。

- 管理アカウント**: Organizations、SCP・RCP、組織の証跡の作成・所有、IAM Identity Center、ルートアクセス集中管理を担う。ワークロードを配置しない。組織の証跡の CloudWatch Logs 連携先ロググループは、証跡を作成・更新したアカウントに置く必要がある。**必須** 管理アカウントで証跡を作成する場合は、ロググループと、第9章で定める L-01・L-04・L-14 の検知条件に対応するメトリクスフィルター・アラームを管理アカウントに置き、アラームアクションはセキュリティ（監査）アカウントの SNS トピックヘクロスアカウントで送ること。管理アカウントには SCP が適用されないため、これらの変更は IaC パイプラインに限定し、利用者を最小化したうえで変更を検知統制で補完すること。**推奨** セキュリティ（監査）アカウントを CloudTrail の委任管理者として登録し、同アカウントから AWS CLI または CreateTrail/UpdateTrail API でロググループを設定することにより、これらを SCP の適用対象アカウントに置いてよい（証跡の所有者は管理アカウントのままである）。採用した方式を設計書に明記すること。
- ログアーカイブアカウント**: 全ログの保全先（S3、Object Lock、KMS）。保存専用で分析ワークロードを置かない（6.5 節）。
- セキュリティ（監査）アカウント**: GuardDuty・Security Hub CSPM の委任管理者、Config アグリゲータ、EventBridge → SNS の通知経路、Athena ワークグループ、監査人ロールを配置する。R-5 と R-6 の作業場所。
- ワークロードアカウント（本番／検証）**: 財務報告関連システムの稼働環境。本番と検証は別アカウントとする。ログの発生源であり、長期保全先を持たない（例外として、S3 サーバーアクセスログと RDS for Db2 の監査ログは同一アカウント・同一リージョンの制約から一次保全用バケットを本アカウントに置き、レプリケーションでログアーカイブアカウントへ集約する。6.3・表6-3・5.3.2 参照）。R-3・R-4 の作業場所。



図6-1 J-SOX 対応ログ保管の標準構成（AWS マルチアカウント）。丸数字は下記の流れの説明の番号に対応する。

図6-1 の流れを要約する。

1. 管理アカウントで作成した組織の証跡が全メンバーアカウントへ展開され、管理イベント（L-01）、選択したデータイベント（L-02）、認証イベント（L-04）、ログ基盤自身の変更（L-14）をログアーカイブアカウントの CloudTrail 用バケットへ直接配信する。メンバーアカウント側では組織の証跡を参照できるだけで、削除・停止・変更はできず、ログの写しもメンバーアカウントには保存されない。
2. 各アカウントの Config レコーダーが構成履歴（L-03）を Config 用バケットへ配信し、セキュリティアカウントのアグリゲータから組織横断で参照する。アグリゲータは参照専用であり、レコーダーと配信チャネルの展開は 6.1.3 に示す手段で別に行う。
3. CloudWatch Logs に出力されるログ（L-05～L-10）は、サブスクリプションフィルターから Amazon Data Firehose を経由して集約バケットへ配信する。ただし RDS for Db2 の監査ログ（L-06）は CloudWatch Logs に発行できないため、ワークロードアカウントの一次保全用バケットから S3 レプリケーションで集約バケットへ複製する（5.3.2）。CloudWatch Logs の S3 エクスポート機能は継続的アーカイブの手段として推奨されないため、定期エクスポートに依存した保全設計を行わないこと。**〔任意〕** 代替として CloudWatch Logs のク

ロスアカウント・クロスリージョンのログ集約（Organizations 前提、集約ルール作成後の新規ログのみ複製）を用いてもよい。

4. ネットワーク・エッジのログ（L-11）は各サービスの S3 直接配信で NW 用バケットへ保全する。
GuardDuty・Security Hub CSPM の検出結果（L-12）はセキュリティアカウントへ集約し、GuardDuty の S3 エクスポートで検知結果用バケットへ保全する。Security Hub CSPM の検出結果は、EventBridge ルールから Amazon Data Firehose を経由して検知結果用バケットへ保全する。**必須** 検出結果は GuardDuty 上では 90 日で保持が終了するため、S3 エクスポートを設定すること。バックアップ・リストア（L-13）は、AWS Backup の API・サービスイベントが CloudTrail 用バケットに、Backup Audit Manager レポートの複製が検知結果用バケットに保全される二経路構成である（表6-1・表6-3）。
5. 検知は EventBridge → SNS で R-5・R-4 へ通知する（第9章）。CloudTrail の CloudWatch Logs 連携先ロググループは証拠と同一アカウントに限られるため、L-01・L-04・L-14 のメトリクスフィルターとアラームは管理アカウントに置き、アラームアクションからセキュリティアカウントの SNS トピックへクロスアカウントで送る。監査人（R-6）はセキュリティアカウントの読み取り専用ロールで Athena を実行し、アーカイブをクロスアカウントで読み取る。ログアーカイブアカウントへの直接サインインは監査人にも許可しない。
6. 監査人（R-6）は、セキュリティ（監査）アカウントの Amazon Athena から、ログアーカイブアカウントのログを読み取り専用で抽出する（6.6 節、第12章）。ログアーカイブアカウントへの書込は AWS のサービスと配信信用ロールに限られ、人の書込権限は設けない。保全されたログは S3 Object Lock（コンプライアンスモード）、SSE-KMS、バケットポリシーで保護し、第7章の保存期間に従って検索可能層からアーカイブ層へ移行する。

● 補足

AWS Control Tower を採用する場合、ランディングゾーン 3.0 以降では組織の証拠が用いられ、証拠・Config・ロググループ・ログアーカイブバケットの変更を拒否する必須コントロール（SCP）が自動適用される。ただし既定のログ保持（標準アカウントログ 1 年、アクセスログ 10 年、最長 15 年まで設定可）は発注者の保存方針と一致しない場合があるため、LR-05 の決定値に合わせて明示的に設定し、設定値を設計書に記録すること。Control Tower への登録前にアカウント単位の証拠が存在すると、管理イベントの重複記録による課金が生じうる。

6.3 ログフロー一覧

表6-1 に、ログ種別 L-01～L-14 ごとの標準的な流れを示す。「保全先」はすべてログアーカイブアカウント内のバケットを指す。ただし S3 サーバーアクセスログは、S3 バケットを宛先とする場合は同一アカウント・同一リージョンに限られるため、発生元アカウント内のバケットに一次保全し、レプリケーションでログアーカイブアカウントへ集約する。**必須** 開発ベンダーは本表を案件固有のリソース名・ロググループ名・バケット名・プレフィックスへ具体化して提出すること（6.7 節）。

表6-1 ログ種別ごとの発生源・収集・保全・分析・アラート

ログ種別	発生源	収集手段	保全先	分析手段	アラート経路
L-01 クラウド 基盤 API 操作	全アカウント・全リージョンの API 呼び出し	組織の証跡（マルチリージョン、整合性検証有効）	CloudTrail 用（Object Lock）	Athena（パーティション射影）	CloudWatch Logs のメトリクスフィルター → アラーム → SNS（ロググループ・アラームは管理アカウントに配置。6.2）
L-02 データ アクセス	財務データを保持する Amazon S3・Amazon DynamoDB 等	高度なイベントセレクトで対象リソースを ARN 限定、S3 サーバーアクセスログ（補助）	CloudTrail 用（データイベント）。S3 サーバーアクセスログはワークロードアカウント内の同一リージョンのバケットへ配信し、レプリケーションで集約用へ複製（または CloudWatch Logs 宛て配信を選択し Amazon Data Firehose 経由で集約用へ配信）	Athena	削除系操作の EventBridge ルール → SNS
L-03 構成 変更 履歴	各アカウント・リージョンの Config レコーダー	配信チャンネル（履歴・スナップショット）、組織単位のレコーダー展開、アグリゲータ（参照のみ）	Config 用	Config 高度なクエリ、 <code>get-resource-config-history</code>	Config ルール NON_COMPLIANT → EventBridge → SNS
L-04 認証・ 認可	コンソールサインイン、AssumeRole、IAM Identity Center、アプリ認証	組織の証跡（グローバルサービスイベント含む）、アプリ認証は CloudWatch Logs	CloudTrail 用、集約用	Athena、Logs Insights	root 使用・MFA なしサインイン・認証失敗のメトリクスフィルター → SNS（管理アカウントに配置）
L-05 サーバ 操作	Session Manager セッション、OS 監査ログ	セッション設定で CloudWatch Logs ヘストリーミング、CloudWatch エージェント	集約用	Logs Insights、Athena	特権操作パターンのメトリクスフィルター → SNS
L-06 データ ベース 監査	Aurora 高度な監査、Amazon RDS／Amazon Aurora のエンジン標準の監査機構（MariaDB Audit Plugin、pgAudit、RDS for Db2 の Db2 監査ログ記録）、Database Activity Streams	CloudWatch Logs へのログ発行、DAS は Amazon Kinesis Data Streams → Amazon Data Firehose。RDS for Db2 は発生源アカウントの一次保全用バケットへ出力し S3 レプリケーションで複製	集約用	Logs Insights、Athena	DDL・DCL・特権接続のメトリクスフィルター → SNS（RDS for Db2 は S3 への到着を契機とする解析等。表9-1 の A-22）

ログ種別	発生源	収集手段	保全先	分析手段	アラート経路
L-07 アプリ ケー ション業 務	トランザクション、承認操作、例外処理	SDK・エージェント → CloudWatch Logs（データ保護ポリシー適用）	集約用	Logs Insights、Athena	例外・承認エラーのメトリクスフィルター → SNS
L-08 ジョ ブ・バ ッチ実 行	ジョブスケジューラ、EventBridge Scheduler	CloudWatch Logs（開始・終了・結果コードを構造化出力）	集約用	Logs Insights	異常終了・未実行のアラーム → SNS
L-09 デー タ連 携	インターフェース送受信処理	CloudWatch Logs（送受信件数・整合結果を構造化出力）	集約用	Logs Insights、Athena	件数不一致・未着のアラーム → SNS
L-10 変 更・デ プ ロイ	CI/CD、IaC 適用（スタックイベント、ドリフト検出）	CloudTrail（承認・実行API）、ビルドログ → CloudWatch Logs	CloudTrail 用、集約用	Athena、Logs Insights	パイプライン失敗・承認待ち・ドリフトの EventBridge ルール → SNS
L-11 ネッ トワ ーク・通 信	VPC Flow Logs、ELB、WAF、CloudFront	各サービスの S3 直接配信（クロスアカウント）	NW 用（WAF はバケット名が <code>aws-waf-logs-</code> で始まること）	Athena（パーティション射影）	GuardDuty 検出結果（フローログ・DNS ログを自動取り込み） → EventBridge → SNS。 ELB/WAF のしきい値監視は Athena による定期集計の結果 → SNS（CloudWatch Logs への配信を併用する場合に限り Logs Insights を利用できる）
L-12 セ キュ リ ティ 検知	GuardDuty 検出結果、Security Hub CSPM コントロール結果	委任管理者で集約、GuardDuty の S3 エクスポート（KMS 必須、リージョンごと）。Security Hub CSPM の検出結果は EventBridge ルール →（必要に応じ Amazon Data Firehose） → 検知結果用バケットへ配信	検知結果用	Security Hub CSPM、Athena	検出結果イベント → EventBridge → SNS
L-13 バッ クア ップ・リ ス トア	AWS Backup のジョブ、Vault Lock	CloudTrail（API・サービスイベント）、Backup Audit Manager レポート（クロスアカウント配信不可のため複製）	CloudTrail 用、検知結果用	Athena、レポート	ジョブ失敗・復元実行の EventBridge ルール → SNS

ログ種別	発生源	収集手段	保全先	分析手段	アラート経路
L-14 ログ 基盤 自身	証跡・Config・ロググループ・バケット・KMS キーの変更／削除 試行（AccessDenied 含む）	組織の証跡（ログアーカイブ・セキュリティアカウントを含む、RecursiveLogging を無効化）、アーカイブバケットのデータイベント、サーバーアクセスログ	CloudTrail 用（正の証跡）、アクセスログ用（補助。ベストエフォート配信かつ Object Lock を適用できないため単独では監査証跡としない）	Athena	証跡・Config・バケットポリシー・KMS 変更のメトリクスフィルター → SNS（最優先。管理アカウントに配置）

必須 CloudTrail のイベントは S3 への配信を正とし、CloudWatch Logs 連携は検知用途に限定すること。256 KB を超えるイベントは CloudWatch Logs にも Amazon EventBridge にも送られず、データイベントと Insights イベントはイベント履歴にも表示されないため、検索・抽出は常にアーカイブに対して行う。EventBridge ルールに依存する検知についても、この上限を前提に代替検知（アーカイブに対する定期クエリ等）の可否を検討すること。**必須** 各経路の配信遅延（CloudTrail は平均約 5 分、S3 サーバーアクセスログはベストエフォートで完全性・適時性の保証がない等）を把握し、欠損検知（LR-11）とアラートの評価間隔（LR-08）を遅延より長く設定すること。

必須 アーカイブバケット自身のデータイベントを取得する場合、CloudTrail 自身の配信 PutObject が再帰的に記録されるため、証跡の RecursiveLogging を無効化すること（`aws cloudtrail create-trail --no-recursive-logging` または `aws cloudtrail update-trail --no-recursive-logging`。既定値は有効）。無効化しない場合、CloudTrail の配信操作自体がデータイベントとして繰り返し記録され、ログ量とデータイベント課金が増大する（配信はイベントを集約して行われるため、イベントとログファイルは1対1ではない）。表6-1 の L-06 に挙げた MariaDB Audit Plugin・pgAudit は Amazon RDS／Amazon Aurora のエンジン標準の監査機構としてサービス側で用いられる識別名であり、実装先を特定するため本書では原名のまま用いる。**推奨** 設計書における呼称の扱いは発注者に確認すること。

6.4 単一アカウント構成の場合（小規模案件向け）

6.4.1 採用条件

必須 単一アカウント構成は次のすべてを満たす場合に限り採用すること。(1) 発注者が AWS Organizations を利用しておらず、本案件のためにアカウントを追加できない事情が文書で示されていること。(2) 発注者（R-1・R-2）が 6.4.3 項の限界を理解し、残存リスクの受容を文書で承認していること。(3) 将来のマルチアカウント化に備え、ログ用リソースをワークロードと分離した IaC スタックとして構築すること。**推奨** 提案の前に、管理アカウント（新設）・ログアーカイブアカウント（新設）・既存ワークロードアカウント（招待）の最小3アカウント構成を提示すること。既存ワークロードアカウントを管理アカウントにする構成は、SCP が管理アカウントへ適用されないため採らない。

6.4.2 代替統制

単一アカウントでは SCP・RCP とアカウント境界が使えない。表6-2 の代替統制を組み合わせること。

表6-2 単一アカウント構成における代替統制

統制目的	マルチアカウントでの手段	単一アカウントでの代替	要求
ログの削除・停止の防止	SCP・RCP	ログバケットのバケットポリシーで削除・ライフサイクル変更・ポリシー変更・暗号化設定変更を Deny（ログ管理者ロールおよび IaC パイプラインの実行ロールのみ除外）。開発者・運用者の全ロールにアクセス許可の境界を適用し、証跡・Config・監査ロググループ・ログバケット・ログ用 KMS キーへの変更を拒否	必須
不変性	Object Lock	同じ。コンプライアンスモードは、ルートを含め迂回できない唯一の予防統制として必ず採用する	必須
職務分掌	アカウント境界	ログ管理者（R-5）専用のロールを分離し、運用者・開発者の権限からログ用リソースの変更を除外。権限の付与・変更を CloudTrail で記録し R-1 が定期レビュー（LR-09）	必須
網羅性	組織の証跡	マルチリージョン証跡と Config ルール multi-region-cloudtrail-enabled、cloud-trail-log-file-validation-enabled、cloud-trail-encryption-enabled による検出	必須
ルートユーザーの統制	ルートアクセス集中管理	root の MFA、アクセスキーなし（iam-root-access-key-check）、root 使用時のアラームと R-2 への通知	必須
別管理境界への複製	別アカウント	別リージョンの Object Lock 有効バケットへのレプリケーション。送信元で Object Lock が有効な場合は送信先でも有効化し、レプリケーション用 IAM ロールに s3:GetObjectRetention と s3:GetObjectLegalHold を付与すること。対象は設定後の新規オブジェクトのみであり、既存オブジェクトは S3 バッチレプリケーションで複製すること	推奨

6.4.3 限界と発注者への説明責任

次の限界は構造的に残る。**必須** 開発ベンダーは設計書の「残存リスク」として明記し、発注者の承認を得ること。あわせて、残存する限界のそれぞれについて、表6-2 のどの代替統制が対応し、その有効性をどの証跡（レビュー記録、拒否記録、設定出力）で確認するかの対応表を設計書に記載し、発注者が代替的又は補完的な統制により目的が達成されているかを検討できる形で提示すること。

- IAM 管理権限を持つ利用者は、アクセス許可の境界やバケットポリシーを変更してから削除操作を行える。予防統制として完結するのは Object Lock コンプライアンスモードのみで、証跡の停止（StopLogging）や KMS キーの削除予約は検知でしか対応できない。KMS キー削除には 7～30 日（既定 30 日）の待機期間があるため、待機中の検知と取消（CancelKeyDeletion）を運用手順に含めること。
- ログの生成主体と保全主体が同一アカウントであるため、「運用者が自らの記録を消せない」ことを構成のみでは示せない。運用手順とレビュー記録（LR-09）による補完が必要となり、監査対応の負荷が増える。
- アカウント閉鎖はコンプライアンスモードの保持を無効化する唯一の手段であり、閉鎖権限（root）の統制が保全の最後の砦になる。

● 監査の視点

監査人は「ログを削除・改変できる者は誰か」「その者は財務データを操作できる者と同一か」を問う。単一アカウント構成では両者が同じアカウント内に存在するため、ポリシー文書の実物、削除試行が拒否された記録（AccessDenied）、レビュー記録の 3 点をセットで提示できるよう、設計段階から証跡の出し方を決めておくこと。

6.5 ログアーカイブアカウントの設計詳細

6.5.1 バケット構成とプレフィックス

配信元サービス・暗号化方式・Object Lock の可否が異なるため、バケットは用途別に分ける（表6-3）。

表6-3 ログアーカイブアカウントのバケット構成

バケット（論理名）	格納するログ	Object Lock	暗号化・書込主体	留意点
cloudtrail （CloudTrail 用）	L-01・L-02・L-04・L-14、ダイジェスト	有（コンプライアンス、既定保持＝LR-05 決定値）	SSE-KMS／ cloudtrail. amazonaws.com （aws: SourceArn で証跡に限定）	構築時に配信成功（get-trail-status）と Object Lock 保持設定の付与を実機で確認し、証跡化すること。既定保持期間は LR-05 の発注者決定値とする。バケットの既定保持の変更は以後に配置されるオブジェクトにのみ適用され、既に保持が付与されたオブジェクトの保持期限はコンプライアンスモードでは短縮できない（延長のみ可能）点に留意する。暗号化強制のバケットポリシーは AES256 を併記しないと証跡を作成・更新できない（6.5.3）
config （Config 用）	L-03（構成履歴・スナップショット）	既定保持付きは非対応（既定保持なしは構築時に確認）	SSE-KMS／ config. amazonaws.com	既定保持を有効化した Object Lock バケットへの配信は非対応。既定保持なしの Object Lock バケットを配信先にできるかは構築時に実機で確認すること。AWS Config は配信オブジェクトに保持を付与しないため、保持を用いる場合は付与の主体と契機（S3 Batch Operations 等）を設計書に明記し、付与までの無保護時間を残存リスクとして発注者の承認を得ること。付与の主体を置けない場合は、バージョンニング＋削除拒否のバケットポリシー＋SCP を代替統制とし、表6-3 の例外として記録すること。Config 自身のデータ保持（既定 7 年、30～2,557 日）は別途設定
logs（集約ログ用）	L-05～L-10（Firehose 集約）、アプリケーション認証ログ（L-04 の一部）、L-02 補助として発生元アカウントから複製した S3 サーバーアクセスログ、および RDS for Db2 の監査ログ（L-06。発生元アカウントの一次保全用バケットから複製）	有	SSE-KMS／各アカウントの Firehose 配信ロール、レプリケーションロール	プレフィックスにログ種別・アカウント ID・リージョン・日付を含める。複製先とする場合は Object Lock を有効化し、レプリケーション用ロールに s3:GetObjectRetention と s3:GetObjectLegalHold を付与すること。ライブレプリケーションは設定後の新規オブジェクトのみが対象であり、既存分は S3 バッチレプリケーションで複製する。RDS for Db2 の監査ログは複製元のキー（db2-audit-logs/<リソースID>/...）のまま格納されるため、リソース ID とアカウント・リージョンの対応表を設計書に記載する
network （ネットワーク用）	L-11（Flow Logs、ELB。WAF と CloudFront のレガシー標準ログは別バケット）	有（サービスごとに配信可否を確認）	サービスが対応する方式／各サービスのログ配信	WAF はバケット名要件（aws-waf-logs- で始まる）、CloudFront のレガシー標準ログは ACL 有効化要件があるため、それぞれ別バケットとする。AWS WAF のログ配信先を別アカウントのバケットとする場合は、可否と必要な設定を実装時点の公式ドキュメントで確認すること。この場合、バケット所有者が delivery.logs.amazonaws.com 向けのバケットポリシーを手動で付与し、送信元アカウントごとに Resource エントリを追加する必要がある。暗号化は SSE-S3 または顧客管理 KMS キーのみで、AWS マネージド KMS キーは使用できない

バケット（論理名）	格納するログ	Object Lock	暗号化・書込主体	留意点
findings（検知結果用）	L-12、L-13（レポートの複製）	有	SSE-KMS（GuardDuty はキーとバケットが同一リージョン）／GuardDuty、複製ジョブ	出力先 /AWSLogs/<アカウント>/GuardDuty/<リージョン> は事前作成。リージョンごとに設定
access-logs（アクセスログ用）	上記各バケット（access-logs バケット自身を除く）のサーバーアクセスログ（L-14 の補助）。L-02 の補助であるワークロード側 S3 サーバーアクセスログは発生元アカウントに一次保全し、複製先は logs バケットとする（本バケットには格納しない）	無（Object Lock バケットは宛先不可）	SSE-S3／S3 ログ配信	同一リージョン・同一アカウント必須、ベストエフォート配信。L-14 の正の証跡はアーカイブバケットに対する CloudTrail データイベント（CloudTrail 用バケット、Object Lock 有）とし、サーバーアクセスログは補助とすること。ベストエフォート配信であり Object Lock も適用できないため、単独では監査証跡としない

必須 バージョニング、パブリックアクセスブロック 4 設定、ACL 無効（CloudFront レガシー標準ログ用を除く）、TLS 強制、暗号化されない PutObject の拒否は全バケット共通で適用すること。暗号化強制のポリシーは表6-3 の暗号化方式に合わせて個別に設計し、SSE-S3 のみに対応する配信先（access-logs バケット）に KMS 限定の拒否を課さないこと。

必須 CloudTrail 用バケットで SSE-KMS と整合性検証を併用する場合、SSE-KMS のみを許可するバケットポリシーは証跡の作成・更新を失敗させる。CloudTrail 用バケットの暗号化強制条件の書き方と構築時の確認は 6.5.3 による。

必須 サーバーアクセスログの有効化は access-logs バケット以外の各バケットに対して行い、宛先は access-logs バケットとすること。access-logs バケット自身は対象外として循環を避け、同バケットへの操作は L-14 として CloudTrail 側で記録すること。

推奨 S3 Inventory（Object Lock の保持期限・モード・暗号化状態を含める）を出力し、LR-11 の欠損検知と保持状態の確認に用いること。プレフィックスは Athena のパーティション射影に適合させ、実際のパスを設計書へ転記すること。

```
# AWS サービスが自動生成（変更不可）
s3://<cloudtrail>/AWSLogs/<o-組織ID>/<アカウントID>/CloudTrail/<リージョン>/<yyyy>/<MM>/<dd>/
s3://<cloudtrail>/AWSLogs/<o-組織ID>/<アカウントID>/CloudTrail-Digest/<リージョン>/...
s3://<network>/AWSLogs/<アカウントID>/vpcflowlogs/<リージョン>/<yyyy>/<MM>/<dd>/
s3://<findings>/AWSLogs/<アカウントID>/GuardDuty/<リージョン>/
```

```
# RDS for Db2 監査ログ：RDS が生成するキーのまま発生元バケットから複製（変更不可）
s3://<logs>/db2-audit-logs/<リソースID>/<日時(UTC)>/[<DB名>/]
```

```
# Firehose 集約ログ：開発ベンダーが設計（Hive 形式でパーティション射影に適合させる）
s3://<logs>/<ログ種別>/account=<アカウントID>/region=<リージョン>/dt=<yyyy-MM-dd>/
例) ssm-session/... (L-05)  rds-audit/... (L-06)  app-audit/... (L-07)  interface/... (L-09)
```

● 注意

設計段階で次の制約を確定させること。(1) Config の配信チャネルは既定の保持設定を有効化した Object Lock バケットをサポートしない。既定保持を設定しない Object Lock バケットは配信先にでき、保持はオブジェクト単位に付与できる。(2) Object Lock 有効バケットはサーバーアクセスログの宛先にできない。(3) サーバーアクセスログの S3 宛先は同一リージョン・同一アカウント・SSE-S3 のみで、配信はベストエフォートである。(4) MFA Delete はライフサイクル設定と併用できないため、階層化を行うバケットでは採用しない。(5) ライフサイクルによる削除・移行はバケットポリシーでは防げず、CloudTrail のオブジェクトレベルログにも記録されない（サーバーアクセスログにのみ残る）。よって

`s3:PutLifecycleConfiguration` 自体を拒否し（IaC パイプラインの実行ロールは除外する。6.5.3）、有効期限は Object Lock の保持期間より後に設定すること。(6) 128 KB 未満のオブジェクトは既定で移行対象外であり、Glacier Flexible Retrieval は 90 日、Glacier Deep Archive は 180 日の最小保存期間がある（第 7 章）。

6.5.2 暗号化（AWS KMS）

必須 アーカイブ用キーはログアーカイブアカウントの顧客管理キーとし、ワークロードアカウントのキーを流用しないこと。キーは配信先バケットと同一リージョンに置く（マルチリージョンキーも可）。キーポリシーは各キーにちょうど 1 つで、キーポリシーが IAM を有効化しない限り IAM ポリシーでは許可できないため、許可主体はキーポリシー側で明示的に列挙すること。配信先バケットで S3 バケットキーを使用する場合、`cloudtrail.amazonaws.com` に対する `kms:Decrypt` の許可も必要であり、これを欠くと証跡の作成・更新に失敗する。**必須** CloudTrail 用キーのキーポリシーには `kms:GenerateDataKey*`（暗号化コンテキストと `aws:SourceArn` で証跡に限定）、`kms:DescribeKey`（`aws:SourceArn` で限定）、S3 バケットキー使用時の `kms:Decrypt`、および読み取り者への `kms:Decrypt`（Null 条件で `kms:EncryptionContext:aws:cloudtrail:arn` を `false` に限定）を含めること。キーの無効化やキーポリシーの誤りがあると CloudTrail はログを配信できない。

```
{
  "Sid": "AllowCloudTrailEncrypt",
  "Effect": "Allow",
  "Principal": {"Service": "cloudtrail.amazonaws.com"},
  "Action": "kms:GenerateDataKey*",
  "Resource": "*",
  "Condition": {
    "StringLike": {"kms:EncryptionContext:aws:cloudtrail:arn": "arn:aws:cloudtrail:*:<管理アカウントID>:trail/*"},
    "StringEquals": {"aws:SourceArn": "arn:aws:cloudtrail:<リージョン>:<管理アカウントID>:trail/<証跡名>"}
  }
}
```

必須 キーの削除予約（`ScheduleKeyDeletion`）と無効化（`DisableKey`）は SCP とキーポリシーで拒否し、検知（メトリクスフィルター、Config ルール `kms-cmk-not-scheduled-for-deletion`）を併用すること。**推奨** 自動ローテーション（既定 365 日）を有効化すること。旧キーマテリアルは保持されるため過去ログの再暗号化は不要である。

6.5.3 アクセス経路

アクセス経路は次の 3 種類に限定し、それ以外を SCP・RCP・バケットポリシー・キーポリシーで拒否する。**書込み経路**は AWS サービスプリンシパルと各ワークロードアカウントの Firehose 配信ロールのみとし、`aws:SourceArn`・`aws:SourceAccount` または配信ロール ARN で限定する。**読取り経路**はセキュリティアカウン

トの監査用読取ロール（Athena 経由、6.6 節）とログ管理者ロール（R-5、整合性検証と欠損確認に限る）のみとする。**変更経路**は IaC パイプラインの実行ロールのみとし、SCP・バケットポリシーの除外条件で許可する主体を当該ロールに限定すること（AWS Control Tower を採用する場合の `AWSControlTowerExecution` は、ランディングゾーン運用のためのサービスロールとして別途除外する）。変更の承認記録は L-10 として保全すること（LR-12）。**必須** パイプライン経由の変更の承認者は R-5 または R-2 とし、R-3・R-4 が単独で起票から承認・適用まで完結できない構成とすること。起票者・承認者・適用者の分離をアクセス制御マトリクス（6.7）に記載し、承認記録（L-10）と実際の適用記録（L-14）を突合できるようにすること。

必須 運用者（R-4）・開発者（R-3）はログアーカイブアカウントへの権限セット割当を持たないこと。IAM Identity Center の割当一覧（`list-account-assignments`）で割当が R-5 と IaC パイプラインの実行ロール（人の権限セット割当を伴わないサービスロール）に限られることを、定期レビューで確認し記録すること（LR-09、第10章）。**必須** ログ基盤リソースをタグまたは命名規約で識別し、SCP の対象をそれに限定すること。保護対象を ARN プレフィックスまたはタグ条件で限定し、ワークロード側の鍵・ロググループ運用を阻害しないこと。**必須** AWS Control Tower を採用する場合、ランディングゾーンの更新・アカウント登録が失敗しないよう `AWSControlTowerExecution` ロールを除外に含めること。Control Tower の必須コントロールと重複する拒否は、二重定義せず必須コントロールに委ねる範囲を設計書に明記すること。次にログ基盤保護 SCP の例を示す。可読性のため共通の条件を `<除外>` と表記しているので、実装時は各ステートメントの `Condition` に展開すること。アクション名は公式リファレンスで確認のうえ、案件のリソース名に置き換えること。

```
# <除外> = {"ArnNotLike": {"aws:PrincipalArn": ["arn:aws:iam::*:role/<IaCパイプラインロール>",
#                                           "arn:aws:iam::*:role/AWSControlTowerExecution"]}}
{"Version": "2012-10-17", "Statement": [
  {"Sid": "ProtectOrgTrail", "Effect": "Deny", "Condition": "<除外>",
   "Action": ["cloudtrail:DeleteTrail", "cloudtrail:PutEventSelectors", "cloudtrail:StopLogging",
   "cloudtrail:UpdateTrail"],
   "Resource": "arn:aws:cloudtrail:*:*:trail/<証跡名>"},
  {"Sid": "ProtectConfig", "Effect": "Deny", "Condition": "<除外>", "Resource": "*",
   "Action": ["config:DeleteConfigurationRecorder", "config:DeleteDeliveryChannel",
   "config:DeleteRetentionConfiguration",
   "config:PutConfigurationRecorder", "config:PutDeliveryChannel",
   "config:PutRetentionConfiguration",
   "config:StopConfigurationRecorder"]},
  {"Sid": "ProtectArchiveBuckets", "Effect": "Deny", "Condition": "<除外>",
   "Action": ["s3:DeleteBucket", "s3:PutBucketPolicy", "s3:DeleteBucketPolicy",
   "s3:PutLifecycleConfiguration",
   "s3:PutEncryptionConfiguration", "s3:PutBucketLogging", "s3:PutBucketVersioning"],
   "Resource": "arn:aws:s3:::<アーカイブバケット名プレフィックス>"},
  {"Sid": "ProtectLogKeys", "Effect": "Deny", "Condition": "<除外>",
   "Action": ["kms:ScheduleKeyDeletion", "kms:DisableKey"],
   "Resource": "arn:aws:kms:*:<ログアーカイブアカウントID>:key/*"},
  {"Sid": "ProtectAuditLogGroups", "Effect": "Deny", "Condition": "<除外>",
   "Action": ["logs:DeleteLogGroup", "logs:PutRetentionPolicy"],
   "Resource": "arn:aws:logs:*:*:log-group:<監査ロググループ名プレフィックス>"}
]}
```

バケットポリシーには、CloudTrail 配信用の許可（`s3:GetBucketAcl`、`bucket-owner-full-control` と `aws:SourceArn` を条件とする `s3:PutObject`、組織 ID 配下プレフィックスへの追加ステートメント）に加え、TLS 未使用の拒否（`aws:SecureTransport` が `false`）、指定キー以外での `PutObject` の拒否、`s3:DeleteObject`・`s3:DeleteObjectVersion`・`s3:PutLifecycleConfiguration` の拒否を含めること。

必須 ただし CloudTrail 用バケットで SSE-KMS と整合性検証を併用する場合、SSE-KMS のみを許可するバケットポリシーは証跡の作成・更新を失敗させるため、暗号化強制条件には `"StringNotEquals": {"s3:x-amz-server-side-encryption": ["aws:kms", "AES256"]}` のように AES256 を併記し、構築時に証跡が作成できることを実機で確認すること。**必須** `s3:PutLifecycleConfiguration` の拒否には、SCP と同じく IaC パイプライ

ンの実行ロールを除外する条件（`aws:PrincipalArn` の `ArnNotLike`）を付すこと。除外を欠くとライフサイクル階層化（表6-3、第7章）を適用できない。除外した主体の一覧と、その変更承認記録の保全先を設計書に明記すること。SCP は管理アカウントへ適用されないため、管理アカウントでの証跡変更は検知統制（`CreateTrail` / `UpdateTrail` / `DeleteTrail` / `StartLogging` / `StopLogging` のメトリクスフィルター）と利用者最小化で補完する。

6.6 監査人アクセスの設計

監査人（R-6）は、Amazon Athena のクエリ結果の出力を除き読み取り専用であり、財務データにもログ基盤の設定にも変更権限を持たない。監査人が Athena で直接照会する方式（標準）と、ログ管理者（R-5）が抽出して提供する方式（代替）があり、どちらを主とするかは、発注者が監査人と協議して決める。監査人側の方針により被監査会社環境への直接アクセスが認められない場合があるため、代替方式（R-5 が抽出して提供する方式）はいずれを主とする場合でも実装し、手順を文書化しておくこと。いずれの場合も、クエリ文・実行 ID・対象期間（UTC）・結果ファイルのハッシュ値を証跡として残すこと（第12章）。標準方式の設計項目を表6-4 に示す。

表6-4 監査人アクセスの設計項目

項目	標準設計	要求	残す証跡
認証	発注者が管理する IAM Identity Center のユーザーとして監査人を登録し MFA を必須とする。ベンダー名義や共有 ID を経由させない	必須	サインインイベント（ <code>UserAuthentication</code> ）
権限	監査専用の読み取り専用権限セット。指定ワークグループでの Athena 実行、データカタログ参照、アーカイブの <code>GetObject</code> / <code>ListBucket</code> 、アーカイブ用キーの <code>kms:Decrypt</code> 、結果バケットへの書き込み（クエリ結果の出力に限る）のみ	必須	権限セット定義（ <code>IaC</code> ）と <code>DescribePermissionSet</code> 出力
割当先	セキュリティ（監査）アカウントのみ。ログアーカイブ・ワークロード・管理アカウントへは割り当てない	必須	<code>list-account-assignments</code> 出力
期間限定	監査期間の開始時に割当を作成し終了時に削除する。作成・削除は R-5 が実施し R-1 が承認する。セッション継続時間は必要最短とする。付与・削除は期中評価、期中評価から期末日までの内部統制の変更に対応する追加手続、翌期の前年度比較のたびに反復実施できる手順とし、通年で活動する内部監査については別枠の割当条件を定めること。割当削除後も、再付与により過去期間のログを同一条件で再照会できること	必須	<code>CreateAccountAssignment</code> / <code>DeleteAccountAssignment</code> と承認記録
クロスアカウント読取	アーカイブ側のバケットポリシーとキーポリシーで、監査用ロールの ARN のみを許可し書き込みは許可しない	必須	バケットポリシー・キーポリシーの実物
ワークグループ・結果バケット	監査専用ワークグループを設け、「クライアント側の設定を上書きする（Override client-side settings）」を有効化して、クエリ結果の出力先・暗号化・想定バケット所有者をワークグループ側で固定すること。同オプションは既定で無効であり、有効化しない限り利用者側の設定が優先される。結果バケットはセキュリティアカウント内の専用バケット（SSE-KMS、保持期間は発注者が決定）とする	必須	ワークグループ設定、 <code>StartQueryExecution</code> イベント
操作の記録	監査人の操作も CloudTrail に記録される。個人を特定できるよう <code>onBehalfOf.userId</code> （Identity Center）または <code>sourceIdentity</code> で追跡できることを確認する	必須	CloudTrail の <code>userIdentity</code>

必須 Athena のテーブル定義はセキュリティアカウントに置き、CloudTrail・VPC Flow Logs・ELB・集約ログのそれぞれについてパーティション射影付きのテーブルを IaC で管理すること。テーブル定義の変更はログ設定の変更管理（LR-12）の対象とする。**推奨** 標準抽出クエリ（root 使用、コンソールサインイン失敗、IAM 変更、特定利用者の操作履歴、証跡・Config の設定変更、S3 オブジェクト削除）を名前付きクエリとして同じワークグループに登録し、監査人が同じクエリを再現できるようにすること（第12章）。

● 監査の視点

監査人は、提供されたログが「改変されていない原本から抽出されたこと」と「抽出者が抽出内容を選別できないこと」を確認したい。ワークグループのクエリ履歴、CloudTrail に残る `StartQueryExecution`、結果ファイルのハッシュ値、`validate-logs` の実行結果を対応付けて提示できれば、抽出過程の信頼性を客観的に示せる。

6.7 設計書に含めるべき図・表

開発ベンダーは表6-5 の図・表を設計書（LR-14、第11章）の一部として提出すること。図中の名称は IaC の論理名および実リソース名と一致させ、変更時は同一の変更単位で更新する（LR-12）。

表6-5 開発ベンダーが提出する図・表の一覧

図・表	主な内容	対応する要求事項	提出時期
アカウント・OU 構成図	アカウント ID、OU、委任管理者、SCP・RCP の適用先、利用リージョン（オプトインリージョン含む）	LR-01、LR-06	基本設計
ログフロー図（図6-1の案件版）	発生源→収集→保全→分析→通知の経路、アカウント境界、書込・読取の向き、暗号化キーの位置	LR-01、LR-11	基本設計
ログフロー一覧（表6-1の案件版）	L-01～L-14 ごとの対象リソース名、ロググループ名、バケット名・プレフィックス、担当役割	LR-01、LR-14	基本設計（詳細設計で確定）
ログ対象リソース台帳	財務報告関連システムの全リソースとログ有効化状況、除外リソースと除外理由、棚卸日	LR-01	詳細設計・構築完了時
ログ項目定義表	ログ種別ごとのフィールドと 5W1H の対応、時刻表記（UTC 基準）、機微情報のマスク対象	LR-02、LR-03、LR-07	詳細設計
保存期間・ライフサイクル表	バケット・ロググループ別の保持日数、Object Lock の保持期間とモード、移行日数、根拠と発注者決定の参照	LR-04、LR-05	基本設計（発注者決定後）
暗号化・鍵管理表	KMS キー一覧、配置アカウント・リージョン、キーポリシーの許可主体、ローテーション、削除保護	LR-07	詳細設計
アクセス制御マトリクス	R-1～R-6 × 資源（証跡、Config、ロググループ、バケット、キー、Athena）× 操作と実装手段の対応、およびログ基盤変更の起票者・承認者・適用者の分離	LR-06、LR-13	基本設計
監視・アラート一覧	検知条件（メトリクスフィルター、Config ルール、EventBridge ルール）、閾値、通知先、一次対応者、対応期限	LR-08	詳細設計
欠損検知・可用性設計	配信失敗の検知方法（get-trail-status、Config 配信通知、Firehose 配信エラー）、S3 Inventory による確認、複製構成	LR-11	詳細設計

図・表	主な内容	対応する要求事項	提出時期
ログ設定の変更管理対象一覧	IaC リポジトリ・スタック・パイプライン、変更承認経路、SCP で除外するパイプラインロール	LR-12	詳細設計
責任分界表	AWS・発注者・開発ベンダー・運用ベンダーの責任分担（設定・監視・レビュー・監査対応の担当）。AWS 責任共有モデル上 AWS が担う範囲を含め、委託しても発注者（委託者）の評価責任は移転しないことを明記し、AWS・運用ベンダーが担う範囲の内部統制をどの証拠（AWS Artifact 経由で入手する SOC 1 保証報告書、運用ベンダーからの報告書等）で確認するかを対応付ける。利用する報告書は一定期間の運用状況を対象とするもの（タイプ2）とし、保証期間が評価対象期間を覆っているか、対象システムと範囲が該当するか、委託会社の相補的な内部統制（発注者・開発ベンダーが実施すべき統制）は何かを確認する。期間や範囲が不足する場合の代替手段も記載する	LR-13、 ITGC-D	基本設計
監査対応手順書の付属図表	標準抽出クエリ集、 <code>validate-logs</code> の実行手順、監査人アクセスの申請・付与・削除手順、証拠の提供様式	LR-04、 LR-09、 LR-10	構築完了時

必須 このうちアカウント・OU 構成図、ログフロー図、ログフロー一覧、保存期間・ライフサイクル表、アクセス制御マトリクス、責任分界表は発注者の受入条件とし、基本設計の承認前に提出すること。**推奨** 表6-5 のその他の図・表も提出し、省略する場合は理由を設計書に記載すること。**推奨** 各図・表は構築後の実環境から出力した情報（`describe-trails`、`get-object-lock-configuration`、`list-account-assignments` 等）と突合し、突合結果をテスト証拠として保存すること（第11章）。

7

保存期間とライフサイクル設計

本章は要求事項 LR-05（保存期間とライフサイクル）の実装要求を定める。ログ種別ごとの保存期間の決め方、AWS 上での階層化の実装、保存期限到来後の削除手続、保存期間そのものを変更する際の統制を扱う。改ざん防止の実装は第8章、監視とレビュー運用は第9章、ログ設計書への記載事項は第11章で扱う。

7.1 基本方針

ログの保存年限は、J-SOX を直接の根拠として決めることはできない。財務報告に係る内部統制の評価及び監査の基準（以下「基準」）および財務報告に係る内部統制の評価及び監査に関する実施基準（以下「実施基準」）は、ログの保存年限を規定していない。実施基準が記録の保存期間に言及するのは内部統制の評価記録についてのみであり、「財務報告に係る内部統制について作成した記録の保存の範囲・方法・期間は、諸法令との関係を考慮して、企業において適切に判断されることとなるが、金融商品取引法上は、有価証券報告書及びその添付書類の縦覧期間（5年）を勘案して、それと同程度の期間…保存することが考えられる」（実施基準 II.3(7)②）とされるにとどまる。経済産業省のシステム管理基準および同追補版も「一定期間」「あらかじめ定められた期間」と述べるのみで、具体的な年数を示していない。

したがって本ガイドラインは、次の四つの原則で保存期間を決定する。

7.1.1 決定の四原則

- 1. 評価期間と監査完了までの参照可能性を最優先とする。** 経営者評価は期末日時点の有効性を判断するものであり、実施基準 II.3(3)④ハは「評価時点（期末日）における内部統制の有効性を判断するには、適切な時期に運用状況の評価を実施することが必要となる」とし、運用状況の評価を期中に実施した場合に期末日までに重要な変更があったときは追加手続の実施を検討するとしている。また監査人（R-6）は、評価対象期間中に実施された当該統制の母集団からサンプルを抽出して運用状況を検証するため、抽出対象は期間内のどの時点にもなり得る。ログは、評価対象期間（発注者の1事業年度）の初日から、内部統制報告書の提出および監査完了までの全期間にわたり、欠損なく取得され参照可能とすること。
- 2. 法令上の帳簿保存年限と整合させる。** 会計帳簿・国税関係帳簿書類の保存年限は 7.2 に整理する。ログが会計帳簿そのものやその「重要な資料」に該当するかは発注者の法務・税務判断であり、開発ベンダーは判断材料として年限を提示する立場にある。
- 3. セキュリティ調査に必要な期間の参考値を下回らない。** NISC「政府機関等の対策基準策定のためのガイドライン」および総務省「地方公共団体における情報セキュリティポリシーに関するガイドライン」は、それぞれ政府機関等・地方公共団体を対象とする基準であり、発注者に直接適用されるものではない。ただしセキュリティ調査に必要な期間の参考値として、これらおよび JPCERT/CC の資料はいずれも1年以上の保存を望ましいとしており（7.2 参照）、本ガイドラインはこれを下限の参考値として採用する。
- 4. 最終根拠は発注者の文書管理規程とする。** 開発ベンダーは 7.3 の推奨値を初期値として提案し、発注者の文書管理規程・記録管理規程との整合を確認したうえで、発注者の承認をもって確定すること。

7.1.2 要求事項

- **必須** ログ種別 L-01～L-14 のそれぞれについて、検索可能（ホット）期間、アーカイブ期間、最終的な保存年限、起算日、削除方法、および年限の根拠をログ設計書（第11章）と付録C 設定パラメーター一覧に記載し、発注者の承認を得ること。
- **必須** いずれのログ種別も、評価対象期間の全期間に加え、期末日後の監査完了までの期間を参照できる保存期間とすること。「取得を開始した日」ではなく「評価対象期間の初日」を起点として充足を確認すること。
- **必須** 保存期間は、監査人が「ログは一定期間保管されているか」「ログは証拠として利用できるか」を確認できるよう、設定値だけでなく実データの取り出し可否をもって示せること。
- **推奨** 全ログ種別を単一の保存期間に丸めず、ログ種別ごとに個別に定めること。補助的な技術証跡まで最長年限に合わせると、コストと機微情報の滞留リスクが不必要に増大する。

● 監査の視点

経済産業省「システム管理基準 追補版（財務報告に係るIT統制ガイダンス）」のモニタリングに関する評価手続の例は、「ログは、一定期間保管されている」「ログは、証拠として利用できるか確かめる」に加え、「モニタリング対象として選んだログが、全ての期間で収集されていることを確かめる」ことを挙げている。設定画面の保持期間だけでは足りず、評価対象期間の初日・期中・期末日の各時点について実データを提示できるかが問われる。設計時点で、期間の端（初日および期末日直後）のデータを抽出できることをテスト項目に含めること。

7.1.3 ログの3区分（業種編）

業種編では、7.1.1 の四原則に加え、業種別調査（付録 G）が用いるログの3区分によって保存期間を定める。区分と保存期間の考え方を表7-0 に示す。

表7-0 ログの3区分と保存期間の考え方

区分	内容	保存期間の考え方
(1) 運用ログ	障害調査・運用監視・セキュリティ監視のためのログ	1年を出発点とする（各社の内部規程で定める）
(2) 監査ログ	「誰が・いつ・何をしたか」を示す証拠となるログ（DB 監査ログ、特権操作、アクセス権の変更、財務報告に関わるデータの変更履歴など）	事業年度末から10年を、共通の下限の目安とする（会社法第432条に準じて扱う解釈。株式会社に共通）
(3) 業種固有の記録とその変更履歴	その業種の法令が保存を求める記録と、その記録を扱うシステムの変更履歴・操作履歴	その業種の法令が定める期間と起算点（7.8）

適用される保存期間の下限のうち、最も遅く満了するものを、起算点とともに推奨とする。期間は年数の大小ではなく満了日で比べる。ただし、上限側の制約（個人情報保護法第22条など。7.8）も確認するため、「長い方を選べばよい」とは限らない。

区分が重なる場合の扱いは次のとおりである。業種固有の記録（区分 (3)）への登録・変更・削除・閲覧の操作ログは、「誰が・いつ・何をしたか」を示すため、区分 (2) にも当たる。この場合は、区分 (2) の期間とその記録の法定保存期間のうち、遅く満了する方まで保存する。記録そのものの訂正・削除の履歴（変更前の値）は、記録の一部として区分 (3) の期間保存する。

- **必須** ログ設計書には、ログ種別（L-01～L-14）ごとに、該当する区分と起算点を記載すること。区分 (3) に当たるログ種別は、対象とする記録の名称と根拠の行番号（付録 G）を併記すること。

7.2 参照する法令・基準の年限

年限決定の参照材料を表7-1 に整理する。いずれも「システムログの保存年限」を直接定めたものではない点に注意すること。

表7-1 保存年限の参照根拠

根拠	対象	年限	ログ保存への含意
金融商品取引法 第25条第1項	有価証券報告書、内部統制報告書およびこれらの訂正報告書の縦覧	5年	実施基準が評価記録の保存期間の目安とする期間の根拠
実施基準 II.3(7)②	内部統制の評価手続・評価結果、発見した不備と是正措置の記録	縦覧期間（5年）を勘案し企業が判断	統制の運用証跡として引用したログは、少なくとも評価記録と同程度の期間、参照可能であること
会社法 第432条第2項	会計帳簿およびその事業に関する重要な資料	会計帳簿の閉鎖の時から10年	会計データの生成・更新記録を保持するログ（L-06、L-07）の該当性は発注者の法務判断
会社法 第435条第4項	計算書類およびその附属明細書	作成した時から10年	10年を採用する場合の根拠
法人税法施行規則 第59条第1項・第67条第2項	青色申告法人等の帳簿書類	起算日から7年	区分(2)の期間に含まれる（7.3）。起算日は同条第2項により、帳簿についてはその閉鎖の日の属する事業年度終了の日の翌日から2月を経過した日、書類についてはその作成又は受領の日の属する事業年度終了の日の翌日から2月を経過した日であり、ログ作成日を起点とするライフサイクル日数とは一致しない（7.4.2 参照）
法人税法施行規則 第26条の3第1項	欠損金額が生じた事業年度の帳簿書類	起算日から10年	欠損金が生じた事業年度がある場合、7年では不足しうる
電子帳簿保存法（平成10年法律第25号）第4条・第7条	国税関係帳簿書類の電磁的記録による保存、電子取引の取引情報	保存方法の特例であり、年限は各税法による	電子的保存の要件充足の要否は発注者の税務判断
日本公認会計士協会 品質管理基準報告書第1号 A85項	監査事務所が保存する監査調書	会社法上の会計帳簿の保存期間（10年）が参考。ただし状況により、これより短い期間または長い期間が適当となる場合があるとされる	監査人が調書に取り込んだログ抜粋は監査人側で保存される。発注者側の保存義務を代替しない
NISC「政府機関等の対策基準策定のためのガイドライン（令和7年度版）」遵守事項7.1.4(1)(b)解説	セキュリティ関連ログ（対象は政府機関等）	1年間以上が望ましい	民間企業への直接適用はなく参考値。検索可能（ホット）期間の下限の参考。直近はオンライン、以降は長期保存媒体という階層化も示されている

根拠	対象	年限	ログ保存への含意
総務省「地方公共団体における情報セキュリティポリシーに関するガイドライン（令和6年10月版）」6.1(6)	各種ログ、クラウドサービス上のアクセスログ等の証跡（対象は地方公共団体）	1年以上が望ましい	民間企業への直接適用はなく参考値。クラウド上の証跡にも同水準を求めている
JPCERT/CC「高度サイバー攻撃への対処におけるログの活用と分析方法」	調査用ログ	1年以上が望ましい	民間企業への直接適用はなく参考値。保存期間はログ量の見積りと調査要件・コストのトレードオフで決めるとされる
経済産業省「システム管理基準」II.5.7、同追補版 IV章	運用ログ、インシデント記録	年限の規定なし（「一定期間」「あらかじめ定められた期間」）	年限は企業が定める。定めていないこと自体が不備となりうる

● 注意

会社法および法人税法の年限は、会計帳簿・帳簿書類の保存義務であってシステムログの保存義務ではない。個々のログが「会計帳簿」「重要な資料」「帳簿書類」に該当するかは、発注者の法務・税務部門が判断する事項である。開発ベンダーは表7-1を年限決定の参照材料として提示し、該当性の判断と最終年限の決定を発注者に求めること。開発ベンダーの判断で法令解釈を確定しないこと。

- **必須** 表7-1のうち発注者に適用される根拠（事業年度、欠損金の有無、電子帳簿保存法の適用範囲を含む）を発注者に確認し、確定した年限とその根拠をログ設計書に記録すること。確認できない項目は保留とせず、発注者への確認依頼として明示すること。

業種編では、表7-1に加え、全業種に共通する法令・基準（付録 G の §3）と、保険の法令・ガイドライン（7.8、付録 G）を参照する。表7-1の会社法第432条第2項は、業種別調査が区分(2)の目安の主な根拠とするものである（付録 G の行 J1）。

7.3 推奨保存期間

基本線は、**検索可能（ホット）期間 15か月以上、区分(2)のログは事業年度末から10年まで保存**とする。区分(3)に当たるログは7.8の期間による。ホット期間の下限は取得から15か月以上とする。有価証券報告書は事業年度経過後3か月以内に提出され（金融商品取引法第24条第1項。やむを得ない理由により内閣総理大臣の承認を受けた場合はその期間内）、内部統制報告書はこれと併せて提出されるため（同法第24条の4の4第1項）、事業年度初日に生成されたログを監査完了時点までホットで照会するには12か月では不足する。提出期限の延長承認を受けた事業年度では、7.1.2の必須要求に従い15か月を超える期間が必要となる場合がある。なお545日は、CloudWatch Logsが受け付ける離散値のうち15か月を下回らない最小の値である。

区分(2)の事業年度末から10年は、業種別調査が全業種に共通する下限の目安としたものであり、会社法第432条第2項に準じて扱う解釈である（7.1.3）。法人税法施行規則第59条第1項の7年は、この期間に含まれる。欠損金額が生じた事業年度の帳簿書類に当たるログは、同規則第26条の3第1項により、区分(2)より約2か月以上長くなりうる。内部統制の運用証跡（L-03、L-04、L-05、L-08、L-09、L-10、L-13）について実施基準 II.3(7)②が評価記録の目安とする縦覧期間（5年）は、区分(2)の期間より短い。業種編では、本書の判断として、これらの運用証跡も「誰が・いつ・何をしたか」を示すログとして区分(2)に含める。いずれも監査ログを明記した法定の期間で

はないため、最終値は、法務部門の確認を経て、発注者の文書管理規程に照らして確定すること。表7-2 でこれらのログ種別の根拠・備考欄が「年限の由来は 7.3 本文のとおり」と記すのは、本段落を指す。

ネットワーク・通信ログ（L-11）およびセキュリティ検知ログ（L-12）のような補助的な技術証跡は、財務報告上の位置づけが「取引記録そのもの」ではなく「調査を補完する証跡」であるため、区分 (1) の運用ログとして扱い、区分 (2) の長期アーカイブの対象とする必要はない。ただし 7.1.2 の必須要求により、評価対象期間に期末日後の監査完了までの期間を加えた15か月以上は確保する（セキュリティ調査の参考値である1年以上はこれに含まれる）。補助的な技術証跡はホット期間のみで最終保存年限を満たすため、アーカイブストレージクラスへの移行は設定しない（7.7 参照）。

「検索可能（ホット）」「アーカイブ」「最終保存年限」はいずれも取得時点からの通算期間で示す。ただし区分 (2) の「事業年度末から10年」は、ログが作成された日の属する事業年度の末日を起算点とする（作成日を起点とする日数では4,018日）。「検索可能（ホット）」は照会ツールから直接検索できる期間、「アーカイブ」はホット期間終了後にアーカイブストレージクラスへ移行したうえで、少なくとも当該通算期間が経過するまで取り出し可能に保管することを意味する。「最終保存年限」は削除するまでの通算年限である。CloudWatch Logs は離散値のみ設定できるため、15か月に対しては545日を選択する（7.4.1）。L-11・L-12 はホット期間で最終保存年限を充足するためアーカイブ層を設けず、アーカイブ欄は「—」と表記する。

表7-2 ログ種別ごとの推奨保存期間

ログ種別	検索可能（ホット）	アーカイブ	最終保存年限（推奨）	根拠・備考
L-01 クラウド基盤API操作ログ	15か月以上 （CloudWatch Logs は545日）	事業年度末から10年まで （作成日起点では4,018日）	事業年度末から10年（区分(2)。区分(3)に当たる場合は7.8の期間と遅く満了する方）	ITGC-A/B/Cの基礎証跡。CloudTrailのイベント履歴（90日）は保管手段にならない
L-02 データアクセスログ	15か月以上 （CloudWatch Logs は545日）	事業年度末から10年まで （作成日起点では4,018日）	事業年度末から10年（区分(2)。区分(3)に当たる場合は7.8の期間と遅く満了する方）	財務データの参照・更新・削除の証跡。対象リソースを限定して量を抑える（7.7）
L-03 構成変更履歴	15か月以上 （CloudWatch Logs は545日）	事業年度末から10年まで （作成日起点では4,018日）	事業年度末から10年（区分(2)。区分(3)に当たる場合は7.8の期間と遅く満了する方）	ITGC-A 変更管理の運用証跡。AWS Config 自身の保持期間とS3 配信分の保持は別々に設定する。年限の由来は7.3本文のとおり
L-04 認証・認可ログ	15か月以上 （CloudWatch Logs は545日）	事業年度末から10年まで （作成日起点では4,018日）	事業年度末から10年（区分(2)。区分(3)に当たる場合は7.8の期間と遅く満了する方）	ITGC-Cの主証跡。ID棚卸・特権ID利用のサンプルテストに使用される。年限の由来は7.3本文のとおり
L-05 サーバ操作ログ	15か月以上 （CloudWatch Logs は545日）	事業年度末から10年まで （作成日起点では4,018日）	事業年度末から10年（区分(2)。区分(3)に当たる場合は7.8の期間と遅く満了する方）	特権操作の証跡。記録できない接続経路を遮断する設計（第5章）とセットで成立する。年限の由来は7.3本文のとおり
L-06 データベース監査ログ	15か月以上 （CloudWatch Logs は545日）	事業年度末から10年まで （作成日起点では4,018日）	事業年度末から10年（区分(2)。区分(3)に当たる場合は7.8の期間と遅く満了する方）	会計データの直接更新の証跡。会社法第432条第2項の該当性は発注者判断。RDS for Db2の監査ログはCloudWatch Logsを経由せずS3に出力されるため、検索可能期間はS3上の検索手段（Athena等）で確保する

ログ種別	検索可能（ホット）	アーカイブ	最終保存年限（推奨）	根拠・備考
L-07 アプリケーション業務ログ	15か月以上（CloudWatch Logs は545日）	事業年度末から10年まで（作成日起点では4,018日）	事業年度末から10年（区分(2)。区分(3)に当たる場合は7.8の期間と遅く満了する方）	IT業務処理統制（承認操作・例外処理）の証跡。会計帳簿本体に準ずる項目を含む場合は10年
L-08 ジョブ・バッチ実行ログ	15か月以上（CloudWatch Logs は545日）	事業年度末から10年まで（作成日起点では4,018日）	事業年度末から10年（区分(2)。区分(3)に当たる場合は7.8の期間と遅く満了する方）	ITGC-B。異常終了と対応記録が運用評価の対象となる。年限の由来は7.3本文のとおり
L-09 データ連携ログ	15か月以上（CloudWatch Logs は545日）	事業年度末から10年まで（作成日起点では4,018日）	事業年度末から10年（区分(2)。区分(3)に当たる場合は7.8の期間と遅く満了する方）	送受信件数の整合記録は完全性の主張を支える一次証跡。年限の由来は7.3本文のとおり
L-10 変更・デプロイログ	15か月以上（CloudWatch Logs は545日）	事業年度末から10年まで（作成日起点では4,018日）	事業年度末から10年（区分(2)。区分(3)に当たる場合は7.8の期間と遅く満了する方）	承認証跡は変更管理ツール側にあるため、突合可能な識別子を双方に保持すること。年限の由来は7.3本文のとおり
L-11 ネットワーク・通信ログ	15か月以上（CloudWatch Logs は545日）	ー（アーカイブ層を設けない。ホット期間で最終保存年限を充足する）	15か月以上	財務報告上は補助証跡だが、7.1.2の必須要求により評価対象期間＋監査完了までを満たす期間を確保する。セキュリティ調査の参考値（1年以上）はこれに含まれる。ホット期間で最終保存年限を満たすためアーカイブ段階の実質的な長さは零であり、深い階層への移行は行わない（7.7）。運用上の代替案として、事業年度単位でプレフィックスを分離し、当該事業年度の監査完了まで削除しない運用としてもよい
L-12 セキュリティ検知ログ	15か月以上（CloudWatch Logs は545日）	ー（アーカイブ層を設けない。ホット期間で最終保存年限を充足する）	15か月以上	GuardDutyの検出結果は90日で保持されなくなるためS3エクスポートが必須（表7-4参照）。ホット期間で最終保存年限を満たすためアーカイブ段階の実質的な長さは零である。運用上の代替案として、事業年度単位でプレフィックスを分離し、当該事業年度の監査完了まで削除しない運用としてもよい
L-13 バックアップ・リストアログ	15か月以上（CloudWatch Logs は545日）	事業年度末から10年まで（作成日起点では4,018日）	事業年度末から10年（区分(2)。区分(3)に当たる場合は7.8の期間と遅く満了する方）	ITGC-B。バックアップジョブ一覧APIは直近30日分のみを返す。年限の由来は7.3本文のとおり

ログ種別	検索可能（ホット）	アーカイブ	最終保存年限（推奨）	根拠・備考
L-14 ログ基盤自身の監査ログ	15か月以上（CloudWatch Logs は545日）	保護対象ログの最長年限以上	同左	完全性の証明に必要。保護対象のログより先に消滅してはならない

表7-2の区分は、ログ種別の主な用途に基づく初期値である。同じログ種別でも用途によって区分が変わる場合（運用監視にだけ使う認証の記録など）は、3.5の当てはめ（表3-3）による。区分(1)とした用途のログは、L-11・L-12と同じく15か月以上保存する。

- **必須** L-14の保存期間は、L-01～L-13のうち最長の保存年限以上とすること。
- **必須** 表7-2を初期値として発注者に提示し、発注者の文書管理規程・事業年度・欠損金の有無を踏まえた確定値の承認を得ること。承認前の値で本番設定を確定しないこと。
- **推奨** 機微情報を含みうるログ（L-06、L-07）は、保存期間を長くするほど滞留リスクが増すため、LR-07のマスキング・暗号化とあわせて期間を決めること。
- **必須** 区分(2)の事業年度末から10年が会社法第432条第2項に準じて扱う解釈であること（7.1.3）を発注者に示し、法務部門の確認を経た決定値をログ設計書に記録すること。

区分(3)の記録のうち、起算点が作成日ではなく事象（7.8に示す起算点）によるものは、作成した時点では満了日が決まらない。このため、これらの記録のログは、本書の実装上の要求として次のとおり扱う。S3 Object Lockの既定の保持期間はバケット単位で設定され、プレフィックスごとには設定できない。また、区分(2)の保全用バケットの既定の保持期間は、LR-05の決定値とする（第6章）。

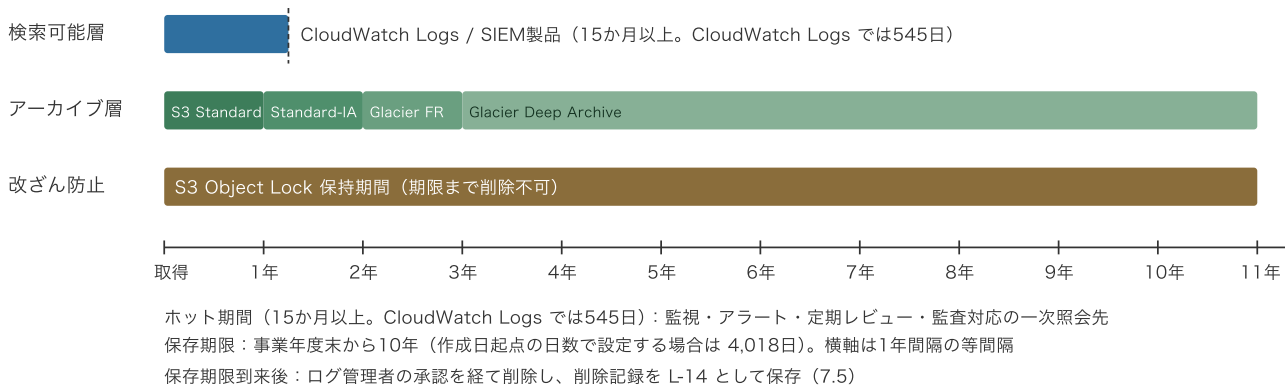
- **必須** 区分(2)のログとは別のバケットに保存し、作成日を起点とする一律の有効期限（Expiration）を設定しないこと。このバケットは、表6-3の保全用バケットとは別に設け、ログ設計書のバケットの一覧に加えること。このバケットの既定の保持期間は、仮の保持期間と同じ値とすること（4.4.2）。
- **必須** Object Lockの保持期間は、書き込み後に、オブジェクトごとの保持期間の設定（PutObjectRetention、またはS3 Batch Operations）で付与すること。まず仮の保持期間を付与し、起算点となる事象の日が確定した時点で、満了日まで延長すること。コンプライアンスモードでは保持期間を延長できるが短縮できないため、仮の保持期間は、確定後の満了日を超えない値とすること。付与と延長の担当者と契機をログ設計書に記載し、付与の状況はS3インベントリで確認すること。
- **必須** 定期レビュー（第9章）の項目として表9-2の項目に加え、仮の保持期限までの残り期間より短い間隔で、次の2点を確認すること。起算点となる事象が確定した記録について、満了日までの延長漏れがないこと。事象が未確定のまま仮の保持期限が近づいた記録について、期限の前に仮の保持期間を延長していること。
- **必須** 満了日を過ぎたログは、7.5の手続により承認を得て削除すること。L-14の保存期間も、延長後の満了日に合わせて延長すること。

7.4 AWS 上の階層化実装

7.4.1 二層構成

検索可能層（CloudWatch Logs または SIEM 製品）と、不変アーカイブ層（Amazon S3）の二層で構成する。図7-1に標準的な時間軸を示す。

図7-1 検索可能層・アーカイブ層・Object Lock 保持期間の関係（区分（2）の例）



- **必須** CloudWatch Logs のロググループには保持期間を明示設定すること。既定ではログデータは無期限に保持される。設定できるのは離散値（1, 3, 5, 7, 14, 30, 60, 90, 120, 150, 180, 365, 400, 545, 731, 1096, 1827, 2192, 2557, 2922, 3288, 3653 日）に限られ、任意の日数は指定できないため、方針値に最も近い上位の値を選び、その選択理由をログ設計書に記載すること。本章が基本線とするホット15か月に対しては545日を選択する（400日は15か月に満たない）。
- **必須** AWS CloudTrail の証跡（Trail）は S3 バケットへ配信し、これを保管の正本とすること。CloudWatch Logs へは監視目的で並行配信するが、256 KB を超えるイベントは CloudWatch Logs および Amazon EventBridge に送られないため、CloudWatch Logs を唯一の保管先としないこと。
- **必須** CloudWatch Logs にしか存在しないログ（OS監査ログ、アプリケーション業務ログ等）の長期保管は、サブスクリプションフィルターから Amazon Data Firehose を経由して S3 へ配信する方式、または CloudWatch Logs の S3/S3 Tables への配信機能を用いる方式で実装すること。いずれの方式でも、最終的な保管先を Object Lock とライフサイクルで保護された S3 バケットとし、採用方式と選定理由をログ設計書に記載すること。S3 エクスポート（CreateExportTask）は継続的なアーカイブ用途には推奨されておらず、エクスポート可能になるまで最大12時間、タスクは24時間でタイムアウトし、同時アクティブタスクはアカウントあたり1つ、ファイル内の時系列順も保証されないため、継続アーカイブの手段としないこと。
- **推奨** 保管上重要なロググループにはロググループの削除保護を有効化すること（既定は無効）。

● 補足

CloudWatch Logs では、保持期限に到達したログデータの実削除に通常最大72時間を要する。「保持期間＝即時消滅」を前提とした説明を運用手順書に書かないこと。なお削除待ちのデータは課金対象外である。

7.4.2 S3 ライフサイクルによる階層化

ストレージクラスごとの最小保存期間と取り出し時間を表7-3 に示す。階層化の設計は、コストだけでなく**監査での提出リードタイム**から逆算すること。

表7-3 アーカイブ層のストレージクラス選択

ストレージクラス	最小保存期間	取り出し	想定用途
S3 Standard	—	即時	取り込み直後～ホット期間
S3 Standard-IA	30日	ミリ秒	ホット期間終了後の中期保管
S3 Glacier Instant Retrieval	90日	ミリ秒	稀に即時照会が必要なアーカイブ
S3 Glacier Flexible Retrieval	90日	Expedited 1～5分／Standard 3～5時間／Bulk 5～12時間	数年単位のアーカイブ
S3 Glacier Deep Archive	180日	Standard 12時間以内／Bulk 48時間以内（Expedited 不可）	最長期アーカイブ

ライフサイクル設定の例を以下に示す（区分 (2) のログを作成日起点の4,018日（事業年度末から10年に相当）保存し、ホット15か月とする構成）。この例は、7.4.3 の Object Lock を併用する前提で**バージョニングを有効化したバケット**に適用するものである。バージョニング有効バケットでは、Expiration は現行バージョンに削除マークを付与して非現行化するだけで実データは消滅せず、恒久削除は NoncurrentVersionExpiration が制御する。したがって設計上の削除日は「Expiration の日数＋NoncurrentDays」の合算となる。Expiration の日数を Object Lock の保持日数以上とし（7.4.3）、両者の合算が最終保存年限を超える分を最小限（NoncurrentDays の日数分）に抑えるよう設定したうえで、恒久削除が実際に行われることを 7.4.3 の制約に照らして検証環境で確認すること。非バージョニングバケットでは Expiration がそのまま恒久削除となるため、同じ日数設定でも挙動が異なる。移行日数の間隔は各クラスの最小保存期間を上回るように設定している。

```
{
  "Rules": [
    {
      "ID": "audit-log-tiering-fy10y",
      "Status": "Enabled",
      "Filter": { "Prefix": "AWSLogs/" },
      "Transitions": [
        { "Days": 366, "StorageClass": "STANDARD_IA" },
        { "Days": 731, "StorageClass": "GLACIER" },
        { "Days": 1096, "StorageClass": "DEEP_ARCHIVE" }
      ],
      "Expiration": { "Days": 4018 },
      "NoncurrentVersionExpiration": { "NoncurrentDays": 1 }
    }
  ]
}
```

保存期間の保持そのものはライフサイクルではなく Object Lock の保持期間で担保する。Object Lock の保持期間中は、ライフサイクルによっても当該バージョンは削除されない。また公式ドキュメントは、Object Lock 設定が適用されたオブジェクトの非現行バージョンに対して Amazon S3 はいかなるアクションも行わないとしており、NoncurrentVersionExpiration による恒久削除が実行されない構成があり得る（7.4.3）。上の例は、Expiration 4,018日＋NoncurrentDays 1日により通算4,019日で恒久削除され、最終保存年限（作成日起点の4,018日）をわずかに超える設定である。実際に恒久削除が行われるかは検証環境で実測し、行われない場合は 7.5 の承認済み手動削除手続によること。ログアーカイブバケットのオブジェクトは追記のみで上書きされず、非現行バージョンは削除マーク付与時にのみ発生し、その時点で既に最深階層にあるため、NoncurrentVersionTransitions は定義しない（S3 Glacier Deep Archive から他のストレージクラスへのライフ

サイクル移行は定義できず、移行はウォーターフォール順に限られる)。すべてのバージョンが削除され削除マーカーのみが残った場合、Amazon S3 は当該の期限切れ削除マーカーを削除する。明示的に整理する場合は `ExpiredObjectDeleteMarker` を用いた別ルールとして定義すること（同一の `Expiration` ブロック内で `Days` と併記することはできない）。

- 必須** 監査で提出を求められる期間のログを S3 Glacier Deep Archive に置く場合は、取り出しに要する時間（Bulk で48時間以内、Standard で12時間以内）を監査対応の所要時間として第12章の手順書に明記し、発注者と監査人の期待と整合させること。
- 必須** ライフサイクルの日数はオブジェクト作成日を起点とする。一方、法人税法施行規則第59条第2項の起算日は「事業年度終了の日の翌日から二月を経過した日」であり両者は一致しない。発注者の事業年度末日を確認したうえで、ログ作成日起点の日数が法定年限に不足しないよう算定すること。あるいは事業年度単位のプレフィックスでオブジェクトを分離し、事業年度単位でライフサイクルと削除を適用すること。
- 必須** 128 KB 未満のオブジェクトは既定でどのストレージクラスにも移行されない。ログは小さいオブジェクトが大量に生成されやすいため、配信側のバッファリング設定でオブジェクトを集約するか、`ObjectSizeGreaterThan` を明示して意図した移行が行われることをテストで確認すること。なお2024年9月より前に作成されたライフサイクル設定は旧来の挙動（S3 Glacier Flexible Retrieval と S3 Glacier Deep Archive へは移行する）を保持するが、ルールを作成・編集・削除した時点で新しい既定挙動に切り替わる。既存環境の設定を 7.6 の変更管理で改訂する際は、変更前後で小オブジェクトの移行有無が変わらないことを確認すること。既定の最小サイズ自体を変更する場合は `PutBucketLifecycleConfiguration` の `x-amz-transition-default-minimum-object-size` ヘッダーを用いること。
- 必須** ライフサイクルによる削除・移行はバケットポリシーでは阻止できない。ライフサイクル設定自体を変更管理の対象とし、7.6 の統制を適用すること。
- 必須** ライフサイクルの操作は CloudTrail のオブジェクトレベルログには記録されない。移行・有効期限の実績は、**S3 Inventory の世代間差分（ライフサイクル適用前後のオブジェクトバージョン一覧の差分、および Object Lock 保持期限・モード・リーガルホールドのフィールド）を一次証跡**とし、S3 サーバーアクセスログ（論理削除は `S3.CREATE.DELETEMARKER`、恒久削除は `S3.EXPIRE.OBJECT`、階層移行は `S3.TRANSITION_GDA.OBJECT` 等）を補完的証跡と位置づけて証跡化すること。サーバーアクセスログはベストエフォート配信であり、特定のリクエストのレコードが配信されないことがあるなど完全性・適時性が保証されないため、単独で削除実績の証跡としないこと。
- 必須** Object Lock を有効化したバケットはサーバーアクセスログの配信先にできないため、**アーカイブバケット自身を配信先にせず、Object Lock を有効化していない別のログ用バケットまたは CloudWatch Logs を配信先とすること**。S3 バケットを配信先とする場合、配信先バケットは元バケットと同一リージョン・同一アカウントである必要があり、暗号化は SSE-S3 のみで SSE-KMS を使用できない。ログアーカイブを別アカウント／別リージョンに集約する構成、または LR-07 により顧客管理 KMS キーでの暗号化を要求する場合は、CloudWatch Logs を配信先とし、そこから長期保管先へ転送すること。
- 必須** MFA Delete を有効化したバケットではライフサイクル設定を使用できない。改ざん防止は Object Lock で実装すること（第8章）。
- 推奨** 1つのルール内で最小保存期間を下回る連鎖移行は定義できないため、移行日数を変更する際は表7-3の最小保存期間を満たしていることをレビュー項目とすること。
- 任意** アーカイブの一部を S3 Glacier Instant Retrieval に置き、取り出しに要する時間を短縮する構成は、保管コストと監査対応の所要時間の兼ね合いで、発注者と協議して採否を決めること。

7.4.3 Object Lock 保持期間とライフサイクルの関係

Object Lock はバージョニングが有効なバケットでのみ動作し、有効化後は Object Lock の無効化もバージョニングの停止もできない。保持期間の延長はいずれのモードでも可能である。コンプライアンスモードでは保持モードの変更と保持期間の短縮ができず、ルートユーザーを含むいかなるユーザーも保持期限前の上書き・削除ができない。期限前に削除する唯一の方法は AWS アカウントの削除である。ガバナンスモードでは `s3:BypassGovernanceRetention` 権限と `x-amz-bypass-governance-retention:true` ヘッダーにより、オブジェクトの上書き・削除に加えて保持設定そのものの変更・解除が可能である。

- 必須** ライフサイクルの有効期限（`Expiration`）日数は、Object Lock の保持日数以上とすること。公式ドキュメントは、Object Lock 設定が適用されたオブジェクトの**非現行バージョン**に対して Amazon S3 はいかなるアクションも行わないとしており、非現行バージョンの恒久削除がライフサイクルでは実行されない構成があり得る。一方、現行バージョンに対する `Expiration` は保持期間中であっても削除マーカの付与として成立する（Object Lock は削除マーカの付与を妨げない）。したがって、保持期限後に恒久削除が実際に行われるかを検証環境で実測して確認したうえで本番に適用し、行われない構成であることが判明した場合は 7.5 の承認済み手動削除手続を代替手段として手順書に定めること。
- 必須** コンプライアンスモードの保持日数は、検証環境での実証を経てから本番に設定すること。過大な値を設定すると、誤って取り込んだデータも含めて保持期限まで削除できない。 `s3:object-lock-remaining-retention-days` 条件キーにより、設定できる保持期間の上下限を制御できる。
- 必須** ガバナンスモードを採用する場合は、`s3:BypassGovernanceRetention` 権限の保有者を 7.6 の例外ルールとして限定し、当該権限の使用（保持設定の変更・解除、バイパス削除）を L-14 として検知・記録すること。統制強度はコンプライアンスモードと同等ではない点を、モード選定の理由とともにログ設計書に記載すること。
- 必須** AWS Security Reference Architecture は、S3 に保存された CloudTrail ログオブジェクトの完全性保護手段として、ログファイル整合性検証と S3 Object Lock の二つを挙げている。採用するバケットの Object Lock 構成（既定保持設定の有無、モード、保持日数）ごとに、対象サービスからの配信が継続することを検証環境で実証してから本番に適用すること。既知の制約例は次項のとおり。
- 必須** AWS Config は、既定の保持設定を有効化した Object Lock バケットを配信チャネルとしてサポートしない。したがって Config の配信先と長期保管先の関係は、配信先バケットと保管バケットを分けて保管側へ複製する方式、または既定保持設定を用いずオブジェクト単位で保持を付与する方式などの選択肢から選定すること。ただし S3 レプリケーションでは、複製オブジェクトはソースバケットの Object Lock 構成を引き継ぎ、宛先バケットの既定保持設定は S3 Replication を経由せず直接アップロードされたオブジェクトにのみ適用される。複製方式を採用する場合は、宛先で S3 Batch Operations または `PutObjectRetention` により保持を明示的に付与する手順を設計に含め、保持が実際に付与されていることを S3 Inventory の保持期限・モードのフィールドで検証すること。いずれの方式も、配信が継続することに加え、宛先オブジェクトに意図した保持期間・モードが付与されていることを検証環境で実証した結果をもって採否を決めること。選定理由と検証結果をログ設計書に記載すること。
- 推奨** Object Lock の保持期限・モード・リーガルホールドの状態は S3 Inventory のフィールドとして出力できる。定期レビュー（第9章）で保持設定の網羅性（Object Lock の付与漏れがないこと）を確認する手段として利用すること。

7.4.4 サービス固有の保持設定

AWS の各サービスには、S3 ライフサイクルとは独立した保持の既定値・上限がある。表7-4 の全項目について、方針値との差分を確認し、明示設定または補完手段を設計すること。

表7-4 サービス固有の保持設定と既定値

対象	既定	設定範囲	設計上の留意点
Amazon CloudWatch Logs（ロググループ）	無期限	1～3,653日の離散値	明示設定が必須。実削除まで通常最大72時間
AWS Config（設定項目の保持）	2,557日（7年）	30～2,557日	Config 自身のデータストアの保持であり、S3・SNS へ配信したデータの保持は別管理
AWS CloudTrail イベント履歴	90日	変更不可	管理イベントのみ・単一アカウント／単一リージョン。CloudTrail の証跡（Trail）の代替にならない
CloudTrail Lake（既存利用者のみ）	1年延長可能保持で366日／7年保持で2,557日	前者は最大3,653日、後者は2,557日	2026年5月31日をもって新規利用者への提供が終了しており、新規に利用を開始することはできない（既存利用者は継続利用可）。KMS キーは関連付け後に変更・削除できない
Amazon GuardDuty 検出結果	90日	変更不可	S3 エクスポートが必須。アーカイブ済みの検出結果はエクスポートされない
AWS Backup ジョブ一覧（ListBackupJobs）	直近30日	変更不可	CloudTrail のサービスイベントとレポートプランの S3 出力で補完する
AWS Systems Manager Session Manager のセッション履歴	過去30日のレポート	変更不可	S3 または CloudWatch Logs へのセッションログ出力設定が必須
Systems Manager Run Command の実行履歴	30日	変更不可	S3 または CloudWatch Logs へ出力すること。既定では出力の先頭24,000文字のみ返される
AWS Control Tower のログ保持	標準アカウントログ1年／アクセスログ10年	最長15年（日・年単位）	既定値のまま放置せず、本章の方針値に合わせて明示設定すること

- **必須** 新規設計では CloudTrail Lake を前提としないこと。CloudTrail の証跡（Trail）＋S3＋CloudWatch Logs を基本構成とし、既存利用者が Lake を併用する場合も長期保管の正本は S3 に置くこと。
- **必須** 表7-4 の各項目について、既定値のままとするか明示設定するかをログ設計書に記載し、既定値のままとする場合はその理由（方針値を満たしている旨）を明記すること。

7.5 保存期限到来後の削除手続

保存期限が到来したログの削除は、事前に承認されたライフサイクル設定による自動削除を原則とする。手動削除は例外であり、以下の手続を経ること。自動削除・手動削除のいずれであっても、削除の事実が事後に検証できることが要件である。

- **必須** 削除の申請には、対象ログ種別（L-xx）、対象期間、対象バケット・プレフィックスまたはロググループ、概算オブジェクト数・容量、適用した保存期間とその根拠、削除方法（ライフサイクル／手動）を記載すること。
- **必須** 削除はログ管理者（R-5）および発注者システム所管（R-2）の承認をもって実行すること。開発ベンダー（R-3）または運用者（R-4）の単独判断で実行しないこと。ライフサイクルによる自動削除については、ライフサイクル設定の初回適用時および変更時に同じ承認を得ること。
- **必須** 削除前に、訴訟・調査・監査対応等による保全（法的保全）の対象でないことをログ管理者が確認すること。保全が必要なログは `s3:PutObjectLegalHold` によるリーガルホールドで期限のない保全を適用し、ラ

ライフサイクルの有効期限対象から除外すること。通常の保持（retention）と、本来破棄される時期を過ぎても保全する保全（preservation）を手順書上で区別すること。

- **必須** Object Lock の保持期限が到来していることを確認すること。保持期間またはリーガルホールドで保護されたオブジェクトでは、モードを問わず（ガバナンスモードで `s3:BypassGovernanceRetention` 権限とバイパスヘッダーを伴わない場合を含む）、バージョンIDを指定した恒久削除は保持期限前には拒否され（403 Forbidden）、削除ジョブは失敗する。一方、バージョンIDを指定しない単純な削除要求は 200 OK で成功し、削除マーカが付与されるだけで実データは残存する。削除完了の確認は、削除マーカの有無ではなくオブジェクトバージョンが消滅したことをもって行うこと。
- **必須** Object Lock の制約により（7.4.3）ライフサイクルによる恒久削除が実行されない構成である場合は、保持期限到来後に本節の承認を得たうえで S3 Batch Operations 等により恒久削除を実行する手順を手順書に定め、実施結果を証跡化すること。自動削除を前提とした記述のまま放置し、実データが残存しているのに削除済みと扱わないこと。
- **必須** 削除実績を証跡化すること。証跡の取得方法（S3 Inventory の世代間差分を一次証跡とし、S3 サーバアクセスログを補完的証跡とする）と保存先は 7.4.2 の定めによる。
- **必須** 削除記録（実行日時、実行者、承認者、対象、件数、結果、証跡の保存パス）を L-14 として記録し、削除対象ログの保存年限以上の期間保存すること。削除記録が削除対象より先に消滅しない設定とすること。
- **推奨** 保存期限到来による削除は、四半期または年次のバッチ処理として計画し、実施時期を発注者の決算・監査スケジュールと重ならないよう調整すること。

● 注意

Object Lock の保持期間はライフサイクルによる削除より優先される設計を前提とするが、両者の設定値が矛盾していると、意図した時期に削除されない（保持期限がライフサイクル有効期限より長い）か、想定より早く削除される（Object Lock が付与されていないオブジェクトが存在する）事態が生じる。Object Lock の付与漏れは S3 Inventory の保持期限・モードのフィールドで検出できる（7.4.3 参照）。

7.6 保存期間変更の統制

ロググループの保持期間、S3 ライフサイクル、Object Lock の保持日数、AWS Config の保持期間は、いずれも統制の有効性を直接左右する統制パラメータである。これらの変更は LR-12（ログ設定の変更管理）に従い、アプリケーションの変更と同等の変更管理下に置くこと。

- **必須** 保存期間に関わる設定を IaC（Infrastructure as Code）で定義し、レビューと承認を経たパイプラインからのみ適用すること。マネジメントコンソールおよび CLI からの直接変更を運用手順上禁止し、権限設計でも制限すること。AWS Security Reference Architecture は、ログアーカイブ用アカウントの設定変更をパイプライン経由に限定することを推奨している。
- **必須** 保持期間の短縮・削除に関わる API を SCP（サービスコントロールポリシー）で制限すること。AWS Control Tower の必須コントロールは、対象リソースに対して `logs:DeleteLogGroup`、`logs:PutRetentionPolicy`、`s3:PutLifecycleConfiguration`、`s3:DeleteBucket`、`config:PutRetentionConfiguration`、`config:DeleteRetentionConfiguration`、`cloudtrail:StopLogging`、`cloudtrail:DeleteTrail` 等を拒否する SCP 本文を公開している。保持期間短縮系の API をまとめて拒否する単一の公式サンプルは提供されていないため、これらを参考に発注者のリソース命名規則と例外ルールに合わせて作成し、例外ルールの利用者を限定すること。7.4.3 でガバナンスモードを採用する場合は、`s3:BypassGovernanceRetention` も同じ例外ルールの管理下に置くこと。

- 必須** 設定変更の検知を実装すること。CloudTrail 設定変更および AWS Config 設定変更については、CIS ベンチマークが規定するメトリクスフィルタが公式に示されている。これらのパターンは項目を追加・変更するとコンプライアンスチェックが不合格となるため改変せず、保持期間変更（PutRetentionPolicy、PutBucketLifecycle、PutRetentionConfiguration、PutBucketObjectLockConfiguration 等）の検知は別のメトリクスフィルタとして追加すること。なお、これらの CloudWatch 系コントロールが Security Hub CSPM で自動評価されるのは CIS AWS Foundations Benchmark v1.2.0 および v1.4.0 であり、v3.0.0 以降では手動チェック扱いとなる。発注者が採用する標準バージョンを確認し、自動評価されない場合はメトリクスフィルタとアラームの存在確認を第9章の定期レビュー項目に含めること。また PutBucketLifecycle は S3 バケットポリシー変更を対象とする公式パターンにも含まれるため、重複して発報させるかを設計時に決めること。
- 必須** オブジェクト単位の保持変更は管理イベントではなくデータイベントとして記録される点に注意すること。PutObjectRetention を呼び出すと、CloudTrail のデータイベントに eventName が PutObjectLockRetention として記録される。PutObjectLegalHold も同様にデータイベントである。したがって、当該ログアーカイブバケットを対象とする S3 データイベントを CloudTrail の証跡で有効化し、そのイベントが検知用ロググループに到達していなければ検知できない（7.7 でデータイベントを限定する際は、ログアーカイブバケット自身を限定範囲に含めること）。管理イベントのみで完結させたい場合は、Object Lock 設定の変更検知をバケットレベル管理イベントである PutBucketObjectLockConfiguration を対象として行い、オブジェクト単位の保持変更は S3 Inventory の保持期限・モードのフィールド差分で点検する方式に切り替えること。

```
# 以下2件は CIS が規定する公式パターン（改変するとコンプライアンスチェックが不合格となるため改変しないこと）
# CloudTrail 設定変更
{($.eventName=CreateTrail) || ($.eventName=UpdateTrail) || ($.eventName=DeleteTrail) ||
 ($.eventName=StartLogging) || ($.eventName=StopLogging)}

# AWS Config 設定変更
{($.eventSource=config.amazonaws.com) && (($.eventName=StopConfigurationRecorder) ||
 ($.eventName=DeleteDeliveryChannel) || ($.eventName=PutDeliveryChannel) ||
 ($.eventName=PutConfigurationRecorder))}

# ここから下は自組織で定義するパターン（環境に合わせて追加・変更してよい）
# 保存期間の変更検知（管理イベント。上記とは別のメトリクスフィルタとして自組織で定義する例）
{($.eventName=PutRetentionPolicy) || ($.eventName=DeleteRetentionPolicy) ||
 ($.eventName=PutBucketLifecycle) || ($.eventName=DeleteBucketLifecycle) ||
 ($.eventName=PutRetentionConfiguration) || ($.eventName=DeleteRetentionConfiguration) ||
 ($.eventName=PutBucketObjectLockConfiguration)}

# オブジェクト単位の保持変更（S3 データイベント。当該バケットのデータイベントが同じロググループに到達している場合のみ発報する）
{($.eventName=PutObjectLockRetention) || ($.eventName=PutObjectLegalHold)}
```

- 推奨** AWS Config のマネージドルール cw-loggroup-retention-period-check（既定の MinRetentionTime は365日）により、ロググループの保持期間が方針値を下回っていないことを継続的に評価すること。ただし MinRetentionTime の有効値は 1, 3, 5, 7, 14, 30, 60, 90, 120, 150, 180, 365, 400, 545, 731, 1827, 3653 日に限られ、2,557日（7年）等は指定できない。方針値がこれらに一致しない場合は、直下の有効値（例: 2,557日の方針に対し1,827日）を閾値としたうえで、方針値そのものとの一致確認は AWS Config の高度なクエリまたは describe-log-groups の実測値突合で補完すること。なお本章が基本線とするホット15か月に対しては、545日を閾値として指定できる。
- 必須** 保持期間を「無期限（Never expire）」のまま運用しているロググループが存在しないことを継続的に検出すること。AWS Config マネージドルール cw-loggroup-retention-period-check は無期限保持のロググループを COMPLIANT と判定するため、当該ルールを採用する場合も、AWS Config の高度なクエリ等によ

る無期限保持の検出を併用すること。保持期間を定めていないことは、コスト面の問題であると同時に「保存期間を定め管理している」という統制の主張が成立しない状態でもある。

- **必須** 保存期間の短縮は既存証跡の消滅につながるため、変更前に影響範囲（対象ログ種別、消滅する期間、その期間を証跡として用いる統制と評価手続）を分析し、発注者内部統制担当（R-1）の承認を得ること。監査人への事前確認の要否は発注者が判断する事項であり、開発ベンダーは分析結果を提供すること。
- **必須** 変更後は、ログ設計書および付録C 設定パラメーター一覧を同一の作業単位で更新し、適用結果を実測値（保持期間・ライフサイクル設定の取得結果）で確認して証跡化すること。設定変更の記録は L-14 として保存すること。

7.7 コストとの両立

ログ量は運用開始後に増加し続ける。コスト最適化は必要であるが、統制の有効性と引き換えにはしてはならない。

- **必須** 統制上必要と定めたログの取得停止、記録項目の削減、保存期間の短縮によってコストを下げないこと。コスト最適化は、階層化、ストレージクラスの選択、オブジェクトの集約、照会方法の使い分けによって行うこと。
- **必須** アラートを発報するロググループ（LR-08）および S3 ヘサブスクリプション転送するロググループは、CloudWatch Logs の Standard クラスとすること。Infrequent Access クラスはメトリクスフィルターとサブスクリプションフィルターに対応しない。ログクラスはロググループ作成後に変更できないため、設計段階で確定すること。なお両クラスの料金差は取り込み分のみで、保存と Logs Insights の料金は同額である。
- **推奨** 長期照会のみを目的とし、アラートも転送も行わないロググループには Infrequent Access クラスの採用を検討すること。ただし Infrequent Access クラスは `GetLogEvents` および `FilterLogEvents` API に対応せず、ログイベントの参照は CloudWatch Logs Insights に限られる。第12章の証跡抽出手順が当該APIに依存しないことを確認したうえで採否を判断すること。
- **推奨** CloudTrail の証跡は重複を排除すること。管理イベントの最初のコピーには追加料金がかからないが、同一リージョンで管理イベントを重複記録する2本目以降の証跡（組織の証跡とメンバーアカウント独自の証跡の併存を含む）は課金対象となる。
- **推奨** データイベント（L-02）は、高度なイベントセレクトタにより財務報告に関連するバケット・プレフィックス・リソースタイプに限定すること。限定した範囲と除外した範囲、およびその判断理由をログ設計書に記載すること。ただし 7.6 の保持変更検知が成立するよう、ログアーカイブバケット自身は限定範囲に含めること。
- **必須** 管理イベントの発生元サービスの除外（`ExcludeManagementEventSources`）を採用する場合は、発注者の承認を得ること。除外している間のイベントは事後に回復できず、AWS Config のマネージドルール `multi-region-cloudtrail-enabled` も除外設定がある場合を NON_COMPLIANT と判定する。
- **推奨** 小さなオブジェクトを大量に生成しないよう、配信側のバッファリングでオブジェクトを集約すること（128 KB 未満のオブジェクトの扱いは 7.4.2 参照）。S3 Glacier Flexible Retrieval および S3 Glacier Deep Archive ではオブジェクトごとに合計40 KB（うち8 KB は S3 Standard 料金、32 KB は移行先クラスの料金）のメタデータ容量が加算されるため、小オブジェクトの大量生成はコスト効率と階層化の双方を損なう。最小保存期間を下回る時点での移行は残期間分が課金されるため、短命な補助証跡（L-11）を深い階層へ移行しないこと。
- **推奨** 照会コストはスキャン量に比例するため、パーティション射影と期間条件により対象を限定すること（第12章）。

- **必須** コスト最適化のために採用した設計判断（ログクラスの選択、ホット期間の長さ、データイベントの限定範囲、階層移行の日数）と、その統制上の影響評価をログ設計書に記載し、発注者の承認を得ること。

● 監査の視点

記録が残っていないコスト削減は、監査時に「必要な証拠を意図的に取得していない」と評価されうる。逆に、限定の範囲・理由・発注者の承認が文書化されていれば、それは統制の設計判断として説明できる。コスト最適化の判断こそ、実施した内容と同時に文書化すること。第9章の定期レビューでは、ログ量とコストの推移に加え、取得範囲・保存期間が承認された設計どおりであることも点検対象とすること。

7.8 保険の保存期間

本節は、業種別調査の保険の推奨案（付録 G の § 6.5）を、ログの 3 区分（7.1.3）ごとに示す。表中の行番号は付録 G の行番号である。

7.8.1 推奨保存期間

保険の推奨保存期間を表7-5 に示す。表7-5 は、付録 G の § 6.5 の推奨案を再構成したものであり、期間・起算点・根拠 ID の記述は業種別調査のとおりである。(2) の作成日起点の日数（4,018日）は、本書の 7.3 による共通の前提である。

表7-5 保険の推奨保存期間

区分	推奨する保存期間	起算点	根拠ID	理由
(1) 運用ログ	1年（業種固有の追加なし）	ログの作成日	ING9（参考：ING1・ING2）	保険業法・監督指針に年数の定めはない。サイバーセキュリティガイドラインは保存期間を手続に定めることを求めるのみ。監督指針は、システムの開発・変更の記録について、保存期間を定めて保管することを求める（ING11）。インターネット取引の認証ログは「事後検証に資する」保存が求められる（ING2）ため、不正検知・顧客通知に使うものは(2)とするかを検討する
(2) 監査ログ	ログ作成日の属する事業年度末から10年（共通の下限と同じ。作成日起点の日数で設定する場合は4,018日。7.3）	事業年度末	株式会社：J1。 相互会社：IN1（・IN2）。取得の根拠：ING1・ING8・ING9	保険業法は、監査ログについて共通の下限より長い期間を定めていない。相互会社は会社法432条の対象外だが、保険業法54条の2が同じ「帳簿閉鎖の時から10年」を定めるため、株式会社・相互会社とも(2)は同じになる。監督指針・実務指針はアクセス記録の取得・保存を明記するが年数はないため、期間は共通の下限による
(3) 業種固有の記録とその変更履歴	保険契約の消滅日から5年（満期のほか、解約・失効等による消滅を含む）。ただし、閲覧の方法で交付した書面のデータ（IN7）は、期間中に苦情の申出があれば、5年の終了日と苦情の解決日の遅い方まで、消去・改変できない状態で保持する（IN8は起算点が最終取引日）。変額保険の特別勘定の経理に関わるものは保険期間の終了日から10年。苦情処理・利益相反管理などの記録は作成日から5年。いずれも(2)にも当たるものは(2)と遅く満了する方まで	契約の消滅日／最終取引日（IN8）／苦情の解決日／保険期間の終了日／作成日	IN6・IN7・IN18（消滅+5年）、 IN9（保険期間終了+10年、保守的解釈）、ING4（保険期間終了まで）、IN11～IN15（作成+5年）、 IN5（締結+5年）	保険業法令は、契約に関わる帳簿・記録の多くを契約の消滅を起算点として定める（仲立人の帳簿、電磁的交付書面、金融サービス仲介業者の記録）。保険会社自身の契約記録・募集記録（意向把握記録など）には法定の保存期間がないが、監督指針は銀行等の募集時の記録を「保険期間が終了するまで」としており、同じ起算点の「消滅+5年」に揃えると説明しやすい

表7-5の(3)の根拠IDのうち、IN9は特定特別勘定元帳(①)を指す。同じIN9の総勘定元帳(②)は作成の日から5年、業務の委託契約書(③)は委託契約の終了の日から5年である（付録GのIN9）。保険金信託業務を行う生命保険会社の信託勘定系の帳簿（IN10）は、§6.5の推奨案には挙がっていないが、本書では、§2の区分(3)の定義（その業種の法令が保存を求める記録）に当てはめて(3)に加える。信託勘定元帳は10年（信託財産の計算期間の終了の日または信託行為によって設定された期間の終了の日から）、総勘定元帳は5年（作成の日から）、委託契約書は5年（委託契約の終了の日から）である（付録GのIN10）。

保険の法令の期間と、共通の下限（区分(2)=事業年度末から10年）との関係は、次のとおりである（付録Gの§6.5）。

- 長い（または長くなりうる）もの：契約の消滅・保険期間の終了を起算点とする期間（IN6・IN7・IN9・IN18、ING4）。終身保険などの長期契約では、保存の終了日が作成から数十年後になり、(2)よりはるかに長い。特にIN9①（変額保険の特定特別勘定元帳）は、保守的に読むと「保険期間の終了から10年」であり、最も長い。
- 同じもの：相互会社の会計帳簿・重要な資料（IN1。10年・帳簿閉鎖の時）。

- 短いもの：特定保険募集人の帳簿書類（IN5。締結の日から5年）、苦情処理・利益相反管理・保険金支払関係の記録（IN11～IN15。作成の日から5年）、変額保険の総勘定元帳（IN9②。作成の日から5年）。また、1年契約の損害保険では「消滅+5年」は作成から約6年で満了し、(2) より短い。

保険仲立人の帳簿（IN6）は、消滅日から見れば(2)の10年より短い、作成日から見れば、契約期間が約5年を超えると(2)より長く保存することになる（付録 G の IN6）。期間は、年数の大小ではなく満了日で比べる（付録 G の §2）。

7.8.2 区分(3)の記録と起算点

保険の区分(3)の記録の多くは、保険契約の消滅という将来の事象を起算点とする。書込み時に保存期間を固定する方式（例：作成日から固定日数のオブジェクトロック）では表現できない。契約の存続中は保存を継続（リーガルホールド相当）し、消滅が確定した時点で N 年の保存期間を設定する、という二段階の設計が必要である。契約データの変更履歴・操作履歴を、契約 ID に紐づけて管理できることが前提になる（付録 G の INF1）。消滅日が確定しない契約（終身保険など）の履歴を、どの単位でまとめて保存するかも決める必要がある（付録 G の INF1）。

起算点となる「消滅」の範囲は、条文に定義がない。失効（復活の可能性がある）、転換、更新、解約・満期・保険金支払による消滅などで、起算点の扱いが変わる。保守的には、復活可能期間の満了、転換後の新契約の消滅、更新を通算した最後の消滅を起算点とする（付録 G の INF2）。この点の公式な解釈は、業種別調査で確認していない（付録 G の §6.7 の 2）。

起算点は、記録の種類と事業者の種類で異なる。

- 保険契約が消滅した日：保険仲立人の帳簿書類（IN6）、保険仲立人の電磁的交付書面（IN7）、金融サービス仲介業者の記録（IN18）（付録 G の IN6、IN7、IN18）。
- 保険契約の締結の日：特定保険募集人の帳簿書類（IN5）。長期契約では、契約の存続中に保存期間が満了しうる（付録 G の IN5）。
- 記載事項に掲げられた取引を最後に行った日：特定保険契約の電磁的交付書面（IN8）（付録 G の IN8）。
- 苦情の解決日：IN7 は、期間中に苦情の申出があれば、期間の終了日と苦情の解決日の遅い方まで保持する。IN8 は、苦情の申出があれば、期間の終了日と苦情の解決日の遅い方まで保持する（付録 G の IN7、IN8）。
- 保険期間の終了日：変額保険の特定特別勘定元帳（IN9①）。条文は「保険年度の終了の日又は保険期間の終了の日」であり、読み方は解釈である。確認までは、保守的に「保険期間の終了日から10年」とする（付録 G の IN9、INF3）。公式な解釈は確認していない（付録 G の §6.7 の 1）。銀行等の募集時の記録（ING4）は「保険期間が終了するまで」である（付録 G の ING4）。
- 作成の日：利益相反管理・保険金支払関係・苦情処理の記録（IN11～IN15）（付録 G の IN11～IN15）。

代理店システムを複数の種類の事業者で共用する場合は、最も長い「消滅+5年」に揃えるのが安全である。特定保険募集人の規模要件は毎事業年度末に判定されるため、要件を満たした年度から帳簿の保存が必要になる（付録 G の INF5）。

業種別調査は、消滅日などの事象の日から数える期間を日数で設定する場合の換算を示している。「消滅日から5年」は、うるう日を1回含む場合1826日、2回含む場合1827日である。「10年」は、うるう日を2回含む場合3652日、3回含む場合3653日である。ただし、うるう年でない2100年をまたぐ期間では1回少なくなり、5年で1825日、10年で3651日になりうる。保存期間を日数で設定する場合は、多い方（5年＝1827日、10年＝3653日）を使えば不足しない（付録 G の §6.5）。これらは事象の日（消滅日など）を起点とする日数であり、作成日を起点とする日数ではない。本書では、INF1 の二段階の設計で、消滅が確定した時点に設定する保存期間として扱う。区分(3)の期間を作成日起点の日数に換算した値は、業種別調査に示されていないため、本書も示さない。

区分(3)の記録への操作ログを区分(2)と重ねる場合は、「事業年度末から10年」と、その記録の期間（例：「消滅日から5年」）のうち、遅く満了する方まで保存する（付録Gの§6.5）。保険会社自身の契約データとその変更履歴を、区分(3)の「消滅+5年」とするか、「事業に関する重要な資料」として区分(2)の10年も満たすかは、法務部門と決める。推奨案は、遅く満了する方まで保存する（付録GのINF7）。

電磁的交付書面のデータ（IN7・IN8）は、保存期間中「消去し又は改変することができないもの」でなければならない一方、顧客の消去の指図があれば消去できるとされており、システムは両方を満たす必要がある（付録Gの§6.4、INF6）。コンプライアンスモードのObject Lockは、保持期限前の削除ができず（2.5.2）、保持期間を延長できるが短縮できない（付録GのCF6）。この2点から、本書の当てはめとして、消去の指図がありうるデータに短縮できない保持設定を使う場合は、指図による消去と両立するかを発注者と確認すること。実装の方式は、7.4.3と第8章の保持設定・リーガルホールドの定めに従う。

全業種に共通する法令では、犯罪収益移転防止法の確認記録（7年）も、起算点が取引終了日であるため、長期の顧客関係では作成から10年を超えて保存が必要になりうる。特定事業者の一覧には保険会社・少額短期保険業者が含まれる（付録GのCM8、CM10、CF7）。取引記録は取引日から7年である（付録GのCM9）。そのほかの全業種に共通する記録（労働関係の記録など）の起算点の扱いは、付録Gの§3.5による。

7.8.3 上限側の制約

保険では、保存を長くしすぎることを制約する次の規定・ガイドラインがある（付録Gの§6.4）。

- 個人情報保護法22条：利用する必要がなくなった個人データは、遅滞なく消去する努力義務。保険の監査ログ・契約データには、契約者・被保険者・受取人の氏名、病歴などが含まれうる（付録GのJ10、§6.4）。
- 金融分野の個人情報ガイドライン7条：保険契約者等の個人データは「契約終了後一定期間内とする等」、利用目的に応じて保存期間を定め、経過したものは消去する「こととする」。個人情報保護法22条（努力義務）より強い書き方であり、金融分野に固有の上限側の制約である。契約データを「無期限に保存」とする設計は、これと整合しない（付録GのING10、§6.4）。
- 機微（センシティブ）情報：金融分野ガイドライン第5条1項は、要配慮個人情報や保健医療に関する情報などを「機微（センシティブ）情報」とし、列举された場合を除き、取得・利用・第三者提供を行わないこととしている。保存期間を定める規定ではないが、ログに病歴などを含めると、業務上必要な範囲を超える利用になりうる。マスキングを検討する（付録Gの§6.4）。
- 電磁的交付書面の消去条項：顧客の消去の指図があれば消去できる。システムは「消去・改変できない」要件と「指図による消去」を両立させる必要がある（付録GのIN7、IN8、§6.4）。
- 監督指針II-4-5-2(2)（クレジットカード情報等）：保存期間を設定し、経過後は速やかに廃棄する。保険料のカード払いを扱う場合は、ログにカード番号等を残さない設計が前提になる（付録Gの§6.4）。
- 通信の秘密に相当する、保険業に固有の上限規定は見当たらない（付録Gの§6.4）。

全業種に共通する制約として、番号法20条は個人番号を含む特定個人情報の保管を禁止しており、ログには個人番号を記録しないことで衝突を避けるのが基本である（付録GのCM17、CMG7、§3.4）。保存しているログは開示請求の対象になりうるため、保存を長くすると開示請求への対応範囲が広がる（付録GのCM22）。また、区分(2)の10年は解釈に基づく期間であり、法令で保存期間が定められている場合の例外にそのまま当たるとは言い切れない。そのため、目的（内部統制の監査・不正調査）と期間の根拠を内部規程に明記しておく（付録GのCMG4、§3.4）。変額保険の特定特別勘定元帳を長期保存する場合は、金融分野ガイドライン7条の消去との兼ね合いも、法務部門の確認事項に含める（付録GのINF3）。

7.8.4 判断が必要な論点

業種別調査が保険について挙げる、判断が必要な論点を表7-6に示す（付録Gの§6.6）。

表7-6 保険の保存期間について判断が必要な論点

ID	論点	必要な判断
INF1	契約に連動する保存期間の実装。区分(3)の保存期間は、契約の消滅という将来の事象から数えるため、書込み時に保存期間を固定する方式（例：作成日から固定日数のオブジェクトロック）では表現できない。契約の存続中は保存を継続（リーガルホールド相当）し、消滅が確定した時点でN年の保存期間を設定する、二段階の設計が必要である	契約管理システムから「消滅日」を受け取り、保存期間を設定する仕組みを設けるか。消滅日が確定しない契約（終身保険など）の履歴を、どの単位でまとめて保存するか
INF2	「消滅」の範囲。失効（復活の可能性はある）、転換（旧契約の消滅と新契約の成立）、更新（1年契約の損害保険を毎年更新する場合、更新ごとに新契約とみるか）、解約・満期・保険金支払による消滅などで、起算点の扱いが変わる。条文は「保険契約が消滅した日」とだけ定めている	法務部門と、失効・転換・更新の扱いを決める。保守的には、復活可能期間の満了、転換後の新契約の消滅、更新を通算した最後の消滅を起算点とする
INF3	IN9①「保険年度の終了の日又は保険期間の終了の日」の読み方。「又は」が、保険年度ごとに数えるのか、早い方・遅い方のいずれかなのか、条文からは明らかでない。同じ構文が信託勘定元帳（IN10など）にもある。「保険期間の終了から10年」は、いずれの読み方でも不足しない安全側の設定である。長期保存と金融分野ガイドライン7条（ING10）の消去との兼ね合いも、法務部門の確認事項に含める	変額保険を扱う場合は、法務部門に確認する。確認までは、保守的に「保険期間の終了日から10年」とする
INF4	意向把握・募集記録の保存期間。意向把握の帳票・意向確認書面・高齢者募集の録音などは、法令上の保存期間がない（IN17・ING3・ING5）。監督指針は銀行等の募集記録を「保険期間が終了するまで」としている（ING4）	推奨案では「消滅+5年」としたが、ING4に合わせて「保険期間の終了まで」とする、または保険法95条（3年。IN19）に余裕を持たせた期間とする選択肢もある。紛争対応の必要性和、個人情報の消去（ING10）とのバランスで、法務・コンプライアンス部門が決める
INF5	事業者の種類による違い。特定保険募集人は「締結+5年」、保険仲立人・金融サービス仲介業者は「消滅+5年」と、起算点が異なる。一般の保険募集人には帳簿の保存義務自体がない（IN4）。代理店システムを複数の種類の事業者で共用する場合は、最も長い「消滅+5年」に揃えるのが安全である	対象システムの利用者が、どの種類の事業者に当たるかを確認する。規模要件（所属保険会社等15以上、手数料等10億円以上）は毎事業年度末に判定される（規則236条の2）ため、要件を満たした年度から帳簿の保存が必要になる点にも注意する
INF6	電磁的交付書面の改ざん防止（IN7・IN8）。閲覧の方法で交付した書面の電子データは、保存期間中「消去し又は改変することができないもの」でなければならない。これはログではなく交付データの要件だが、同じストレージ設計（WORM、改ざん検知）で満たすことが多い。顧客の指図による消去を認める必要がある	交付データの保存基盤を監査ログと共用するか。消去の指図の記録（誰が・いつ・何を消去したか）を(2)として残すか
INF7	保険会社の契約記録そのもの。保険会社が保有する保険契約のデータ（申込書、保険証券の控えなど）の保存期間を、保険業法令は直接定めていない（変額保険の特別勘定を除く）。会社法432条（J1）の「事業に関する重要な資料」に当たるかは解釈である	契約データとその変更履歴を(3)として「消滅+5年」とするか、「事業に関する重要な資料」として(2)の10年も満たすかを、法務部門と決める（推奨案は、遅く満了する方まで保存）

業種別調査では、次の項目を確認していない（付録Gの§6.7）。対象システムがこれらに関わる場合は、別途確認する。

- ・規則75条の2第3項1号「保険年度の終了の日又は保険期間の終了の日」の公式な解釈（INF3）
- ・「保険契約が消滅した日」に、失効・転換・更新がどう当たるかの公式な解釈（INF2）
- ・意向確認書面・意向把握帳票の保存期間に関する金融庁の解釈（パブリックコメント回答、Q&A）。監督指針の本文に期間の記載がないことは確認済みである

- 保険業法・同法施行規則の帳簿書類を電磁的記録で保存する場合の要件（e-文書法に基づく金融庁所管の主務省令のうち、保険業法関係の部分）。業種別調査は、e-文書法の金融関連施行規則の要件について SC13（証券・資産運用編の付録 G に収録）を参照するとしているが、保険業法の帳簿がどの条で電磁的保存の対象とされているかは確認していない
- 少額短期保険業者に固有の帳簿書類の保存規定。保険業法施行規則の全文を検索した範囲では見つからなかったが、準用規定の網羅的な確認はしていない
- 「金融機関における個人情報保護に関する Q & A」（令和8年10月1日適用）の、ログ・保存期間に関する記述の有無

生命保険協会・日本損害保険協会の自主ガイドライン類と個人情報保護指針、FISC の安全対策基準、ISO/IEC 27001・JIS Q 27001、PCI DSS などの民間・業界団体の基準や有料の規格は、業種別調査の対象外である（付録 G の § 6.8）。

7.8.5 要求事項

- **必須** 表7-5 を初期値として発注者に提示し、事業者の種類（保険会社〔株式会社・相互会社〕、特定保険募集人、保険仲立人、金融サービス仲介業者など）と、変額保険・保険金信託業務の取扱いの有無に応じた確定値の承認を得ること。
- **必須** 区分 (2) の根拠 ID を会社形態に合わせて記載すること（株式会社は J1、相互会社は IN1）。業種別調査に根拠の記載がない事業者（外国相互会社以外の外国保険会社等、少額短期保険業者）は、法務部門が確認した根拠を記載すること。保険業法13条を保存期間の根拠として書かないこと（付録 G の § 6.5、IN3）。
- **必須** 起算点が事象の日である区分 (3) の記録（IN5～IN10・IN18 の帳簿・記録・データ、推奨案により「消滅+5年」とする契約記録・募集記録、CM8 の確認記録）は、記録ごとに契約 ID と起算点となる日を保持し、事象の日から満了日を計算できるようにすること。作成日起点の固定日数だけで保存期限を設定しないこと（付録 G の INF1、CF3、CM8）。
- **必須** 契約に連動する記録は、契約の存続中は保存を継続し、契約管理システムから受け取った消滅日に基づいて保存期間を設定すること。日数で設定する場合は、5年＝1827日、10年＝3653日を下回らないこと（付録 G の INF1、§ 6.5）。
- **必須** 「消滅」に失効・転換・更新をどう含めるかを法務部門と決め、その結果をログ設計書に記録すること（付録 G の INF2）。
- **必須** 電磁的交付書面のデータ（IN7・IN8）を扱う場合は、保存期間中、消去・改変できない状態で保持し、苦情の申出に応じて苦情の解決日まで保持期限を延長する手段と、顧客の指図により消去する手続を設計書に記載すること（付録 G の IN7、IN8、INF6）。
- **必須** 変額保険を扱う場合は、法務部門の確認までは、特定特別勘定元帳を保険期間の終了日から10年保存すること（付録 G の INF3）。
- **必須** 区分 (3) の記録への登録・変更・削除・閲覧の操作ログは、区分 (2) の期間とその記録の期間のうち、遅く満了する方まで保存すること（付録 G の § 6.5）。
- **推奨** 代理店システムを複数の種類の事業者で共用する場合は、帳簿書類の保存期間を「消滅+5年」に揃えること（付録 G の INF5）。
- **推奨** 意向把握・募集記録（録音を含む）の保存期間は、推奨案の「消滅+5年」を初期値とし、法務・コンプライアンス部門が決めた値と理由を記録すること（付録 G の INF4）。
- **推奨** 契約者向け Web サービスの認証ログのうち、不正検知・顧客通知に使うものを区分 (2) とするかを決め、記録すること（付録 G の § 6.5、ING2）。

- **必須** 個人データを含むログと契約データの保存期間を、利用目的に応じて規程に定めること。契約データを無期限の保存としないこと（付録 G の ING10、§ 6.4）。
- **必須** ログにカード番号等と個人番号を記録しない設計とすること（付録 G の § 6.4、CM17、CMG7）。
- **推奨** ログに病歴などの機微情報を含めないよう、マスキングを検討すること（付録 G の § 6.4）。
- **必須** ログの取得・監視・保存の手続を文書化し、保存期間とログの改ざん防止を手続に含めること（付録 G の ING9）。
- **必須** システムの開発や変更の記録の保存期間を規程に定めること（付録 G の ING11）。

8

改ざん防止と完全性の実装

本章は、LR-04（改ざん防止と完全性の保証）を AWS 上でどのように実装し、どのような証跡を残すかを定める。対象は「記録された内容が後から書き換えられないこと」だけではない。本章でいうログの完全性（integrity）とは、**記録が止められないこと・範囲が縮められないこと・消されないこと・そしてそれらが起きたときに気付けること**を合わせたものである。したがって本章は、予防統制（予防的統制。設定変更・削除をさせない）、保全（保存済みログを不変にする）、検証（改ざん・欠落がないことを確認する）、発見統制（発見的統制。試行を検知する）の4層を扱う。

● 補足

実施基準が IT の統制目標「信頼性」の構成要素（正当性・完全性・正確性）として定義する「完全性（記録した取引に漏れ、重複がないこと）」とは別に、本章ではログという記録そのものの保全に関する性質を指して「完全性」の語を用いる。第1章で学ぶ実施基準上の定義と混同しないこと。また、経済産業省のガイダンスは「予防的統制」「発見的統制」の語を用いる。本書は以降「予防統制」「発見統制」と表記し、両者は同義として扱う。

本章は IT 全般統制の領域のうち ITGC-B（システムの運用・管理）と ITGC-C（内外からのアクセス管理などシステムの安全性の確保）の双方を中核とし、責任分界の面で ITGC-D（外部委託に関する契約の管理）に関係する。保存期間そのものの決定は第7章、ログ管理者ロールの権限設計と職務分掌は第10章、アラートの通知先・エスケーションは第9章で定める。本章はそれらを前提に、改ざん防止に必要な設定・テスト・証跡だけを規定する。

● 監査の視点

経済産業省「システム管理基準 追補版（財務報告に係るIT統制ガイダンス）」（令和6年12月25日）は、**運用管理**（本書の ITGC-B に対応する領域）の統制評価手続の例として、ログの記録や保管に際して改ざんや削除ができないかを確認することを挙げている。同ガイダンスは、その具体的手続として、情報システムとデータ処理に関する操作状況を調査し、調査した時間帯のログのサンプルを取得したうえで、取得されたログの完全性と正確性を確かめることを例示している。本書は、この確認をより直接的に裏付けるため、発注者の受入条件として 8.7 の完全性テストの結果提出を求める。

8.1 脅威モデル

統制を設計する前に、誰がどの経路でログを改ざん・削除・停止し得るかを特定すること。AWS 環境では、ログの改ざんは「ファイルの書き換え」よりも「配信の停止」「記録範囲の縮小」「保持設定の変更」「暗号鍵の削除」という**設定操作**の形で発生する。いずれも通常の運用操作と外形が似ており、痕跡も残りにくい。

8.1.1 想定される主体

- **運用者（R-4、運用ベンダーを含む）** — 本番環境に恒常的な権限を持つため、影響が最も大きい。悪意だけでなく、保持期間やライフサイクルの誤設定、不要と判断したロググループの削除といった**誤操作**も同じ結果を

もたらす。

- **開発ベンダー要員（R-3）** — 障害調査のための一時的な昇格権限、共有ID、踏み台経由のアクセスが経路となる。加えて、CI/CD 実行ロールに広い権限が与えられていると、パイプライン経由でログ設定が変更され得る（L-10 と LR-12 の対象）。
- **侵害された認証情報** — 攻撃者は活動の痕跡を消すため、CloudTrail の停止と保存済みログの削除を優先的に試みる。予防に失敗した場合でも、試行そのものが検知できることが重要となる。
- **ルートユーザー** — AWS Organizations の SCP はメンバーアカウントのルートユーザーにも適用されるが、**管理アカウントには適用されない**。またサービスリンクロールにも適用されない。ルートユーザーでも削除できない状態を作れるのは、S3 Object Lock のコンプライアンスモードなど限られた仕組みだけである。
- **ログ管理者（R-5）自身** — 例外ロールは統制の抜け穴になり得る。R-5 の操作は L-14（ログ基盤自身の監査ログ）として記録し、申請・承認とあわせてレビュー対象とすること。

8.1.2 脅威の分類

以下の7分類を本章の脅威IDとし、8.2以降の統制、8.6の検知項目、8.7のテストを対応付ける。脅威ID（T-1～T-7）は本章限りの識別子であり、他章の固定IDとは別の体系である。 **必須** 自環境版の脅威一覧をログ設計書に記載すること。

- **T-1 記録の停止** — `cloudtrail:StopLogging` / `DeleteTrail`、`config:StopConfigurationRecorder` / `DeleteConfigurationRecorder` / `DeleteDeliveryChannel`、エージェントやサブスクリプションの停止。
- **T-2 記録範囲の縮小** — `cloudtrail:UpdateTrail` / `PutEventSelectors` による対象の絞り込み。特に `ExcludeManagementEventSources` に `kms.amazonaws.com` を設定すると AWS KMS の管理イベントが記録されなくなり、**除外していた期間のイベントは事後に回復できない**。データイベントの無効化（L-02の欠落）も同じ性質を持つ。
- **T-3 保存済みログの改ざん・削除** — S3 オブジェクトの上書き・削除（`s3:DeleteObject` / `s3:DeleteObjectVersion`）、ロググループの削除（`logs:DeleteLogGroup`）、バケット自体の削除。
- **T-4 保持期間・ライフサイクルの悪用** — ライフサイクルルールによる早期の有効期限切れ、CloudWatch Logs の保持期間短縮。**バケットポリシーではライフサイクルによる削除・移行を防げない点、およびライフサイクルによる削除は CloudTrail のオブジェクトレベルログに記録されず、S3 サーバーアクセスログでしか確認できない点により、最も痕跡が残りにくい経路である。**
- **T-5 暗号鍵の削除・無効化** — `kms:ScheduleKeyDeletion` / `kms:DisableKey`。暗号文は残るが復号できず、実質的な消去となる。削除の待機期間は 7～30 日（既定 30 日）であり、この間に検知できれば `CancelKeyDeletion` で回復できる。
- **T-6 検知・通知の無効化** — `guardduty:DeleteDetector`、`securityhub:DisableSecurityHub`、メトリクスフィルターやアラームの削除、通知先の購読解除。
- **T-7 特権による統制の迂回** — ルートユーザーの利用、過大な管理者権限、CI/CD 実行ロール。AWS マネージドポリシー `AWSCloudTrail_FullAccess` は監査機能を無効化・再設定できるため、付与を最小限に留めること。

● 注意

T-2 と T-4 は「ログが消えた」のではなく「最初から記録されていない／保持期限が来ただけ」という外形をとるため、事後の復元も、通常のログ調査による発見も期待できない。この2分類については、予防統制（SCP と Object Lock）と設定変更の即時検知を必須とすること。

8.2 多層防御の全体像

単一の統制で改ざん防止を成立させることはできない。ログの生成から参照までの経路に沿って、予防・保全・検証・発見を重ねること。全体像を図8-1に示す。基本方針は次の4点である。

- **必須** 保存先を専用のログアーカイブアカウントに分離し、当該アカウントへの書き込みはAWSサービスのプリンシパルに限定、読み取りは第10章で定めるログ管理者（R-5）および監査人（R-6）の読み取り専用ロールに限定すること。AWS Security Reference Architecture は Log Archive アカウントを「不変ストレージであり、制御・自動化・監視された仕組みからのみアクセスされる」ものと位置付けている。
- **必須** 組織の証跡（organization trail）を用いること。組織の証跡はメンバーアカウント側で削除・停止・設定変更ができないため、アカウント単位の証跡より強い予防統制となる。組織にアカウントが追加されると自動的に記録が開始される点も、LR-01（網羅性）の維持に有効である。
- **必須** ログアーカイブ用 S3 バケットは、バージョニングを有効化したうえで S3 Object Lock（コンプライアンスモード）を適用し、SSE-KMS で暗号化すること（8.4、LR-07）。適用範囲は L-01、L-02 のうち CloudTrail データイベント、および L-04～L-14 を集約するログアーカイブバケットとする。既定保持期間を設定した Object Lock バケットを配信先にできない L-03（構成変更履歴）と、Object Lock を有効化したバケットを配信先にできない S3 サーバーアクセスログ（L-02 の一部）については、8.4 の注意 (1)(3) および 8.5.1 に従い別バケットを設計し、その保全方式（バージョニング、削除拒否、保存期間）をログ設計書に記載すること。
- **推奨** ログ基盤の設定変更は IaC とパイプライン経由に限定し、コンソール・CLI からの直接変更を行わないこと。変更履歴は L-10 として保全し、LR-12（ログ設定の変更管理）の証跡とすること。

図8-1 ログの流れ（生成→配信→保管→参照）と防御層の対応

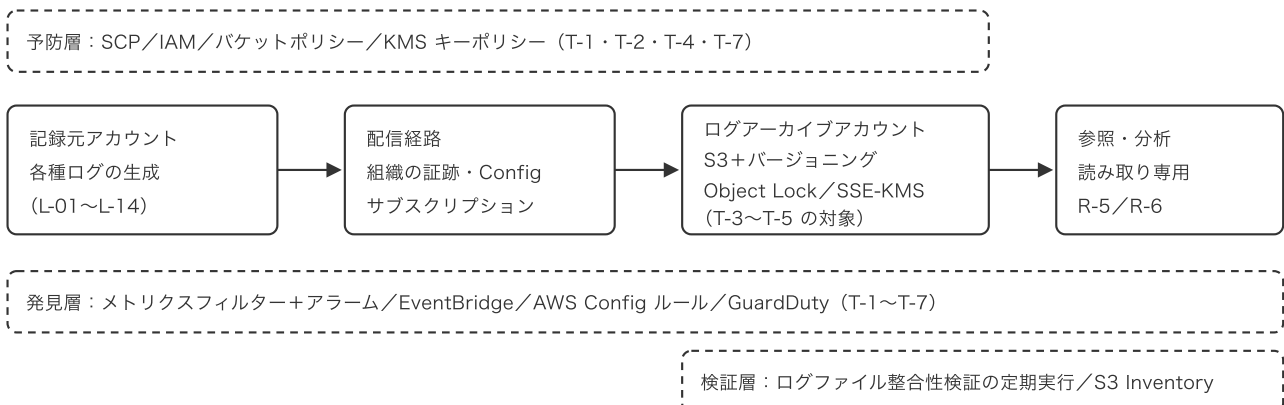


表8-1 脅威と統制の対応

脅威	予防統制	発見統制	対応するAWS機能	LR-04 との対応
T-1 記録の停止	SCP で <code>StopLogging</code> / <code>DeleteTrail</code> / <code>StopConfigurationRecorder</code> を拒否。 組織の証跡によりメンバー側の停止を封じる	設定変更イベントのアラート、証跡の稼働状態の定期確認	AWS Organizations (SCP)、組織の証跡、AWS Config、Amazon CloudWatch	記録の継続性を担保。LR-01 / LR-12 と併読
T-2 記録範囲の縮小	SCP で <code>UpdateTrail</code> / <code>PutEventSelectors</code> を拒否。セレクトタを IaC 管理	当該イベントのアラート、Config ルール <code>multi-region-cloudtrail-enabled</code> （管理イベントの除外設定があると <code>NON_COMPLIANT</code> ）	SCP、AWS Config、Amazon EventBridge	記録範囲の恒常性を担保。LR-01 / LR-12 と併読
T-3 保存済みログの改ざん・削除	Object Lock（コンプライアンスモード）＋バージョンing、バケットポリシーによる削除拒否、書き込み主体の限定	ログファイル整合性検証、S3 Inventory、バケットポリシー変更のアラート	Amazon S3 Object Lock、AWS CloudTrail 整合性検証、S3 Inventory	LR-04 の中核。LR-06 と併読
T-4 保持期間・ライフサイクルの悪用	Object Lock の保持期間（バケットポリシーでは防げない）、SCP で <code>s3:PutLifecycleConfiguration</code> / <code>logs:PutRetentionPolicy</code> を拒否	ライフサイクル・保持設定変更のアラート、Config ルールによる保持期間確認、ログアーカイブバケット自身のサーバーアクセスログでの失効記録確認（8.4 の注意(4)）	S3 Object Lock、SCP、AWS Config、S3 サーバーアクセスログ	保存期間の実効性を担保。LR-05 と併読
T-5 暗号鍵の削除・無効化	SCP およびキーポリシーで <code>kms:ScheduleKeyDeletion</code> / <code>kms:DisableKey</code> / <code>kms:PutKeyPolicy</code> を限定	鍵操作のアラート、Config ルール <code>kms-cmk-not-scheduled-for-deletion</code> 、復号失敗の検出	AWS KMS、CloudWatch メトリクスフィルター、AWS Config	可読性の維持。LR-07 と併読
T-6 検知・通知の無効化	SCP で <code>guardduty:DeleteDetector</code> / <code>securityhub:DisableSecurityHub</code> 等を拒否	Config ルール <code>guardduty-enabled-centralized</code> / <code>securityhub-enabled</code> 、通知経路の生存確認	SCP、AWS Config、Amazon GuardDuty、AWS Security Hub	発見統制自体の完全性。LR-08 と併読
T-7 特権による迂回	ログアーカイブアカウントの分離、 <code>AWSCloudTrail_FullAccess</code> の付与最小化、ルート認証情報の集中管理、設定変更のパイプライン限定	ルートユーザー使用のアラート、権限変更の記録とレビュー	AWS Organizations、AWS IAM、AWS Control Tower	統制の迂回防止。LR-06 / LR-13 と併読

8.3 CloudTrail ログファイル整合性検証

8.3.1 仕組み

CloudTrail のログファイル整合性検証は、配信済みのログファイルが改変・削除されていないことを暗号的に確認する機能である。有効化すると、CloudTrail は各ログファイルの **SHA-256 ハッシュ**を含むダイジェストファイルを**1時間ごと**にログとは別のフォルダ（CloudTrail-Digest）へ配信する。ダイジェストファイルは **SHA-256 with RSA** で署名され、**直前のダイジェストファイルの署名を含む**ため、ダイジェスト自体が連鎖（チェーン）を構成する。署名に用いるキーペアはリージョンごとに異なる。

- **必須** すべての証跡でログファイル整合性検証を有効化すること。Config ルール `cloud-trail-log-file-validation-enabled` により有効化状態を継続的に監視すること。
- **必須** ダイジェストファイルはログ本体と同じ保護（Object Lock、削除拒否、保存期間）の対象に含めること。ダイジェストが失われると検証自体が成立しない。

8.3.2 検証の実行

有効化は検証を行うものではない。検証は `validate-logs` の実行によって初めて成立する。

```
aws cloudtrail validate-logs \
  --trail-arn arn:aws:cloudtrail:ap-northeast-1:111122223333:trail/org-log-trail \
  --start-time 2026-08-01T00:00:00Z \
  --end-time 2026-08-31T23:59:59Z \
  --account-id 222233334444 \
  --region ap-northeast-1 \
  --verbose

# 出力に現れる主な判定
#   valid                                : 検証成功
#   INVALID: hash value doesn't match    : ログファイルが改変された
#   INVALID: not found                   : ログファイルが削除された
#   INVALID: signature verification failed : ダイジェストの署名検証に失敗した
#   INVALID: has been moved from its original location : 配信元の位置から移動された
```

- **必須** 時刻はすべて UTC で指定すること。 `--region` の指定が必要であり、リージョンごとに実行すること。組織の証跡を検証する場合は `--account-id` が必須であり、ここには**検証対象アカウント**を指定する。組織の証跡には管理アカウント自身のログも含まれるため、管理アカウントと全メンバーアカウントを対象として、対象アカウントの数だけ実行すること。
- **必須** 実行主体はログ管理者（R-5）とし、実行結果（実行日時、対象証跡ARN、対象アカウント、対象期間、判定結果、実行者）を証跡として保存すること。
- **推奨** Amazon EventBridge Scheduler を起点に、AWS CLI を実行できる実行環境（AWS Lambda、AWS Systems Manager Automation、AWS CodeBuild 等）を経由して月次に自動実行し、出力をログアーカイブ以外の証跡保管先に保存すること。 `validate-logs` は AWS CLI のクライアント側処理であり単独の API として呼び出せないため、EventBridge Scheduler から直接実行することはできない。実行環境には対象バケットへのオブジェクト一覧取得・取得・バケットロケーション取得の権限と、SSE-KMS の場合は `kms:Decrypt` 権限を付与すること。
- **必須** INVALID が1件でも出た場合は、直ちに第9章のインシデント対応手順に従い報告し、対象期間・対象アカウント・影響範囲を特定して記録すること。是正前に「検証済み」としないこと。

8.3.3 検証範囲の制約

この機能の適用範囲は限定的であり、それを前提に他の統制を設計すること。

- 検証できるのは、**CloudTrail が配信した位置にそのまま存在するログファイル**だけである。ローカルにダウンロードしたファイルや、別バケット・別プレフィックスへ移動したファイルは検証できない。したがって、ログのアーカイブ移行はストレージクラスの移行（第7章）で行い、オブジェクトの物理的な移動・再配置は行わないこと。
- ダイジェストファイルに参照されていないファイルは検証対象外である。
- 実行者には S3 の読み取り権限（オブジェクトの一覧取得、取得、バケットロケーションの取得）が必要である。SSE-KMS で暗号化している場合は、キーポリシーで `kms:Decrypt` が許可されている必要がある。
- **対象は CloudTrail の証跡ログのみ**である。AWS Config の設定履歴、VPC フローログ、ELB/WAF のアクセスログ、データベース監査ログ、アプリケーションログ（L-03、L-06～L-11 など）はこの機能では検証できない。これらの完全性は、Object Lock による不変性、アクセス制御、および LR-11 の欠損検知（配信件数と受領件数の照合）で担保すること。

8.4 S3 Object Lock による WORM 化

8.4.1 採用方針

S3 Object Lock は WORM（Write Once Read Many）モデルを提供し、保持期限までオブジェクトバージョンの上書き・削除を禁止する。ログアーカイブの中核的な保全手段として採用する。

- **必須** ログアーカイブ用バケットでは、バージョニングを有効化したうえで Object Lock を有効化すること。Object Lock はバージョニングが有効なバケットでのみ動作する。
- **必須** 保持モードは**コンプライアンスモード**を採用すること。コンプライアンスモードでは、ルートユーザーを含むいかなるユーザーもオブジェクトバージョンを上書き・削除できず、保持モードの変更も保持期間の短縮もできない。保持期限前に削除する唯一の方法は AWS アカウントそのものを削除することである。機微情報や個人データを含むログを誤って書き込んだ場合も保持期限まで削除できないため、LR-07 に従い、ログ出力の時点でマスキング・出力抑止を行い、検証環境で機微情報が出力されないことを確認してから本番に適用すること。
- **必須** ガバナンスモードは採用しないこと。ガバナンスモードは `s3:BypassGovernanceRetention` 権限と `x-amz-bypass-governance-retention:true` ヘッダーの組み合わせで保持を上書きでき、しかも S3 コンソールは既定でこのヘッダーを付与する。本書は、上書き経路自体を残さない方針（8.1 の T-7 特権による統制の迂回への対応）として、発注者の受入条件によりコンプライアンスモードを採用する。
- **必須** バケットの既定保持期間（日または年で指定）を設定し、値は第7章で定める保存期間方針と一致させること。オブジェクトに適用済みの保持期間は延長のみ可能であり、コンプライアンスモードでは短縮できない。バケットの既定保持期間の設定値は変更できるが、変更は以後に配置されるオブジェクトにのみ適用される。
- **推奨** `s3:object-lock-remaining-retention-days` 条件キーを用いて、個別オブジェクトに設定できる保持期間の上限・下限を制御すること。

8.4.2 リーガルホールドの用途

リーガルホールドは保持期間とは独立に設定でき、期限を持たない。`s3:PutObjectLegalHold` 権限を持つ者が付与・解除する。監査・不正調査・係争など、通常の保存期間を超えて特定期間のログを保全する必要が生じた場合

に用いること。

- **必須** リーガルホールドの付与・解除権限はログ管理者（R-5）に限定し、付与理由・対象範囲・申請者・承認者・解除日を記録すること。解除は保全事由の消滅を確認した後に行うこと。

8.4.3 既存バケットからの移行

Object Lock は既存バケットに対しても有効化できる。ただし不可逆な設定であるため、次の順序で進めること。

1. 対象バケットの棚卸（配信元サービス、現行のライフサイクルルール、レプリケーション設定、MFA Deleteの有無、既存オブジェクト数と容量）を行うこと。
2. 検証環境の同等構成で、配信・保持・参照・削除拒否の各動作を確認すること。
3. バージョニングを有効化すること。バージョニングは有効化後、未バージョニング状態には戻せない（停止のみ可能）。
4. Object Lock を有効化すること。**有効化後は Object Lock の無効化もバージョニングの停止もできない。**
5. 既定保持期間（コンプライアンスモード）を設定すること。既定保持は**新規オブジェクトにのみ適用**される。
6. 既存オブジェクトに保持を適用する場合は S3 バッチオペレーションで一括設定すること。S3 バッチオペレーションの実行ロールは `s3:PutObjectRetention` を要する。8.5.1 のバケットポリシーは当該アクションをログ管理者ロール以外に対して拒否しているため、バッチオペレーションの実行ロールをログ管理者ロールとするか、移行期間に限り除外条件に追加し、追加・削除の記録を L-14 として保全すること。
7. ライフサイクルの移行ルールと保持期間の整合を確認すること。S3 Glacier Instant Retrieval / Glacier Flexible Retrieval は最小保存期間 90 日、S3 Glacier Deep Archive は 180 日であり、保持期限前に削除できないことと合わせて保管コストを試算すること。

● 注意

設計上、次の4点を採用前に必ず確認すること。

1. **必須** **AWS Config の配信チャンネルは、既定の保持設定を有効化した Object Lock バケットをサポートしない。**したがって L-03（構成変更履歴）の配信先は、既定保持を設定しない別バケットとし、オブジェクト単位の保持適用またはレプリケーション先での不変化によって保全すること。この設計判断をログ設計書に記載すること。
2. **必須** **AWS Security Reference Architecture は、Amazon S3 に保管された CloudTrail ログオブジェクトの完全性を保護する手段として、ログファイル整合性検証と S3 Object Lock の2つを挙げている。**ただし既定保持期間の値・保持モードと配信の組み合わせは環境依存であるため、採用前に検証環境で実際に配信が成功し、配信されたオブジェクトに想定どおりの保持設定が付与されることを確認し、その結果（配信されたオブジェクトの一覧と保持状態、確認日、参照した公式ドキュメント）を証跡として提出すること。
3. **必須** **Object Lock を有効化したバケットは S3 サーバーアクセスログの配信先にできない。**L-02 のサーバーアクセスログを取得する場合は、配信先バケットを別に用意し、当該バケットの保全方式を設計書に記載すること。
4. **必須** ログアーカイブバケット自身のサーバーアクセスログを有効化し、ライフサイクルによる失効・移行（`S3.EXPIRE.OBJECT`、`S3.TRANSITION_GDA.OBJECT` 等）を記録すること。T-4 はライフサイクルによる削除が CloudTrail のオブジェクトレベルログに残らないため、この記録が唯一の発見統制となる。配信先は (3) のとおり Object Lock を有効化していない別バケットとし、当該バケットの保全方式（バージョニング、削除拒否、保存期間）をログ設計書に記載すること。

● 補足

MFA Delete は**ライフサイクル設定と併用できず**、有効化できるのはバケット所有者（ルートユーザー）のみでコンソールからは設定できない。ライフサイクルによる階層化を行うログアーカイブでは、MFA Delete ではなく Object Lock を保全手段とすること。また、ログのバックアップを AWS Backup で保護する場合は、Vault Lock のコンプライアンスモード（猶予期間経過後は解除不可）が同等の不変性を提供する。別リージョンへの複製を行う場合は、Object Lock 有効バケット間のレプリケーション要件を公式ドキュメントで確認したうえで、複製の可否を判断すること。

8.5 削除・停止・設定変更の予防

本節のポリシーは実装のひな型である。**必須** アカウントID、バケット名、ロール名、キーARN、証跡ARN は自環境の値に置き換え、適用前に検証環境で配信・参照・拒否の各動作を確認すること。

本節の例では、8.2 のアカウント分離方針に合わせてアカウントIDを役割ごとに書き分ける。**111122223333 は組織の証跡を所有する管理アカウント、333344445555 はログアーカイブアカウント、444455556666 は監査人（R-6）の読み取り専用ロールを置くアカウント**を表す。組織の証跡の ARN および `aws:SourceArn` は管理アカウント所有の値でなければならず、バケット・KMS キー・ログ管理者ロールはログアーカイブアカウントに置く。

8.5.1 ログアーカイブバケットのバケットポリシー

次の例は**CloudTrail 用ログアーカイブバケット**（`example-log-archive`）に適用するものである。L-03（構成変更履歴）の配信先は 8.4 の注意 (1) のとおり別バケットとし、そのバケットポリシーは本節末尾に別に示す。

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyInsecureTransport",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:*",
      "Resource": [
        "arn:aws:s3:::example-log-archive",
        "arn:aws:s3:::example-log-archive/*"
      ],
      "Condition": { "Bool": { "aws:SecureTransport": "false" } }
    },
    {
      "Sid": "DenyUploadWithoutDesignatedKmsKey",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::example-log-archive/*",
      "Condition": {
        "ArnNotEqualsIfExists": {
          "s3:x-amz-server-side-encryption-aws-kms-key-id":
            "arn:aws:kms:ap-northeast-1:333344445555:key/1234abcd-12ab-34cd-56ef-1234567890ab"
        }
      }
    },
    {
      "Sid": "DenyDeletionAndConfigurationChange",
      "Effect": "Deny",
      "Principal": "*",
      "Action": [
        "s3:DeleteObject",
        "s3:DeleteObjectVersion",
        "s3:DeleteBucket",
        "s3:PutLifecycleConfiguration",
        "s3:PutBucketPolicy",
        "s3:DeleteBucketPolicy",
        "s3:PutBucketVersioning",
        "s3:PutEncryptionConfiguration",
        "s3:PutObjectRetention",
        "s3:PutObjectLegalHold",
        "s3:BypassGovernanceRetention"
      ],
      "Resource": [
        "arn:aws:s3:::example-log-archive",
        "arn:aws:s3:::example-log-archive/*"
      ],
      "Condition": {
        "ArnNotLike": {
          "aws:PrincipalArn": "arn:aws:iam::333344445555:role/LogArchiveAdminRole"
        }
      }
    },
    {
      "Sid": "AWSCloudTrailAclCheck",
      "Effect": "Allow",
      "Principal": { "Service": "cloudtrail.amazonaws.com" },
      "Action": "s3:GetBucketAcl",
      "Resource": "arn:aws:s3:::example-log-archive",
      "Condition": {
        "StringEquals": {
          "aws:SourceArn":

```

```

        "arn:aws:cloudtrail:ap-northeast-1:111122223333:trail/org-log-trail"
    }
}
},
{
    "Sid": "AWSCloudTrailAccountWrite",
    "Effect": "Allow",
    "Principal": { "Service": "cloudtrail.amazonaws.com" },
    "Action": "s3:PutObject",
    "Resource": "arn:aws:s3:::example-log-archive/AWSLogs/111122223333/*",
    "Condition": {
        "StringEquals": {
            "s3:x-amz-acl": "bucket-owner-full-control",
            "aws:SourceArn":
                "arn:aws:cloudtrail:ap-northeast-1:111122223333:trail/org-log-trail"
        }
    }
},
{
    "Sid": "AWSCloudTrailOrganizationWrite",
    "Effect": "Allow",
    "Principal": { "Service": "cloudtrail.amazonaws.com" },
    "Action": "s3:PutObject",
    "Resource": "arn:aws:s3:::example-log-archive/AWSLogs/o-exampleorgid/*",
    "Condition": {
        "StringEquals": {
            "s3:x-amz-acl": "bucket-owner-full-control",
            "aws:SourceArn":
                "arn:aws:cloudtrail:ap-northeast-1:111122223333:trail/org-log-trail"
        }
    }
}
}
]
}

```

この例に関する留意事項は次のとおりである。

- 組織の証跡に必要な PutObject ステートメントは2本である。** 公式ドキュメントは、バケットに対する `s3:GetBucketAcl` に加えて、`AWSLogs/<管理アカウントID>/*` 宛と `AWSLogs/<組織ID>/*` 宛の2つの `s3:PutObject` を規定している。前者を欠くと、組織の証跡を単一アカウントの証跡に変更した場合に配信が失敗する。いずれにも `s3:x-amz-acl` と `aws:SourceArn` の条件を付与すること。配信先バケットに Requester Pays は使用できない。ポリシー誤りにより配信が失敗した場合、CloudTrail は 30 日間再配信を試行する。再配信に伴う課金の有無は最新の公式ドキュメントで確認すること。
- 必須** 本バケットは既定保持期間つきの Object Lock を有効化するため、**AWS Config の配信チャネルの宛先にはできない** (8.4 の注意 (1))。L-03 の配信先は下記の別バケットとし、本ポリシーに AWS Config 向けのステートメントを追加しないこと。
- 必須** SSE-KMS 非対応または既定で SSE-S3 を用いる配信元（S3 サーバーアクセスログ、AWS Config の既定設定等）を本バケットに集約しないこと。上記の `DenyUploadWithoutDesignatedKmsKey` により配信が拒否される。
- Deny ステートメントは AWS のサービスプリンシパルにも及ぶ（サービスプリンシパルには `aws:PrincipalArn` が存在しないため `ArnNotLike` が成立する）。配信に必要な操作を Deny の `Action` に含めないこと。
- 削除の拒否には `s3:DeleteObject`、`s3:DeleteObjectVersion`、`s3:PutLifecycleConfiguration` の3つが必要である。** ただし、既に設定済みのライフサイクルルールによる削除・移行はバケットポリシーでは防げない。ライフサイクルによる消失を防げるのは Object Lock のみである (8.4)。

- **必須** バケットのパブリックアクセスブロック（4設定すべて）を有効化すること。パブリックアクセスブロックの継続確認には Config ルール `s3-bucket-level-public-access-prohibited`（バケット単位）および `s3-account-level-public-access-blocks-periodic`（アカウント単位）を用いること。あわせて、TLS 強制・KMS 既定暗号化・バージョニング・Object Lock 既定保持については `s3-bucket-ssl-requests-only`、`s3-default-encryption-kms`、`s3-bucket-versioning-enabled`、`s3-bucket-default-lock-enabled` で継続的に確認すること。

必須 AWS Config 配信先バケット（例: `example-config-delivery`）には、公式ドキュメントが規定する次の3ステートメントを適用し、検証環境で配信が成功することを確認したうえで、適用したステートメントと配信成功の確認記録をログ設計書に記録すること。

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AWSConfigBucketPermissionsCheck",
      "Effect": "Allow",
      "Principal": { "Service": "config.amazonaws.com" },
      "Action": "s3:GetBucketAcl",
      "Resource": "arn:aws:s3:::example-config-delivery",
      "Condition": {
        "StringEquals": { "AWS:SourceAccount": "<記録元アカウントID>" }
      }
    },
    {
      "Sid": "AWSConfigBucketExistenceCheck",
      "Effect": "Allow",
      "Principal": { "Service": "config.amazonaws.com" },
      "Action": "s3:ListBucket",
      "Resource": "arn:aws:s3:::example-config-delivery",
      "Condition": {
        "StringEquals": { "AWS:SourceAccount": "<記録元アカウントID>" }
      }
    },
    {
      "Sid": "AWSConfigBucketDelivery",
      "Effect": "Allow",
      "Principal": { "Service": "config.amazonaws.com" },
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::example-config-delivery/AWSLogs/<記録元アカウントID>/Config/*",
      "Condition": {
        "StringEquals": {
          "s3:x-amz-acl": "bucket-owner-full-control",
          "AWS:SourceAccount": "<記録元アカウントID>"
        }
      }
    }
  ]
}
```

必須 上記の `AWS:SourceAccount` 条件および `AWSConfigBucketDelivery` の `Resource` は**記録元アカウントごとに設定する必要がある**。組織全体の L-03 を1つのバケットに集約する場合は、記録元アカウントごとにステートメントを設けるか、条件値を列挙するか、または公式ドキュメントが案内する IAM ロールと `aws:PrincipalOrgID` 等の Organizations 条件キーを用いる方法とするかを検証のうえ決定し、その記述方法と対象アカウントの一覧をログ設計書に記載すること。アカウントの追加時に当該記述を更新する手順も定めること（LR-01）。

● 補足

バケットポリシーの誤設定により自らアクセスできなくなった場合、AWS Organizations の集中ルートアクセス管理で有効化する特権ルートアクション（S3 バケットポリシーの削除）または `sts:AssumeRoot`（タスクポリシー `S3UnlockBucketPolicy`）による復旧手段がある。復旧手段の有無と実施手順を運用設計に含め、実施記録を残せるようにしておくこと。

8.5.2 サービスコントロールポリシー（SCP）

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyLoggingPipelineTampering",
      "Effect": "Deny",
      "Action": [
        "cloudtrail:StopLogging",
        "cloudtrail:DeleteTrail",
        "cloudtrail:UpdateTrail",
        "cloudtrail:PutEventSelectors",
        "config:StopConfigurationRecorder",
        "config:DeleteConfigurationRecorder",
        "config:DeleteDeliveryChannel",
        "config:PutConfigurationRecorder",
        "config:PutDeliveryChannel",
        "config:PutRetentionConfiguration",
        "config:DeleteRetentionConfiguration",
        "logs:DeleteLogGroup",
        "logs:PutRetentionPolicy",
        "kms:ScheduleKeyDeletion",
        "kms:DisableKey",
        "guardduty:DeleteDetector",
        "guardduty:UpdateDetector",
        "guardduty:DeletePublishingDestination",
        "guardduty:StopMonitoringMembers",
        "securityhub:DisableSecurityHub",
        "securityhub:BatchDisableStandards"
      ],
      "Resource": "*",
      "Condition": {
        "ArnNotLike": {
          "aws:PrincipalArn":
            "arn:aws:iam::333344445555:role/LogArchiveAdminRole"
        }
      }
    },
    {
      "Sid": "DenyLogArchiveDeletion",
      "Effect": "Deny",
      "Action": [
        "s3:DeleteObject",
        "s3:DeleteObjectVersion",
        "s3:DeleteBucket",
        "s3:PutLifecycleConfiguration",
        "s3:PutBucketPolicy",
        "s3:DeleteBucketPolicy",
        "s3:PutBucketVersioning",
        "s3:BypassGovernanceRetention"
      ],
      "Resource": [
        "arn:aws:s3:::example-log-archive",
        "arn:aws:s3:::example-log-archive/*"
      ],
      "Condition": {
        "ArnNotLike": {
          "aws:PrincipalArn":
            "arn:aws:iam::333344445555:role/LogArchiveAdminRole"
        }
      }
    }
  ]
}
```

```

    },
    {
      "Sid": "DenyExceptionRoleImpersonation",
      "Effect": "Deny",
      "Action": [
        "iam:CreateRole",
        "iam:UpdateAssumeRolePolicy",
        "iam:AttachRolePolicy",
        "iam:PutRolePolicy"
      ],
      "Resource": "arn:aws:iam::*:role/LogArchiveAdminRole",
      "Condition": {
        "ArnNotLike": {
          "aws:PrincipalArn": "arn:aws:iam::333344445555:role/<IaC実行ロール名>"
        }
      }
    }
  ]
}

```

- 必須** 第1ステートメント（DenyLoggingPipelineTampering）は Resource が * であるため、logs:・kms: の拒否は組織内の全ロググループ・全 KMS キーに及ぶ。ログ基盤以外のリソースまで対象とするか、保護対象の ARN パターンやタグ条件（例: aws:ResourceTag/LogArchive）で限定するかを設計時に決定し、決定内容と業務側への影響（保持期間設定・鍵管理の申請経路）をログ設計書に記載すること。
- 必須** 例外ロール（LogArchiveAdminRole）は SCP の適用前にログアーカイブアカウントで作成し、以後の変更は DenyExceptionRoleImpersonation で除外した IaC 実行ロール経由に限ること。SCP を一時的に外して変更しないこと。除外した IaC 実行ロールをログ設計書に記載すること。
- 必須** 例外として除外するロールは、ロール名だけでなくアカウントIDまで固定した ARN で指定すること。アカウントID部をワイルドカードにすると、いずれかのメンバーアカウントで同名のロールを作成するだけで全 Deny を迂回できる。あわせて、上記 DenyExceptionRoleImpersonation により、例外ロール名と同名のロールがメンバーアカウントで作成・改変されないよう制限すること。
- 必須** 例外として除外するロールは第10章で定義するログ管理者ロール（R-5）に限定し、その引き受け条件・利用申請・承認・操作記録を LR-06 に従って管理すること。**SCP、バケットポリシー、KMS キーポリシーの例外ロールが相互に一致していること、および当該ロールが R-5 に対応することを確認すること。**本節の例では、いずれも arn:aws:iam::333344445555:role/LogArchiveAdminRole に統一している。
- 必須** ランディングゾーン管理やデプロイ自動化のための実行ロール（AWSControlTowerExecution 等）に例外が必要な場合は、上記の包括的な除外条件に加えず、**対象アクションとリソースを限定した別ステートメントに分離し**、除外理由・対象アカウント・対象アクションをログ設計書に記載すること。名前のみで一致させる包括的な除外は行わないこと。
- SCP はメンバーアカウントの IAM ユーザー・ロールおよび**ルートユーザー**の最大権限を定義する。ただし**管理アカウントには適用されず、サービスリンクロールにも影響しない**。管理アカウントの保護は、ルート認証情報の集中管理（メンバーアカウントのルート認証情報の削除、ルートユーザー MFA の必須化）と、管理アカウントでの操作の監視によって別途担保すること。
- AWS Control Tower を利用する場合、必須コントロールとして同種の SCP（aws-controltower-* のリソースを対象とする CloudTrail・AWS Config・CloudWatch Logs・ログアーカイブバケットの変更拒否）が既に適用される。**必須** 自組織の SCP と Control Tower のコントロールの適用範囲・除外ロールの整合を確認し、重複と欠落を明示すること。
- 必須** 本例は自組織向けの構成例である。適用前に検証用 OU で**正常系（通常運用の操作が阻害されないこと）と異常系（対象操作が拒否されること）の両方を確認し**、その結果を証跡として残すこと。特に、メン

バーアカウントでの AWS Config 設定レコーダーの展開など、正当な自動化経路が阻害されないことを確認すること。

- **推奨** CloudWatch Logs のロググループには削除保護を設定すること（削除保護を有効にしたロググループの削除は検証エラーとなる）。設定方法と適用範囲は公式ドキュメントで確認すること。

8.5.3 KMS キーポリシーの要点

KMS キーポリシーは各キーにちょうど1つだけ存在し、**キーポリシー等で明示的に許可されない限り、ルートユーザーやキー作成者であっても権限を持たない**。したがって、**鍵の管理権限（`kms:PutKeyPolicy` を含む）を持つ主体を明示的に許可していないキーポリシーを適用すると、キーポリシーの修正・自動ローテーション設定・削除予約のいずれもできない回復不能なキーとなり、復旧には AWS サポートへの問い合わせが必要になる**。次の例は、この点を踏まえて管理主体の許可を先頭に置いている。

```

{
  "Version": "2012-10-17",
  "Id": "log-archive-key-policy",
  "Statement": [
    {
      "Sid": "EnableIAMUserPermissions",
      "Effect": "Allow",
      "Principal": { "AWS": "arn:aws:iam::333344445555:root" },
      "Action": "kms:*",
      "Resource": "*"
    },
    {
      "Sid": "AllowKeyAdministration",
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::333344445555:role/LogArchiveAdminRole"
      },
      "Action": [
        "kms:Describe*",
        "kms:Get*",
        "kms:List*",
        "kms:PutKeyPolicy",
        "kms:EnableKey",
        "kms:DisableKey",
        "kms:EnableKeyRotation",
        "kms:DisableKeyRotation",
        "kms:TagResource",
        "kms:ScheduleKeyDeletion",
        "kms:CancelKeyDeletion"
      ],
      "Resource": "*"
    },
    {
      "Sid": "AllowCloudTrailToEncrypt",
      "Effect": "Allow",
      "Principal": { "Service": "cloudtrail.amazonaws.com" },
      "Action": "kms:GenerateDataKey*",
      "Resource": "*",
      "Condition": {
        "StringLike": {
          "kms:EncryptionContext:aws:cloudtrail:arn":
            "arn:aws:cloudtrail:*:111122223333:trail/*"
        },
        "StringEquals": {
          "aws:SourceArn":
            "arn:aws:cloudtrail:ap-northeast-1:111122223333:trail/org-log-trail"
        }
      }
    },
    {
      "Sid": "AllowCloudTrailDecrypt",
      "Effect": "Allow",
      "Principal": { "Service": "cloudtrail.amazonaws.com" },
      "Action": "kms:Decrypt",
      "Resource": "*"
    },
    {
      "Sid": "AllowCloudTrailDescribeKey",
      "Effect": "Allow",
      "Principal": { "Service": "cloudtrail.amazonaws.com" },
      "Action": "kms:DescribeKey",
      "Resource": "*",
      "Condition": {

```

```

    "StringEquals": {
      "aws:SourceArn":
        "arn:aws:cloudtrail:ap-northeast-1:11112223333:trail/org-log-trail"
    }
  },
  {
    "Sid": "AllowReadersToDecrypt",
    "Effect": "Allow",
    "Principal": {
      "AWS": [
        "arn:aws:iam::333344445555:role/LogArchiveAdminRole",
        "arn:aws:iam::444455556666:role/AuditorReadOnlyRole"
      ]
    },
    "Action": "kms:Decrypt",
    "Resource": "*"
  },
  {
    "Sid": "DenyKeyLifecycleChangeExceptKeyAdmin",
    "Effect": "Deny",
    "Principal": "*",
    "Action": [ "kms:ScheduleKeyDeletion", "kms:DisableKey", "kms:PutKeyPolicy" ],
    "Resource": "*",
    "Condition": {
      "ArnNotLike": {
        "aws:PrincipalArn":
          "arn:aws:iam::333344445555:role/LogArchiveAdminRole"
      }
    }
  }
}

```

- 必須** キーポリシーには、鍵の管理主体（`kms:PutKeyPolicy` を含む管理権限）を必ず含め、その主体を Deny の対象から除外すること。除外対象は 8.5.2 の SCP および 8.5.1 のバケットポリシーの例外ルールと一致させること。また、Deny の対象としたアクション（`kms:ScheduleKeyDeletion`、`kms:DisableKey`）は、除外した主体に対して Allow でも付与されていることを確認すること。除外しただけでは許可にならない。
- 必須** 適用前に検証環境で、鍵ポリシーの再適用（`kms:PutKeyPolicy`）が実際に可能であることを確認し、その結果を証跡として残すこと。管理主体を欠いたキーポリシーを適用すると鍵は回復不能となる。
- 必須** `kms:DescribeKey` は暗号化コンテキストを伴わずに呼び出されるため、**`kms:EncryptionContext` 条件を付けた同一ステートメントにまとめないこと**。上記のとおり独立したステートメントとし、条件は `aws:SourceArn` のみとすること。まとめると条件が成立せず、SSE-KMS を有効にした証跡の作成・更新およびログ配信が失敗する。
- 必須** CloudTrail サービスプリンシパルへの `kms:Decrypt` は、暗号化コンテキストの条件を付けた暗号化用ステートメントに含めず、例の `AllowCloudTrailDecrypt` のように独立したステートメントで許可すること。S3 バケットキーを使用するバケットでは CloudTrail に `kms:Decrypt` が必要である。
- 必須** 先頭の `EnableIAMUserPermissions` は IAM ポリシーによる許可を有効化するため、ログアーカイブアカウント内で `kms:*` を付与する IAM ポリシーを作成しないこと（第10章）。キーポリシーの変更（`kms:PutKeyPolicy`）は例の `DenyKeyLifecycleChangeExceptKeyAdmin` で例外ルール以外に拒否する。
- 必須** 読み取り側（R-5・R-6）の `kms:Decrypt` には、CloudTrail の暗号化コンテキストの有無を条件としないこと。同一キーで暗号化された他のログ種別（L-03、L-06～L-11 等）を復号できなくなり、LR-06・LR-10 および第12章の監査対応と矛盾する。ログ種別ごとに鍵を分ける方針を採る場合は、その旨と鍵の割当てをログ設計書に明記すること。

- **必須** KMS キーは**ログ配信先の S3 バケットと同じリージョン**に作成すること。
- **必須** CloudWatch Logs のロググループを暗号化する場合は、`logs.<リージョン>.amazonaws.com` に対して `kms:Encrypt` / `kms:Decrypt` / `kms:ReEncrypt*` / `kms:GenerateDataKey*` / `kms:Describe*` を許可し、`kms:EncryptionContext:aws:logs:arn` 条件でロググループARNに限定すること。
- **推奨** 自動キーローテーションを有効化すること（既定 365 日、90～2,560 日でカスタム可能）。旧キーマテリアルは保持されるため、過去のログを再暗号化する必要はない。ローテーションは CloudTrail に記録される。
- **必須** 監査人（R-6）へは `kms:Decrypt` のみを付与し、鍵の管理操作を付与しないこと。監査人のロールが別アカウントにある場合は、キーポリシーでの許可に加えて、当該アカウント側の IAM ポリシーでも対象キーARN への `kms:Decrypt` を許可する必要がある（第10章）。
- **必須** 新しい AWS Security Hub を利用する場合は、利用中のバージョンに対応する無効化 API（例: `securityhub:DisableSecurityHubV2`）を公式ドキュメントで確認し、8.5.2 の SCP の拒否対象に追加すること。

8.6 発見統制

予防統制は完全ではない。管理アカウントの操作、例外ロールの利用、SCP の適用漏れがあり得るため、改ざん・停止・設定変更の**試行**を検知できるようにすること。実装は、CloudTrail を CloudWatch Logs に配信したうえでのメトリクスフィルター＋アラーム、または EventBridge ルール（`detail-type` が `AWS API Call via CloudTrail`）による。

- **必須** **組織の証跡の CloudWatch Logs 配信先ロググループは、証跡を作成・更新するアカウント内に置く必要がある**ため、配信先アカウントをログ設計書に明記すること。CloudTrail の委任管理者アカウントから証跡を構成する場合はロググループを委任管理者アカウントに置けるため、SCP による保護が及ぶこの構成を推奨する（この場合、8.5 の例の証跡 ARN と `aws:SourceArn` は委任管理者の構成に合わせて読み替えること）。管理アカウントに置く場合は SCP が適用されない（8.5.2）ため、当該アカウントでのロググループ削除・メトリクスフィルター削除・アラーム削除を検知する代替統制（第9章のアラートおよび第10章の権限設計）を個別に定義し、ログ設計書に記載すること。
- **必須** 検知対象の CloudTrail イベントを 8.1 の脅威IDと対応付けて定義し、表8-2 のとおり第9章のアラートIDと1対1で対応付けること。通知先・エスカレーション・対応期限・レビュー頻度は第9章のアラート定義に登録して管理すること。本章は「何を検知するか」、第9章は「検知したときにどう動くか」を定める。**第9章に定義のないアラートIDを本章で用いないこと。**
- **必須** メトリクスフィルターは**作成後に取り込まれたログにのみ適用**され、遡及しない。またログクラスが Standard のロググループでのみ利用できる（1ロググループあたり 100 個まで）。ログ基盤の構築時点で設定すること。
- **必須** CloudTrail は**256 KB を超えるイベントを CloudWatch Logs および EventBridge に送信しない**。大きなイベントの検知漏れが起こり得るため、重要な統制については S3 に配信されたログに対する定期的な照会（第12章）を併用すること。

表8-2 検知対象イベントとアラート定義の対応

脅威 ID	検知対象イベント（API名・CIS統制ID）	実装方式	第9章アラート ID	主な通知先（詳細は第9章）
T-1	CreateTrail / UpdateTrail / DeleteTrail / StartLogging / StopLogging (CloudWatch.5)	メトリクスフィルター＋アラーム	AL-01	ログ管理者（R-5）、システム所管（R-2）
T-1	StopConfigurationRecorder / DeleteDeliveryChannel / PutDeliveryChannel / PutConfigurationRecorder (CloudWatch.9)	メトリクスフィルター＋アラーム	AL-02	ログ管理者（R-5）、システム所管（R-2）
T-2	PutEventSelectors (CIS 規定パターンに含まれないため独自定義)	EventBridge ルール	AL-03	ログ管理者（R-5）、内部統制担当（R-1）
T-3・T-4	PutBucketAcl / PutBucketPolicy / PutBucketLifecycle / DeleteBucketPolicy / DeleteBucketLifecycle ほか (CloudWatch.8)	メトリクスフィルター＋アラーム	AL-04	ログ管理者（R-5）、システム所管（R-2）
T-3	logs:DeleteLogGroup	EventBridge ルール	AL-05	ログ管理者（R-5）、システム所管（R-2）
T-4	PutRetentionPolicy、PutBucketLifecycle	EventBridge ルール	AL-06	ログ管理者（R-5）
T-5	DisableKey / ScheduleKeyDeletion (CloudWatch.7)	メトリクスフィルター＋アラーム	AL-07	ログ管理者（R-5）、内部統制担当（R-1）
T-5	削除待機状態のキーに起因する復号失敗（エラーメッセージにキーARNと削除保留の旨を含む）	メトリクスフィルター＋アラーム	AL-08	ログ管理者（R-5）、内部統制担当（R-1）
T-6	guardduty:DeleteDetector / securityhub:DisableSecurityHub	EventBridge ルール	AL-09	ログ管理者（R-5）
T-7	ルートユーザーの使用 (CloudWatch.1)	メトリクスフィルター＋アラーム	AL-10	内部統制担当（R-1）、システム所管（R-2）
T-7	例外ロール（ログ管理者ロール）の引き受けと使用	EventBridge ルール	AL-11	内部統制担当（R-1）

8.6.1 検知対象イベントのメトリクスフィルター

以下は AWS Security Hub CSPM が CIS 準拠のコントロールとして提示するメトリクスフィルターパターンである。これらのコントロールは、規定されたパターンと完全に一致しない場合（項目や語の追加を含む）に不合格となるため、原文どおりに設定すること。

```
# T-1 CloudTrail 設定変更 (CloudWatch.5 / AL-01。PutEventSelectors は含まれないため AL-03 を併用する)
{($.eventName=CreateTrail) || ($.eventName=UpdateTrail) || ($.eventName=DeleteTrail) ||
 ($.eventName=StartLogging) || ($.eventName=StopLogging)}
```

```
# T-1 AWS Config 設定変更 (CloudWatch.9 / AL-02)
{($.eventSource=config.amazonaws.com) && (($.eventName=StopConfigurationRecorder) ||
 ($.eventName=DeleteDeliveryChannel) || ($.eventName=PutDeliveryChannel) ||
 ($.eventName=PutConfigurationRecorder))}
```

```
# T-3・T-4 S3 バケットポリシー・ライフサイクル変更 (CloudWatch.8 / AL-04)
{($.eventSource=s3.amazonaws.com) && (($.eventName=PutBucketAcl) || ($.eventName=PutBucketPolicy) ||
 ($.eventName=PutBucketCors) || ($.eventName=PutBucketLifecycle) || ($.eventName=PutBucketReplication) ||
 ($.eventName=DeleteBucketPolicy) || ($.eventName=DeleteBucketCors) || ($.eventName=DeleteBucketLifecycle)
 || ($.eventName=DeleteBucketReplication))}
```

```
# T-5 カスタマーマネージドキーの無効化・削除予約 (CloudWatch.7 / AL-07)
{($.eventSource=kms.amazonaws.com) && (($.eventName=DisableKey) || ($.eventName=ScheduleKeyDeletion))}
```

```
# T-7 ルートユーザーの使用 (CloudWatch.1 / AL-10)
{$.userIdentity.type="Root" && $.userIdentity.invokedBy NOT EXISTS && $.eventType != "AwsServiceEvent"}
```

アラームは、メトリクス名前空間を `CloudTrailMetrics`、統計を `Sum`、期間を5分、しきい値を1以上として設定する例が公式に示されている。上記に加えて次を設定すること。

- **必須** **CloudWatch.7 は、メトリクスフィルタが規定どおりであっても、証跡の `ExcludeManagementEventSources` に `kms.amazonaws.com` が含まれる場合は不合格となる。** T-2 の予防統制 (SCP による `PutEventSelectors` の拒否) と一体で確認すること。
- **必須** **T-2 の一部は CIS 規定のパターンでは検知できない。** CloudWatch.5 のパターンには `PutEventSelectors` が含まれないため、`cloudtrail:PutEventSelectors` (記録範囲の縮小) を検知する独自のメトリクスフィルタまたは EventBridge ルール (AL-03) を追加すること。
- **必須** T-3 のうち `logs:DeleteLogGroup` (AL-05)、T-6 の `guardduty:DeleteDetector` ・ `securityhub:DisableSecurityHub` (AL-09)、および例外ロール (ログ管理者ロール) の引き受けと使用 (AL-11) を検知対象に加えること。
- **必須** T-5 について、鍵が削除待機状態になったことに起因する復号失敗 (エラーメッセージに当該キーARN と削除保留である旨が含まれる) を検知するメトリクスフィルタとアラーム (AL-08) を設定すること。削除の待機期間は7~30日 (既定30日) であり、この間に検知できれば取り消せる。
- **必須** 読み取り専用の管理イベント (AL-11 の `AssumeRole` 等) を EventBridge で受け取る場合は、ルールごとのオプトイン設定 (`ENABLED_WITH_ALL_CLOUDTRAIL_MANAGEMENT_EVENTS`) を行うこと。この設定はルール単位で読み取り専用の管理イベントすべてを受信対象とするため、イベントパターンで対象を絞り、通知量を設計時に評価すること。

8.6.2 設定状態の継続的な確認

イベント検知に加えて、AWS Config による「あるべき設定であり続けていること」の確認を併用すること。

- **必須** 次のマネージドルールを有効化すること。 `multi-region-cloudtrail-enabled` (管理イベントの除外設定があると `NON_COMPLIANT` となる)、 `cloud-trail-log-file-validation-enabled`、 `cloud-trail-encryption-enabled`、 `cloud-trail-cloud-watch-logs-enabled`、 `s3-bucket-versioning-enabled`、 `s3-bucket-default-lock-enabled`、 `s3-bucket-level-public-access-prohibited`、 `s3-account-level-public-access-blocks-periodic`、 `kms-cmk-not-scheduled-for-deletion`、 `guardduty-enabled-centralized`、 `securityhub-enabled`。

- **必須** `cw-loggroup-retention-period-check` は保持期間が「無期限」でも **COMPLIANT** と判定されるため、これだけでは保持期間の妥当性を確認できない。ロググループごとの `retentionInDays` を第7章の方針と突合する手順を別に設けること。
- **推奨** リソースタイプ `AWS::Config::ConfigurationRecorder` を記録対象に含め、設定レコーダー自体の停止・削除を追跡すること（追加料金は発生しない）。
- **推奨** CIS AWS Foundations Benchmark を採用する場合、**v3.0.0 および v5.0.0 では CloudWatch.1～14（メトリクスフィルター系）が自動チェックの対象外（手動確認）**となる。採用するバージョンによって自動評価の可否が変わるため、どのバージョンを採用し、手動確認をどの手続で代替するかを明記すること。

8.7 完全性テスト

改ざん防止は「設定したこと」ではなく「できないことを確かめたこと」で証明される。次のテストを受入テスト（第11章の受入チェックリスト）に含め、開発ベンダーが実施し、結果を発注者に提出すること。テストIDは本章の完全性（integrity）テストを表す `CT-` を接頭辞とし、本章限りの識別子として他章の固定IDとは別の体系とする。● **必須** 本番相当の構成で実施し、実施日時（UTC と現地時刻の対応を明記）、実施者、対象アカウント・リソース、実行コマンド、出力全文を記録すること。

なお、委託業務に係る内部統制についても発注者が責任を有し、発注者の評価範囲に含まれる。本章の実施結果は発注者による評価の基礎資料であり、発注者は提出された記録が十分な証拠を提供しているかを自ら検討する（必要に応じ、再実施への立会い、提出物からのサンプル抽出検証を行う）。

● 注意

予防統制を一時的に解除してテストしないこと。SCP やバケットポリシーを外して「削除できること」を確認する行為は統制の空白期間を作り、その間の操作は不可逆となる。CT-09b の鍵削除予約は検証環境の専用キーでのみ実施し、本番のログ暗号化キーでは行わないこと。

表8-3 完全性テスト項目

テストID	手順概要	期待結果	証跡
CT-01	運用者ロールでログアーカイブバケットのオブジェクト（バージョン指定）削除を試行する	アクセス拒否（HTTP 403）。対象バージョンが残存する	実行コマンドと出力、実行前後のオブジェクトバージョン一覧
CT-02	ログ管理者ロールで、保持期限内オブジェクトの削除と保持期間の短縮を試行する	いずれも拒否される（コンプライアンスモードではルートユーザーでも不可）	実行コマンドと出力、対象オブジェクトの保持設定の取得結果
CT-03	運用者ロールでライフサイクル設定の変更、バケットポリシーの変更・削除を試行する	アクセス拒否。既存のライフサイクル設定が変更されていない	実行コマンドと出力、適用中のライフサイクル設定とバケットポリシー
CT-04	運用者ロールで CloudWatch Logs の保持期間短縮とロググループ削除を試行する	SCP によりアクセス拒否。保持期間が維持されている	実行コマンドと出力、対象ロググループの保持期間
CT-05	運用者ロールで CloudTrail の証跡停止（StopLogging）と設定変更を試行し、証跡の状態を確認する	アクセス拒否。証跡は記録中のまま	実行コマンドと出力、証跡の状態取得結果
CT-06	運用者ロールで AWS Config の設定レコーダー停止と配信チャネル削除を試行する	アクセス拒否。レコーダーは記録中のまま	実行コマンドと出力、レコーダー状態の取得結果
CT-07	対象期間・対象アカウントを指定して <code>validate-logs</code> を実行する	標準ダイジェストとバックフィルダイジェスト（出力行に (backfill) が付く）の双方について、対象期間の全ファイルが valid。INVALID および欠落がない	実行コマンド全文と出力、対象証跡ARN・期間・実行者・実行日時（UTC）
CT-08	運用者ロールで、SSE-KMS の指定なしでのオブジェクト書き込み、および TLS を用いない操作を試行する	いずれもアクセス拒否	実行コマンドと出力
CT-09a	SCP・キーポリシー適用下のアカウントで、運用者ロールにより KMS キーの削除予約を試行する	アクセス拒否。キーの状態が変化しない	実行コマンドと出力、キーの状態取得結果
CT-09b	検証環境の専用 KMS キー（SCP 除外下）で、ログ管理者ロールにより削除予約を実行する（本番キーでは実施しない）	当該検証環境に構成した AL-07 相当のアラートが所定時間内に通知され、 <code>CancelKeyDeletion</code> により予約を取り消せる	実行コマンドと出力、アラート通知の受信記録、取り消し後のキー状態取得結果
CT-10	CT-03～CT-06 の拒否イベント発生後、アラートの発報と通知到達を確認する	第9章で定めた通知先（表8-2 の該当アラートID）に所定時間内に到達する	通知本文と受信日時、該当メトリクスの値、通知先の購読状態

- **必須** 例外ロール（ログ管理者ロール）については、CT-03～CT-06 と同一の手順が**意図どおり成功すること**を別途確認し、その実行記録を証跡に含めること。予防統制は「拒否されること」と「正当な主体では実行できること」の両方で成立する。
- **必須** 本テストは受入時に加え、**評価対象期間ごとに1回以上再実施すること**。また、SCP、バケットポリシー、Object Lock 設定、キーポリシー、証跡設定に変更があった場合は、当該変更に関係するテスト項目を変更後に再実施し、実施記録を保存すること。受入時の一回限りの実施では、8.8 の監査の視点が求める「評価対象期間の全体にわたって統制が有効であったこと」を裏付けられない。

● 補足

CT-01～CT-06 および CT-08 は、拒否されること自体に加えて、**拒否イベントが記録されていること**を確認する。ただし CT-01・CT-02・CT-08 はオブジェクトレベルの操作であり CloudTrail のデータイベントとして記録されるため、拒否記録の確認は当該バケットのデータイベントを有効にしている場合に限られる。有効にしていない場合は、ログアーカイブバケット自身のサーバーアクセスログ（8.4 の注意 (4)）での確認をもって代替し、その旨を証跡に記載すること。拒否された API 呼び出しはエラーコードを伴って記録され、CIS の「未認可の API 呼び出し」の検知もこれを利用している。テストの実行時刻で該当イベントを検索し、その結果もあわせて証跡とすること。これは LR-08（監視とアラート）と L-14（ログ基盤自身の監査ログ）の実装確認を兼ねる。

8.8 証跡として提出するもの

本章の統制について、開発ベンダーは次を成果物として発注者に提出すること。提出形式と提出手順は第12章、ログ設計書への記載事項は第11章、証跡の保管・証跡化は LR-09、ログ設計書・運用手順書としての文書化は LR-14 に従う。

- **必須** **改ざん防止設計の記述**（ログ設計書の一部）— 自環境に即した脅威モデル（8.1 の脅威IDごとの適用有無）、統制一覧（表8-1 の自環境版）、例外ロールの一覧とその根拠。
- **必須** **責任分界の一覧**— 本章の各統制について、開発ベンダーが設定・実装し検証できる範囲と、クラウド事業者側で担保され開発ベンダーが検証できない範囲（Object Lock による不変性の実装、ダイジェストファイルの署名、S3 の耐久性など）を区分して示すこと。後者の確認方法（保証報告書の入手、質問書・確認書、往査等）の選択は発注者が決定する（LR-13、ITGC-D）。ただしクラウドサービスでは委託先の内部統制が外部から見えにくいため、監査権の獲得または保証報告書の入手による確認が現実的な手段となる。
- **必須** **適用済み設定の取得結果**— バケットの Object Lock 設定、バージョニング状態、バケットポリシー、暗号化設定、SCP 本文、KMS キーポリシー、証跡の設定と稼働状態。いずれも取得コマンド・取得日時・実行者を付して提出すること（画面の写しのみは不可）。
- **必須** **設定変更の管理証跡**— 上記設定を管理する IaC のリポジトリ・コミットID、承認記録、適用日時。設定がパイプライン経由で管理されていることを示すこと（LR-12）。
- **必須** **整合性検証の実行記録**— `validate-logs` の実行日、対象証跡ARN、対象アカウント、対象期間、判定結果、実行者。管理アカウントを含む全対象アカウントが網羅されていること、および期間に切れ目がないこと（対象期間の全体が検証済みであること）が確認できる形で提出すること。
- **必須** **完全性テストの実施記録**— 表8-3 の全項目について、手順・実行結果・証跡・判定（合否）・是正内容。受入時の実施記録に加え、評価対象期間中の再実施記録および設定変更後の再実施記録を含めること。
- **必須** **Config ルールの評価結果**— 対象ルール名、評価日、COMPLIANT／NON_COMPLIANT の別、NON_COMPLIANT の是正記録。
- **推奨** **S3 Inventory レポート**— Object Lock の保持モード・保持期限・リーガルホールド・暗号化状態を含む項目を出力し、保全状態の一覧証跡とすること（日次または週次、初回配信までに時間を要する点に留意）。
- **必須** **例外操作の記録**— ログ管理者ロールの利用申請・承認・実施記録と、当該操作の L-14 における記録の突合結果。
- **必須** **検知・通知の実効性確認記録**— CT-09a・CT-09b・CT-10 の結果、および通知先の購読状態の確認記録。あわせて、表8-2 の各行が第9章のアラート定義と1対1で対応していることを示す突合結果。

- **必須 検証環境での確認結果**— 8.4 の注意 (2) に基づく CloudTrail の Object Lock 有効バケットへの配信確認（配信されたオブジェクトの一覧と保持状態）、8.5.1 の AWS Config 配信先バケットへの配信成功確認、8.5.2 の SCP の正常系・異常系確認、8.5.3 のキーポリシー再適用可能性の確認について、確認日・実施環境・確認結果・設計への反映内容を一覧にして提出すること。

● 監査の視点

内部統制の評価時点は期末日である。経済産業省「システム管理基準 追補版（財務報告に係るIT統制ガイドランス）」（令和6年12月25日）は、モニタリングの統制評価手続の例として、モニタリング対象として選んだログが全ての期間で収集されていることを確かめることを挙げている。この確認は、発注者の経営者評価、内部監査、外部監査（内部監査と外部監査はいずれも本書の R-6 監査人に含まれる）のいずれによっても行われ得る。したがって、期中に証跡が停止していた期間、整合性検証で INVALID が出た期間、アラートが機能していなかった期間があれば、それ自体が不備となり得る。ただし、期中に発見された不備でも、期末日までに是正し、是正後の運用状況の有効性を確認できれば、期末日時点の評価では有効と判断され得る。そのため、欠落の発生期間、検知日、是正日、是正後の再テストの記録を一連で残すこと。設定が現在正しいことを示すだけでは足りない。**評価対象期間の全体にわたって統制が有効であったことを、検証記録と検知記録の連続性で示せるようにしておくこと。**なお、IT全般統制の不備は直ちに開示すべき重要な不備と評価されるものではないが、代替的・補完的な統制の有無を検討されることになるため、不備が生じた期間と補完手続を記録しておくこと。

9

監視・アラートと定期レビュー運用

本章は、LR-08（監視とアラート）と LR-09（定期レビューと証拠化）を AWS 上でどのように実装し、どのような記録を残すかを定める。第8章までで「記録が残り、改ざんされない」状態を作った。本章はその先、**記録を見て気づき、対応し、対応したことを記録に残す**までの運用を規定する。ログは取得しただけでは統制ではない。誰にも見られていないログは、監査上は統制が存在しないのと同じ扱いになり得る。

本章は IT 全般統制の領域のうち ITGC-B（システムの運用・管理）と ITGC-C（内外からのアクセス管理などシステムの安全性の確保）を中心に扱い、変更レビュー（RV-05）およびログ設定の変更管理（RV-10）の範囲で ITGC-A（システムの開発、保守に係る管理）に、監視・レビュー業務の全部または一部を運用ベンダーに委託する場合の契約事項（実施責任、報告義務、証拠の提供、監査権）の面で ITGC-D（外部委託に関する契約の管理）に関係する。ログの取得設定そのものは第4章・第5章、保存期間は第7章、改ざん防止は第8章、レビュー実施者の権限設計と職務分掌は第10章で定める。本章はそれらを前提に、検知と定期レビューの設計・実装・記録だけを規定する。

読者である開発ベンダーの責務は、原則として**アラートとレビューの「仕組み」を構築し、運用主体（R-4 運用者、R-5 ログ管理者）が実施できる状態にして引き渡す**ことである。レビューの実施そのものは運用フェーズの作業だが、実施可能な状態（アラート定義、抽出クエリ、様式、手順書、権限）を用意するのは開発ベンダーの成果物である。9.7 にその一覧を示す。

● 補足

本章の表記規約を二つ示す。第一に、「～すること」の形で書かれた**要求事項には必ず要求レベル（必須／推奨／任意）**を付す。表の中の要求事項は、当該表のレベル欄、または表を導入する段落に付したレベルに従う。第二に、AWS CloudTrail が記録の書き出し先と範囲を定める設定単位は**証拠（trail）**と表記し、監査上の証拠を指す語は**証拠**に統一する（付録A 用語集）。

9.1 監視設計の考え方

9.1.1 リアルタイム検知と定期レビューの役割分担

監視は二層で設計すること（**必須**）。第一層はリアルタイム検知（LR-08）であり、特定の事象が発生した時点で通知を発する。第二層は定期レビュー（LR-09）であり、一定期間のログを人がまとめて確認し、確認した事実を記録に残す。両者は代替関係ではなく補完関係にあり、統制上の役割が異なる。

- **リアルタイム検知（LR-08）**は、被害の拡大防止と統制無効化の即時把握を目的とする。対象は個別事象（発生したか否かが問題になるもの）であり、出力は通知・初動対応記録・インシデント記録である。統制上は自動化された発見的統制にあたり、**整備状況（アラート定義と設定の存在）に加え、対象期間を通じて機能していたこと（発報記録と対応記録、実装テスト結果、設定変更履歴）が運用状況の評価の対象となる**。実施基準は、自動化された内部統制について、評価された時点から内部統制が変更されていないこと、障害・エラー等の不具合が発生していないこと、及び関連する全般統制の整備及び運用の状況を確認及び評価した結果、全般

統制が有効に機能していると判断できる場合には、**その結果を記録することで**、当該評価結果を継続して利用することができるとしている（実施基準Ⅱ.3(3)⑤二c）。設定が存在することを示すだけでは足りない。

- **定期レビュー（LR-09）**は、統制が対象期間を通じて機能していたことの立証を目的とする。対象は期間内の母集団（傾向・網羅性が問題になるもの）であり、出力はレビュー記録（実施者・承認者・確認結果・例外）である。統制上は人手による発見的統制およびモニタリングにあたり、監査では運用状況評価のサンプリング母集団と実施記録として使われる。

アラートだけを実装し定期レビューを設計しない構成は認められない。アラートは設定された事象しか検知しないため、アラート定義から漏れた事象は誰の目にも触れない。逆に定期レビューだけの構成も認められない。月次レビューではログ配信の停止を最大1か月見逃すことになり、その期間の記録は回復できない。両者の関係を図9-1に示す。

● 監査の視点

2023年（令和5年）4月改訂の実施基準は、ITを利用した内部統制の評価に関する留意点として「自動化されたITに係る業務処理統制であっても過信せずに、内部統制の無効化のリスクを完全に防ぐことは困難であるという視点を持つことが重要である。また、電子記録について変更の痕跡が残りにくい場合には、内部統制の無効化が生じてその発見が遅れることがある点についても留意することが重要である」との記述を追加した（実施基準Ⅱ.3(3)⑤二b）。同改訂は併せて、ITに係る全般統制が有効に機能していると評価されたとしても、それだけでITに係る業務処理統制も有効に機能しているという結論に至らない点に留意することが必要である旨を追加している（同⑤イ）。本章が二層構成を求める理由はここにある。監査人は「自動で記録している」という説明ではなく、**記録を誰が、いつ、どのような観点で確認し、何を発見し、どう対処したかを問う**。

9.1.2 予防統制との関係と検知の限界

経済産業省「システム管理基準 追補版（財務報告に係るIT統制ガイダンス）」はIT全般統制の目的として「プログラム及びデータへのアクセスは、あらかじめ承認された者だけにアクセス権限が設定される（予防的統制）。さらに、アクセス違反をモニタリングすることで、プログラムとデータの改ざんが防止される（発見的統制）」と述べる（追補版Ⅱ章2(2)①）。本章のアラートは後段の発見的統制に相当し、前段の予防的統制（SCP、IAM、バケットポリシー、Object Lock 等。第8章・第10章）を代替しない。

特に、技術的にログを取得できない操作をアラートで補うことはできない。例として AWS Systems Manager Session Manager は、ポートフォワーディング経由および SSH 経由のセッションについてセッションログを取得できない。この種の経路は検知ではなく**禁止**（IAM ポリシーまたは SCP による拒否）で対処すること（**必須**）。詳細は第5章および第10章に従う。

● 注意

「アラートを設定したので当該操作を許可してよい」という設計は認められない。ログを取得できない操作経路、記録に個人が現れない共有認証情報、承認記録が残らない直接操作については、検知ではなく経路の遮断で対処すること（**必須**）。検知に依存してよいのは、**操作の記録が確実に残る経路**に限られる。

9.1.3 CIS AWS Foundations Benchmark との整合

アラート定義は独自に一から設計するのではなく、CIS AWS Foundations Benchmark のモニタリング関連項目を基礎として設計すること（**必須**）。AWS Security Hub CSPM はこれらを CloudWatch.1～CloudWatch.14 のコントロールとして実装しており、各コントロールの Remediation（修復）節にメトリクスフィルターのパターン

を掲載している。同ドキュメントは「CIS が規定する正確なメトリクスフィルターを使用しない場合、このコントロールは不合格となる。メトリクスフィルターにフィールドや項を追加することはできない」と明記しているため、**Security Hub CSPM の各コントロールの Remediation 節に記載されたパターンをそのまま転記して実装すること（必須）**。

ただし CloudWatch.4（IAM ポリシー変更=A-03）および CloudWatch.13（ルートテーブル変更=A-16）については、同ドキュメントに「**当社の推奨フィルターパターンは CIS ガイドンスのフィルターパターンと異なる**」旨が**明記されている**（AWS 推奨パターンは、それぞれ IAM の API 呼び出し、Amazon EC2 の API 呼び出しに由来するイベントのみを対象とする）。転記すべきは Security Hub CSPM に掲載されたパターンであり、CIS 公表資料との差異を理由にパターンを改変しないこと（**必須**）。改変すると、当該コントロールが自動評価される構成（次段落の CIS バージョン別の区分を参照）では不合格となり得る。自動評価されない構成でも、パターンの一貫性と証拠の説明可能性を保つため、この要求を同様に適用する。

また、採用する CIS のバージョンによって自動評価の可否が変わる。Security Hub CSPM は CIS AWS Foundations Benchmark の v5.0.0、v3.0.0、v1.4.0、v1.2.0 をサポートし推奨は v5.0.0 であるが、**CloudWatch.1～14（メトリクスフィルター系）のすべてが自動チェックの対象となるのは v1.2.0 のみ**である。v1.4.0 では CloudWatch.2（未認可 API 呼び出し）と CloudWatch.3（MFA なしコンソールサインイン）が標準に含まれず「Not supported – manual check」（手動確認）として扱われ、残る12件（CloudWatch.1 および CloudWatch.4～14）のみが自動判定される。v3.0.0 および v5.0.0 では CloudWatch.1～14 のすべてが手動確認として扱われる。この違いは、提出すべき証拠の形を変える。

- **v1.2.0 を採用する場合:** CloudWatch.1～14 は自動判定されるため、Security Hub CSPM のコントロール結果（合格状態）をアラート実装の証拠として利用できる。
- **v1.4.0 を採用する場合:** CloudWatch.1 および CloudWatch.4～14 は自動判定され、コントロール結果を証拠として利用できる。一方、**A-11（CloudWatch.3）および A-12（CloudWatch.2）については自動判定結果が得られない**。この2件は、開発ベンダーがメトリクスフィルターとアラームの設定一覧、および 9.3 に基づく実装テスト結果を自ら証拠として提出すること（**必須**）。
- **v3.0.0 または v5.0.0 を採用する場合:** CloudWatch.1～14 は自動判定されない。開発ベンダーが**メトリクスフィルターとアラームの設定一覧、および 9.3 に基づく実装テスト結果を自ら証拠として提出すること（必須）**。Security Hub CSPM の合格結果をもってアラート実装の証拠とする設計は成立しない。
- **複数バージョンを併用する場合:** 同ドキュメントは複数バージョンの同時有効化を認めており、旧版を無効化する前に新版を有効化することで検査の空白を避けられるとしている。したがって、最新の統制水準を v5.0.0 で維持しながら CloudWatch.1～14 の自動判定を残すために **v5.0.0 と v1.2.0 を併用すること**も選択肢となる。併用する場合は上記の該当する証拠を揃えたうえで、重複するコントロールの読み替え表を作成すること（**必須**）。

● 注意

Security Hub CSPM のコントロール結果を証拠として用いる方式には、**組織証跡（organization trail）を使用する場合の制約**がある。同ドキュメントは、組織証跡を使用すると組織のメンバーアカウントで評価される当該コントロールの状態が `NO_DATA` となること、メンバーアカウントではそのアカウントが所有するリソースについてのみ検出結果が生成されること、組織証跡に関する検出結果は**リソース所有者のアカウントで生成される**ことを明記している。またマルチリージョン証跡は別のリージョンを基点とする場合があり、これらの検出結果は Security Hub CSPM の委任管理者アカウントでクロスリージョン集約により参照する。第6章のリファレンスアーキテクチャに従って組織証跡を採用する場合、この方式では大半のアカウントで証拠が得られないため、**コントロール結果が生成されるアカウントと、メンバーアカウント側の代替証拠（メトリクスフィルター・アラームの設定一覧および実装テスト結果）を設計時に定めること（必須）**。

どのバージョンを採用するかは発注者が決定する事項である。開発ベンダーは着手時に採用バージョンを確認すること（**必須**）。なお CIS は v3.0.0 以降で CloudTrail の Amazon CloudWatch Logs 連携に関する要件（CloudTrail.5）を削除しているが、本ガイドラインは 9.3 の実装経路上これを必須とする（**必須**）。

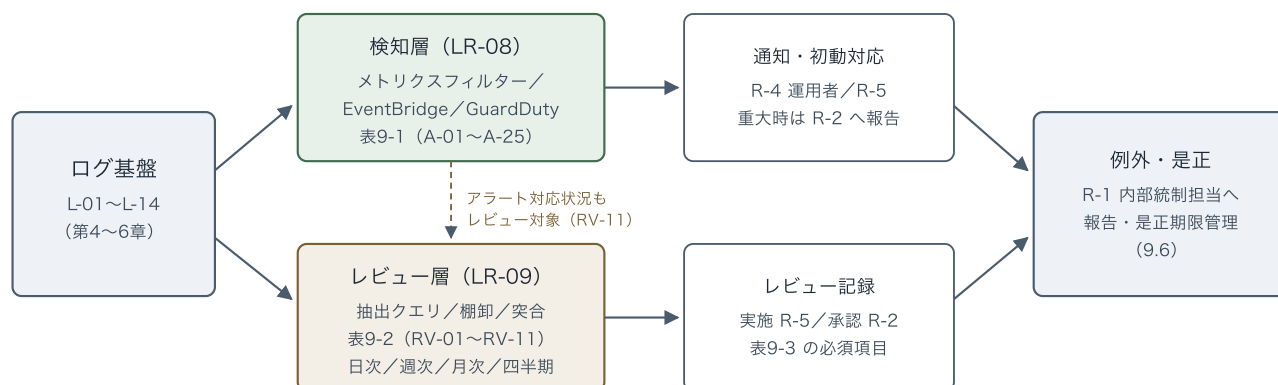


図9-1 検知層と定期レビュー層の二層構成

9.2 アラートカタログ

表9-1 のアラートを、各行のレベル欄に従って実装すること。レベルが「必須」の項目は発注者が受入条件とする。発生源欄の「CloudWatch.n」は Security Hub CSPM のコントロール番号を示し、当該コントロールの Remediation 節が規定するメトリクスフィルターパターンを CloudTrail 連携先の Amazon CloudWatch Logs ロググループに対して作成することを意味する。

重要度は **P1（即時対応）** と **P2（翌営業日までに初動）** の2段階とし、各重要度の具体的な対応時限・通知体制・受付時間帯（24時間365日か営業時間内か）は発注者と協議して確定すること（**必須**）。定期レビューでのみ確認すれば足りる事象は、アラートの重要度区分ではなく 9.4 の表9-2（RV-01～RV-11）で扱う。したがって第3の区分は設けない。記号に「S」を用いないのは、Amazon S3 の表記と紛れることを避けるためである。

なおレベル欄の区分は、本ガイドラインが発注者の受入条件として定めるものであり、CIS の項目区分とは一致しない。ネットワーク関連の CloudWatch.10～14 のうち A-15（ネットワークゲートウェイの変更）のみを「推奨」としているのは、財務報告に関連するシステムの構成として当該変更が想定されない場合があるためである。A-12（未認可 API 呼び出しの多発）を「推奨」としているのは、検出の大半が権限設計の誤りや正常な権限境界による拒否に由来し、誤検知が多く運用負荷が高くなるため、発注者が費用対効果を判断する余地を残す趣旨である。A-20（Security Hub CSPM のコントロール不合格）を「推奨」としているのは、検出結果の件数と重要度が有効化する標準・コントロールの構成に依存し、通知量が過大になる場合があるためであり、発注者が対象コントロールの絞り込みとあわせて採否を判断する趣旨である。A-12、A-15 および A-20 のいずれについても実装しない場合は、その判断と理由を発注者と合意し 9.7 のアラート一覧表に記録すること（**必須**）。CIS の当該バージョンに準拠すること自体を発注者が求める場合は、A-12 および A-15 を含む CloudWatch.1～14 のすべてを実装すること（**必須**）。

表9-1 アラートカタログ

ID	検知事象	発生源	重要度	初動対応	レベル
A-01	ルートユーザーによる API 操作・サービス利用	CloudTrail→CloudWatch Logs メトリクスフィルター (CloudWatch.1)	P1	利用者と作業目的を特定し事前承認の有無を確認する。承認がなければ認証情報を無効化し R-1 へ報告する	必須
A-02	ルートユーザーのコンソールサインイン	CloudTrail→CloudWatch Logs メトリクスフィルター（自作パターン。CloudWatch.1 の規定パターンとは別に作成する。 userIdentity.type=Root と eventName=ConsoleLogin の組合せ。CIS 規定パターンではないため自作し、検証すること）	P1	A-01 と同じ。加えて送信元 IP と MFA 使用状況を記録する	必須
A-03	IAM ポリシー・権限の変更	メトリクスフィルター (CloudWatch.4。AWS 推奨パターンは CIS 公表ガイダンスと異なる。9.1.3 参照)	P2	変更申請と突合する。申請外であれば差し戻し、影響範囲を調査する	必須
A-04	CloudTrail 設定変更・記録停止	メトリクスフィルター (CloudWatch.5)	P1	記録停止の場合は直ちに再開する。停止期間を特定し欠損期間として記録する	必須
A-05	CloudTrail イベントセクター変更（記録範囲の縮小）	EventBridge ルール（PutEventSelectors 等。CloudWatch.5 のパターンに含まれない。証跡（trail）のホームリージョンに作成すること）	P1	除外されたイベントソース・データイベントを特定する。除外期間中のイベントは事後に回復できないため欠損として記録する	必須
A-06	AWS Config 設定変更・記録停止	メトリクスフィルター (CloudWatch.9)	P1	記録停止の場合は直ちに再開する。停止期間の構成変更履歴の欠損を記録する	必須
A-07	Config レコーダー削除・設定項目の保持期間変更	EventBridge ルール（DeleteConfigurationRecorder／PutRetentionConfiguration／DeleteRetentionConfiguration。CloudWatch.9 のパターンに含まれない。AWS Config を有効化した各リージョンに作成すること）	P1	削除・短縮の承認有無を確認し、承認外であれば復旧して R-1 へ報告する	必須
A-08	KMS カスタマー管理キーの無効化・削除予約	メトリクスフィルター (CloudWatch.7)	P1	対象キーがログ暗号化用か判定する。ログ用であれば待機期間内に削除予約を取り消す	必須

ID	検知事象	発生源	重要度	初動対応	レベル
A-09	ログ用 Amazon S3 バケットのポリシー・ライフサイクル・レプリケーション変更	メトリクスフィルター（CloudWatch.8。パターンは改変できないため対象バケットの絞り込みは通知後の判別で行う）	P1	変更内容を差分で特定する。保持期間の短縮や削除許可の追加は直ちに巻き戻す	必須
A-10	コンソール認証失敗の多発	メトリクスフィルター（CloudWatch.6）+しきい値（例: 5分間に3回以上）。ConsoleLogin イベントの認証失敗を対象とするため、IAM Identity Center またはフェデレーション経由のサインイン失敗は検知されない（後述の注意を参照）	P2	対象アカウントと送信元 IP を特定する。総当たりの兆候があればアカウントを停止する	必須
A-11	MFA を使用しないコンソールサインイン	メトリクスフィルター（CloudWatch.3）。パターンが <code>userIdentity.type</code> を <code>IAMUser</code> に限定しているため、IAM Identity Center またはフェデレーション経由のサインインは検知されない（後述の注意を参照）	P2	対象ユーザーの MFA 設定状況を確認し、未設定であれば登録を強制する	必須
A-12	未認可 API 呼び出し（アクセス拒否）の多発	メトリクスフィルター（CloudWatch.2）+しきい値	P2	権限設計の誤りか不正試行かを切り分ける。不正試行であれば A-10 に準じる	推奨
A-13	セキュリティグループの変更	メトリクスフィルター（CloudWatch.10）	P2	変更申請と突合する。全開放ルールの追加は直ちに撤回する	必須
A-14	ネットワーク ACL の変更	メトリクスフィルター（CloudWatch.11）	P2	変更申請と突合する	必須
A-15	ネットワークゲートウェイの変更	メトリクスフィルター（CloudWatch.12）	P2	承認されていない外部接続経路の追加でないことを確認する	推奨
A-16	ルートテーブルの変更	メトリクスフィルター（CloudWatch.13。AWS 推奨パターンは CIS 公表ガイダンスと異なる。9.1.3 参照）	P2	変更申請と突合し、ログ配信経路への影響を確認する	必須
A-17	VPC の変更・ピアリング接続	メトリクスフィルター（CloudWatch.14）	P2	変更申請と突合し、承認されていない外部組織との接続でないことを確認する	必須

ID	検知事象	発生源	重要度	初動対応	レベル
A-18	AWS Organizations の変更（アカウント作成・移動・脱退、ポリシー変更）	EventBridge ルール（eventSource=organizations.amazonaws.com）。 AWS Organizations は米国東部（バージニア北部）リージョンでのみホストされるため、ルールと通知先は us-east-1 に作成すること。 CIS 規定のメトリクスフィルターパターンは Security Hub CSPM のコントロールとして提供されていないため、監視対象 API 名を発注者と合意のうえ自作し、実イベントで検知を検証すること	P1	アカウント脱退と SCP 変更は組織証跡（organization trail）および予防統制に直結するため、記録範囲への影響を最優先で確認する	必須
A-19	GuardDuty の高重要度検出結果	Amazon GuardDuty→EventBridge（新規検出結果はニアリアルタイムで配信され、この頻度は変更できない）	P1	検出種別に応じて封じ込める。検出結果は90日で消えるため Amazon S3 へのエクスポートが有効であることを確認する	必須
A-20	Security Hub CSPM のコントロール不合格（統制逸脱）および重大な検出結果	AWS Security Hub CSPM→EventBridge（連携経路と検出結果の形式は公式ドキュメントで確認すること）	P2	該当コントロールを是正する。是正しない場合は 9.6 の例外手続に載せる	推奨
A-21	特権セッションの開始（Session Manager）	EventBridge ルール（Systems Manager のセッション開始 API。対象イベント名は公式ドキュメントで確認すること）	P2	事前承認記録と突合する。承認外のセッションは即時終了し R-2 へ報告する	必須

ID	検知事象	発生源	重要度	初動対応	レベル
A-22	データベース管理者アカウントのログイン失敗	DB 監査ログ（L-06）→CloudWatch Logs メトリクスフィルター。監査ログの形式と出力先はデータベースエンジンにより異なる（Aurora MySQL の高度な監査および RDS の MariaDB Audit Plugin は CSV 形式、RDS/Aurora PostgreSQL の pgAudit は PostgreSQL のログへ出力、RDS for Oracle は audit_trail パラメータを設定したうえで監査ログを CloudWatch Logs へ発行でき（ロググループは /aws/rds/instance/<インスタンス名>/audit）メトリクスフィルターの対象にできる。RDS for SQL Server が CloudWatch Logs へ発行できるログは error と agent であり、SQL Server Audit の監査ファイルは Amazon S3 に出力されるため、メトリクスフィルターの対象にならない。RDS for Db2 の監査ログも S3 にのみ出力される（完了したログファイル単位でアップロードされる）ため、メトリクスフィルターの対象にならない。Database Activity Streams はストリームへの配信であり、いずれのエンジンでもメトリクスフィルターの対象にならない。採用エンジンの実ログの構成を確認したうえでパターンまたは代替の検知手段を設計し、検証すること。接続の失敗を記録するための設定はエンジンにより異なる（Aurora MySQL の高度な監査および MariaDB Audit Plugin は監査イベント種別に CONNECT を含める。RDS/Aurora PostgreSQL の pgAudit には接続イベントのクラスがないため、接続・認証の失敗は PostgreSQL 本体のログ設定（log_connections 等）で記録する。RDS for Db2 は監査ポリシーの VALIDATE カテゴリ（ALL に含まれる）を FAILURE または BOTH で設定する）。S3 にのみ出力される監査ログ（SQL Server Audit、RDS for Db2）を対象とする場合は、S3 への到着を契機とする解析または定期抽出による検知とし、検知までの遅延を設計書に明記すること。詳細は第5章に従う	P2	接続元と対象アカウントを特定する。アプリケーション由来でなければ A-10 に準じる	必須
A-23	ログ配信の停止・ログ量の急減	CloudWatch アラーム（ロググループの取り込み量に対する下限しきい値を設定する。 ログ配信が完全に停止するとデータポイントが発生せず、既定の欠測データ設定ではアラームが INSUFFICIENT_DATA にとどまり通知されないため、欠測データを breaching として扱うよう明示的に設定すること ）+証跡（trail）の配信状態の定期確認（get-trail-status）。使用するメトリクス名は公式ドキュメントで確認すること。S3 に直接出力されるログ（RDS for Db2 の監査ログ等）はロググループの取り込み量で監視できないため、出力先プレフィックスへの新規オブジェクトの到着の有無（S3 のリクエストメトリクス、イベント通知等）を監視すること	P1	配信エラーの内容（バケットポリシー、KMS キーポリシー、プレフィックス不一致等）を特定して復旧する。欠損期間を記録する	必須
A-24	バックアップジョブの失敗	AWS Backup のサービスイベント→EventBridge	P2	再取得の可否を判定する。取得できなかった対象と期間を記録する。失敗が連続する場合は復旧目標への影響を R-2 に報告する	必須

ID	検知事象	発生源	重要度	初動対応	レベル
A-25	財務報告に関連するジョブ・バッチの異常終了	ジョブ・バッチ実行ログ（L-08）→CloudWatch Logs メトリクスフィルター、またはジョブ基盤からの EventBridge 連携。いずれの経路を採るかを設計書に記録すること（9.3.4）	P1	再実行の可否を判定する。データ不整合の可能性がある場合は業務部門へ即時連絡し影響範囲を記録する	必須

● 注意

A-05 と A-07 を省略しないこと。CloudWatch.5 のパターンは CloudTrail のイベントセレクトター変更を含まず、CloudWatch.9 のパターンは Config レコーダーの削除および保持設定の変更を含まない。すなわち CIS のメトリクスフィルターだけを実装すると、**記録を止めずに記録範囲だけを縮小する操作**が検知されない穴が残る。特に CloudTrail のイベントセレクトターで管理イベントのソースを除外した場合、除外期間中のイベントは事後に回復できない。EventBridge による補完に加え、AWS Config マネージドルール `multi-region-cloudtrail-enabled`（管理イベントの除外設定が空でない場合も NON_COMPLIANT と判定される）を発見的統制として併用すること（**必須**）。

● 注意

A-10 と A-11 の検知範囲には限界がある。A-11 が採用する CloudWatch.3 の規定パターンは `userIdentity.type` が `IAMUser` であるサインインのみを対象とし、A-10 が採用する CloudWatch.6 の規定パターンは `ConsoleLogin` イベントの認証失敗を対象とする。一方、本書が第5章・第10章で推奨する IAM Identity Center またはフェデレーションによるサインインは、これらとは異なるイベントソースおよびイベント種別で記録される。したがって**これら2件のアラートを実装しても、IAM Identity Center 経由のサインイン失敗および MFA を用いないサインインは検知されない**。採用する認証方式に応じて、L-04（認証・認可ログ）側の検知定義を追加するか、RV-02（アクセス権棚卸）で補完すること（**必須**）。対象となるイベントソースとイベント種別は第5章に従い、公式ドキュメントで確認すること（**必須**）。

9.3 実装パターン

表9-1 の25件は、次の4つの実装経路のいずれかに割り当てられる。経路1（メトリクスフィルター）に15件（A-01～A-04、A-06、A-08～A-17）、経路2（EventBridge ルール）に5件（A-05、A-07、A-18、A-21、A-24）、経路3（セキュリティ検知サービス）に2件（A-19、A-20）、経路4（CloudTrail 以外のログ）に3件（A-22、A-23、A-25）である。**すべてのアラートについて採用した実装経路を 9.7 のアラート一覧表に記載し、経路の割り当てに漏れないことを確認できるようにすること（必須）**。

9.3.1 経路1: メトリクスフィルター経由

CloudTrail のイベントを Amazon CloudWatch Logs に配信し、メトリクスフィルターでメトリクス化し、CloudWatch アラームから Amazon SNS へ通知する経路である。CIS 由来のアラート（A-01、A-03、A-04、A-06、A-08～A-17）および自作パターンの A-02 は、実装する場合はこの経路によること（**必須**）。各アラートの実装要否は表9-1 のレベル欄に従い、推奨のアラート（A-12、A-15 等）を実装しない場合は、その旨と理由を 9.7 のアラート一覧表に記載すること。ただし改変が禁止されるのは CIS が規定するパターン（Security Hub CSPM

の Remediation 節に掲載されたもの）のみであり、A-02 のパターンは自作・検証のうえ 9.7 のアラート一覧表にパターン本文を記載すること（**必須**）。CloudTrail の証跡（trail）に CloudWatch Logs への配信を設定し（IAM ロールが必要で、ロググループは同一アカウント内に置く）、ロググループに対してメトリクスフィルターを作成し、生成されたメトリクスにアラームを設定して Amazon SNS トピックへ通知する。AWS の設定例では、名前空間 `CloudTrailMetrics`、統計 `Sum`、期間5分、しきい値1以上が用いられている。

```
# A-01 ルートユーザー使用（CloudWatch.1 の AWS 推奨パターン。Remediation 節より転記。改変しないこと）
{$.userIdentity.type="Root" && $.userIdentity.invokedBy NOT EXISTS && $.eventType != "AwsServiceEvent"}

# A-04 CloudTrail 設定変更・記録停止（CloudWatch.5 の AWS 推奨パターン）
{($.eventName=CreateTrail) || ($.eventName=UpdateTrail) || ($.eventName=DeleteTrail) ||
 ($.eventName=StartLogging) || ($.eventName=StopLogging)}

# A-10 コンソール認証失敗（CloudWatch.6 の AWS 推奨パターン）
{($.eventName=ConsoleLogin) && ($.errorMessage="Failed authentication") }

# A-11 MFA を使用しないコンソールサインイン（CloudWatch.3 の AWS 推奨パターン。IAMUser に限定される点に注意）
{ ($.eventName = "ConsoleLogin") && ($.additionalEventData.MFAUsed != "Yes") && ($.userIdentity.type =
"IAMUser") && ($.responseElements.ConsoleLogin = "Success") }
```

設定は IaC で管理すること（**必須**）。成果物は 9.7）。参考として CLI での作成手順を示す。

```
aws logs put-metric-filter \
  --log-group-name <CloudTrail 連携先ロググループ名> \
  --filter-name RootAccountUsage \
  --filter-pattern '{$.userIdentity.type="Root" && $.userIdentity.invokedBy NOT EXISTS && $.eventType
!="AwsServiceEvent"}' \
  --metric-transformations \
    metricName=RootAccountUsageCount,metricNamespace=CloudTrailMetrics,metricValue=1

aws cloudwatch put-metric-alarm \
  --alarm-name JSOX-A-01-RootAccountUsage \
  --metric-name RootAccountUsageCount \
  --namespace CloudTrailMetrics \
  --statistic Sum \
  --period 300 \
  --evaluation-periods 1 \
  --threshold 1 \
  --comparison-operator GreaterThanOrEqualToThreshold \
  --alarm-actions <SNS トピック ARN>
```

この経路には次の制約がある。設計時にすべて考慮すること（**必須**）。

- **遡及適用されない**: メトリクスフィルターは作成後に取り込まれたデータのみを対象とする。したがって本番稼働開始前にすべてのフィルターを作成し、作成日時を証拠として記録すること（**必須**）。稼働後に追加した場合は、追加前の期間を検知の空白として記録すること（**必須**）。
- **ログクラスの制約**: メトリクスフィルターは Standard ログクラスでのみ利用でき、ロググループのログクラスは作成後に変更できない。CloudTrail 連携先ロググループを Infrequent Access クラスで作成しないこと（**必須**）。コスト削減は保持期間の設定と Amazon S3 への階層化（第7章）で行うこと（**推奨**）。
- **個数上限**: メトリクスフィルターはロググループあたり100個までである。アラート定義数が上限に近づく場合はロググループを分割するか、EventBridge 経路へ振り分けること（**推奨**）。
- **イベントサイズの制約**: CloudTrail は 256 KB を超えるイベントを CloudWatch Logs および EventBridge に送信しない。大きなリクエストパラメータを伴う操作は検知できない場合がある。当該操作は Amazon S3 上の証跡（trail）のログに対する定期レビュー（RV-01、RV-05）で補完すること（**必須**）。

- **配信遅延:** CloudTrail のログ配信は API 呼び出しから平均約5分だが保証されていない。アラートの対応时限は「イベント発生時刻」ではなく「通知受信時刻」を起点として定義すること（**必須**）。
- **欠測データの扱い:** 取り込み量の下限監視など「無音」を検知するアラームでは、欠測データを breaching として扱うよう明示的に指定すること（AWS CLI では `put-metric-alarm` の `--treat-missing-data breaching`）（**必須**）。指定しない場合、対象が完全に停止したときはデータポイント自体が発生しないため、アラームは `INSUFFICIENT_DATA` にとどまり通知を発しない。
- **異常検知の適用範囲:** CloudWatch Logs の異常検知機能は、CloudTrail のような長大な JSON ログや監査・アクセスログには適さない（解析対象がイベントの先頭部分に限られる）。統制目的のアラートを異常検知に依存させず、定義済みパターンによる検知を基本とすること（**必須**）。

9.3.2 経路2: EventBridge ルール経由

EventBridge ルールはリージョナルなリソースであり、CloudTrail 経由の API イベントは当該 API 呼び出しが記録されたリージョンのイベントバスにのみ配信される。マルチリージョン証跡（trail）の単一ロググループを対象とすればよい経路1（メトリクスフィルター）と異なり、経路2では監視対象イベントが記録されるリージョンのすべてにルールを作成すること（**必須**）。とりわけ AWS Organizations は米国東部（バージニア北部）リージョンでのみホストされるため、A-18 のルールと通知先は **us-east-1 に作成すること**（**必須**）。他リージョンに作成したルールはエラーを出さずに一度も発火せず、統制が存在しないまま合格と判定されるおそれがある。A-05（証跡のホームリージョン）および A-07（AWS Config を有効化した各リージョン）についても、対象リージョンを一覧化し、作成漏れがないことを 9.7 のアラート一覧表で確認できるようにすること（**必須**）。IAM や AWS STS などグローバルサービスの API 呼び出しイベントが配信されるリージョンは公式ドキュメントで確認し、対象リージョンの一覧と展開方法（IaC による全リージョン展開の可否）を設計書に明記すること（**必須**）。

CIS がパターンを規定していない事象（A-05、A-07、A-18、A-21、A-24）はこの経路で実装すること（**必須**）。CloudTrail 経由の API イベントは `detail-type` が `"AWS API Call via CloudTrail"` となる。次はイベントパターンの記述例である（このルールは us-east-1 に作成する）。

```
{
  "source": ["aws.organizations"],
  "detail-type": ["AWS API Call via CloudTrail"],
  "detail": {
    "eventSource": ["organizations.amazonaws.com"],
    "eventName": ["<監視対象の API 名を発注者と合意のうえ列挙する>"]
  }
}
```

読み取り専用（Describe/Get/List 等）の管理イベントは既定では EventBridge に配信されず、ルールごとにオプトインする必要がある（`ENABLED_WITH_ALL_CLOUDTRAIL_MANAGEMENT_EVENTS`。CLI または CloudFormation でのみ設定可能）。監視対象に読み取り系の操作を含める場合は、この設定の可否を検討すること（**推奨**）。

● 補足

A-18（Organizations 変更）については、AWS が公開する既製のメトリクスフィルターパターンが存在しない。開発ベンダーは監視対象 API 名を一覧として提示し、発注者の承認を得たうえで実装すること（**必須**）。実装後は、検証環境で実際に対象操作を行って通知が届くことを確認し、その記録を受入証拠に含めること（**必須**）。この検証は、ルールが正しいリージョン（us-east-1）に作成されていることの確認を兼ねる。

9.3.3 経路3: セキュリティ検知サービス経由

Amazon GuardDuty および AWS Security Hub CSPM の検出結果を EventBridge で受け、Amazon SNS へ通知する経路である。A-19、A-20 は、実装する場合はこの経路によること（**必須**）。実装要否は表9-1 のレベル欄による）。GuardDuty の新規検出結果はニアリアルタイムで EventBridge へ配信され、この配信頻度は変更できない。更新された検出結果の配信頻度は既定6時間であり、15分または1時間に変更できるため、運用要件に応じて設定すること（**推奨**）。GuardDuty の検出結果は90日で保持が終了するため、Amazon S3 へのエクスポート（AWS KMS による暗号化が**必須**。詳細は第5章）を併せて設定すること（**必須**）。アーカイブ済みの検出結果はエクスポートされない点に留意する。

なお2025年以降、セキュリティ標準とコントロール評価を担う **AWS Security Hub CSPM** と、GuardDuty や Inspector 等の信号を相関させる**新しい AWS Security Hub** は別のサービスとして扱われている。A-20 の「統制逸脱」は Security Hub CSPM のコントロール不合格を指す。新しい AWS Security Hub を併用する場合は、いずれの検出結果を A-20 の対象とするかを発注者と合意し、9.7 のアラート一覧表に明記すること（**必須**）。

9.3.4 経路4: CloudTrail 以外のログに対するメトリクスフィルター・アラーム

CloudTrail 以外のログを発生源とするアラート（A-22、A-23、A-25）はこの経路で実装すること（**必須**）。ただし CloudWatch Logs に取り込まれず S3 にのみ出力されるログ（RDS for SQL Server の SQL Server Audit、RDS for Db2 の監査ログ）を発生源とする場合は、表9-1 の A-22・A-23 に記載した代替手段による）。経路1 と同じ CloudWatch Logs のメトリクスフィルターとアラームを用いるが、対象ロググループも判定条件も CIS の規定にやらないため、次の点を設計書に明記すること（**必須**）。

- **対象ロググループ:** A-22 はデータベース監査ログ（L-06）の発行先ロググループ（S3 にのみ出力されるエンジンでは、代替手段の対象とする S3 バケットとプレフィックス）、A-23 は監視対象とする各ログの取り込み量、A-25 はジョブ・バッチ実行ログ（L-08）の出力先ロググループを、それぞれ名称で特定して記載すること（**必須**）。
- **パターン作成の前提:** 判定パターンは実ログの形式に合わせて自作すること（**必須**）。CloudTrail を前提とした JSON パターンは、CSV 形式やテキスト形式のログには適用できない。採用したパターン本文と、検証に用いた実ログのサンプル（機微情報を除く）を 9.7 のアラート一覧表に記載すること（**必須**）。
- **欠測時の扱い:** A-23 では欠測データを breaching として扱うこと（**必須**。理由は 9.3.1 の「欠測データの扱い」を参照）。
- **A-25 の実装経路の選択:** A-25 は、ジョブ・バッチのログに対するメトリクスフィルターで検知する方式と、ジョブ基盤（ワークフローエンジン、コンテナオーケストレーター等）の状態変化を EventBridge で受ける方式のいずれでも実装できる。いずれを採るか、その選択理由、および検知漏れがないことの検証結果を設計書と受入証拠に記録すること（**必須**）。

参考として、A-23 の「無音の検知」を成立させる CLI の指定を示す。要点は `--treat-missing-data breaching` である。

```
aws cloudwatch put-metric-alarm \
  --alarm-name JSOX-A-23-LogIngestionStopped \
  --metric-name <取り込み量メトリクス名> \
  --namespace <名前空間> \
  --dimensions Name=LogGroupName,Value=<監視対象ロググループ名> \
  --statistic Sum \
  --period 3600 \
  --evaluation-periods 1 \
  --threshold <平常時の取り込み量から定めた下限値> \
  --comparison-operator LessThanThreshold \
  --treat-missing-data breaching \
  --alarm-actions <SNS トピック ARN>
```

9.3.5 通知先の二重化と失効監視

通知経路そのものが統制の単一障害点になる。次を実装すること。要求レベルは各項に付したとおりとする。

- 重要度 P1 のアラートは、少なくとも2系統の通知先（例: 運用チームの配信先アドレスと、チャット連携またはインシデント管理システム連携）に配信すること（**必須**）。個人のアドレス単独を通知先にしないこと（**必須**）。
- Amazon SNS のメール配信には次の失効要因がある。設計と運用の両面で対処すること（**必須**）。
 - バウンスが発生すると、そのアドレスへの配信が7日間抑止される。
 - 確認されていないサブスクリプションは48時間で削除される。
 - email/email-json の宛先に対して1秒あたり10メッセージを超えると配信が自動停止し、当該サブスクリプションは確認待ち（PendingConfirmation）状態に戻されたうえで、再確認されなければ30日後に自動削除される。P1 アラートの一斉発報時にこの上限を超えない通知設計とすること（**必須**）。
 - 未確認のサブスクリプションは確認待ちのまま通知を受信できない。CloudWatch アラームの通知先一覧には確認待ちとして表示されるため、全受信者の確認完了を稼働前に確認し記録すること（**必須**）。
 - メールのセキュリティ検査機構が配信停止リンクを自動的に開くことで、意図せず購読が解除される事象が報告されている。配信停止に認証を要求する設定を検討すること（**推奨**）。
- サブスクリプションの状態（確認済みであるか、削除されていないか）を定期的に確認して記録し、これを RV-11 のレビュー項目に含めること（**必須**）。
- アラートが実際に通知されることを、本番稼働前および構成変更後にテストイベントで確認し記録すること（**必須**）。テスト方法と結果は第11章の受入チェックリストに含める。

9.4 レビューカタログ

表9-2 のレビューを設計し、手順書・抽出クエリ・様式を整備すること（**必須**）。承認は R-2 システム所管が行う。レビューの実施体制は次の二通りを認める。第一は、**開発・運用から独立した R-5 ログ管理者が単独で実施する**形であり、原則としてこれによる。第二は、**運用者（R-4）が一次確認を行い、開発・運用から独立した確認者（R-5）が二次確認（独立レビュー）を行う**二段構成であり、日次・週次の運用結果の確認のように運用主体が実施しなければ実務が回らないレビュー（RV-06、RV-07）に限って認める。いずれの場合も、承認の前段に開発・運用から独立した者による確認が必ず入ること（**必須**）。

R-6 監査人は読み取り専用の立場であり、表9-2 のレビュー（日常的モニタリングとして実施する統制）の実施者にはしないこと（**必須**）。ただしこれは、内部監査部門が独立的評価としてレビューの実施状況・記録を検証す

ることを妨げるものではない。頻度は初期値であり、発注者の決算スケジュールおよびリスク評価に応じて確定すること（**必須**）。

表9-2の「一次確認／独立レビュー／承認」欄は、レビューを最初を実施する役割、開発・運用から独立した立場で確認する役割、結果を承認する役割の順に示す。「同左」は、一次確認者がすでに開発・運用から独立しており、別途の独立レビューを要しないことを意味する。「関連要求事項（LR-xx）」欄は第2章の要求事項との対応であり、表9-3の必須項目に転記する。

表9-2 レビューカタログ

ID	対象ログ	関連要求事項 (LR-xx)	頻度	一次確認／独立レビュー／承認	確認観点	記録様式	記録の保存先
RV-01	L-01、L-05（特権操作・特権セッション）	LR-09、LR-02	月次	R-5／同左／R-2	特権利用が事前承認と対応しているか。共有 ID 使用時に実行者個人が特定できているか。承認外操作の有無	様式A（特権操作レビュー票）	ログ基盤から分離した文書管理領域
RV-02	L-04（認証・認可ログ）＋IAM 認証情報レポート・IAM Identity Center 割り当て情報（いずれもログではなく構成情報）	LR-09、LR-06	四半期	R-5／同左／R-2	IAM 認証情報レポートと IAM Identity Center の割り当ての棚卸。退職・異動者の権限が削除されているか。未使用のアクセスキー・パスワードの有無。MFA 設定状況。A-10・A-11 で検知されない IAM Identity Center 経由のサインインに係る設定状況	様式B（アクセス権棚卸表）	同上
RV-03	L-04、L-07（業務アプリケーションの権限）	LR-09、LR-06	四半期	R-5／同左／R-2（業務部門長の確認を含む）	承認権限・マスタ更新権限の付与が職務と一致しているか。職務分掌違反となる権限の組合せがないか	様式B	同上
RV-04	L-04、L-05（開発ベンダー・運用ベンダー要員のアカウント）	LR-09、LR-13	四半期（要員異動時は都度）	R-5／同左／R-2	契約上の要員名簿とアカウント一覧の一致。契約終了・要員離任後のアカウント無効化。接続元・時間帯の制限が有効か	様式B（ベンダー区分を明記）	同上
RV-05	L-03、L-10（構成変更・デプロイ）	LR-09	月次	R-5／同左／R-2	本番環境への反映と変更申請・承認記録の突合。申請のない変更の有無。緊急変更の事後承認の完了	様式C（変更突合表）	同上
RV-06	L-08、L-09（ジョブ・データ連携）	LR-09、LR-08	日次（結果の集計は月次）	R-4／R-5（月次に再確認）／R-2	予定どおり実行されたか。異常終了の対応が完了しているか。連携件数・金額の整合。再実行が承認されているか	様式D（実行結果一覧）	同上
RV-07	L-13（バックアップ・リストア）	LR-09、LR-11	週次（復旧テストは年次以上）	R-4／R-5（週次に確認）／R-2	計画どおり取得されたか。失敗ジョブの再取得完了。保持世代と保管先の妥当性。復旧テストの結果	様式D	同上
RV-08	L-12（セキュリティ検知）	LR-09、LR-08	週次	R-5／同左／R-2	検出結果の対応状況。未対応・保留の理由と期限。抑止（アーカイブ）した検出結果の妥当性	様式E（検知対応一覧）	同上

ID	対象ログ	関連要求事項 (LR-xx)	頻度	一次確認／独立レビュー／承認	確認観点	記録様式	記録の保存先
RV-09	L-01～L-14 全般（収集の網羅性）	LR-09、LR-11、LR-04、LR-01	月次	R-5／同左／R-2	対象期間のログが全期間について収集されているか。完全性検証（ダイジェスト検証）の結果。配信エラー・欠損期間の有無と原因。 収集されているかどうかを扱い、ログ基盤自身の設定変更の妥当性は RV-10 で扱う	様式F（ログ完全性・欠損検証記録）	同上
RV-10	L-14（ログ基盤自身の監査ログ＝ログ設定変更・削除試行）	LR-09、LR-12	月次	R-5／同左／R-2	ログ取得設定・保持設定・アクセス権の変更が承認済みか。ログ設計書（第11章）と実設定の一致。laC 外の手動変更の有無。 設定変更の承認と妥当性を扱い、収集の網羅性そのものは RV-09 で扱う	様式C	同上
RV-11	アラート通知・対応記録、通知経路の状態	LR-08、LR-09	月次	R-5／同左／R-2	各アラートの発報件数と対応完了状況。未対応の滞留。誤検知の傾向とチューニングの要否。通知先サブスクリプションが確認済みで有効か	様式G（アラート対応状況表）	同上

9.4.1 各レビューの内部統制上の根拠

レビュー項目は網羅性のためではなく、監査人が求める証拠に対応させるために設定している。開発ベンダーは手順書に各レビューの目的を記載すること（**必須**）。

- RV-01（特権操作）**：日本公認会計士協会の監査基準報告書315 実務ガイダンス第1号「ITの利用の理解並びにITの利用から生じるリスクの識別及び対応に関する監査人の手続に係るQ & A（実務ガイダンス）」は、特権IDを「全てのマスター情報、パラメータ設定値の変更や会計データの作成、変更、削除及びそれらの権限の設定等が可能な、操作に制限を受けない特別なID」と定義し、「特権IDが共有されており、誰が使用して会計データを修正したかを特定することが困難なリスク」を挙げ、対応として「会計システムのログの取得機能を活用し、事後的にモニタリングする等の発見的な内部統制を組み込む」ことを示している。同ガイダンスは財務諸表監査の基準であり、内部統制報告制度が直接に課す要求ではないが、特権IDに係る統制の考え方は内部統制報告制度における評価でも参照される。
- RV-02・RV-03（アクセス権棚卸）**：監査基準報告書315 付録6はIT全般統制の例としてプロビジョニング、デプロビジョニング、利用者アクセスレビュー、特権アクセス管理を挙げる。追補版は評価手続の例として「退職者のサンプルを抽出し、退職後、即座にアクセス権が削除されていることを確かめる」を示す。
- RV-04（ベンダー要員アカウント棚卸）**：実施基準は委託業務について「委託業務に関しては、委託者が責任を有しており、委託業務に係る内部統制についても評価の範囲に含まれる」と定め、2023年改訂で「情報システムの開発・運用・保守などITに関する業務を外部の専門会社に委託する場合」が委託業務の例に明示された（実施基準II.2(1)②イ）。ベンダー要員のアカウント管理は発注者の評価対象である。評価の手続には、委託業務結果の報告書と基礎資料との整合性の検証等（サンプリングによる検証）と、受託会社の内部統制の評価結果を記載した報告書等の利用があり、いずれによるかは発注者が判断する。金融庁「内部統制報告制度に関するQ & A」（問24）は、保証業務実務指針3402に基づく報告書が必ず必要になるわけではないとしている。開発ベンダーは、いずれの手続にも対応できるよう、要員名簿とアカウント一覧の提供手段および抽出手順を用意すること（**必須**）。

- **RV-05（変更レビュー）**：実施基準は、監査人がITに係る全般統制を検討する際の留意点として「新たなシステム、ソフトウェアの開発、調達又は変更について、その過程が適切に記録及び保存される」ことを挙げる（Ⅲ.4(2)②口a）。金融庁「内部統制報告制度に関するQ & A」問78は、システム変更の評価として「変更依頼又は変更されたプログラム等からサンプリング」し、どのような手続で依頼・承認されたものかを確認する方法を示す。
- **RV-06（ジョブ実行結果）**：監査基準報告書315 付録6はIT業務を管理するプロセスとして「ジョブの監視 財務報告のジョブ又はプログラムの実行の成否を監視する内部統制」を挙げる。
- **RV-07（バックアップ結果）**：実施基準は、監査人がITに係る全般統制を検討する際の留意点として「システムを構成する重要なデータやソフトウェアについて、障害や故障等によるデータ消失等に備え、その内容を保存し、迅速な復旧を図るための対策が取られていること」を挙げる（Ⅲ.4(2)②口b）。監査基準報告書315 付録6も「バックアップと復旧」を挙げる。
- **RV-08（セキュリティ検出結果）**：実施基準は、監査人がITに係る全般統制を検討する際の留意点として「システム、ソフトウェアに障害や故障等が発生した場合、障害や故障等の状況の把握、分析、解決等の対応が適切に行われていること」を挙げる（Ⅲ.4(2)②口b）。追補版はインシデントについて「ログを安全な環境（改ざん、滅失、意図しない暗号化などが行われない環境）に、あらかじめ定められた期間保存されるようにすること」を求める。
- **RV-09（ログ欠損・完全性）**：追補版のモニタリングに関する評価手続の例は「モニタリング対象として選んだログが、全ての期間で収集されていることを確かめる」「ログは、証拠として利用できるか確かめる」を挙げる。ログの欠損は運用状況評価の母集団の欠落に直結する。
- **RV-10（ログ設定変更）**：追補版はログの記録・保管に関する評価手続の例として「ログの記録や保管に際して、改ざんや削除ができないかについて確かめる」を挙げ、取得されたログは内容が改ざんされないように保管することが望ましいとしている。ログ取得設定そのものの変更管理は本書 LR-12 の要求であり、実設定の変更と承認記録との突合によって担保する。
- **RV-11（アラート対応状況）**：実施基準は整備状況評価の留意点として「内部統制によって発見された不正又は誤謬に適時に対処する手続が設定されているか」を挙げる（Ⅱ.3(3)③）。検知したのみで対処していない状態は統制として不十分である。

● 補足

本章が引用する基準等の正式名称と参照箇所は次のとおりであり、付録B 参考文献に対応付けている。「実施基準」＝「財務報告に係る内部統制の評価及び監査に関する実施基準」（2023年〈令和5年〉4月改訂）。本章で参照する主な箇所は、自動化された内部統制に関する留意点＝Ⅱ.3(3)⑤ニb および⑤ニc、全般統制と業務処理統制の関係＝Ⅱ.3(3)⑤イ、整備状況評価の留意点＝Ⅱ.3(3)③、運用状況の評価とサンプリング＝Ⅱ.3(3)④口・④ニa、期中評価後の追加手続＝Ⅱ.3(3)④ハ、委託業務の評価＝Ⅱ.2(1)②イ、不備の定義＝Ⅱ.1②イ、ITに係る全般統制の不備の取扱い＝Ⅱ.3(4)③、期末日後の是正措置＝Ⅱ.3(5)②、評価記録の保存＝Ⅱ.3(7)、監査人の手続におけるサンプル件数の例示＝Ⅲ.4(2)①口a、監査人によるITを利用した内部統制の評価の検討＝Ⅲ.4(2)②口。「追補版」＝経済産業省「システム管理基準 追補版（財務報告に係るIT統制ガイダンス）」。「監査基準報告書315」および「同 実務ガイダンス第1号」は日本公認会計士協会が公表する財務諸表監査の基準である。

● 注意

RV-05（変更レビュー）の突合相手である**変更申請と承認の記録は AWS 上には存在しない**。AWS Config と CloudTrail が示すのは「何がいつ変更されたか」であって「誰がそれを承認したか」ではない。承認記録は変更管理ツールまたはチケットシステム側に存在するため、両者を突合できるよう**変更 ID と AWS 側の変更履歴を対応付ける仕組み**（例: 変更 ID をリソースタグ、デプロイパイプラインの実行識別子、コミットメッセージに一貫して埋め込む）を設計すること（**必須**）。この対応付けがないと突合は人手による推測となり、監査上の証拠能力が著しく低下する。

9.4.2 サンプルングと全件確認

レビューを全件確認とするかサンプルングとするかは、母集団の件数と対象の重要性に応じて決定すること（**必須**）。実施基準は監査人の手続の例示として「日常反復継続する取引について、統計上の二項分布を前提とすると、90%の信頼度を得るには、評価対象となる統制上の要点ごとに少なくとも 25 件のサンプルが必要になる」と述べており（III.4(2)①ロa）、追補版の付録も頻度別のサンプル件数の例（日次25件、週次5件、月次2件、四半期次2件、年次1件。いずれも許容逸脱件数0件を前提とする例であり、追補版は1日につき多数および日次の場合以外は統計的方法によるものではないと注記している）を示している。ただし**これらはいずれも例示であって法令上の要件ではない**。

本章のレビューは発注者（経営者）自身の評価に用いるものであるから、**採用するサンプル件数と抽出方法は発注者が決定する事項であり**、必要に応じて監査人と協議して確定される。実施基準は経営者の評価について、運用状況の評価の実施に際しては原則としてサンプルングにより十分かつ適切な証拠を入手するとし（II.3(3)④ロ）、サンプル件数・サンプルの対象期間等は内部統制の重要性、複雑さ、担当者が行う判断の性質、内部統制の実施者の能力、前年度の評価結果やその後の変更の状況等を考慮して決定するとしている（同④ニa）。上記の25件はあくまで監査人側の手続の例示であり、発注者側レビューの件数を直接に定めるものではない。

開発ベンダーは、サンプルングと全件確認のいずれにも対応できるよう、**母集団の総件数を機械的に算出できる抽出クエリを用意すること**（**必須**）。母集団の件数を示せないサンプルングは、抽出の妥当性を説明できない。抽出条件と件数の記録方法は9.5に従う。

9.5 レビュー記録の必須項目

レビュー記録は、実施したという事実だけでなく、**後から第三者が同じ条件で再現できることを要件とする**。実施基準は評価記録について「後日、第三者による検証が可能となるよう、関連する証拠書類を適切に保存する必要がある」と述べる（II.3(7)）。表9-3の項目を様式に含めること（**必須**）。

表9-3 レビュー記録の必須項目

項目	記載内容
レビュー ID・名称	表9-2のIDと名称。対象のLR-xx/L-xxを併記する（表9-2の「関連要求事項（LR-xx）」欄および「対象ログ」欄から転記する）
レビュー実施日時	実施した日時。タイムゾーンを明記する（AWSのログは協定世界時で記録されるため、記録側の表記規約を第4章の規定に合わせる）
対象期間	レビュー対象としたログの期間。開始と終了をタイムゾーン付きで記載する。前回レビューの対象期間と連続しており、空白がないこと
実施者	氏名または職務上の識別子と役割（R-x）。一次確認を運用担当（R-4）が行う場合（RV-06およびRV-07）は、その旨を明記したうえで、開発・運用から独立した独立レビュー実施者（R-5）の氏名または識別子、確認日時、確認範囲を併記すること。承認前の独立レビュー実施者は、対象システムの開発・運用担当を兼務していないこと
承認者	氏名または識別子、役割、承認日時。実施者および独立レビュー実施者と同一人物にしないこと
抽出条件	実行したクエリ本文またはクエリ識別子、対象ロググループ・バケット・テーブル、フィルタ条件。再実行して同じ結果が得られる粒度で記載する
母集団件数	抽出条件に合致した総件数
確認件数・抽出方法	全件確認かサンプリングかの別。サンプリングの場合は件数と抽出方法（無作為抽出、条件抽出等）
確認結果	確認観点ごとの判定（問題なし／例外あり）。「問題なし」のみの記載は認めない。何と何を照合した結果かを記載する
例外事項	発見した例外の内容、対象（アカウント、リソース、時刻）、件数、暫定的な影響評価
対応内容	例外に対して実施した対応、または対応予定。対応済みの場合は実施日時と実施者
是正期限	未完了の対応について、責任者と完了予定日。9.6.2の基準に従って設定する
証拠の所在	クエリ結果ファイル、画面出力、エクスポートデータの保存先パスとファイル識別子。同一性を確認できる手段（ハッシュ値等）を併記すること（推奨）
特記事項	ツールの制約、対象外とした範囲とその理由、前回からの変更点

● 補足

レビュー記録の保存先は、レビュー対象であるログ基盤とは分離すること（必須）。同一の権限でレビュー対象ログとレビュー記録の双方を改変できる構成は、記録の証拠能力を損なう。保存先の基盤と保存期間は発注者が決定する事項であり、第7章の保存期間の考え方と整合させること（必須）。様式そのものは付録Dに示す。

9.5.1 記録例（RV-01 特権操作レビュー）

抽出条件欄には、次のようにクエリ本文をそのまま記載すること（必須）。Amazon Athena（Amazon S3上のCloudTrailログ）での抽出例を示す。テーブル定義と分析基盤の構成は第5章および第12章に従う。


```
-- RV-01 対象期間の特権操作の抽出（例）
SELECT eventtime,
       useridentity.arn,
       useridentity.sessioncontext.sessionissuer.arn AS role_arn,
       eventsource, eventname, sourceipaddress, errorcode
FROM cloudtrail_logs_pp
WHERE "timestamp" BETWEEN '2026/07/01' AND '2026/07/31'
      AND (readonly = 'false' OR readonly IS NULL)
      AND (useridentity.type = 'Root'
           OR useridentity.sessioncontext.sessionissuer.arn LIKE ':%:role/<特権ロール名>')
ORDER BY eventtime;
```

CloudTrail の `readonly` は省略可能な項目であり、サービス・API・イベント種別によっては記録されない。`readonly = 'false'` の等値比較だけでは値のない行が母集団から静かに脱落するため、上記のように `readonly IS NULL` を含めて抽出すること（**必須**）。母集団の欠落は 9.4.2 で求める抽出の妥当性の説明を損なう。

確認結果欄には「母集団 47 件、うち事前承認記録と一致 45 件、承認記録のない操作 2 件（例外 EX-2026-07-003 として起票）」のように、件数と照合結果を記載すること（**必須**）。件数を伴わない記述は認めない。

9.6 例外・逸脱の取り扱い

アラートまたはレビューで発見した例外は、発見した事実の記録で終わらせず、原因分析・是正・報告・再発防止まで一連の手続として管理すること（**必須**）。以下 9.6.1 の各手続はこの必須要求に含まれる。

9.6.1 手続

- 起票:** 例外を一意の識別子で起票し、発見日時、発見手段（アラートID またはレビューID）、対象、事象の内容、暫定的な影響範囲を記録すること。財務報告に関連するデータへの影響の有無を必ず判定欄に含めること。
- 暫定対応:** 被害の拡大防止と証拠の保全を行うこと。ログの欠損・改ざんの疑いがある場合は、当該期間のログを別領域に保全してから復旧作業を行うこと。
- 原因分析:** 直接原因（何が起きたか）と根本原因（なぜ防げなかったか）を分けて記録すること。根本原因は「設計の欠落」「設定誤り」「手順の不備」「権限の過剰付与」「教育不足」等に分類し、分類ごとに再発防止策を対応付けること。
- 統制上の評価:** 発生した事象が内部統制の不備に該当するかを R-1 内部統制担当が判定する。実施基準は不備を「内部統制が存在しない、又は規定されている内部統制では内部統制の目的を十分に果たすことができない等の整備上の不備」と「整備段階で意図したように内部統制が運用されていない、又は運用上の誤りが多い、あるいは内部統制を実施する者が統制内容や目的を正しく理解していない等の運用の不備」に区分している（II.1②イ）。開発ベンダーは、判定に必要な事実（対象範囲、期間、件数、影響の有無）を提供すること。
- 是正:** 恒久対策を実施し、実施日時と実施者を記録すること。設定変更を伴う場合は変更管理手続（RV-05 の対象）に載せること。
- 報告:** R-2 システム所管を経由して R-1 内部統制担当へ報告すること。重要度 P1 のアラートに起因する例外、およびログの欠損・改ざんに関する例外は、暫定対応の完了を待たずに速報すること。
- 再発防止の検証:** 是正後、同種の事象が再発していないことを次回以降のレビューで確認し、確認結果を記録すること。例外のクローズはこの確認をもって行うこと。

9.6.2 是正期限の設定

是正期限は、事象の重要度と**発注者の決算日**を基準に設定すること（**必須**）。実施基準は「内部統制の評価時点は期末日であり、期末日後に実施した是正措置は、期末日における財務報告に係る内部統制の評価には影響しない。ただし、経営者は、内部統制報告書の提出日までに実施した是正措置がある場合は、その内容を内部統制報告書に付記事項として記載できる」と定めている（II.3(5)②）。したがって、期末日を越えた是正は当期の評価結果を改善しない。

開発ベンダーは、例外を検出した時点で**期末日までの残余日数を考慮した是正計画を提示すること**（**必須**）。是正計画には、是正の完了日だけでなく、**是正後の統制が有効に運用されたことを示す証拠（発報記録、レビュー記録、確認件数）を期末日までに積み上げられる期間**を織り込むこと（**必須**）。実施基準は、運用状況の評価を期中に実施した場合に期末日までに内部統制に関する重要な変更があったときは、重要な変更の内容の把握・整理、変更後の内部統制の整備状況の有効性の評価、変更後の内部統制の運用状況の有効性の評価という追加手続の実施を検討するとしており（II.3(3)④ハ）、統制の是正は評価のやり直しを伴う。期末日の直前に是正しても運用の証拠が積み上がり、期末日時点で有効と評価できない事態が生じ得る。期末日までに是正が完了しない見込みとなった時点で、その旨を R-1 内部統制担当へ報告すること（**必須**）。報告の遅延は、代替手続を検討する機会そのものを失わせる。

● 監査の視点

実施基準は「ITに係る全般統制に不備がある場合には、代替的又は補完的な他の内部統制により、財務報告の信頼性という目的が達成されているかを検討する。ITに係る全般統制の不備は、財務報告の重要な事項に虚偽記載が発生するリスクに直接に繋がるものではないため、直ちに開示すべき重要な不備と評価されるものではない」と述べている（II.3(4)③）。すなわち、アラート未設定やレビュー未実施が判明しても、代替手続によって目的が達成されていれば直ちに重大な結論には至らない。**ただしこの取り扱いがIT全般統制の不備についてのものであり、IT業務処理統制の不備や、これに依拠する業務プロセスに係る内部統制の不備には当てはまらない。**本章のアラート・レビューには、L-07（承認操作の記録）や L-06（データ修正の記録）のように業務処理統制およびその前提となる証拠に関わるものが含まれており、それらの不備はこの取り扱の対象外である。金融庁「内部統制報告制度に関するQ & A」（問14）も、ITに係る全般統制の不備は直ちに開示すべき重要な不備と評価されるものではないとする一方、代替的・補完的な統制の検討を前提としている。また実施基準II.3(4)③は続けて「その有効な運用を継続的に維持することができない可能性があり、虚偽記載が発生するリスクが高まることとなる」とも述べる。実務上重要なのは、**例外を隠さず記録し、代替手続を提示できる状態にしておくこと**である。記録のない例外は、代替手続の検討すらできない。

9.6.3 影響がないと判断した場合でも起票する事象

次の事象は、影響がないと判断した場合でも必ず例外として起票し、判断の理由を記録すること（**必須**）。

- ログの記録停止・記録範囲の縮小（A-04～A-07）。停止・縮小期間の記録は事後に回復できない。
- ログの配信失敗・欠損（A-23、RV-09）。期間と件数を特定し、代替となる記録の有無を記載すること。
- ルートユーザーの使用（A-01、A-02）。承認済みの計画作業であっても、実施内容と承認記録を対応付けて記録すること。
- 完全性検証の失敗（第8章の検証手続）。検証結果がハッシュ不一致・未検出・移動済みのいずれであるかを記録すること。
- 承認記録と突合できない本番環境の変更（RV-05）。

9.7 運用引継ぎ時に開発ベンダーが提供するもの

開発ベンダーは、本章で定めた仕組みを運用主体（R-4 運用者、R-5 ログ管理者）が実施できる状態にして引き渡すこと（**必須**）。引継ぎ物は表9-4のとおりとする。個々の成果物の記載事項は第11章の規定に従う。

表9-4 監視・レビューに関する引継ぎ成果物

成果物	内容	レベル
アラート定義の IaC	表9-1 のアラートに対応するメトリクスフィルター、CloudWatch アラーム、EventBridge ルール、Amazon SNS トピックおよびサブスクリプションの定義一式。手動作成した設定を残さないこと。定義とアラートID の対応表を含めること。EventBridge ルールについては作成対象リージョンを定義上で明示すること	必須
アラート一覧表	アラートID、検知事象、発生源、パターン本文、重要度、通知先、初動対応、対応時限、採用した実装経路（9.3 の経路1～4）、EventBridge ルールの作成対象リージョン、実装しない旨を発注者と合意した推奨項目とその理由。表9-1 に発注者環境固有の値を追記したもの	必須
アラート実装テスト結果	各アラートについて、実際に対象事象を発生させて通知が届くことを確認した記録（実施日時、実施者、実施手順、通知受信時刻）。CIS v1.4.0 を採用する場合は A-11 および A-12 について、v3.0.0 または v5.0.0 を採用する場合は CloudWatch.1～14 に対応するすべてのアラートについて、これが実装の証拠の主体となる（9.1.3）。組織証跡を使用する場合は、メンバーアカウント側の代替証跡としても用いる	必須
レビュー手順書	表9-2 の各レビューについて、目的、対象、頻度、実施手順、判定基準、例外時のエスカレーション先、所要時間の目安。一次確認と独立レビューを分ける場合は、それぞれの実施範囲と記録欄を明示すること。運用ベンダー要員が単独で実施できる粒度で記述すること	必須
抽出クエリ集	各レビューおよびアラートの事後調査に対応する Amazon Athena／CloudWatch Logs Insights／AWS Config 高度なクエリ／CLI コマンド。母集団件数を算出するクエリを含めること。パラメータ（対象期間、対象アカウント）を明示し、実行結果例を添付すること	必須
レビュー様式	表9-3 の必須項目を満たす様式A～G。記入例を1件ずつ添付すること	必須
監視・レビューの権限設計書	レビュー実施に必要な読み取り権限、通知設定の変更権限、様式の保存先への書き込み権限の一覧。職務分掌の観点（第10章）との対応を明記すること	必須
年間レビュー計画表	各レビューの実施予定を暦上に展開したもの。発注者の決算スケジュールおよび監査人の往査時期との整合を確認できる形式とすること	推奨
誤検知・チューニング記録の様式	アラートのしきい値・除外条件を変更する際の申請様式。変更は RV-10 の対象であり、記録のない変更を認めないこと	推奨
監視ダッシュボード	アラート発報状況、ログ取り込み量、レビュー実施状況を一覧できるダッシュボードの定義。IaC で管理すること	任意

● 補足

引継ぎの完了条件は「成果物を提出したこと」ではなく、**運用主体が成果物のみを用いてレビューを1回完遂できたこと**とする。引継ぎ期間中に、運用主体が実施し開発ベンダーが立ち会う形で各レビューを少なくとも1回試行し、手順書の不足箇所を反映してから引き渡すこと（**必須**）。この試行結果は第11章の受入チェックリストの確認項目に含める。

10

職務分掌とログへのアクセス制御

本章は、LR-06（ログへのアクセス制御と職務分掌）を AWS 上でどのように実装し、どのような証跡を残すかを定める。第8章がログを「消させない」ための技術的な保全を扱ったのに対し、本章は「誰にその操作をさせるか」という権限設計を扱う。ログを守る統制は、最終的には権限を持つ人の集合をどこまで絞れるかで決まる。設定がどれほど厳格でも、それを解除できる権限が広く配られていれば統制は成立しない。

本章は IT 全般統制の領域のうち ITGC-C（内外からのアクセス管理などシステムの安全性の確保）を中心に、ベンダー要員のアクセス管理の面で ITGC-D（外部委託に関する契約の管理）に関係する。実施基準はIT全般統制の具体例として「内外からのアクセス管理などシステムの安全性の確保」を挙げ、監査人側の検討項目として「データ、システム、ソフトウェア等の不正使用、改竄、破壊等を防止するために…適切なアクセス管理等の方針を定めているか確認する」としている。本章の要求事項はこの求めに対応する。

● 監査の視点

経済産業省「システム管理基準 追補版（財務報告に係るIT統制ガイダンス）」は、アクセス権の申請と承認について「同一人物が両方の行為を実施していないことを確かめる」、特権IDについて「特権IDが、全ての機能を利用できる場合には、スプリットパスワードや相互監視等（デュアルコントロールとも呼ばれる）の別の統制が併用されていることを確かめる」としている。また ID 管理の評価手続として「新規の登録のサンプルを抽出し、責任者がアクセス権を承認したか」「退職者のサンプルを抽出し、退職後、即座にアクセス権が削除されていることを確かめる」を挙げる。本章の 10.4.3・10.5・10.6 は、これらの評価手続にそのまま提示できる形の証跡を残すことを目的としている。このうち、操作範囲を技術的に制限できない特権ID（すべての機能を利用できるID）を用いる場合は、相互監視（デュアルコントロール）等の別の統制を併用し、その実施記録を残すこと（**必須**。10.5）。

10.1 職務分掌の原則

職務分掌は「役職を分ける」ことではなく、**単独の主体が不正または誤謬を発生させ、かつそれを隠蔽できる状態を作らない**ことである。ログ管理においては、記録の対象となる行為と、記録そのものを操作する行為とを、同一人物が併せ持たないことが要件となる。以下の4原則を設計の前提とすること。

10.1.1 開発と運用の分離

必須 開発ベンダーの開発者（R-3）が本番環境へ恒常的な変更権限を持たないこと。プログラム変更を行う主体と、それを本番環境へ反映する主体を分離すること。日本公認会計士協会 監査基準報告書315 の付録6はIT全般統制の例として「本番環境への移行に関する職務の分離 プログラムの変更と本番環境への移行に対するアクセス権の分離の内部統制」を挙げている。

本番反映の権限は、人ではなく CI/CD パイプラインの実行ロールに集約し、そのロールを引き受けられる主体を限定することで実現すること。人が本番環境で直接操作する必要がある場合は 10.4.4 のブレイクグラス手順による。開発ベンダー要員が本番環境の権限を恒常的に保有していた結果、テスト目的の変更が本番環境に適用され

た事例は、日本公認会計士協会 IT委員会研究報告第46号「重要な虚偽表示リスクとIT全般統制の評価」（2014年9月30日公表。2022年10月13日廃止。現行の枠組みは監査基準報告書315 および同実務ガイダンス第1号）でも、外部委託における典型的な不備として示されている。

10.1.2 ログ管理者の独立

必須 ログ管理者（R-5）を、開発（R-3）および運用（R-4）から独立した役割として設置すること。同一の個人が R-4 と R-5 を兼務しないこと。R-5 を発注者側に置くか委託先に置くかを発注者と合意し、委託先に置く場合は、R-4 と異なる指揮命令系統であること、および R-5 の操作を発注者（R-1／R-2）がレビューする統制を併せて定めること。合意結果を 10.7 の特権ID管理手順書に記載すること。運用者が自らの操作記録の設定・保持期間・アラート条件を変更できる状態は、記録が自身に不利に働く場面で無効化され得るため、統制として成立しない。

推奨 ログ基盤の実体を、業務システムとは別の AWS アカウント（ログアーカイブアカウント）に分離すること。AWS Security Reference Architecture はログアーカイブアカウントについて「セキュリティ関連のログとバックアップの取り込み・保管専用」であり「不変ストレージであり、制御・自動化・監視された仕組みからのみアクセスされるべき」としている。アカウント分離により、業務システム側の権限がどれほど広くてもログ本体には到達できないという構造が作れる。詳細は第6章による。

10.1.3 承認者と実施者の分離

必須 アクセス権の付与・変更・削除、および特権IDの利用について、申請者・承認者・実施者を別の個人とすること。承認者は申請者の上位者または権限を所管する役割（原則として R-2 発注者 システム所管）とし、実施者はその承認記録を根拠に操作すること。

必須 承認の記録は、AWS の操作記録とは別に、日時・申請内容・承認者・承認日時・有効期限が追跡できる形で保存すること。AWS 上のログ（L-01 クラウド基盤API操作ログ、L-04 認証・認可ログ）は「誰が何をしたか」を記録するが、「それが承認されたものか」は記録しない。この対応付けは申請・承認記録側で担保する必要がある。

10.1.4 ログを削除できる者を作らない

必須 保存期間内のログについて、削除を実行できる権限を保有する役割を設けないこと。これは「削除権限を限られた者だけに与える」ではなく「与えない」という要求である。表10-1 の「ログ削除」列に○を付ける役割は存在しない。

技術的には、S3 Object Lock（コンプライアンスモード）により保持期限内のオブジェクトはルートユーザーを含むいかなるユーザーも上書き・削除できない状態とし、加えて SCP により削除系 API を拒否することで実装する（第8章）。保持期限到来後の廃棄は、個別の削除操作ではなくライフサイクル設定による自動失効として設計し、その手続は第7章による。ただし、業種編で起算点が事象による区分 (3) のログは、この例外とし、7.3 と 7.5 の手続により削除する。

● 注意

「削除できない」を実現するうえで見落とされやすいのが暗号鍵である。AWS KMS のキーを削除すると、そのキーで暗号化されたデータは復号できず回復不能となる。削除の待機期間は 7～30 日（既定 30 日）で、待機中はキーが `Pending deletion` 状態となり暗号操作ができなくなる。すなわち**キー管理権限は実質的にログの消去能力である**。KMS キー管理権限を単独の個人に与えないこと（10.2、10.3.6）。

10.2 役割と権限マトリクス

必須 ログ基盤（ログの保存先、ログ設定、暗号鍵、アラート設定を含む）に対する権限を、役割ごとに以下のとおり設計すること。開発ベンダーは、本マトリクスを実際のアカウント構成・許可セット名・IAM ロール名に展開した実体版を成果物として提出すること（10.7）。

本マトリクスは本番稼働後の常時付与される権限を定めたものである。構築フェーズにおいて開発ベンダーが一時的に必要な権限は、対象・期間・承認者・操作記録を定めた上で期限付きで付与し、受入前に解除して解除の記録を提出すること（移行時の扱いは第13章による）。

表10-1 ログ基盤に対する役割別権限マトリクス

役割	ログ閲覧	検索・抽出	アラート設定変更	ログ設定変更	ログ削除	KMS キー管理	アクセス権付与
R-1 発注者 内部統制担当	○	○	×	×	×	×	×
R-2 発注者 システム所管	○	○	×	×	×	×	×
R-3 開発ベンダー 開発者	△	△	×	×	×	×	×
R-4 運用者（運用ベンダー含む）	○	○	△	×	×	×	×
R-5 ログ管理者（開発・運用から独立）	○	○	○	△	×	△	△
R-6 監査人（読み取り専用）	○	○	×	×	×	×	×
CI/CD パイプライン実行ロール（人が直接引き受けない）	×	×	△	△	×	×	×

凡例 — ○: 恒常的に許可する。△: 人が担う役割については、申請・承認・期間限定・操作記録の4条件をすべて満たすことを最低条件とし、これに加えて各列に示す追加条件を満たす場合に限り許可する。CI/CD パイプライン実行ロールの△は、承認済みのコードとして定義された変更のみを適用すること、および当該操作が記録されることを条件とする。×: 技術的に成立させない（IAM ポリシーまたは SCP・リソースベースポリシーで明示的に拒否するか、アクセス許可の境界により当該操作を最大権限の外に置き、権限が付与されていないだけの状態にしない）。本表は**操作を実行する権限**のみを示すものであり、承認者としての関与は含まない。R-2（発注者 システム所管）が承認者として果たす役割は表10-2 に示す。>>> @@ L05 <<<（テスト項目は第8章） ===（改ざん防止の確認方法は第8章、テスト観点の整理は第11章による）

CI/CD パイプライン実行ロールは人が直接引き受けられないものとし、パイプライン定義の変更は R-2 の承認を経たコードレビューによること。SCP の除外条件に用いるロール ARN は 10.7 の成果物に明記すること。

各列の△に課す追加条件は以下のとおり。

- ログ閲覧・検索/抽出** — R-3 の△は、担当システムのアプリケーション業務ログ（L-07）およびジョブ・バッチ実行ログ（L-08）に限り、障害調査等の目的で期間を限って許可する意である。認証・認可ログ（L-04）、サーバ操作ログ（L-05）、データベース監査ログ（L-06）、ログ基盤自身の監査ログ（L-14）への開発者アクセスは原則として認めないこと。閲覧範囲の限定は、ロググループ単位・S3 プレフィックス単位のリソース指定で実装すること。
- アラート設定変更** — R-4 の△は、監視の実運用上必要となるしきい値・通知先の調整を、承認と記録を条件に認める意である。検知条件そのものの削除・無効化は R-4 に認めないこと。CI/CD パイプライン実行ロールの△は、承認済みのコードとして定義されたアラート設定を適用する範囲に限る。アラートの設計は第9章による。

- **ログ設定変更** — 記録対象の範囲（イベントセクタ等）、保持期間、ライフサイクル、証跡の稼働状態を指す。R-5 の△は、変更を IaC（コードとしてのインフラ）経由に限定し、コードレビューとパイプライン承認を経たもののみ適用する運用を前提とする。コンソール・CLI からの直接変更は認めないこと。実際に変更 API を実行する主体は CI/CD パイプライン実行ロールであり、同ロールの△は、承認済みのコードとして定義された変更のみを適用する範囲に限る。
- **ログ削除** — 全役割が×である。保持期限到来後の廃棄手続については第7章を参照すること。
- **KMS キー管理** — キーポリシーの変更、キーの無効化、削除予約を指す。R-5 の△は、単独では実行できないこと（デュアルコントロール）を条件とする（10.3.6）。
- **アクセス権付与** — ログ基盤に対する許可セット・ロールの割り当てを指す。R-5 の△は、R-2 の承認を前提とし、付与操作そのものが記録されることを条件とする。**R-5 自身に対する割り当ての変更は、R-2 の承認を得たうえで R-2 が指名する R-5 以外の要員が実施するものとし、R-5 が自ら実施しないこと。当該付与イベントは監視対象とすること**（自己付与により 10.1.3 の分離が無効化されることを防ぐ）。

● 補足

本マトリクスは、人が担う役割と、人に代わって設定変更を適用する CI/CD パイプライン実行ロールを対象とする。一方、ログの書き込みは人ではなく AWS サービスのサービスプリンシパル（AWS CloudTrail、AWS Config、Amazon Data Firehose 等）が行う。書き込み権限はこれらのサービスプリンシパルに限定し、人が担う役割にもパイプライン実行ロールにも一切与えないこと。書き込み権限を持つ主体が読み取り・削除もできる構成は避けること。

10.3 AWS での実装

10.3.1 IAM Identity Center の許可セット設計

必須 人によるアクセスは AWS IAM Identity Center を経由させ、アカウント個別の IAM ユーザーを人に対して作成しないこと。表10-1 の各行を許可セットとして定義し、対象アカウントへの割り当てで権限を制御すること。

必須 許可セットのセッション期間は、業務に必要な最小限に設定すること。セッション期間は既定で1時間であり、1時間から12時間の範囲で設定できる。長時間のセッションは、権限剥奪後も一定時間アクセスが継続し得るため、退任時の即時削除（10.4.3）の実効性を損なう。

必須 許可セットの作成・変更・割り当て・解除を CloudTrail で記録し、レビュー対象に含めること。IAM Identity Center の操作は `sso.amazonaws.com`、ID ストアの操作は `identitystore.amazonaws.com` および `sso-directory.amazonaws.com`、SCIM プロビジョニングは `identitystore-scim.amazonaws.com`、OIDC は `sso-oauth.amazonaws.com`、サインインは `signin.amazonaws.com` をイベントソースとして記録される。監視対象とすべき代表的なイベント名は `CreatePermissionSet`、`CreateAccountAssignment`、`DeleteAccountAssignment`、`ProvisionPermissionSet`、`AttachManagedPolicyToPermissionSet`、`PutInlinePolicyToPermissionSet` である。

推奨 許可セットの定義を IaC で管理し、変更をコードレビューとパイプライン承認を経て適用すること。これにより、10.1.3 の承認者と実施者の分離を、AWS の外側の申請書ではなくバージョン管理されたコードの承認履歴で証明できる。

● 注意

IAM Identity Center のサインインイベントは `CredentialChallenge`、`CredentialVerification`、`UserAuthentication` の3種で記録され、`UserAuthentication` は全チャレンジ完了時のみ出力される。一連の認証は `AuthWorkflowID` で関連付けること。`CredentialType` には `PASSWORD`、`TOTP`、`WEBAUTHN`、`EXTERNAL_IDP`、`RESYNC_TOTP`、`EMAIL_OTP` が記録される。なお、IAM Identity Center の CloudTrail イベントがどのリージョンに記録されるかは、実際の環境で確認したうえでログ設計書に記載すること。

10.3.2 アクセス許可の境界

必須 開発ベンダー要員および運用ベンダー要員が引き受けるロール・許可セットに対し、アクセス許可の境界（permissions boundary）を設定し、ログ基盤に対する設定変更・削除・鍵操作を境界の外側に置くこと。アクセス許可の境界は最大権限を定義する管理ポリシーであり、それ自体は権限を付与しない。有効な権限はアイデンティティベースポリシーとの積集合となる。したがって、アイデンティティベースポリシーが誤って広く付与されても、境界を超える操作は成立しない。

● 補足

アクセス許可の境界には既知の挙動差がある。同一アカウント内で IAM ユーザーの ARN に許可を与えるリソースベースポリシーは、境界による暗黙の拒否に制限されないが、ロールの ARN 宛の場合は制限される。ログ保存先バケットのバケットポリシーで主体を指定する際は、ロール ARN を用いること。境界のみに依存せず、SCP による組織レベルの拒否と併用すること（10.3.7）。

10.3.3 読み取り専用の監査ロール

必須 監査人（R-6）向けに、読み取り専用のクロスアカウントロールを定義すること。監査人が業務システムアカウントを経由せずログを参照できる経路を用意し、参照のたびに運用者へ依頼する構成にしないこと。

必須 監査ロールに `AWSCloudTrail_FullAccess` を付与しないこと。AWS はこのポリシーについて「監査機能が無効化・再設定できるため付与を最小限にする」としており、AWS Security Reference Architecture も同ポリシーの付与を可能な限り少人数に限定するよう求めている。

● 注意

読み取り専用のマネージドポリシー（`SecurityAudit`、`ReadOnlyAccess` 等）を監査ロールに用いる場合、両者の許可範囲は同一ではない。`SecurityAudit` は AWS 公式に「セキュリティ設定のメタデータを読み取るためのアクセスを付与する」ポリシーと位置づけられ、構成情報・メタデータの参照に範囲が絞られている。一方 `ReadOnlyAccess` は設定情報の参照にとどまらずデータ本体の読み取りを含み得るため、ログ本文や業務データへの意図しない到達が生じる可能性がある。監査ロールには原則として `SecurityAudit` を起点とし、ログ本文の参照が必要な範囲のみを顧客管理ポリシーで追加すること。Athena による抽出には `athena:StartQueryExecution` / `athena:GetQueryResults`、AWS Glue データカタログの読み取り、ログ保存先への `s3:GetObject` が、CloudWatch Logs Insights による抽出には `logs:StartQuery` / `logs:GetQueryResults` が必要であり、いずれも `SecurityAudit` には含まれない。`ReadOnlyAccess` は業務データへの到達範囲が広いため、監査ロールの既定としないこと。**付与前に各マネージドポリシーの許可範囲を公式ドキュメントで確認し、必要な権限のみを含む顧客管理ポリシーの採用を検討すること。**採用したポリシーとその選定理由をログ設計書に記載すること。

必須 ログ保存先が SSE-KMS で暗号化されている場合、監査ロールには S3 の読み取り権限に加えて KMS キーポリシーによる復号権限（`kms:Decrypt`）が必要である。CloudTrail のログを読む場合、キーポリシーの復号許可には条件 `Null: kms:EncryptionContext:aws:cloudtrail:arn = false` を伴う形が示されている。復号権限の付与はキーポリシー側で行い、鍵の管理権限（`kms:PutKeyPolicy`、`kms:ScheduleKeyDeletion`、`kms:DisableKey`）とは明確に分けること。

必須 監査ロールを外部から無条件に引き受けられない構成とすること。IAM Identity Center 経由の許可セットを用いる場合、MFA の強制は Identity Center および ID プロバイダー側の認証設定で行い、`aws:MultiFactorAuthPresent` / `aws:MultiFactorAuthAge` はフェデレーションされた ID の要求コンテキストに含まれないことに留意すること。以下の信頼ポリシー例は、IAM ユーザー起点のクロスアカウント経路を意図的に残す場合にのみ適用される。条件キーの正確な指定方法は公式ドキュメントで確認すること。

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowAuditorAssumeRoleWithMFA",
      "Effect": "Allow",
      "Principal": { "AWS": "arn:aws:iam::<監査人が利用するアカウントID>:root" },
      "Action": "sts:AssumeRole",
      "Condition": {
        "Null": { "aws:MultiFactorAuthAge": "false" },
        "NumericLessThan": { "aws:MultiFactorAuthAge": "3600" },
        "StringEquals": { "sts:ExternalId": "<発注者が発行する外部ID>" }
      }
    }
  ]
}
```

必須 第三者である監査人にロールの引き受けを許す場合は、外部ID（`sts:ExternalId`）の条件を付けること。外部IDは発注者が発行して監査人以外に共有せず、発行・管理・失効の手順を 10.7 の設計書に定義すること。

● 注意

`aws:MultiFactorAuthAge` および `aws:MultiFactorAuthPresent` は、フェデレーティッドアイデンティティ（SAML、ウェブID、IAM Identity Center のアイデンティティを含む）のリクエストには存在しない。上記の例は、監査人が自らのアカウントの IAM ユーザーで MFA 認証したうえでクロスアカウントに引き受ける場合を想定したものである。監査人が IdP / IAM Identity Center 経由で到達する構成では、IdP の認証方式をセッションタグとして渡し `aws:PrincipalTag` で判定する方法、または IAM Identity Center のアクセスコントロール属性を用いる方法を採用すること。いずれの方式を採用したかをログ設計書に記載すること。

上記の `Principal` にある `:root` は、当該 AWS アカウント全体を主体として指す ARN の記法であり、ルートユーザーによる引き受けを許可する意味ではない（10.3.8 のルートユーザー封印と矛盾しない）。実際に引き受けられるのは、当該アカウント側で `sts:AssumeRole` を明示的に許可された主体に限られる。

10.3.4 MFA の必須化と長期アクセスキーの禁止

必須 すべての人による AWS へのサインインに MFA を必須とすること。MFA の使用有無は CloudTrail に記録される。コンソールサインインでは `additionalEventData.MFAUsed`、MFA サインイン後のロール利用では `sessionContext.attributes.mfaAuthenticated` が `true` となる。IAM ユーザー起点の経路ではこの2項目を、IAM Identity Center 経由の経路では 10.3.1 に示したサインインイベント（`UserAuthentication` と

`CredentialType`）を、それぞれ 10.6 のレビューで確認対象とすること。Identity Center 経由の一連の認証は `AuthWorkflowID` で関連付けること。

必須 人に対して長期のアクセスキー（IAM ユーザーのアクセスキー）を発行しないこと。人によるアクセスは IAM Identity Center 経由の一時認証情報に統一し、自動処理は IAM ロールに割り当てること。やむを得ず長期キーを用いる場合は、対象・理由・所有者・ローテーション周期を記録し、発注者の承認を得ること。

必須 以下の AWS Config マネジドルールを有効化し、逸脱を検知すること。`iam-root-access-key-check`（ルートのアクセスキー不存在）、`access-keys-rotated`（アクセスキーのローテーション）、`iam-user-mfa-enabled`、`mfa-enabled-for-iam-console-access`、`root-account-mfa-enabled`、`iam-user-unused-credentials-check`、`iam-password-policy`。

10.3.5 セッションの識別（セッションタグ・`sourceIdentity`）

必須 ロールを引き受けた後の操作から、実際の操作者を特定できる構成とすること。ロールを引き受けた後の操作は、ロールセッション名を含む形で記録される（`userIdentity` の ARN および `principalId`）。ただしロールセッション名は引き受ける側が任意に指定できるため、命名規約とその強制がなければ個人を特定できない。識別に利用できるのは `sts:SourceIdentity`、`sts:RoleSessionName`（規約と強制条件を伴うもの）、および IAM Identity Center 経由の場合の `onBehalfOf.userId` / `identityStoreArn` である。

推奨 委託先区分・申請番号等をセッションタグとして付与し、抽出時の絞り込みに用いること。セッションタグは `AssumeRole`、`SAML`、`OIDC`、`GetFederationToken` で渡すことができ、信頼ポリシーに `sts:TagSession` の許可が必要である。最大 50 タグ、キーは 128 文字、値は 256 文字。CloudTrail では、`AssumeRole` / `GetFederationToken` の場合は `requestParameters.tags`、`SAML` / `OIDC` 経由の場合は `requestParameters.principalTags` に付与内容が記録され、いずれも `transitiveTagKeys` で推移的タグキーを確認できる。抽出条件は経路ごとに定義すること。

● 注意

セッションタグはコンソールの「ロールの切り替え（Switch Role）」では渡せない。コンソール操作を主とする役割にセッションタグによる識別を依存させないこと。この場合は `sts:RoleSessionName` または IAM Identity Center の `onBehalfOf.userId` による識別を用いること。

10.3.6 KMS キー管理のデュアルコントロール

必須 ログ暗号化に用いる KMS キーについて、キーポリシーの変更・キーの無効化・削除予約を単独の個人が実行できない構成とすること。キーポリシーは各 KMS キーにちょうど 1 つ存在し、ルートユーザーやキー作成者であってもキーポリシー等で明示的に許可されない限り権限を持たない。この性質を利用し、管理権限を持つロールを限定したうえで、当該ロールの引き受け自体を承認と記録の対象とすること。組織レベルの予防統制は 10.3.7 の SCP（`kms:ScheduleKeyDeletion` 等の拒否）が担う。ただし SCP は主体を除外するか全面的に拒否するかのいずれかであり、二名の関与を要求する機能を持たない。そこでデュアルコントロールは、キーポリシーの変更と削除予約を承認済みの IaC パイプライン経由に限定し、パイプラインの二名承認とキーポリシー上の権限分離によって実装すること。本項のロール限定・承認・記録はその上に置く手続的統制であり、両者を併せて設計すること。

必須 `ScheduleKeyDeletion`、`DisableKey`、`PutKeyPolicy` を CloudTrail の監視対象とし、検知時に即時通知すること。KMS のすべての操作は管理イベントとして CloudTrail に記録される。ただし、証跡の管理イベント設定によっては AWS KMS のイベントが記録対象から除外されている場合があるため、対象証跡で KMS イベント

が除外されていないことを設定画面または `GetEventSelectors` の出力で確認し、確認結果をログ設計書に記載すること。フィルターパターンおよびアラート設計は第9章による。

推奨 AWS Config ルール `kms-cmk-not-scheduled-for-deletion` および `cmk-backing-key-rotation-enabled` を有効化すること。

10.3.7 SCP による組織レベルの拒否

必須 AWS Organizations のサービスコントロールポリシー（SCP）により、ログの停止・設定変更・削除に関わる API を組織レベルで拒否すること。SCP はメンバーアカウントの IAM ユーザー・ロール（ルートユーザーを含む）の最大権限を定義し、権限を付与しない。有効な権限は SCP と IAM ポリシーの積集合となるため、アカウント内で誤って広い権限が付与されても SCP の拒否は破られない。管理アカウントとサービスリンクロールには適用されない点に留意すること。**本要求は AWS Organizations の管理アカウントにおける設定であり、実施主体は発注者とする。**開発ベンダーは、拒否対象とすべき API の一覧、除外が必要な主体（パイプライン実行ロール等）とその理由を設計書として提出し、適用後に拒否が有効であることをテストで確認すること。

AWS Control Tower の必須コントロールとして公開されている SCP は、拒否すべき API の具体例として利用できる。CloudWatch Logs については `logs:DeleteLogGroup` と `logs:PutRetentionPolicy` を、ログアーカイブバケットについては `s3:DeleteBucket`、`s3:PutBucketPolicy`、`s3:DeleteBucketPolicy`、`s3:PutLifecycleConfiguration`、`s3:PutEncryptionConfiguration`、`s3:PutBucketLogging` を拒否し、パイプライン実行ロールのみを `ArnNotLike` 条件で除外する形式である。CloudTrail については `cloudtrail:DeleteTrail`、`cloudtrail:PutEventSelectors`、`cloudtrail:StopLogging`、`cloudtrail:UpdateTrail`、AWS Config については `config:DeleteConfigurationRecorder`、`config:DeleteDeliveryChannel`、`config:DeleteRetentionConfiguration`、`config:PutConfigurationRecorder`、`config:PutDeliveryChannel`、`config:PutRetentionConfiguration`、`config:StopConfigurationRecorder` が対象とされている。

必須 `kms:ScheduleKeyDeletion` についても同形の拒否を組織で作成すること。なお S3 ライフサイクル設定の変更は、上記の Control Tower 必須コントロールに含まれる `s3:PutLifecycleConfiguration`（IAM の Action 名。API 名 `PutBucketLifecycleConfiguration` とは異なるため、API 名をそのまま Action に記述しないこと）で既に拒否対象となっているため、ログアーカイブバケットを対象とする同等のステートメントを自組織の SCP に含めること。KMS キー削除をまとめて拒否する AWS 公式の SCP 例文は確認できていないため、上記の公式例を参考に作成し、適用後に実際に拒否されることをテストで確認すること（テスト項目は第8章）。

10.3.8 ルートユーザーの封印

必須 ルート認証情報を保持するアカウント（管理アカウント、スタンドアロンアカウント、および集中ルートアクセス管理を適用していないメンバーアカウント）のルートユーザーに MFA を設定すること。AWS はすべてのアカウント種別についてルートユーザーの MFA 設定を必須としており、未設定の場合はマネジメントコンソールへの初回サインイン試行から35日以内の登録が求められる（適用の範囲と時期は公式ドキュメントで確認すること）。利用できる MFA はパスキー／セキュリティキー（FIDO）、仮想認証アプリ（TOTP）、ハードウェア TOTP である。

必須 ルートユーザーを日常業務に使用しないこと。ルートユーザーの使用は CloudTrail で検知し、即時に通知すること。検知には公式に示されている以下のメトリクスフィルターパターンを用いること。

```
{$.userIdentity.type="Root" && $.userIdentity.invokedBy NOT EXISTS && $.eventType != "AwsServiceEvent"}
```


推奨 AWS Organizations の集中ルートアクセス管理を有効化し、メンバーアカウントのルート認証情報（パスワード、アクセスキー、署名証明書）を削除して MFA を無効化すること。**集中ルートアクセス管理を適用したメンバーアカウントは、前段のルートユーザー MFA 設定要求の対象外とする。**この機能を有効化すると、新規に作成されるアカウントは既定でルート認証情報を持たない。有効化は `aws iam enable-organizations-root-credentials-management` および `aws iam enable-organizations-root-sessions`、委任管理者の登録は `aws organizations register-delegated-administrator --service-principal iam.amazonaws.com` による。**本項は AWS Organizations の管理アカウントにおける設定であり、実施主体は発注者とする。**開発ベンダーは、適用対象アカウントの範囲と、ルート認証情報削除後に必要となる代替手段の設計を提出すること。

● 注意

ルート認証情報を削除する場合、ルートユーザーでしか実施できないタスク（S3 バケットの MFA Delete の設定、すべてを拒否する S3/SQS ポリシーの修正、アカウント閉鎖等）の実施手段をあらかじめ確保すること。集中ルートアクセス管理では、特権ルートアクションとして S3 バケットポリシー削除、SQS キューポリシー削除、ルート認証情報削除、パスワード回復許可を実行できる。特権セッションは `sts:AssumeRoot`（リージョナル STS エンドポイントのみ、ルート認証情報では呼び出せない）で開始し、`task-policy-arn` に、`IAMAuditRootUserCredentials`、`IAMCreateRootUserPassword`、`IAMDeleteRootUserCredentials`、`S3UnlockBucketPolicy`、`SQSUnlockQueuePolicy` のいずれかに対応するタスクポリシーの ARN を指定する（ポリシー名のみでは指定できず、`arn:aws:iam::aws:policy/root-task/<ポリシー名>` 形式の ARN を指定する。CLI では `--task-policy-arn arn=<ARN>` のように `arn=` を付けて指定する。特権セッションの有効時間は最大900秒（15分）である）。指定できるタスクポリシーは条件キー `sts:TaskPolicyArn` で制限できる。**MFA Delete を統制手段として採用している場合は、ルート認証情報削除の前にその再設定手段を確認すること。**

10.4 開発ベンダー・運用ベンダー要員のアクセス管理

実施基準は2023年改訂で「情報システムの開発・運用・保守などITに関する業務の全て又は一部を、外部組織に委託するケースもあり、かかるITの委託業務に係る統制の重要性が増している」と明記し、委託業務の評価範囲に「情報システムの開発・運用・保守などITに関する業務を外部の専門会社に委託する場合」を含めた。また「委託業務に関しては、委託者が責任を有しており、委託業務に係る内部統制についても評価の範囲に含まれる」としている。したがって、開発ベンダー要員のアクセス管理は貴社内部の管理事項ではなく、発注者が評価し監査人が検討する対象である。責任分界の定義は LR-13 および第11章による。

10.4.1 個人IDの原則と共有IDの禁止

必須 開発ベンダー・運用ベンダーの要員に対し、個人単位の ID を発行すること。複数名で1つの ID を共用しないこと。日本公認会計士協会 監査基準報告書315 実務ガイダンス第1号 Q41 は、特権IDに関するリスクの例として「特権IDが共有されており、誰が使用して会計データを修正したかを特定することが困難なリスク」を挙げている。

必須 業務上やむを得ず共有の実行ロールを用いる場合であっても、CloudTrail から個人を特定できる構成とすること。具体的には 10.3.5 の `sts:SourceIdentity`、`sts:RoleSessionName`、IAM Identity Center の `onBehalfOf.userId` のいずれかにより、ロールセッションと個人を対応付けること。この対応関係をログ設計書に記載すること。

必須 要員の入退場に合わせた ID のプロビジョニング・デプロビジョニングを、ID プロバイダーからの SCIM 連携等により自動化すること。手作業による削除漏れは、退職者アクセス権の残存として直接的な不備となる。

10.4.2 本番環境アクセスの経路

必須 本番環境のサーバへの対話的アクセスは AWS Systems Manager Session Manager 経由に限定し、セッションログを Amazon S3 または Amazon CloudWatch Logs に出力する設定を明示的に行うこと。セッションログの出力はセッション設定（Preferences）で有効化しない限り取得されない。SSH ポートを開放した踏み台サーバによるアクセスを設計に含めないこと。

● 注意

Session Manager には**ログを取得できない利用形態がある**。ポートフォワーディング経由および SSH 経由のセッションはログ記録の対象外である（SSH は TLS トンネル内で暗号化され、Session Manager は単なるトンネルとして動作するため）。これらを禁止しないまま Session Manager を採用すると、記録されない本番アクセス経路が残る。また Linux/macOS では `screen` ユーティリティが導入されていないとログが切り詰められる可能性がある（Amazon Linux 2/2023、Ubuntu は既定で導入済み）。

必須 SSH セッションおよびポートフォワーディングを IAM ポリシーで拒否すること。AWS 公式が示す SSH の拒否例は次のとおりであり、ポートフォワーディング用のドキュメント（`AWS-StartPortForwardingSession`、`AWS-StartPortForwardingSessionToRemoteHost`）についても同形で拒否すること。

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyUnloggableSessionTypes",
      "Effect": "Deny",
      "Action": "ssm:StartSession",
      "Resource": [
        "arn:aws:ssm:*:*:document/AWS-StartSSHSession",
        "arn:aws:ssm:*:*:document/AWS-StartPortForwardingSession",
        "arn:aws:ssm:*:*:document/AWS-StartPortForwardingSessionToRemoteHost"
      ]
    }
  ]
}
```

推奨 条件キー `ssm:resourceTag/<key>` により、要員が接続できるノードをタグで限定すること。また、IAM ポリシーの Condition 要素で条件キー `ssm:SessionDocumentAccessCheck` を `true` として指定し、利用者がアクセス権を持つセッションドキュメントでのみセッションを開始できるようにすること。

必須 セッション中にパスワード等の秘密値を入力する運用を設計しないこと。やむを得ない場合は、Linux では `stty -echo; read passwd; stty echo;`、Windows では `$Passwd = Read-Host -AsSecureString` によりログへの記録を回避すること。機微情報の保護は LR-07 および第5章による。

● 補足

Session Manager のセッション履歴（`aws ssm describe-sessions --state History`）は過去30日の範囲であり、かつ Session Manager 経由で開始されたセッションのみが対象で、Session Manager を経由しない直接の RDP/SSH 接続は一覧に現れない。なお Session Manager 経由の SSH セッションおよびポートフォワーディングセッションは一覧には現れるが、セッションログは取得されない。監査対応で必要となる長期の証跡は、S3/CloudWatch Logs へ出力したセッションログと、CloudTrail に記録される Systems Manager の API 呼び出しで確保すること。CloudTrail に記録されるセッション関連イベントの具体的な名称は、実際の環境で確認したうえでログ設計書に記載すること。

10.4.3 申請・承認・期限付き付与と退任時の削除

必須 ベンダー要員へのアクセス権付与は、期限を定めた付与とすること。期限到来時に失効させる仕組みを設けること。IAM Identity Center には割り当てに有効期限を設定して自動失効させる標準機能がないため、期限到来時に `DeleteAccountAssignment` を実行する自動処理、または期限管理と失効操作を伴う承認ワークフローとして実装し、その実装方式をログ設計書に記載すること。恒常的な付与を既定としないこと。

必須 要員の離任・契約終了時に、当日中にアクセス権を削除すること。追補版は評価手続として「退職者のサンプルを抽出し、退職後、即座にアクセス権が削除されていることを確かめる」を挙げており、削除日時が確認できる証跡（ID プロバイダーの操作記録、および `DeleteAccountAssignment` 等の CloudTrail 記録）を残すこと。

必須 発注者との契約において、要員の ID・権限の管理主体、棚卸の実施頻度、棚卸結果の報告義務を明確にすること。本要求は発注者と開発ベンダーの双方が当事者となる契約事項であり、開発ベンダーは自社要員に関する管理体制と報告様式を提示すること。日本公認会計士協会 IT委員会研究報告第46号（2014年9月30日公表。2022年10月13日廃止。現行の枠組みは監査基準報告書315 および同実務ガイダンス第1号）には、外部委託先が使用するユーザ ID を委託先側で管理し、ID や権限を定期的に棚卸したうえでその結果を委託会社へ報告することを業務委託契約書上で取り決める運用が参考事例として示されている。

10.4.4 緊急アクセス（ブレイクグラス）

必須 通常の申請・承認を経る時間がない障害対応等のために、緊急アクセス（ブレイクグラス）の手順を定めること。手順を定めないことは、統制を守れない事態が生じたときに手順外の操作が行われることを意味し、かえって記録の欠落を招く。

ブレイクグラスの設計要件は以下のとおり。

- 必須** 専用のロール・許可セットを用意し、通常業務のものと分けること。ログ削除および KMS キー管理は、ブレイクグラス用ロールにおいても付与しないこと（ログ削除は表10-1 で全役割が×であり、緊急時にも解除されない。KMS キー管理は R-5 に限り△であるが、ブレイクグラス用ロールはこの△の対象に含めない）。
- 必須** 使用時に自動的に通知が発報されること。通知先は R-2 および R-5 を含めること。
- 必須** セッションに `sts:SourceIdentity` または `sts:RoleSessionName` により実行者と事案識別子を記録すること。
- 必須** 有効期間を限定し、期限到来で自動的に失効すること。
- 必須** 使用後に事後レビューを行い、実施内容と操作記録（CloudTrail、Session Manager セッションログ）を突合すること。事後レビューの実施期限を発注者と合意し、手順書に記載すること。
- 必須** 事後レビューの実施者は、ブレイクグラスを使用した本人以外とすること。

10.5 特権ID管理の統制フロー

本節の特権IDは、ログ基盤に対する権限（表10-1）に限らず、業務システムの本番環境において構成・データ・権限を変更し得るすべての高権限IDを対象とする。ログ基盤に対する権限については、表10-1 の×は本フローによっても解除されない。

必須 特権IDを恒常的に利用可能な状態に置かず、利用の都度、承認を得たうえで期間を限って付与すること。日本公認会計士協会 監査基準報告書315 実務ガイダンス第1号 Q41 は特権IDを「全てのマスター情報、パラメータ設定値の変更や会計データの作成、変更、削除及びそれらの権限の設定等が可能な、操作に制限を受けない特別なID」と定義し、統制の例として「特権IDの操作に関しては、操作内容を文書化し、ユーザ部門管理者の承認を受ける」「会計システムのログの取得機能を活用し、事後的にモニタリングする等の発見的な内部統制を組み込む」を挙げている。また追補版は「特権については、運用基準があり、特権の付与に際して、最小限にとどめていること。利用が終わって、不要になれば、すぐに特権を停止する」としている。

統制フローの全体像を図10-1 に、各段階の実施者・承認者・実装・証跡を表10-2 に示す。

図10-1 特権ID管理の統制フロー



表10-2 特権ID統制フローの実施者・承認者・実装・証跡

段階	実施者	承認者	AWS での実装	残す証跡
申請	R-3/R-4 (利用希望者本人)	—	AWS 外の申請ワークフロー（目的、対象アカウント、許可セット、期間、対象作業を記載）	申請記録（申請者、申請日時、目的、有効期間）
承認	—	R-2（申請者と別の個人）	AWS 外の承認ワークフロー。IaC 経由の場合はプルリクエスト承認	承認記録（承認者、承認日時、承認範囲）。申請者と承認者が別人であること
付与	R-5	—	IAM Identity Center の許可セット割り当て（CreateAccountAssignment）	CloudTrail の付与イベント。承認記録との対応付け
利用	R-3/R-4	—	MFA 必須、sts:SourceIdentity による個人識別、Session Manager 経由の操作記録	L-01 クラウド基盤API操作ログ、L-04 認証・認可ログ、L-05 サーバ操作ログ
レビュー	R-5	R-2（レビュー結果の承認）	Amazon Athena/CloudWatch Logs Insights による抽出（第12章）	抽出条件、抽出結果、申請との突合結果、逸脱と対応。レビュー実施者と承認者の記録
失効	R-5（自動処理を含む）	—	許可セット割り当ての解除（DeleteAccountAssignment）。期限到来時の解除は自動処理として実装する（標準機能ではない）	CloudTrail の解除イベント。有効期間内に解除されたことの確認結果

● 監査の視点

監査人はこのフローの各段階を、記録どうしの突合で確かめる。とくに「申請にない特権利用がないこと」と「期限内に失効していること」の2点は、抽出結果を提示するだけでは足りず、**申請記録と CloudTrail の双方を突き合わせた結果**が求められる。レビューの実施者と、その結果を承認する責任者が別であることも確認対象となる（経済産業省 追補版はアクセス権の申請と承認について「同一人物が両方の行為を実施していないことを確かめる」としており、レビューについても実施者と承認者の分離が同じ考え方で問われる）。突合はレビューのたびに実施し、突合表そのものを証拠として保存すること。

10.6 アクセス権棚卸の証跡

必須 アクセス権の棚卸を定期的実施し、結果を証拠として保存すること。棚卸では、実際に設定されている権限の一覧を AWS から取得し、承認済みの権限一覧（台帳）と突合すること。台帳との照合ではなく台帳の閲覧のみで済ませないこと。日本公認会計士協会 IT委員会研究報告第46号「重要な虚偽表示リスクとIT全般統制の評価」（2014年9月30日公表。2022年10月13日廃止のため現行文書ではないが参考となる。現行の枠組みは監査基準報告書315 および同実務ガイダンス第1号）は、「作業ミスによりアクセス権限を管理する台帳と、システムに実際に設定されている状況とが不一致であるケース」を挙げ、「必要に応じて、システムから実際に設定されている情報を出力して適切に設定されているかを検討する」としている。

推奨 棚卸の頻度は四半期ごととすること。最終的な頻度は発注者が決定する。なお、運用状況評価のサンプル件数について、経済産業省「システム管理基準 追補版（財務報告に係るIT統制ガイダンス）」（令和6年12月25日公表）は付録図表1-1に例として四半期次の処理は2件・許容逸脱0件を示しているが、同資料はこれを「例」と位置づけ「1日につき多数及び日次の場合以外は、統計的方法によるものではない」としており、法令上の要件ではない。棚卸そのものは全件で実施することを原則とする（設定情報の全件出力と台帳の突合）。なお、運用状況評価においては経営者側もサンプリングにより証拠を入手することが実施基準上の原則であり（実施基準II.3(3)④ロ「運用状況の評価の実施に際して、経営者は、原則としてサンプリングにより十分かつ適切な証拠を入手する」）、上記の件数例はその際の参考である。棚卸の全件実施と、運用状況評価のサンプリングとは別の手続である。

10.6.1 取得コマンド例

棚卸に用いる取得手順は、手作業のコンソール操作ではなくコマンドとして定義し、実行日時（UTC）・実行者・出力ファイル名を記録して保存すること。

```
# IAM 認証情報レポート（生成は4時間に1回まで）
aws iam generate-credential-report
aws iam get-credential-report --query 'Content' --output text | base64 --decode \
  > credential-report_$(date -u +%Y%m%dT%H%M%S).csv

# IAM Identity Center: インスタンスと ID ストアの特定
aws sso-admin list-instances

# アカウントに割り当て済みの許可セットを列挙し、その割り当て先を取得
aws sso-admin list-permission-sets-provisioned-to-account \
  --instance-arn <InstanceArn> --account-id <AccountId>
aws sso-admin list-account-assignments \
  --instance-arn <InstanceArn> --account-id <AccountId> \
  --permission-set-arn <PermissionSetArn>

# 特定の利用者を起点に、割り当てを横断的に取得
# （組織インスタンスでは管理アカウントから実行する）
aws sso-admin list-account-assignments-for-principal \
  --instance-arn <InstanceArn> --principal-id <PrincipalId> --principal-type USER

# ID ストアの利用者・グループ・所属
aws identitystore list-users --identity-store-id <IdentityStoreId>
aws identitystore list-groups --identity-store-id <IdentityStoreId>
aws identitystore list-group-memberships \
  --identity-store-id <IdentityStoreId> --group-id <GroupId>
```

推奨 IAM Access Analyzer の未使用アクセス分析を有効化し、一定期間使用されていない権限を棚卸の入力とすること。未使用アクセス分析はリージョン非依存で、分析対象のロール・ユーザー数に応じて課金される。追跡期間は 1～365 日の範囲で設定できる。アナライザーの作成と検出結果の取得は、例えば `aws accessanalyzer create-analyzer --analyzer-name unused-access --type ORGANIZATION_UNUSED_ACCESS` と `aws accessanalyzer list-findings-v2 --analyzer-arn <アナライザーARN>` で行う（追跡期間等のパラメータは公式ドキュメントで確認すること）。コマンドと出力を 10.6.3 の実施記録に含めること。

10.6.2 取得できる情報と限界

棚卸の証跡は、取得元ごとに網羅範囲が異なる。単一の出力で「すべての権限を確認した」と主張しないこと。

表10-3 棚卸の取得元と留意点

棚卸対象	取得元	網羅範囲と留意点
IAM ユーザーの認証情報	IAM 認証情報レポート	パスワード、MFAの有無、ユーザーごと最初の2つのアクセスキー、X.509 証明書が対象。 3つ目以降のアクセスキーとサービス固有の認証情報は含まない 。アクセスキー最終使用は15分単位、パスワード最終使用は5分単位で、最初の使用のみ記録される
IAM Identity Center の割り当て	sso-admin / identitystore の各 API	許可セットの割り当て（利用者・グループ単位）を列挙できる。list-account-assignments は1ページ最大100件のため、全件取得のページング処理を実装すること。list-account-assignments-for-principal は組織インスタンスの管理アカウントからのみ実行できる
未使用の権限	IAM Access Analyzer（未使用アクセス）、IAM の最終アクセス情報	最終アクセス情報はサービス単位で少なくとも400日追跡される。アクション単位の追跡は対象サービス・開始時期が限定される。 拒否された試行も含まれるため、実際に成功した操作の有無は CloudTrail を正とすること
権限設定の逸脱	AWS Config（10.3.4 のルール群、構成履歴）	IAM のグローバルリソース（ユーザー・グループ・ロール・カスタマー管理ポリシー）は記録可能なリージョンが限定されるため、記録リージョンを設計書に明記すること。記録対象外リソースは作成・削除のみが捕捉され構成詳細は残らない
権限の付与・変更の履歴	CloudTrail（L-01、L-04、L-14）	「いつ・誰が付与したか」を記録する。棚卸時点の状態のみでは、期中に付与され棚卸前に解除された権限を検出できないため、期間全体の付与イベントを併せて抽出すること
アプリケーションの権限	アプリケーションの権限マスタ	AWS の統制範囲外である。 必須 開発ベンダーは、利用者・ロール・権限の対応を一覧として出力する機能を実装すること （画面での目視確認のみとしないこと）。出力形式・項目は 10.7 の設計書に定義すること

10.6.3 棚卸の実施記録

必須 棚卸のたびに、以下を含む実施記録を作成し保存すること。対象期間、実施日時（UTC およびその表記規約）、実施者、承認者、取得コマンドと出力ファイル、台帳との突合結果、検出した差異、差異ごとの原因と是正内容、是正の完了日時。差異が0件であった場合も、突合を実施した記録を残すこと。

必須 是正措置は、次回棚卸を待たずに実施すること。実施基準は「内部統制によって発見された不正又は誤謬に適時に対処する手続が設定されているか」を整備状況評価の留意点としている。差異を検出しながら是正を次期に持ち越す運用は、統制の運用の不備と評価され得る。

10.7 提出する設計書・証跡

必須 開発ベンダーは、本章に関して以下の成果物を提出すること。ログ設計書全体の記載事項、テスト観点、受入チェックリストは第11章による。本節は本章に固有の成果物のみを示す。

表10-4 第10章に関する提出成果物

成果物	記載すべき内容	提出時期
権限マトリクス実体版	表10-1 を、実際のアカウント・許可セット名・IAM ロール名・対象リソース（ロググループ、バケット、KMS キー）に展開したもの。○△×の各セルを、それを実現するポリシー文または SCP の該当ステートメントに対応付けること。CI/CD パイプライン実行ロールの ARN を明記すること	設計完了時
許可セット・ロール定義 (IaC)	許可セットの定義、アクセス許可の境界、監査ロールの信頼ポリシーおよび権限ポリシー、セッション期間の設定値と設定理由	構築完了時
ログ保護ポリシー一式	SCP（ログの停止・設定変更・削除の拒否）に含めるべき API の一覧と設計、KMS キーポリシー、ログ保存先バケットのバケットポリシー。除外している主体（パイプライン実行ロール等）とその理由。SCP の適用は発注者が実施するため、開発ベンダーは設計と適用後のテスト結果を提出すること	構築完了時
本番アクセス経路の設計と拒否ポリシー	Session Manager のセッション設定（出力先、暗号化）、SSH・ポートフォワーディング拒否ポリシー、接続可能ノードの限定方法、記録されない経路が存在しないことの説明	構築完了時
特権ID管理手順書	表10-2 の各段階の手順、申請様式、承認者、有効期間の上限、突合の手順と様式。R-5 を発注者側と委託先のいずれに置くかの合意結果と、委託先に置く場合の指揮命令系統および発注者によるレビュー統制（10.1.2）	運用設計完了時
ブレイクグラス手順書	発動条件、使用するロール、通知先、有効期間、事後レビューの実施者・期限・様式。ログ削除および KMS キー管理を含まないことの明示	運用設計完了時
棚卸手順書	対象範囲、頻度、取得コマンド、台帳の様式、突合方法、差異の是正手順、記録の保存先と保存期間	運用設計完了時
アクセス制御テスト結果	表10-1 の×が実際に拒否されることを確認したテストの実施記録（実行者、実行日時、コマンド、出力）。とくにログ削除・KMS キー削除予約・ログ設定変更の拒否を含めること。あわせて、構築フェーズで開発ベンダーに付与した暫定権限がすべて解除され、表10-1 の定常状態に移行したことの確認結果（解除対象の一覧、解除日時、解除操作の CloudTrail 記録）を含めること	受入前
初回棚卸の実施記録	10.6.3 の実施記録一式。稼働開始前の状態を基準として保存すること	受入前
ID・権限一覧の出力機能仕様	アプリケーションにおける利用者・ロール・権限の対応を出力する機能の仕様（出力項目、形式、権限、実行方法）	設計完了時

● 補足

本章の成果物は、監査人への提示を前提とした形式で作成すること。監査人が確認するのは設定値そのものよりも、**設定値が承認されたものであり、その後変更されていないこと**である。したがって、設定を IaC で管理し、変更履歴をコードの承認履歴として残す構成が、証跡の作成負荷を最も小さくする。証跡の抽出・提出の手順は第12章による。

11

開発ベンダーの実装責任と成果物

第2章から第10章は、ログ管理として何が求められ、それを AWS 上でどう実装するかを定めた。本章は、それを**開発ベンダーが誰の責任で、いつまでに、どの成果物として提出し、どう検証されるか**に翻訳する。要求事項の内容そのものは各章に譲り、本章は成果物・テスト・受入基準の一覧としてまとめる。

本章の位置づけは IT 全般統制の領域のうち主として ITGC-A（システムの開発、保守に係る管理）と ITGC-D（外部委託に関する契約の管理）であるが、11.8 の運用・保守手続および 11.5 のレビュー手順のリハーサル（T-16）は ITGC-B（システムの運用・管理）に、11.3 のアクセス制御に係る記載事項および 11.5 の権限テスト（T-14・T-15）は ITGC-C（内外からのアクセス管理などシステムの安全性の確保）にも関係する。実施基準は、システムの開発・変更に際して「開発・変更の過程等の記録を適切に保存する」ことを全般的な統制活動の例として挙げており、2023年の改訂では、委託業務の評価範囲を定める実施基準 II.2(1)②イにおいて、委託業務の例として「情報システムの開発・運用・保守などITに関する業務を外部の専門会社に委託する場合」が明示された。開発ベンダーが作成する設計書・テスト記録・設定証跡は、発注者にとって**自社の内部統制の評価資料そのもの**であり、納品物の一部ではなく統制の構成要素である。

本章で用いる識別子は次のとおりである。成果物は D-01～D-14（11.2）、テスト観点は T-01～T-18（11.5）とする。各章が個別に定めた提出物は、本章の D-xx に含めて提出し、二重に作成しない。吸収先は次のとおりとする。表6-5 の図・表は D-01 の別紙および D-03、表8-3 の完全性テスト項目は D-09、表9-4 の監視・レビューに関する引継ぎ成果物は主に D-06・D-07・D-11、表10-4 のアクセス制御関連成果物は主に D-01 の「アクセス制御」章および D-10 に含める。いずれも、元の表の項目と D-xx の対応関係を示すこと。

11.1 フェーズ別の実施事項

必須 開発ベンダーは、ログ管理を構築フェーズの設定作業として扱わず、要件定義から運用引継ぎまでの各フェーズに組み込むこと。とくに、対象範囲（LR-01）と記録項目（LR-02）は要件定義・基本設計で確定しないと、アプリケーション（L-07）の改修が後戻りとなる。保存期間（LR-05）と責任分界（LR-13）は発注者の決定事項を含むため、決定を待つ期間を工程に見込むこと。

● 注意

内部統制の評価は期末日時点の有効性を判断するものであり、そのためには期中の運用実績（レビュー記録、アラート対応記録、欠損検知の記録）が必要になる。ログ取得だけが稼働していてレビュー運用が半年後に始まる状態では、当期の運用状況の評価に耐える証跡が積み上がらない。**カットオーバー時点で、取得・保全・監視・レビュー・監査対応の一連が稼働していること**を工程の前提とし、運用引継ぎをカットオーバー後に持ち越さないこと。持ち越す場合は、その期間の代替統制を発注者と合意し記録すること。

表11-1 フェーズ別の実施事項と成果物

フェーズ	開発ベンダーの実施事項	成果物	発注者の確認事項
要件定義	対象システムの財務報告への関連を発注者と確認し、LR-01に基づきログ取得対象（アカウント、リージョン、AWS サービス、アプリケーション機能）を特定する。L-01～L-14 の適用・非適用と非適用理由を整理する。保存期間・監視要件・監査人からの既存要求をヒアリングする。役割（R-1～R-6）の割当てと運用ベンダーの有無を確認する	D-02（初版）	評価対象システムと勘定科目・業務プロセスの対応、保存期間の決定方針、監査人との事前協議の要否、既存ログ基盤の有無と流用範囲
基本設計	第6章のリファレンスアーキテクチャに基づき、ログ集約先アカウント、S3 と CloudWatch Logs の役割分担、暗号化境界、分析手段を決定する。LR-01～LR-14 のそれぞれに実装手段を割り当て、対応表を作成する。ログ量とコストを試算し、階層化方針を提示する	D-01（骨子）、D-03、D-13	アカウント構成と既存の AWS Organizations・ランディングゾーンとの整合、保存期間の決定、コストの承認、SIEM 製品・ログ管理製品の採否
詳細設計	サービスごとの設定値を確定する（証拠のイベントセクター、保持日数、ライフサイクル、KMS キーポリシー、バケットポリシー、IAM・SCP）。L-07 の出力項目とマスキング対象を確定する。アラート条件・通知先・対応時限、レビュー手順、監査対応クエリを設計する	D-01（確定）、D-05、D-06、D-07（案）、D-08（案）、D-14（採用時）	マスキング対象項目と保持する項目、アラート通知先と対応時限、レビュー実施者・承認者（R-2・R-5）、監査人ロール（R-6）の付与先アカウント
構築	IaC により構築し、手動設定を残さない。ログの停止・削除・保持期間短縮を抑止するガードレール（SCP、バケットポリシー、キーポリシー）を適用する。構築完了時点の設定証拠を取得する	D-04、D-05（実測値更新）、D-10（構築時点）	IaC リポジトリの受領方法とコミットハッシュ、パイプライン実行ロールの権限、ガードレールの適用範囲と除外主体
テスト	表11-3 の T-01～T-18 を、実施環境欄の指定に従い本番相当の検証環境で実施し、証拠を採取する。不合格項目は是正して再試験する。表11-4 の受入チェックリストに回答する	D-09、D-10（更新）、D-12	テスト立会いの要否、監査人へのテスト結果提示の可否、残存する制約の受容可否と代替統制
移行	切替前後のログの連続性を確保する。旧システムのログの保全と参照手段、切替期間中の記録の欠落有無を確認する。本番環境で設定証拠を再取得し、表11-3 の実施環境欄で本番環境の実施を指定した項目を再実施する	D-10（本番稼働時点）、D-09（本番再実施分）	旧システムログの保存責任と保存場所、期中切替に伴う評価対象期間の扱い、監査人への説明資料の要否
運用引継ぎ	運用者（R-4）とログ管理者（R-5）に手順書を引き渡し、レビュー・監査対応・復元を立会いのもとで実施させる。保守期間中の変更手続を合意する。開発ベンダーの本番権限を必要範囲に縮小する	D-07（確定）、D-08（確定）、D-11	11.8 の引継ぎ完了条件の充足、保守契約期間中の変更手続と連絡体制、権限縮小後の残存権限

11.2 成果物一覧

必須 開発ベンダーは表11-2 のうちレベルが必須の成果物を提出すること。推奨・任意の成果物は採否を発注者と協議し、判断結果を記録すること。各成果物には版数、作成日、作成者、承認者を記載し、改訂時は改訂履歴を残すこと（LR-14）。成果物間の参照は本章の ID（D-xx）と各章の ID（LR-xx、L-xx、R-x、A-xx、RV-xx、CT-xx、T-xx）で行い、名称の言い換えによる参照を行わないこと。相互参照の不一致は受入時の是正対象とする。なお、D-01 の別紙として綴じる図・表の提出時期は表6-5 によるものとし、表6-5 が基本設計時の提出と定めた図・表（アカウント・OU 構成図、ログフロー図、ログフロー一覧、保存期間・ライフサイクル表、アクセス制御マトリクス、責任分界表）は、D-01 本体の確定を待たずに基本設計の承認前に提出すること。

表11-2 提出成果物一覧

ID	名称	内容	レベル	提出時期
D-01	ログ設計書	11.3の章立てに従うログ管理の主文書。LR-01～LR-14と実装の対応表を含む。表6-5の図・表は本書の別紙として綴じること	必須	基本設計完了時に骨子、詳細設計完了時に確定
D-02	ログ取得対象一覧	L-01～L-14と、対象アカウント・リージョン・リソース・ロググループ名・バケットプレフィックスの網羅表。種別ごとに、組織単位で自動的に記録対象となるか、リソース単位の有効化を要するかという包含方式と、その実現手段（組織の証跡、StackSets、ランディングゾーン、IaCモジュール、既定パラメータグループ、起動テンプレート等）を記載する。非適用としたものは理由と代替手段を記載。棚卸日を記載し、リソース追加のつど更新する	必須	要件定義完了時、以後変更のつど
D-03	ログ基盤構成図	アカウント間のログの流路、保存先、暗号化キーの位置、書込・読取の主体と向き、通知経路を示す図。表6-5のアカウント・OU構成図とログフロー図を含む。図中の名称はIaCの論理名と一致させる	必須	基本設計完了時
D-04	IaC一式	ログ基盤とログ設定を再現できるテンプレート・モジュール一式、リポジトリの所在、適用パイプラインの定義、適用手順。手動設定が残る箇所はその一覧と理由	必須	構築完了時（以後は変更のつど）
D-05	設定パラメーター一覧	サービスごとの設定項目・設定値・設定理由・変更時の影響。付録Cの様式に従う。既定値から変更した項目と、既定値のまま採用した項目を区別して記載すること	必須	詳細設計完了時、構築完了時に実測値で更新
D-06	アラート定義書	表9-1のアラート（A-xx）に対応する検知条件・パターン本文・しきい値・重大度・通知先・初動対応・対応時限。誤検知時の除外手続と、除外の承認者	必須	詳細設計完了時
D-07	レビュー手順書	表9-2のレビュー（RV-xx）ごとの対象・頻度・手順・判定基準・記録様式・実施者・承認者・所要時間の目安。運用ベンダー要員が単独で実施できる粒度で記述する	必須	詳細設計完了時に案、運用引継ぎ時に確定
D-08	監査対応手順書	監査人からの典型的な依頼に対する抽出手順とクエリ集、出力様式、実行に要する時間とコストの目安（アーカイブからの復元は保管クラスと取り出しオプション別の見積り範囲）、提出前の確認事項（機微情報の有無、対象期間の網羅性）。詳細は第12章による	必須	詳細設計完了時に案、運用引継ぎ時に確定
D-09	テスト結果報告書（完全性テストを含む）	表11-3のT-01～T-18について、手順・実施環境・実施日時（UTCと現地時刻）・実施者・対象・実行コマンド・出力・判定・是正内容。表8-3のCT-xxの結果を含む	必須	テスト完了時、および本番環境反映後
D-10	設定証跡集	11.6の方法で取得した設定出力一式と索引。取得日時・取得コマンド・実行者・対象アカウント・リージョンを付し、対象の全アカウント・全リージョンを網羅する	必須	構築完了時・テスト完了時・本番稼働時の3時点
D-11	運用引継ぎ書	運用体制と連絡経路、日次・週次・月次・年次の作業、エスカレーション基準、既知の制約と代替統制、未完了事項と対応予定、障害時の復旧手順	必須	運用引継ぎ時
D-12	受入チェックリスト回答書	表11-4の各項目に対する開発ベンダーの回答と、根拠となる成果物・証跡ファイルの所在（D-xxとファイル名）	必須	受入検査前

ID	名称	内容	レベル	提出時期
D-13	ログ量・コスト試算書	ログ種別ごとの想定発生量、取り込み・保存・クエリのコスト試算、階層化による削減効果、想定量を超えた場合の見直し基準と通知方法	推奨	基本設計完了時
D-14	SIEM 製品連携設計書	SIEM 製品またはログ管理製品を導入する場合の連携方式、転送対象と転送しないもの、製品側の保持期間と AWS 側の保持期間の関係、製品側での改ざん防止とアクセス制御、製品障害時の代替手段	任意	詳細設計完了時

必須 提出は電子ファイルとし、発注者が指定する保管領域に格納すること。成果物そのものも保存対象の記録であり、実施基準は評価に関する記録の保存について、金融商品取引法上の縦覧期間（5年）を勘案して保存期間を決定することが考えられるとしている。最終的な保存期間は発注者が決定するため、引渡し後の保管責任と保管場所を D-11 に明記すること。

11.3 ログ設計書の必須記載事項

必須 D-01 ログ設計書は次の章立てに従い、各項目を漏れなく記載すること。該当なしとする項目は、空欄にせず「該当なし」と、そう判断した理由を記載すること。設計書は監査人が単独で読んで統制の内容を理解できることを目標とし、AWS のサービス名だけを並べた記述にしないこと。

- 目的** 本設計書が対象とするシステムと、財務報告に係る内部統制における位置づけ。準拠する社内規程・本ガイドライン・関連する確定文書。想定読者（R-1～R-6）。
- 対象範囲**（LR-01） 対象アカウント・リージョン・環境（本番・検証）・対象システムとその境界。対象外とした範囲と、対象外にできる理由。範囲が変動する場合（アカウント追加、リージョン追加、リソース追加）に取得対象に含まれる仕組みを、組織単位で強制できる記録とリソース単位の有効化を要する記録に分けて記載し、それぞれの確認方法と未適用の検出方法を示すこと。
- ログ種別一覧**（L-01～L-14 対応） 種別ごとの発生源、取得手段、非適用の場合の理由と代替統制。D-02 と 1対1で対応させること。
- 記録項目定義**（LR-02） 種別ごとの記録項目と、5W1H（いつ・誰が・どこで・何を・どうした・結果）の対応。項目が取得できない場合の理由と、それを補う他の記録。L-07・L-08・L-09 は 11.4 の規約に従う。
- フォーマット**（LR-02、LR-03、LR-10） 出力形式（構造化 JSON、CSV、テキスト）、文字コード、時刻表記の規約（UTC 基準、タイムゾーンの明示方法、現地時刻との対応の付け方）、識別子の採番規則。異なる種別のログを突合する際の結合キー。
- 保存先と保存期間**（LR-05） 保存先（バケット名・プレフィックス、ロググループ名）、保持日数、ライフサイクル（移行日数と移行先クラス）、削除の手続。保存期間は第7章の推奨値ではなく**発注者が決定した値**を記載し、決定日と決定者を併記すること。AWS Config の設定項目保持期間と、S3 へ配信された設定履歴・スナップショットの保存期間は別管理であるため、両者の値と役割分担を併記すること。
- 暗号化**（LR-07） 保存時・転送時の暗号化方式、KMS キーの一覧と配置（アカウント・リージョン）、キーポリシーの許可主体、ローテーション方針、キー削除の抑止と検知。機微情報のマスキング対象項目と、監査上必要なため意図的に保持する項目の一覧。
- アクセス制御**（LR-06） R-1～R-6 ごとの権限（ログの読取・書込・設定変更・削除）と実装手段（許可セット、IAM ロール、SCP、バケットポリシー、キーポリシー）。監査人（R-6）に許可する参照経路と、その経路での参照が記録される仕組み。ログを削除できる主体が存在しないこと、または存在する場合の限定条件と補完統制。開発ベンダー・運用ベンダー要員のアクセス経路と有効期限。共有IDの使用を承認した場合の対象・理由・期間・承認者の一覧。

9. **監視・アラート**（LR-08）— A-xx ごとの検知条件、しきい値、通知先、初動対応、対応時限。検知できない事象と、それを定期レビューで補う対応関係。
10. **レビュー**（LR-09）— RV-xx ごとの対象・頻度・母集団の定義・抽出方法（全件か標本か）・判定基準・記録様式・実施者と承認者の分離。
11. **欠損検知**（LR-11）— ログが配信されていないことを検知する手段と検知までの時間、検知後の手順、欠損期間を特定し記録する方法、バックアップと復旧の方式。
12. **変更管理**（LR-12）— ログ設定の変更手続（申請・承認・適用・確認の担当分離）、IaC による管理範囲、緊急変更の扱いと事後の反映期限、変更がログ自身に記録されること（L-14）。
13. **責任分担**（LR-13）— 発注者・開発ベンダー・運用ベンダー・AWS の責任分界。設定・監視・レビュー・障害対応・監査対応それぞれの実施者と承認者。AWS の責任共有モデル上、利用者側の責任となる範囲の明示と、AWS 側の統制を確認する手段（AWS Artifact から入手する報告書等）。委託先の内部統制も発注者の評価範囲に含まれるため、開発ベンダー・運用ベンダー側の統制状況を発注者に報告する方法と頻度を定めること。
14. **文書管理**（LR-14）— 版数、改訂履歴（改訂日・改訂者・改訂理由・承認者）、関連文書の一覧と参照関係、保管場所と保管期間。

11.4 実装ガイド — アプリケーション業務ログ（L-07）の実装規約

L-01～L-06 および L-10～L-14 は主に AWS サービスの設定で取得できるが、L-07 に加え、L-08（ジョブ・バッチ実行ログ）と L-09（データ連携ログ。送受信件数の整合を含む）は、開発ベンダーが実装しなければ内容が存在しない。実行基盤の起動・終了記録は AWS サービスの設定で取得できても、処理件数、送受信件数の整合結果、業務エラーの内容はアプリケーション側で出力しない限り残らない。財務報告に直結する承認操作・金額変更・マスタ変更の証跡は L-07 にしかないことが多く、本節の規約は L-07 を主対象とする受入条件であるが、L-08 および L-09 のアプリケーション出力にも同じ規約を適用すること。

11.4.1 出力項目と時刻表記

必須 監査対象となる業務操作（作成・変更・削除・承認・却下・取消・締め処理・エラーによる中断）について、次の項目を出力すること。項目名は D-01 の記録項目定義に列挙し、実装と一致させること。

- **いつ**— 事象発生時刻。UTC の ISO 8601 形式（例 2026-09-08T04:12:33.482Z）でミリ秒まで出力すること。現地時刻での出力、タイムゾーン表記の省略、アプリケーションごとに異なる形式の使用は認めない。時刻源は第2章 LR-03 および第5章に定める時刻同期の対象とすること。
- **誰が**— 個人を特定できる利用者ID、認証方式、引き受けたロール（該当する場合）、リクエスト元 IP アドレス。ロードバランサーや CDN を経由する構成では、アプリケーションが観測する接続元 IP は経路上の機器のアドレスとなり、そのままでは操作者の追跡に使えない。リクエスト元 IP を転送ヘッダー（X-Forwarded-For 等）から取得する規約を定め、どの値を採用するか（左端の値を採るか、信頼できるプロキシ数を指定するか）を D-01 に記載すること。取得できない場合は、経路上のアクセスログ（L-11）との突合方法を定めること。共有IDでの操作は原則禁止とする。やむを得ず使用する場合は、対象・理由・期間について R-1 または R-2 の事前承認を得たうえで、実操作者を特定できる項目を必ず併記し、承認記録を D-01 に一覧化すること。
- **どこで**— アプリケーション名、バージョン、環境（本番・検証）、実行ホストまたはタスクの識別子。
- **何を**— 操作対象の資源種別と、業務上の主キー（伝票番号、口座ID、マスタコード等）。
- **どうした**— 操作種別。固定語彙（例 payment.approve）とし、画面名や自由文にしないこと。承認・金額変更・マスタ変更については変更前後の値を出力すること。
- **結果**— 成功・失敗の別、失敗時のエラーコードと理由。権限不足による拒否も記録すること。

- **識別子**— ログ1件を一意に識別する ID と、後述の相関 ID。
- **区分**— 監査ログか運用ログかを示す区分（`log_type`）。

11.4.2 構造化ログの出力例

必須 L-07 は1件1行の構造化 JSON で出力すること。可読性のための整形出力、複数行にわたるスタックトレースの監査ログへの混在、メッセージ文字列に値を埋め込む形式（後から機械的に抽出できない形式）は認めない。次を最小形とする。なお、次の例は可読性のため改行して示しているが、実際の出力は改行を含まない1行の JSON とすること。

```
{
  "ts": "2026-09-08T04:12:33.482Z",
  "log_type": "audit",
  "event_id": "01J9Z6M2K7Q0X4V8N3B5T1C9D2",
  "correlation_id": "req-8f3a1c7e-2b90-4d51-9a6c-7e0f2d4b8a13",
  "level": "INFO",
  "app": "ap-payment",
  "app_version": "1.14.2",
  "env": "prod",
  "host": "ip-10-0-12-34",
  "actor": {
    "user_id": "U004821",
    "auth_method": "idc-saml",
    "assumed_role": "arn:aws:iam::111122223333:role/AppApproverRole",
    "source_identity": "U004821",
    "source_ip": "203.0.113.24"
  },
  "action": "payment.approve",
  "target": {
    "resource": "payment_request",
    "record_key": "PR-2026-004821",
    "amount": 1250000,
    "currency": "JPY",
    "bank_account_no": "****"
  },
  "before": { "status": "pending", "approver": null },
  "after": { "status": "approved", "approver": "U004821" },
  "result": "success",
  "error_code": null,
  "masked_fields": ["target.bank_account_no"]
}
```

11.4.3 機微情報の非出力とマスキング

必須 パスワード、認証トークン、アクセスキー、秘密鍵、クレジットカード番号、個人番号はいかなる形でもログに出力しないこと。口座番号、氏名、住所等は D-01 のマスキング対象一覧に従い、アプリケーション側で出力前にマスクすること。マスクした事実は `masked_fields` のように記録し、マスクされたのか元々存在しなかったのかを区別できるようにすること。

必須 マスキング対象一覧には、**マスクする項目と、監査上の追跡可能性のために意図的に保持する項目（伝票番号、承認者ID、金額、勘定コード等）の双方を**列挙し、発注者の承認を得ること。追跡に必要な業務キーまでマスクすると、監査人が承認操作を業務データと突合できなくなり、それ自体が内部統制の不備と評価される可能性がある。マスキングの範囲は R-1 と協議して決定すること。

● 注意

ログ基盤側のマスキング機能を一次防御にしないこと。CloudWatch Logs のデータ保護ポリシーは有効な補完手段だが、**ポリシー設定前に取り込まれたイベントはマスクされない**。誤って出力した機微情報は、保全されたログに残り、改ざん防止設定が効いているために削除もできないという状態になり得る。アプリケーション側で出力しないことを第一の統制とし、ログ基盤側の機能は二重化として位置づけること。実装前に検証環境で T-18 を先行実施し、出力されないことを確認してから本番に反映すること。

11.4.4 関連IDとログレベル

必須 1つの業務要求に対して1つの関連 ID を採番し、同一要求から派生するすべてのログ（画面操作、API、非同期処理、バッチ、データ連携）に伝播させること。外部システムとの連携（L-09）では、送信側・受信側の双方に同一の関連 ID を出力するか、対応表を出力すること。関連 ID がないと、監査人からの「この伝票の承認から会計反映までの流れを示せ」という依頼に対して、複数のログを機械的に結合できない。

必須 監査ログはログレベルの設定によって出力が抑止されない実装とすること。運用上の設定変更（デバッグログの抑制、レベルの引き上げ）が監査ログの欠落につながる実装は認めない。 **推奨** 運用ログのレベルは INFO・WARN・ERROR の3段階以上とし、レベルの意味と使い分けを D-01 に定義すること。

11.4.5 監査ログと運用ログの分離

必須 監査ログと運用ログは `log_type` で区別し、**別の出力先（別のロググループまたは別のプレフィックス）に分離すること**。監査ログの出力先には、第7章の保存期間、第8章の改ざん防止、第10章のアクセス制御を個別に適用する。運用ログと同一の出力先に混在させると、運用ログの量に引きずられて保持期間を短縮する、コスト削減のために削除するといった判断が監査ログに及ぶ。

必須 CloudWatch Logs を出力先とする場合、ロググループのログクラスは**作成後に変更できない**ため、設計時に決定すること。メトリクスフィルタによるアラートを設定するロググループは Standard クラスとすること。Infrequent Access クラスではメトリクスフィルタに加えてサブスクリプションフィルタ、`GetLogEvents` / `FilterLogEvents` API、Live Tail、フィールドインデックスが利用できず、サブスクリプションフィルタによる準リアルタイム転送（D-14）や、これらの API による抽出を前提とするロググループには選択できない。一方、Amazon S3 へのエクスポートと CloudWatch Logs Insights による抽出は利用できるため、これらの経路で LR-10 を満たせる場合は選択し得る。分析・保管のみで即時検知を要しないログのクラス選択は、これらの機能制約を D-05 に記載したうえで発注者と協議すること。

11.4.6 ログ出力失敗時の扱い

必須 監査ログの書き込みに失敗した場合、**業務トランザクションを成功として確定させないこと**。例外を握りつぶして処理を継続する実装、監査ログを「ベストエフォート」として破棄する実装は認めない。実施基準 I.2(6)〔ITの利用〕は「システムの仕様によっては、ITを利用して実施した手続や情報の変更等が適切に記録されないことがあり、そのような場合には、事後の検証が困難となるとの問題が生じうる」と述べており、記録されない業務処理が成立する設計はこの問題そのものである。

必須 同期書き込みが性能上困難な場合は、次のいずれかとすること。

- ローカルの永続領域（ディスク）または永続キューにいったん書き出し、送達確認をもって完了とする。プロセス異常終了時に失われるメモリ上のバッファのみに依存しないこと。
- 業務データベースの同一トランザクション内に監査記録を書き込み、そこからログ基盤へ非同期に転送する。転送遅延と未転送件数を監視すること。

必須 退避したログの再送は、ログ基盤側の受入制約の範囲内で完了する設計とすること。CloudWatch Logs は、イベントのタイムスタンプが一定以上過去のもの（および未来のもの）を受け付けないため、長時間の滞留は再送不能を招く。制約値は実装前に公式ドキュメントで確認し、再送の期限とアラート条件を D-06 に定めること。**必須** ログ書き込みの失敗そのものを運用ログとメトリクスに記録し、LR-08 のアラート対象とすること。

11.5 テスト観点

必須 開発ベンダーは表11-3 のテストを実施し、結果を D-09 として提出すること。原則として本番相当の検証環境で実施する。実施環境欄が「検証環境・本番環境」の項目は本番環境でも再実施し、「本番環境」のみを指定した項目は本番環境で実施すること。実施環境、実施日時（UTC と現地時刻の対応を明記）、実施者、対象アカウント・リソース、実行コマンド、出力全文を記録すること。予防統制の設定そのものを一時的に解除して「できること」を確認する行為は、統制の空白期間を作るため行わないこと。ただし、正当な例外ロール（ログ管理者ロール）で所定の操作が意図どおり成功することの確認（第8章）はこれに含まれず、その実行記録を D-09 に含めること。

期待結果は「できないこと」ではなく**観測できる事象または成果物の記載状態**で記述している。拒否テストでは、拒否されたこと（アクセス拒否の応答）に加えて、**その拒否が L-14 に記録されていること**を確認する。これは LR-08 と L-14 の実装確認を兼ねる。

● 監査の視点

テスト記録は納品時の品質証明であると同時に、**整備状況の評価（内部統制が適切に設計され、かつ業務に適用されているか）の資料**として監査人に提示され得る。したがって、実施者が誰か、いつの時点の環境か、同じ手順で再現できるかが分かる形で記録すること。合格した項目だけでなく、**いったん不合格となり是正した項目も、不合格の内容・是正内容・再試験の結果まで残すこと**。是正の履歴は、統制が機能していることの証拠であって、隠すべき瑕疵ではない。なお、経営者評価では期末日時点の有効性が問われるため、稼働後に設定を変更した場合は、変更後の構成で該当テストを再実施した記録が必要になる。

表11-3 テスト観点

ID	観点	実施環境	手順概要	期待結果	証跡
T-01	出力項目の充足 (LR-02・L-07・L-08・L-09)	検証環境	代表業務（作成・変更・削除・承認・却下・取消・締め処理・エラーによる中断）とバッチ・データ連携を実行し、出力ログを D-01 の記録項目定義と1件ずつ突合する	全必須項目が欠落なく出力され、値が実操作と一致する。変更操作は変更前後の値が記録されている	操作手順、抽出したログ（JSON 原文）、項目突合表（D-09）
T-02	取得対象の網羅性 (LR-01)	検証環境・本番環境	D-02 の全行について、実際に取得されているログまたは有効化されている設定を確認する。非適用行は理由の妥当性を確認する	D-02 の全行に実ログまたは設定取得結果が対応し、未取得の行がない	種別ごとのログサンプル一覧、設定取得結果（D-10）、突合表（D-09）
T-03	時刻同期とタイムスタンプ (LR-03)	検証環境・本番環境	各サーバの時刻同期状態を確認し、同一の業務操作について L-07・L-05・L-01 の記録時刻を突合する	時刻源が定めた同期先に設定され同期済みである。同一操作の記録時刻の差が D-01 の許容値以内で、時系列を再構成できる	時刻同期状態の取得出力、時刻突合表（D-09）
T-04	改ざん防止：削除・上書きの拒否 (LR-04)	検証環境・本番環境	表8-3 の CT-01～CT-03 を実施する（運用者・ログ管理者ロールでのオブジェクト削除、保持設定・ライフサイクル・バケットポリシーの変更）。削除・上書きの拒否確認は、既に配信済みのオブジェクトに対して実施することを原則とする。テスト用オブジェクトを投入する場合、コンプライアンスモードでは保持期限まで削除できず保管コストが発生し続けるため、保持期間を短く設定した試験用バケットで実施するか、投入時にオブジェクト単位で短い保持期限を指定して実施し（Object Lock の既定保持設定はバケット単位であり、プレフィックス単位では設定できない）、本番との設定差分を D-09 に記録する	いずれもアクセス拒否となり、対象オブジェクトとポリシーが変更されていない。拒否イベントが L-14 に記録されている（オブジェクトの削除・上書きは CloudTrail のデータイベントであり既定では記録されないため、事前にログ保管バケットのデータイベントが有効であることを確認し、確認結果を D-09 に添付する）	実行コマンドと出力、実行前後の設定取得結果、拒否イベントの抽出結果、試験用バケットと本番の設定差分（D-09）

ID	観点	実施環境	手順概要	期待結果	証跡
T-05	改ざん防止：保持期限の短縮・解除の拒否（LR-04、LR-05）	検証環境・本番環境	オブジェクトの保持期限の短縮、保持モードの緩和、ロググループ保持日数の短縮を試行する（表8-3のCT-02・CT-04）	短縮・解除がいずれも拒否される。バイパス権限を持たない主体では例外なく拒否される。保持設定が変更されていない	実行コマンドと出力、対象の保持設定取得結果（D-09）
T-06	改ざん防止：記録停止・設定変更の拒否（LR-04、LR-12）	検証環境・本番環境	開発者・運用者ロールで証跡の停止（StopLogging）・削除・イベントセクター変更、設定レコーダーの停止を試行する（表8-3のCT-05・CT-06）	いずれも拒否され、証跡と記録が稼働状態のまま維持される。拒否がL-14に記録され、D-06に定義した記録停止・設定レコーダー停止に係るアラートが発報する	実行コマンドと出力、稼働状態の取得結果、アラート受信記録（D-09）
T-07	ログファイル整合性検証（LR-04）	検証環境・本番環境	対象期間・対象アカウント・対象リージョンを指定し、 validate-logs を 配信元の保存場所に対して 実行する（表8-3のCT-07）。 validate-logs はリージョン固有のコマンドであり、 --region で指定したリージョンのダイジェストのみを検証するため、記録対象の全リージョン分（グローバルサービスイベントが記録される us-east-1 を含む）について繰り返し実行する。組織の証跡では --account-id が必須であり、1回の実行は指定した1アカウント分のみを検証するため、対象アカウントと対象リージョンの全組合せについて実行し、出力の S3 パスにより意図したアカウント・リージョンのダイジェストが検証されたことを確認する。実行方法は実施前に公式ドキュメントで確認すること	指定した全リージョン・全対象アカウントについてダイジェストチェーンが連続し、ダイジェストに参照される全ログファイルが valid と判定される。ダイジェストに参照されないファイルは検証対象外であること、ログファイル整合性検証を有効化した以降の期間のみ検証できること、手元にコピーしたファイルでは検証できないことを手順書に明記している	実行コマンド全文と出力、対象証跡・対象リージョン一覧・期間・実行者・実行日時（D-09）

ID	観点	実施環境	手順概要	期待結果	証跡
T-08	保持期間設定 (LR-05)	検証環境・本番環境	全保存先の保持設定（保持日数、ライフサイクル、保持期間の設定）を取得し、D-01 に記載された発注者決定値と突合する（第7章は推奨値の出典であり、判定基準ではない）。AWS Config については、Config 自身のデータストアの保持期間と、S3 へ配信された設定履歴・スナップショットの保存期間の双方を確認する	すべて決定値と一致する。無期限保持のまま残っている保存先がない。 describe-log-groups の応答は保持ポリシー未設定のロググループでは retentionInDays フィールド自体が返らないため、フィールドの欠落を「無期限保持」と判定している	設定取得出力、全ロググループについて retentionInDays の有無と値を列挙した保持期間突合表（無期限となっている保存先が設計上の意図であるかを個別に確認した結果を含む）、Config 側と S3 側の保持期間突合表 (D-10・D-09)
T-09	暗号化と復号権限 (LR-07)	検証環境・本番環境	保存先の暗号化方式とキーポリシーを取得する。暗号化指定なしの書き込みと非 TLS 操作を試行する（表8-3 の CT-08）。復号権限を持たない主体で読み取りを試行する	全保存先が指定した鍵で暗号化されている。暗号化指定なしの書き込みと非 TLS 操作は拒否される。復号権限のない主体は内容を取得できない	設定取得出力、実行コマンドと出力 (D-10・D-09)
T-10	アラート発報と通知到達 (LR-08)	検証環境（通知先の購読状態確認とテスト通知は本番環境）	D-06 の全アラートについて、検知対象事象を検証環境で発生させる。あわせて本番環境の通知先の購読状態を確認し、テスト通知を送信する	定義した通知先に対応期限内に到達し、通知内容から対象・時刻・実行者が判別できる。未確認・失効した通知先がない	事象の発生手順、通知本文と受信日時、購読状態の取得結果 (D-09)
T-11	欠損検知 (LR-11)	検証環境	検証環境でログ配信を意図的に失敗させる（配信先の権限誤りの再現、エージェント停止等）	D-01 に定めた時間内に欠損として検知・通知される。復旧後、欠損した期間を特定して記録できる	事象の再現手順、検知通知、配信状況の取得結果、欠損期間の記録 (D-09)
T-12	検索・抽出 (LR-10、監査想定クエリ)	本番環境	D-08 のクエリ集を用い、指定期間について「特権利用」「ログイン失敗」「権限変更」「特定利用者の全操作」「特定伝票の処理経路」を抽出する	監査人が求める期間・粒度の結果が得られ、所要時間とコストが D-08 の見積り内に収まる。結果が0件の場合も0件であることを示せる	クエリ本文、実行日時と実行者、結果ファイル、実行時間の記録 (D-09・D-08)

ID	観点	実施環境	手順概要	期待結果	証跡
T-13	アーカイブからの復元 (LR-11)	検証環境	長期保存クラスを直接指定して書き込んだ検証用オブジェクト、または長期保存クラスへ移行済みのログを復元し、内容を確認する（ライフサイクルの移行日数の経過を待たずに実測できるようにする）。復元要求から取り出し可能になるまでの時間を計測し、復元対象の保管クラスと取り出しオプション（迅速／標準／大容量の別）、復元後に参照可能な期間を記録する	所要時間が D-08 の見積り範囲内に収まり、内容が破損なく参照できる。取り出しに時間を要すること自体は仕様であり、監査対応の所要時間として手順書に明記されている	復元要求と完了の記録、保管クラスと取り出しオプションの別、取得した内容の確認結果（D-09）
T-14	権限テスト：開発者 (LR-06)	検証環境・本番環境	開発者ロールで、ログの削除・上書き、保持期間の変更、ログ設定の変更、暗号鍵の無効化・削除予約を試行する	すべて拒否される。開発者ロールに、ログを消せる経路・記録を止められる経路が存在しない	実行コマンドと出力、開発者ロールの権限取得結果（D-09）
T-15	権限テスト：監査人ロール (LR-06、R-6)	検証環境・本番環境	監査人ロール（R-6）で、D-01 に定めた参照経路によりログの参照・抽出を行い、続けて書き込み・削除・設定変更を試行する	参照と抽出は成功し、書き込み・削除・設定変更はすべて拒否される。D-01 に定めた参照経路で行った参照操作が記録される	実行コマンドと出力、参照経路の特定、監査人ロールの操作記録の抽出結果（D-09）
T-16	レビュー手順のリハーサル (LR-09)	本番環境	D-07 に従い、運用主体（R-4・R-5）が実データで各レビューを1サイクル実施し、開発ベンダーが立ち会う	手順書のみで完遂でき、記録様式に実施者・実施日・母集団・確認結果・承認が記録される。所要時間が手順書の見積り内である	記入済みのレビュー記録、立会い記録、手順書の是正内容（D-09・D-07）

ID	観点	実施環境	手順概要	期待結果	証跡
T-17	新規アカウント・リソースの自動包含 (LR-01)	検証環境	検証用の新規アカウントおよび新規リソース（インスタンス、ロググループ、データベース）を作成し、D-02 に記載した包含方式のとおりログが集約されるか確認する	(a) 組織の証跡による L-01 は、新規アカウント・新規リージョン・新規リソースに追加設定なしで適用され、当該アカウント側で停止・変更できない。組織単位で展開した AWS Config による L-03 は、新規アカウントへ自動展開され、新規リージョンが展開対象に含まれ、かつ SCP により停止・削除・配信チャネルの変更が拒否されている (T-06) ことをもって同等とみなす。(b) リソース単位の有効化を要する記録 (OS 監査ログ L-05 のエージェント導入、データベース監査ログ L-06 のパラメータグループ／オプショングループとログのエクスポート設定 (RDS for Db2 は DB2_AUDIT オプション。データベースごとの監査ポリシーは、データベース作成手順への組み込みと設定状態の定期確認による未設定検出で代替する)、ネットワーク通信ログ L-11 等) は、標準AMI・起動テンプレート・既定パラメータグループ・StackSets・ランディングゾーン・IaC モジュール等によりリソース作成時に自動適用され、かつ未適用のリソースを検出する仕組みが機能する。(a) について個々のアカウントの任意設定に依存する構成は不合格とする	新規作成の記録、当該アカウントのログ出力、記録設定の取得結果、未適用検出の動作記録 (D-09)
T-18	機微情報の非出力 (LR-07)	検証環境・本番環境	パスワード・トークン・口座番号等の項目に、実在しない一意の試験用文字列を入力して業務操作と運用操作（サーバ操作を含む）を行い、全保存先を対象に当該文字列を検索する。本番環境では実在の資格情報・口座番号を用いない	投入した試験用文字列がいずれの保存先にも平文で出現しない。マスク対象項目は置換されており、置換された事実が記録されている	投入した項目名と投入方法の一覧（値そのものは記録しない）、検索クエリと結果（0件）(D-09)

11.6 設定証跡の取得方法

必須 設定証跡 (D-10) は、**実環境の設定を、再現可能な手段で、取得日時・取得者とともに取得すること**。設計書に書かれた設定値は「そう設計した」ことの証拠にすぎず、実環境がそうなっていることの証拠にはならない。監査人が確認するのは実環境の状態であり、設計書と実環境の突合こそが証跡である。

11.6.1 CLI による設定取得

必須 設定の取得は、各サービスの `describe-*`／`get-*`／`list-*` 系コマンドの出力を機械可読形式 (JSON・CSV) で保存する方法を第一とすること。取得対象は D-05 の全項目とし、取得漏れがないよう取得スクリプトを

D-04 に含めて版管理すること。コマンド名とオプションはサービスの更新により変わり得るため、実行前に公式ドキュメントで確認すること。

必須 次のサンプルは単一アカウント・単一リージョンでの取得例である。D-10 は対象の全アカウント・全リージョン分を網羅すること。とくに IAM・STS・CloudFront のグローバルサービスイベントは us-east-1 に記録されるため、us-east-1 を必ず取得対象に含める。取得スクリプトは対象アカウント・リージョンを反復し、取得できなかった組合せは索引に理由とともに記録すること。

```

# 証跡の稼働状態と配信状況（配信エラーの有無を含む）
aws cloudtrail get-trail-status --region ap-northeast-1 \
  --name "arn:aws:cloudtrail:ap-northeast-1:111122223333:trail/org-trail" \
  > 20260908_cloudtrail-status_prod-111122223333-ap-northeast-1.json

# ログファイル整合性の検証（配信元の保存場所に対して実行する）
# validate-logs はリージョン固有のコマンドであり、--region で指定した
# リージョンのダイジェストのみを検証する。記録対象の全リージョン分
# （グローバルサービスイベントが記録される us-east-1 を含む）について
# --region を変えて繰り返し実行し、出力の S3 パスで対象リージョンの
# ダイジェストが検証されたことを確認すること。
aws cloudtrail validate-logs \
  --trail-arn "arn:aws:cloudtrail:ap-northeast-1:111122223333:trail/org-trail" \
  --start-time 2026-04-01T00:00:00Z --end-time 2026-06-30T23:59:59Z \
  --account-id 111122223333 --region ap-northeast-1 --verbose \
  > 20260908_validate-logs_prod-111122223333-ap-northeast-1_20260401-20260630.txt

# 保存先の保全設定（バージョニング、Object Lock、ライフサイクル、ポリシー）
aws s3api get-object-lock-configuration --bucket log-archive-prod \
  > 20260908_s3-objectlock_log-archive-prod.json
aws s3api get-bucket-policy --bucket log-archive-prod \
  > 20260908_s3-bucketpolicy_log-archive-prod.json
aws s3api get-bucket-versioning --bucket log-archive-prod \
  > 20260908_s3-versioning_log-archive-prod.json
aws s3api get-bucket-lifecycle-configuration --bucket log-archive-prod \
  > 20260908_s3-lifecycle_log-archive-prod.json

# ロググループの保持日数一覧
# 保持ポリシー未設定のロググループでは retentionInDays フィールド自体が
# 返らない。フィールドの欠落は無期限保持として扱うこと。
aws logs describe-log-groups --region ap-northeast-1 \
  > 20260908_cwlogs-loggroups_prod-ap-northeast-1.json

# Config ルールの評価結果（コンプライアンス状態）の取得（当該アカウント・リージョン）
aws configservice select-resource-config --region ap-northeast-1 \
  --expression "SELECT resourceId, configuration.complianceType \
WHERE resourceType = 'AWS::Config::ResourceCompliance'" \
  > 20260908_config-compliance_prod-111122223333-ap-northeast-1.json

# 複数アカウントを横断して取得する場合はアグリゲータを指定する
aws configservice select-aggregate-resource-config \
  --configuration-aggregator-name org-log-aggregator \
  --expression "SELECT accountId, awsRegion, resourceId, resourceType" \
  > 20260908_config-aggregate_prod-org.json

# 特定リソースの構成履歴（変更の前後を示す）
aws configservice get-resource-config-history \
  --resource-type AWS::S3::Bucket --resource-id log-archive-prod \
  --region ap-northeast-1 > 20260908_config-history_log-archive-prod.json

# IAM ユーザの認証情報状態（生成は非同期。State が完了するまで待機して取得する）
aws iam generate-credential-report
aws iam get-credential-report --query 'GeneratedTime' --output text \
  > 20260908_credential-report-generatedtime_prod-111122223333.txt
aws iam get-credential-report --query 'Content' --output text \
  | base64 --decode > 20260908_credential-report_prod-111122223333.csv

# IAM ロールと付与されたポリシー
aws iam get-role --role-name LogArchiveAuditorRole \
  > 20260908_iam-role_prod-LogArchiveAuditorRole.json
aws iam list-attached-role-policies --role-name LogArchiveAuditorRole \
  > 20260908_iam-rolepolicies_prod-LogArchiveAuditorRole.json
# インラインポリシーは list-attached-role-policies に含まれないため別途取得する

```

```
aws iam list-role-policies --role-name LogArchiveAuditorRole \
  > 20260908_iam-inlinepolicies_prod-LogArchiveAuditorRole.json
aws iam get-role-policy --role-name LogArchiveAuditorRole \
  --policy-name <インラインポリシー名> \
  > 20260908_iam-inlinepolicy_prod-LogArchiveAuditorRole.json

# IAM Identity Center の許可セットと割当て
aws sso-admin list-permission-sets \
  --instance-arn "arn:aws:sso::instance/ssoins-1234567890abcdef" \
  > 20260908_idc-permissionsets_prod-org.json
aws sso-admin list-account-assignments \
  --instance-arn "arn:aws:sso::instance/ssoins-1234567890abcdef" \
  --account-id 111122223333 \
  --permission-set-arn "arn:aws:sso::permissionSet/ssoins-1234567890abcdef/ps-1234567890abcdef" \
  > 20260908_idc-assignments_prod-111122223333.json

# SCP とキーポリシー
aws organizations list-policies --filter SERVICE_CONTROL_POLICY \
  > 20260908_scp-list_prod-org.json
aws organizations describe-policy --policy-id <ポリシーID> \
  > 20260908_scp-body_<ポリシーID>.json
aws organizations list-targets-for-policy --policy-id <ポリシーID> \
  > 20260908_scp-targets_<ポリシーID>.json
aws kms get-key-policy --policy-name default --region ap-northeast-1 \
  --key-id "arn:aws:kms:ap-northeast-1:111122223333:key/1234abcd-12ab-34cd-56ef-1234567890ab" \
  > 20260908_kms-keypolicy_prod-111122223333-ap-northeast-1-log-archive-key.json
```

必須 IAM 認証情報レポートの生成は非同期であり、かつレポートは4時間に1回しか再生成されない。`generate-credential-report` は生成状態（State）を返すだけで、直後に `get-credential-report` を実行すると、生成が完了していないか、直近4時間以内に生成された古いレポートが返る。State が完了となるまで待機してから取得し、`get-credential-report` の応答に含まれる `GeneratedTime` を D-10 の索引に記録して、コマンド実行時刻ではなく**レポート生成時刻**を証跡の基準時点とすること。

必須 認証情報レポートの対象はルートユーザーと IAM ユーザーの、パスワード・利用者あたり最初の2つのアクセスキー・MFA デバイス・X.509 署名証明書に限られ、IAM ロール、IAM Identity Center の許可セット、SCP、バケットポリシー、キーポリシーは含まれない。LR-06 が求める実際の権限の証跡としては不足するため、上記サンプルのとおりロール、許可セットと割当て、SCP、バケットポリシー、キーポリシーを個別に取得して補うこと。

11.6.2 構成履歴・スナップショットの利用

推奨 「評価基準日時点の設定がどうであったか」を後から示す必要がある場合、その時点で取得した CLI 出力に加えて、AWS Config の設定履歴・設定スナップショットを証跡とすること。設定履歴はリソースタイプごとに一定間隔で保存先へ配信され、スナップショットは配信頻度の設定に従って配信される。配信頻度の設定値と、その頻度で評価基準日をまたぐ設定変更を捕捉できるかは D-05 に記載すること。

必須 AWS Config 自身のデータストアにおける設定項目の保持期間は 30日～2,557日（約7年）で、既定は 2,557日である。発注者が決定した保存期間がこれを超える場合、Config の保持期間設定だけでは要求を満たせないため、S3 へ配信される設定履歴・設定スナップショットファイル側の保存期間（ライフサイクル、Object Lock）で担保すること。Config の保持期間設定は、S3 および SNS へ配信済みのデータには適用されない。両者の保持期間と役割分担を D-01・D-05 に記載し、T-08 では Config 側と S3 側の双方を確認すること。

11.6.3 IaC のコミットハッシュ

必須 本番に適用された IaC について、リポジトリ、ブランチ、**コミットハッシュ**、適用日時、適用実行者、パイプライン実行 ID を D-10 に記録すること。IaC の内容そのものは「そう適用したはずだ」という証拠にとどまるため、必ず 11.6.1 の実環境からの取得結果と突合し、突合結果を証拠とすること。差異があった場合は、差異の内容・原因・是正内容を記録すること（手動変更が残っていた場合は LR-12 の不備として扱う）。

11.6.4 画面キャプチャの扱い

必須 画面キャプチャは**補助的な証拠**とし、主たる証拠にしないこと。再取得できず、範囲を任意に切り取れ、加工の有無を検証できないためである。CLI で取得できない事項（通知の受信画面、コンソールでしか表示されない状態）に限って使用し、次を満たすこと。

- 取得日時、取得者、対象アカウント・リージョン、画面名が画面内またはファイル内に含まれること。
- 該当箇所のみを切り抜かず、対象を特定できる情報（アカウント、リソース名）が写った状態で取得すること。
- 機微情報が写り込む場合はマスクし、マスクした事実と理由を索引に記載すること。それ以外の加工を行わないこと。

11.6.5 証拠ファイルの命名と保存先

必須 証拠ファイルは YYYYMMDD_対象_スコープ[_期間].拡張子 の形式で命名すること。各要素は次のとおりとし、区切り文字はアンダースコアとする。

- YYYYMMDD（必須）— 取得日。UTC 基準とする場合はその旨を索引に記載する。
- 対象（必須）— 取得した設定の対象を示す語（cloudtrail-status、validate-logs、credential-report 等）。
- スコープ（必須）— 環境名、アカウントID、リージョン、リソース名など、取得範囲を一意に特定できる識別子。複数を用いる場合はハイフンで連結する（例 prod-111122223333-ap-northeast-1）。
- 期間（任意）— 対象期間を含める場合に付す。会計年度と暦年の取り違えを避けるため、YYYYMMDD-YYYYMMDD の開始日・終了日で表記し、「2026Q1」のような四半期表記を用いない。

保存先は発注者が指定する領域とし、テストID（T-xx）または受入チェック項目ごとにフォルダを分けること。

必須 D-10 には索引ファイルを必ず添えること。索引には、ファイル名、上記各要素の意味、取得日時、取得者、実行コマンド全文、対象アカウント・リージョン、対応する T-xx または表11-4 の項目、備考（取得できなかった項目とその理由）を記載すること。索引のない証拠の束は、監査人にとって何を示す資料か判別できず、証拠として機能しない。

11.7 受入チェックリスト

発注者は表11-4 により受入を判定する。**必須** 開発ベンダーは D-12 として各項目に回答し、根拠となる成果物 ID と証拠ファイル名を記載すること。確認方法欄に示す成果物・証拠が存在しない項目は不合格とする。合格しない項目がある場合、発注者は是正を求め、または残存リスクとして受容する旨を記録に残す。

表11-4 受入チェックリスト

項目	確認方法	結果
LR-01 対象範囲の特定と網羅性	D-02 の全行と T-02 の突合表を照合する。非適用とした L-xx の理由が発注者の承認を得ている。T-17 により、組織単位で強制できる記録が新規アカウント・リソースに追加設定なしで適用され、リソース単位の有効化を要する記録が構成自動化により適用され未適用を検出できることを確認する	☐
LR-02 記録項目 (5W1H)	D-01 の記録項目定義と T-01 の項目突合表を照合する。承認・金額変更について変更前後の値が記録されている	☐
LR-03 時刻同期とタイムスタンプ	T-03 の時刻突合表と時刻同期状態の取得出力を確認する。全ログの時刻表記が UTC 基準に統一され、現地時刻との対応が D-01 に記載されている	☐
LR-04 改ざん防止と完全性の保証	T-04～T-07 の結果を確認する。削除・保持期限短縮・記録停止がいずれも拒否され、対象期間について記録対象の全リージョン（us-east-1 を含む）の整合性検証が valid である。拒否イベントが記録されている	☐
LR-05 保存期間とライフサイクル	T-08 の保持期間突合表を、D-01 に記載された発注者決定値と照合する。実設定値で確認すること（cw-loggroup-retention-period-check は「無期限」を適合と判定するため、当該ルールの結果のみで保持期間の妥当性を判定しないこと）。retentionInDays フィールドが返らないロググループが無期限保持として扱われている。AWS Config は Config 側と S3 側の双方の保持期間が確認されている	☐
LR-06 ログへのアクセス制御と職務分掌	T-14・T-15 の結果と、D-01 のアクセス制御の記述および実際の権限取得結果（ロール、許可セットと割当て、SCP、バケットポリシー、キーポリシーを含む）を照合する。ログを削除できる主体が存在しない、または限定され補完統制がある	☐
LR-07 暗号化と機微情報の保護	T-09・T-18 の結果と、キーポリシー・暗号化設定の取得出力を確認する。マスキング対象一覧と保持する項目の一覧が承認されている	☐
LR-08 監視とアラート	D-06 の全アラートについて T-10 の発報・受信記録を確認する。通知先に未確認・失効がなく、対応時限と初動対応が定義されている	☐
LR-09 定期レビューと証跡化	D-07 と T-16 の記入済みレビュー記録を確認する。実施者と承認者が分離され、母集団と抽出方法が記録様式に含まれている	☐
LR-10 検索・抽出（監査対応）	D-08 と T-12 の結果を確認する。監査人の想定依頼に対する抽出結果と、所要時間・コストの実測値が記録されている	☐
LR-11 バックアップ・可用性・欠損検知	T-11・T-13 の結果を確認する。欠損が検知・通知され、欠損期間を特定でき、アーカイブからの復元手順と、保管クラス・取り出しオプション別の所要時間が実測されている	☐
LR-12 ログ設定の変更管理	D-04 と D-10 の突合結果（IaC と実環境の一致）、11.8 の変更手続の合意文書、設定変更が L-14 に記録されることの確認結果を照合する	☐
LR-13 外部委託と責任分界	D-01 の責任分担章を確認する。R-1～R-6 と運用ベンダーの担当が特定され、AWS の責任共有モデル上の分界と、AWS 側統制の確認手段が記載されている	☐
LR-14 文書化（ログ設計書・運用手順書）	D-01・D-05・D-07・D-08・D-11 を受領し、版数・作成日・作成者・承認者・改訂履歴が記載されていることを確認する	☐
成果物の一貫性	D-01～D-12 が提出され、相互参照（D-xx、LR-xx、L-xx、A-xx、RV-xx、CT-xx、T-xx）と版数が一致していることを確認する。D-13・D-14 は採否の判断結果が記録されている	☐
テストの完了	D-09 に T-01～T-18 の全項目があり、実施環境欄の指定に従って実施され、不合格のまま残っている項目がない。是正した項目は再試験の結果が記録されている	☐

項目	確認方法	結果
運用引継ぎの完了	11.8の引継ぎ完了条件をすべて満たしていることを確認する。既知の制約と代替統制がD-11に記載され、発注者が受容している	☐

11.8 運用引継ぎと保守中の責任

11.8.1 引継ぎ完了条件

必須 運用引継ぎは、成果物の提出をもって完了とせず、次の条件をすべて満たしたことををもって完了とする。充足の確認結果は発注者と開発ベンダーの双方が記録すること。

- D-01～D-12 が最新版で提出され、記載内容が実環境と一致していること。差異がある場合は、実環境からの再取得（11.6）により解消し、突合結果を残していること。
- 表11-3 の T-01～T-18 が、実施環境欄の指定に従って実施され、すべて合格していること。残存する技術的制約（例として、特定の接続方式ではサーバ操作のセッション記録が取得できない、といった制約）はD-11に既知の制約として明記し、代替統制（接続方式自体の禁止、API 記録による代替、レビューでの補完）を発注者と合意していること。
- 運用者（R-4）とログ管理者（R-5）が、D-07 のレビューと D-08 の監査対応を、開発ベンダーの立会いのもとで各1サイクル完遂していること（T-16）。手順書の不足箇所は反映済みであること。
- アラートの通知先が引継ぎ後の運用体制の宛先に更新され、到達確認が済んでいること。開発ベンダーの連絡先のみが登録されている状態で引き渡さないこと。
- 開発ベンダーがログ基盤に対して保持していた権限が、保守に必要な範囲まで縮小または削除され、その実施がL-01に記載されていること。削除しない権限がある場合、その一覧・理由・有効期限・棚卸方法がD-11に記載されていること。
- 発注者が表11-4の全項目を確認済みであること。

11.8.2 保守契約期間中のログ設定変更の手続

必須 保守期間中のログ設定の変更は、業務機能の変更を伴わない場合であってもLR-12の変更管理の対象とすること。「設定変更だけだから」という理由で手続を省略した変更が、後から統制の空白として発見されることがある。

- **必須** 変更はD-04のIaCを通じて行い、コンソール・CLIからの直接変更を行わないこと。緊急対応でやむを得ず直接変更した場合は、発注者に即時報告し、あらかじめ定めた期限内にIaCへ反映して差異を解消し、その記録を残すこと。
- **必須** 申請・承認・適用・確認を分離し、適用者と承認者を同一人とししないこと。承認者には発注者側の役割（R-2またはR-1）を含めること。
- **必須** ログの取得停止、保存期間の短縮、記録範囲の縮小、出力項目の削減、アラートの無効化は、R-1の承認なしに行わないこと。これらは統制水準を下げる変更であり、コスト削減や運用簡素化を理由に運用者の判断で実施しないこと。
- **必須** 変更後はD-05とD-10を更新し、影響する表11-3のテストを再実施すること。保存期間・暗号化・アクセス制御・改ざん防止・アラートに影響する変更については再実施を必須とする。
- **推奨** 変更が第6章のアーキテクチャまたは第7章の保存期間に影響する場合は、監査人への説明の可否を発注者と協議すること。評価対象期間の途中で統制の内容が変わると、変更前後それぞれの期間について評価が必

要になり得る。

● 注意

内部統制の評価時点は期末日である。期中に発見した不備は、是正後の統制が期末日までに十分な期間運用されれば有効と評価され得るため、**発見の時点で速やかに発注者（R-1・R-2）に報告すること**。一方、**期末日後に実施した是正措置は、期末日時点の評価には影響しない**とされている（ただし、内部統制報告書の提出日までに実施した是正措置は、その内容を内部統制報告書に付記事項として記載できるとされている）。したがって、保守期間中にログの欠落、記録の停止、アラートの不動作を発見した場合、**報告の遅れは、発注者が期中に是正または代替手続を実施する機会そのものを奪う**。報告にあたっては、欠落した期間、原因、影響範囲、代替して確認できる記録の有無を提示すること。報告の経路と時限は D-11 に定め、引継ぎ時に合意しておくこと。

11.8.3 脆弱性・仕様変更への追随

必須 開発ベンダーは、保守契約の範囲内で次の変化を継続的に確認し、ログ取得に影響する事項を発注者に報告すること。報告の頻度は契約で定め、少なくとも年1回の定期報告と、重大な変更を把握した時点での随時報告とすること。

- **AWS サービスの仕様変更**— 機能の提供終了、新規利用の受付停止、既定値の変更、記録項目の追加・変更、新リージョンの追加。設計が依存しているサービスに提供形態の変更があった場合は、代替方式への移行計画（移行先、時期、コスト、移行期間中の記録の連続性）を提示し、実施の要否を発注者と協議すること。AWS サービスには提供形態が変更され、新規利用の受付が終了する場合があるため、設計時点で選択したサービス（とくにログの分析・可視化に用いるマネージドサービス）が将来も新規に利用可能である前提を置かず、設計時および定期報告時にサービスの提供状況を確認すること。
- **対象範囲の拡大**— 新規アカウント、新規リージョン、新規サービス、新規リソースの追加。追加のつど D-02 を更新し、T-17 に相当する確認（組織単位で強制できる記録が追加設定なしに記録対象へ含まれること、リソース単位の有効化を要する記録が構成自動化により適用され未適用を検出できること）を実施すること。
- **アプリケーションの改修**— L-07・L-08・L-09 の出力項目、マスキング対象、関連 ID の伝播経路に変更が生じる改修を行う場合は、D-01 を**同一の変更単位で**更新すること。設計書を後日まとめて更新する運用は、設計と実装の乖離を生み、整備状況の評価において不備と評価される可能性がある。
- **脆弱性・セキュリティ勧告**— ログ収集エージェント、ログ転送経路、分析基盤に関する脆弱性情報を受領した場合の連絡経路、影響評価の担当、対応時限を D-11 に定めること。ログ基盤の停止を伴う対応が必要な場合は、停止期間を欠損期間として記録し、発注者に報告すること。

推奨 上記の確認と報告は、保守契約の作業項目として明記し、費用と工数を見積りに含めること。契約に定めのない善意の対応に依存すると、担当者の交代とともに確認が途絶える。委託業務に係る統制の重要性は制度上も増しており、発注者は委託先の統制状況を把握・評価する責任を負う。開発ベンダーは、報告を「発注者が自社の内部統制を評価するために必要な入力」として位置づけること。

12

監査対応 — 証跡の抽出と提出

本章は、監査人（R-6）からの依頼に対して、保全したログから証跡を抽出し、提出するまでの手続を定める。第4章・第5章がログを「取得・保全できる状態」にし、第8章がその「改変されていないこと」を担保するのに対し、本章は「求められたときに、必要な範囲を、説明可能な形で取り出す」ことを扱う。対応する要求事項は LR-10（検索・抽出）を中心に、LR-04（改ざん防止と完全性の保証）、LR-06（ログへのアクセス制御と職務分掌）、LR-09（定期レビューと証跡化）、LR-11（バックアップ・可用性・欠損検知）、LR-14（文書化）である。本章は特定の IT 全般統制の領域に限定されない。ITGC-A（システムの開発、保守に係る管理）、ITGC-B（システムの運用・管理）、ITGC-C（内外からのアクセス管理などシステムの安全性の確保）、ITGC-D（外部委託に関する契約の管理）のいずれについても、その有効性を裏付ける証跡は最終的に本章の手続を通じて提出される。

本章の手続は**母集団の抽出を起点に構成している**。監査人はまず対象期間の母集団一覧の提出を求め、そこからサンプルを指定し、指定されたサンプルについて詳細の提示を求める。したがって開発ベンダーが実装すべきは、個別ログを1件表示する機能ではなく、**期間と条件を指定して母集団を漏れなく一覧化し、その一覧が漏れていないことを説明できる能力**である。12.2 の各依頼類型、12.3 の抽出クエリ、12.4 の提出パッケージは、すべてこの順序に沿って設計されている。

● 補足

本章が扱うのは、発注者の内部統制の評価・監査に必要な証跡である。開発ベンダー自身の内部統制（開発ベンダーが受託会社として評価対象となる場合の証跡）については、「財務報告に係る内部統制の評価及び監査に関する実施基準」（以下「実施基準」。版および適用時期は 12.1.1 に示す）Ⅱ.2(1)② が定める委託業務の評価の枠組みに従い、発注者と協議して別途定める（LR-13、第10章 10.7）。

12.1 監査の流れとタイミング

証跡の依頼は年間を通じて散発的に発生するのではなく、評価・監査の局面ごとにまとまって発生する。開発ベンダーは、どの局面でどの種類の依頼が来るかを理解したうえで、抽出手順と体制を設計すること。

12.1.1 評価・監査の局面

「財務報告に係る内部統制の評価及び監査に関する実施基準」（以下「実施基準」）は、経営者による評価を整備状況の評価と運用状況の評価に分けている。本書が引用するのは、2023年4月7日に改訂され、2024年4月1日以後開始する事業年度における評価及び監査から適用される版である。証跡の性格は局面ごとに異なる。

以下の各局面に付した括弧内の時期は、実務上の一般的な実施時期であり、実施基準が定めた区分ではない。整備状況・運用状況のいずれについても、評価時点は期末日である（実施基準 Ⅱ.3(3)④ハ、Ⅱ.3(5)②）。

- **整備状況の評価（実務上は期首～期中前半に実施されることが多い）**。統制が適切に整備されているかを判断する局面である。実施基準 Ⅱ.3(3)③ は「関連文書の閲覧、従業員等への質問、観察等」による判断としてお

り、依頼の中心はログ設計書と設定証跡（第11章）である。ログ本体は、設定が意図どおり機能していることを確かめるための限定的な抽出にとどまることが多い。抽出件数は監査人の依頼内容による。

- **運用状況の評価（実務上は期中～期末にかけて実施されることが多い）。本章の主対象である。**実施基準 II.3(3)④イは「関連文書の閲覧、当該内部統制に関係する適切な担当者への質問、業務の観察、**内部統制の実施記録の検証**…」により運用状況を確認するとし、④ロは「運用状況の評価の実施に際して、経営者は、原則としてサンプリングにより十分かつ適切な証拠を入手する」とする。依頼は母集団一覧とサンプルの詳細、および運用記録との突合という形をとる。
- **期中評価後の追加手続（実務上いわゆるロールフォワード。期中評価実施後～期末日）。**実施基準 II.3(3)④ハは、評価時点は期末日であるとしたうえで、運用状況の評価を期中に実施した場合において期末日までに内部統制に関する重要な変更があったときは、重要な変更の内容の把握・整理、変更後の内部統制の整備状況の有効性の評価、変更後の運用状況の有効性の評価といった追加手続の実施を検討するとする。依頼は期中評価日以降の差分、すなわち設定変更の有無（L-14、L-03）と変更後期間の再抽出となる。
- **内部統制監査（実務上は期中から期末後にかけて実施される）。**監査人が経営者の評価結果の適正性を監査する。実施基準 III.4(2)①ロ b は、監査人は経営者の評価の実施から期末日までの期間に内部統制に重要な変更があった場合、経営者が追加手続を実施しているか確認するとする。経営者評価と同じ証跡に加え、評価の実施過程そのものの記録が対象となる。
- **期末日後の是正（期末日後～報告書提出日）。**実施基準 II.3(5)②は「内部統制の評価時点は期末日であり、期末日後に実施した是正措置は、期末日における財務報告に係る内部統制の評価には影響しない。ただし、経営者は、内部統制報告書の提出日までに実施した是正措置がある場合は、その内容を内部統制報告書に付記事項として記載できる」とする。是正の実施記録が対象となるが、**当期の評価結果は変わらない。**

● 注意

「ロールフォワード」は実務上広く用いられる呼称であるが、この語自体は基準・実施基準の本文には現れない。該当する要求の実体は上に引用した実施基準 II.3(3)④ハ および III.4(2)①ロ b である。文書や報告で用いる場合は、根拠条項を併記すること。

この局面が開発ベンダーに与える実務上の含意は明確である。**期中評価の後にログ設定を変更すると、変更後期間について評価をやり直す必要が生じ得る。**ログ設定の変更（LR-12）は変更管理の対象であるだけでなく、監査スケジュール上の影響を伴う。期中の設定変更は、発注者のシステム所管（R-2）および内部統制担当（R-1）に事前に通知すること（**必須**）。

12.1.2 依頼経路と役割

証跡の依頼は監査人から直接開発ベンダーに届くのではなく、発注者を經由する。この経路を守るとは、単なる事務手続ではなく統制上の要請である。開発ベンダーが監査人と直接やり取りすると、依頼内容の解釈と抽出範囲の決定が実施者側に委ねられることになり、抽出者が抽出内容を選別できないという前提（第6章 6.6）が崩れる。経路の全体像を図12-1に示す。

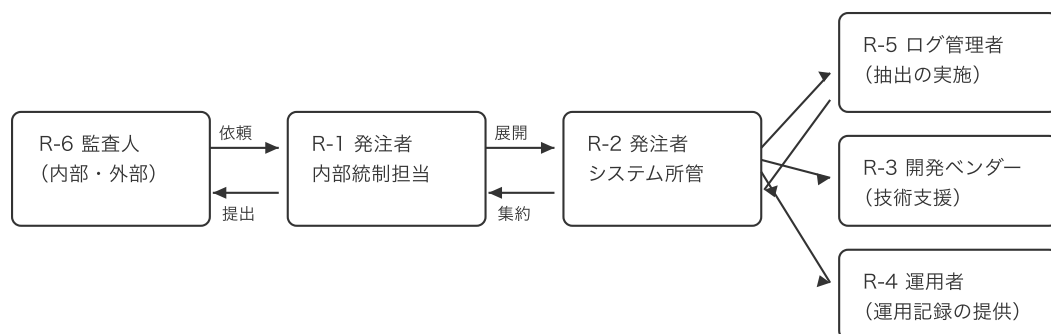


図12-1 証跡依頼の経路と役割分担

各役割の責任は次のとおりである。括弧内は、その役割が行ってはいけない事項を示す。

- **R-6 監査人** — 依頼内容（対象統制、対象期間、母集団の定義、サンプル）を書面で示し、提出物の十分性を判断する。読み取り専用であり、設定変更・データ変更の権限を持たない。
- **R-1 発注者 内部統制担当** — 依頼を受領し、対象システム・対象ログを特定して R-2 へ展開する。提出物を監査人へ引き渡し、提出記録を管理する。経営者による評価（12.1.1）に伴う抽出依頼については R-1 自身が依頼の起点となり、以降の経路は監査人からの依頼と同一である。
- **R-2 発注者 システム所管** — 抽出条件を確定し、R-5 に抽出を指示する。抽出結果の内容を確認し承認する。（抽出条件の確定を開発ベンダーに委ねないこと。）
- **R-5 ログ管理者** — 確定した条件で抽出を実行し、実行記録（12.4）を作成する。完全性の裏付け（`validate-logs` 等）を取得する。（抽出結果から任意に行を除外しないこと。条件を独断で変更しないこと。）
- **R-3 開発ベンダー 開発者** — クエリの作成・検証、ログ構造とフィールドの意味の技術説明、抽出結果の妥当性（なぜこの条件で母集団が網羅されるか）の説明を担う。（発注者の明示的な指示がある場合を除き、監査人と直接やり取りしないこと。統制が有効であるという判断を代弁しないこと。）
- **R-4 運用者（運用ベンダーを含む）** — ログ外の運用記録（申請・承認記録、ジョブ対応記録、レビュー記録）を提供する。（自らが実施した操作の証跡を、自ら選別して提出しないこと。）

必須 抽出の実行は、開発（R-3）および運用（R-4）から独立したログ管理者（R-5）が行うこと。ただし、12.5 に従い期間限定の直接アクセスを付与された監査人（R-6）が自ら照会する場合を除く。いずれの場合も、開発ベンダーは抽出を実行しないこと。開発ベンダーの役割は、クエリの作成と技術説明に限る。この分離は第10章の職務分掌設計に対応する。

必須 依頼受領から提出までの各段階（依頼内容、条件確定、抽出実行、承認、提出）を記録として残し、誰がいつ何を判断したかを追跡可能にすること。

推奨 依頼票の書式を発注者と合意し、対象統制ID、対象期間（タイムゾーンを明記）、母集団の定義、必要な項目、提出期限、提出先を必須記入欄とすること。口頭やチャットのみの依頼を起点としないこと。

12.2 典型的な依頼と対応するログ

表12-1 および表12-2 は、実務上依頼されることの多い証跡と、対応するログ種別・抽出手段・出力形式を示す。第1章 表1-3 が「依頼される証跡とログ種別・要求事項の対応」を示したのに対し、本表は**抽出の実行手段**に踏み込む。「必要なログ」の列は本書のログ種別 ID（L-01～L-14）で示す。

表12-1 典型的な依頼と抽出手段（アクセス管理・変更管理）

依頼例	必要なログ	抽出手段	出力形式
特定期間の特権操作一覧（ルートユーザー使用、管理者ロールによる操作）	L-01、L-04	Amazon Athena（12.3.2 クエリ①④）。直近90日のみなら CloudTrail イベント履歴でも可	CSV（実行記録を添付）
基準日時点のアクセス権一覧（利用者、権限、MFA、最終利用日）	L-04、L-03	IAM 認証情報レポート（12.3.6）、IAM Identity Center の割当一覧（12.3.7）、AWS Config の高度なクエリ（12.3.5）	CSV。基準日を明記
アクセス権の付与・変更・削除の一覧と承認記録との突合	L-04、L-01	Athena（クエリ③）。承認記録は変更管理ツール側から取得し、申請番号で突合	CSV（突合用の共通識別子列を含む）
退職者・異動者のアクセス削除証跡（削除日、実施者、削除までの日数）	L-04、L-01	Athena（DeleteUser、DeleteAccountAssignment、UpdateUser（SCIM による無効化）等）。人事の退職日リストと突合	CSV（対象者ごとに1行）
コンソール認証失敗の発生状況と対応記録	L-04	Athena（クエリ②-a・②-b）。CloudTrail を CloudWatch Logs に配信している場合は CloudWatch Logs Insights（12.3.4）でも可	CSV（集計と明細の2種）
特定利用者・特定要員（委託先要員を含む）の期間内の全操作履歴	L-01、L-05、L-02	Athena（クエリ④）。サーバ操作は Session Manager のセッションログ	CSV（操作一覧）＋セッションログ本文
本番環境への変更一覧と、変更依頼・承認・テスト記録との突合	L-10、L-03、L-01	CI/CD の実行履歴、AWS Config の構成履歴（get-resource-config-history）、Athena	CSV（変更単位ごとに1行、チケット番号を含む）
承認されていない変更が本番に反映されていないこと（構成ドリフト）	L-03、L-10	AWS Config の高度なクエリ、AWS CloudFormation のドリフト検出結果	ドリフト検出結果（JSON/CSV）＋差分の説明
本番データベースへの直接アクセス・直接更新の記録と承認	L-06、L-05、L-02	DB 監査ログ（CloudWatch Logs Insights または Athena。RDS for Db2 は S3 上の監査ログを 5.3.3 で定めた手順で抽出）。接続経路は L-05 と突合	CSV（ステートメント単位）

● 注意

IAM Identity Center において、利用者の無効化・削除がどのイベント名・どの eventSource（identitystore.amazonaws.com か sso-directory.amazonaws.com か）で記録されるかは、ID ソースと連携方式により異なる。AWS が公開している Identity Store API のイベント名は CreateUser / UpdateUser / DeleteUser / CreateGroup / UpdateGroup / DeleteGroup / CreateGroupMembership / DeleteGroupMembership であり、SCIM 連携における利用者の無効化は active 属性の更新として UpdateUser に現れる。コンソール由来の操作は sso-directory.amazonaws.com の別イベントとして記録されることがある。12.3 冒頭の必須事項に従い、対象環境で実際に無効化・削除を実施してイベント名を確認し、確認結果をログ設計書に記載したうえでクエリを確定すること（**必須**）。**当たらないイベント名で抽出すると「0件＝削除証跡なし」という誤った結論に直結する。**

表12-2 典型的な依頼と抽出手段（運用管理・ログ基盤・外部委託）

依頼例	必要なログ	抽出手段	出力形式
ジョブ・バッチの実行結果一覧、異常終了と対応記録	L-08、L-07	CloudWatch Logs Insights（アプリ・バッチのロググループ）。対応記録は運用記録側から取得	CSV（実行単位で1行、実行IDを含む）
データ連携の送受信件数の整合と、不整合発生時の対応	L-09、L-07	CloudWatch Logs Insights（件数サマリの集計）	CSV（連携単位・日次の件数対比）
バックアップ実施記録と復旧テストの記録	L-13	AWS Backup のレポートプランによるジョブレポート（S3 へ自動配信）。API の <code>ListBackupJobs</code> は直近30日分のみを返す点に注意	CSV/JSON（レポートプランの出力）
セキュリティ検知事象と対応記録	L-12、L-11	Amazon GuardDuty の検出結果（12.3.8）、AWS Security Hub	JSON（検出結果）＋対応記録
ログレビューの実施記録と責任者による承認	L-14 および運用記録	第9章で定めるレビュー記録様式（システム外）。レビュー対象の抽出条件と件数はログ側から再現	レビュー記録（様式）＋当該期間の抽出結果
ログの改ざん防止設定が対象期間中有効であったことの証明	L-14、L-03、L-01	AWS Config の構成履歴（証跡・バケット・ロググループの設定推移）、Athena（クエリ⑤＋クエリ⑦）	構成履歴（JSON）＋設定変更が無いことを示す抽出結果
ログに欠損がなく改ざんされていないことの証明	L-01	<code>aws cloudtrail validate-logs</code> （12.4.2）。CloudWatch Logs 側は取り込み件数の連続性で補完	検証コマンドの出力全文（対象期間分）
ログの削除試行・アクセス拒否の発生状況	L-14、L-01	Athena（ <code>errorCode</code> が <code>AccessDenied*</code> のイベント、ログアーカイブ関連リソースを対象）	CSV
外部委託先要員のID一覧・棚卸結果と本番操作記録	L-04、L-05、L-01	12.3.6／12.3.7 の一覧に、委託先要員の識別属性で絞り込みを加える	CSV（要員一覧と操作一覧の2種）
クラウド事業者側の統制に関する保証報告書	—（AWS 提供文書）	AWS Artifact から発注者が取得する	AWS Artifact の提供形式

● 注意

AWS Artifact の文書は、取得時に AWS Artifact の秘密保持契約（NDA）への同意が必要となる場合がある。AWS Artifact の機密扱いの文書を共有できる範囲は、**自社内、規制当局、監査人に限られ、顧客への提示やウェブサイトへの掲載は認められていない**。文書ごとに追加の利用条件（Terms and Conditions）への同意が求められる場合があるため、取得の都度これを確認すること。取得と監査人への提示は**発注者が実施すること**。開発ベンダーが取得・保管・再配布しないこと（**必須**）。ダウンロード後の文書の取扱い（保管・共有範囲）は、同意した秘密保持契約および当該報告書の利用条件に従うこと。

保証報告書を委託業務の評価に用いる場合、経営者は当該報告書等が十分な証拠を提供しているかどうかを検討しなければならない（実施基準 II.2(1)②ロb）。対象期間が評価対象期間を包含しているか、対象範囲に本システムが利用する AWS サービス・リージョンが含まれるか、委託会社の相補的な内部統制（本書では発注者側で整備すべき内部統制）が満たされているかを発注者が確認すること。開発ベンダーは、本システムが利用する AWS サービスとリージョンの一覧を提供してこの確認を支援すること（**必須**）。

● 監査の視点

表12-1・表12-2の依頼のうち、ログだけで完結するものは半分に満たない。「承認記録との突合」「対応記録」「レビュー記録」は、いずれもログの外側にある運用記録である。監査人が確認したいのは「操作があったこと」ではなく「その操作が承認されたものであったこと」であり、両者を結び付ける識別子が無ければ突合そのものが成立しない。第1章 1.8の注意に従い、変更管理チケット番号・申請番号・ジョブ実行IDを、ログ側と運用記録側の双方に記録すること。この設計を怠ると、監査対応のたびに母集団の全件を人手で突き合わせることであり、対応工数と誤りのリスクがともに増大する。

12.3 抽出手順

本節は、表12-1・表12-2の抽出手段を具体的な手順として定める。掲載するテーブル定義・クエリ・コマンドは**実装の出発点**であり、そのまま流用できることを保証するものではない。開発ベンダーは対象環境で実行して結果を検証し、検証結果をログ設計書（第11章）に添付すること（**必須**）。

12.3.1 Amazon Athena のテーブル定義（AWS CloudTrail）

本章では、ログの保管・抽出にかかわる二つのバケットを次のとおり呼び分ける。**ログアーカイブ用バケット**とは、CloudTrail 等が配信したログの原本を保管するバケットをいう。**証跡バケット**とは、抽出結果および監査人への提出パッケージを保管する、原本とは別に設けるバケットをいう（12.4.4）。また、これらを保有するアカウントを本章では**セキュリティアカウント**（第6章のセキュリティアカウント）と呼ぶ。

S3に保全したCloudTrailログをSQLで照会するため、パーティション射影を用いたテーブルを定義する。パーティション射影を用いると `ALTER TABLE ADD PARTITION` によるパーティションの手動追加が不要となり、新しい日付が自動的に検索対象に含まれる。以下は単一アカウント・単一リージョンを対象とする定義である。

```
CREATE EXTERNAL TABLE cloudtrail_logs_pp(
  eventversion STRING,
  useridentity STRUCT<
    type: STRING, principalid: STRING, arn: STRING, accountid: STRING,
    invokedby: STRING, accesskeyid: STRING, username: STRING,
    onbehalf: STRUCT<userid: STRING, identitystorearn: STRING>,
    sessioncontext: STRUCT<
      attributes: STRUCT<mfaauthenticated: STRING, creationdate: STRING>,
      sessionissuer: STRUCT<type: STRING, principalid: STRING, arn: STRING,
        accountid: STRING, username: STRING>,
      ec2roledelivery: STRING,
      webidfederationdata: STRUCT<federatedprovider: STRING,
        attributes: map<string,string>>
    >
  >,
  eventtime STRING, eventsource STRING, eventname STRING, awsregion STRING,
  sourceipaddress STRING, useragent STRING, errorcode STRING, errormessage STRING,
  requestparameters STRING, responseelements STRING, additionaleventdata STRING,
  requestid STRING, eventid STRING, readonly STRING,
  resources ARRAY<STRUCT<arn: STRING, accountid: STRING, type: STRING>>,
  eventtype STRING, apiversion STRING, recipientaccountid STRING,
  serviceeventdetails STRING, sharedeventid STRING, vpcendpointid STRING,
  vpcendpointaccountid STRING, eventcategory STRING,
  addendum STRUCT<reason:STRING, updatedfields:STRING,
    originalrequestid:STRING, originaleventid:STRING>,
  sessioncredentialfromconsole STRING, edgedevicedetails STRING,
  tlsdetails STRUCT<tlsversion:STRING, ciphersuite:STRING,
    clientprovidedhostheader:STRING>
)
PARTITIONED BY (`timestamp` string)
ROW FORMAT SERDE 'org.apache.hive.hcatalog.data.JsonSerDe'
STORED AS INPUTFORMAT 'com.amazon.emr.cloudtrail.CloudTrailInputFormat'
OUTPUTFORMAT 'org.apache.hadoop.hive.ql.io.HiveIgnoreKeyTextOutputFormat'
LOCATION 's3://<ログアーカイブ用バケット名>/AWSLogs/<アカウントID>/CloudTrail/<リージョン>'
TBLPROPERTIES (
  'projection.enabled'='true',
  'projection.timestamp.format'='yyyy/MM/dd',
  'projection.timestamp.interval'='1',
  'projection.timestamp.interval.unit'='DAYS',
  'projection.timestamp.range'='<運用開始日 yyyy/MM/dd>,NOW',
  'projection.timestamp.type'='date',
  'storage.location.template'='
  's3://<ログアーカイブ用バケット名>/AWSLogs/<アカウントID>/CloudTrail/<リージョン>/${timestamp}'
)
```

- **必須** テーブル定義はセキュリティアカウントに置き、IaC で管理すること。テーブル定義の変更は LR-12（ログ設定の変更管理）の対象とする（第6章 6.6）。
- **必須** `projection.timestamp.range` の開始日をログの運用開始日と一致させること。開始日が実際より後になっていると、それ以前の期間が**検索結果に現れないまま「該当なし」と誤って報告される**。この不整合はクエリ側では検知できないため、テーブル作成時と保存期間の設定変更時に確認すること。
- **必須** パーティション列 `timestamp` は S3 のプレフィックス上の日付であり、これは**ログファイルが配信された日付（UTC）**である。イベントの発生時刻 `eventtime` とは一致せず、CloudTrail は平均約5分の遅延で配信するほか、遅延イベントがバックフィルとして後日配信されることがある。したがって**母集団の境界を確定するのは `timestamp` ではなく `eventtime` である**。`timestamp` はスキャン範囲を絞るためだけに用い、対象期間より前後1日以上広く指定したうえで、`eventtime` で期間を確定すること。`timestamp` で絞り込まない場合は全期間がスキャンされ照会コストが増大するため、両方を必ず指定すること。
- **必須** ライフサイクルにより S3 Glacier Flexible Retrieval または S3 Glacier Deep Archive に移行した期間を抽出する場合、Athena は既定で当該オブジェクトを**エラーも警告も返さずに読み飛ばす**。抽出前に、(1) 対象

オブジェクトを S3 Batch Operations 等で復元し（Athena はオブジェクトの復元を代行しない）、(2) テーブルプロパティ `read_restored_glacier_objects` を `true` に設定すること。設定コマンドは `ALTER TABLE cloudtrail_logs_pp SET TBLPROPERTIES ('read_restored_glacier_objects' = 'true')` である。本機能は Athena エンジンバージョン3かつ Apache Hive テーブルでのみ利用できる。復元は対象期間の全オブジェクトに対して必要であり、復元漏れは**エラーを伴わない結果の欠落**として現れる。設定の有無、復元対象の範囲、復元件数と抽出件数の対応を 12.4.1 の実行記録に記載すること。

- **推奨** 組織の証跡（複数アカウント・複数リージョン）を対象とする場合、AWS が文書化している方法はアカウント・リージョン・年月日をパーティション列とし `ALTER TABLE ADD PARTITION` で追加する方式である。パーティション射影でアカウント・リージョンを列挙する方式を採用する場合は、Amazon Athena のパーティション射影に関する公式ドキュメントで構文を検証したうえで採用し、検証結果を記録すること。
- **必須** クエリ結果の出力先バケットを、ログアーカイブ用バケットと分離すること。抽出結果には機微な情報が含まれうる（LR-07）。

12.3.2 代表的な抽出クエリ

以下の①～⑦（②と⑥はそれぞれ $a \cdot b$ に分かれる）を標準クエリとし、第6章 6.6 に従って監査専用ワークグループに名前付きクエリとして登録すること（**必須**）。登録することで、監査人が同一のクエリを再現でき、抽出条件の説明が容易になる。フィールド名は CloudTrail のレコード仕様に基づくが、クエリ自体は本書が構成したものであり、実行前の検証を要する。以下の例はいずれも対象期間を 2026年4月1日 00:00:00 UTC 以上 2026年7月1日 00:00:00 UTC 未満とし、`timestamp` を前後1日広げてスキャン範囲を確保している。


```
-- ① ルートユーザーの使用
SELECT eventtime, eventsource, eventname, awsregion, sourceipaddress, useragent,
       useridentity.sessioncontext.attributes.mfaauthenticated
FROM cloudtrail_logs_pp
WHERE "timestamp" BETWEEN '2026/03/31' AND '2026/07/01'
      AND eventtime >= '2026-04-01T00:00:00Z'
      AND eventtime < '2026-07-01T00:00:00Z'
      AND useridentity.type = 'Root'
      AND useridentity.invokedby IS NULL      -- AWS サービス起因を除外
      AND eventtype <> 'AwsServiceEvent'
ORDER BY eventtime;

-- ②-a コンソール認証の失敗（IAM ユーザー・ルートユーザーのサインイン）
SELECT eventtime, useridentity.type, useridentity.arn, useridentity.username,
       sourceipaddress, errormessage, additionaleventdata
FROM cloudtrail_logs_pp
WHERE "timestamp" BETWEEN '2026/03/31' AND '2026/07/01'
      AND eventtime >= '2026-04-01T00:00:00Z'
      AND eventtime < '2026-07-01T00:00:00Z'
      AND eventsource = 'signin.amazonaws.com'
      AND eventname = 'ConsoleLogin'
      AND json_extract_scalar(responseelements, '$.ConsoleLogin') = 'Failure'
ORDER BY eventtime;

-- ②-b IAM Identity Center 利用環境の認証失敗
SELECT eventtime, useridentity.arn, eventsource, eventname, errorcode, errormessage, serviceeventdetails,
       sourceipaddress
FROM cloudtrail_logs_pp
WHERE "timestamp" BETWEEN '2026/03/31' AND '2026/07/01'
      AND eventtime >= '2026-04-01T00:00:00Z'
      AND eventtime < '2026-07-01T00:00:00Z'
      AND eventname = 'CredentialVerification'
      -- 失敗の判定に用いるフィールド（errorcode/serviceeventdetails 等）と eventsource の値は、
      -- 対象環境で認証失敗を実際に発生させて確認し、確定してから使用する（12.3 冒頭の必須事項）
      AND errorcode IS NOT NULL
ORDER BY eventtime;

-- ③ 利用者・権限の付与／変更／削除（IAM および IAM Identity Center）
SELECT eventtime, useridentity.arn, eventsource, eventname, requestparameters, sourceipaddress
FROM cloudtrail_logs_pp
WHERE "timestamp" BETWEEN '2026/03/31' AND '2026/07/01'
      AND eventtime >= '2026-04-01T00:00:00Z'
      AND eventtime < '2026-07-01T00:00:00Z'
      AND ((eventsource = 'iam.amazonaws.com'
            AND eventname IN ('CreateUser', 'DeleteUser', 'CreateRole', 'DeleteRole',
                              'CreateGroup', 'DeleteGroup', 'AddUserToGroup', 'RemoveUserFromGroup',
                              'CreateAccessKey', 'DeleteAccessKey', 'UpdateAccessKey',
                              'CreateLoginProfile', 'UpdateLoginProfile', 'DeleteLoginProfile',
                              'EnableMFADevice', 'DeactivateMFADevice',
                              'PutUserPolicy', 'DeleteUserPolicy', 'PutRolePolicy', 'DeleteRolePolicy',
                              'PutGroupPolicy', 'DeleteGroupPolicy', 'AttachUserPolicy', 'DetachUserPolicy',
                              'AttachRolePolicy', 'DetachRolePolicy', 'AttachGroupPolicy', 'DetachGroupPolicy',
                              'CreatePolicy', 'DeletePolicy', 'CreatePolicyVersion', 'DeletePolicyVersion',
                              'UpdateAssumeRolePolicy'))
            OR (eventsource = 'sso.amazonaws.com'
                AND eventname IN ('CreateAccountAssignment', 'DeleteAccountAssignment',
                                  'CreatePermissionSet', 'UpdatePermissionSet', 'DeletePermissionSet',
                                  'ProvisionPermissionSet', 'PutInlinePolicyToPermissionSet',
                                  'DeleteInlinePolicyFromPermissionSet', 'AttachManagedPolicyToPermissionSet',
                                  'DetachManagedPolicyFromPermissionSet'))
            OR (eventsource IN ('identitystore.amazonaws.com', 'sso-directory.amazonaws.com')
                AND eventname IN ('CreateUser', 'UpdateUser', 'DeleteUser',
                                  'CreateGroup', 'UpdateGroup', 'DeleteGroup',
```

```

        'CreateGroupMembership','DeleteGroupMembership'))))
ORDER BY eventtime;

-- ④ 特定利用者の操作履歴（ロール引き受け経由を含む）
SELECT eventtime, eventsource, eventname, awsregion, sourceipaddress,
       readonly, errorcode
FROM cloudtrail_logs_pp
WHERE "timestamp" BETWEEN '2026/03/31' AND '2026/07/01'
      AND eventtime >= '2026-04-01T00:00:00Z'
      AND eventtime < '2026-07-01T00:00:00Z'
      AND (useridentity.arn LIKE '%:user/<利用者名>'
           OR useridentity.sessioncontext.sessionissuer.arn LIKE '%:role/<ロール名>')
ORDER BY eventtime;

-- ⑤ CloudTrail / AWS Config の設定変更
SELECT eventtime, useridentity.arn, eventsource, eventname, requestparameters
FROM cloudtrail_logs_pp
WHERE "timestamp" BETWEEN '2026/03/31' AND '2026/07/01'
      AND eventtime >= '2026-04-01T00:00:00Z'
      AND eventtime < '2026-07-01T00:00:00Z'
      AND ((eventsource = 'cloudtrail.amazonaws.com'
            AND eventname IN ('CreateTrail','UpdateTrail','DeleteTrail',
                              'StartLogging','StopLogging','PutEventSelectors'))
           OR (eventsource = 'config.amazonaws.com'
            AND eventname IN ('PutConfigurationRecorder','StopConfigurationRecorder',
                              'DeleteConfigurationRecorder','PutDeliveryChannel',
                              'DeleteDeliveryChannel','PutRetentionConfiguration'))))
ORDER BY eventtime;

-- ⑥-a S3 オブジェクトの削除（データイベントの取得が前提）
SELECT eventtime, useridentity.arn, eventname, requestparameters, sourceipaddress
FROM cloudtrail_logs_pp
WHERE "timestamp" BETWEEN '2026/03/31' AND '2026/07/01'
      AND eventtime >= '2026-04-01T00:00:00Z'
      AND eventtime < '2026-07-01T00:00:00Z'
      AND eventsource = 's3.amazonaws.com'
      AND eventname IN ('DeleteObject','DeleteObjects')
ORDER BY eventtime;

-- ⑥-b S3 バケットの削除（管理イベント。既定で記録される）
SELECT eventtime, useridentity.arn, eventname, requestparameters, sourceipaddress
FROM cloudtrail_logs_pp
WHERE "timestamp" BETWEEN '2026/03/31' AND '2026/07/01'
      AND eventtime >= '2026-04-01T00:00:00Z'
      AND eventtime < '2026-07-01T00:00:00Z'
      AND eventsource = 's3.amazonaws.com'
      AND eventname = 'DeleteBucket'
ORDER BY eventtime;

-- ⑦ ログ保全設定（S3 / CloudWatch Logs）の変更
SELECT eventtime, useridentity.arn, eventsource, eventname, requestparameters, sourceipaddress
FROM cloudtrail_logs_pp
WHERE "timestamp" BETWEEN '2026/03/31' AND '2026/07/01'
      AND eventtime >= '2026-04-01T00:00:00Z'
      AND eventtime < '2026-07-01T00:00:00Z'
      AND ((eventsource = 's3.amazonaws.com'
            AND eventname IN ('PutBucketLifecycleConfiguration','DeleteBucketLifecycle',
                              'PutBucketPolicy','DeleteBucketPolicy','PutBucketVersioning',
                              'PutObjectLockConfiguration','PutBucketReplication',
                              'PutBucketAcl'))
           OR (eventsource = 'logs.amazonaws.com'
            AND eventname IN ('PutRetentionPolicy','DeleteRetentionPolicy','DeleteLogGroup',

```

```
                                'DeleteLogStream','AssociateKmsKey','DisassociateKmsKey'))))  
ORDER BY eventtime;
```

● 注意

クエリ⑥のうち `DeleteObject` / `DeleteObjects` (⑥-a) はデータイベントを取得している場合にのみ結果を返す (`DeleteBucket` (⑥-b) は管理イベントであり既定で記録される)。CloudTrail は既定でデータイベントを記録しないため、取得していない期間について ⑥-a は「削除操作は0件」という結果を返す。これは「オブジェクトの削除が無かった」ことの証明にはならない。データイベントの取得範囲と取得開始日を、抽出結果に必ず併記すること (必須)。同様の注意は、S3 のライフサイクルによる削除・移行にも当てはまる。ライフサイクルによる削除は CloudTrail のオブジェクトレベルログには記録されず、S3 サーバーアクセスログでのみ確認できる。

クエリ⑦は、ログアーカイブ用バケットおよびログ保管先ロググループの保全設定の変更を対象とする。S3 側はアカウント内の全バケットが対象となるため、`requestparameters` に含まれるバケット名で対象バケットに絞り込むこと (必須)。クエリ⑤の対象は `cloudtrail.amazonaws.com` と `config.amazonaws.com` のイベントのみであり、バケット側・ロググループ側の保全設定の変更は含まれない。「改ざん防止設定が対象期間中変更されていないこと」を示すには、⑤と⑦の双方に加えて AWS Config の構成履歴を併せて提出すること (必須)。

クエリ①の `invokedby` と `eventtype` の2行は、CIS AWS Foundations Benchmark が規定するルートユーザー使用の判定条件 (AWS Security Hub CSPM のコントロール CloudWatch.1 と同一) に合わせたものであり、AWS サービスがアカウントに代わって実行したイベントを除外する。除外の要否は監査人の依頼内容に従い、除外した場合はその旨を抽出条件として明記すること。

クエリ②-a は `signin.amazonaws.com` のコンソールサインインのみを対象とする。IAM Identity Center を利用者の認証基盤としている環境では、認証失敗は ②-b が対象とする IAM Identity Center のサインインイベント (`CredentialVerification`) として記録され、②-a では検出されない。どちらの認証経路を対象としたかを 12.4.1 の網羅範囲の限定事項に記載すること (必須)。`errorMessage` は失敗事由の説明のために表示するにとどめ、絞り込み条件としないこと。文字列の完全一致で絞り込むと、MFA 未達・パスワード変更要求等の失敗を取りこぼす。②-b は個々の資格情報の検証結果 (成功／失敗) を記録する `CredentialVerification` のみを対象とする。`CredentialChallenge` はチャレンジの発行、`UserAuthentication` はすべてのチャレンジを完了してサインインに成功した場合にのみ記録されるイベントであり、いずれも失敗の判定には用いない。

コンソールサインインの失敗のうち、利用者名の入力誤りによるものは、CloudTrail 上で利用者名が `HIDDEN_DUE_TO_SECURITY_REASONS` として秘匿される。これらの行は母集団に含まれるが個人に帰属させることができないため、抽出結果には `useridentity.type` と `useridentity.arn` を併せて出力し、秘匿された行が存在する場合はその件数と理由を「読み方の説明」(表12-4)に記載すること (必須)。この件数を差し引いて提出しないこと。

クエリ③は IAM と IAM Identity Center の双方を対象とする。IAM ユーザーのみを利用する環境では `sso.amazonaws.com` 等の条件は結果を返さないため、その旨を注記し、網羅範囲の限定事項 (12.4.1) として記録すること。列挙したイベント名のうち IAM Identity Center 側のものは、環境により記録されるイベント名が異なるため、12.2 の注意に従い実機で確認してから確定すること。

クエリ④の `useridentity.arn` による絞り込みは、ロールを引き受けた後の操作では「ロール ID のみ (利用者名なし)」で記録される場合がある点に注意する。共有ロールを利用している場合は、`sts:SourceIdentity`、`sts:RoleSessionName`、または IAM Identity Center 利用時の `useridentity.onbehalfof.userid` によって個人を特定できる設計になっていることが前提となる (第5章、第10章)。

12.3.3 CloudTrail の簡易抽出と AWS CloudTrail Lake

イベント履歴と lookup-events。直近90日の管理イベントに限れば、コンソールのイベント履歴または `aws cloudtrail lookup-events` で抽出できる。ただし属性フィルタは1つのみ、データイベント・Insights イベント・ネットワークアクティビティイベントは対象外、組織単位の集約は不可、単一アカウント・単一リージョンという制約がある。**90日を超える期間、および複数条件の絞り込みには使用できないため、監査提出の主手段とはしないこと。**

```
aws cloudtrail lookup-events \
  --lookup-attributes AttributeKey=Username,AttributeValue=root \
  --start-time 2026-06-01T00:00:00Z --end-time 2026-07-01T00:00:00Z \
  --region <リージョン>
```

CloudTrail Lake。Lake のイベントデータストアを利用している場合は SQL による照会が可能である。ただし **CloudTrail Lake は 2026年5月31日以降、新規顧客に開放されない**。既存の利用者は継続利用できるが、重要なバグ修正とセキュリティ更新のみが提供される。証跡（Trails）と Insights はこの変更の影響を受けない。したがって**新規の設計では Lake を前提とせず、証跡+S3+Athena を基本構成とすること（必須）**。既存利用者が Lake で抽出する場合の手順を以下に示す。

```
aws cloudtrail start-query \
  --query-statement "SELECT eventTime, eventName, userIdentity.arn, sourceIPAddress
    FROM <イベントデータストアID>
    WHERE eventTime >= timestamp '2026-04-01 00:00:00'
      AND eventTime < timestamp '2026-07-01 00:00:00'
      AND eventSource = 'signin.amazonaws.com'
      AND eventName = 'ConsoleLogin'" \
  --delivery-s3-uri "s3://<結果出力先バケット>"

aws cloudtrail describe-query --query-id <クエリID>
aws cloudtrail get-query-results --query-id <クエリID>
```

Lake のクエリはスキャンしたデータ量に応じて課金されるため、`eventTime` の開始・終了で対象を絞ること。クエリは1時間を超えるとタイムアウトする可能性があり、キャンセルしてもスキャンした分は課金される。

必須 既存利用者であっても、継続サポートの水準はイベントデータストアの種別により異なる。**アカウントレベルのイベントデータストアのみを構成している場合、組織に新たに追加されたメンバーアカウントのイベントは取り込まれない**（取り込むには組織イベントデータストアが必要である）。評価対象期間中にアカウントを追加した場合、当該アカウントの当該期間が母集団から欠落するため、イベントデータストアの種別を確認し、確認結果を網羅範囲の限定事項（表12-3）として記載すること。

任意 既に Lake を利用している環境において、抽出基盤を S3+Athena または CloudWatch へ統合するかどうかは、移行時に失われる期間（下記の補足を参照）、既存の抽出手順の再作成コスト、監査対応中の切替リスクを比較し、発注者と協議して決めること。移行する場合は、移行前後で同一条件の抽出結果が一致することを確認し、その結果を証跡として残すこと。

● 補足

Lake から Amazon CloudWatch へ移行する場合、`aws logs create-import-task` によるインポートが用意されているが、**2023年より前のデータは移行されない**。監査上必要な期間が2023年より前に及ぶ場合は、当該期間を Lake で直接照会するか S3 へ移す必要がある。移行を計画する際は、保存年限（第7章）との整合を先に確認すること。

12.3.4 Amazon CloudWatch Logs Insights（アプリケーション業務ログ等）

L-07（アプリケーション業務ログ）、L-08（ジョブ・バッチ実行ログ）、L-09（データ連携ログ）のように CloudWatch Logs に保管しているログは、Logs Insights で照会する。以下は照会例である。例中の `jobId`、`jobName`、`status`、`exitCode`、`approvalId` 等のフィールド名は説明のための仮のものであり、本書が指定する名称ではない。実際のクエリはアプリケーションのログ形式に依存するため、開発ベンダーがログ設計書（LR-14）に定めた実際のフィールド名に合わせて作成すること。

```
# ジョブの実行結果一覧（実行IDごとの終了状態）
fields @timestamp, jobId, jobName, status, exitCode, message
| filter ispresent(jobId) and (status = "SUCCEEDED" or status = "FAILED")
| sort @timestamp asc

# 異常終了のみを抽出し、件数を日次で集計
fields @timestamp, jobId, jobName, exitCode
| filter status = "FAILED"
| stats count(*) as failures by jobName, bin(1d)

# 承認操作の一覧（業務ログ）
fields @timestamp, userId, action, targetId, approvalId, amount
| filter action = "APPROVE"
| sort @timestamp asc
```

- **必須** Logs Insights のクエリ結果は7日間しか保持されない。監査人への提出物とする場合は、結果を CSV 等に出力して 12.4 の提出パッケージに保全すること。画面のスクリーンショットや結果画面の共有で代替しないこと。
- **必須** 対象データは 2018年11月5日以降のものに限られ、クエリは60分でタイムアウトする。長期間・大量のロググループを対象とする場合は、期間を分割して実行し、分割単位ごとに実行記録を残すこと。
- **必須** CloudWatch Logs のイベントのタイムスタンプは 1970年1月1日 UTC からのミリ秒である。抽出結果に表示する時刻のタイムゾーンを 12.7.3 の規約に従って明記すること。
- **推奨** 監査で繰り返し使用するクエリは保存クエリとして登録し、クエリ名と用途をログ設計書に記載すること。

12.3.5 AWS Config（構成情報と構成履歴）

「基準日時点の設定はどうであったか」「対象期間中に設定が変わっていないか」という依頼には AWS Config を用いる。現在の構成の横断照会には高度なクエリ、特定リソースの推移には構成履歴を用いる。

```
# 高度なクエリ（現在の構成の横断照会）
aws configservice select-resource-config \
  --expression "SELECT resourceId, resourceType, configuration, tags
               WHERE resourceType = 'AWS::S3::Bucket'"

# アグリゲータ経由（複数アカウント・複数リージョンの横断照会）
aws configservice select-aggregate-resource-config \
  --configuration-aggregator-name <アグリゲータ名> \
  --expression "SELECT accountId, COUNT(*) GROUP BY accountId"

# 構成履歴（特定リソースの設定推移）
aws configservice get-resource-config-history \
  --resource-type AWS::CloudTrail::Trail \
  --resource-id <リソースID> --region <リージョン>
```

- **必須** 高度なクエリは SQL の `SELECT` のサブセットであり、`JOIN`、`DISTINCT`、`HAVING`、`UNION` は使用できない。また**削除済みリソースおよび記録対象外リソースは照会できず**、`SELECT *` は上位のスカラー属性のみを返す。基準日時点の状態や削除済みリソースを示す必要がある場合は、`get-resource-config-history` を併用すること。
- **必須** AWS Config が記録できるリソースタイプのすべてが高度なクエリで照会できるわけではなく、また設定項目の一部のフィールドは検索不可である（検索不可フィールドは `SELECT` には指定できるが `WHERE` / `GROUP BY` / `ORDER BY` には使用できない）。抽出前に対象リソースタイプとフィールドが高度なクエリで照会可能かを確認し、照会できないものは網羅範囲の限定事項（表12-3）として明記すること。照会できないリソースタイプについては `get-resource-config-history` または CloudTrail 側の設定変更イベントで補完すること。
- **必須** 高度なクエリは**現在の構成**を返す。「基準日時点」の依頼に対して実行日の結果を提出しないこと。基準日と実行日が異なる場合は、その差と、差の期間に変更が無かったことの根拠（構成履歴または設定変更イベントの不存在）を併せて示すこと。
- **必須** グローバルな IAM リソース（ユーザー・グループ・ロール・カスタマー管理ポリシー）の記録には、記録可能なリージョンの制約がある。記録対象としているリージョンと、記録されていないリソースタイプをログ設計書に明記し、抽出結果の網羅範囲として説明できるようにすること（LR-01）。

12.3.6 IAM 認証情報レポート

基準日時点の IAM ユーザーの一覧（パスワードの有無、MFA の状態、アクセスキーの状態と最終利用日など）は、IAM 認証情報レポートで取得する。CSV 形式で出力され、そのまま監査人へ提出できる形式である。

```
aws iam generate-credential-report
aws iam get-credential-report --output json \
  > credential-report_<基準日>_raw.json # GeneratedTime を含む原本

# GeneratedTime を確認したうえで Content をデコードする
jq -r '.Content' credential-report_<基準日>_raw.json | base64 --decode \
  > credential-report_<基準日>.csv
```

- **必須** IAM は直近4時間以内に生成済みのレポートが存在する場合、`generate-credential-report` を実行しても新規生成せず既存のレポートを返す。したがって取得したレポートは**最大4時間前の状態を示している可能性がある**。応答に含まれる `GeneratedTime` を必ず取得して原本として保全し、表12-3 の実行記録に記載して基準日との差を説明すること。`--query 'Content'` のみを用いて `GeneratedTime` を捨てないこと。
- レポートは**4時間に1回**生成できる。必要な権限は `iam:GenerateCredentialReport` と `iam:GetCredentialReport` である。
- 主な列は `user`、`arn`、`user_creation_time`、`password_enabled`、`password_last_used`、`password_last_changed`、`password_next_rotation`、`mfa_active`、`access_key_1_active`、`access_key_1_last_rotated`、`access_key_1_last_used_date` / `_region` / `_service`、`access_key_2_*`、`cert_1_*`、`cert_2_*`、`additional_credentials_info` である。
- **必須** レポートに含まれる認証情報は、パスワード、MFA、アクセスキー、X.509 証明書である。IAM ユーザーのアクセスキーは1ユーザーあたり2本が上限（引き上げ不可）であり、アクセスキーはレポートで網羅される。一方、**サービス固有の認証情報は含まれないため**、`ListServiceSpecificCredentials` で補完すること。この範囲と補完手段を抽出結果の注記として明示すること。
- **必須** `password_last_used` には 2018年5月3日から同月23日の期間にデータの欠損がある。この期間を含む「未使用アカウントの識別」に用いる場合は、欠損を注記すること。

- **必須** IAM Identity Center を利用している環境では、認証情報レポートは IAM ユーザーのみを対象とし、Identity Center の利用者は含まれない。アクセス権一覧の依頼に対しては、本レポートと Identity Center の割当一覧の双方を提出し、両者の対象範囲の違いを注記すること。

12.3.7 IAM Identity Center の割当一覧

Identity Center には「全アカウント・全利用者の割当を1回で返す API」は用意されていない。したがって割当一覧は、**アカウント×権限セットの二重ループで列挙する方針**をとる。以下の順序で取得し、結果を結合して一覧を作成すること。

```
# 1. インスタンス ARN と ID ストア ID を取得
aws sso-admin list-instances

# 2. 対象アカウントにプロビジョニング済みの権限セットを列挙
aws sso-admin list-permission-sets-provisioned-to-account \
  --instance-arn <インスタンスARN> --account-id <アカウントID>

# 3. 権限セットごとに割当（利用者・グループ）を列挙（1ページ最大100件）
aws sso-admin list-account-assignments \
  --instance-arn <インスタンスARN> --account-id <アカウントID> \
  --permission-set-arn <権限セットARN>

# 4. 利用者・グループの実体とメンバーシップを取得
aws identitystore list-users --identity-store-id <IDストアID>
aws identitystore list-groups --identity-store-id <IDストアID>
aws identitystore list-group-memberships \
  --identity-store-id <IDストアID> --group-id <グループID>

# 5. 権限セットの内容（付与される権限）を取得
aws sso-admin describe-permission-set \
  --instance-arn <インスタンスARN> --permission-set-arn <権限セットARN>
```

- **必須** 手順3はアカウントごと・権限セットごとの実行が必要であり、ページングを伴う。**対象アカウントの一覧が漏れていれば結果も漏れる**。組織のアカウント一覧を起点とし、抽出対象アカウント数と実際に処理したアカウント数を実行記録に記載すること。
- **必須** 手順3・4を組み合わせた一覧化はスクリプトで実施し、そのスクリプトをバージョン管理下に置いて成果物とすること（第11章）。手作業での画面転記を行わないこと。
- **推奨** 特定の利用者・グループを起点に割当を調べる場合は `list-account-assignments-for-principal` が利用できる。ただしこの API は**組織インスタンスの管理アカウントからのみ**実行できる。監査人の読み取り専用ロールでも、セキュリティアカウントに置かれた R-5 でも実行できない点に注意する。管理アカウントで実行できる役割・権限と、その権限付与が第10章の職務分掌とどう整合するかを発注者と合意し、ログ設計書に明記すること。合意できない場合は、手順2～4のループによる列挙で同等の一覧を作成すること。
- **必須** グループ経由の割当は、グループのメンバーシップを展開しなければ「誰が何の権限を持つか」にならない。手順4の展開結果を含めた一覧を作成すること。展開しない一覧は、監査上「アクセス権一覧」として不十分である。

12.3.8 Amazon GuardDuty 検出結果

GuardDuty の**検出結果は90日で保持されなくなる**。監査対象期間が90日を超える場合、事後に取得することはできないため、S3 へのエクスポートを事前に構成しておくことが前提となる（第5章）。

```
# エクスポート先の構成（KMS 暗号化が必須。リージョンごとに設定する）
aws guardduty create-publishing-destination --detector-id <検出機能ID> \
  --destination-type S3 \
  --destination-properties \
    'DestinationArn=arn:aws:s3:::<バケット名>,KmsKeyArn=arn:aws:kms:<リージョン>:<アカウントID>:key/<キーID>'

# 検出結果の一覧と取得（一度に取得できるのは最大50件）
aws guardduty list-findings --detector-id <検出機能ID> \
  --sort-criteria '{"AttributeName":"severity","OrderBy":"DESC"}'
aws guardduty get-findings --detector-id <検出機能ID> --finding-ids <検出結果ID...>
```

- **必須** エクスポートの構成はリージョンごとに必要である。利用している全リージョンで構成されていることを確認し、確認結果を証跡として残すこと（LR-01）。
- **必須** アーカイブ済みの検出結果はエクスポートされない。運用上「対応済み」としてアーカイブする手順を採る場合、アーカイブ前にエクスポートされる構成であることを確認すること。確認できない場合、アーカイブ前に検出結果を保全する手順を運用手順書に定めること。
- S3 上の出力パスは /AWSLogs/<アカウントID>/GuardDuty/<リージョン> である。フォルダは事前に作成しておく必要がある。管理者アカウントで構成した場合、同一リージョンのメンバーアカウントの検出結果も同じ場所に出力される。

12.4 抽出結果の完全性と提出パッケージ

抽出結果そのものは「誰かが何らかの条件で取り出した表」に過ぎない。監査上の証跡として成立させるには、**その表が、改変されていない原本から、指定された条件で、漏れなく取り出されたものであることを説明できなければならない**。本節はそのための記録項目とパッケージ構成を定める。

12.4.1 抽出記録に含める項目

表12-3 抽出1件ごとに記録する項目

項目	内容	取得元
抽出ID	本パッケージ内で一意の識別子。ファイル名にも用いる	採番規約 (12.4.3)
依頼元・依頼日・依頼内容	依頼票の番号、対象統制ID、母集団の定義	依頼票 (12.1.2)
対象期間	開始・終了を秒まで記載し、 タイムゾーンを明記 する（原則 UTC）	依頼票
抽出条件	実行したクエリ文またはコマンドの全文。省略・要約をしない	実行記録
実行ID	Athena のクエリ実行 ID、CloudTrail Lake のクエリ ID 等。クエリ履歴と突合するための鍵	実行結果
実行日時・実行者	実行の日時（UTC）と、実行したログ管理者（R-5）の識別子	実行記録、 CloudTrail
基準日と生成時刻の差	基準日時点の一覧を提出する場合、データの生成時刻（例: IAM 認証情報レポートの GeneratedTime）と基準日との差、およびその差の説明	実行結果 (12.3.6)
件数	抽出結果の行数。0件の場合も「0件」と記載する	実行結果
網羅範囲の限定事項	データイベントの取得開始日、記録対象外のリージョン・リソースタイプ、対象とした認証経路、イベントデータストアの種別、アーカイブ階層からの復元範囲等、母集団が制限される要因	ログ設計書
ハッシュ値	結果ファイルの SHA-256 ハッシュ値	12.4.3
承認者・承認日	内容を確認したシステム所管（R-2）	承認記録
保存先	証跡バケット上のオブジェクトキー	12.4.4

必須 表12-3 の全項目を、抽出1件ごとに記録すること。特に**抽出条件（クエリ文の全文）**と**実行ID**は、抽出者が結果を選別していないことを示す中核であり、省略しないこと。

必須 件数が0件の場合も記録を作成し提出すること。「該当なし」の口頭回答で済ませないこと。0件という事実は、統制が有効に機能していたことの証跡になり得る一方、抽出条件の誤りによる0件と区別できなければ証跡にならない。

12.4.2 完全性の裏付け

抽出結果の完全性は、抽出処理の正しさだけでは示せない。対象期間のログが欠損なく保管されていること（LR-11）と、保管中に改変されていないこと（LR-04）が併せて示されて初めて成立する。CloudTrail のログについては、ログファイルの整合性検証機能で裏付けを取得する。

```
aws cloudtrail validate-logs \
  --trail-arn arn:aws:cloudtrail:<リージョン>:<アカウントID>:trail/<証跡名> \
  --start-time 2026-04-01T00:00:00Z \
  --end-time 2026-07-01T00:00:00Z \
  --region <リージョン> \
  --account-id <アカウントID> \
  --verbose
```

- ハッシュは SHA-256、署名は SHA-256 with RSA である。整合性検証を有効にすると、各ログファイルのハッシュを含むダイジェストファイルが1時間ごとに配信され、各ダイジェストは直前のダイジェストの署名を含む

む連鎖構造をなす。

- **必須** `--region` の指定が必要である。検証はリージョン固有であり、リージョンごとに実行すること。組織の証跡の場合は `--account-id` が必須である。時刻の指定は UTC である。
- **必須** 出力に `valid` 以外の結果が1行でも含まれる場合は、**提出を保留し、直ちに発注者へ報告すること**。原因を特定せずに抽出結果のみを提出しないこと。`INVALID:` で始まるメッセージには `hash value doesn't match`、`not found`、`invalid format`、`signature verification failed`、`has been moved from its original location`、`public key not found for fingerprint ...`、`Unable to load PKCS #1 key with fingerprint ...` があり、**ここに挙げたものが全てとは限らない**。また出力には標準ダイジェスト系列とは別に `(backfill)` 接頭辞の付いたバックフィルダイジェスト系列が含まれることがあり、これも検証対象として全文を保全すること。
- **必須** 検証結果は要約せず、出力全文をパッケージに含めること。「検証済み」という記述だけでは証跡にならない。

● 注意

`validate-logs` は、**ログファイルが CloudTrail の配信元の場所から移動されていないこと**を前提とする。ローカルにダウンロードしたファイルや、別のバケットへコピーしたファイルは検証できない（`INVALID: has been moved from its original location` となる）。また、ダイジェストファイルから参照されないファイルは検証の対象にならない。

この制約は提出パッケージの構成を直接規定する。**ログファイルの原本をログアーカイブ用バケットから取り出して監査人へ渡す運用は採らないこと**（**必須**）。原本はログアーカイブ用バケット上に留置し、提出するのは「抽出結果」と「原本の場所で実行した検証結果」である。監査人が原本自体の検証を求める場合は、12.5 の直接アクセスによって監査人自身に実行してもらうこと。

推奨 CloudTrail 以外のログ（CloudWatch Logs 由来のもの等）には同等の整合性検証機能が無いため、代替として (a) 取り込み件数の日次連続性、(b) ログアーカイブ用バケットの S3 Object Lock 設定と対象期間中の設定変更の不存在（クエリ⑤・⑦および構成履歴）、(c) 削除・変更操作の不存在（L-14）を組み合わせることで示すこと。組み合わせた説明を「完全性の説明書」として1ページにまとめ、パッケージに含めること。

12.4.3 ファイル命名規約とハッシュ値

必須 提出ファイルの命名規約を定め、ファイル名だけで対象・期間・版が識別できるようにすること。規約は発注者と合意し、ログ設計書に記載する。以下は規約の例である。

<抽出ID>_<対象>_<期間開始>-<期間終了>_<TZ>_<版>.<拡張子>
 （基準日時点の一覧は <期間開始>-<期間終了> に代えて <基準日> のみを記載する。
 抽出条件ファイルは結果ファイルと同一の名称に `.query.txt` を付す）

例)

```
AUD2026-018_root-usage_20260401-20260630_UTC_v1.csv
AUD2026-018_root-usage_20260401-20260630_UTC_v1.query.txt
AUD2026-019_iam-changes_20260401-20260630_UTC_v1.csv
AUD2026-020_validate-logs_20260401-20260630_UTC_v1.txt
AUD2026-021_credential-report_20260630_UTC_v1.csv
MANIFEST_AUD2026-Q1_v1.csv
```

必須 ハッシュ値は結果ファイルごとに算出し、マニフェストに記載すること。マニフェスト自身のハッシュ値は、パッケージの外側（提出記録および提出時の連絡）にも記載すること。マニフェスト自身のハッシュ値をパッケージ内にのみ置くと、パッケージ全体が差し替えられた場合に検知できない。

```
# 各ファイルのハッシュ値算出（SHA-256）
sha256sum AUD2026-018_root-usage_20260401-20260630.UTC_v1.csv
shasum -a 256 AUD2026-018_root-usage_20260401-20260630.UTC_v1.csv

# 各ファイルのハッシュ値一覧の生成（マニフェストの元データ。いずれか一方を用いる）
sha256sum AUD2026-*. * > AUD2026-Q1_v1.sha256
shasum -a 256 AUD2026-*. * > AUD2026-Q1_v1.sha256
```

このハッシュ値一覧に、収録ファイルごとの件数・対象期間・抽出IDを付して、表12-4のマニフェスト（MANIFEST_AUD2026-Q1_v1.csv）を作成すること（**必須**）。ハッシュ値一覧そのものをマニフェストとして提出しないこと。

- **必須** 利用できるコマンドは実行環境により異なる。実行環境で用いたコマンドを実行記録に記載すること。
- **必須** ハッシュ値は**抽出直後に算出**し、その後にファイルを編集しないこと。列の並べ替え、書式設定、不要行の削除といった加工を行うと、その時点で「原本から取り出したもの」ではなくなる。加工が必要な場合は、加工前のファイルを原本として保全し、加工後のファイルを別ファイルとして版管理すること。
- **必須** 表計算ソフトで開いて保存し直さないこと。文字コード・数値書式・先頭ゼロの自動変換により内容が変化し、ハッシュ値が一致しなくなる。
- **推奨** ハッシュ値の算出とマニフェスト生成はスクリプト化し、抽出処理の一部として自動実行すること。

12.4.4 提出パッケージの構成と提出記録

表12-4 提出パッケージの構成

構成要素	内容	要求
マニフェスト	収録ファイルの一覧、各ファイルの SHA-256 ハッシュ値、件数、対象期間、抽出ID	必須
抽出結果ファイル	CSV 等。加工前の原本	必須
抽出条件ファイル	実行したクエリ文・コマンドの全文（結果ファイルと1対1）	必須
実行記録	表12-3の項目一式。実行ID、実行者、実行日時、承認者を含む	必須
完全性の裏付け	validate-logs の出力全文、および 12.4.2 の説明書	必須
網羅範囲の説明	対象アカウント・リージョンの一覧、データイベント等の取得開始日、記録対象外の範囲	必須
読み方の説明	列の意味、コード値の対応、時刻のタイムゾーン、空欄の意味、秘匿した行の件数と理由	必須

- **必須** パッケージは証跡バケット（12.3.1に定義した、抽出結果の保管専用バケット）に保存すること。保存先は SSE-KMS で暗号化し、既定のアクセスを R-1/R-2/R-5 に限定すること。監査人（R-6）への読み取り権限は、発注者が承認した場合に限り、12.5の期間限定付与の手順に従って付与すること。証跡バケット自体の保存期間は発注者が決定する（第7章）。
- **必須** 提出記録として、提出日、提出先（監査人の所属と担当。個人名の記録要否は発注者の方針による）、パッケージのマニフェストのハッシュ値、提出手段を残すこと。
- **必須** 抽出結果に個人情報・機微情報が含まれる場合の取扱い（マスキングの要否、提出手段の制限）を発注者と事前に合意すること（LR-07）。合意なくマスキングを施すと、抽出結果の完全性の主張と矛盾する。マスキングを行った場合はその事実と範囲をマニフェストに記載すること。
- **推奨** 再抽出（条件変更や期間追加）は新しい抽出IDを採番し、元のパッケージを削除・上書きしないこと。差し替えではなく追加として管理する。
- **任意** パッケージの受け渡し手段（証跡バケットに対する読み取り権限を監査人へ期間限定で付与する方式、発注者が別の手段で受け渡す方式のいずれを採るか）は、発注者の情報管理方針に従って協議のうえ決めること。

と。いずれの方式でも、提出したパッケージの内容とハッシュ値は発注者側に残すこと。

12.5 監査人への直接アクセス提供

監査人が自ら照会する方式（標準）を採る場合の設計項目は第6章 6.6 の表6-4 に定めた。本節は、その設計を前提とした**監査対応時の運用手順**を定める。

12.5.1 期間限定のアクセス付与

- **必須** 監査人のアクセスは、発注者が管理する IAM Identity Center の利用者として付与し、MFA を必須とすること。開発ベンダー名義のID、共有ID、一時的な IAM ユーザーを経由させないこと。
- **必須** 権限は読み取り専用とし、指定した監査専用ワークグループでの Athena の実行、データカタログの参照、ログアーカイブ用バケットの `GetObject` / `ListBucket`、ログアーカイブ用 KMS キーの `kms:Decrypt`、結果出力先バケットへの書き込みに限定すること。ログ基盤の設定変更権限、財務データへのアクセス権限を含めないこと。
- **必須** 割当は監査期間の開始時に作成し、**終了時に削除すること**。作成・削除は R-5 が実施し、R-1 が承認する。`CreateAccountAssignment` / `DeleteAccountAssignment` のイベントと承認記録を対応付けて保管する。
- **必須** 割当の削除を、監査対応の完了条件（12.6 のチェックリスト）に含めること。**監査終了後に権限が残置されている状態は、それ自体が次期の監査で指摘対象となり得る。**
- **推奨** 割当の期間、対象アカウント、権限セット、利用者を一覧化した「監査アクセス管理表」を維持し、四半期ごとに棚卸すること。

12.5.2 監査人の閲覧も記録される

監査人による照会操作は、他の利用者の操作と同様に記録される。この点を監査人および発注者に事前に説明しておくこと。

表12-5 監査人の操作として記録される主な事象

操作	記録される内容	ログ種別
アクセスポータルへのサインイン	Identity Center のサインインイベント（ <code>CredentialChallenge</code> 、 <code>CredentialVerification</code> 、 <code>UserAuthentication</code> ）。 <code>AuthWorkflowID</code> で一連を相関できる	L-04
ロールの引き受け	<code>AssumeRole</code> 系のイベント。以降の操作は <code>useridentity.onbehalfof.userid</code> 等で個人と対応付ける	L-04、L-01
Athena でのクエリ実行	<code>StartQueryExecution</code> 等の管理イベント。ワークグループのクエリ履歴にもクエリ文と実行IDが残る	L-01
ログアーカイブ用バケットの読み取り	S3 の <code>GetObject</code> 。 データイベントを取得している場合にのみ記録される	L-02
暗号化されたログの復号	AWS KMS の <code>Decrypt</code> / <code>GenerateDataKey</code> 。これらは管理イベントとして記録されるが、 読み取り（Read）に分類されるため、証跡が「書き込みのみ」の設定であれば記録されない	L-01

● 補足

表12-5 の記録は、監査人を監視するためのものではない。目的は二つある。第一に、ログ基盤へのアクセスが例外なく記録される設計であること自体が LR-06（ログへのアクセス制御と職務分掌）の証跡となる。第二に、監査人が実行したクエリの履歴が残ることで、後日「どの範囲を確認したか」を双方が再現できる。なお、監査人自身の監査調書に何を記録するかは監査人が判断する事項であり、本書はクエリ履歴が事後に参照可能な状態を維持することのみを求める。

必須 直接アクセス方式であっても、**経営者評価の証拠として用いる抽出**については、実行者が監査人であるか R-5 であるかを問わず 12.4 の記録を作成すること。実施基準 II.3(7) は経営者の評価手続等の記録・保存について「後日、第三者による検証が可能となるよう、関連する証拠書類を適切に保存する必要がある」としている。一方、監査人が監査手続として実行した照会そのものについては、Athena のクエリ履歴および L-01 の記録により事後に再現できる状態を維持すれば足りる。

推奨 直接アクセス方式と R-5 による抽出方式を併用する場合、どちらの方式でどの依頼に対応したかを提出記録上で区別できるようにすること。

12.6 回答期限の目安と体制

12.6.1 依頼から提出までの目安

回答期限は本書が一律に定めるものではなく、**発注者と監査人が合意する事項**である。ただし、目安を設計時点で置かなければ、必要な照会性能・階層化設計・要員配置を決められない。表12-6 に設計上の目安を示す。開発ベンダーはこの目安を満たす構成を提案し、発注者の合意を得たうえでログ設計書および運用手順書に確定値を記載すること（**必須**）。

表12-6 依頼から提出までの所要時間の目安（設計前提）

依頼の種類	技術的な律速要因	目安
ホット層（S3 Standard、CloudWatch Logs）にある期間の母集団抽出	クエリ実行時間と承認	1営業日
Standard-IA／Glacier Instant Retrieval にある期間の抽出	同上（取り出しはミリ秒）	1営業日
Glacier Flexible Retrieval にある期間の抽出	対象オブジェクト全件の復元ジョブ（S3 Batch Operations。取り出し自体は Expedited 1～5分／Standard 3～5時間／Bulk 5～12時間）＋テーブルプロパティ設定（12.3.1）＋クエリ	2営業日を起点とし、対象オブジェクト件数に応じた復元ジョブの所要時間を加えて発注者と確定する
Glacier Deep Archive にある期間の抽出	対象オブジェクト全件の復元ジョブ（S3 Batch Operations。取り出し自体は Standard 12時間以内／Bulk 48時間以内。Expedited は利用不可）＋テーブルプロパティ設定（12.3.1）＋クエリ	3～4営業日を起点とし、同上の方法で確定する
複数アカウント・複数リージョン横断の母集団一覧	クエリ実行時間、対象範囲の確認	2～3営業日
指定サンプルの詳細（母集団抽出済みの場合）	再抽出と突合	0.5～1営業日
運用記録との突合を伴う提出	運用記録の収集（R-4）と突合	3～5営業日

- **必須** Glacier Deep Archive に置く期間がある場合、その取り出し時間を上記のとおり運用手順書に明記し、発注者を通じて監査人の期待と整合させること。第7章の階層化設計は、この応答時間を前提として決定する。
- **必須** アーカイブ階層に置く期間については、復元の対象範囲・所要時間・件数を実測し、その結果を目安の確定根拠として記録すること。復元は Athena が代行しないため、復元漏れは結果の欠落として現れる（12.3.1）。
- **推奨** 期末監査の繁忙期（期末日後～内部統制報告書提出まで）は依頼が集中するため、当該期間の要員配置と優先順位付けの方針をあらかじめ合意しておくこと。

12.6.2 緊急時の連絡経路

次のいずれかに該当する場合は、通常の依頼経路とは別に、直ちに発注者のシステム所管（R-2）および内部統制担当（R-1）へ報告すること（**必須**）。いずれも監査上の重要事項であり、開発ベンダー内での判断・調整で保留してはならない。

- 対象期間のログに**欠損が判明した場合**（設定が有効でなかった期間、配信エラー、保持期間切れによる消失を含む）。
- `validate-logs` が `valid` 以外の結果を返した場合。
- 依頼された条件では母集団を網羅できないことが判明した場合（記録対象外のリージョン・リソースが含まれる等）。
- 抽出の結果、ログ設定の変更・停止・削除の試行が発見された場合。
- 目安時間内での提出が困難であることが判明した場合。判明した時点で、確定した遅延幅ではなく**見込みの段階**で報告すること。

12.6.3 開発ベンダーの支援範囲

表12-7 監査対応における開発ベンダーの役割

区分	内容
実施すること	ログの構造・フィールドの意味・コード値の技術説明。抽出クエリの作成と検証。抽出結果の妥当性の説明（なぜこの条件で母集団が網羅されるか、限定事項は何か）。設定証跡の提示。指摘事項に対する技術的な是正案の提示
実施しないこと	抽出の実行（R-5 の役割）。抽出結果からの行の選別。監査人との直接のやり取り（発注者が明示的に同席・回答を求める場合を除く）。統制が有効であるという判断・主張。発注者の評価結論の代弁
事前に準備すること	標準クエリの名前付きクエリ登録と実行検証の記録（12.3.2。必須事項である）。ログ設計書のフィールド定義（第11章）。網羅範囲の限定事項の一覧。抽出手順書

必須 「実施しないこと」に挙げた事項を求められた場合は、その場で応じず発注者（R-2）に確認すること。特に監査人との直接のやり取りは、発注者の明示的な指示に基づく場合に限る（12.1.2 の R-3 の責任と同一の条件である）。

推奨 期末監査の前に、代表的な依頼類型について抽出のリハーサルを実施し、所要時間と成果物を記録すること。第11章の受入テストで実施した実演の結果を、この記録の初回版として用いてよい。

12.7 よくある指摘と予防

本節は、ログを取得していながら証跡として通用しなかった典型例と、その予防策を示す。いずれも設計・構築段階で予防できるものであり、監査対応の段階では手遅れになる性質を持つ。

表12-8 よくある指摘と予防策

指摘	原因	予防策	関連
証跡の期間が不足している	保持期間の既定値のまま運用、ライフサイクルによる早期削除、データイベントの取得開始が期首より後	保存年限を第7章に従って明示設定し、設定値を年次で確認する。取得開始日を全ログ種別について記録し、評価対象期間と照合する	LR-05、LR-01
抽出条件が不明確で再現できない	クエリ文を残していない、画面操作で抽出、条件を要約して記載	クエリ文の全文と実行IDを記録し提出する（12.4.1）。標準クエリを名前付きクエリとして登録する（12.3.2の必須事項）	LR-10、LR-14
時刻表記が統一されていない	ログごとに UTC と JST が混在、変換規則が示されていない、時刻同期がされていない	12.7.3の規約を適用する。時刻同期は第4章・第5章の設定に従う	LR-03
証跡が改変された疑いがある	表計算ソフトでの再保存、列の並べ替え、行の削除、ハッシュ値の未取得	抽出直後にハッシュ値を算出し以後編集しない（12.4.3）。加工は別ファイルとして版管理する	LR-04
対象が漏れている	リージョン・アカウントの取りこぼし、記録対象外リソース、グループ経由の権限の未展開、アーカイブ階層の復元漏れ	12.7.2のチェックを抽出前に実施し、対象範囲を実行記録に明記する	LR-01
実施者が特定できない	共有ID・共有ロールの利用、個人識別子がログに渡っていない	個人識別子の引き渡し（sourceIdentity 等）を設計時に組み込む。稼働後の追加では過去分を救済できない	LR-02、LR-06
運用記録と突合できない	ログ側とチケット側に共通の識別子が無い	変更管理チケット番号・申請番号・ジョブ実行IDを双方に記録する	LR-02、LR-12
ログの取得設定が期中に変わっていた	設定変更が変更管理の対象外、変更が記録されていない	ログ設定の変更を LR-12 の対象とし、変更前後の設定と承認記録を保管する。期中の変更は事前に発注者へ通知する（12.1.1）	LR-12、LR-04
0件の回答が信用されない	抽出条件の誤りと真の0件を区別できない	0件でも 12.4.1 の実行記録を作成し、クエリ文の全文と網羅範囲の限定事項を併せて示す	LR-10
監査人のアクセス権が残置されている	監査終了時の削除手順が定義されていない	割当削除を監査対応の完了条件とし、監査アクセス管理表で棚卸する（12.5.1）	LR-06

12.7.1 期間不足を作り込まないための確認

期間不足は最も回復不能な指摘である。有効化していない期間のログは、後から生成できない。以下を本番稼働前および毎期の評価開始前に確認すること（**必須**）。

- 評価対象期間の開始日が、各ログ種別（L-01～L-14）の取得開始日以降であること。取得開始日の一覧をログ設計書に維持すること。
- 評価対象期間の終了日から遡って、保持期間が当該期間を包含していること。CloudWatch Logs の保持期間の既定は**無期限**であるが、明示設定されている場合はその値を確認すること。なお AWS Config のマネージドルール `cw-loggroup-retention-period-check` は、保持期間が `MinRetentionTime`（既定365日）を下回る場合に非準拠と判定する一方、「無期限（Never expire）」は準拠と判定する。したがって、明示設定された保持期間が閾値を下回ったことは検出できるが、「意図した無期限」と「保持期間が未設定のまま放置された状態」は区別できない。`MinRetentionTime` に発注者が決定した保存年限（第7章）を設定したうえで、無期限

設定のロググループについては設定意図をログ設計書に記載すること。保持期間が発注者の定めた年限に明示設定されていることの確認を、このルールだけで代替しないこと。

- S3 のライフサイクル設定が、評価対象期間のオブジェクトを削除する構成になっていないこと。**バケットポリシーではライフサイクルによる削除・移行を防げない点**に注意する。
- 期中に保持期間・ライフサイクル・取得範囲を変更した場合、変更前後の期間について証跡が連続していること。

12.7.2 対象漏れを防ぐための抽出前チェック

抽出の実行前に、以下を確認し実行記録に記載すること（**必須**）。

- **アカウント**。対象アカウントの一覧が組織の現在のアカウント一覧と一致すること。評価対象期間中に追加・除外されたアカウントがある場合、その期間の扱いを明記する。組織から除外されたアカウントについても、除外前に作成されたログはログアーカイブ用バケットに残っている。CloudTrail Lake を利用している場合は、イベントデータストアの種別により新規アカウントが取り込まれないことがある（12.3.3）。
- **リージョン**。利用している全リージョンが対象に含まれること。IAM・AWS STS・Amazon CloudFront のグローバルサービスのイベントは `us-east-1` に記録されるため、このリージョンが対象から漏れていると**認証・権限関連のイベントを取りこぼす**。オプトインリージョンを利用している場合は、各メンバーアカウントで有効化されているかを確認する。
- **ログ種別**。依頼内容に対して必要なログ種別（表12-1・表12-2）がすべて対象に含まれること。特にデータイベント（L-02）とサーバ操作ログ（L-05）は既定では取得されないため、取得の有無を確認する。
- **ストレージ階層**。対象期間のオブジェクトが Glacier Flexible Retrieval または Glacier Deep Archive に移行していないこと。移行している場合は、復元とテーブルプロパティ設定（12.3.1）を完了してから抽出すること。
- **記録対象外**。AWS Config の記録対象外リソースタイプ、高度なクエリで照会できないリソースタイプおよび検索不可フィールド、記録対象としていないリージョン、記録できないグローバルリソースの範囲。
- **ログに現れない操作**。Session Manager の**ポートフォワーディング経由および SSH 経由のセッションはログを取得できない**。これらの経路を遮断していることを設定証跡で示すか、遮断していない場合はその範囲を限定事項として明記する。

12.7.3 時刻表記の規約

複数システムのログを突き合わせて事象の前後関係を確定できないことは、証跡としての致命的な欠陥となる。以下を本書の規約とする。

- **必須** **抽出条件および抽出結果は、原則として協定世界時（UTC）で記録・出力すること**。AWS の各サービスのログは UTC で記録される。CloudTrail の `eventTime` は API エンドポイントを提供するホストの時刻に基づく UTC であり、`2014-07-16T15:49:27Z` の形式で記録される。CloudWatch Logs のイベントのタイムスタンプは 1970年1月1日 UTC からのミリ秒である。`lookup-events` および `validate-logs` の時刻指定も UTC である。UTC のまま提出することで、変換に伴う誤りの余地を排除する。
- **必須** 日本標準時（JST、UTC+9）の併記が求められる場合は、**UTC の列を残したうえで JST の列を追加すること**。UTC 列を JST に置き換えないこと。変換規則（UTC+9、夏時間の適用なし）をマニフェストに記載し、ファイル名にもタイムゾーンを含めること（12.4.3）。
- **必須** 1つのファイル内で、時刻列のタイムゾーンを混在させないこと。列名にタイムゾーンを含める（例：`eventtime_utc`、`eventtime_jst`）。

- **必須** 対象期間の指定における境界の扱い（開始・終了を含むか）を明記すること。日付のみで期間を指定する場合、その日付が UTC のいずれの時刻範囲を指すかを記載する。**日本時間の期首・期末と UTC の日付境界は9時間ずれる**ため、期首日・期末日の境界付近の事象が抽出結果に含まれるかどうかが変わる。**母集団の境界はイベントの発生時刻（CloudTrail であれば eventtime）で確定すること**。S3 のプレフィックス上の日付やパーティション列は、配信日付に基づくためスキャン範囲の指定にとどめる（12.3.1）。
- **必須** ログの出力元がタイムゾーンを含まない形式で時刻を記録する場合（一部のデータベース監査ログ等）、その時刻がどのタイムゾーンで記録されているかを実機で確認し、ログ設計書に記載すること。公式ドキュメントに明示が無い場合は、実測により確認した結果を記録すること。
- **必須** 各サーバ・機器の時刻同期が構成されていることを設定証跡で示せること（LR-03）。EC2 インスタンスは Amazon Time Sync Service を、オンプレミス機器を含む場合は同一の時刻源への同期を用いる。

● 監査の視点

監査人が抽出結果を受け取ったとき、最初に確認するのは中身ではなく**枠組み**である。すなわち、(1) この表は何を母集団とし、どの条件で取り出したのか、(2) 取り出した元のデータは対象期間を通じて欠損なく存在し、改変されていないと言えるのか、(3) 取り出した人は結果を選別できない立場か、(4) 同じ条件で再実行すれば同じ結果が得られるか、の4点である。

本章の要求は、この4点にそれぞれ対応している。抽出条件と実行IDの記録（12.4.1）が(1)と(4)に、整合性検証と網羅範囲の説明（12.4.2）が(2)に、R-5 による実行と承認の分離（12.1.2）が(3)に対応する。逆にいえば、この4点を説明できない証跡は、内容がどれほど詳細でも監査上の価値を持たない。開発ベンダーは、ログを「取得できること」ではなく「この4点を満たして提出できること」を設計目標とすること。

本章で用いた成果物（抽出手順書、標準クエリ、命名規約、提出パッケージの様式）は、ログ設計書および運用手順書（LR-14）の一部として第11章の成果物一覧に含める。様式は付録Dに示す。

12.8 保険での監査・検査対応の留意点

業種別調査の保険の節（付録 G の § 6）は、当局の報告徴求・立入検査に関わる行を挙げていない。本節では、同節と全業種に共通する法令の節に根拠がある事項だけを示す。

監督指針は、不正アクセス・情報漏えいを牽制・防止する仕組みとして「アクセス記録の保存、検証」を挙げている（付録 G の ING1）。実務指針は、個人データへのアクセス・操作の記録の分析・保存と、不正が疑われる異常な記録の存否の定期的な確認を求めている（付録 G の ING8）。定期レビューの運用は第 9 章による。

保険では、次の場面で、保存期間の満了による自動削除を止めるか、保持期限を延ばす必要がある。

- 契約に連動する記録：契約の存続中は保存を継続する（リーガルホールド相当）（付録 G の INF1）。
- 電磁的交付書面のデータ：苦情の申出があれば、期間の終了日と苦情の解決日の遅い方まで保持する（付録 G の IN7、IN8）。

このほか、刑事訴訟法197条3項の保全要請（最長60日）、漏えい等の調査、訴訟の予期に備え、自動削除を対象を絞って止められるようにする（付録 G の CF6）。197条3項の対象となる設備を設置している者に自社が当たるかは、法務部門に確認する（要法務確認）（付録 G の CM26、CF6）。

訂正削除の履歴は、監査ログとは別に、記録の一部として求められることがある。業種別調査は、金融関連法令の e-文書法施行規則（SC13。証券・資産運用編の付録 G に収録）が、訂正・削除の事実と内容を確認できる措置などを求めるとしている（付録 G の § 1.1）。ただし、保険業法の帳簿がどの条で電磁的保存の対象とされているか

は、確認していない（付録 G の § 6.7 の 4）。特定保険募集人・保険仲立人の帳簿書類（IN4）を電磁的記録で作成・保存する場合は、そのデータと訂正削除の履歴が関わる（付録 G の IN4）。会計・請求・経費精算のシステムでは、電子帳簿保存法が訂正削除の履歴を求める場面がある（全業種に共通。付録 G の CF1）。履歴は、その記録の保存期間の終了まで保持する（付録 G の § 1.1）。

- **必須** 保全の対象・手順・承認者を運用手順に定め、自動削除から対象のログ・記録を個別に外せるようにすること（7.5）（付録 G の CF6）。
- **必須** 苦情の申出と解決の状態を電磁的交付書面のデータの保持期限に反映する手順を、運用手順に含めること（付録 G の IN7、IN8）。
- **推奨** 顧客情報へのアクセス記録について、異常な記録の存否の定期的な確認の結果を記録し、監査で提示できるようにすること（付録 G の IN8）。

13

導入ロードマップと移行時の留意点

本章は、第2章から第12章までの要求事項を、開発ベンダーが実際の案件でどの順序で実装・検証し、どの時点で何を発注者に引き渡すかを示す。ログ基盤は「作れば終わり」ではなく、期首から期末までの全期間にわたって欠落なく記録され、監査人が求める形で抽出できて初めて統制として成立する。したがって導入は段階的に行い、各段階で完了条件と成果物を確定させながら進めること。

13.1 段階的導入

導入は次の5フェーズに分ける。**必須** フェーズ1（基盤ログ）はフェーズ2以降の前提であるため、順序を入れ替えないこと。フェーズ2の各ログ種別（L-05～L-13）は相互に独立しているため並行して進めてよいが、フェーズ3の監視・レビュー運用は対象ログが揃ってからでなければ検知条件を確定できない。**必須** フェーズ4の監査リハーサルは、実際の監査依頼を受ける前に抽出可能性を確認するためのものであり、初年度は本番運用開始前に実施すること。ただし抽出の所要時間は蓄積されたログ量に依存するため、開始前の実測値は暫定値として扱い、初回の評価期間中に本番データ量で再実測し、双方の記録を残すこと。

表13-1 導入フェーズ・完了条件・成果物

フェーズ	主な実施事項（参照章）	完了条件	成果物／ 主担当
フェーズ0 現状把握	財務報告に関連する対象システム・AWSアカウント・リージョンの特定、現行ログの棚卸し（取得有無・保存先・保存期間・アクセス権）、LR-01～LR-14 および L-01～L-14 に対するギャップ分析（第2章・第3章）	対象範囲が発注者（R-1 および R-2）の連名承認を得ていること。ギャップごとに是正フェーズと担当が割り当てられていること。取得しないログ種別には理由が記録されていること	D-01 対象システム・現行ログ現状調査結果 D-02 ギャップ分析表 R-3が作成、R-1・R-2が承認
フェーズ1 基盤ログ	AWS CloudTrail の組織の証跡（マルチリージョン、管理イベント、必要なデータイベント。L-01・L-02）、AWS Config（L-03）、認証・認可ログ（コンソールログイン、AssumeRole、AWS IAM Identity Center。L-04）、ログ基盤自身の監査ログ（ログ設定変更・削除試行。L-14）、ログ保管用 Amazon S3（バージョンニング・Object Lock・SSE-KMS・パブリックアクセスブロック）、AWS KMS キーポリシー、ログ削除・停止を禁止する SCP の適用（第4章・第5章・第6章・第8章・第10章）	全対象アカウント・全対象リージョンで配信が成功していること（配信状況の確認結果を証跡として保存）。L-01～L-04 および L-14 の各ログが実データで取得できていること。ログファイル整合性検証が有効で、検証コマンドが正常終了すること。運用者・開発者がログを削除できないことをテストで確認していること	D-03 ログ設計書（初版） D-04 ログ基盤 IaC テンプレート D-05 基盤ログ取得・保全テスト結果報告書 R-3（R-5が確認）
フェーズ2 ワークロードログ	AWS Systems Manager Session Manager のセッションログ・OS 監査ログ（L-05）、Amazon RDS／Amazon Aurora の監査ログ（L-06）、アプリケーション業務ログ（承認操作・エラー。L-07）、ジョブ・バッチ（L-08）、データ連携（L-09）、CI/CD・IaC 適用ログ（L-10）、ネットワーク・通信ログ（VPC Flow Logs、ELB／WAF／CloudFront。L-11）、セキュリティ検知ログ（Amazon GuardDuty、AWS Security Hub の有効化と集約。L-12）、バックアップ・リストアログ（AWS Backup。L-13）の取得（第5章。アプリケーション業務ログ・ジョブ・データ連携・デプロイログの記録項目は第3章および第11章）	L-05～L-13 の各ログについて、LR-02（5W1H）を満たす記録項目が実データで確認できていること。取得できない経路（ポートフォワーディング等）を代替統制または禁止設定で塞いでいること	D-06 設定パラメータ一覧（付録C準拠） D-07 ワークロードログ取得テスト結果報告書 R-3
フェーズ3 監視・レビュー運用	検知条件（ログ設定変更・特権利用・認証失敗等）とアラート、通知経路、エスカレーション、定期レビューの頻度・実施者・承認者・様式の確定と初回試行（第9章・第10章）	試験イベントを発生させ、検知から通知・一次対応・記録までが所定の時間内に完了すること。通知先の到達確認が取れていること。レビュー記録様式（付録D）で初回レビューが実施・承認されていること	D-08 監視・アラート定義書 D-09 ログ運用手順書 R-3／R-4（R-5・R-2が承認）

フェーズ	主な実施事項（参照章）	完了条件	成果物／主担当
フェーズ4 監査リハーサル	想定される監査依頼に対する抽出訓練。期間・対象者・操作種別を指定した抽出、完全性の証明、提出形式と開示範囲の確認、所要時間の実測（第12章）	想定依頼のすべてについて、手順書どおりに抽出でき、回答期限内に収まることが実測で確認されていること。本番データ量での再実測を計画に含めていること。抽出者と依頼者・承認者が分離されていること	D-10 監査証跡抽出手順書・監査リハーサル記録 R-4／R-5（R-6が立会または結果確認）

● 補足

D-01～D-10 は本ガイドラインを通じて用いる成果物識別子であり、第11章の成果物一覧に対応する。各成果物の必須記載事項、テスト観点、受入チェックリストは第11章に従うこと。D-03 ログ設計書はフェーズ1で初版を作成し、フェーズ2以降の追加取得に応じて同一文書を改訂する（新規作成を繰り返さない）。

13.1.1 フェーズ0で確定させるべき事項

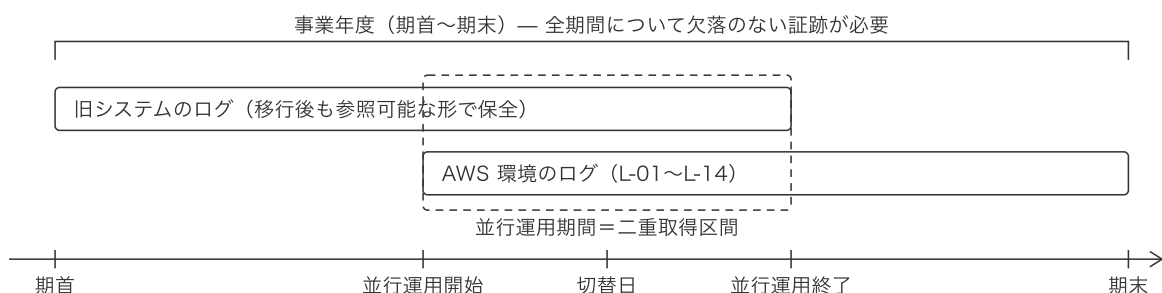
必須 フェーズ0のギャップ分析は、LR-01～LR-14 の各要求事項と L-01～L-14 の各ログ種別を軸に、「現状」「あるべき姿」「差分」「是正フェーズ」「担当」を1件ずつ記録すること。差分が無いと判断した項目についても、その根拠（設定値、確認日、確認方法）を記録すること。

必須 対象範囲は、開発ベンダー（R-3）が案を作成し、発注者の内部統制担当（R-1）およびシステム所管（R-2）の連名承認を得ること。開発ベンダーが単独で「財務報告に関連しない」と判断してログ取得を見送らないこと。

推奨 フェーズ0の時点で、監査人（R-6）が過年度に依頼した証跡の実例を発注者から入手し、フェーズ4のリハーサル項目の原案とすること。

13.2 オンプレミスからの移行時の留意点

評価は期末日を基準日として行われるが、運用状況の評価は期末日までの適切な期間について実施され、期中にシステムを切り替えた場合は切替前の旧システムに係る統制も評価の対象となりうる。ログ基盤の設計はこの前提に立ち、**必須** 「移行後に旧システムの証跡が取り出せない」「切替前後で記録が途切れる」状態を作らないこと。



13.2.1 旧システムのログ保存と参照可能性の維持

必須 旧システムの廃止前に、財務報告に関連するログを、発注者が定めた保存年限（第7章）まで参照可能な形で保全すること。保全にあたっては、ログ本体だけでなく、(1) ログ中のコード値・区分値の意味を示すマスタまたはコード表、(2) ユーザーIDと氏名・所属の対応、(3) 閲覧・検索手段（旧アプリケーションが無くても読める形式への変換の要否）を併せて保全すること。旧システムでしか読めない独自形式のまま退避すると、証跡としての参照可能性を失う。

推奨 退避先は新環境のログ保管領域と同一の保護水準（バージョニング、Object Lock、SSE-KMS、読み取り専用のアクセス制御）とし、退避作業自体を CloudTrail のデータイベントで記録すること。

13.2.2 期中移行における証跡の連続性

必須 切替日前後の二重取得期間は、表13-3の「移行方針」として発注者と合意すること。期間はテスト移行および切戻し判断期限を含む長さとし、合意した期間にわたり旧系・新系の双方で記録が残るよう二重取得すること。新系のログ取得（少なくとも L-01 クラウド基盤API操作ログ、L-04 認証・認可ログ、L-14 ログ基盤自身の監査ログ）は、業務データの移行や本番切替の作業そのものを記録できるよう、切替日より前に有効化しておくこと。切替後に有効化すると、移行作業を行った操作の記録が残らない。

必須 二重取得を開始した日時、終了した日時、その間に両系で記録された同一事象の対応関係（例: 同一の承認操作が旧系・新系のどちらに記録されるか）をログ設計書（D-03）に記載すること。

● 監査の視点

内部統制の評価時点は期末日であり、監査人は期末日における有効性に関する経営者の評価結果を監査する。経営者が運用状況の評価を期中に実施した場合において、期末日までに内部統制に重要な変更があったときは、経営者は変更内容の把握、変更後の整備状況の評価、変更後の運用状況の評価といった追加手続の実施を検討し、監査人は経営者がこれらの追加手続を実施しているかを確認する。切替日が期の途中にある場合、切替前の期間について旧システムの証跡を提示できないと、当該期間の運用状況について十分かつ適切な証拠を入手できず、評価範囲や評価結論に影響するおそれがある。切替日と並行運用期間は、設計段階で発注者・監査人と共有しておくこと。

13.2.3 並行運用期間のログ

必須 並行運用期間中は、同一の取引が旧系・新系の双方に記録されうる。どちらの系の記録が正（会計処理の根拠）であるかを日付または取引区分で一意に判定できるようにし、その判定規則を文書化すること。判定規則がないと、二重計上・計上漏れの検証ができない。

推奨 並行運用期間の突合（件数・金額合計の一致確認）を日次または週次で実施し、その結果と差異の是正内容を記録すること。

13.2.4 ユーザーID対応表

必須 旧システムの利用者IDと、AWS 環境における識別子との対応表を作成し、保存年限にわたって維持すること。AWS 環境では操作者の識別形式がアクセス経路によって異なるため、対応表には少なくとも次を含めること。

- IAM ユーザーによる操作: `userIdentity.arn`
- ロール引き受け（AssumeRole）による操作: `userIdentity.sessionContext.sessionIssuer.arn`（ロール ARN）と、操作者を識別する `userIdentity.sessionContext.sourceIdentity`（AWS STS のソースアイデン

ティティ。AssumeRole 呼び出し自体のイベントでは `requestParameters.sourceIdentity` に記録される)、またはロールセッション名 (`userIdentity.arn` の末尾)

- AWS IAM Identity Center 経由の操作: 許可セットでロールを引き受けた操作は `AssumedRole` として記録されるため、ロールセッション名 (`userIdentity.arn` の末尾) が操作者の識別子となる。 `userIdentity.type` が `IdentityCenterUser` の場合 (IAM Identity Center の認可アクセストークンによる呼び出し) は `userIdentity.onBehalfOf.userId` および `identityStoreArn` が Identity Store 上のユーザーに対応する。自環境のアクセス経路がどちらの形式で記録されるかを実データで確認し、該当する形式を対応表に含めること。
- アプリケーション業務ログ上の利用者ID (L-07) と、上記 AWS 側識別子との対応

必須 ロールを共有して利用する構成では、IAM の `sts:SourceIdentity` 条件キー等により個人が特定できるよう設定すること。ソースアイデンティティを記録するには、ロールの信頼ポリシーで `sts:SetSourceIdentity` を許可し、ロールを引き受ける側が値を設定する実装とすること。共有IDのまま個人を特定できない構成は、特権利用に係る統制上のリスクとなる。ログの適時かつ適切なモニタリング等の代替的・補完的統制がない場合は不備と評価されるため、個人を特定できる設定とするか、代替統制の内容とその評価結果を記録すること。なお、信頼ポリシーでソースアイデンティティの設定を条件として必須化したロールは、マネジメントコンソールのスイッチロールでは引き受けられず、AWS CLI または API から `AssumeRole` を呼び出す必要がある。必須化の場合は、対象ロールの利用手順 (コンソール利用の可否と代替手順) が成立することを設計時に確認すること。

13.2.5 時刻・タイムゾーンの統一

必須 ログを出力するすべての構成要素を単一の時刻源に同期させること。Amazon EC2 上の OS は Amazon Time Sync Service (IPv4 は `169.254.169.123`、Nitro 世代の IPv6 は `fd00:ec2::123`) を、AWS 外の機器は `time.aws.com` を利用できる。

必須 ログのタイムスタンプ表記規約を設計書に明記すること。AWS の主要サービスのログは UTC で記録される (AWS CloudTrail の `eventTime` は UTC、Amazon CloudWatch Logs のイベントタイムスタンプは 1970-01-01 UTC からのミリ秒)。保管する生ログのタイムゾーンと、表示・突合時の換算規則をあらかじめ定め、全ログを単一のタイムゾーンに揃えて分析できるようにすること。業務システムの利用範囲が国内に限られる場合は日本標準時 (JST)、海外を含む場合は協定世界時 (UTC) のいずれかに統一する方針が考えられるが、採用するタイムゾーン方針は発注者と合意すること。表示系を JST とする場合も、生ログの記録が UTC であることを前提に換算規則を設計書へ明記すること。

必須 データベース監査ログのように、出力形式にタイムゾーン表記を含まないログがある。該当するログについては、そのタイムスタンプが UTC か DB インスタンスのタイムゾーン設定に従うかを公式ドキュメントおよび実データで確認し、確認結果を設計書に記載すること。

13.2.6 移行データ検証の記録の証跡化

必須 データ移行 (データコンバージョン) の検証記録そのものを証跡として残すこと。移行検証は変更管理プロセスの一部として監査人の検討対象となる。記録には少なくとも、移行対象 (テーブル・勘定科目・期間)、移行前後の件数と金額合計、突合結果、差異の内容と原因、是正内容、実施者、承認者、実施日時を含めること。

推奨 検証記録は、ログと同じ改ざん防止領域 (Object Lock を適用した S3 バケット等) に保存し、後日の第三者による検証に耐える形で保全すること。

13.3 既存AWS環境への適用時の留意点

すでに稼働している AWS 環境に本ガイドラインを適用する場合、稼働中のサービスを停止させずに是正する必要がある。**必須** 是正作業自体がログの欠落を生まないよう、「新旧の並行期間を設ける」「切替後に旧設定を停止する」順序を守ること。

13.3.1 S3 Object Lock の適用と新バケットへの移行

Amazon S3 Object Lock は既存バケットにも有効化できる。ただし前提としてバージョニングが有効である必要があり、有効化後は Object Lock の無効化もバージョニングの停止もできない。既存オブジェクトへの保持設定の適用は S3 Batch Operations で行う。

必須 次のいずれかに該当する場合は、既存バケットへの後付けではなく、新バケットを作成してログの配信先を切り替えること。

- そのバケットがバージョニング未有効で、他用途との共用のため不可逆な変更を加えられない場合
- そのバケットが S3 サーバーアクセスログの配信先になっている場合（Object Lock を有効化したバケットはサーバーアクセスログの配信先にできない）
- そのバケットを AWS Config の配信チャネルとして使用している場合（既定の保持設定を有効化した Object Lock バケットへの配信はサポートされない）
- ログ以外のデータが同居しており、保持設定が業務データにも及ぶ場合

必須 新バケットへ移行する場合の順序は、(1) 新バケット作成（バージョニング、Object Lock、SSE-KMS、パブリックアクセスブロック、削除を拒否するバケットポリシー）、(2) 証跡・配信設定の宛先変更と配信成功の確認、(3) 旧バケットへの書き込み停止、(4) 旧バケットを保持年限満了まで読み取り専用で保全、とすること。旧バケットを先に閉じないこと。移行期間中は、抽出用のテーブル定義・クエリが旧新双方のバケットを対象にできるようにしておくこと。

S3 Object Lock と AWS CloudTrail のログファイル整合性検証は、いずれもログの完全性を保護する手段であり、併用できる。**必須** ログ保管用バケットは、上記の制約があるため、CloudTrail ログ用バケットを S3 サーバーアクセスログの配信先や AWS Config の配信チャネルと兼用しないこと。

● 注意

Object Lock のコンプライアンスモードは、保持期限が到来するまでルートユーザーを含む誰も上書き・削除できず、モード変更も保持期間の短縮もできない。誤って過大な保持期間を設定すると取り消せないため、保持年限は第7章の設計と発注者の承認を経てから設定すること。Object Lock を採用できない場合の代替として MFA Delete を用いるときは、MFA Delete がライフサイクル設定と併用できず、バケット所有者（ルートユーザー）が CLI/API でのみ設定できる点に留意し、第7章の階層化設計と矛盾しないことを確認すること。

13.3.2 CloudWatch Logs 保持期間の一括是正

Amazon CloudWatch Logs のロググループは、既定ではログデータを無期限に保持する。既存環境では保持期間が未設定のロググループが放置されている場合が多い。

必須 全アカウント・全リージョンのロググループを棚卸しし、ログ種別ごとの保存年限（第7章）に対応する保持期間を設定すること。`retentionInDays` は任意の日数ではなく規定された有効値のみを指定できるため、設計

上の年限を下回らない最小の有効値（切り上げ）を選定し、選定理由を記録すること。保存年限が有効値と一致しない場合は、切り上げにより保管期間が設計値を超える点を発注者と合意すること。

必須 保持期間の設定は削除を伴う。無期限保持のロググループに保存年限を超える古いログが含まれている場合、保持期間を短くすると当該データは削除される。短縮前に、既に保存されている古いログは S3 エクスポートタスク（`aws logs create-export-task`。期間を指定して取り込み済みのログを Amazon S3 へ出力する）で長期保管用バケットへ退避し、出力結果の対象期間と件数を確認すること。エクスポートタスクは Object Lock（保持期間つき）バケットおよび SSE-KMS バケットへの出力に対応する（DSSE-KMS は非対応）。なお、エクスポート先の Amazon S3 バケットは、エクスポート対象のログデータと同一リージョンに存在する必要があるため、別リージョンのバケットへのエクスポートはサポートされない（別アカウントのバケットへのエクスポートは可能）。したがって、対象リージョンごとに同一リージョンの受け皿バケットへエクスポートし、その後にレプリケーションまたはコピーでログアーカイブ用アカウントの長期保管バケットへ集約する手順とすること。ログデータがエクスポート可能になるまで最大12時間を要し、タスクは24時間でタイムアウトし、同時に実行できるタスクはアカウント・リージョンごとに1つであるため、同一リージョン内では分割した対象期間を逐次実行することになる。保持期間の変更日から逆算し、対象リージョン数（各リージョン内では逐次実行となる）と分割した対象期間を織り込んで余裕をもって計画すること。なお、サブスクリプションフィルターは設定後に取り込まれたログのみを転送するため、保存済みのログを遡って退避することはできない。以後の継続的なアーカイブ手段としては、定期的なエクスポートではなくサブスクリプションの利用が推奨されており、その場合は Amazon Data Firehose を経由して Amazon S3 へ配信すること（サブスクリプションフィルターは Amazon S3 を直接の配信先に指定できない）。

推奨 是正後の再発防止として、ロググループの削除保護を有効化し、保持期間の設定漏れを検知する仕組みを設けること。AWS Config のマネージドルール `cw-loggroup-retention-period-check` は「Never expire」（無期限）を COMPLIANT と判定するため、無期限保持の検出にはこのルールだけでは不十分である。棚卸しの結果を用いた別の検知手段を併用すること。

```
# 以下は1アカウント・1リージョン分である。対象アカウント（ロール引き受け）と
# 有効化しているリージョンのすべてについて反復実行し、結果を一覧化して証跡とすること。

# ロググループごとの保持期間を棚卸しする（未設定は None と表示される。
# アカウント・リージョンごとに実行し、結果を突合すること。
# 結果はページングされるため、全ページを取得して全件を対象とする）
aws logs describe-log-groups --region <リージョン> \
  --query 'logGroups[].[logGroupName,retentionInDays]' --output text

# 保持期間を設定する（--retention-in-days は規定の有効値のみ指定可。
# 値は発注者が決定した保存年限を下回らない最小の有効値を選定し、選定理由を記録する）
aws logs put-retention-policy --region <リージョン> \
  --log-group-name <ロググループ名> --retention-in-days <有効値>

# 組織の証跡がエラーなく配信されているかを確認する。
# メンバーアカウント側でも実行し、LatestDeliveryError 等の有無を確認すること
aws cloudtrail get-trail-status --name <証跡のARN> --region <リージョン>
```

13.3.3 既存 CloudTrail の組織の証跡への統合

必須 アカウントごとに個別の証跡が作成されている環境では、組織の証跡（AWS Organizations の管理アカウントまたは委任管理者が作成する証跡）に統合すること。組織の証跡はメンバーアカウント側で削除・停止・設定変更ができないため、ログ停止に対する予防統制として機能する。統合後、メンバーアカウント側の個別証跡を停止・削除するのは、組織の証跡の配信が全アカウント・全リージョンで成功していることを確認した後とすること。

必須 組織の証跡は、配信先バケットポリシーの誤りなど検証に失敗した場合でもメンバーアカウントに作成される。作成できたことをもって配信できていると判断せず、配信状況（`get-trail-status`）で確認すること。

必須 マルチリージョンの証跡とし、グローバルサービスイベントを含める設定を有効にすること。AWS IAM、AWS STS、Amazon CloudFront のグローバルサービスイベントは `us-east-1` に記録されるため、`us-east-1` を含まない単一リージョンの証跡ではこれらを取りこぼす。また、オプトインリージョンは各メンバーアカウントで有効化されて初めて記録対象となるため、有効化しているリージョンの一覧と証跡の対象範囲を突合すること。

推奨 同一リージョンで管理イベントを重複して記録する2本目以降の証跡は課金対象となる。統合後に不要となった個別証跡は、上記の確認を経たうえで停止し、既存のログファイルは保持年限満了まで残すこと。

13.3.4 既存アカウントの Organizations 参加

必須 ログの削除・停止を禁止するサービスコントロールポリシー（SCP）は、すべての機能が有効化された組織でのみ使用できる。既存アカウントを組織へ参加させる際は、参加後に SCP と組織の証跡が確実に適用されたことを確認し、確認結果を証跡として保存すること。

必須 SCP は管理アカウントには適用されない。管理アカウントに財務報告に関連するワークロードやログ保管領域を配置しないこと。ログ保管は専用のログアーカイブ用アカウントに分離し、読み取りはセキュリティ／ログ管理の主体、書き込みはログ配信サービスに限定すること（第6章・第10章）。

推奨 AWS Control Tower を利用する場合、既存の証跡があるアカウントを登録すると重複課金が生じるため、登録前に既存証跡の可否を判断すること。また、AWS Control Tower のログ保持期間は、カスタマイズしない場合の既定が標準のアカウントログ1年、アクセスログ10年であり、日または年単位で最長15年まで設定できる。発注者が定めた保存年限に合わせて明示的に設定し直すこと。API でランディングゾーンを管理する場合、保持期間はマニフェストの `centralizedLogging.configurations.loggingBucket.retentionDays` および `centralizedLogging.configurations.accessLoggingBucket.retentionDays` で指定する（ランディングゾーン 4.0 では AWS Config 用に `config.configurations` 配下にも同名のキーがあるため、対象を取り違えないこと）。なお、この保持期間はランディングゾーンのセットアップ時、または更新・リセット時に設定するため、稼働後に変更する場合はランディングゾーンの更新作業として計画すること。

13.3.5 既存環境が依存しているサービスの提供形態の変化

必須 既存環境が AWS CloudTrail Lake または AWS Audit Manager を証跡の保管・自動収集に用いている場合、その継続方針を発注者と確認すること。CloudTrail Lake は 2026年5月31日以降、新規顧客への提供が行われなくなる（既存利用者は継続利用可能だが、重要なバグ修正とセキュリティ更新のみが提供される。またアカウント単位のイベントデータストアでは、組織に後から追加した新規アカウントのイベントが取り込まれない。なお、この変更により証跡（Trail）および Insights が影響を受けることはない）。AWS Audit Manager は 2026年4月30日以降、新規アカウントでのセットアップができない（既存利用者は継続利用可能だが、新機能・新フレームワーク・新リージョンは追加されない）。

必須 新規に設計するログ基盤は、これらのサービスを前提としないこと。証跡+Amazon S3（Object Lock・ライフサイクル）を長期保全の基軸とし、照会は Amazon Athena または Amazon CloudWatch Logs によって行う構成を基本とすること（第6章）。

推奨 既存の CloudTrail Lake から Amazon CloudWatch へ履歴データをインポートする場合、2023年より前のデータは移行されない。当該期間のイベントは CloudTrail Lake で直接照会するか Amazon S3 へ退避する必要があるため、移行対象期間と移行されないデータの取り扱い（S3 への退避等）を移行計画に明記し、移行前後で保有期間に空白が生じないことを確認すること。

推奨 既存環境の CloudTrail Lake が組織単位のイベントデータストアか、アカウント単位のイベントデータストアのみかを確認すること。後者の場合、組織に新たに追加したアカウントのイベントは取り込まれないため、組織単位のイベントデータストアへの切り替え、または Lake に依存しない構成（証跡+Amazon S3）への移行を、アカウントの Organizations 参加（13.3.4）より前に計画すること。

13.4 よくある不備と予防策

表13-2 は、AWS 環境のログ管理でしばしば見られる不備と、その予防策である。**必須** フェーズ0のギャップ分析（D-02）およびフェーズ1～4の完了条件の確認において、少なくとも本表の項目を点検すること。

表13-2 よくある不備と予防策

不備例	統制上の影響	予防策	関連
CloudTrail のデータイベントが未設定（既定で無効）	会計データを保持する S3 オブジェクトの取得・更新・削除が追跡できない	対象バケット・プレフィックスを特定してデータイベントを有効化。取得量と費用を見積もり、対象を限定した理由を記録	LR-01／ L-02
証跡を作成せず、イベント履歴（過去90日）を保管手段と誤解	期首側の証跡が消失し、期末の評価時に対象期間全体を提示できない	証跡を作成し S3 へ配信。イベント履歴は調査用であって保管手段ではないことを設計書に明記	LR-05／ L-01
対象範囲の漏れ（単一リージョンの証跡、オプトインリージョン未対象、組織参加後の新規アカウントが集約対象外）	グローバルサービスイベントや新規アカウント上の操作が記録されず、網羅性の主張が崩れる	マルチリージョンの組織の証跡とし、グローバルサービスイベントを含める。アカウント一覧・有効化リージョン一覧と証跡の対象範囲を定期突合	LR-01／ LR-11
CloudWatch Logs の保持期間が既定の無期限のまま	保存方針と実態が不一致。削除方針が履行されず、費用も増大	全ロググループを棚卸しし保持期間を設定。cw-loggroup-retention-period-check は「Never expire」を COMPLIANT と判定するため、無期限保持はこのルールでは検出できない。棚卸し結果や別の検知手段で点検	LR-05／ LR-12
ログ保管バケットにバージョニング・Object Lock が無く、運用者が削除権限を持つ	改ざん・削除の可能性を否定できず、証跡としての証明力が低下	バージョニング+Object Lock+削除を拒否するバケットポリシー。削除できないことをテストで確認し結果を保存	LR-04／ LR-06
ログファイル整合性検証を有効化しただけで、検証を実施していない	完全性を主張する根拠がない。改ざん・欠落があっても気付けない	検証コマンドの定期実行を運用手順に組み込み、実行結果を証跡として保存。ログを元の配置から移動しない	LR-04／ LR-09
KMS キーの無効化・削除予約、またはキーポリシー不備	暗号化されたログを復号できず、監査時に提示不能となる	キーポリシーで復号主体を明示。無効化・削除予約を検知してアラート。削除ではなく無効化を原則とする	LR-07／ LR-11
バケットポリシー・プレフィックス・キーポリシーの不整合で配信が失敗	気付かないまま一定期間のログが欠落する	設定変更時に配信状況を確認。配信失敗を検知するアラートと、日次の到着件数監視を設ける	LR-11／ LR-12
Session Manager のログ出力先が未設定、またはポートフォワーディング・SSH 経由で接続	サーバ上の操作内容が記録されない（当該経路はセッションログを取得できない）	セッション設定でログ出力先を指定。SSH 用ドキュメント（AWS-StartSSHSession）およびポートフォワーディング用ドキュメント（AWS-StartPortForwardingSession、AWS-StartPortForwardingSessionToRemoteHost）の利用を IAM ポリシーで禁止し、代替経路を用意	LR-01／ L-05
RDS/Aurora の監査ログが未有効（既定で無効）	データベースへの直接操作・特権利用が追跡できない	エンジンに応じた監査機能を有効化し CloudWatch Logs へ発行（RDS for Db2 は DB2_AUDIT オプションとデータベースごとの監査ポリシーを設定して S3 へ出力）。対象イベント種別と除外ユーザーの妥当性を記録	LR-01／ L-06

不備例	統制上の影響	予防策	関連
RDS for Db2 の監査ポリシーをカテゴリ ALL のみで設定	更新系 DML を含む SQL 文の実行（EXECUTE）が記録されない。追加したデータベースに監査ポリシーが設定されないまま残る	EXECUTE を個別に設定し、更新系 DML が記録されることをテストで確認する。データベース作成手順に監査ポリシーの設定を組み込み、設定状態を定期確認する	LR-02/ L-06
アプリケーション業務ログに承認者・変更前後の値が無い	承認統制の運用証跡として使えず、追加の手作業証憑が必要になる	LR-02 の記録項目を設計段階で定義し、承認操作・マスタ変更・例外処理を対象に含める	LR-02/ L-07
特権ロールが共有され、操作者個人を特定できない	誰が実施したかを特定できず、特権利用の統制が成立しない	ロール引き受け時に操作者を識別する属性を必須化。特権利用は都度申請・承認とし、申請記録とログを突合	LR-02/ LR-06
アラート通知先が失効（サブスクリプション未確認・解除、担当者異動）	検知しても通知が届かず、発見的統制が機能しない	通知経路の生存確認を定期実施し記録。宛先は個人アドレスではなく運用グループとする	LR-08/ LR-11
ログレビューは実施しているが、実施記録と承認が残らない	運用状況の評価に用いる証拠が存在せず、実施した事実を示せない	様式（付録D）に基づき、対象期間・確認範囲・確認結果・例外対応・実施者・承認者を記録	LR-09
ログ設定の変更がコンソール直接操作で行われ、変更管理の対象外	設定変更の正当性・承認を示せず、ログ設定自体の信頼性が疑われる	ログ基盤を IaC で管理し、変更は申請・承認・パイプライン経由に限定。設定変更イベント（L-14）を検知	LR-12/ L-14
運用ベンダーがログ管理者を兼務し、責任分界が契約に定義されていない	職務分掌が確保されず、外部委託先の統制も評価できない	ログ管理者（R-5）を運用（R-4）から独立させる。取得・保全・レビュー・報告の分担と報告義務を契約に明記	LR-06/ LR-13
ログに平文パスワードや個人情報が出力される	ログ自体が機微情報となり、閲覧範囲の拡大が別のリスクを生む	出力前のマスキングを実装。マスキング機能は設定前に取り込まれたデータには適用されないため、初期構築時から適用	LR-07
ログ出力元が単一の時刻源に同期されていない、または生ログ（UTC）と表示・突合系（JST）の換算規則が未定義	複数ログ間で事象の時系列を突合できず、期間を指定した抽出が境界日でずれ、証跡の対応関係を示せない	全構成要素を単一時刻源へ同期し、タイムスタンプ表記規約と換算規則を設計書に明記。タイムゾーン表記を含まない DB 監査ログは公式ドキュメントと実データで基準を確認	LR-03
抽出手順が未整備で、監査依頼への回答が期限に間に合わない	証跡は存在するのに提示できず、統制が無効と評価されうる	抽出手順書と定型クエリを整備し、リハーサル（フェーズ4）で所要時間を実測。テーブル定義は移行前後の双方を対象化	LR-10/ LR-14

13.5 発注者との合意事項チェックリスト

次の事項は開発ベンダーが単独で決定できない。**必須** フェーズ0からフェーズ1着手までの間に発注者と合意し、合意内容と決定日、決定者をログ設計書（D-03）に記載すること。未合意のまま実装を進めると、後戻りが不可能な設定（Object Lock の保持期間、バケット構成、アカウント構成）に影響する。

表13-3 発注者との合意事項チェックリスト

合意項目	合意すべき内容	主な当事者	関連
対象範囲	財務報告に関連するシステム、区分 (3) の記録を扱うシステム (0.3)、AWS アカウント、リージョン、対象外とするものとその理由	R-1/R-2 (提案はR-3)	LR-01
取得するログ種別	L-01～L-14 の取得要否。データイベントの対象範囲。取得しない種別の理由と代替統制	R-1/R-2	LR-01
保存年限	ログ種別ごとの区分 (7.1.3)、即時照会可能期間とアーカイブ期間、合計保存年限と起算点 (区分 (3) は 7.8)。参照する根拠 (会社法・法人税法・金商法の縦覧期間・セキュリティ上の推奨) と、最終決定は発注者が行うこと	R-1 (R-2 が確認)	LR-05
アカウント構成	組織の証跡の所有主体、ログアーカイブ用アカウントの所有・運用主体、既存アカウントの Organizations 参加時期	R-2 (R-1 が承認)	LR-06 /LR-13
監査人アクセス方式	監査人 (R-6) へ読み取り専用ロールを直接付与するか、抽出を代行して成果物を提出するか。開示範囲 (他システム・他社データを含めない措置) と申請・承認手順	R-1/R-2 /R-6	LR-06 /LR-10
レビュー体制	定期レビューの実施者と承認者、頻度、確認範囲とサンプル方針、使用する様式、記録の保存先	R-2/R-4 /R-5	LR-09
職務分掌	ログ管理者 (R-5) を発注者側に置くか運用ベンダー側に置くか。運用ベンダー側に置く場合は、R-4 (運用者) と同一の担当者・同一の指揮命令系統としないこと (兼務は不可) を条件として明記する。緊急時の特権利用と事後承認の手順	R-1/R-2	LR-06
委託業務の評価方法	運用ベンダーが実施するログ取得・保全・レビューについて、発注者がその内部統制をどの方法で評価するか (質問書・確認書の送付、往査、受託会社の内部統制に関する保証報告書の入手のいずれによるか)、および結果の受領時期。保証報告書の入手は選択肢の一つであり、必ず必要となるものではない	R-1/R-2 (R-4が協力)	LR-13
監視・アラート運用	検知対象事象、通知先と通知手段、対応時間帯 (常時か営業時間内か)、一次対応者と是正責任者、エスカレーション基準	R-2/R-4	LR-08
ログ設定の変更管理	ログ設定変更の申請・承認手順と承認者、IaC で管理する範囲、緊急変更時の事後承認期限	R-2/R-3 /R-4	LR-12
移行方針	切替日と並行運用期間、二重取得の対象と期間、旧システムログの保全主体・保全場所・参照手段	R-1/R-2	LR-01 /LR-05
欠損・障害時の報告	ログの欠落・配信失敗を検知した際の報告先と報告期限、再取得の可否と代替証跡、記録の残し方	R-2/R-4 /R-5	LR-11
費用負担の考え方	課金が発生する要素 (データイベントの取得、管理イベントを重複記録する2本目以降の証跡、ログの取り込み・保管、スキャン量に応じた照会、長期アーカイブからの取り出し) について、負担区分と、取得量が想定を超えた場合の見直し手順。監査対応の抽出作業の工数の扱い	R-1/R-2	LR-13
文書化と引継ぎ	ログ設計書・運用手順書の納品範囲と更新責任、運用ベンダーへの引継ぎ時期と引継ぎ内容	R-2/R-3 /R-4	LR-14

● 補足

保存年限は J-SOX の基準・実施基準そのものが年数を定めているわけではない。上表の「保存年限」は、会社法・法人税法・金融商品取引法上の縦覧期間やセキュリティ上の推奨といった外部の根拠を整理したうえで、発注者が自社の方針として決定する事項である。開発ベンダーは根拠と選択肢を提示し、決定内容を設計に反映する立場にあることを、提案時に明確にすること（第7章）。

付録

本付録は、本文（第0章～第13章）を設計・構築・運用設計に落とし込む際の参照資料である。付録Aは用語、付録Bは根拠とした一次情報、付録Cは実装すべき設定値、付録Dは運用で用いる記録様式、付録EおよびFは要求事項とログ種別の索引である。

レベル欄の意味は本文と同一とする。**必須** は発注者が受入条件とする事項、**推奨** は合理的理由なく省略しない事項、**任意** は発注者と協議して採否を決める事項である。AWSの既定値・設定可能範囲・上限は本書作成時点の記載に基づくため、実装着手時に付録Bの該当ページで再確認すること。

付録A 用語集

表A-1 用語集

用語	説明	関連
J-SOX	金融商品取引法に基づく内部統制報告制度の通称。上場株券等の発行者に内部統制報告書の提出義務が課される。	第1章
内部統制報告書	金融商品取引法第24条の4の4第1項に基づき、有価証券報告書と併せて提出する報告書。上場会社等は原則として公認会計士又は監査法人の監査証明を受ける（同法第193条の2第2項ただし書により、資本の額等が内閣府令で定める基準に達しない上場会社等は、上場会社等に初めて該当した日から一定期間、監査証明が不要となる）。	第1章
実施基準	企業会計審議会「財務報告に係る内部統制の評価及び監査に関する実施基準」。2023年4月7日改訂、2024年4月1日以後開始事業年度から適用。	第1章
IT全社的統制	企業集団全体を対象としたITに係る内部統制。経済産業省「システム管理基準 追補版」の用語であり、金融庁の基準・実施基準本文には現れない。	第1章
IT全般統制（ITGC）	業務処理統制が有効に機能する環境を保証する統制活動。実施基準は開発・保守・運用・管理、アクセス管理等による安全性の確保、外部委託契約の管理を例示する。	ITGC-A～D
IT業務処理統制	承認された業務が全て正確に処理・記録されることを確保するため業務プロセスに組み込まれた統制。入力完全性・正確性・正当性、例外処理、マスタ管理、アクセス管理が例。	第1章
整備状況評価	統制上の要点が適切に整備されているかを、関連文書の閲覧・質問・観察等により判断する評価。	第1章
運用状況評価	関連文書の閲覧・質問・観察、内部統制の実施記録の検証等により、意図どおり運用されているかを確認する評価。原則としてサンプリングによる。ログは実施記録の主要な証拠となる。	第1章
ロールフォワード	期中に運用状況評価を行った場合に、期末日までの重要な変更を把握し追加手続を行う実務上の呼称。実施基準にこの語はなく、評価の実施時期に関する規定が該当する。	第1章、第13章
不備	統制が存在しない等の整備上の不備と、意図したように運用されていない等の運用の不備からなる。	第1章
開示すべき重要な不備	財務報告に重要な影響を及ぼす可能性が高い不備。IT全般統制の不備は直ちに開示すべき重要な不備と評価されるものではない。ただし、IT全般統制に不備がある場合は、たとえIT業務処理統制が有効に機能するよう整備されていても、その有効な運用を継続的に維持できない可能性があり、虚偽記載が発生するリスクが高まる。	第1章
監査証拠	操作の発生から記録までを事後に追跡・検証できる記録。システム監査基準は監査調書に監査証拠を含む記録の記載と保管を求める。	第12章
特権ID	マスター情報・パラメータ設定値の変更や会計データの作成・変更・削除、権限設定等が可能な、操作に制限を受けない特別なID。	LR-06、様式D-3
職務分掌	相互に牽制が働くよう役割と権限を分離すること。本書では開発・運用・ログ管理・監査の分離と、ログの書込・読取・設定変更の権限分離を指す。	第10章、LR-06
5W1H	本書におけるログ記録項目の要件。誰が・いつ・どこから・何に対し・何を・結果はどうであったかを一意に特定できる項目群。	LR-02
WORM	Write Once Read Many。一度書き込んだ後は保持期間中の変更・削除ができない保存方式。	LR-04
Object Lock	Amazon S3のWORM機能。バージョニング有効バケットでのみ動作し、有効化後は無効化もバージョニング停止もできない。ガバナンス／コンプライアンスの2モードがある。	第8章、LR-04
リーガルホールド	保持期限とは独立に設定する期限のない保護。s3:PutObjectLegalHold 権限者が設定・解除でき、係争・調査時の証拠保全に用いる。	第8章、LR-04

用語	説明	関連
ブレークグラス	緊急時に限り高権限を使用する例外手続。発動条件、時限的付与、全操作の記録、事後レビューを伴う。	第10章、様式D-3
相関ID	複数ログを一つの処理単位で突合する識別子。CloudTrail の <code>eventID</code> / <code>requestID</code> 、IAM Identity Center の <code>AuthWorkflowID</code> 等。	LR-02、LR-03
UTC/ISO 8601	協定世界時と日付時刻の国際表記形式。CloudTrail の <code>eventTime</code> は UTC。本書は証跡上の日時を <code>YYYY-MM-DDThh:mm:ssZ</code> に統一する。	LR-03
IaC	Infrastructure as Code。インフラ構成をコードで定義し、版管理とレビューを経て適用する方式。	LR-12、L-10
ドリフト	IaCで定義した期待値と実際の設定との差異。CloudFormation のドリフト検出、および AWS Config ルール（期待値との適合性評価）が検出手段。ログ基盤自体の設定変更は CloudTrail と L-14 で検知する。	LR-12
責任共有モデル	AWSが「クラウドのセキュリティ」、利用者が「クラウド内のセキュリティ」を担う分担。継承・共有・利用者固有のコントロールに区分される。	LR-13
SOC 1	委託会社の財務報告に係る内部統制に関連する受託会社の統制を対象とする保証報告書。JICPA保証業務実務指針3402に該当。基準日を対象とするタイプ1と、一定期間の運用状況まで対象とするタイプ2がある。	LR-13
AWS Artifact	AWSのコンプライアンスレポート・認証をオンデマンド取得するサービス。取得文書の共有は社内、規制当局、監査人に限られる。	LR-13、第12章
証跡（Trail）	CloudTrail でイベントを継続記録し S3 等へ配信する設定単位。イベント履歴（過去90日の管理イベント）とは別に作成を要する。	L-01
管理イベント／データイベント	前者はリソースへの管理操作の記録で証跡では既定で記録される。後者はリソース内のデータ操作の記録で既定では記録されず追加料金が発生する。	L-01、L-02
ダイジェストファイル	CloudTrail のログファイル整合性検証を有効化すると1時間ごとに配信される、ログのSHA-256 ハッシュを含むファイル。前のダイジェストの署名を含む連鎖構造を持つ。	第8章、LR-04
組織の証跡	管理アカウントまたは委任管理者が作成し、組織内全アカウントのイベントを単一バケットに記録する証跡。メンバーは削除・停止・変更ができない。	第6章、LR-01
設定項目（CI）	AWS Config が記録する、特定時点のリソースの属性・関係・関連イベントの記録。	L-03
アグリゲータ	複数アカウント・リージョンまたは組織全体の AWS Config データを集約する読み取り専用ビュー。追加料金は発生しない。	第5章、LR-10
メトリクスフィルター	CloudWatch Logs のログイベントをパターンで抽出しメトリクス化する機能。作成後に取り込まれたデータのみが対象で、過去に遡って適用できない。	第9章、LR-08
サブスクリプションフィルター	CloudWatch Logs のイベントを Amazon Data Firehose 等へ準リアルタイム転送する機能。長期保管への連携手段。	第7章、LR-05
Logs Insights	CloudWatch Logs のクエリ機能。クエリ結果は7日間保持される。	第12章、LR-10
パーティション射影	Athena がパーティション値をテーブルプロパティから計算する方式。ALTER TABLE ADD PARTITION による手動追加が不要になる。	第12章、LR-10

用語	説明	関連
CMK	AWS KMS のカスタマー管理キー（customer managed key）。AWS KMS は旧称 customer master key（CMK）を廃止して「KMS キー」に改称しているため、本書の CMK はカスタマー管理キーを指す略語として用いる。各KMSキーはちょうど一つのキーポリシーを持ち、キーポリシーが有効化しない限りIAMポリシーで許可を与えられない。	LR-07
SCP	サービスコントロールポリシー。メンバーアカウントのIAMプリンシパル（ルートユーザーを含む）の最大権限を定義する。権限は付与せず、管理アカウントとサービスリンクロールには影響しない。	第10章、LR-04
RCP	リソースコントロールポリシー。組織内リソースへの最大権限を定義し、組織外プリンシパルからのアクセスにも適用される。	第10章、LR-06
委任管理者	管理アカウントに代わり、特定サービスの組織全体の設定を管理する権限を委任されたメンバーアカウント。	第6章
Log Archive アカウント	セキュリティ関連ログとバックアップの取り込み・保管専用アカウント。不変ストレージとし、統制・自動化・監視された仕組みのみからアクセスする。	第6章、LR-06
Vault Lock	AWS Backup のボールドに対するWORM構成。権限があれば解除できるガバナンスモードと、猶予期間後は解除できないコンプライアンスモードがある。	L-13、LR-11
Amazon Time Sync Service	EC2からリンクローカルアドレス（IPv4 169.254.169.123、IPv6 fd00:ec2::123。IPv6はNitro ベースのインスタンスでのみ利用可能で、IPv4 との併用は不要）で利用する時刻同期サービス。パブリックエンドポイントは time.aws.com。うるう秒は NTP エンドポイントではスミアされるが、PTP ハードウェアクロックはスミアしない。	LR-03
ライフサイクルルール	S3 オブジェクトのストレージクラス移行と有効期限を定義する設定。既存オブジェクトにも適用され、バケットポリシーではライフサイクルによる削除・移行を防げない。	第7章、LR-05

● 補足

「IT全社統制」は経済産業省の追補版の用語であり、「ロールフォワード」は金融庁の基準・実施基準・追補版のいずれにも現れない。監査人との協議や成果物への記載では、対応する基準上の記述に紐付けて用いること。

付録B 参考文献

表B-1 参考文献（法令・基準・ガイドライン）

区分	名称	URL
法令	金融商品取引法（第24条の4の4、第25条、第193条の2）	https://laws.e-gov.go.jp/law/323AC0000000025
法令	金融商品取引法施行令（第4条の2の7、第35条の2、第35条の3）	https://laws.e-gov.go.jp/law/340CO0000000321
法令	財務計算に関する書類その他の情報の適正性を確保するための体制に関する内閣府令	https://laws.e-gov.go.jp/law/419M60000002062
法令	会社法（第432条第2項、第435条第4項）	https://laws.e-gov.go.jp/law/417AC0000000086
法令	法人税法施行規則（第26条の3、第59条、第67条）	https://laws.e-gov.go.jp/law/340M5000040012
法令	電子帳簿保存法（電子計算機を使用して作成する国税関係帳簿書類の保存方法等の特例に関する法律）	https://laws.e-gov.go.jp/law/410AC0000000025
国税庁	タックスアンサー No.5930 帳簿書類等の保存期間	https://www.nta.go.jp/taxes/shiraberu/taxanswer/hojin/5930.htm
金融庁・企業会計審議会	財務報告に係る内部統制の評価及び監査の基準並びに財務報告に係る内部統制の評価及び監査に関する実施基準の改訂について（意見書、2023年4月7日、企業会計審議会）	https://www.fsa.go.jp/news/r4/sonota/20230407/1.pdf
金融庁・企業会計審議会	同 新旧対照表（抄）	https://www.fsa.go.jp/news/r4/sonota/20230407/3.pdf
金融庁	同 公表ページ（適用時期・意見募集結果）	https://www.fsa.go.jp/news/r4/sonota/20230407/20230407.html
金融庁	内部統制報告制度に関するQ&A（2023年8月31日改訂）	https://www.fsa.go.jp/news/r5/sonota/20230831-2/02.pdf
経済産業省	システム管理基準（2023年4月26日改訂）	https://www.meti.go.jp/policy/netsecurity/sys-kansa/sys-kanri-2023.pdf
経済産業省	システム監査基準（2023年4月26日改訂）	https://www.meti.go.jp/policy/netsecurity/sys-kansa/sys-kansa-2023r.pdf
経済産業省	システム管理基準 追補版（財務報告に係るIT統制ガイダンス、2024年12月25日）	https://www.meti.go.jp/policy/netsecurity/docs/secgov/2024_ZaimuHokokuNiKakaruITTouseiGuidance.pdf
JICPA	監査基準報告書315「重要な虚偽表示リスクの識別と評価」（最終改正2022年6月16日）	https://jicpa.or.jp/specialized_field/2-24-315-2-20220616.pdf
JICPA	監査基準報告書315 実務ガイダンス第1号（ITの利用に係るQ&A、改正2022年10月13日）	https://jicpa.or.jp/specialized_field/2-24-315g_1-2-20221013.pdf
JICPA	財務報告内部統制監査基準報告書第1号「財務報告に係る内部統制の監査」（最終改正2025年2月13日。2025年4月1日以後開始する連結会計年度及び事業年度に係る内部統制監査から適用）	https://jicpa.or.jp/specialized_field/files/2-24-nkh_1-2-20250214.pdf

区分	名称	URL
JICPA	同 改正の公表ページ（改正の概要・適用時期）	https://jicpa.or.jp/specialized_field/20250214ige.html
JICPA	保証業務実務指針3402「受託業務に係る内部統制の保証報告書に関する実務指針」	https://jicpa.or.jp/specialized_field/2-24-3402-2-20250723.pdf
JICPA	品質管理基準報告書第1号（監査調書の保存期間に関する適用指針を含む）	https://jicpa.or.jp/specialized_field/files/0-99-0-2-20230316.pdf
NISC	政府機関等の対策基準策定のためのガイドライン（令和7年度版、2025年9月5日一部改定）	https://www.cyber.go.jp/pdf/policy/general/guider7_9.pdf
総務省	地方公共団体における情報セキュリティポリシーに関するガイドライン（令和6年10月版）	https://www.soumu.go.jp/main_content/000970479.pdf
総務省	国民のためのサイバーセキュリティサイト「監査ログの管理」	https://www.soumu.go.jp/main_sosiki/cybersecurity/kokumin/security/business/admin/12/
JPCERT/CC	高度サイバー攻撃への対処におけるログの活用と分析方法（1.2版、2022年5月10日）	https://www.jpcert.or.jp/research/APT-loganalysis_Report_20220510.pdf
NIST	SP 800-92 Guide to Computer Security Log Management（2006年9月）	https://nvlpubs.nist.gov/nistpubs/legacy/SP/nistspecialpublication800-92.Pdf
IPA	NIST SP 800-92 日本語訳「コンピュータセキュリティログ管理ガイド」	https://www.ipa.go.jp/security/reports/oversea/nist/ug65p90000019cp4-att/begoj9000000bfnm.pdf
日本規格協会	JIS Q 27002:2024 情報セキュリティ管理策（2024年6月20日発行）	https://webdesk.jsa.or.jp/books/W11M0090/index/?bunsyo_id=JIS+Q+27002%3A2024

表B-2 参考文献（AWS公式ドキュメント・ホワイトペーパー）

区分	名称	URL
CloudTrail	管理イベントのログ記録	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/logging-management-events-with-cloudtrail.html
CloudTrail	データイベントのログ記録	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/logging-data-events-with-cloudtrail.html
CloudTrail	組織の証跡の作成	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/creating-trail-organization.html
CloudTrail	ログファイル整合性検証の概要	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-log-file-validation-intro.html
CloudTrail	AWS CLI によるログファイル整合性の検証	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-log-file-validation-cli.html
CloudTrail	S3 バケットポリシーの要件	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/create-s3-bucket-policy-for-cloudtrail.html
CloudTrail	KMS キーポリシーの要件	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/create-kms-key-policy-for-cloudtrail.html
CloudTrail	CloudWatch Logs へのイベント送信	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/send-cloudtrail-events-to-cloudwatch-logs.html
CloudTrail	CloudTrail 用の CloudWatch アラームの作成	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudwatch-alarms-for-cloudtrail.html
CloudTrail	イベントレコードの内容	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-event-reference-record-contents.html
CloudTrail	userIdentity 要素	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-event-reference-user-identity.html
CloudTrail	イベント履歴の表示（過去90日の管理イベント）	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/view-cloudtrail-events.html
CloudTrail	セキュリティのベストプラクティス	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/best-practices-security.html
AWS Config	記録対象リソースの選択	https://docs.aws.amazon.com/config/latest/developerguide/select-resources.html
AWS Config	配信チャネルの管理	https://docs.aws.amazon.com/config/latest/developerguide/manage-delivery-channel.html
AWS Config	設定項目の保持期間	https://docs.aws.amazon.com/config/latest/developerguide/delete-config-data-with-retention-period.html

区分	名称	URL
AWS Config	マネージドルール一覧	https://docs.aws.amazon.com/config/latest/developerguide/managed-rules-by-aws-config.html
AWS Config	cw-loggroup-retention-period-check (MinRetentionTimeの有効値)	https://docs.aws.amazon.com/config/latest/developerguide/cw-loggroup-retention-period-check.html
AWS Config	データの集約（アグリゲータ）	https://docs.aws.amazon.com/config/latest/developerguide/aggregate-data.html
AWS Config	高度なクエリ	https://docs.aws.amazon.com/config/latest/developerguide/querying-AWS-resources.html
CloudWatch Logs	ロググループとログストリームの操作	https://docs.aws.amazon.com/AmazonCloudWatch/latest/logs/Working-with-log-groups-and-streams.html
CloudWatch Logs	PutRetentionPolicy API（保持期間の有効値）	https://docs.aws.amazon.com/AmazonCloudWatchLogs/latest/APIReference/API_PutRetentionPolicy.html
CloudWatch Logs	AWS KMS によるログデータの暗号化	https://docs.aws.amazon.com/AmazonCloudWatch/latest/logs/encrypt-log-data-kms.html
CloudWatch Logs	ログクラス（Standard／Infrequent Access）	https://docs.aws.amazon.com/AmazonCloudWatch/latest/logs/CloudWatch_Logs_Log_Classes.html
CloudWatch Logs	機微データのマスキング（データ保護ポリシー）	https://docs.aws.amazon.com/AmazonCloudWatch/latest/logs/mask-sensitive-log-data.html
CloudWatch Logs	ロググループの削除保護	https://docs.aws.amazon.com/AmazonCloudWatch/latest/logs/protecting-log-groups-from-deletion.html
CloudWatch Logs	メトリクスフィルターによるログデータの監視	https://docs.aws.amazon.com/AmazonCloudWatch/latest/logs/MonitoringLogData.html
CloudWatch Logs	サブスクリプションフィルターによるログデータのリアルタイム処理	https://docs.aws.amazon.com/AmazonCloudWatch/latest/logs/SubscriptionFilters.html
CloudWatch Logs	S3 へのログデータのエクスポート	https://docs.aws.amazon.com/AmazonCloudWatch/latest/logs/S3Export.html
CloudWatch エージェント	エージェント設定ファイルの詳細（ファイルログ・Windows イベントログの収集）	https://docs.aws.amazon.com/AmazonCloudWatch/latest/monitoring/CloudWatch-Agent-Configuration-File-Details.html
Amazon S3	S3 Object Lock（モードと動作）	https://docs.aws.amazon.com/AmazonS3/latest/userguide/object-lock.html
Amazon S3	S3 Object Lock の設定	https://docs.aws.amazon.com/AmazonS3/latest/userguide/object-lock-configure.html
Amazon S3	ライフサイクル移行に関する一般的な考慮事項	https://docs.aws.amazon.com/AmazonS3/latest/userguide/lifecycle-transition-general-considerations.html
Amazon S3	ストレージクラス（最小保存期間）	https://docs.aws.amazon.com/AmazonS3/latest/userguide/storage-class-intro.html

区分	名称	URL
Amazon S3	MFA Delete	https://docs.aws.amazon.com/AmazonS3/latest/userguide/MultiFactorAuthenticationDelete.html
Amazon S3	バケットポリシーの例	https://docs.aws.amazon.com/AmazonS3/latest/userguide/example-bucket-policies.html
Amazon S3	S3 のログ記録オプションの比較	https://docs.aws.amazon.com/AmazonS3/latest/userguide/logging-with-S3.html
Amazon S3	サーバーアクセスログの記録（配信先の選択肢と配信特性）	https://docs.aws.amazon.com/AmazonS3/latest/userguide/ServerLogs.html
Amazon S3	サーバーアクセスログの有効化（配信先バケットの要件）	https://docs.aws.amazon.com/AmazonS3/latest/userguide/enable-server-access-logging.html
AWS KMS	キーポリシー	https://docs.aws.amazon.com/kms/latest/developerguide/key-policies.html
AWS KMS	自動キーローテーション	https://docs.aws.amazon.com/kms/latest/developerguide/rotating-keys-enable.html
AWS KMS	キーの削除	https://docs.aws.amazon.com/kms/latest/developerguide/deleting-keys.html
Systems Manager	Session Manager のセッションアクティビティのログ記録	https://docs.aws.amazon.com/systems-manager/latest/userguide/session-manager-logging.html
Systems Manager	セッションの開始（SSH・ポートフォワーディングのセッションドキュメント）	https://docs.aws.amazon.com/systems-manager/latest/userguide/session-manager-working-with-sessions-start.html
Amazon Aurora	Aurora MySQL の高度な監査	https://docs.aws.amazon.com/AmazonRDS/latest/AuroraUserGuide/AuroraMySQL.Auditing.html
Amazon RDS	MariaDB Audit Plugin（RDS for MySQL）	https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/Appendix.MySQL.Options.AuditPlugin.html
Amazon RDS	pgAudit を使用したデータベースアクティビティのログ記録	https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/Appendix.PostgreSQL.CommonDBATasks.pgaudit.html
Amazon RDS	CloudWatch Logs へのデータベースログの発行	https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/USER_LogAccess.Procedural.UploadtoCloudWatch.html
Amazon Aurora	Database Activity Streams	https://docs.aws.amazon.com/AmazonRDS/latest/AuroraUserGuide/DBActivityStreams.html
Amazon RDS	Db2 監査ログ記録	https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/Db2.Options.Audit.html
Amazon RDS	RDS for Db2 の監査ポリシーのストアブローージャ	https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/db2-sp-managing-audit-policies.html
Amazon RDS	Amazon RDS for Db2 データベースのログファイル	https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/USER_LogAccess.Concepts.Db2.html

区分	名称	URL
Amazon RDS	データベースアクティビティストリームでサポートされているリージョンと DB エンジン	https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/Concepts.RDS_Fea_Regions_DB-eng.Feature.DBActivityStreams.html
Amazon VPC	フローログレコード（カスタム形式のフィールド）	https://docs.aws.amazon.com/vpc/latest/userguide/flow-log-records.html
Amazon VPC	フローログの制約事項（記録されない通信）	https://docs.aws.amazon.com/vpc/latest/userguide/flow-logs-limitations.html
Elastic Load Balancing	Application Load Balancer のアクセスログ	https://docs.aws.amazon.com/elasticloadbalancing/latest/application/load-balancer-access-logs.html
AWS WAF	Web ACL トラフィックのログ記録	https://docs.aws.amazon.com/waf/latest/development/guide/logging.html
Amazon GuardDuty	検出結果のエクスポート	https://docs.aws.amazon.com/guardduty/latest/userguide/guardduty_exportfindings.html
Security Hub CSPM	CloudWatch コントロール（CIS 準拠のメトリクスフィルター）	https://docs.aws.amazon.com/securityhub/latest/userguide/cloudwatch-controls.html
Security Hub CSPM	CIS AWS Foundations Benchmark（対応バージョンと自動チェック範囲）	https://docs.aws.amazon.com/securityhub/latest/userguide/securityhub-standards-cis.html
Amazon EventBridge	CloudTrail 経由の AWS API 呼び出しイベント	https://docs.aws.amazon.com/eventbridge/latest/userguide/eb-service-event-cloudtrail-management.html
Amazon SNS	Subscribe API（確認トークンの有効期間）	https://docs.aws.amazon.com/sns/latest/api/API_Subscribe.html
Amazon SNS	E メールサブスクリプションの設定と管理（未確認サブスクリプションの削除、バウンス時の抑止）	https://docs.aws.amazon.com/sns/latest/dg/sns-email-notifications.html
AWS CloudFormation	スタックのドリフト検出	https://docs.aws.amazon.com/AWSCloudFormation/latest/UserGuide/using-cfn-stack-drift.html
AWS Backup	AWS Backup Vault Lock	https://docs.aws.amazon.com/aws-backup/latest/devguide/vault-lock.html
AWS Backup	Backup Audit Manager	https://docs.aws.amazon.com/aws-backup/latest/devguide/aws-backup-audit-manager.html
AWS Organizations	サービスコントロールポリシー（SCP）	https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_scps.html
AWS Organizations	リソースコントロールポリシー（RCP）	https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_rcps.html
AWS Control Tower	ログ保持期間の設定	https://docs.aws.amazon.com/controltower/latest/userguide/configure-log-retention.html
AWS Control Tower	必須コントロール（ログ設定変更を拒否する SCP）	https://docs.aws.amazon.com/controltower/latest/controlreference/mandatory-controls.html
AWS IAM	認証情報レポートの取得	https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_getting-report.html

区分	名称	URL
AWS IAM	ルートユーザーの MFA 有効化	https://docs.aws.amazon.com/IAM/latest/UserGuide/enable-mfa-for-root.html
IAM Identity Center	サインインイベントの理解	https://docs.aws.amazon.com/singlesignon/latest/userguide/understanding-sign-in-events.html
Amazon EC2	インスタンスの時刻設定	https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/set-time.html
Amazon EC2	EC2 インスタンスの NTP 設定（リンクローカルアドレスと Nitro 要件）	https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/configure-ec2-ntp.html
Amazon Athena	パーティション射影を使用した CloudTrail テーブルの作成	https://docs.aws.amazon.com/athena/latest/ug/create-cloudtrail-table-partition-projection.html
Amazon Athena	CloudTrail ログのクエリ例	https://docs.aws.amazon.com/athena/latest/ug/query-examples-cloudtrail-logs.html
Well-Architected	セキュリティの柱 SEC04-BP01 サービスとアプリケーションのログ記録を設定する	https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/sec_detect_investigate_event_s_app_service_logging.html
Prescriptive Guidance	AWS Security Reference Architecture: Log Archive アカウント	https://docs.aws.amazon.com/prescriptive-guidance/latest/security-reference-architecture/log-archive.html
AWS Artifact	文書のダウンロードと共有条件	https://docs.aws.amazon.com/artifact/latest/ug/downloading-documents.html
AWS	責任共有モデル	https://aws.amazon.com/compliance/shared-responsibility-model/
AWS	SOC コンプライアンスに関するよくある質問	https://aws.amazon.com/compliance/soc-faqs/
AWS（ホワイトペーパー）	AWS の使用に際しての監査の概要（2015年10月）	https://d1.awsstatic.com/whitepapers/compliance/Jp_Whitepapers/AWS_Auditing_Security_Checklist_jp.pdf

● 注意

「AWS の使用に際しての監査の概要」は2015年10月公開であり、S3 Object Lock、AWS Control Tower、組織の証跡といった現行機能に言及していない。監査の着眼点の整理には利用できるが、現行仕様の根拠には用いず、表B-2の各サービスドキュメントを参照すること。

付録C 設定パラメーター一覧

本表は開発ベンダーが設計書および構築物に反映すべき設定値である。「推奨値・設定内容」欄には、AWS の既定値・設定可能範囲と、本書が求める設定内容を併記する。受入条件となるか否かはレベル欄が示す。ログの保存期間そのものは第7章に基づき発注者が決定する。決定前に暫定値で構築する場合は、暫定である旨と確定手続を設計書に明記すること。

「関連LR／ログ種別」欄には、ログ管理要求事項ID（LR-01～LR-14、付録E）とログ種別ID（L-01～L-14、付録F）を、LR-xx を先、L-xx を後の順で記載する。対象のログ種別が特定の一つに限定されない行には L-xx を付さない。

表C-1 設定パラメーター一覧（1）基盤ログの取得・保全

サービス	パラメータ	推奨値・設定内容	レベル	関連 LR ／ロ グ種 別
CloudTrail	証跡の記録範囲	マルチリージョン証跡（ <code>IsMultiRegionTrail=true</code> ）とすること。	必須	LR-01
CloudTrail	<code>IncludeGlobalServiceEvents</code>	<code>true</code> とすること。IAM・STS・CloudFront のイベントは us-east-1 に記録されるため、無効化すると認証系を取りこぼす。	必須	LR-01
CloudTrail	組織の証跡	管理アカウントまたは委任管理者が作成し、全メンバーを対象とすること。新規追加アカウントは自動的に記録対象となる。	必須	LR-01, LR-13
CloudTrail	管理イベント	Read／Write の両方を記録すること。	必須	LR-01, LR-02
CloudTrail	<code>ExcludeManagementEventSources</code>	空（除外なし）とすること。除外期間中のイベントは事後に回復できない。除外する場合は理由を設計書に記録すること。この場合、必須のマネージドルール <code>multi-region-cloudtrail-enabled</code> は恒常的に NON_COMPLIANT となるため、除外の承認記録と当該ルールの例外扱いを LR-12 の変更管理証跡に含めること。	推奨	LR-01
CloudTrail	データイベント	財務報告に関連するデータを保持する S3 バケット等に対し有効化すること。既定では記録されず追加料金が発生する。	必須	LR-01, L-02
CloudTrail	ログファイル整合性検証	有効化すること。1時間ごとにダイジェストファイルが配信される。有効化のみでは検証は行われないため、検証手順を運用に組み込むこと。	必須	LR-04
CloudTrail	CloudWatch Logs 連携	アラート対象とする証跡（少なくとも管理イベントを記録する組織の証跡）で有効化すること。表C-2のメトリクスフィルターは本連携を前提とするため、連携なしでは LR-08 の要求を満たせない。256 KB を超えるイベントは送信されない点に留意する。	必須	LR-08, L-14
CloudTrail	配信状態の監視	<code>get-trail-status</code> により配信エラーを定期確認すること。バケットポリシー誤りがあっても組織の証跡は作成されるため、作成成功と配信成功を別に確認すること。	必須	LR-11
CloudTrail	設定変更の抑止	<code>StopLogging</code> ／ <code>DeleteTrail</code> ／ <code>UpdateTrail</code> ／ <code>PutEventSelectors</code> を SCP で拒否し、例外ロールのみを <code>ArnNotLike</code> で除外すること。	必須	LR-04, LR-12
AWS Config	設定レコーダー	対象全リージョンで有効化し、サポート対象リソースタイプを記録すること。記録頻度は Continuous とすること。	必須	LR-01, L-03

サービス	パラメータ	推奨値・設定内容	レベル	関連 LR ／ロ グ種 別
AWS Config	グローバルIAMリソース	設定項目の重複を避けるため1リージョンでのみ記録すること。2022年2月以降にAWS Configが提供されたリージョンでは記録できない点を確認すること。	推奨	LR-01
AWS Config	配信チャンネル	ログ専用アカウントの S3 バケットを指定すること。既定の保持設定を有効化した Object Lock バケットは配信先としてサポートされないため、CloudTrail 用バケットとは分離すること。	必須	LR-01, LR-04
AWS Config	設定項目の保持期間	30～2,557日の範囲で、第7章で発注者が決定した保存期間に合わせる（既定7年＝2,557日）。S3・SNS 側の保持は別管理である。	必須	LR-05
AWS Config	マネージドルール	最低限 multi-region-cloudtrail-enabled、cloud-trail-log-file-validation-enabled、cloud-trail-encryption-enabled、cloud-trail-cloud-watch-logs-enabled、s3-bucket-versioning-enabled、vpc-flow-logs-enabled を適用すること。	必須	LR-12
AWS Config	cw-loggroup-retention-period-check	MinRetentionTime を発注者決定の保存期間に合わせる。本ルールは無期限保持を COMPLIANT と判定するため、無期限設定の検出には別途クエリを併用すること。ただし MinRetentionTime の有効値は 1/3/5/7/14/30/60/90/120/150/180/365/400/545/731/1827/3653 日に限られ、ロググループ側で設定可能な 1096/2192/2557/2922/3288 日は指定できない。発注者決定の保存期間がこれらに該当する場合、本ルール単独では要求値を表現できないため、その旨を設計書に記録したうえで、実際の retentionInDays を照合する別途のクエリまたはカスタムルールを併用すること。	推奨	LR-05, LR-12
AWS Config	設定変更の抑止	StopConfigurationRecorder / DeleteConfigurationRecorder / DeleteDeliveryChannel / PutConfigurationRecorder / PutRetentionConfiguration を SCP で拒否し、ログ設定を適用する IaC 実行ロールのみを aws:PrincipalArn の ArnNotLike で除外すること（除外ロールの使用は L-14 の検知対象とする）。	必須	LR-04, LR-12
CloudWatch Logs	ロググループの保持期間	既定は無期限保持であるため必ず明示設定すること。設定可能値は 1/3/5/7/14/30/60/90/120/150/180/365/400/545/731/1096/1827/2192/2557/2922/3288/3653 日である。第7章で決定した保存期間に最も近い値を選択すること。	必須	LR-05
CloudWatch Logs	暗号化	監査対象ロググループにカスタマー管理キーを関連付けること。既存ロググループへの関連付けはコンソールでは行えない。	推奨	LR-07

サービス	パラメータ	推奨値・設定内容	レベル	関連 LR ／ロ グ種 別
CloudWatch Logs	削除保護	監査対象ロググループで有効化すること（既定は無効）。	推奨	LR-04
CloudWatch Logs	ログクラス	メトリクスフィルターやサブスクリプションフィルターを設定するロググループは Standard とすること。作成後にクラスは変更できない。	推奨	LR-05, LR-08
CloudWatch Logs	データ保護ポリシー	認証情報・PII 等のマネージドデータ識別子でマスクすること。設定前に取り込まれたイベントはマスクされないため設計初期に適用すること。解除には logs: Unmask を要する。	推奨	LR-07
CloudWatch Logs	長期保管への連携	サブスクリプションフィルターを用いること。定期的な S3 エクスポートは継続的のアーカイブ用途には推奨されない。	推奨	LR-05, LR-11
CloudWatch Logs	削除・保持変更の抑止	監査対象ロググループに対する logs: DeleteLogGroup / logs: PutRetentionPolicy を SCP で拒否し、ログ設定を適用する IaC 実行ロールのみを aws:PrincipalArn の ArnNotLike で除外すること（除外ロールの使用は L-14 の検知対象とする）。	必須	LR-04
Amazon S3	バージョニング	ログアーカイブバケットで有効化すること。有効化後は未バージョニング状態に戻せない。	必須	LR-04
Amazon S3	Object Lock の有効化	ログアーカイブバケットで有効化すること。バージョニングの先行有効化が必要で、有効化後は無効化できない。AWS Security Reference Architecture は、CloudTrail ログの完全性保護手段としてログファイル整合性検証と S3 Object Lock の二つを挙げている。バケットの既定保持設定（モード・期間）が各ログの配信および運用に与える影響を検証環境で確認し、結果を証跡として残すこと。	必須	LR-04
Amazon S3	Object Lock の保持モード・保持期間	ガバナンスモードを既定とし、s3: BypassGovernanceRetention を SCP で拒否すること。保持期間は第7章で決定した保存期間に整合させること。ただし SCP は組織の管理アカウントには適用されないため、本構成はログアーカイブバケットを管理アカウント以外のメンバーアカウント（第6章の Log Archive アカウント）に配置することを前提とする。	必須	LR-04, LR-05
Amazon S3	コンプライアンスモードの採用	採否と保持期間は発注者と協議して決定すること。コンプライアンスモードは保持期限前の削除手段がアカウント削除のみであり、期間設定の誤りを取り消せない。	任意	LR-04, LR-05
Amazon S3	リーガルホールド	係争・調査時に対象オブジェクトへ適用する運用手順と権限者を定めること。	推奨	LR-04

サービス	パラメータ	推奨値・設定内容	レベル	関連 LR ／ロ グ種 別
Amazon S3	パブリックアクセスブロック	BlockPublicAcls / IgnorePublicAcls / BlockPublicPolicy / RestrictPublicBuckets の4設定をすべて有効化し、アカウントレベルでも適用すること。	必須	LR-06
Amazon S3	バケットポリシー	aws:SecureTransport が false の場合に s3:* を拒否すること。あわせて s3:DeleteObject、s3:DeleteObjectVersion、s3:PutLifecycleConfiguration の3アクションを拒否すること（削除アクションの拒否だけではライフサイクルによる自動削除を防げないため、s3:PutLifecycleConfiguration の拒否が必要である）。ただしライフサイクル設定の投入・変更を行う基盤管理ロールのみを aws:PrincipalArn の ArnNotLike 等で除外し、除外対象のロールと変更手続を設計書に明記すること。拒否の対象プリンシパルは、当該除外ロールを除く全プリンシパルとする。	必須	LR-04, LR-07
Amazon S3	ライフサイクルルール	第7章で決定した保存期間・階層に従い移行と有効期限を設定すること。最小保存期間（Standard-IA 30日、Glacier Instant Retrieval および Glacier Flexible Retrieval 90日、Glacier Deep Archive 180日）と、128 KB 未満のオブジェクトが既定で移行対象外である点を織り込むこと。	必須	LR-05
Amazon S3	サーバーアクセスログ	ログバケットへの操作記録として別バケットへ出力すること。Object Lock 有効バケットは配信先にできず、S3 バケット宛て配信は同一リージョン・同一アカウントのバケットに限られ、配信先バケットの既定の暗号化は SSE-S3 である必要がある。ベストエフォート配信である。なお、サーバーアクセスログは Amazon CloudWatch Logs ロググループを配信先とすることもでき、その場合は AWS KMS による暗号化とクロスアカウント・クロスリージョンの集約に対応する。LR-07 のカスタマー管理キー要件を満たす必要がある場合は、この配信先の採用可否を発注者と協議すること。上記の同一リージョン・同一アカウント・SSE-S3 の制約は S3 バケット宛て配信に適用される。	推奨	LR-06, LR-07, L-02
Amazon S3	S3 Inventory	日次または週次で出力し、暗号化状態、Object Lock の保持期限・モード・リーガルホールドをフィールドに含め、保全状態の定期確認に用いること。	任意	LR-11
Amazon S3	レプリケーション／MFA Delete	可用性・不変性要件に応じて採否を協議すること。レプリケーションは設定後の新規・更新オブジェクトのみが対象であり、Object Lock 有効バケット間の要件は公式ドキュメントで確認すること。MFA Delete はライフサイクルと併用できない。また、有効化はバケット所有アカウントのルートユーザーによる CLI/API 操作に限られるため、採用する場合はルート認証情報の維持要否をあわせて協議すること。	任意	LR-04, LR-11

サービス	パラメータ	推奨値・設定内容	レベル	関連 LR ／ロ グ種 別
AWS KMS	ログ暗号化キー	ログ用途専用のカスタマー管理キーを作成すること。CloudTrail 用キーは配信先 S3 バケットと同一リージョンに作成する必要がある。	必須	LR-07
AWS KMS	キーポリシー	配信サービスプリンシパルへの書込権限と読取者への kms:Decrypt を分離すること。CloudTrail 用キーは kms:EncryptionContext:aws:cloudtrail:arn と aws:SourceArn で条件を絞ること。	必須	LR-06, LR-07
AWS KMS	自動キーローテーション	有効化すること。既定周期は365日で、90～2,560日の範囲でカスタマイズできる。旧キーマテリアルは保持されるため再暗号化は不要である。	推奨	LR-07
AWS KMS	キー削除の統制	CloudTrail イベント DisableKey / ScheduleKeyDeletion を即時アラート対象とし、あわせて SCP で kms:DisableKey / kms:ScheduleKeyDeletion を拒否すること。削除の待機期間は7～30日（既定30日）である。キーを削除すると当該キーで暗号化したログは復号できない。	必須	LR-04, LR-08

● 注意

ログ保全に関わる三つの制約は互いに矛盾しうするため、バケット構成の設計時に整理すること。(1) AWS Config の配信チャネルは、既定の保持設定を有効化した Object Lock バケットをサポートしない。(2) S3 サーバーアクセスログは Object Lock 有効バケットを配信先にできない。(3) MFA Delete とライフサイクル設定は併用できない。結果として、CloudTrail 用・AWS Config 用・アクセスログ用のバケットを分離する設計が現実的である。統合する設計を採る場合は、各サービスの配信成功を検証環境で確認し、結果を設計書に記録すること。

表C-2 設定パラメーター一覧（2）認証・操作・データ・ネットワーク・検知・組織統制

サービス	パラメータ	推奨値・設定内容	レベル	関連 LR／ ログ 種別
Session Manager	セッションログ	出力先（S3 または CloudWatch Logs）を明示設定し、「暗号化されたバケット／ロググループのみを許可」を有効にすること。設定を省略するとセッション内容は保存されない。	必須	LR-01, LR-07
Session Manager	SSH・ポートフォワーディングの抑止	AWS-StartSSHSesssion、AWS-StartPortForwardingSession、AWS-StartPortForwardingSessionToRemoteHost の各セッションドキュメントに対する ssm:StartSession を IAM ポリシー（および SCP）で拒否すること。SSH およびポートフォワーディング経由のセッションはセッションログを記録できないため、拒否しない限りログの残らない操作経路が既定で開いたままとなる。	必須	LR-01, LR-06, L-05
Session Manager	ポートフォワーディングの例外運用	業務上ポートフォワーディングが必要な場合は、発注者と協議のうえ対象ノード・時間帯・利用者を限定すること。様式D-3の申請・承認記録と CloudTrail の StartSession イベントで補完すること。	任意	LR-01, LR-06, L-05
Session Manager	セッションデータの暗号化	対称 KMS キーによる暗号化を有効化すること。有効化後はセッション開始者と接続先ノードの双方に鍵利用権限が必要となる。	推奨	LR-07
OS 監査ログ	CloudWatch エージェント	Linux は /var/log/audit/audit.log ・ /var/log/secure 等を、Windows はセキュリティイベントログ（ログオン成否のイベントIDを含む）を収集対象とし、ロググループと保持期間を指定すること。	必須	LR-01, L-05
Aurora MySQL	server_audit_logging / server_audit_events	前者を ON（既定 OFF）にし、後者に CONNECT, QUERY_DCL, QUERY_DDL, QUERY_DML, TABLE を設定すること（既定は空）。特定クエリのみを除外するフィルタはない。	必須	LR-01, LR-02, L-06
RDS for MySQL	MARIADB_AUDIT_PLUGIN	カスタムオプショングループに追加すること。SERVER_AUDIT_EVENTS の既定は CONNECT, QUERY、ローテーションは既定1,000,000バイト×9世代でインスタンス上の保持は短い。SERVER_AUDIT_EXCL_USERS への rdsadmin 指定を検討すること。	必須	LR-01, L-06
RDS／Aurora PostgreSQL	pgAudit	shared_preload_libraries に pgaudit を追加して再起動し、拡張作成後に pgaudit.log を設定すること（既定 none）。ddl,role,write を基本とし、読み取り監査が必要な場合に read を追加すること。	必須	LR-02, L-06
RDS for Db2	DB2_AUDIT（IAM_ROLE_ARN / S3_BUCKET_ARN）	カスタムオプショングループに追加すること（再起動不要）。出力先は DB インスタンスと同一アカウント・同一リージョンの一次保全用バケットとし、ログアーカイブアカウントの logs バケットへ S3 レプリケーションで複製すること。	必須	LR-01, LR-04, L-06
RDS for Db2	rdsadmin.configure_db_audit（データベースごと）	ALL を BOTH に設定し、EXECUTE を BOTH,WITHOUT で個別に設定すること（ALL は CONTEXT・EXECUTE・ERROR を含まない）。WITH の採否は LR-07 に照らして協議する。	必須	LR-01, LR-02, L-06

サービス	パラメータ	推奨値・設定内容	レベル	関連 LR/ ログ 種別
RDS for Db2	<code>rdsadmin. configure_db_ audit</code> (ERROR カテゴリ)	AUDIT に設定すること（既定の NORMAL では監査機能自身のエラーが記録されない）。	推奨	LR-11, L-06
RDS/Aurora	CloudWatch Logs への発行	<code>audit</code> ・ <code>error</code> 等を有効化すること（RDS for Db2 の監査ログは発行対象外で S3 へ出力する。発行できるのは <code>diag.log</code> ・ <code>notify.log</code> ）。自動作成されるロググループの保持期間の既定は無期限であるため必ず明示設定すること。	必須	LR-05
RDS/Aurora	Database Activity Streams	DBAによるログ改ざんを排除する必要がある場合に採用を協議すること。KMS 暗号化は必須で Amazon Kinesis Data Streams の料金が発生する。同期モードは Aurora PostgreSQL のみ対応である。RDS for Db2・RDS for MySQL・RDS for MariaDB・RDS for PostgreSQL は非対応である。	任意	LR-04, LR-06, L-06
VPC Flow Logs	有効化と形式	対象システムの全 VPC で有効化し、最大集約間隔を1分（既定10分）とすること。カスタム形式で <code>vpc-id</code> 、 <code>subnet-id</code> 、 <code>instance-id</code> 、 <code>flow-direction</code> 等を追加すること。作成後に形式は変更できない。表 C-1 の必須マネージドルール <code>vpc-flow-logs-enabled</code> が本設定を評価対象とするため、レベルを必須とする。	必須	LR-01, LR-02, L-11
Amazon GuardDuty	有効化範囲	組織の全アカウント・対象全リージョンで有効化し、委任管理者をセキュリティ運用用アカウントに設定すること。	必須	LR-08, L-12
Amazon GuardDuty	検出結果のエクスポート	S3 エクスポートをリージョンごとに設定すること（KMS 暗号化必須）。検出結果は90日で消えるため、未設定だと履歴が失われる。更新結果の出力頻度は既定6時間で15分または1時間に変更できる。	必須	LR-05, LR-11, L-12
Security Hub CSPM	有効化範囲と標準	対象全リージョンで有効化し、クロスリージョン集約を設定すること。適用する CIS AWS Foundations Benchmark のバージョンを設計書に明記すること。	推奨	LR-08, LR-12, L-12
CloudWatch Logs	統制事象のメトリクスフィルター	ルートユーザー使用、コンソール認証失敗、MFAなしサインイン、CloudTrail 設定変更、AWS Config 設定変更、CMK の無効化・削除予約、S3 バケットポリシー変更、IAM ポリシー変更を検知対象とすること。フィルターは作成後のデータのみを対象とするため証跡連携と同時に設定すること。	必須	LR-08, L-14
Amazon SNS	通知先の生存確認	サブスクリプションの確認状態を定期確認する手順を定めること。確認トークンの有効期間は2日間であり、未確認のサブスクリプションは48時間で削除される。パウンスしたEメールアドレスは7日間配信が抑止される。	必須	LR-08
AWS Backup	Vault Lock	ログのバックアップを保持するボルトに適用すること。保持日数は最長36,500日、コンプライアンスモードの猶予期間（ <code>ChangeableForDays</code> ）は3～36,500日で最短3日である。モードと期間は発注者と協議すること。	推奨	LR-11, L-13

サービス	パラメータ	推奨値・設定内容	レベル	関連 LR/ ログ 種別
AWS Backup	Backup Audit Manager	フレームワークとレポートプランを構成し、バックアップ実施結果を定期レポートとして S3 に出力すること。AWS Config のリソース記録が前提となる。レポートはレポートプランを作成したアカウントが所有する S3 バケットにしか配信できないため、ログアーカイブアカウントへ集約する場合は、配信後にレプリケーション等で転送する手順を設計書に定めること。	推奨	LR-09, L-13
AWS Organizations	SCP/RCP	SCP で CloudTrail・AWS Config・CloudWatch Logs・ログ用 S3 バケット・ログ暗号化キーの停止／削除／設定変更を拒否し、例外ロールのみを除外すること。RCP で組織外プリンシパルからのログアクセスを制限すること。SCP は管理アカウントには適用されないため、ログ関連リソースは管理アカウント以外に配置すること。	必須	LR-04, LR-06
AWS Organizations	ルートユーザー保護	全アカウント種別でルートユーザーの MFA を有効化すること。集中ルートアクセス管理によるメンバーアカウントのルート認証情報削除を検討すること。	必須	LR-06
IAM Identity Center	権限セット	ログ読み取り、ログ管理、監査人閲覧の権限セットを分離して定義し、割り当て一覧を証跡として出力できるようにすること。	必須	LR-06, LR-10
AWS Control Tower	ログ保持期間	第7章で決定した保存期間に合わせて明示設定すること。既定は標準アカウントログ1年・アクセスログ10年、最長15年である。	推奨	LR-05
Amazon EC2	時刻同期	Amazon Time Sync Service（IPv4 169.254.169.123 または IPv6 fd00:ec2::123）を最優先の時刻源として設定すること。IPv6 エンドポイントは Nitro ベースのインスタンスでのみ利用でき、IPv4 との併用は不要である。オンプレミス機器は time.aws.com で同一時刻源に揃えること。	必須	LR-03
Amazon Athena	ログ照会テーブル	CloudTrail・VPC フローログ・ALB アクセスログについて、パーティション射影を用いたテーブル定義と標準クエリを設計書に記載すること。	必須	LR-10

統制上特に重要なメトリクスフィルターパターンを次に示す。残る2事象（IAM ポリシー変更・S3 バケットポリシー変更）のパターンは、第9章および表B-2の Security Hub CSPM「CloudWatch コントロール」から転記すること。これらは規定どおりの文字列を用いる必要があり、項目や語句を追加すると自動チェックが不合格となる。各コードブロックの内容のみをそのままフィルターパターンとして設定すること。

ルートユーザーの使用（CloudWatch.1）

```
{$.userIdentity.type="Root" && $.userIdentity.invokedBy NOT EXISTS && $.eventType != "AwsServiceEvent"}
```

MFA なしのコンソールサインイン（CloudWatch.3）

```
{ ($.eventName = "ConsoleLogin") && ($.additionalEventData.MFAUsed != "Yes") && ($.userIdentity.type = "IAMUser") && ($.responseElements.ConsoleLogin = "Success") }
```

CloudTrail 設定の変更（CloudWatch.5）


```
{ ($.eventName=CreateTrail) || ($.eventName=UpdateTrail) || ($.eventName>DeleteTrail) ||  
 ($.eventName=StartLogging) || ($.eventName=StopLogging) }
```

コンソール認証の失敗（CloudWatch.6）

```
{ ($.eventName=ConsoleLogin) && ($.errorMessage="Failed authentication") }
```

CMK の無効化・削除予約（CloudWatch.7）

```
{ ($.eventSource=kms.amazonaws.com) && ( ($.eventName=DisableKey) || ($.eventName=ScheduleKeyDeletion)) }
```

AWS Config 設定の変更（CloudWatch.9）

```
{ ($.eventSource=config.amazonaws.com) && ( ($.eventName=StopConfigurationRecorder) ||  
 ($.eventName>DeleteDeliveryChannel) || ($.eventName=PutDeliveryChannel) ||  
 ($.eventName=PutConfigurationRecorder)) }
```

● 注意

Security Hub CSPM による自動チェックの範囲はバージョンにより異なる。CloudWatch.1 および CloudWatch.4～14 は v1.2.0 と v1.4.0 で自動チェックされるが、CloudWatch.2 および CloudWatch.3 を自動チェックするのは v1.2.0 のみである。v3.0.0 および v5.0.0 では CloudWatch 系コントロールはすべて「手動チェック」の扱いとなり自動判定されない。したがって、いずれのバージョンを有効化するかにかかわらず、メトリクスフィルタとアラームの設置自体は LR-08 の要求事項として実装し、その存在確認を定期レビュー（LR-09）の項目に含めること。有効化した標準のバージョンは設計書に明記すること。

付録D 様式（レビュー記録・証跡提出記録）

本付録の様式は記入項目の最小セットである。発注者が既に運用している様式がある場合はそれを優先する。いずれの様式にも、認証情報（パスワード、アクセスキー、トークン）、個人情報、および業務データの実値を記入しないこと。必要な場合はマスクした値または識別子のみを記入すること。本書の記入例には実在の氏名を記載しない。実際の記録では、実施者・承認者・申請者・依頼元を、役割ID（R-1～R-6）に加えて一意に識別できる利用者ID（IAM Identity Center のユーザー名、社員番号等）で記載すること。氏名の記載要否は発注者の個人情報の取扱方針に従う。

様式D-1 ログレビュー記録

表D-1 ログレビュー記録（様式）

項番	記入項目	記入要領
1	記録番号	連番。証跡保存先のファイル名と一致させる。
2	対象期間	UTC で開始・終了を記載（例 2026-04-01T00:00:00Z～2026-06-30T23:59:59Z）。
3	対象ログ種別	L-01～L-14 の ID と名称。複数の場合は列挙する。
4	対象アカウント・リージョン	アカウントIDとリージョン。組織全体の場合はその旨と対象アカウント数。
5	レビュー実施者・実施日	役割（原則 R-5。R-4 が実施する場合は、レビュー対象期間に当該実施者自身の操作が含まれないことを確認し、含まれる場合は R-5 が実施すること）、職名、所属。実施日が定めた頻度に適合していることを確認する。
6	レビュー手続	実行したクエリまたはコマンドを転記する。再実行して同じ結果が得られる粒度で記載する。
7	母集団件数・抽出件数	対象期間の総件数とレビュー対象件数。サンプリングによる場合は抽出方法と件数の根拠。
8	ログ収集の網羅性確認	対象期間の全期間にわたりログが収集されていたことの確認結果（配信状態の確認、欠損検知の結果）。
9	検知事象の件数	定義済みの検知事象ごとの件数。ゼロ件の場合も明記する。
10	検知事象の内容と評価	発生日時（UTC）、主体、操作、承認済みか否か、承認記録との突合結果。承認記録がある場合は様式 D-3 の記録番号を参照する。
11	是正・フォローアップ	是正措置の内容、担当、期限。未完了の場合は管理番号を記載し、完了時に本記録を更新する。
12	承認者・承認日	R-2 による承認。レビュー実施者と同一人物であってはならない。
13	証跡保存先	クエリ結果ファイルおよび本記録の保存先。

様式D-2 証跡提出記録

表D-2 証跡提出記録（様式）

項番	記入項目	記入要領
1	提出番号	連番。
2	依頼元・依頼日	依頼元の区分（R-6 監査人：内部監査／外部監査）と依頼日。
3	依頼内容	対象の統制（ITGC-A～D または統制番号）、対象期間、求められた証跡の種類。
4	抽出元	ログ種別（L-ID）、保存先（バケット名・プレフィックス、ロググループ名）、対象アカウント・リージョン。
5	抽出方法	実行したクエリまたはコマンドを転記する。時刻条件は UTC で記載する。
6	抽出実行者・実行日時	役割（R-5 を原則とする）と実行日時（UTC）。
7	抽出件数	抽出結果の件数。母集団件数が判明する場合は併記する。
8	完全性検証の結果	S3 上の元の配置に対して <code>aws cloudtrail validate-logs</code> を実行した結果（対象期間、リージョン、判定）を記載する。ダウンロード後のファイルは検証できず、組織の証跡では <code>--account-id</code> の指定が必要である。CloudTrail 以外のログは、配信元と提出物のオブジェクト数・チェックサム的一致確認結果を記載する。
9	マスキング処理	実施した場合はその範囲と方法、およびマスキング前後で件数が一致することの確認結果。
10	提出形式・提出日・提出先	ファイル形式、提出日、提出方法。AWS Artifact 取得文書を含む場合は共有条件（社内・規制当局・監査人に限る）を満たすことの確認結果を記載する。
11	承認者・承認日	R-2 による提出承認。
12	提出物の保管先	提出した成果物そのものの保管先。再提出・照合に備えて保存する。

様式D-3 特権アクセス申請・承認記録

表D-3 特権アクセス申請・承認記録（様式）

項番	記入項目	記入要領
1	申請番号	連番。
2	申請者	職名、所属、区分（開発ベンダー／運用ベンダー／発注者）。
3	対象	アカウントID、ロール名または権限セット名、対象リソース。
4	利用目的・作業内容	実施する操作と、通常権限で実施できない理由。
5	利用予定日時	開始・終了を UTC で記載。ブレークグラスの場合はその旨と発動条件。
6	承認者・承認日時	R-2 による承認。申請者と同一人物であってはならない。事後承認の場合は承認期限と実際の承認日時。
7	実際の利用開始・終了	CloudTrail のイベント時刻（UTC）または Session Manager のセッション開始・終了時刻。
8	本人特定の手段	共有ロールを使用した場合、実際の操作者を特定した根拠を記載する（ <code>sts:SourceIdentity</code> 、 <code>userIdentity.sessionContext.sessionIssuer</code> と <code>RoleSessionName</code> 、IAM Identity Center 経由の場合は <code>onBehalfOf.userId</code> ）。
9	操作記録の所在	Session Manager のセッションIDとログ保存先、CloudTrail のイベントID、該当ロググループ名。
10	実施操作の結果	予定どおり完了したか。想定外の操作がある場合は内容と事後承認の状況。
11	権限解除の確認	利用終了後に権限が解除されたことの確認者・確認日時と、確認に用いた証跡。
12	事後レビュー	R-5 による事後レビューの実施者・実施日・結果。様式D-1 の記録番号と相互参照する。

様式D-4 ログ設計書 目次テンプレート

LR-14 に基づき開発ベンダーが作成するログ設計書の目次構成を示す。該当がない節は「該当なし」とその理由を記載し、節そのものを削除しないこと。

1. 文書管理情報（文書番号、版数、作成者、承認者、改訂履歴、関連文書）
2. 適用範囲
 - a. 対象システム、対象アカウント、対象リージョン
 - b. 財務報告関連性の判定と根拠（LR-01）
 - c. 責任分界（発注者・開発ベンダー・運用ベンダー・AWS）（LR-13）
3. ログ種別と取得方針
 - a. ログ種別一覧（L-01～L-14 の採否と理由）
 - b. 記録項目（5W1H）の定義とフィールド対応表（LR-02）
 - c. 取得対象外とした事象と代替統制
4. 時刻とタイムスタンプ（LR-03）：時刻源と同期設定、タイムゾーンおよび日時表記の規約、相関IDの付与規約
5. 保全設計

- a. 保存先とアカウント配置、バケット・ロググループ命名規約
 - b. 暗号化とキー管理（LR-07）
 - c. 改ざん防止の実装と検証手順（LR-04）
 - d. 保存期間とライフサイクル（LR-05）
 - e. バックアップ・可用性・欠損検知（LR-11）
- 6. アクセス制御と職務分掌（LR-06）：役割（R-1～R-6）と権限のマトリクス、IAM・権限セット設計、SCP／RCP、特権アクセスおよびブレイクグラスの手順
 - 7. 監視・アラート（LR-08）：検知事象一覧と検知方式、通知経路とエスカレーション、通知経路の生存確認手順
 - 8. 定期レビュー（LR-09）：レビュー対象・頻度・手続・サンプリング方針、記録様式と承認フロー
 - 9. 検索・抽出（LR-10）：抽出基盤とテーブル定義、統制ごとの標準クエリ集、抽出手順と証跡化
 - 10. ログ設定の変更管理（LR-12）：IaCの管理範囲とリポジトリ、変更の申請・承認・適用手順、ドリフト検出と是正
 - 11. 試験：テスト観点と試験項目（第11章に対応）、試験結果および証跡の保存先
 - 12. 運用手順書への引き継ぎ事項
 - 13. 前提・制約・未決事項（発注者の決定を要する事項を含む）
 - 14. 付属資料（設定値一覧、権限一覧、通知先一覧、ログ種別ごとの保存期間一覧）

● 監査の視点

監査人はレビュー記録について、「実施したこと」だけでなく「実施者と承認者が分離されていること」「レビュー手続が再現可能であること」「検知事象がゼロであった場合にその母集団が正しく取得されていたこと」を確かめる。特に最後の点は見落とされやすい。様式D-1の「ログ収集の網羅性確認」欄は、この確認を記録上に明示的に残すためのものである。

付録E 要求事項一覧（LR-01～LR-14 サマリー）

表E-1 ログ管理要求事項の一覧

ID	名称	要点	主要なAWSサービス・手段	本文参照
LR-01	対象範囲の特定と網羅性	財務報告に関連するアカウント・リージョン・システム（業種編では、区分(3)の記録を扱うシステムを含む。0.3）を特定し、取得対象ログを漏れなく定義する。取得しない事象は理由と代替統制を記録する。	AWS CloudTrail、AWS Config、AWS Organizations	2.1
LR-02	記録項目（5W1H）	誰が・いつ・どこから・何に対し・何を・結果はどうであったかを一意に特定できる項目を定義し、共有ロール利用時の本人特定手段を含める。	CloudTrail（userIdentity）、AWS STS、IAM Identity Center	2.2
LR-03	時刻同期とタイムスタンプ	全ログソースを共通の時刻源に同期し、UTC表記に統一する。相関IDの付与規約を定める。	Amazon Time Sync Service、Amazon CloudWatch Logs	2.3
LR-04	改ざん防止と完全性の保証	取得後のログの変更・削除を技術的に不可能または検知可能にし、検証手順を定める。	CloudTrail ログファイル整合性検証、Amazon S3（バージョニング、Object Lock）、SCP	2.4
LR-05	保存期間とライフサイクル	ログ種別ごとに保存期間・保存階層・削除手順を定める。J-SOX自体は年限を定めておらず、最終決定は発注者が行う。業種編では、ログを3区分に分け（7.1.3）、区分(2)は事業年度末から10年、区分(3)は7.8の期間と起算点による。	Amazon S3 ライフサイクル、CloudWatch Logs 保持期間、AWS Config 保持期間	2.5、7.1.3、7.8
LR-06	ログへのアクセス制御と職務分掌	ログの書込・読取・設定変更の権限を分離し、開発・運用から独立したログ管理者（R-5）を置く。	IAM Identity Center、SCP／RCP、AWS KMS キーポリシー	2.6
LR-07	暗号化と機微情報の保護	保管時・転送時の暗号化を行い、ログに含まれる機微情報をマスクする。復号権限は読取権限と併せて設計する。	AWS KMS、CloudWatch Logs データ保護ポリシー、S3 バケットポリシー	2.7
LR-08	監視とアラート	統制上重要な事象を定義し、検知から通知・エスカレーションまでの経路を実装し、経路の生存を維持する。	CloudWatch メトリクスフィルター／アラーム、Amazon EventBridge、Amazon SNS、Amazon GuardDuty	2.8
LR-09	定期レビューと証跡化	レビューの対象・頻度・手続・承認を定め、実施記録を様式D-1で残す。実施者と承認者は分離する。	Amazon CloudWatch Logs Insights、Amazon Athena	2.9
LR-10	検索・抽出（監査対応）	監査人の依頼に対し、指定期間・条件のログを再現可能な手順で抽出できる状態を維持する。	Amazon Athena（パーティション射影）、CloudWatch Logs Insights、AWS CLI	2.10
LR-11	バックアップ・可用性・欠損検知	ログ基盤自体の冗長化とバックアップを行い、配信失敗・欠損を検知する仕組みを実装する。	AWS Backup、Amazon S3 レプリケーション、CloudTrail 配信状態の監視	2.11
LR-12	ログ設定の変更管理	ログ設定をIaCで管理し、変更の申請・承認・適用・ドリフト検出を統制する。	AWS Config ルール、AWS CloudFormation ドリフト検出、AWS CodePipeline 等のCI/CD基盤	2.12

ID	名称	要点	主要なAWSサービス・手段	本文参照
LR-13	外部委託と責任分界	AWS・開発ベンダー・運用ベンダー・発注者の責任範囲を文書化し、受託会社の統制を確認する手段を定める。	AWS Artifact（SOC 1 等）、責任共有モデル	2.13
LR-14	文書化（ログ設計書・運用手順書）	ログ設計書と運用手順書を成果物として作成・維持し、実装と記載内容の一致を保つ。	文書成果物（目次構成は様式D-4を参照）	2.14

付録F ログ種別一覧（L-01～L-14 サマリー）

表F-1 ログ種別の一覧

ID	名称	主な発生源	保全先	本文参照
L-01	クラウド基盤API操作ログ	AWS CloudTrail 管理イベント（全リージョン、組織の証跡）	ログ専用アカウントのAmazon S3。監視用にCloudWatch Logs へ併送	3.3.1
L-02	データアクセスログ	CloudTrail データイベント、Amazon S3 サーバーアクセスログ	データイベントはログ専用アカウントの S3。サーバーアクセスログは Object Lock 非対応のため別バケット	3.3.2
L-03	構成変更履歴	AWS Config の設定項目・設定履歴	AWS Config データストア（既定7年）および配信チャンネルの S3	3.3.3
L-04	認証・認可ログ	コンソールログイン（signin.amazonaws.com）、AWS STS の AssumeRole、IAM Identity Center のサインイン・割り当て操作、アプリケーション認証	AWS側は CloudTrail 経由で S3。アプリケーション認証は CloudWatch Logs 経由で S3	3.3.4
L-05	サーバ操作ログ	Session Manager のセッションログ、OS監査ログ（auditd、Windowsセキュリティイベントログ）	S3 または CloudWatch Logs（OSログは CloudWatch エージェント経由）	3.3.5
L-06	データベース監査ログ	Aurora MySQL の高度な監査、RDS の MariaDB Audit Plugin、pgAudit、RDS for Db2 の Db2 監査ログ記録、Database Activity Streams	CloudWatch Logs（/aws/rds/...）経由で S3。RDS for Db2 は発生元アカウントの S3 から複製。Database Activity Streams は Amazon Kinesis Data Streams	3.3.6
L-07	アプリケーション業務ログ	アプリケーション（トランザクション、承認操作、エラー・例外処理）	CloudWatch Logs 経由で S3	3.3.7
L-08	ジョブ・バッチ実行ログ	ジョブ実行基盤、AWS Systems Manager Run Command 等	CloudWatch Logs または S3	3.3.8
L-09	データ連携ログ	インターフェース処理（送受信、件数整合チェック）	CloudWatch Logs 経由で S3	3.3.9
L-10	変更・デプロイログ	CI/CDパイプライン、IaC適用、AWS CloudFormation スタックイベント	CloudWatch Logs および S3。API操作は CloudTrail	3.3.10

ID	名称	主な発生源	保全先	本文参照
L-11	ネットワーク・通信ログ	VPCフローログ、ELB／AWS WAF／Amazon CloudFront のアクセスログ、Amazon Route 53 Resolver クエリログ	S3（用途に応じて CloudWatch Logs または Amazon Data Firehose 経由）	3.3.11
L-12	セキュリティ検知ログ	Amazon GuardDuty、AWS Security Hub CSPM	ログ専用アカウントの Amazon S3（検出結果は90日で失われるため S3 エクスポートを設定。KMS暗号化必須）	3.3.12
L-13	バックアップ・リストアログ	AWS Backup のジョブおよびレポート、CloudTrail のサービスイベント	Backup Audit Manager のレポート出力先 S3、および CloudTrail	3.3.13
L-14	ログ基盤自身の監査ログ	CloudTrail（StopLogging、DeleteTrail、PutEventSelectors）、AWS Config（StopConfigurationRecorder 等）、CloudWatch Logs（DeleteLogGroup、PutRetentionPolicy）、S3（PutBucketPolicy、PutBucketLifecycle）、KMS（DisableKey、ScheduleKeyDeletion）	ログ専用アカウントの S3。あわせて即時アラートの対象とする	3.3.14

● 補足

L-14 は他のログ種別と性質が異なり、「ログが取得され続けていること自体」を証明するためのログである。これが欠けると、他の13種別について「事象が発生しなかった」のか「記録が止められていた」のかを区別できない。第8章および第9章の実装と併せて最優先で構成すること。

付録G 保険の法令・ガイドライン調査

本付録は、日本の主要10業種について監査ログの保存期間を整理した法令調査（基準日 2026-10-06。以下「業種別調査」）のうち、保険に関わる部分を収録する。収録したのは、業種別調査の §1（保険の結論と業種をまたぐ発見）、§2（調査の前提と枠組み）、§3（全業種に共通する法令・基準）、§6（保険）である。本付録の「§」の番号、表の行番号（BK1、CM1 など）は業種別調査のものであり、本書の章・節の番号とは別である。ほかの業種の節と行は、日本の主要10業種シリーズの各業種編の付録 G に収録している。

業種別調査は法的助言ではない。最終的な決定には、法務部門と監査部門（内部統制）の確認が必要である。表の各行は公式の原文を直接読んで確認したもの（確認レベル A）であり、確認できなかった項目は「未確認の一覧」に分けている。各行の原文の引用は調査時の原資料に保存しており、本書には収録していない。

■ §1 結論

業種法令が監査ログの保存年数を直接定めている例は、ほとんどない。 業種法令が保存期間を定めるのは、帳簿書類・記録である。そのため、監査ログ（区分(2)）の推奨は、全業種で「事業年度末から10年」を共通の下限の目安とし（会社法432条などに準じて扱う解釈。§2）、業種ごとに、これを超える記録（区分(3)）と、設計上の注意点を示す。

保険についての結論は、次のとおりである。

項目	内容（保険）
業種法令が定める記録の保存期間（代表）	保険業法は監査ログの年数を定めていない。保険会社（株式会社）は会社法432条、相互会社は保険業法54条の2で、帳簿閉鎖の時から10年。保険仲立人の帳簿・電磁的交付書面・金融サービス仲介業者の記録は、契約の消滅日から5年。特定保険募集人の帳簿は締結日から5年（一般の募集人には保存義務なし）
監査ログ（区分(2)）の推奨	事業年度末から10年
共通の下限を超える記録（区分(3)）	契約の消滅日・保険期間の終了日を起点とする期間（仲立人の帳簿・電磁的交付書面・仲介業者の記録：消滅日から5年。変額保険の特別勘定元帳：保守的な読みで保険期間の終了から10年）。終身保険などの長期契約では数十年に及ぶ
設計で特に注意する点	起点が将来の事象（契約の消滅）のため、作成日起算の固定日数ロックでは対応できない。電磁的交付書面は消去・変更できない状態で保存する。個人情報の保存期間設定・消去との両立
詳細	§ 6

§ 1.1 業種をまたぐ発見

1. **業種法令のうち、ログの保存期間を年数で定めているのは、エネルギー（送配電・導管部門の非公開情報システムのアクセス記録：5年。EN1・EN3～EN6（エネルギー（電力・ガス）編））だけである。**業種法令が保存期間を定めるのは、通常、帳簿書類・記録である。共通法令では、番号法23条（情報提供ネットワークシステムの情報照会者・情報提供者に限る。7年。CM18）がある。刑事訴訟法197条3項（CM26・TL8）は、平時の保存期間ではなく、要請を受けた場合の保全期間（最長60日）を定める。政府のガイドラインでは、電気通信（ガイドラインの解説と総務省の要請。通信履歴は3か月～1年程度）と医療（経済産業省・総務省のガイドライン。法定保存年限以上）が、ログの保存期間の目安に触れている。それ以外の分野（金融など）のガイドラインは、ログの取得・点検を求めるが、年数は示していない。
2. **区分(2)の「事業年度末から10年」は、全業種に共通する下限の目安である。**株式会社では会社法432条2項（J1）、信用金庫・労働金庫・信用協同組合では各設置法（BK9～BK11（銀行編））、相互会社では保険業法54条の2（IN1）、医療法人では医療法50条の2（HC16（医療編））に準じて扱う。いずれも、監査ログを明記した規定ではなく、解釈である（要法務確認）。個人診療所・公立病院など、同等の規定が見当たらない事業者では、法令に準じる根拠のない社内の目安として採用することになる（§ 8.5（医療編））。業種法令が定める期間（5年・7年・1年・3年など）が10年より短くても、監査ログを短くする根拠にはならない。特に運輸・物流では、点呼記録の1年は記録そのものの期間であり、点呼システムの操作ログの期間ではない。
3. **10年を超える記録がある。**(a)年数そのものが10年を超えるもの：医薬品・医療機器（特定生物由来製品は30年、特定保守管理医療機器は15年）、医療（特定生物由来製品の使用記録は20年以上）、建築士事務所（15年）。(b)起点が事象のため、作成日から数えると10年を超えるもの：保険（契約の消滅日から5年など）、証券・資産運用（契約に係る業務の終了日から10年）、銀行（特定投資家制度の書面を閲覧で提供した場合の電子交付ファイル：最終取引日から5年）、割賦販売法の調査記録（カード有効期間などに連動）、犯罪収益移転防止法の確認記録（取引終了日から7年）、携帯音声通信事業者の本人確認記録（契約終了日から3年）、宅地建物取引業者の従業者名簿（最終記載日から10年）、不動産特定共同事業（契約終了日から5年など）、発電用水力設備の検査記録（設備の存続期間）、航空機の整備記録（廃棄・売却まで）。
4. **起点が事象の期間は、作成日起算の固定日数のロックでは管理できない。**契約の消滅、引渡し、退職、最終取引日、設備の廃止などを起点とする期間は、作成時に満了日が決まらない。記録ごとに起点となる日を持たせ、事象の発生時に保存期限を設定・延長する仕組みが要る。年数の大小だけで比べると誤る。満了日で比べる。

5. **保存を長くしすぎることを制約する規定がある。** 個人情報保護法22条（利用する必要がなくなった個人データの消去の努力義務）、金融分野の個人情報ガイドライン7条（保存期間を定めて消去する）、電気通信事業法4条の通信の秘密、番号法20条（特定個人情報の保管の禁止）である。ログにカード番号・マイナンバー・通信の構成要素などを出力しない設計にして、監査ログを長期保存できるようにする。
6. **訂正・削除の履歴は、監査ログとは別に、記録の一部として求められることがある。** 法令では、金融関連法令のe-文書法施行規則（SC13（証券・資産運用編））、医療の電磁的保存に関する厚生労働省令（HC13（医療編））、点呼機器の告示（TR18（運輸・物流編））が、訂正・削除の事実と内容を確認できる措置などを求める。電子帳簿保存法は、優良な電子帳簿（任意）、スキャナ保存・電子取引（選択制）の場合に求める（CM2～CM4）。通知・監督指針では、ER/ES指針（PHG1（医薬品・医療機器編））、金融商品取引業者向けの監督指針（SCG3・SCG4（証券・資産運用編））、金融庁の事務ガイドライン（RTG3（小売・EC・決済編））が求める。履歴は、その記録の保存期間の終了まで保持する。
7. **保存場所の制約がある。** 金融商品取引業者の帳簿は国内保存が原則である。暗号資産・電子決済手段・仲介業の帳簿（RT5・RT7・RT9（小売・EC・決済編））と、銀行法の電子決済等取扱業者の帳簿（BK7（銀行編））も国内保存を求められる。クラウドのリージョンを選ぶときに影響する。
8. **法的な保全に備え、自動削除を個別に止められるようにする。** 刑事訴訟法に基づく捜査機関の保全要請（通算で最長60日）、訴訟の予期、漏えい等の調査がある。期間満了による自動削除から、対象のログを個別に外す手段を設ける。

§ 2 調査の前提と枠組み

- 基準日は2026-10-06。調査対象は、日本の法律・政令・省令・告示と、政府の公式ガイドライン（法的拘束力なし）である。民間・業界団体の基準、有料の規格は、各業種の「対象外の一覧」に名前と理由だけを載せた。
- 各行の「確認レベル」は、その数字をどこまで確かめたかを示す。本資料の表に掲げた項目は、すべて公式の原文（条文・PDF・公式データ）を直接読んで確認した（A）。確認できなかった項目は、表に載せず、各業種の「未確認の一覧」に分けた。条文の解釈にとどまる点は、「対象システムへの適用性」の欄に「解釈」と明記した（解釈＝条文の読み方。見解＝本資料の判断・推奨）。
- 各行の原文の引用（200字以内）は、別添の原資料に保存してある。

ログの3区分（基礎資料「自動車業界のシステム開発における監査ログの保存期間」の区分を、業種に依存しない形にした）

区分	内容	保存期間の考え方
(1) 運用ログ	障害調査・運用監視・セキュリティ監視のためのログ	1年を出発点とする（各社の内部規程で定める）
(2) 監査ログ	「誰が・いつ・何をしたか」を示す証拠となるログ（DB監査ログ、特権操作、アクセス権の変更、財務報告に関わるデータの変更履歴など）	事業年度末から10年を、共通の下限の目安とする（会社法432条に準じて扱う解釈。株式会社に共通。基礎資料のJ1）
(3) 業種固有の記録とその変更履歴	その業種の法令が保存を求める記録（診療録、保険契約の帳簿、運行記録、製造記録など）と、その記録を扱うシステムの変更履歴・操作履歴	その業種の法令が定める期間と起算点

推奨の決め方: 適用される保存期間の下限のうち、最も遅く満了するものを、起算点とともに推奨とする。年数の大小ではなく、**満了日**で比べる。ただし、上限側の制約（個人情報保護法22条、通信の秘密など）も確認する。「長い方を選べばよい」とは限らない。

区分が重なる場合：業種固有の記録（区分(3)）への登録・変更・削除・閲覧の操作ログは、「誰が・いつ・何をしたか」を示すため、区分(2)にも当たる。この場合は、区分(2)の期間と、その記録の法定保存期間のうち、遅く満了する方まで保存する。記録そのものの訂正・削除の履歴（変更前の値）は、記録の一部として区分(3)の期間保存する。業種によっては、区分を細分した（電気通信の(1')＝利用者の通信履歴、医療の(3a)＝記録と訂正履歴・(3b)＝アクセスログ）。

「対象システムへの適用性」の3区分: **直接**（条文がログ・アクセス記録・操作履歴などを明記して保存を求める）、**間接**（帳簿書類・記録を電磁的記録で保存する場合の、そのデータ・訂正削除の履歴・システム要件として関わる）、**対象外**（紛らわしいが、監査ログには適用されない）。「その業種の法令は、監査ログの保存年数を直接定めていない」は、正当な結論である。

表のIDの接頭辞: 共通＝CM、銀行＝BK、証券・資産運用＝SC、保険＝IN、小売・EC・決済＝RT、医療＝HC、医薬品・医療機器＝PH、電気通信＝TL、エネルギー＝EN、運輸・物流＝TR、建設・不動産＝CN。ガイドラインの行は、接頭辞にGを加える（例：BKG1（銀行編））。留意点・判断事項のIDは接頭辞にFまたはNを、未確認のIDはUを付ける場合がある（例：BKF1（銀行編）、RTN1（小売・EC・決済編）、RTU1（小売・EC・決済編））。J・Uで始まる行は、基礎資料の行である（§ 3.0に再掲した）。

§ 3 全業種に共通する法令・基準

§ 3.0 基礎資料から引用する行（確認済み。基準日 2026-02-01）

基礎資料（「自動車業界のシステム開発における監査ログの保存期間」）の行のうち、業種の節が引用するものを再掲する。表中の「§」の番号、区分(1)(2)(3)、「部品構成の管理」などの記述は、基礎資料の構成・文脈のものであり、本資料の節・区分とは対応しない。

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
J1	会社法432条2項	会計帳簿、およびその事業に関する重要な資料	10年	会計帳簿の閉鎖の時	監査ログを対象と明記した条文ではない。会計の根拠となる重要資料に準じて扱う、という解釈である（要法務確認）。(2)の10年の主な根拠	A	https://laws.e-gov.go.jp/law/417AC0000000086
J2	会社法435条4項	計算書類・附属明細書	10年	計算書類を作成した時	間接的な根拠（会計データの出力物）。(2)を10年とする補強材料の一つ	A	https://laws.e-gov.go.jp/law/417AC0000000086
J3	法人税法施行規則59条（7年）・26条の3（欠損金年度は10年）、国税庁タックスアンサー No.5930	帳簿、取引関係書類	7年。欠損金が生じた事業年度などは10年	その事業年度の確定申告書の提出期限の翌日	部品構成の管理など、会計帳簿を直接扱わないシステムは、単体では国税関係帳簿に当たらない可能性が高い（見解）。ただし、原価計算や棚卸資産の基礎データと連動する場合は要確認。(2)が帳簿書類に当たる場合の7年の根拠	A	https://laws.e-gov.go.jp/law/340M50000040012 / https://www.nta.go.jp/taxes/shiraberu/taxanswer/hojin/5930.htm
J4	金融商品取引法25条1項3号・5号	有価証券報告書、内部統制報告書の公衆縦覧	5年	受理した日から（縦覧期間）	保存義務ではなく、縦覧の期間である。J5がこの期間を参照している	A	https://laws.e-gov.go.jp/law/323AC0000000025
J5	財務報告に係る内部統制の評価及び監査に関する実施基準 II.3.(7)②「記録の保存」	内部統制について作成した記録	範囲・方法・期間は、「諸法令との関係を考慮して企業が適切に判断」するものとされる。金商法上は、縦覧期間（5年）を勘案し、それと同程度の期間を保存することが考えられる、としている	明記なし	義務ではなく目安である。 年数を直接定めてはいないが、5年という数字が示されている。(2)の目安5年の根拠	A	https://www.fsa.go.jp/singi/singi_kigyoku/kijun/20230407_naibutousei_kansa.pdf
J6	金融商品取引法24条の4の4第1項	内部統制報告書の提出義務	—	—	有価証券報告書の提出会社のうち、一定の会社が対象。上場会社にはJ-SOXが適用される（ 自社が該当するか要確認 ）	A	https://laws.e-gov.go.jp/law/323AC0000000025
J7	経済産業省「システム管理基準 追補版（財務報告に係るIT統制ガイドランス）」2024年版	IT統制の評価観点	ログの保存年数の記載は確認できなかった。 一方、「文書・データの保管期間と条件が定められている」ことを確認する観点は示されている	—	年数そのものではなく、保存期間を定め、それを守っていることを求めている。(1)(2)の期間を文書化して運用する根拠	A	https://www.meti.go.jp/policy/netsecurity/docs/secgov/2024_ZaimuHoukokuNiKakaruITTouseiGuidance.pdf

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
J8	製造物責任法5条1項～3項	（保存義務ではない）損害賠償請求の期間制限	3年（認識時。生命・身体への侵害は5年。2項）、 引渡しから10年 。ただし、蓄積・潜伏型の損害は、10年を損害が生じた時から数える（3項）	3年：損害と賠償義務者を知った時。10年：製造業者等が製造物を引き渡した時（3項の損害は、損害が生じた時）	(3)の根拠。期間は原則として引渡しから数える（蓄積・潜伏型の損害は損害発生時から。3項）。引渡しは生産終了より後になりうるため、起点は最終引渡し（補給部品を含む）とする方が安全側である。生産終了を起点にする場合は、生産終了後の引渡し分に注意する	A	https://laws.e-gov.go.jp/law/406AC000000085
J9	製造物責任法6条、民法724条・724条の2・166条・167条	（保存義務ではない）民法による請求の期間制限	不法行為は3年（認識時。生命・身体への侵害は5年。724条の2）／20年（不法行為の時）。債権は5年（知った時）／10年（行使できる時。生命・身体への侵害による損害賠償請求権は20年。167条）。最長20年	左記のとおり	PL法6条（「この法律の規定によるほか、民法の規定による」）により、民法による請求も可能と解される（解釈。§8）。PL法ではなく民法で請求される場合の上限は、目安として20年。 推奨には含めない（§7）	A	https://laws.e-gov.go.jp/law/129AC000000089
J10	個人情報保護法22条	個人データ	利用する必要がなくなったときは遅滞なく消去する努力義務	利用不要となった時	保存期間の上限を抑える制約。 監査ログにユーザーID・IPアドレスなどが含まれる場合は、無期限の保存を避ける	A	https://laws.e-gov.go.jp/law/415AC000000057
J11	個人情報保護法施行規則21条	第三者提供に係る記録	3年または1年（作成方法による）	1号・2号は最後に提供した日から。3号は記録を作成した日から	監査ログは対象外 （対象は第三者提供の記録のみ。混同しやすいため掲載）	A	https://laws.e-gov.go.jp/law/428M6002000003
U5	18 U.S.C. 1519	連邦機関の所管事項や破産事件に関する調査・事件を妨害する意図での記録の破棄・改ざん	懲役最長20年	—	保存期間の定めではない。 連邦機関の所管事項に関する調査や、破産事件が見込まれる場合は、保存期間が満了していても削除してはならないこと の根拠（故意に、妨害の意図で破棄・改ざんした場合が対象。民事訴訟はU6）	A	https://www.govinfo.gov/content/pkg/USCODE-2024-title18/html/USCODE-2024-title18-part1-chap73-sec1519.htm

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
U6	連邦民事訴訟規則（FRCP）37(e)	電子的に保存された情報（ESI）	保存期間の定めではない	訴訟を予期した時（または訴訟の係属中）	合理的な保存措置を怠ってESIが失われ、追加の開示手続でも復元・代替できない場合の救済措置の規定（相手方の不利益を補う範囲の措置。重い制裁は、情報を奪う意図が認められる場合に限る）。保存義務そのものを定める規定ではないが、リーガルホールド（訴訟に備えた保存措置）を実施する実務上の理由になる	A	https://www.uscourts.gov/sites/default/files/document/federal-rules-of-civil-procedure.pdf

§ 3.1 業種の概要

本節は特定の業種ではなく、10業種の節が共通で引用する法令を扱う。対象事業者は、(a) 法人税・消費税の保存義務者（全法人）、(b) 労働者を使用する全事業者（労働基準法・労働安全衛生法）、(c) 個人情報取扱事業者と個人番号関係事務実施者（ほぼ全事業者）、(d) 株式会社（会社法）、(e) 犯罪収益移転防止法の特定事業者（金融・不動産・貴金属・土業など一部の業種）である。システム上で問題になるのは、会計・請求・経費精算・電子取引のデータとその**訂正削除の履歴**（電子帳簿保存法）、勤怠・PC使用時間の記録（労基法・安衛法）、本人確認・取引の記録（犯収法）、個人データ・個人番号へのアクセスの記録（個人情報保護法・番号法の安全管理措置）、そして漏えい・不正アクセス・捜査の際のログの保全である。**全業種共通の法令に、監査ログ全般の保存年数を直接定めた規定は見当たらない。**ログを明記して保存・保全を求める規定は、番号法23条（情報提供ネットワークシステムの接続者に限る、7年）と、刑事訴訟法197条3項（要請があった場合の通信履歴の保全、最長60日）だけである。このほか、労働安全衛生規則52条の7の3が、労働時間の状況の把握の方法として「電子計算機の使用時間の記録」を明記している（保存を求めるのは労働時間の状況の記録で3年。CM15）。

§ 3.2 法令の表

条文は、いずれも e-Gov 法令API（v1）で取得した、2026-10-06 時点で施行済みの版である。改正の情報（直近の改正法令と施行日）は「引用」の各行に記した。

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
CM1	電子帳簿保存法4条1項・2項、同法施行規則2条2項（帳簿）・3項（書類。2項を準用）	自己が最初の記録段階から一貫して電子計算機で作成する国税関係帳簿・書類の電磁的記録。あわせて、システムの概要書・開発時の書類・操作説明書・事務手続書の備付け	定めなし（国税の法律の保存期間による。法人税はJ3の7年・10年）	国税の法律による（J3）	間接。 帳簿を電子で保存する場合の要件で、 一般の電子帳簿には訂正削除の履歴は求められていない （規則2条2項は、システム関係書類の備付け、ディスプレイ・書面への出力、提示・提出要求への対応のみ）。会計・販売・購買など帳簿を作るシステムが対象。 全業種	A	https://laws.e-gov.go.jp/law/410AC0000000025 / https://laws.e-gov.go.jp/law/410M50000040043
CM2	電子帳簿保存法8条4項、同法施行規則5条5項1号イ(1)(2)・ハ（優良な電子帳簿）※2027-01-01から規則5条4項1号に移る	特例国税関係帳簿（仕訳帳・総勘定元帳など）の電磁的記録の 訂正・削除の事実及び内容 、通常の期間を過ぎた後の入力の事実	定めなし（帳簿の保存期間を通じて要件を満たし続けることが必要。法8条4項「引き続き当該要件を満たして」）	国税の法律による（J3）	間接。 訂正削除の履歴を明文で求める。ただし優良な電子帳簿は 任意 であり（届出制）、満たすと、過少申告加算税が、基礎となる税額の5%分軽減される（法8条4項。隠蔽・偽装がある場合を除く）。会計システムの変更履歴の設計に直結する。 全業種	A	https://laws.e-gov.go.jp/law/410AC0000000025 / https://laws.e-gov.go.jp/law/410M50000040043
CM3	電子帳簿保存法4条3項、同法施行規則2条6項2号ロ・ハ、5号（スキャナ保存）	紙の国税関係書類をスキャナで読み取った電磁的記録。タイムスタンプ、 訂正削除の事実及び内容を確認できること、又は訂正削除ができないこと 、検索機能	国税関係書類の保存期間（規則2条6項2号ロ(1)「保存期間…を通じ」、同条12項）	国税の法律による（J3）	間接。 スキャナ保存を選んだ場合の要件。訂正削除の履歴は「訂正削除不可」との選択制。経費精算・文書管理システムが対象。 全業種	A	https://laws.e-gov.go.jp/law/410M50000040043 / https://laws.e-gov.go.jp/law/410AC0000000025

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
CM4	電子帳簿保存法7条、同法施行規則4条1項（電子取引の取引情報）	電子取引（メール・EDI・Web等で授受した注文書・契約書・請求書・領収書等の情報）の電磁的記録	書面で授受したとした場合に保存すべき期間（規則4条1項）。法人税はJ3の7年・10年	国税の法律による（J3）	間接。法人税の保存義務者には義務（「しなければならない」）。真実性の措置は4つから選択（①タイムスタンプ付与後に授受、②授受後にタイムスタンプ付与、③訂正削除の履歴が残る又は訂正削除できないシステム、④訂正削除防止の事務処理規程）。措置は保存期間を通じて講じる。あわせて、システムの概要を記載した書類の備付け（規則2条6項6号で準用する2条2項1号イ。自社開発のプログラムを使う場合）、ディスプレイ等の備付け（規則2条2項2号）と検索機能（規則2条6項5号。取引年月日・取引金額・取引先で検索）が必要（提示・提出の要求に応じる場合は範囲指定・組合せ検索が不要、基準期間の売上高5,000万円以下などの場合で提示・提出の要求にも応じるときは検索機能自体が不要）。全業種（最も横断的な要件）	A	https://laws.e-gov.go.jp/law/410AC0000000025 / https://laws.e-gov.go.jp/law/410M50000040043
CM5	電子帳簿保存法6条	（適用関係の規定）国税関係帳簿書類	—	—	間接。国税関係帳簿書類にはe-文書法3条・4条を適用しない。税務の帳簿書類の電子保存の要件は、e-文書法の省令ではなく電子帳簿保存法による。全業種	A	https://laws.e-gov.go.jp/law/410AC0000000025
CM6	e-文書法（民間事業者等が行う書面の保存等における情報通信の技術の利用に関する法律）3条・4条・9条	他の法令が書面での保存・作成を求めるもののうち、主務省令で定めるもの	定めなし（元の法令の期間による）	元の法令による	間接。書面の保存・作成に代えて電磁的記録を認める枠組み法であり、要件（方法・見読性など）は各省の主務省令に委ねる（3条1項「主務省令で定めるところにより」）。法律本体に見読性・完全性・機密性・検索性の文言は無い。業種ごとの省令は、各業種の節（§4～§13）で扱う。全業種	A	https://laws.e-gov.go.jp/law/416AC0000000149

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
CM7	e-文書法の主務省令の例：経済産業省令（平成17年第32号）4条2項・4項、財務省令（平成17年第16号）4条2項・3項、厚生労働省令（平成17年第44号）4条3項・4項	上記省令の別表に掲げる書面に係る電磁的記録	「保存すべき期間中」（厚労省令4条4項2号・3号）。年数は元の法令による	元の法令による	間接 。3省令に共通するのは 見読性 （直ちに整然とした形式・明瞭な状態で表示・書面化できること）だけである。 検索性 は財務省令4条3項（関税等の特定の法令）のみ、 改変・消去の事実と内容の確認・責任の所在・復元可能性 は厚労省令4条4項（別表第一の二～四の書面）のみ。機密性を明記した規定は、この3省令の本文には無い。なお、経済産業省令4条4項は、別表第二の書面について、「経済産業大臣が定める基準」の確保を努力義務として定める。この基準（告示）の内容は確認していないため、「機密性を明記した規定は無い」は、3省令の本文に限った確認である。業種固有の省令を引く際の比較の基準として掲載	A	https://laws.e-gov.go.jp/law/417M60000400032 / https://laws.e-gov.go.jp/law/417M6000040016 / https://laws.e-gov.go.jp/law/417M60000100044
CM8	犯罪収益移転防止法6条、同法施行規則19条・21条	確認記録（取引時確認の事項、とった措置。本人確認書類の写し・画像などの添付資料を含む。電磁的記録で作成可）	7年	取引終了日（規則21条2項1号に掲げる取引は当該取引に係る契約が終了した日、それ以外は取引が行われた日）と、取引時確認済みの取引に係る取引終了日のうち後に到来する日（規則21条）	間接 。本人確認（eKYC等）のシステムが保存する記録そのもの。 起算点が契約終了のため 、長期の顧客関係では、作成から10年を超えて保存が必要になりうる。 特定事業者（CM10）に限る	A	https://laws.e-gov.go.jp/law/419AC0000000022 / https://laws.e-gov.go.jp/law/420M60000F5A001
CM9	犯罪収益移転防止法7条1項・3項、同法施行規則23条・24条	取引記録等（確認記録を検索する事項、取引の日付・種類・価額、財産移転の移転元・移転先など。電磁的記録で作成可）	7年	取引（又は特定受任行為の代理等）が行われた日	間接 。勘定系・決済・売買のシステムの取引データそのもの。区分(2)（事業年度末から10年）より短い。 特定事業者（CM10）に限る	A	https://laws.e-gov.go.jp/law/419AC0000000022 / https://laws.e-gov.go.jp/law/420M60000F5A001

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
CM10	犯罪収益移転防止法2条2項（特定事業者の範囲）	—	—	—	間接（適用範囲の規定）。1～49号：銀行・信用金庫・労金・信組・農協・漁協等の金融機関、保険会社・少額短期保険業者、金融商品取引業者、信託会社、不動産特定共同事業者、貸金業者、前払式支払手段発行者（届出者）、資金移動業者、電子決済手段等取引業者、電子決済等取扱業者、暗号資産交換業者、商品先物取引業者、振替機関・口座管理機関、電子債権記録機関、両替業者、ファイナンスリース事業者、クレジットカード事業者、カジノ事業者、宅地建物取引業者、貴金属等の売買業者、郵便物受取・電話受付代行業者、弁護士、司法書士、行政書士、公認会計士、税理士。 金融・不動産・小売（貴金属）・土業などの業種のみ。ただし、弁護士・弁護士法人（45号）は、4条1項により6条・7条の「特定事業者」から除かれる。確認記録・取引記録に相当する措置は、12条により日本弁護士連合会の会則による（CM8・CM9の7年は直接には適用されない）	A	https://laws.e-gov.go.jp/law/419AC0000000022
CM11	労働基準法109条・附則143条1項	労働者名簿、賃金台帳、雇入れ・解雇・災害補償・賃金その他労働関係に関する重要な書類	5年 （附則143条1項により「当分の間」 3年 ）	労基則56条による（CM12）	間接。勤怠・人事・給与システムのデータそのもの。出勤簿・タイムカード等の労働時間の記録もこれに含まれると厚生労働省は示している（CMG9）。区分(2)より短い。起算点が退職日等の事象のため、在職期間が長い場合は作成から10年を超える。全業種（労働者を使用する全事業者）	A	https://laws.e-gov.go.jp/law/322AC0000000049

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
CM12	労働基準法施行規則56条	109条の記録の保存期間の起算日	—	労働者名簿：死亡・退職・解雇の日／賃金台帳：最後の記入をした日／雇入れ・退職の書類：退職・死亡の日／災害補償の書類：災害補償を終わった日／その他の重要な書類：完結の日。賃金の支払期日がこれより遅い場合は支払期日（2項）	間接。 勤怠・給与システムの保存期間の起算点を、作成日ではなく 事象の日 で設計する必要がある。 全業種	A	https://laws.e-gov.go.jp/law/322M40000100023
CM13	労働基準法施行規則24条の7・附則71条	年次有給休暇管理簿。附則71条は、裁量労働制等の労働時間の状況の記録、労使委員会の議事録などの5年も対象	5年 （附則71条により「当分の間」 3年 ）	年次有給休暇管理簿は、有給休暇を与えた期間の満了後（期間中も保存）（賃金の支払期日が遅い場合は支払期日とする56条2項を、56条3項で準用）	間接。 勤怠・休暇管理システムのデータそのもの。 全業種	A	https://laws.e-gov.go.jp/law/322M40000100023
CM14	労働基準法108条、同法施行規則54条1項	賃金台帳の記入事項（労働日数、 労働時間数 、時間外・休日・深夜の労働時間数など）	CM11 による	CM12 による	間接。 勤怠システムで集計する労働時間数が賃金台帳の記入事項になるため、集計の根拠データの保存の考え方に関わる。 全業種	A	https://laws.e-gov.go.jp/law/322AC0000000049 / https://laws.e-gov.go.jp/law/322M40000100023

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
CM15	労働安全衛生法66条の8の3、労働安全衛生規則52条の7の3	労働時間の状況の記録（把握の方法として「タイムカードによる記録、 パーソナルコンピュータ等の電子計算機の使用時間の記録 等の客観的な方法」を明記）	3年	条文に明記なし	間接 （共通法令の中で、ログ（PCの使用時間の記録）を条文に明記した例外的な規定）。保存を求めるのは、把握した「労働時間の状況の記録」である。PCのログオン・ログオフの記録を把握の方法とする場合に、その記録（又はそれから作成した記録）を3年保存する根拠になる。生ログそのものの保存が必要かは解釈。 全業種 （労働基準法41条の2第1項により労働する労働者（66条の8の4の対象者）を除く）	A	https://laws.e-gov.go.jp/law/347AC0000000057 / https://laws.e-gov.go.jp/law/347M50002000032
CM16	番号法（行政手続における特定の個人を識別するための番号の利用等に関する法律）12条	個人番号の漏えい・滅失・毀損の防止その他の適切な管理のために必要な措置	定めなし	—	間接 。安全管理措置の義務であり、ログの保存期間は定めていない。措置の内容は委員会のガイドライン（CMG6～CMG8）が示す。給与・人事・支払調書のシステム。 全業種 （個人番号関係事務実施者）	A	https://laws.e-gov.go.jp/law/425AC0000000027
CM17	番号法20条	特定個人情報（他人の個人番号を含むもの）	19条各号に当たらない場合を除き、収集・ 保管の禁止	—	間接 （上限側の制約）。保存義務ではなく、 保管の禁止 である（個人情報保護法22条の努力義務より強い）。監査ログ・アプリログに個人番号を記録すると、ログ自体がこの規定の対象になる。 全業種	A	https://laws.e-gov.go.jp/law/425AC0000000027
CM18	番号法23条1項・2項、同法施行令30条	情報提供ネットワークシステムによる利用特定個人情報の提供の求め・提供の記録（情報照会者・情報提供者の名称、提供の求めの日時・提供の日時・項目など）	7年	条文に明記なし	直接 （提供の求め・提供の日時などを電子計算機に記録し保存することを明記）。ただし義務を負うのは 情報照会者・情報提供者 （別表の行政機関・地方公共団体・健康保険組合等）に限る。源泉徴収票の作成などを行うだけの一般の事業者は対象外。 特定の業種 （健康保険組合等の保険者、公的機関のシステム）	A	https://laws.e-gov.go.jp/law/425AC0000000027 / https://laws.e-gov.go.jp/law/426CO0000000155
CM19	番号法29条の4	特定個人情報の漏えい等の委員会への報告・本人への通知	定めなし	—	間接 。報告の前提として、漏えい等の事実・範囲を特定できるログが必要になる。保存期間は定めていない。 全業種	A	https://laws.e-gov.go.jp/law/425AC0000000027
CM20	個人情報保護法23条・24条・25条	個人データの安全管理措置、従業者・委託先の監督	定めなし	—	間接 。条文はログに触れず、保存期間も定めていない。アクセスログの記録は委員会のガイドライン（CMG1・CMG2）が手法の例として示す。 全業種	A	https://laws.e-gov.go.jp/law/415AC0000000057

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
CM21	個人情報保護法26条、同法施行規則7条・8条	漏えい等の報告（対象：要配慮個人情報、財産的被害のおそれ、不正の目的によるおそれ、1,000人超）	報告期限：知った後速やかに（速報）、知った日から 30日以内 （不正の目的によるおそれの事態は 60日以内 ）（速報）	事態を知った日	間接 。確報では「本人の数」「原因」などの報告が必要であり、それを特定するログが無いと報告できない。ログの保存期間は定めていない。不正アクセスは発覚までに時間がかかることがあるため、運用ログ（区分(1)）の期間を決める際の考慮要素になる（見解）。 全業種	A	https://laws.e-gov.go.jp/law/415AC0000000057 / https://laws.e-gov.go.jp/law/428M600200000003
CM22	個人情報保護法33条	保有個人データの開示請求への対応	定めなし	—	間接 。ユーザーIDで整理されたログ情報は個人情報データベース等に当たりうる（CMG5）。その場合、保存しているログは保有個人データとして 開示請求の対象 になりうる。保存期間を長くすると、開示請求への対応範囲も広がる。 全業種 （特に一般消費者向けのサービス）	A	https://laws.e-gov.go.jp/law/415AC0000000057
CM23	会社法362条4項6号・5項、会社法施行規則100条1項1号（取締役会設置会社）。ほかに98条1項1号（取締役会を置かない会社）、110条の4第2項1号（監査等委員会設置会社）、112条2項1号（指名委員会等設置会社。執行役）	取締役（執行役）の職務の執行に係る情報の保存及び管理に関する体制（内部統制システム）	定めなし	—	間接 。保存年数ではなく、 情報の保存・管理の体制 を整備することを求める。情報の保存・管理の体制の整備は、取締役会（取締役会を置かない会社は取締役）が決定する事項である。決定が義務となるのは、大会社と、監査等委員会設置会社・指名委員会等設置会社である（362条5項、348条4項など）。ログの保存期間を内部規程で定め、文書化して運用する根拠（J7と同趣旨）。 全業種 （株式会社）。98条は取締役会を置かない会社の規定で、取締役会設置会社は100条である	A	https://laws.e-gov.go.jp/law/417AC0000000086 / https://laws.e-gov.go.jp/law/418M60000010012
CM24	不正アクセス禁止法8条・9条1項	（保存義務ではない）アクセス管理者の防御措置：識別符号の適正な管理、アクセス制御機能の有効性の検証、機能の高度化等（努力義務）	定めなし	—	対象外 。8条はログに触れておらず、保存期間も定めていない。9条1項は、援助を申し出る際に、不正アクセス行為が行われた際の作動状況・管理状況の資料を添えることを定める。運用ログ（区分(1)）を保持しておく実務上の理由にはなるが、年数の根拠にはならない。 全業種	A	https://laws.e-gov.go.jp/law/411AC0000000128

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
CM25	消費税法施行令50条1項・71条2項（消費税法30条7項・58条）	仕入税額控除の帳簿・請求書等（適格請求書等の電磁的記録を含む）、帳簿	7年 （50条1項ただし書の場合は5年を超えて保存を要しない）	帳簿：閉鎖の日の属する課税期間の末日の翌日から2月を経過した日。 請求書等：受領した日（電磁的記録は提供を受けた日）の属する課税期間の末日の翌日から2月を経過した日	間接 。請求書・購買・会計のシステムのデータそのもの。電子インボイスはCM4（電子取引）の要件も満たす必要がある。期間は法人税の7年（J3）とほぼ同じ時期に満了し、区分(2)より短い。 全業種 （課税事業者）	A	https://laws.e-gov.go.jp/law/363CO0000000360
CM26	刑事訴訟法197条3項・4項	業務上記録している電気通信の送信元・送信先・通信日時その他の 通信履歴の電磁的記録	要請があった場合に消去しない期間： 30日以内 。延長しても通じて 60日以内	条文に明記なし（求めの中で期間を定める。受領時からと解される＝解釈）	直接 （通信履歴の電磁的記録を明記）。ただし平時の保存期間を定める規定ではなく、検察官・検察事務官・司法警察員が、差押え又は電磁的記録提供命令のため必要があるときに行う求めがあった場合の 消去の停止 である。対象は電気通信事業者と、「自己の業務のために不特定若しくは多数の者の通信を媒介することのできる電気通信を行うための設備を設置している者」。ログの自動削除を、個別に止められる設計（リーガルホールド）が必要になる。 全業種 （該当する設備を設置している場合。該当性は要法務確認）	A	https://laws.e-gov.go.jp/law/323AC0000000131

§ 3.3 ガイドラインの表

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
CMG1	個人情報保護委員会「個人情報の保護に関する法律についてのガイドライン（通則編）」（令和8年6月一部改正）10（別添）講ずべき安全管理措置の内容「組織的安全管理措置」(2)・(3)	システムログ その他の個人データの取扱いに係る記録。項目の例：個人情報データベース等の利用・出力状況、削除・廃棄の状況、 担当者の情報システムの利用状況（ログイン実績、アクセスログ等）	記載なし	—	ガイドライン（法的拘束力なし） 。(2)の記録は「考えられる」手法の例示。(3)の「取扱状況を確認する手段の整備」は「しなければならない」措置だが、記録の保存期間は示していない。個人データを扱う全システム。 全業種 （業種別ガイドラインがある分野は、その上乗せを各業種の節で扱う）	A	https://www.ppc.go.jp/files/pdf/260614_guidelines01.pdf
CMG2	同 通則編 10（別添）「技術的安全管理措置」(3)外部からの不正アクセス等の防止	ログ等	記載なし	—	ガイドライン（法的拘束力なし） 。「ログ等の定期的な分析により、不正アクセス等を検知する」が手法の例示。ログの保存期間ではなく、分析の運用を求めるもの。 全業種	A	https://www.ppc.go.jp/files/pdf/260614_guidelines01.pdf
CMG3	同 通則編 10（別添）「物理的安全管理措置」(4)個人データの削除及び機器、電子媒体等の廃棄	個人データを削除・廃棄した記録	記載なし	—	ガイドライン（法的拘束力なし） 。削除・廃棄した記録を保存することが「重要である」とする。保存期間の満了による削除の ジョブの実行記録 も、この記録に当たる（見解）。 全業種	A	https://www.ppc.go.jp/files/pdf/260614_guidelines01.pdf
CMG4	同 通則編 3-4-1 データ内容の正確性の確保等（法第22条関係）	個人データ	保存期間を設定すること。利用する必要がなくなったときは遅滞なく消去（努力義務）。 法令の定めにより保存期間等が定められている場合は、この限りでない	利用する必要がなくなった時	ガイドライン（法的拘束力なし） 。J10（個人情報保護法22条）の解釈。法令で期間が定められていればその期間の保存は妨げられない。ただし、区分(2)の10年は会社法432条に「準じて扱う」 解釈 であり（J1）、法令が監査ログの保存期間を定めたものではないため、この例外にそのまま当たるとは言い切れない（見解）。 全業種	A	https://www.ppc.go.jp/files/pdf/260614_guidelines01.pdf

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
CMG5	同 通則編「個人情報データベース等（法第16条第1項関係）」の事例2	ユーザーが利用したサービスに係るログ情報	—	—	ガイドライン（法的拘束力なし） 。ユーザーIDで整理されたログ情報（ユーザーIDと個人情報を容易に照合できる場合）は個人情報データベース等に当たる例とされる。したがって、そのログは個人データとして、安全管理措置・消去の努力義務・開示請求（CM20～CM22、J10）の対象になりうる。 全業種 （特に一般消費者向けのサービス）	A	https://www.ppc.go.jp/files/pdf/260614_guidelines01.pdf
CMG6	個人情報保護委員会「特定個人情報の適正な取扱いに関するガイドライン（事業者編）」（令和7年6月一部改正）（別添1）2 C b 取扱規程等に基づく運用	特定個人情報ファイルの利用・出力状況の記録、削除・廃棄記録、 事務取扱担当者の情報システムの利用状況（ログイン実績、アクセスログ等）の記録	記載なし	—	ガイドライン（法的拘束力なし） 。番号法12条（CM16）の措置の内容。「特定個人情報等の利用状況等を記録する」とし、記録項目を例示。給与・人事システム。 全業種	A	https://www.ppc.go.jp/files/pdf/2506_my_number_guideline_jigyosha.pdf
CMG7	同 事業者編（別添1）2 C c 取扱状況を確認する手段の整備	取扱状況を確認するための記録等	記載なし	—	ガイドライン（法的拘束力なし） 。「取扱状況を確認するための記録等には、特定個人情報等は記載しない」。監査ログ・操作ログに個人番号を出力しない設計の直接の根拠。 全業種	A	https://www.ppc.go.jp/files/pdf/2506_my_number_guideline_jigyosha.pdf
CMG8	同 事業者編 第4-3-(3) B 保管制限と廃棄、（別添1）2 E d 個人番号の削除、機器及び電子媒体等の廃棄	個人番号・特定個人情報ファイル。削除・廃棄した記録	所管法令の保存期間を経過し、事務を処理する必要がなくなった場合は、 できるだけ速やかに廃棄又は削除 。例：扶養控除等申告書は所得税法施行規則76条の3により7年	所管法令による	ガイドライン（法的拘束力なし） 。保存期間経過後の削除を前提としたシステムの構築が「望ましい」「考えられる」とし、削除・廃棄した記録を保存とする。上限側の制約（CM17）。 全業種	A	https://www.ppc.go.jp/files/pdf/2506_my_number_guideline_jigyosha.pdf

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
CMG9	厚生労働省「労働時間の適正な把握のために使用者が講ずべき措置に関するガイドライン」（平成29年1月20日策定）4(2)イ・4(3)ウ・4(5)	始業・終業時刻の記録。出勤簿・ タイムカード等の労働時間の記録に関する書類	3年 （「労働基準法第109条に基づき、3年間保存しなければならない」）	記載なし（CM12による）	ガイドライン（法的拘束力なし） 。タイムカード、ICカード、 パソコンの使用時間の記録等 の客観的な記録を基礎とすることを原則とし、自己申告制では入退場記録やPCの使用時間の記録との乖離を確認とする。勤怠の記録が109条の「重要な書類」に当たるという行政解釈。策定は、109条を3年から5年に改め附則143条（当分の間3年）を設けた改正（令和2年法律第13号、2020-04-01施行。e-Govの改正履歴で改正前後の条文を確認）より前であり、3年は現行の附則143条1項の期間と一致する。 全業種	A	https://www.mhlw.go.jp/kinkyu/dl/151106-04.pdf
CMG10	国税庁「電子帳簿保存法取扱通達」（令和7年6月27日付一部改正分まで。令和9年1月1日施行分を含む）7-6・7-7・8-8～8-11	訂正削除の履歴（訂正前・削除前の記録事項と訂正削除の内容）、訂正削除の事務処理の記録	記載なし（CM2～CM4による）	—	ガイドライン（法的拘束力なし） （法令解釈通達。納税者を直接拘束しない）。①訂正削除の履歴は、訂正前の記録事項と内容が その電磁的記録又は別の電磁的記録（訂正削除前の履歴ファイル）に自動的に記録されるシステム （7-6）。② 反対仕訳も訂正削除に含む （8-8）。反対仕訳による方法も認める（8-9）。③入力から 1週間以内 の誤りは正の期間を事務手続書に定めれば、その期間の訂正削除は履歴を残さなくてよい（8-10）。④入力日・一連番号の自動付与と訂正不可で追加入力の履歴を満たす（8-11）。⑤事務処理規程には訂正削除日・理由・内容・担当者の記録と保存を含める（7-7）。 注意 ：通達は、2027-01-01施行後の条番号で書かれている。7-6・7-8・8-8～8-11・8-26が引用する「規則5条4項」は、現行の5条5項（優良な電子帳簿）に当たる。7-6・8-26の「規則5条5項1号」は、施行後に新設される特定電磁的記録のシステムの要件であり、現行の5条5項1号（優良な電子帳簿）ではない。 全業種	A	https://www.nta.go.jp/law/joho-zeikaishaku/sonota/jirei/pdf/0025006-066.pdf

§ 3.4 上限側の制約

- **番号法20条（CM17）**：個人番号を含む特定個人情報、法定の事務に必要な場合を除き**保管してはならない**（禁止規定）。保存期間経過後はできるだけ速やかに削除する（CMG8）。監査ログ・アプリログ・デバッグログに個人番号が出力されると、ログの保存期間（区分(2)の10年など）と衝突する。**ログには個人番号を記録しない**（CMG7）ことで衝突を避けるのが基本である。

- **個人情報保護法22条（J10）**：利用する必要がなくなった個人データの消去の努力義務。ユーザーIDで整理されたログ情報は個人データに当たりうる（CMG5）。法令で保存期間が定められている場合は例外とされる（CMG4）が、区分(2)の10年は解釈に基づく期間であるため、目的（内部統制の監査・不正調査）と期間の根拠を内部規程に明記しておく。
- **個人情報保護法33条（CM22）**：保存しているログは開示請求の対象になりうる。保存を長くすると、開示請求への対応範囲が広がる（制約というより、長期保存の負担）。
- 通信の秘密（電気通信事業法）は業種固有の法令のため、本節では扱わない（§ 10（電気通信編）で扱う）。

§ 3.5 推奨案

区分	推奨する保存期間	起算点	根拠ID	理由
(1) 運用ログ	1年 （基礎資料のとおり）	ログの作成日	共通法令に年数の定めなし。考慮要素：CM21、CM24、CM26	共通法令は運用ログの年数を定めていない。漏えい等の確報（30日・60日）で「本人の数」「原因」を特定するには、発覚までの期間を遡れるログが必要であり、1年はその目安として妥当である（見解）。捜査機関の保全要請（最長60日）や訴訟の予期に備え、自動削除を個別に止められるようにする
(2) 監査ログ	事業年度末から10年 （基礎資料のとおり。作成日起算なら11年）	事業年度末	J1（主）、CM2～CM4、CM25（帳簿書類に当たる場合）、CM23（体制）	共通法令で区分(2)より長い年数を直接定めるものはない。電子帳簿保存法の訂正削除の履歴は帳簿書類の保存期間（J3：7年。欠損金の年度は10年。申告期限の翌日から）に従うため、 欠損金の年度に限り、区分(2)より約2か月以上（申告期限の延長があればさらに）長くなりうる （基礎資料F1と同じ論点：作成日起算で設定する場合に、欠損金のある事業年度の法人税の10年（申告期限の翌日から）まで満たすため、12年〔約4383日〕とする案）。会計システムの訂正削除の履歴を(2)に含める場合は、12年（約4383日）への延長を検討する
(3) 業種固有の記録とその変更履歴	共通法令による追加として、次のものがある（いずれも該当するシステムに限る）。 ・電子取引データ・スキナ保存データ・電子帳簿（とその訂正削除の履歴）： 国税の保存期間 （法人税7年・10年、消費税7年） ・犯収法の確認記録： 取引終了日から7年 、取引記録： 取引日から7年 ・労働関係の記録（勤怠・PC使用時間の記録を含む）： 3年 （本則は5年。労基法附則143条1項・労基法附則71条の「当分の間」の経過措置による。安衛則52条の7の3は3年。経過措置の終了に備え、保存期間を設定で5年に変更できるようにする）、起算点は退職日・最後の記入日・完結の日など	各行の起算点	CM1～CM4、CM25、CM8～CM10、CM11～CM15	年数は、いずれも区分(2)の10年より 短い 。ただし 起算点が事象の日 （契約終了、退職、最後の記入）であるものは、作成日から数えると10年を超えることがある。例：2026年に作成した確認記録でも、対象の契約が2040年に終了した場合は2047年まで保存（契約終了日が起算日となる取引の場合）。保存期間は「作成日＋年数」ではなく「事象の日＋年数」で管理する

共通の下限（区分(2)=事業年度末から10年）との関係：共通法令で、年数として区分(2)を上回るものはない（番号法23条の7年、犯収法の7年、国税の7年、労働関係の3年（本則5年））。上回りうるのは、**起算点が後ろにずれる場合**だけである。具体的には、①犯収法の確認記録（取引終了日から）、②労働者名簿など（退職日から）、③欠損金の年度の法人税の帳簿書類（申告期限の翌日から10年。区分(2)より約2か月以上長い）である。

§ 3.6 留意点・判断が必要な論点

#	論点	内容	必要な判断
CF1	電子帳簿保存法の訂正削除の履歴が求められる場面	訂正削除の履歴は、①優良な電子帳簿（任意、CM2）、②スキャナ保存（「訂正削除できない」との選択、CM3）、③電子取引（4つの措置の1つ、CM4）で求められる。一般の電子帳簿（CM1）では求められない。電子取引で③のシステム要件を選ぶと、訂正前の記録事項と訂正の内容を、 本体のデータと同じ保存期間 （書面で保存すべき期間）を通じて確認できるようにする必要がある（規則4条1項）。監査ログの保存期間とは別に、「業務データの変更履歴」として設計する（基礎資料F4と同じ考え方：ログではなく、業務データの保存要件として設計する）なお、2027-01-01以降は、特定電磁的記録の保存（規則5条5項。任意。重加算税の加重を受けないための要件）が4つ目の場面になる（CF2参照）。電子取引で事務処理規程の方法（規則4条1項4号）を選んだ場合でも、通達7-7により、訂正削除の日・理由・内容・担当者の記録と保存が規程の内容に含まれる。	会計・請求・経費精算のシステムで、①優良な電子帳簿を目指すか、②電子取引の措置をシステム（履歴）・タイムスタンプ・事務処理規程のどれで満たすかを決める。履歴で満たす場合は、反対仕訳も訂正削除に当たること（CMG10）、1週間以内の誤り是正を除外する定めの有無を設計に反映する
CF2	電子帳簿保存法の2027-01-01施行の改正	令和7年法律第13号・令和7年財務省令第28号のうち、2027-01-01施行分が未施行である（e-Govの改正履歴で確認）。施行後は、優良な電子帳簿の要件が 規則5条5項1号イ→5条4項1号イ に移り、5条5項は、電子取引の「特定電磁的記録」を、訂正削除の履歴（又は訂正削除不可）のある「特定電子計算機処理システム」で保存する要件になる（同時に法8条5項も改正）。国税庁長官が定める基準（告示。令和7年3月31日現在の掲載は確認したが、本文は確認していない）が、そのシステムの基準を定める	業種の資料で規則の条番号を引用する場合は、施行日の前後で条番号が異なることを注記する。2027年以降に運用するシステムは、施行後の要件も確認する
CF3	保存期間の起算点が作成日でない記録	犯収法の確認記録（取引終了日）、労基法の記録（退職日・最後の記入日・完結の日、賃金の支払期日が遅ければ支払期日）、消費税（課税期間の末日の翌日から2月を経過した日）、法人税（申告期限の翌日）は、作成日起算のオブジェクトロック（例：S3）で単純に設定できない	事象の日を管理するテーブルを持ち、満了日をアプリケーションで計算するか、事象の発生時にロック期間を延長する方式とするかを決める
CF4	ログへの個人番号・個人情報出力	番号法20条とガイドライン（CMG7）により、ログに個人番号を記録しないことが基本である。個人情報（ユーザーIDと照合できる情報）を含むログは個人データになりうる（CMG5）	ログ出力の項目から個人番号を除外する（マスキングでなく非出力）。個人データを含むログの保存期間の根拠を規程に明記する
CF5	勤怠システム・PCログの扱い	PCの使用時間の記録を労働時間の状況の把握に使う場合、その記録は安衛則で3年、労基法109条の重要な書類として3年（当分の間）保存する。起算点は、労基則56条により完結の日等（賃金の支払期日が遅ければ支払期日）。生ログそのものまで保存が必要かは解釈が分かれる	PCログ（運用ログ扱いの1年）を労働時間の把握の根拠に使うかを人事部門と決める。使う場合は、生ログ又は集計後の記録を3年以上保存する区分を設ける
CF6	リーガルホールド（消去の停止）	刑事訴訟法197条3項の保全要請（最長60日）、漏えい等の調査、訴訟の予期（基礎資料U5・U6）に備え、自動削除を対象を絞って止められるようにする。コンプライアンスモードのオブジェクトロックは延長できるが短縮できない点も考慮する	保全の対象・手順・承認者を運用手順に定める。197条3項の「不特定若しくは多数の者の通信を媒介することのできる…設備を設置している者」に自社が当たるかを法務部門に確認する
CF7	犯収法の特定事業者	特定事業者は金融・不動産・貴金属・土業などに限られる（CM10）。該当する業種の資料は、CM8・CM9を引用し、確認記録の起算点（取引終了日）に注意する	自社が特定事業者に当たるか、どの業務が特定業務に当たるかを確認する

§ 3.7 未確認の一覧

項目	理由
e-文書法の「見読性・完全性・機密性・検索性」の4要件という整理	法律本体・施行令に、これらの文言は無い（全文検索で確認）。主務省令3件を確認した範囲では、見読性は共通、検索性・改変消去の確認（完全性）は一部の省令のみ、機密性の明文は無い（CM7）。経済産業省令4条4項の「経済産業大臣が定める基準」（告示）も取得していない。4要件として整理した政府の公式文書は、公式サイトから原文で取得できなかった。法律本体の要件としては、法令に見当たらない
電子帳簿保存法の2027-01-01施行後の法8条5項・規則5条5項の詳細（特定電磁的記録の範囲、重加算税の加重の不適用の要件の全体）	未施行の版の条文は取得したが、施行前のため表には載せず、条番号の移動のみをCF2 に記した
番号法23条の記録の保存期間（7年）の起算点	法23条・施行令30条に起算点の明記がない。行政の解釈は確認していない
安衛則52条の7の3の3年の起算点、生ログそのものの保存の要否	条文に明記がない。行政通達を確認していない
刑事訴訟法197条3項の「自己の業務のために不特定若しくは多数の者の通信を媒介することのできる電気通信を行うための設備を設置している者」に、一般の企業の社内ネットワークが当たるか	条文の解釈であり、解釈を示す公式文書を確認していない
漏えい等の報告（個人情報保護法26条・番号法29条の4）に関連して、報告した事案の記録の保存期間	法律・施行規則に、記録の保存期間の規定は見当たらなかった。ガイドラインの該当箇所（3-5）の全文は精読していない
所得税法施行規則76条の3（扶養控除等申告書の7年）の条文	ガイドライン（CMG8）の記載で触れたのみで、条文は取得していない。人事・給与システムで必要な場合は確認する
公益通報者保護法の体制整備（11条）と指針における記録の保管	確認していない。内部通報システムを扱う場合は別途確認する
雇用保険法施行規則・健康保険法施行規則・厚生年金保険法施行規則などの社会保険関係書類の保存期間	調査範囲外とした（いずれも区分(2)の10年に影響しない短期の期間と推測されるが、未確認）

§ 3.8 対象外の一覧

名称	理由
JIIMA 認証（電子帳簿・電子取引ソフトの認証）	民間団体の認証であり法令ではない
JIS Z 6016、JIS Z 8305	電子帳簿保存法施行規則が引用するが、有料の規格であり本文は確認していない（規則の要件として CM3 の範囲で言及するにとどめる）
ISO/IEC 27001・27002 のログ管理の管理策	有料の国際規格
業種固有の法令（銀行法、保険業法、医師法、薬機法、電気通信事業法など）	各業種の節（§ 4～§ 13）で扱う
業種別の個人情報ガイドライン（金融・医療・電気通信分野など）	各業種の節（§ 4～§ 13）で扱う

§ 6 保険

§ 6.1 業種の概要

対象は、保険業法に基づく保険会社（生命保険会社・損害保険会社。株式会社と相互会社がある。外国保険会社等、少額短期保険業者を含む）、保険募集人（生命保険募集人・損害保険代理店・少額短期保険募集人。うち規模の大きい「特定保険募集人」「特定大規模乗合保険募集人」には追加の義務がある）、保険仲立人、および金融サービス提供法に基づき保険媒介業務を行う金融サービス仲介業者である。システムで記録・ログが問題になる場面は、①保険契約の管理（契約の締結から消滅まで数十年に及ぶ終身保険などの長期契約）、②保険募集（意向把握・意向確認、説明の記録、書面の電磁的交付）、③募集人・仲立人の帳簿書類、④変額保険などの特別勘定の経理、⑤苦情処理・利益相反管理の記録、⑥顧客情報（機微情報を含む）へのアクセス管理とインターネット取引の不正検知、である。保険業法は、**監査ログの保存年数を直接定めていない**。保存期間を定めるのは帳簿書類・記録であり、その一部は**保険契約の消滅（保険期間の終了）を起算点とする**点が、この業種の特徴である。

§ 6.2 法令の表

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
IN1	保険業法54条の2第2項（198条で外国相互会社に準用）	相互会社の会計帳簿、およびその事業に関する重要な資料	10年	会計帳簿の閉鎖の時	間接 ：会社法432条2項（J1）と同じ内容を、株式会社でない相互会社について定めた規定。監査ログを明記した条文ではなく、J1と同様に「重要な資料に準じて扱う」という解釈で(2)の根拠になる（ 要法務確認 ）。相互会社では、(2)の10年の根拠はJ1ではなく本条になる	A	https://laws.e-gov.go.jp/law/407AC0000000105
IN2	保険業法54条の3第4項	相互会社の計算書類・附属明細書	10年	計算書類を作成した時	間接 ：会社法435条4項（基礎資料J2）に相当する相互会社の規定。会計データの出力物であり、(2)を10年とする補強材料	A	https://laws.e-gov.go.jp/law/407AC0000000105
IN3	保険業法13条	（株式会社である保険会社に対する会社法432条1項などの読替え）	定めなし	—	対象外 ：「法務省令」を「内閣府令」と読み替えるだけで、保存期間を定めていない。 株式会社である保険会社の会計帳簿の保存期間は、保険業法ではなく会社法432条2項（J1）による	A	https://laws.e-gov.go.jp/law/407AC0000000105
IN4	保険業法303条、同法施行規則236条の2・237条の2（罰則：法320条3号）	特定保険募集人（規模の大きいもの）・保険仲立人の、事務所ごとの業務に関する帳簿書類（保険契約者ごとの締結年月日・引受保険会社・保険料・受領した手数料等。仲立人は媒介の内容なども）	IN5・IN6のとおり	IN5・IN6のとおり	間接 ：帳簿書類を電磁的記録で作成・保存する場合の、そのデータと訂正削除の履歴として関わる。対象は、所属保険会社等の数が15以上、または2以上の所属保険会社等から受けた手数料等の総額が10億円以上の募集人（規則236条の2）と、保険仲立人に限られる。 これに当たらない一般の保険募集人には、保険業法上の帳簿書類の保存義務はない	A	https://laws.e-gov.go.jp/law/407AC0000000105 / https://laws.e-gov.go.jp/law/408M50000040005
IN5	保険業法施行規則237条1項	特定保険募集人の、保険契約ごとの帳簿書類（IN4）	5年	保険契約の締結の日	間接 ：起算点が契約の消滅ではなく締結の日である。長期契約では、契約の存続中に保存期間が満了しうる。共通の下限（(2)＝事業年度末から10年）より 短い	A	https://laws.e-gov.go.jp/law/408M50000040005
IN6	保険業法施行規則237条2項	保険仲立人の、保険契約ごとの帳簿書類（IN4）。顧客に交付した書面の写し、結約書の写し、媒介の委託契約書などとともに保存	5年	保険契約が消滅した日	間接 ：契約期間に連動する。保存の終了日は「契約消滅日＋5年」であり、終身保険などでは作成から数十年後になる。消滅日から見れば(2)の10年より短い、作成日から見れば、契約期間が約5年を超えると(2)より長く保存することになる	A	https://laws.e-gov.go.jp/law/408M50000040005

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
IN7	保険業法施行規則227条の4第2項3号	保険仲立人が、法294条4項の書面（仲立人の商号・権限・損害賠償に関する事項など）の交付に代えて、同条5項の電磁的方法のうち、規則227条の4第1項1号ハ・ニの閲覧の方法（顧客ファイル・閲覧ファイル）で提供した記載事項	5年（期間中に苦情の申出があれば、期間の終了日と苦情の解決日の遅い方まで）	保険契約が消滅した日以後	間接：保存期間というより、「消去し又は改変することができないもの」であることを求めるシステム要件（改ざん防止・WORM相当）。対象は交付した書面の電子データであり、ログではない。顧客の消去の指図や書面交付への切替えなどの場合は消去できる（同号ただし書）	A	https://laws.e-gov.go.jp/law/408M50000040005
IN8	保険業法施行規則234条の6第2項3号	特定保険契約（変額保険など、市場リスクのある保険。法300条の2）について、準用金融商品取引法34条の2第4項等により書面に代えて閲覧の方法で提供した記載事項。保険会社等・保険募集人・保険仲立人が対象（対象は、特定投資家制度の申出・承諾に関する書面に限られる。契約締結前・締結時の情報提供（準用金商法37条の3・37条の4）は、現行法では書面交付ではなく情報提供とされ、34条の2第4項を準用しないため、本条の対象ではない）	5年（苦情の申出があれば、期間の終了日と苦情の解決日の遅い方まで）	記載事項に掲げられた取引を最後に行った日以後	間接：IN7と同じく、「消去し又は改変することができないもの」であることを求めるシステム要件。対象は提供した書面の電子データであり、ログではない	A	https://laws.e-gov.go.jp/law/408M50000040005

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
IN9	保険業法施行規則75条の2第3項（外国保険会社等は154条の2に同旨）	運用実績連動型保険契約（変額保険など）の特別勘定（特定特別勘定）の帳簿書類：①特定特別勘定元帳、②特定特別勘定に係る総勘定元帳、③業務の委託契約書	①10年、②5年、③5年	①「保険年度の終了の日又は保険期間の終了の日」、②作成の日、③委託契約の終了の日	間接 ：変額保険を扱う保険会社の経理システムに関わる。①は 契約期間に連動しうる 。「又は」の読み方は条文上明確でない（ 解釈 。保守的に「保険期間の終了の日から10年」と読むと、変額終身保険では作成から数十年後まで保存が必要になる）。共通の下限（(2)）より 長くなりうる	A	https://laws.e-gov.go.jp/law/408M50000040005
IN10	保険業法施行規則52条の22第4項	保険金信託業務を行う生命保険会社等の帳簿書類：①信託勘定元帳、②総勘定元帳、③委託契約書	①10年、②5年、③5年	①信託財産の計算期間の終了の日または信託行為によって設定された期間の終了の日、②作成の日、③委託契約の終了の日	間接 ：保険金信託業務（法99条）を行う生命保険会社のみ。①は信託期間に連動する	A	https://laws.e-gov.go.jp/law/408M50000040005
IN11	保険業法施行規則53条の14第2項（外国保険会社等は133条の4、保険持株会社は210条の6の6に同旨）	利益相反管理の記録（対象取引の特定に係る記録、顧客保護のための措置に係る記録）	5年	記録の作成の日	間接 ：利益相反管理システムで記録を作成・保存する場合のデータ。共通の下限（(2)）より 短い	A	https://laws.e-gov.go.jp/law/408M50000040005
IN12	保険業法施行規則53条の14の2第2項（外国損害保険会社等は133条の5に同旨）	損害保険会社が、兼業特定保険募集人（自動車修理などを兼業する代理店）との関係で講じる、保険金支払業務の公正確保の措置・監視に係る記録	5年	記録の作成の日	間接 ：保険金支払システム・代理店管理システムの記録として関わる。共通の下限（(2)）より 短い	A	https://laws.e-gov.go.jp/law/408M50000040005

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
IN13	保険業法294条の4第3号、同法施行規則227条の19第2項	特定大規模乗合損害保険代理店の、保険募集の業務に係る苦情処理の記録（申立者、受付日時、内容、原因究明の結果、やり取りの経緯、講じた措置など）	5年	記録の作成の日	間接 ：苦情管理システムの記録として関わる。共通の下限（(2)）より 短い	A	https://laws.e-gov.go.jp/law/407AC0000000105 / https://laws.e-gov.go.jp/law/408M50000040005
IN14	保険業法施行規則227条の20第2項	兼業特定保険募集人である特定大規模乗合損害保険代理店の、保険募集以外の業務（保険金の支払の請求に関するもの）の特定・監視・体制整備の記録	5年	記録の作成の日	間接 ：監督指針（ING6）は、自動車の修理見積額の適切性に係る証拠の記録・保存を、本項に基づく保存として求めている。共通の下限（(2)）より 短い	A	https://laws.e-gov.go.jp/law/408M50000040005
IN15	保険業法施行令40条、同法施行規則215条の4第1項3号口	特定大規模乗合生命保険募集人（2以上の生命保険会社の乗合で規模の大きいもの）の、苦情処理の記録	5年	記録の作成の日	間接 ：IN13の生命保険版。共通の下限（(2)）より 短い	A	https://laws.e-gov.go.jp/law/407CO0000000425 / https://laws.e-gov.go.jp/law/408M50000040005

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
IN16	保険業法施行規則53条の8（保険会社）・227条の9（保険募集人・保険仲立人）	個人である顧客に関する情報の安全管理措置	定めなし	—	間接 ：保険業法上の安全管理義務であり、期間の定めはない。保険募集人・保険仲立人については、監督指針II-4-2-2(14)が、規則227条の9の「必要かつ適切な措置」を金融分野ガイドライン第8条～第10条と実務指針I～III・別添2に基づく措置とする、と明記しており、実務指針のアクセス記録の義務（ING8）がこの規定を通じて求められる。保険会社（53条の8）についても、監督指針II-4-5-2(2)（およびII-4-4-1-2(13)）が、規則53条の8に基づく措置として、金融分野ガイドライン第8条～第10条と実務指針I～III・別添2の措置を求めている、実務指針のアクセス記録の義務（ING8）は、保険会社・保険募集人・保険仲立人のいずれにも、この規定を通じて求められる。なお、ING8そのものは個人情報保護法の安全管理措置（同法23条）に関する指針である	A	https://laws.e-gov.go.jp/law/408M50000040005
IN17	保険業法294条の2（意向把握・確認義務）、同法施行規則53条の7・227条の7（社内規則等）	顧客の意向の把握、意向に沿った提案・説明、意向と契約内容の合致を顧客が確認する機会の提供	定めなし	—	対象外 ：意向把握・確認の実施を義務づけるが、その 記録の作成・保存や保存期間は定めていない 。記録の保存は、監督指針（ING3）が「保存するなどの措置」として示すにとどまる	A	https://laws.e-gov.go.jp/law/407AC0000000105 / https://laws.e-gov.go.jp/law/408M50000040005
IN18	金融サービスの提供及び利用環境の整備等に関する法律33条、金融サービス仲介業者等に関する内閣府令138条1項2号・139条2項	金融サービス仲介業者の、保険媒介業務（同法11条3項）に係る記録（媒介年月日、保険契約の種類・内容、保険期間の始期・終期、保険料、媒介の内容など）	5年	保険契約が消滅した日	間接 ：保険業法以外で、保険契約の情報の保存を定める法令。IN6と同じく 契約期間に連動する	A	https://laws.e-gov.go.jp/law/412AC0000000101 / https://laws.e-gov.go.jp/law/503M60000002035

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
IN19	保険法95条	（保存義務ではない）保険給付・保険料の返還・保険料積立金の払戻しの請求権の消滅時効（1項）、保険料請求権の消滅時効（2項）	1項：3年、2項：1年	権利を行使することができる時	対象外 ：保存義務ではない。保険法には記録の保存を定める規定は見当たらない（「保存」「記録」で検索して該当なし）。保険金請求の紛争に備える期間の参考にとどまる	A	https://laws.e-gov.go.jp/law/420AC0000000056
IN20	保険業法施行規則239条の10第2項・239条の13第1項（法308条の11・308条の13第9項）	指定紛争解決機関の苦情処理手続の記録、紛争解決手続の手続実施記録	少なくとも5年／少なくとも10年	手続が終了した日	対象外 ：義務を負うのは指定紛争解決機関（ADR機関）であり、保険会社・募集人ではない。混同しやすいため掲載	A	https://laws.e-gov.go.jp/law/408M50000040005

§ 6.3 ガイドラインの表

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
ING1	金融庁「保険会社向けの総合的な監督指針」（令和8年10月版）II-3-13-2-1-2(4)（システムリスク管理態勢・情報セキュリティ管理）	顧客の重要情報へのアクセス記録。重要情報の洗い出しの対象には、障害解析用データや取引ログも含む	定めなし	—	ガイドライン（法的拘束力なし） ：不正アクセス・情報漏えいを牽制・防止する仕組みとして「アクセス記録の保存、検証」を挙げる。 ログの取得・保存を明記する（直接）が、年数は示していない。 (2)の監査ログ（アクセス権の付与、特権操作、顧客情報へのアクセス）の取得根拠	A	https://www.fsa.go.jp/common/law/guide/ins/02c.html
ING2	同監督指針 II-3-13-2-2-2(2)（インターネット取引・セキュリティの確保）	ログイン・取引時の情報	定めなし	—	ガイドライン（法的拘束力なし） ：不正アクセス検知と「事後検証に資するログイン・取引時の情報の保存」を求める。年数の記載はない。契約者向けWebサービスの認証ログの取得根拠	A	https://www.fsa.go.jp/common/law/guide/ins/02c.html
ING3	同監督指針 II-4-2-2(3)④ア・イ(ア)(キ)（意向把握・確認義務に係る体制整備）	意向把握に用いた帳票等（アンケート、設計書など。当初の意向と最終的な意向に係るもの）、意向確認書面	定めなし	—	ガイドライン（法的拘束力なし） ：保険会社または保険募集人が「保存するなどの措置」、意向確認書面を「事後的に確認できる方法により保存」することを求めるが、 保存期間は示していない。 募集支援システムの記録（業種固有の記録）として、(3)の対象	A	https://www.fsa.go.jp/common/law/guide/ins/02d.html
ING4	同監督指針 II-4-2-6-3(5)（銀行等の保険募集指針）	銀行等が保険募集を行う場合の、保険募集時の説明に係る記録等（顧客との面談内容などの記録）	保険期間が終了するまで	（保険期間の終了時まで）	ガイドライン（法的拘束力なし） ：銀行等の窓口販売に限った記述だが、 募集時の記録の保存期間を契約期間に連動させた、唯一の公式の記述である	A	https://www.fsa.go.jp/common/law/guide/ins/02d.html
ING5	同監督指針 II-4-4-2-1(4)（高齢者に対する保険募集）	保険募集内容の記録（録音・報告書への記録など）	定めなし	—	ガイドライン（法的拘束力なし） ：高齢者や商品の特性に応じた記録・保存を、適切な取組みの例として挙げる。年数の記載はない。録音データなどの保存期間は各社で定める	A	https://www.fsa.go.jp/common/law/guide/ins/02d.html
ING6	同監督指針 II-4-2-15-5(1)①・(4)（兼業特定保険募集人である特定大規模乗合損害保険代理店）	自動車の損傷状況・修理内容など見積額の適切性に係る証拠、定期的な検証の記録、体制整備の記録	規則227条の20第2項（IN14）に基づき保存（＝5年）	（IN14：作成の日）	ガイドライン（法的拘束力なし） ：IN14の具体化。保存期間はIN14による	A	https://www.fsa.go.jp/common/law/guide/ins/02d.html

#	法令・条項	保存対象	期間	起算点	対象システムへの適用性	確認レベル	URL
ING7	同監督指針Ⅱ-4-2-10（帳簿書類）	特定保険募集人の帳簿書類（規則237条の2第1項）	定めなし（IN5による）	—	ガイドライン（法的拘束力なし） ：帳簿書類の作成・保存の方法を社内規則等に具体的に定めることを求める	A	https://www.fsa.go.jp/common/law/guide/ins/02d.html
ING8	個人情報保護委員会・金融庁「金融分野における個人情報保護に関するガイドラインの安全管理措置等についての実務指針」（令和6年3月改正、同年4月1日適用。告示）5-5・5-6・5-7、7-2-2⑤⑥	個人データへのアクセス・操作の記録、個人データを取り扱う情報システムの稼動状況の記録	定めなし	—	ガイドライン（法的拘束力なし） ：アクセスや操作を「記録するとともに、当該記録の分析・保存を行わなければならない」とし、不正が疑われる異常な記録の存否の定期的な確認も求める。 ログの取得・保存を明記する（直接）が、年数は示していない 。告示の形式で公表されているが、ガイドラインの表に載せる	A	https://www.fsa.go.jp/common/law/kj-ho-go-2/03-3.pdf
ING9	金融庁「金融分野におけるサイバーセキュリティに関するガイドライン」（令和6年10月4日制定、令和7年7月4日改正）2.3.4.2①②（ログ管理）、2.3.1④（認証・アクセス管理）	イベントログ、運用担当者の作業ログ、ユーザの処理内容のログ	定めなし（ 保存期間を手続に定めることを求める ）	—	ガイドライン（法的拘束力なし） ：保険会社・少額短期保険業者・金融サービス仲介業者を対象に含む。「基本的な対応事項」として、ログの取得・監視・保存の手続を策定し、その手続に「保存期間」「ログの改ざん防止」などを含めることを求める。年数は示していない。(1)(2)の期間を文書化する根拠	A	https://www.fsa.go.jp/common/law/cybersecurity_guideline.pdf
ING10	個人情報保護委員会・金融庁「金融分野における個人情報保護に関するガイドライン」（令和6年3月改正、同年4月1日適用）第7条	預金者・保険契約者等の個人データ	利用目的に応じて定める（例：契約終了後一定期間内）	（例示では契約終了）	ガイドライン（法的拘束力なし） ：保存期間を定め、経過した個人データを消去することを求める。 保存の上限側の制約 として扱う（下記「上限側の制約」）。なお、令和8年7月24日改正（令和9年4月1日適用）は第4条の例示の追加のみで、第7条・第8条は変わらない（新旧対照表で確認）	A	https://www.fsa.go.jp/common/law/kj-ho-go-2/01-4.pdf
ING11	保険会社向けの総合的な監督指針Ⅱ-3-13-2-1-2(6)ア(オ)	システムの開発や変更の記録	定めなし（保存期間を定めて保管することを求める）	—	ガイドライン（法的拘束力なし） ：システム変更履歴の保存期間を規程で定める根拠。年数は示していない	A	https://www.fsa.go.jp/common/law/guide/ins/02c.html

§ 6.4 上限側の制約

- **個人情報保護法22条（J10）**：利用する必要がなくなった個人データは、遅滞なく消去する努力義務。保険の監査ログ・契約データには、契約者・被保険者・受取人の氏名、病歴などが含まれる。

- **金融分野における個人情報保護に関するガイドライン第7条（ING10）**：保険契約者等の個人データは「契約終了後一定期間内とする等」、利用目的に応じて保存期間を定め、経過したものは消去する「こととする」。個人情報保護法22条（努力義務）より強い書き方であり、**金融分野に固有の上限側の制約**である。契約データを「無期限に保存」とする設計は、これと整合しない。
- **機微（センシティブ）情報**：金融分野ガイドライン第5条1項は、要配慮個人情報や保健医療に関する情報などを「機微（センシティブ）情報」とし、列挙された場合（⑧「保険業その他金融分野の事業の適切な業務運営を確保する必要性から、本人の同意に基づき業務遂行上必要な範囲で」など）を除き、取得・利用・第三者提供を行わないこととしている。保存期間を定める規定ではないが、ログに病歴などを含めると、業務上必要な範囲を超える利用になりうる。マスキングを検討する。
- **規則227条の4・234条の6（IN7・IN8）の消去条項**：顧客の消去の指図があれば消去できる、とされている。システムは「消去・改変できない」要件と「指図による消去」を両立させる必要がある。
- **監督指針Ⅱ-4-5-2(2)（クレジットカード情報等）**：保存期間を設定し、経過後は速やかに廃棄する。保険料のカード払いを扱う場合は、ログにカード番号等を残さない設計が前提になる（銀行のBKG4と同旨）。
- 通信の秘密に相当する、保険業に固有の上限規定は見当たらない。

§ 6.5 推奨案

区分	推奨する保存期間	起算点	根拠ID	理由
(1) 運用ログ	1年 （業種固有の追加なし）	ログの作成日	ING9（参考：ING1・ING2）	保険業法・監督指針に年数の定めはない。サイバーセキュリティガイドラインは保存期間を手続に定めることを求めるのみ。監督指針は、システムの開発・変更の記録について、保存期間を定めて保管することを求める（ING11）。インターネット取引の認証ログは「事後検証に資する」保存が求められる（ING2）ため、不正検知・顧客通知に使うものは(2)とするかを検討する
(2) 監査ログ	ログ作成日の属する事業年度末から10年 （共通の下限と同じ）	事業年度末	株式会社：J1。 相互会社：IN1（・IN2）。取得の根拠：ING1・ING8・ING9	保険業法は、監査ログについて共通の下限より長い期間を定めていない。 相互会社は会社法432条の対象外だが、保険業法54条の2が同じ「帳簿閉鎖の時から10年」を定めるため、株式会社・相互会社とも(2)は同じになる。 監督指針・実務指針はアクセス記録の取得・保存を明記するが年数はないため、期間は共通の下限による
(3) 業種固有の記録とその変更履歴	保険契約の消滅日から5年 （満期のほか、解約・失効等による消滅を含む）。ただし、閲覧の方法で交付した書面のデータ（IN7）は、期間中に苦情の申出があれば、5年の終了日と苦情の解決日の遅い方まで、消去・改変できない状態で保持する（IN8は起算点が最終取引日）。変額保険の特別勘定の経理に関わるものは 保険期間の終了日から10年 。苦情処理・利益相反管理などの記録は 作成日から5年 。いずれも(2)にも当たるものは(2)と遅く満了する方まで	契約の消滅日／最終取引日（IN8）／苦情の解決日／保険期間の終了日／作成日	IN6・IN7・IN18（消滅＋5年）、IN9（保険期間終了＋10年、保守的解釈）、ING4（保険期間終了まで）、IN11～IN15（作成＋5年）、IN5（締結＋5年）	保険業法令は、契約に関わる帳簿・記録の多くを 契約の消滅を起算点 として定める（仲立人の帳簿、電磁的交付書面、金融サービス仲介業者の記録）。保険会社自身の契約記録・募集記録（意向把握記録など）には法定の保存期間がないが、監督指針は銀行等の募集時の記録を「保険期間が終了するまで」としており、同じ起算点の「消滅＋5年」に揃えると説明しやすい

共通の下限（区分(2)＝事業年度末から10年）との関係

- **長い（または長くなりうる）もの**：契約の消滅・保険期間の終了を起算点とする期間（IN6・IN7・IN9・IN18、ING4）。終身保険などの長期契約では、保存の終了日が作成から数十年後になり、(2)より**はるかに長い**。特にIN9①（変額保険の特定特別勘定元帳）は、保守的に読むと「保険期間の終了から10年」であり、最も長い。
- **同じもの**：相互会社の会計帳簿・重要な資料（IN1。10年・帳簿閉鎖の時）。
- **短いもの**：特定保険募集人の帳簿書類（IN5。**締結の日**から5年）、苦情処理・利益相反管理・保険金支払関係の記録（IN11～IN15。作成の日から5年）、変額保険の総勘定元帳（IN9②。作成の日から5年）。また、1年契約の損害保険では「消滅＋5年」は作成から約6年で満了し、(2)より短い。
- **保存の終了日の換算**：「消滅日から5年」は、うるう日を1回含む場合1826日、2回含む場合1827日である。「10年」は、うるう日を2回含む場合3652日、3回含む場合3653日である（5年の期間には2月29日が1回または2回、10年の期間には2回または3回含まれる。ただし、うるう年でない2100年をまたぐ期間では1回少なくなり、5年で1825日、10年で3651日になりうる）。保存期間を日数で設定する場合は、多い方（5年＝1827日、10年＝3653日）を使えば不足しない。

§ 6.6 留意点・判断が必要な論点

#	論点	内容	必要な判断
INF1	契約に連動する保存期間の実装	(3)の保存期間は、契約の消滅という 将来の事象 から数える。書き込み時に保存期間を固定する方式（例：作成日から固定日数のオブジェクトロック）では表現できない。契約の存続中は保存を継続（リーガルホールド相当）し、消滅が確定した時点でN年の保存期間を設定する、という二段階の設計が必要である。契約データの変更履歴・操作履歴を、契約IDに紐づけて管理できることが前提になる	契約管理システムから「消滅日」を受け取り、保存期間を設定する仕組みを設けるか。消滅日が確定しない契約（終身保険など）の履歴を、どの単位でまとめて保存するか
INF2	「消滅」の範囲	失効（復活の可能性がある）、転換（旧契約の消滅と新契約の成立）、更新（1年契約の損害保険を毎年更新する場合、更新ごとに新契約とみるか）、解約・満期・保険金支払による消滅などで、起算点の扱いが変わる。条文は「保険契約が消滅した日」とだけ定めている	法務部門と、失効・転換・更新の扱いを決める。保守的には、復活可能期間の満了、転換後の新契約の消滅、更新を通算した最後の消滅を起算点とする
INF3	IN9①「保険年度の終了の日又は保険期間の終了の日」の読み方	「又は」が、保険年度ごとに数える（毎年度の記載はその年度末から10年）のか、早い方・遅い方のいずれかなのか、条文からは明らかでない。同じ構文が信託勘定元帳（規則52条の22第4項1号、信託業法施行規則39条）にもある。保険年度ごとの元帳をその保険年度の終了から数える読み方では、共通の下限とほぼ同じになる。「保険期間の終了から10年」は、いずれの読み方でも不足しない安全側の設定であり、長期保存と金融分野ガイドライン7条（ING10）の消去との兼ね合いも、法務部門の確認事項に含める	変額保険を扱う場合は、法務部門に確認する。確認までは、保守的に「保険期間の終了日から10年」とする
INF4	意向把握・募集記録の保存期間	意向把握の帳票・意向確認書面・高齢者募集の録音などは、法令上の保存期間がない（IN17・ING3・ING5）。監督指針は銀行等の募集記録を「保険期間が終了するまで」としている（ING4）	推奨案では「消滅+5年」としたが、ING4に合わせて「保険期間の終了まで」とする、または保険法95条（3年）に余裕を持たせた期間とする選択肢もある。紛争対応の必要性和、個人情報の消去（ING10）とのバランスで、法務・コンプライアンス部門が決める
INF5	事業者の種類による違い	特定保険募集人は「締結+5年」、保険仲立人・金融サービス仲介業者は「消滅+5年」と、起算点が異なる。一般の保険募集人には帳簿の保存義務自体がない（IN4）。代理店システムを複数の種類の事業者で共用する場合は、最も長い「消滅+5年」に揃えるのが安全である	対象システムの利用者が、どの種類の事業者に当たるかを確認する。規模要件（所属保険会社等15以上、手数料等10億円以上）は毎事業年度末に判定される（規則236条の2）ため、要件を満たした年度から帳簿の保存が必要になる点にも注意する
INF6	電磁的交付書面の改ざん防止（IN7・IN8）	閲覧の方法で交付した書面の電子データは、保存期間中「消去し又は改変することができないもの」でなければならない。これはログではなく交付データの要件だが、同じストレージ設計（WORM、改ざん検知）で満たすことが多い。顧客の指図による消去を認める必要がある	交付データの保存基盤を監査ログと共用するか。消去の指図の記録（誰が・いつ・何を消去したか）を(2)として残すか
INF7	保険会社の契約記録そのものの	保険会社が保有する保険契約のデータ（申込書、保険証券の控えなど）の保存期間を、保険業法令は直接定めていない（変額保険の特別勘定を除く）。会社法432条（J1）の「事業に関する重要な資料」に当たるかは解釈である	契約データとその変更履歴を(3)として「消滅+5年」とするか、「事業に関する重要な資料」として(2)の10年も満たすかを、法務部門と決める（推奨案は、遅く満了する方まで保存）

§ 6.7 未確認の一覧

#	項目	理由
1	規則75条の2第3項1号「保険年度の終了の日又は保険期間の終了の日」の公式な解釈	条文からは読み方が定まらない。金融庁のQ&A・パブリックコメント回答は調べていない（INF3）
2	「保険契約が消滅した日」に、失効・転換・更新がどう当たるかの公式な解釈	条文に定義がない。行政解釈は調べていない（INF2）
3	意向確認書面・意向把握帳票の保存期間に関する金融庁の解釈（パブリックコメント回答、Q&A）	監督指針の本文には期間の記載がないことを確認した。それ以外の公式資料は調べていない
4	保険業法・同法施行規則の帳簿書類を電磁的記録で保存する場合の要件（e-文書法に基づく金融庁所管の主務省令のうち、保険業法関係の部分）	e-文書法の金融関連施行規則の要件は、SC13（証券・資産運用編）（§5（証券・資産運用編））を参照する。保険業法の帳簿がどの条で電磁的保存の対象とされているかは、本資料では確認していない
5	少額短期保険業者に固有の帳簿書類の保存規定	保険業法施行規則の全文を「年間」「保存しなければならない」で検索した範囲では、少額短期保険業者に固有の保存期間の規定は見つからなかった。ただし、準用規定の網羅的な確認はしていない
6	「金融機関における個人情報保護に関するQ & A」（令和8年10月1日適用）	ログ・保存期間に関する記述の有無を調べていない

§ 6.8 対象外の一覧

名称	理由
生命保険協会の自主ガイドライン類（意向把握・確認、高齢者向け募集、代理店管理などに関するもの）	民間・業界団体の基準であり、法令・政府ガイドラインではない（個別の文書名・内容は確認していない）
日本損害保険協会の自主ガイドライン類（募集・代理店管理などに関するもの）	民間・業界団体の基準であり、法令・政府ガイドラインではない（個別の文書名・内容は確認していない）
生命保険協会・日本損害保険協会などが認定個人情報保護団体として定める個人情報保護指針	業界団体が定める指針であり、本資料の法令・政府ガイドラインの表の対象外
FISC「金融機関等コンピュータシステムの安全対策基準・解説書」	民間団体の有料の基準
ISO/IEC 27001、JIS Q 27001	有料の規格
PCI DSS	保険料のカード払いを扱う場合に関わる民間の基準
犯罪収益移転防止法の確認記録・取引記録	全業種共通の法令として§3で扱う（CM8・CM9。確認済み）